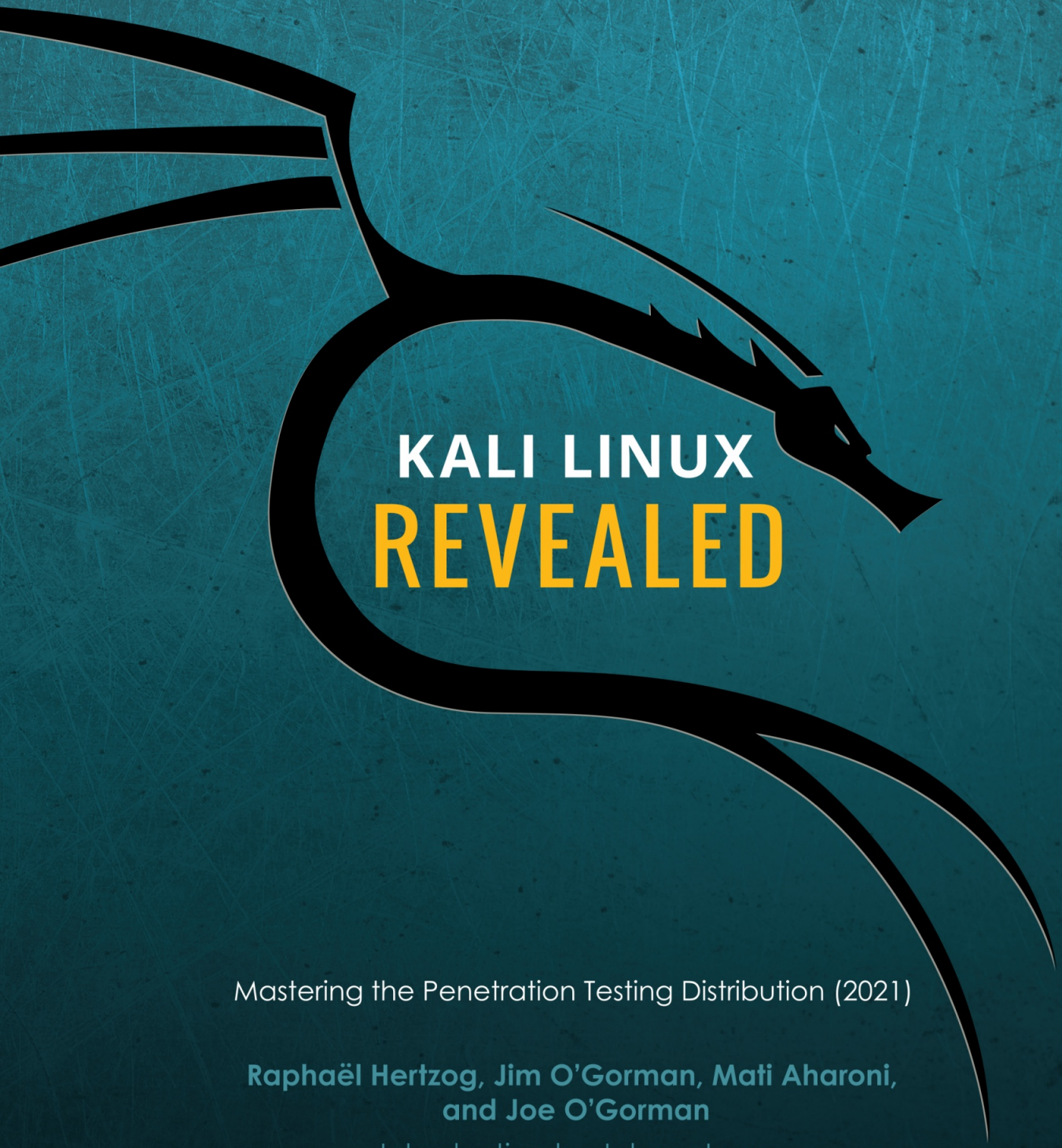
Machine Translated by Google



# KALI LINUX REVEALED

Mastering the Penetration Testing Distribution (2021)

**Raphaël Hertzog, Jim O'Gorman, Mati Aharoni, and Joe O'Gorman**

Introduction by Johnny Long

Machine Translated by Google

# Kali Linux Rivelato

## Padroneggiare il Penetration Testing Distribuzione (2021)

Machine Translated by Google

Machine Translated by Google

# Kali Linux Rivelato

## Padroneggiare il Penetration Testing Distribuzione (2021)

di Raphaël Hertzog, Jim O'Gorman, Mati Aharoni e Joe O'Gorman




OFFSEC PRESS

Machine Translated by Google

**Kali Linux svelato**

Copyright © 2021 Raphaël Hertzog, Jim O'Gorman, Mati Aharoni e Joe O'Gorman

Questo libro è distribuito con licenza Creative Commons Attribuzione-Condividi allo stesso modo 3.0 Unported.

ÿ https://creativecommons.org/licenses/by-sa/3.0/ Alcune sezioni

di questo libro riprendono contenuti dal "Manuale dell'amministratore Debian, Debian Jessie dalla scoperta alla padronanza", scritto da Raphaël Hertzog e Roland Mas, disponibile qui:

ÿ https://debian-handbook.info/browse/stable/

Ai fini della licenza CC-BY-SA, Kali Linux Revealed è un adattamento del Manuale dell'amministratore di Debian.

“Kali Linux” è un marchio registrato di Offensive Security. Qualsiasi utilizzo o distribuzione di questo libro, modificato o meno, deve essere conforme alla politica sui marchi registrata definita qui:

ÿ https://www.kali.org/trademark-policy/

Tutti i diritti non espressamente concessi sopra sono riservati.

ISBN: 978-0-9976156-0-9 (tascabile)

OffSec Press
230 Park Ave, 3° piano ovest
New York NY 10169
U.S.A.
www.offensive-security.com

Numero di controllo della Biblioteca del Congresso:

2017905895 Le informazioni contenute in questo libro sono distribuite "così come sono", senza alcuna garanzia. Sebbene siano state prese tutte le precauzioni nella preparazione di quest'opera, né gli autori né OffSec Press si assumono alcuna responsabilità nei confronti di persone o enti per qualsiasi perdita o danno causato o presumibilmente causato direttamente o indirettamente dalle informazioni in essa contenute.

Data la natura dinamica di Internet, gli indirizzi web o i link contenuti in questo libro potrebbero essere cambiati dalla data di pubblicazione e potrebbero non essere più validi.

Stampato negli Stati Uniti d'America.

Machine Translated by Google

# Sommario


**1. Informazioni su Kali Linux** 1

1.1 Un po' di storia . . . . . 2

1.2 Relazione con Debian 1.2.1 . . . . . 4

Il flusso dei pacchetti . . . . . 4

1.2.2 Gestire le differenze con Debian 1.3 Scopo . . . . . 5

e casi d'uso 1.4 Principali . . . . . 5

caratteristiche di Kali Linux . . . . . 8

1.4.1 Un sistema live . . . . . 8

1.4.2 Modalità forense . . . . . 8

1.4.3 Un kernel Linux personalizzato . . . . . 9

1.4.4 Completamente personalizzabile . . . . . 9

1.4.5 Un sistema operativo affidabile ... . . . . 9

1.4.6 Utilizzabile su una vasta gamma di dispositivi . . . . . 10

ARM 1.5 Politiche di Kali Linux . . . . . 10

1.5.1 Servizi di rete disabilitati per impostazione predefinita . . . . . 10

1.5.2 Una raccolta selezionata di applicazioni . . . . . 10

1.6 Sommario . . . . . 11

**2. Introduzione a Kali Linux** 13

2.1 Download di un'immagine ISO di Kali . . . . . 14

2.1.1 Dove scaricare . . . . . 14

2.1.2 Cosa scaricare . . . . . 14

2.1.3 Verifica dell'integrità e dell'autenticità . . . . . 17

Affidarsi al sito web protetto da TLS . . . . . 17

Affidarsi alla rete di fiducia di PGP . . . . . 17

2.1.4 Copia dell'immagine su un DVD-ROM o una chiavetta USB . . . . . 19

Creazione di un'unità USB avviabile con Kali su Windows . . . . . 19

Creazione di un'unità USB avviabile con Kali Linux . . . . . 21

Come creare un'unità USB avviabile con Kali Linux su OS X/macOS . . . . . 23

2.2 Avvio di un'immagine ISO di Kali in modalità Live . . . . . 24

2.2.1 Su un computer reale . . . . . 24

2.2.2 In una macchina virtuale . . . . . 24

Osservazioni preliminari . . . . . 25

Machine Translated by Google

VirtualBox . . . . . 25
Workstation VMware . . . . . 37
2.3 Sommario . . . . . 44
**3. Nozioni fondamentali su Linux** 47
3.1 Che cos'è Linux e cosa fa ? . . . . . 48
3.1.1 Componenti hardware di pilotaggio . . . . . 48
3.1.2 Unificazione dei file system . . . . . 49
3.1.3 Gestione dei processi . . . . . 50
3.1.4 Gestione dei diritti . . . . . 51
3.2 La riga di comando . . . . . 51
3.2.1 Come ottenere una riga di comando . . . . . 51
3.2.2 Nozioni di base della riga di comando: Esplorazione della struttura delle directory e gestione dei file . . . . . 52
3.3 Il file system . . . . . 54
3.3.1 Lo standard della gerarchia del filesystem . . . . . 54
3.3.2 La directory home dell'utente . . . . . 55
3.4 Comandi utili . . . . . 56
3.4.1 Visualizzazione e modifica dei file di testo . . . . . 56
3.4.2 Ricerca di file e all'interno dei file . . . . . 56
3.4.3 Gestione dei processi . . . . . 57
3.4.4 Gestione dei diritti . . . . . 57
3.4.5 Acquisizione di informazioni e registri di sistema . . . . . 60
3.4.6 Scoperta dell'hardware . . . . . 61
3.5 Riepilogo . . . . . 62
**4. Installazione di Kali Linux** 65
4.1 Requisiti minimi di installazione . . . . . 66
4.2 Installazione passo passo su un disco rigido . . . . . 66
4.2.1 Installazione semplice . . . . . 66
Avvio e avvio del programma di installazione . . . . . 66
Selezione della lingua . . . . . 67
Selezione del Paese . . . . . 68
Selezione del layout di tastiera ... . . . . 69
Rilevamento dell'hardware . . . . . 70
Caricamento dei componenti . . . . . 70
Rilevamento dell'hardware di rete . . . . . 71
Configurazione della rete . . . . . 71
Creazione utente . . . . . 72
Impostazione dell'orologio . . . . . 74
Rilevamento di dischi e altri dispositivi . . . . . 74
Partizionamento . . . . . 75
Copia dell'immagine live . . . . . 83

Machine Translated by Google

Configurazione del gestore di pacchetti (apt) . . . . . 84
Installazione dei metapackage . . . . . 85
Installazione del boot loader GRUB . . . . . 85
Completamento dell'installazione e riavvio . . . . . 88
4.2.2 Installazione su un file system completamente crittografato . . . . . 88
Introduzione a LVM . . . . . 89
Introduzione a LUKS . . . . . 89
Configurazione delle partizioni crittografate . . . . . 90
Fine della partizione guidata con LVM crittografato . . . . . 93
4.3 Installazioni non presidiate . . . . . 95
4.3.1 Preimpostazione delle risposte . . . . . 96
Con parametri di avvio . . . . . 96
Con un file preimpostato nell'Initrd . . . . . 96
Con un file preimpostato nel supporto di avvio . . . . . 96
Con un file preimpostato caricato dalla rete . . . . . 97
4.3.2 Creazione di un file preimpostato . . . . . 97
4.4 Installazioni ARM . . . . . 98
4.5 Risoluzione dei problemi di installazione . . . . . 99
4.6 Riepilogo . . . . . 104

**5. Configurazione di Kali Linux** 107
5.1 Configurazione della rete . . . . . 108
5.1.1 Sul desktop con NetworkManager . . . . . 108
5.1.2 Dalla riga di comando con Ifupdown . . . . . 109
5.1.3 Dalla riga di comando con systemd-networkd . . . . . 110
5.2 Gestione degli utenti e dei gruppi Unix . . . . . 112
5.2.1 Creazione di account utente . . . . . 112
5.2.2 Modifica di un account o di una password esistenti . . . . . 113
5.2.3 Disattivazione di un account . . . . . 113
5.2.4 Gestione dei gruppi Unix . . . . . 113
5.3 Configurazione dei servizi . . . . . 114
5.3.1 Configurazione di un programma specifico . . . . . 114
5.3.2 Configurazione di SSH per gli accessi remoti . . . . . 115
5.3.3 Configurazione dei database PostgreSQL . . . . . 115
Tipo di connessione e autenticazione del client . . . . . 116
Creazione di utenti e database . . . . . 116
Gestione dei cluster PostgreSQL . . . . . 117
5.3.4 Configurazione di Apache . . . . . 118
Configurazione degli host virtuali . . . . . 118
Direttive comuni . . . . . 119
5.4 Gestione dei servizi . . . . . 121
5.5 Riepilogo . . . . . 123

Machine Translated by Google


# 6. Aiutarsi da soli e chiedere aiuto 127

6.1 Fonti della documentazione . . . . . 128

6.1.1 Pagine del manuale . . . . . 128

6.1.2 Documenti informativi . . . . . 130

6.1.3 Documentazione specifica del pacchetto . . . . . 130

6.1.4 Siti web . . . . . 131

6.1.5 Documentazione di Kali disponibile su kali.org/docs/ . . . . . 131

6.2 Comunità Kali Linux . . . . . 132

6.2.1 Forum su forums.kali.org . . . . . 132

6.2.2 Canale IRC #kali-linux su Freenode . . . . . 133

6.3 Come presentare una buona segnalazione di bug . . . . . 134

6.3.1 Raccomandazioni generiche . . . . . 134

Come comunicare . . . . . 134

Cosa inserire nella segnalazione di bug ... . . . . 135

Suggerimenti vari . . . . . 136

6.3.2 Dove inviare una segnalazione di bug . . . . . 137

6.3.3 Come inviare una segnalazione di bug . . . . . 138

Segnalazione di bug in Kali . . . . . 138

Come inviare una segnalazione di bug in Debian . . . . . 142

Segnalazione di bug in un altro progetto di software libero . . . . . 148

6.4 Sommario . . . . . 151

# 7. Protezione e monitoraggio di Kali Linux 155

7.1 Definizione di una politica di sicurezza . . . . . 156

7.2 Possibili misure di sicurezza . . . . . 158

7.2.1 Su un server . . . . . 158

7.2.2 Su un laptop . . . . . 158

7.3 Protezione dei servizi di . . . . . 159

rete 7.4 Firewall o filtro pacchetti . . . . . 159

7.4.1 Comportamento del filtro di rete . . . . . 160

7.4.2 Sintassi di iptables e ip6tables . . . . . 163

Comandi . . . . . 163

Regole . . . . . 163

7.4.3 Creazione delle regole . . . . . 165

7.4.4 Installazione delle regole ad . . . . . 166

ogni avvio 7.5 Monitoraggio e registrazione . . . . . 167

7.5.1 Monitoraggio dei log con logcheck . . . . . 167

7.5.2 Monitoraggio dell'attività in tempo reale . . . . . 168

7.5.3 Rilevamento dei cambiamenti . . . . . 169

Verifica dei pacchetti con dpkg --verify . . . . . 169

Monitoraggio dei file: . . . . . 170

Riepilogo AIDE 7.6 . . . . . 171

Machine Translated by Google


# 8. Gestione dei pacchetti Debian 175

8.1 Introduzione ad APT . . . . . 176

8.1.1 Relazione tra APT e dpkg . . . . . 176

8.1.2 Comprensione del file sources.list . . . . . 178

8.1.3 Repository Kali . . . . . 179

Il repository Kali-Rolling ... . . . . 179

Il repository Kali-Dev ... . . . . 180

Mirror di Kali Linux . . . . . 180

8.2 Interazione di base con i pacchetti . . . . . 181

8.2.1 Inizializzazione . . . . . 181

di APT 8.2.2 Installazione dei pacchetti . . . . . 182

Installazione dei pacchetti con dpkg . . . . . 182

Installazione dei pacchetti con APT . . . . . 183

8.2.3 Aggiornamento di Kali Linux . . . . . 184

8.2.4 Rimozione e pulizia dei pacchetti ... . . . . 186

8.2.5 Ispezione dei pacchi . . . . . 187

Interrogazione del database di dpkg e ispezione dei file .deb . . . . . 187

Interrogazione del database dei pacchetti disponibili con apt-cache e apt . . . . . 191

8.2.6 Risoluzione dei problemi . . . . . 192

Gestione dei problemi dopo un aggiornamento . . . . . 193

Il file di registro di dpkg . . . . . 194

Reinstallazione dei pacchetti con apt --reinstall e aptitude reinstall . . . . . 194

Sfruttare --force-* per riparare le dipendenze interrotte . . . . . 195

8.2.7 Frontend: attitudine e sinapsi . . . . . 196

Attitudine . . . . . 196

Sinaptico . . . . . 199

8.3 Configurazione e utilizzo avanzati di APT . . . . . 200

8.3.1 Configurazione di . . . . . 200

APT 8.3.2 Gestione delle priorità dei pacchetti . . . . . 202

8.3.3 Lavorare con diverse distribuzioni . . . . . 204

8.3.4 Monitoraggio dei pacchetti installati automaticamente . . . . . 205

8.3.5 Sfruttare il supporto multi-arco . . . . . 206

Abilitazione Multi-Arch . . . . . 206

Modifiche relative a architetture multiple . . . . . 207

8.3.6 Convalida dell'autenticità del pacchetto ... . . . . 208

8.4 Riferimento ai pacchetti APT: Approfondimento sul sistema di pacchetti Debian . . . . . 210

8.4.1 Il file di controllo . . . . . 211

Dipendenze: il campo Dipende . . . . . 212

Pre-Depends, un Depends più esigente . . . . . 213

Raccomanda, suggerisce e migliora i campi . . . . . 214

Conflitti: il campo dei conflitti . . . . . 214

Machine Translated by Google

Incompatibilità: il campo delle rotture . . . . . 214
Elementi forniti: il campo Fornisce . . . . . 215
Sostituzione dei file: il campo Sostituisce . . . . . 216
8.4.2 Script di configurazione . . . . . 217
Sequenza di script per l'installazione e l'aggiornamento . . . . . 219
Rimozione del pacco . . . . . 219
8.4.3 Checksum, Confili . . . . . 220
8.5 Sommario . . . . . 222
9. Utilizzo avanzato 227
9.1 Modifica dei pacchetti Kali . . . . . 228
9.1.1 Reperire le fonti . . . . . 229
9.1.2 Installazione delle dipendenze di compilazione . . . . . 231
9.1.3 Apportare modifiche . . . . . 232
Applicazione di una toppa . . . . . 233
Modifica delle opzioni di compilazione . . . . . 234
Confezionamento di una nuova versione a monte . . . . . 235
9.1.4 Avvio della compilazione . . . . . 236
9.2 Ricompilazione del kernel Linux . . . . . 237
9.2.1 Introduzione e prerequisiti . . . . . 238
9.2.2 Ottenere le fonti . . . . . 238
9.2.3 Configurazione del . . . . . 239
kernel 9.2.4 Compilazione e creazione del pacchetto . . . . . 241
9.3 Creazione di immagini ISO live personalizzate di Kali . . . . . 241
9.3.1 Installazione dei prerequisiti . . . . . 242
9.3.2 Creazione di immagini live con diversi ambienti desktop . . . . . 242
9.3.3 Modifica dell'insieme dei pacchetti installati . . . . . 243
9.3.4 Utilizzo degli hook per modificare il contenuto dell'immagine . . . . . 245
9.3.5 Aggiunta di file nell'immagine ISO o nel filesystem live . . . . . 245
9.4 Aggiunta della persistenza all'immagine ISO live tramite chiavetta USB . . . . . 246
9.4.1 La funzionalità di persistenza: spiegazioni . . . . . 246
9.4.2 Configurazione della persistenza non crittografata su una chiavetta USB . . . . . 247
9.4.3 Configurazione della persistenza crittografata su una chiavetta USB . . . . . 248
9.4.4 Utilizzo di più archivi di . . . . . 249
persistenza 9.5 Riepilogo . . . . . 251
9.5.1 Riepilogo Suggerimenti per la modifica dei pacchetti Kali . . . . . 251
9.5.2 Riepilogo Suggerimenti per la ricompilazione del kernel Linux . . . . . 252
9.5.3 Riepilogo Suggerimenti per la creazione di immagini ISO live personalizzate di Kali . . . . . 253
10. Kali Linux in ambito aziendale 257
10.1 Installazione di Kali Linux tramite rete (avvio PXE) . . . . . 258
10.2 Sfruttare la gestione della configurazione . . . . . 261

Machine Translated by Google

10.2.1 Configurazione di SaltStack . . . . . 261
10.2.2 Esecuzione di comandi sui Minion . . . . . 262
10.2.3 Stati del sale e altre caratteristiche . . . . . 264
10.3 Estensione e personalizzazione di Kali Linux . . . . . 268
10.3.1 Creazione di fork dei pacchetti Kali . . . . . 268
10.3.2 Creazione di pacchetti di configurazione . . . . . 269
10.3.3 Creazione di un repository di pacchetti per APT . . . . . 275
10.4 Riepilogo . . . . . 279
11. Introduzione alle valutazioni di sicurezza 283
11.1 Kali Linux in una valutazione . . . . . 285
11.2 Tipologie di valutazioni . . . . . 287
11.2.1 Valutazione della vulnerabilità . . . . . 288
Probabilità di accadimento . . . . . 291
Impatto . . . . . 291
Rischio complessivo . . . . . 291
In sintesi . . . . . 292
11.2.2 Test di penetrazione di conformità . . . . . 292
11.2.3 Test di penetrazione tradizionale . . . . . 293
11.2.4 Valutazione dell'applicazione . . . . . 295
11.3 Formalizzazione della valutazione . . . . . 297
11.4 Tipi di attacchi . . . . . 298
11.4.1 Negazione del servizio . . . . . 298
11.4.2 Corruzione della memoria . . . . . 299
11.4.3 Vulnerabilità Web . . . . . 300
11.4.4 Attacchi alle password . . . . . 300
11.4.5 Attacchi lato client . . . . . 301
11.5 Sommario . . . . . 301
12. Conclusione: La strada da percorrere 305
12.1 Tenersi al passo con i cambiamenti . . . . . 306
12.2 Mettere in mostra le nuove conoscenze acquisite . . . . . 306
12.3 Andare oltre . . . . . 307
12.3.1 Verso l'amministrazione del sistema . . . . . 307
12.3.2 Verso il penetration testing . . . . . 307
Indice 308

Machine Translated by Google

Machine Translated by Google

# Prefazione

Non hai idea di quanto tu sia fortunato.

Nel 1998 ero un hacker emergente, co-fondatore di uno dei primi team di hacker etici professionisti. Eravamo dei ragazzi, in realtà, con un lavoro da sogno, pagati per penetrare in alcuni dei sistemi informatici, reti ed edifici più sicuri del pianeta.

Sembra piuttosto affascinante, ma in realtà passavamo la maggior parte del tempo chini su una tastiera, armati degli strumenti digitali del nostro mestiere. Utilizzavamo una squallida collezione di programmi, progettati per mappare le reti e individuare i bersagli; poi scansionarli, sfruttarne le vulnerabilità e muoverci al loro interno. In alcuni casi, uno di noi (spesso Jim Chapple) scriveva strumenti personalizzati per fare cose incredibili come scansionare una rete di Classe A (cosa che nessun altro strumento era in grado di fare, all'epoca), ma il più delle volte usavamo o modificavamo strumenti scritti dalla comunità degli hacker. In quei tempi pre-Google, frequentavamo BugTraq, AstaLaVista, Packet Storm, w00w00, SecurityFocus, X-Force e altre risorse per condurre ricerche e ampliare il nostro arsenale.

Avendo a disposizione un tempo limitato per ogni incarico, dovevamo muoverci velocemente. Questo significava che non potevamo perdere tempo a smanettare con gli strumenti. Significava che dovevamo imparare a conoscere a fondo gli strumenti principali e tenere a portata di mano quelli ausiliari, per ogni evenienza. Significava che dovevamo avere i nostri strumenti ben organizzati, documentati e testati, in modo da ridurre al minimo le sorprese sul campo. Dopotutto, se non fossimo riusciti a portare a termine il lavoro, avremmo perso la faccia con i nostri clienti e avrebbero preso molto meno sul serio i nostri consigli.

Per questo motivo, ho dedicato molto tempo alla catalogazione degli strumenti. Quando uno strumento veniva rilasciato o aggiornato, seguivo una procedura specifica. Dovevo verificare se funzionasse sulla piattaforma di attacco (alcuni non funzionavano) e se valesse la pena utilizzarlo (alcuni no); dovevo aggiornare tutti gli script che ne dipendevano, documentarlo e testarlo, includendo anche il trasferimento di eventuali modifiche apportate alla versione precedente.

Quindi, tiravo fuori tutti gli strumenti e li organizzavo in cartelle in base alla loro funzione durante una valutazione. Scrivevo script wrapper per determinati strumenti, ne concatenavo alcuni e correlavo il tutto in un CD separato che potevamo portare in aree sensibili, quando i clienti non ci permettevano di portare macchine di attacco o di prelevare supporti dai loro laboratori.

Questo processo è stato doloroso, ma necessario. Sapevamo di avere la capacità di penetrare in qualsiasi rete, a patto di applicare correttamente le nostre competenze e la nostra esperienza, di rimanere organizzati e di lavorare in modo efficiente.
Sebbene rimanere imbattuti fosse una motivazione, l'obiettivo principale era fornire un servizio ai clienti che *avevano bisogno* del nostro intervento per penetrare nelle reti, in modo da poter colmare le lacune e destinare fondi a programmi di sicurezza informatica cruciali ma trascurati.

Machine Translated by Google

Abbiamo dedicato anni ad affinare le nostre competenze e la nostra esperienza, ma non avremmo avuto successo senza organizzazione ed efficienza. Avremmo fallito se non fossimo stati in grado di reperire lo strumento giusto al momento giusto.

Ecco perché ho dedicato così tanto tempo alla ricerca, alla documentazione, al test e alla catalogazione degli strumenti, e all'inizio del XXI secolo, questo lavoro si stava rapidamente trasformando in un impegno a tempo pieno e gravoso. Grazie a Internet, la superficie di attacco globale è esplosa e la varietà e il numero di strumenti di attacco sono aumentati esponenzialmente, così come il carico di lavoro necessario per la loro manutenzione.

A partire dal 2004, Internet ha conosciuto un'esplosione, diventando non solo la base per le attività commerciali, ma anche una piattaforma sociale. I computer sono diventati più accessibili, più facili da usare e onnipresenti. La tecnologia di archiviazione si è espansa dai megabyte ai gigabyte. Ethernet è passata da centinaia di kilobit a decine di megabit al secondo e le connessioni Internet sono diventate più veloci ed economiche che mai. L'e-commerce era in piena espansione, i social media come Facebook (2004) e Twitter (2006) sono approdati online e Google (1998) era maturato al punto che chiunque (compresi i criminali) poteva trovare praticamente qualsiasi cosa su Internet.

La ricerca è diventata fondamentale per team come il nostro, perché dovevamo stare al passo con i nuovi attacchi e gli strumenti a nostra disposizione. Dovevamo far fronte a un numero sempre maggiore di crimini informatici e il lavoro di analisi forense ci imponeva di procedere con cautela nell'esaminare le potenziali prove. Il concetto di *Live CD* ci ha permesso di eseguire analisi forensi in tempo reale su una macchina compromessa senza compromettere le prove.

Ora il nostro piccolo team doveva gestire strumenti di attacco, strumenti forensi e la distribuzione di strumenti per aree sensibili; dovevamo stare al passo con tutte le metodologie di attacco e di sfruttamento più recenti; e dovevamo, ovviamente, fare quello per cui venivamo pagati: i penetration test, che erano molto richiesti. La situazione stava sfuggendo di mano e, in breve tempo, passavamo meno tempo in battaglia e molto più tempo a fare ricerca, affinare i nostri strumenti e pianificare.

Non eravamo soli in questa lotta. Nel 2004, Mati "Muts" Aharoni, un hacker e professionista della sicurezza, pubblicò "WHoppiX" (White Hat Knoppix), un Live CD di Linux che definì "il Live CD definitivo per il penetration testing". Includeva "tutti gli exploit di SecurityFocus, Packet Storm e k-otik, Metasploit Framework 2.2 e molto, molto altro".

Ricordo di aver scaricato WHoppiX e di aver pensato che fosse una cosa fantastica da avere a disposizione. Ho scaricato anche altri CD live, pensando che se mi fossi trovato in una situazione davvero difficile, i CD live avrebbero potuto salvarmi la pelle sul campo. Ma non avevo intenzione di affidarmi a WHoppiX o a qualsiasi altro CD per il mio lavoro vero e proprio. Non mi fidavo di nessuno di loro per soddisfare la maggior parte delle mie esigenze; nessuno mi sembrava adatto al mio flusso di lavoro; non erano distribuzioni complete e installabili; e nel momento stesso in cui li scaricavo erano già obsoleti. Un set di strumenti obsoleto è la rovina nel nostro settore.

Ho semplicemente aggiunto queste immagini CD, nonostante le loro dimensioni relativamente enormi, al nostro arsenale e ho continuato il faticoso processo di manutenzione del nostro kit di strumenti "reale".

Ma, nonostante le mie opinioni personali dell'epoca, e forse anche nonostante le aspettative di Muts, WHoppiX e i suoi successori hanno avuto un impatto epocale sulla sua vita, sul nostro settore e sulla nostra comunità.

Machine Translated by Google

Nel 2005, WHoppiX si è evoluto in WHAX, con un set di strumenti ampliato e aggiornato, basato sul "CD live SLAX (Slackware) più modulare". Muts e un team crescente di volontari della comunità hacker sembravano aver capito che, per quanto perspicaci fossero, non avrebbero mai potuto prevedere tutta la crescita e le fluttuazioni del nostro settore e che gli utenti del loro CD avrebbero avuto esigenze diverse sul campo. Era evidente che Muts e il suo team stessero effettivamente utilizzando WHAX sul campo e sembravano determinati a farlo funzionare. Questo mi ha incoraggiato.

Nel 2006, Muts, Max Moser e i loro team unificarono Auditor Security Linux e WHAX in un'unica distribuzione chiamata BackTrack. Pur rimanendo basata su SLAX, BackTrack continuò a crescere, aggiungendo nuovi strumenti, framework, un supporto linguistico esteso, un supporto wireless completo, una struttura di menu adatta sia agli utenti principianti che a quelli esperti e un kernel pesantemente modificato. BackTrack divenne la distribuzione di sicurezza leader del settore, ma molti, come me, la utilizzavano ancora come backup per i loro "veri strumenti".

All'inizio del 2009, Muts e il suo team avevano esteso significativamente BackTrack, arrivando alla versione 4. BackTrack, che per Muts era diventato un lavoro a tempo pieno, non era più un CD live, ma una vera e propria distribuzione basata su Ubuntu, che sfruttava i repository software di Ubuntu. Questo cambiamento segnò una seria evoluzione: BackTrack 4 disponeva di un meccanismo di aggiornamento. Nelle parole di Muts: "Sincronizzando con i nostri repository BackTrack, riceverete regolarmente aggiornamenti degli strumenti di sicurezza poco dopo il loro rilascio."

Questo è stato un punto di svolta. Il team di BackTrack aveva compreso le difficoltà affrontate dai penetration tester, dagli analisti forensi e da altri professionisti del nostro settore. Il loro impegno ci avrebbe fatto risparmiare innumerevoli ore e ci avrebbe fornito una solida base, permettendoci di tornare a concentrarci sul lavoro e dedicare più tempo alle attività importanti (e divertenti). Di conseguenza, la community ha risposto con entusiasmo, affollando i forum e la wiki e contribuendo attivamente al team di sviluppo. BackTrack è stato un vero e proprio progetto comunitario, con Muts ancora in prima linea.

BackTrack 4 era finalmente diventato una piattaforma di livello industriale e io, come molti altri, tirammo un sospiro di sollievo. Conoscevamo in prima persona le "difficoltà e le sofferenze" che Muts e il suo team stavano affrontando, perché le avevamo vissute in prima persona. Di conseguenza, molti di noi iniziarono a usare BackTrack come base principale per il proprio lavoro. Certo, continuavamo a smanettare con gli strumenti, a scrivere il nostro codice e a sviluppare i nostri exploit e tecniche; facevamo ricerche e sperimentazioni; ma non passavamo tutto il tempo a raccogliere, aggiornare, validare e organizzare strumenti.

BackTrack 4 R1 e R2 rappresentarono ulteriori revisioni nel 2010, che portarono alla ricostruzione completa di BackTrack 5 nel 2011. Ancora basato su Ubuntu, e con una crescita esponenziale a ogni nuova versione, BackTrack era ormai diventato un progetto imponente che richiedeva un impegno eroico da parte di volontari e della comunità, oltre a ingenti finanziamenti. Muts ha lanciato Offensive Security (nel 2006) non solo per fornire servizi di formazione e penetration testing di livello mondiale, ma anche per creare uno strumento che consentisse lo sviluppo continuo di BackTrack e garantisse che BackTrack rimanesse open source e gratuito.

BackTrack ha continuato a crescere e a migliorare nel corso del 2012 (con le versioni R1, R2 e R3), mantenendo un nucleo basato su Ubuntu e aggiungendo centinaia di nuovi strumenti, tra cui strumenti per lo sfruttamento di vulnerabilità fisiche e hardware, supporto per VMware, innumerevoli driver wireless e hardware e una moltitudine di miglioramenti alla stabilità e correzioni di bug. Tuttavia, dopo il rilascio della versione R3, lo sviluppo di BackTrack si è interrotto in modo relativamente, e alquanto misterioso, silenzioso.

Machine Translated by Google

Nel settore circolavano alcune voci. Alcuni pensavano che BackTrack stesse per essere "acquistata", che stesse vendendo la sua anima a un'anonima e malvagia multinazionale in cambio di un'ingente somma di denaro. Offensive Security si stava affermando come una delle società di formazione più rispettate e un punto di riferimento nel nostro settore, e alcuni ipotizzavano che il suo successo avesse inghiottito e messo da parte gli sviluppatori chiave di BackTrack. Tuttavia, niente poteva essere più lontano dalla verità.

Nel 2013 è stata rilasciata la versione 1.0 di Kali Linux. Dalle note di rilascio: "Dopo un anno di sviluppo silenzioso, Offensive Security è orgogliosa di annunciare il rilascio e la disponibilità pubblica di Kali Linux, la distribuzione per penetration testing più avanzata, robusta e stabile fino ad oggi. Kali è una versione di BackTrack più matura, sicura e pronta per l'uso aziendale."

Kali Linux non era una semplice riedizione di BackTrack. Con oltre 600 strumenti completamente rielaborati, era chiaramente un set di strumenti straordinario, ma c'era ancora di più. Kali era stato costruito, da zero, su un kernel Debian. Per i non esperti, questo potrebbe non sembrare un grande risultato. Ma gli effetti a catena furono sbalorditivi. Grazie a un massiccio lavoro di rielaborazione, gli utenti di Kali potevano scaricare il codice sorgente di ogni singolo strumento; potevano modificare e ricompilare uno strumento secondo necessità, con pochi semplici clic. A differenza degli altri sistemi operativi più diffusi dell'epoca, Kali Linux si sincronizzava con i repository Debian quattro volte al giorno, il che significava che gli utenti di Kali potevano ottenere aggiornamenti dei pacchetti e correzioni di sicurezza estremamente recenti. Gli sviluppatori di Kali si sono dedicati con impegno al packaging e alla manutenzione delle versioni upstream di molti strumenti, in modo che gli utenti fossero sempre all'avanguardia. Grazie alle sue radici Debian, gli utenti di Kali potevano avviare un'installazione o un'immagine ISO direttamente dai repository, aprendo la strada a installazioni di Kali completamente personalizzate o a implementazioni aziendali su larga scala, ulteriormente automatizzabili e personalizzabili con file di preimpostazione. Per completare il trio di personalizzazione, gli utenti di Kali potevano modificare l'ambiente desktop, alterare i menu, cambiare le icone e persino sostituire gli ambienti delle finestre. Un massiccio impulso allo sviluppo ARM ha aperto le porte all'installazione di Kali Linux su un'ampia gamma di piattaforme hardware, inclusi access point, computer a scheda singola (Raspberry Pi, ODROID, BeagleBone e CubieBoard, ad esempio) e Chromebook basati su ARM. Infine, ma non meno importante, Kali Linux offriva aggiornamenti minori e maggiori senza interruzioni, il che significava che gli appassionati non avrebbero mai dovuto reinstallare configurazioni personalizzate di Kali Linux.

La comunità se n'è accorta. Nei primi cinque giorni, 90.000 di noi hanno scaricato Kali 1.0.

Questo fu solo l'inizio. Nel 2015 venne rilasciata Kali 2.0, seguita dalle versioni rolling release del 2016.
In sintesi, "Se Kali 1.0 si concentrava sulla costruzione di una solida infrastruttura, Kali 2.0 si concentra sulla revisione completa dell'esperienza utente e sul mantenimento di pacchetti e repository di strumenti aggiornati."

La versione attuale di Kali Linux è una distribuzione rolling release, che segna la fine delle versioni discrete. Ora gli utenti sono costantemente aggiornati e ricevono aggiornamenti e patch non appena vengono rilasciati.
Gli strumenti principali vengono aggiornati più frequentemente grazie a un sistema di etichettatura delle versioni upstream, sono stati implementati miglioramenti rivoluzionari per l'accessibilità per i non vedenti e i kernel Linux vengono aggiornati e patchati per continuare il supporto all'iniezione wireless 802.11. Gli strumenti Software Defined Radio (SDR) e Near-Field Communication (NFC) aggiungono il supporto per nuovi campi di test di sicurezza. Sono disponibili opzioni complete di installazione di dischi Linux crittografati e di autodistruzione di emergenza.

Machine Translated by Google

Grazie rispettivamente a LVM e LUKS, sono state aggiunte opzioni di persistenza USB, che consentono alle installazioni di Kali su USB di mantenere le modifiche tra un riavvio e l'altro, indipendentemente dal fatto che l'unità USB sia crittografata o meno. Infine, le ultime revisioni di Kali hanno aperto le porte a NetHunter, un sistema operativo open source di livello mondiale che gira su dispositivi mobili basati su Kali Linux e Android.

Kali Linux si è evoluto non solo fino a diventare la piattaforma preferita dai professionisti della sicurezza informatica, ma anche una vera e propria distribuzione di sistema operativo di livello industriale, di livello mondiale, matura, sicura e pronta per le aziende.

Nel corso di un decennio di sviluppo, Muts e il suo team, insieme all'instancabile dedizione di innumerevoli volontari della comunità hacker, si sono assunti l'onere di semplificare e organizzare il nostro ambiente di lavoro, liberandoci da gran parte delle attività più gravose e fornendoci una base sicura e affidabile, che ci permette di concentrarci sul far progredire il settore verso l'obiettivo finale di proteggere il nostro mondo digitale.

E, cosa interessante ma non sorprendente, attorno a Kali Linux si è creata una comunità straordinaria.
Ogni mese, da trecentomila a quattrocentomila di noi scaricano una versione di Kali. Ci ritroviamo sui forum di Kali, che contano circa quarantamila membri, e da trecento a quattrocento di noi sono presenti contemporaneamente sul canale IRC di Kali. Partecipiamo a conferenze e incontri Kali Dojo per imparare dagli sviluppatori stessi come sfruttare al meglio Kali.

Kali Linux ha cambiato in meglio il mondo della sicurezza informatica e Muts e il suo team ci hanno risparmiato innumerevoli ore di fatica e frustrazione, permettendoci di dedicare più tempo ed energie a far progredire il settore, insieme.

Nonostante la sua straordinaria diffusione, il supporto e la popolarità, Kali non ha mai pubblicato un manuale ufficiale. Bene, ora le cose sono cambiate. Sono entusiasta di aver collaborato con il team di sviluppo di Kali, e in particolare con Mati Aharoni, Raphaël Hertzog, Devon Kearns e Jim O'Gorman, per offrire questo, il primo di una serie di pubblicazioni ufficiali dedicate a Kali Linux. In questo libro, ci concentreremo sulla piattaforma Kali Linux stessa e vi aiuteremo a comprenderla e a sfruttarla al meglio partendo dalle basi. Non approfondiremo ancora l'insieme degli strumenti inclusi in Kali Linux, ma che siate veterani o principianti assoluti, questo è il punto di partenza ideale se siete pronti ad approfondire e a fare sul serio con Kali Linux. Indipendentemente dalla vostra esperienza, la decisione di leggere questo libro vi connetterà alla crescente comunità di Kali Linux, una delle più antiche, grandi, attive e vivaci del nostro settore.

A nome di Muts e di tutto il fantastico team di Kali, congratulazioni per aver compiuto il primo passo verso la padronanza di Kali Linux!

Johnny Long,

febbraio 2017

Machine Translated by Google

Machine Translated by Google

# Prefazione

I sedici laptop di fascia alta ordinati per il tuo team di penetration testing sono appena arrivati e il tuo compito è configurarli per l'incontro fuori sede di domani. Installi Kali e avvii uno dei laptop, solo per scoprire che è a malapena utilizzabile. Nonostante il kernel all'avanguardia di Kali, le schede di rete e il mouse non funzionano e la potente scheda grafica NVIDIA con la GPU ti fissano con lo sguardo perso nel vuoto, perché mancano i driver installati correttamente. Sospiri.

In *modalità Kali Live,* digiti velocemente lspci nella console, poi socchiudi gli occhi. Scorri l'elenco dell'hardware: "Ponte PCI, controller USB, controller SATA. Aha! Controller Ethernet e di rete." Una rapida ricerca su Google dei rispettivi numeri di modello, incrociati con la versione del kernel di Kali, rivela che questi driver all'avanguardia non sono ancora stati integrati nel kernel principale.

Ma non tutto è perduto. Un piano sta lentamente prendendo forma nella tua testa e ringrazi il cielo per il libro *"Kali Linux Revealed"* che hai preso in mano un paio di settimane fa. Potresti usare il sistema Kali Live-Build per creare un'immagine ISO di Kali personalizzata, che includerebbe i driver necessari nel supporto di installazione. Inoltre, potresti includere i driver grafici NVIDIA e le librerie CUDA necessarie per far comunicare quella bestia di GPU con hashcat e farla ronzare mentre decifra gli hash delle password a velocità incredibili. Potresti persino aggiungere uno sfondo personalizzato con il logo Microsoft, per prendere in giro i tuoi colleghi di lavoro.

Poiché i profili hardware per le vostre installazioni sono identici, aggiungete un'opzione di avvio preconfigurata all'immagine ISO, in modo che il vostro team possa avviare il sistema da una chiavetta USB e avere Kali installato senza alcuna interazione da parte dell'utente: l'installazione si gestisce automaticamente, inclusa la crittografia completa del disco.

Perfetto! Ora puoi generare una versione aggiornata di Kali su richiesta, progettata e ottimizzata specificamente per il tuo hardware. Hai risolto la situazione. Missione compiuta!

Con la valanga di hardware che invade il mercato, questo scenario sta diventando sempre più comune per chi, come noi, si allontana dai sistemi operativi più diffusi, alla ricerca di qualcosa di più snello, potente o più adatto al proprio lavoro e al proprio stile.

Questo vale soprattutto per coloro che sono attratti dal settore della sicurezza informatica, che si tratti di un hobby affascinante, di una passione o di una professione. Come neofiti, spesso si trovano disorientati dall'ambiente o dal sistema operativo. Per molti, Kali rappresenta il primo approccio a Linux.

Abbiamo riconosciuto questo cambiamento nella nostra base di utenti un paio di anni fa e abbiamo pensato che avremmo potuto aiutare la nostra comunità creando un libro introduttivo strutturato che guidasse gli utenti nel mondo

Machine Translated by Google

di sicurezza, fornendo al contempo tutta la sofisticatezza di Linux necessaria per iniziare. E così è nato il libro su Kali, ora disponibile gratuitamente su Internet a beneficio di chiunque sia interessato ad entrare nel campo della sicurezza tramite Kali Linux.

Tuttavia, man mano che il libro prendeva forma, ci siamo presto resi conto che c'era un potenziale inespresso. Questa sarebbe un'ottima opportunità per andare oltre un libro introduttivo su Kali Linux ed esplorare alcune delle funzionalità più interessanti e meno conosciute. Da qui il titolo del libro: *Kali Linux Revealed (Kali Linux svelato).*

Alla fine, eravamo entusiasti del risultato. Il libro ha soddisfatto tutte le nostre esigenze e sono orgoglioso di dire che ha superato le nostre aspettative. Ci siamo resi conto di aver inavvertitamente ampliato la potenziale base di utenti del libro. Non era più destinato solo ai neofiti nel campo della sicurezza, ma includeva anche ottime informazioni per i penetration tester esperti che avevano bisogno di migliorare e perfezionare la loro conoscenza di Kali Linux, consentendo loro di sbloccare tutto il potenziale della nostra distribuzione. Che si trattasse di gestire una singola macchina o migliaia in un'azienda, di apportare piccole modifiche alla configurazione o di personalizzare completamente fino al livello del kernel, di creare i propri repository, di rimanere in superficie o di addentrarsi nel fantastico sistema di gestione dei pacchetti Debian, *Kali Linux Revealed* fornisce la roadmap.

Con la mappa in mano, a nome mio e dell'intero team di Kali Linux, vi auguro un viaggio emozionante, divertente, proficuo e "rivelatore"!

Meticci

Febbraio 2017

Machine Translated by Google

# Introduzione

Kali Linux è la piattaforma di penetration testing più potente e diffusa al mondo, utilizzata da professionisti della sicurezza in un'ampia gamma di specializzazioni, tra cui penetration testing, analisi forense, reverse engineering e valutazione delle vulnerabilità. È il culmine di anni di perfezionamento e il risultato di una continua evoluzione della piattaforma, da WHoppiX a WHAX, a BackTrack, fino ad arrivare a un framework completo per il penetration testing che sfrutta molte funzionalità di Debian GNU/Linux e la vivace comunità open source a livello globale.

Kali Linux non è stato concepito come una semplice raccolta di strumenti, bensì come un framework flessibile che i penetration tester professionisti, gli appassionati di sicurezza, gli studenti e i dilettanti possono personalizzare in base alle proprie esigenze specifiche.

## Perché questo libro?

Kali Linux non è semplicemente una raccolta di vari strumenti di sicurezza informatica installati su una base Debian standard e preconfigurati per essere subito operativi. Per sfruttare al meglio Kali, è importante avere una conoscenza approfondita delle sue potenti fondamenta Debian GNU/Linux (che supportano tutti questi ottimi strumenti) e imparare come utilizzarle nel proprio ambiente.

Sebbene Kali sia decisamente versatile, è progettato principalmente per agevolare i test di penetrazione. L'obiettivo di questo libro non è solo quello di farti sentire a tuo agio nell'utilizzo di Kali Linux, ma anche di migliorare la tua comprensione e ottimizzare la tua esperienza, in modo che, quando ti trovi impegnato in un penetration test e il tempo è un fattore critico, non dovrai preoccuparti di perdere minuti preziosi per installare nuovi software o abilitare nuovi servizi di rete. In questo libro, ti introdurremo prima a Linux, per poi approfondire le peculiarità di Kali Linux, in modo che tu sappia esattamente cosa succede "sotto il cofano".

Si tratta di una conoscenza preziosa, soprattutto quando si lavora con tempi ristretti. Non è raro aver bisogno di questo livello di conoscenza durante la fase di configurazione, la risoluzione di un problema, la difficoltà nell'adattare uno strumento alle proprie esigenze, l'analisi dell'output di uno strumento o l'utilizzo di Kali in un ambiente su larga scala.

Machine Translated by Google

## Questo libro fa per te?

Se desiderate immergervi nel campo, ricco di spunti intellettuali e incredibilmente affascinante, della sicurezza informatica e avete giustamente scelto Kali Linux come piattaforma principale, questo libro vi accompagnerà in questo percorso. È pensato per chi si avvicina a Linux per la prima volta, per gli utenti Kali che desiderano approfondire la conoscenza dei fondamenti di Kali e per coloro che utilizzano Kali da anni e vogliono consolidare le proprie competenze, ampliare le proprie capacità e colmare eventuali lacune.

Inoltre, questo libro può servire da guida, riferimento tecnico e manuale di studio per coloro che intendono conseguire la certificazione Kali Linux Certified Professional.

## Approccio generale e struttura del libro

Questo libro è stato concepito in modo che tu possa cimentarti con Kali Linux fin dalle prime fasi.
Non è necessario leggere metà del libro per iniziare. Ogni argomento è trattato in modo molto pragmatico e il libro è ricco di esempi e schermate per rendere le spiegazioni più concrete.

Nel capitolo 1, "Informazioni su Kali Linux" [pagina 2], definiamo alcuni termini di base e spieghiamo lo scopo di Kali Linux. Nel capitolo 2, "Introduzione a Kali Linux" [pagina 14], vi guidiamo passo passo dal download dell'immagine ISO all'installazione e all'esecuzione di Kali Linux sul vostro computer. Segue il capitolo 3, "Fondamenti di Linux" [pagina 48], che fornisce le conoscenze di base necessarie su qualsiasi sistema Linux, come l'architettura, il processo di installazione, la gerarchia del file system, i permessi e altro ancora.

A questo punto, avrete già utilizzato Kali Linux come sistema live per un po' di tempo. Nel capitolo 4, "Installazione di Kali Linux" [pagina 66], imparerete come effettuare un'installazione permanente di Kali Linux (sul vostro disco rigido) e nel capitolo 5, "Configurazione di Kali Linux" [pagina 108], come personalizzarlo a vostro piacimento. Come utenti abituali di Kali, è giunto il momento di familiarizzare con le importanti risorse a disposizione degli utenti: il capitolo 6, "Aiutarsi da soli e ottenere aiuto" [pagina 128], vi fornirà gli strumenti per affrontare i problemi imprevisti che probabilmente incontrerete.

Dopo aver trattato a fondo le nozioni di base, il resto del libro approfondisce argomenti più avanzati: il capitolo 7, "Protezione e monitoraggio di Kali Linux" [pagina 156], fornisce suggerimenti per garantire che l'installazione di Kali Linux soddisfi i requisiti di sicurezza. Successivamente, il capitolo 8, "Gestione dei pacchetti Debian" [pagina 176], spiega come sfruttare appieno il potenziale dell'ecosistema di pacchettizzazione di Debian. Infine, nel capitolo 9, "Utilizzo avanzato" [pagina 228], si apprende come creare un'immagine ISO di Kali Linux completamente personalizzata. Tutti questi argomenti risultano ancora più rilevanti quando si implementa Kali Linux su larga scala in un'azienda, come documentato nel capitolo 10, "Kali Linux in azienda" [pagina 258].

Machine Translated by Google

L'ultimo capitolo, il capitolo 11, "Introduzione alle valutazioni di sicurezza" [pagina 284], stabilisce il collegamento tra tutto ciò che avete appreso in questo libro e il lavoro quotidiano dei professionisti della sicurezza.

## Ringraziamenti di Raphaël Hertzog

Vorrei ringraziare Mati Aharoni: nel 2012 mi contattò perché ero uno dei tanti consulenti Debian e lui voleva creare un successore di BackTrack basato su Debian. È così che ho iniziato a lavorare su Kali Linux e da allora ho apprezzato molto il mio percorso nel mondo di Kali.

Nel corso degli anni, Kali Linux si è avvicinato sempre di più a Debian GNU/Linux, in particolare con il passaggio a Kali Rolling, basato su Debian Testing. Ora gran parte del mio lavoro, sia su Kali che su Debian, apporta benefici all'intero ecosistema Debian. Ed è proprio questo che mi motiva a continuare, giorno dopo giorno, mese dopo mese, anno dopo anno.

Lavorare a questo libro è stata anche una grande opportunità che Mati mi ha offerto. Non è lo stesso tipo di lavoro, ma è altrettanto gratificante poter aiutare le persone e condividere con loro la mia esperienza con il sistema operativo Debian/Kali. Basandomi sulla mia esperienza con il *Manuale dell'Amministratore di Debian,* spero che le mie spiegazioni vi aiutino a muovere i primi passi nel mondo in rapida evoluzione della sicurezza informatica.

Vorrei inoltre ringraziare tutti i membri del team di Offensive Security che hanno contribuito alla realizzazione del libro: Jim O'Gorman (coautore di alcuni capitoli), Devon Kearns (revisore), Ron Henry (redattore tecnico), Joe Steinbach e Tony Cruse (responsabili del progetto). Un ringraziamento speciale anche a Johnny Long, che inizialmente aveva iniziato a scrivere la prefazione, ma alla fine ha revisionato l'intero libro.

## Ringraziamenti a Jim O'Gorman

Desidero ringraziare tutti coloro che hanno partecipato a questo progetto per il loro contributo, di cui il mio è stato solo una piccola parte. Questo libro, proprio come Kali Linux stesso, è stato un progetto collaborativo in cui molte mani hanno reso il lavoro più agevole. Un ringraziamento speciale a Raphaël, Devon, Mati, Johnny e Ron per essersi assunti la maggior parte dell'impegno. Senza di loro, questo libro non avrebbe mai visto la luce.

## Ringraziamenti di Mati Aharoni

Sono passati alcuni anni da quando Kali Linux è stato rilasciato per la prima volta e, fin dal primo giorno, ho sempre sognato di pubblicare un libro ufficiale che coprisse il sistema operativo Kali nella sua interezza. È quindi un grande privilegio per me vedere finalmente un libro del genere arrivare al pubblico. Vorrei ringraziare sinceramente tutti coloro che sono coinvolti nella creazione di questo progetto, tra cui Jim, Devon, Johnny,

Machine Translated by Google

e Ron. Un ringraziamento speciale va a Raphaël per aver svolto la maggior parte del lavoro più impegnativo in questo libro e per aver messo a disposizione del nostro gruppo la sua vasta esperienza.

## Ringraziamenti a Joe O'Gorman - Revisione 2021

Kali Linux è cambiato molto da quando Kali Linux Revealed è stato rilasciato per la prima volta nel 2017. Dall'aggiunta di nuovi sviluppatori all'abbandono dell'utente root come predefinito, sono stati fatti molti progressi nel corso degli anni. Kali Linux Revealed necessitava di una revisione e sono onorato di aver avuto l'opportunità di contribuire a questo progetto epico durante il processo di revisione.

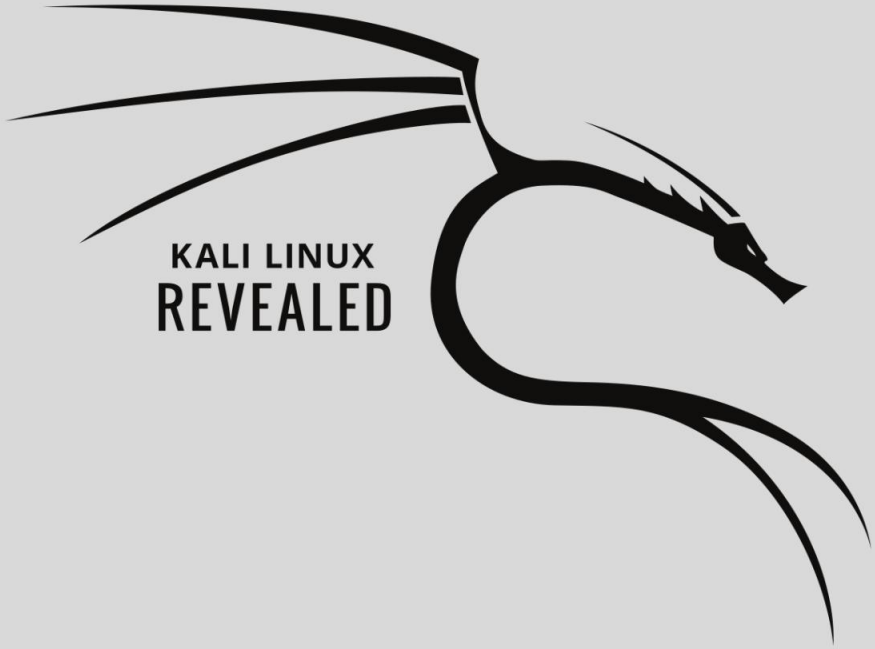
Machine Translated by Google



Machine Translated by Google

**Parole chiave**

**Distribuzione Linux**
**derivato di Debian**
**Scopo**
**Caratteristiche**
**Politiche**



Machine Translated by Google

Capitolo

# 1

# Informazioni su Kali Linux

Contenuto

Un po' di storia 2
Relazione con Debian 4
Scopo e casi d'uso 5
Caratteristiche principali di Kali Linux 8
Politiche di Kali Linux 10
Sommario 11

Machine Translated by Google

Kali Linux1 Kali è una distribuzione Linux per audit di sicurezza pronta per l'uso aziendale, basata su Debian GNU/Linux. Si rivolge a professionisti della sicurezza e amministratori IT, consentendo loro di condurre test di penetrazione avanzati, analisi forensi e audit di sicurezza.

**Che cos'è una distribuzione Linux?**

Sebbene sia comunemente usato come nome per l'intero sistema operativo, Linux è solo il nome del kernel, un software che gestisce le interazioni tra l'hardware e le applicazioni dell'utente finale.

L'espressione "distribuzione Linux", d'altro canto, si riferisce a un sistema operativo (SO) completo costruito sul kernel Linux, che di solito include un programma di installazione e numerose applicazioni, preinstallate o impacchettate in modo da facilitarne l'installazione.

Debian GNU/Linux2 Kali Linux è una delle principali distribuzioni Linux generiche, nota per la sua qualità e stabilità. Si basa sul lavoro del progetto Debian e aggiunge oltre 400 pacchetti proprietari specifici, tutti relativi alla sicurezza informatica, in particolare al campo del penetration testing.

Debian è un progetto software libero che offre diverse versioni del suo sistema operativo e spesso usiamo il termine distribuzione per riferirci a una versione specifica, ad esempio le distribuzioni Debian Stable o Debian Testing. Lo stesso vale anche per Kali Linux, con la distribuzione Kali Rolling, ad esempio.

## 1.1. Un po' di storia

Il progetto Kali Linux è iniziato silenziosamente nel 2012, quando Offensive Security decise di voler sostituire il suo venerabile progetto BackTrack Linux, che veniva mantenuto manualmente, con qualcosa che potesse diventare un autentico derivato di Debian. , completo di tutta l'infrastrutturanecessaria e di tecniche di packaging migliorate. La decisione di costruire Kali sulla distribuzione Debian è stata presa perché è ben nota per la sua qualità, stabilità e ampia selezione di software disponibile.
Ecco perché io (Raphaël) mi sono coinvolto in questo progetto, in qualità di consulente Debian.

La prima versione (1.0) è stata rilasciata un anno dopo, nel marzo 2013, ed era basata su Debian 7 "Wheezy", la distribuzione stabile di Debian all'epoca. In quel primo anno di sviluppo, abbiamo impacchettato centinaia di applicazioni relative al penetration testing e costruito l'infrastruttura. Sebbene il numero di applicazioni sia significativo, l'elenco è stato meticolosamente curato, eliminando quelle che non funzionavano più o che duplicavano funzionalità già presenti in programmi migliori.

Durante i due anni successivi alla versione 1.0, Kali ha rilasciato molti aggiornamenti incrementali, ampliando la gamma di applicazioni disponibili e migliorando il supporto hardware, grazie alle nuove versioni del kernel. Con alcuni investimenti nell'integrazione continua, abbiamo garantito che tutti i pacchetti importanti

[1] https://www.kali.org/
[2] https://www.debian.org/
[3] https://wiki.debian.org/Derivatives/Census

Machine Translated by Google

venivano mantenuti in uno stato installabile e si potevano sempre creare immagini live personalizzate (un segno distintivo della distribuzione).

Nel 2015, con l'uscita di Debian 8 "Jessie", abbiamo lavorato per riprogettare Kali Linux basandoci su di essa. Mentre Kali Linux 1.x evitava GNOME Shell (affidandosi invece a GNOME Fallback), in questa versione abbiamo deciso di integrarla e migliorarla: abbiamo aggiunto alcune estensioni di GNOME Shell per ottenere le funzionalità mancanti, in particolare il menu Applicazioni. Il risultato di questo lavoro è stato Kali Linux 2.0, pubblicato nell'agosto del 2015.

| | |
|---|---|
| **Xfce è Kali Linux Desktop predefinito Ambiente** | Un ambiente desktop è una raccolta di applicazioni grafiche che condividono un toolkit grafico comune e che sono progettate per essere utilizzate insieme sulle workstation degli utenti. Gli ambienti desktop non vengono generalmente utilizzati sui server. Solitamente includono un launcher di applicazioni, un file manager, un browser web, un client di posta elettronica, una suite per ufficio, ecc.<br><br>Xfce4 è uno degli ambienti desktop leggeri più popolari, perfetto per le nostre immagini ISO live ed è incluso nelle principali immagini ISO di installazione fornite da Kali Linux (insieme a GNOME5) KDE6 ). Puoi selezionare un ambiente desktop a tua scelta durante l'installazione. Altrimenti, dopo l'installazione hai le opzioni aggiuntive di; i37 , i3-gaps8 , MATE9 , Illuminazione10 ,LXDE11 . |

Parallelamente, abbiamo intensificato i nostri sforzi per garantire che Kali Linux disponga sempre della versione più recente di tutte le applicazioni di penetration testing. Sfortunatamente, questo obiettivo era in qualche modo in contrasto con l'utilizzo di Debian Stable12 come base per la distribuzione, perché ci ha richiesto di effettuare il backport di molti pacchetti. Questo è dovuto al fatto che Debian Stable dà priorità alla stabilità del software, causando spesso un lungo ritardo tra il rilascio di un aggiornamento upstream e la sua integrazione nella distribuzione. Dato il nostro investimento nell'integrazione continua, è stata una scelta del tutto naturale basare Kali Linux su Debian Testing13. In questo modo potremmo beneficiare dell'ultima versione di tutti i pacchetti Debian non appena disponibili. Debian Testing ha un ciclo di aggiornamento molto più rapido, più compatibile con la filosofia di Kali Linux.

Questo è, in sostanza, il concetto di Kali Rolling. Sebbene la distribuzione rolling sia disponibile da tempo, Kali 2016.1 è stata la prima release ad adottare ufficialmente la natura rolling di tale distribuzione: quando si installa l'ultima release di Kali, il sistema segue effettivamente la distribuzione Kali Rolling e *ogni giorno si ricevono nuovi aggiornamenti.* In passato, le release di Kali erano snapshot della distribuzione Debian sottostante con pacchetti specifici di Kali iniettati al suo interno.

---

[4] https://www.xfce.org/
[5] https://www.gnome.org/
[6] https://kde.org/
[7] https://i3wm.org/
[8] https://github.com/Airblader/i3
[9] https://mate-desktop.org/
10https://www.enlightenment.org/
11https://www.lxde.org/
12https://www.debian.org/releases/stable/ 13https://www.debian.org/releases/testing/

Machine Translated by Google

Una distribuzione rolling release offre molti vantaggi, ma comporta anche numerose sfide, sia per chi la sviluppa, sia per gli utenti che devono gestire un flusso continuo di aggiornamenti e, a volte, modifiche incompatibili con le versioni precedenti. Questo libro si propone di fornire le conoscenze necessarie per affrontare qualsiasi problema si possa incontrare durante la gestione di un'installazione di Kali Linux.

## 1.2. Rapporto con Debian

La distribuzione Kali Linux è basata su Debian Testing 14. Pertanto, la maggior parte dei pacchetti disponibili in Kali Linux proviene direttamente da questo repository Debian.

Sebbene Kali Linux dipenda fortemente da Debian, è anche completamente indipendente15 nel senso che disponiamo di una nostra infrastruttura e conserviamo la libertà di apportare tutte le modifiche che desideriamo.

### 1.2.1. Il flusso dei pacchi

Per quanto riguarda Debian, i collaboratori lavorano quotidianamente all'aggiornamento dei pacchetti e al loro caricamento nella distribuzione Debian Unstable (nota anche come sid16). Da lì, i pacchetti migrano alla distribuzione Debian Testing una volta risolti i bug più problematici.
Il processo di migrazione garantisce inoltre che nessuna dipendenza venga compromessa in Debian Testing. L'obiettivo è che Testing sia sempre in uno stato utilizzabile (o addirittura rilasciabile!).

Gli obiettivi di Debian Testing si allineano piuttosto bene con quelli di Kali Linux, quindi l'abbiamo scelta come base. Per aggiungere i pacchetti specifici di Kali alla distribuzione, seguiamo un processo in due fasi.

Innanzitutto, prendiamo Debian Testing e iniettiamo forzatamente i nostri pacchetti Kali (situati nel nostro repository *kali-dev dedicato )* per creare il repository *kali-dev* . Questo repository potrebbe presentare problemi di tanto in tanto: ad esempio, i nostri pacchetti specifici per Kali potrebbero non essere installabili finché non vengono ricompilati con librerie più recenti. In altri casi, anche i pacchetti che abbiamo forkato potrebbero dover essere aggiornati, sia per renderli nuovamente installabili, sia per risolvere i problemi di installabilità di un altro pacchetto che dipende da una versione più recente del pacchetto forkato. In ogni caso, *kali-dev* non è destinato agli utenti finali.

*kali-rolling* è la distribuzione che gli utenti di Kali Linux dovrebbero seguire ed è basata su *kali-dev,* nello stesso modo in cui Debian Testing è basata su Debian Unstable. I pacchetti vengono migrati solo quando tutte le dipendenze possono essere soddisfatte nella distribuzione di destinazione.

14https://www.debian.org/releases/testing/ 15https://www.debian.org/derivatives/ 16https://www.debian.org/releases/sid/

Machine Translated by Google

### 1.2.2. Gestire le differenze con Debian

Per scelta progettuale, cerchiamo di ridurre al minimo il numero di pacchetti derivati. Tuttavia, per implementare alcune delle funzionalità esclusive di Kali, è necessario apportare delle modifiche. Per limitare l'impatto di queste modifiche, ci impegniamo a integrarle direttamente nel progetto principale, o aggiungendo gli hook necessari in modo che sia semplice abilitare le funzionalità desiderate senza dover modificare ulteriormente i pacchetti originali.

Il tracker dei pacchetti Kali17 Ci aiuta a tenere traccia delle nostre divergenze con Debian. In qualsiasi momento, possiamo verificare quale pacchetto è stato forkato e se è sincronizzato con Debian, oppure se è necessario un aggiornamento. Tutti i nostri pacchetti sono gestiti in repository Git18 ospitando un ramo Debian e un ramo Kali fianco a fianco. Grazie a ciò, l'aggiornamento di un pacchetto forkato è un semplice processo in due fasi: aggiornare il ramo Debian e poi unirlo al ramo Kali.

Sebbene il numero di pacchetti derivati da fork in Kali sia relativamente basso, il numero di pacchetti aggiuntivi è piuttosto elevato: a gennaio 2021 se ne contavano quasi 50019. La maggior parte di questi pacchetti è software libero conforme alle Linee guida per il software libero di Debian20 e il nostro obiettivo finale sarebbe quello di mantenere quei pacchetti all'interno di Debian ogni qualvolta sia possibile. Ecco perché ci sforziamo di rispettare la Debian Policy21 e per seguire le buone pratiche di packaging utilizzate in Debian. Sfortunatamente, ci sono anche diverse eccezioni in cui è stato quasi impossibile creare un packaging adeguato. A causa della scarsità di tempo, pochi pacchetti sono stati rilasciati su Debian.

## 1.3. Scopo e casi d'uso

Sebbene l'obiettivo principale di Kali possa essere riassunto in "penetration testing e audit di sicurezza", dietro queste attività si celano molteplici compiti. Kali Linux è concepito come una *piattaforma,* in quanto include numerosi strumenti che coprono casi d'uso molto diversi (anche se possono certamente essere utilizzati in combinazione durante un penetration test).

Ad esempio, Kali Linux può essere utilizzato su vari tipi di computer: ovviamente sui laptop dei penetration tester, ma anche sui server degli amministratori di sistema che desiderano monitorare la propria rete, sulle workstation degli analisti forensi e, in modo più inaspettato, su dispositivi embedded discreti, tipicamente con CPU ARM, che possono essere posizionati nel raggio di una rete wireless o collegati al computer degli utenti target. Molti dispositivi ARM sono anche macchine d'attacco perfette grazie alle loro dimensioni ridotte e al basso consumo energetico. Kali Linux può anche essere distribuito nel cloud per creare rapidamente un cluster di macchine per il cracking delle password e su telefoni cellulari e tablet per consentire test di penetrazione veramente portatili.

---

17https://pkg.kali.org/derivative/kali-dev/
18https://gitlab.com/kalilinux/packages
19https://pkg.kali.org/derivative/kali-roll/ 20https://
www.debian.org/social_contract 21https://
www.debian.org/doc/debian-policy/

Machine Translated by Google

Ma non è tutto; i penetration tester hanno bisogno anche di server: per utilizzare software di collaborazione all'interno di un team di penetration tester, per configurare un server web da utilizzare nelle campagne di phishing, per eseguire strumenti di scansione delle vulnerabilità e per altre attività correlate.

Una volta avviato Kali, scoprirai subito che il menu principale di Kali Linux è organizzato per temi, in base alle diverse tipologie di attività e compiti rilevanti per i penetration tester e altri professionisti della sicurezza informatica, come mostrato nella Figura 1.1, "Menu Applicazioni di Kali Linux" [pagina 6].

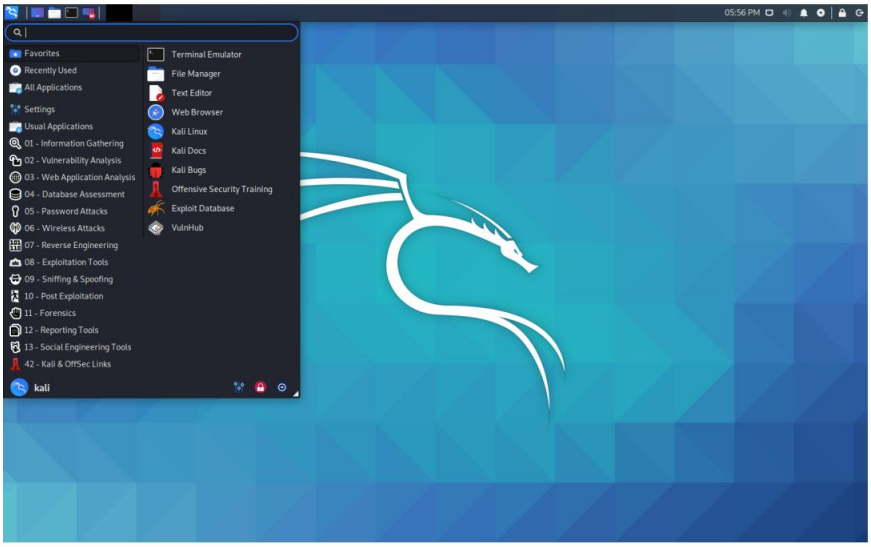



**Figura 1.1** Menu Applicazioni di Kali Linux

Questi compiti e attività includono:

- Raccolta di informazioni: Raccolta di dati sulla rete target e sulla sua struttura, identificazione dei computer, dei loro sistemi operativi e dei servizi in esecuzione. Identificazione delle parti potenzialmente sensibili del sistema informativo. Estrazione di elenchi di ogni tipo dai servizi di directory in esecuzione.

- Analisi delle vulnerabilità: verifica rapida se un sistema locale o remoto è interessato da una serie di vulnerabilità note o configurazioni non sicure. Gli scanner di vulnerabilità utilizzano database contenenti migliaia di firme per identificare potenziali vulnerabilità.

- Analisi delle applicazioni web: identificazione di configurazioni errate e vulnerabilità di sicurezza nelle applicazioni web. È fondamentale individuare e mitigare questi problemi, dato che la disponibilità pubblica di tali applicazioni le rende bersagli ideali per gli aggressori.

Machine Translated by Google

- Valutazione del database: dall'iniezione SQL all'attacco alle credenziali, gli attacchi ai database sono una strategia comune per gli aggressori. Qui è possibile trovare strumenti che testano le vulnerabilità agli attacchi, dall'iniezione SQL all'estrazione e all'analisi dei dati.
- Attacchi alle password: i sistemi di autenticazione sono sempre un vettore di attacco privilegiato. In questo ambito si possono trovare molti strumenti utili, dagli strumenti online per l'attacco alle password agli attacchi offline contro i sistemi di crittografia o di hashing.
- Attacchi wireless: la natura pervasiva delle reti wireless fa sì che rappresentino sempre un vettore di attacco comune. Grazie all'ampio supporto per diverse schede wireless, Kali è una scelta ovvia per gli attacchi contro molteplici tipi di reti wireless.
- Reverse Engineering: Il reverse engineering è un'attività con molteplici scopi. A supporto delle attività offensive, rappresenta uno dei metodi principali per l'identificazione delle vulnerabilità e lo sviluppo di exploit. In ambito difensivo, viene utilizzato per analizzare il malware impiegato in attacchi mirati. In questo contesto, l'obiettivo è identificare le capacità di una determinata tecnica di attacco.

- Strumenti di sfruttamento: Sfruttare, ovvero trarre vantaggio da una vulnerabilità (precedentemente identificata), consente di ottenere il controllo di una macchina (o dispositivo) remota. Questo accesso può quindi essere utilizzato per ulteriori attacchi di escalation dei privilegi, localmente sulla macchina compromessa o su altre macchine accessibili sulla sua rete locale. Questa categoria contiene una serie di strumenti e utility che semplificano il processo di scrittura dei propri exploit. • Sniffing e spoofing: Ottenere

l'accesso ai dati mentre transitano sulla rete è spesso vantaggioso per un attaccante. Qui è possibile trovare strumenti di spoofing che consentono di impersonare un utente legittimo, nonché strumenti di sniffing che consentono di acquisire e analizzare i dati direttamente dalla rete. Se utilizzati insieme, questi strumenti possono essere molto potenti. • Post-sfruttamento: Una volta ottenuto l'accesso a un

sistema, spesso si desidera mantenere tale livello di accesso o estendere il controllo spostandosi lateralmente all'interno della rete. Gli strumenti che aiutano a raggiungere questi obiettivi si trovano qui.

- Analisi forense: gli ambienti di avvio live di Linux per l'analisi forense sono molto popolari ormai da anni. Kali contiene un gran numero di popolari strumenti forensi basati su Linux che consentono di fare tutto, dalla valutazione iniziale, all'acquisizione di immagini dei dati, all'analisi completa e alla gestione del caso. •

Strumenti di reporting: un penetration test è completo solo dopo che i risultati sono stati riportati. Questa categoria contiene strumenti per raccogliere i dati provenienti da strumenti di raccolta informazioni, scoprire relazioni non ovvie e riunire il tutto in vari report. • Strumenti di ingegneria sociale: quando l'aspetto

tecnico è ben protetto, esiste spesso la possibilità di sfruttare il comportamento umano come vettore di attacco. Con la giusta influenza, le persone possono essere indotte a compiere azioni che compromettono la sicurezza dell'ambiente.

La chiavetta USB che la segretaria ha appena inserito conteneva un PDF innocuo? O era anche un cavallo di Troia che installava una backdoor? Il sito web della banca a cui il contabile si è appena collegato era quello previsto o una copia perfetta utilizzata per scopi di phishing? Questa categoria contiene strumenti che facilitano questo tipo di attacchi.

Machine Translated by Google

## 1.4. Caratteristiche principali di Kali Linux

Kali Linux è una distribuzione Linux che contiene una propria raccolta di centinaia di strumenti software specificamente pensati per i suoi utenti di riferimento: i penetration tester e altri professionisti della sicurezza.
Include inoltre un programma di installazione per configurare completamente Kali Linux come sistema operativo principale su qualsiasi computer.

È praticamente simile a tutte le altre distribuzioni Linux esistenti, ma ci sono altre caratteristiche che differenziano Kali Linux, molte delle quali sono pensate per le esigenze specifiche dei penetration tester.
Diamo un'occhiata ad alcune di queste caratteristiche.

### 1.4.1. Un sistema in tempo reale

Oltre alle immagini ISO di installazione principali, Kali Linux offre un'immagine ISO live separata da scaricare.
Questo permette di utilizzare Kali Linux come sistema live avviabile. In altre parole, è possibile utilizzare Kali Linux senza installarlo, semplicemente avviando l'immagine ISO (di solito dopo aver copiato l'immagine su una chiavetta USB).

Il sistema live contiene gli strumenti più comunemente utilizzati dai penetration tester, quindi anche se il tuo sistema di uso quotidiano non è Kali Linux, puoi semplicemente inserire il disco o la chiavetta USB e riavviare per eseguire Kali.
Tuttavia, tieni presente che la configurazione predefinita non manterrà le modifiche tra un riavvio e l'altro.
Se si configura la persistenza con una chiave USB (vedere la sezione 9.4, "Aggiunta della persistenza all'immagine ISO live con una chiave USB" [pagina 246]), è possibile personalizzare il sistema a proprio piacimento (modificare i file di configurazione, salvare i report, aggiornare il software e installare pacchetti aggiuntivi, ad esempio) e le modifiche verranno mantenute anche dopo il riavvio.

### 1.4.2. Modalità forense

In generale, quando si esegue un'analisi forense su un sistema, è fondamentale evitare qualsiasi attività che possa alterare i dati presenti sul sistema analizzato. Purtroppo, i moderni ambienti desktop tendono a interferire con questo obiettivo tentando di montare automaticamente qualsiasi disco rilevino. Per ovviare a questo problema, Kali Linux offre una modalità forense attivabile dal menu di avvio, che disabilita tutte queste funzionalità.

Il sistema live è particolarmente utile a fini forensi, perché permette di riavviare qualsiasi computer con un sistema Kali Linux senza accedere o modificare i dischi rigidi.

Machine Translated by Google

### 1.4.3. Un kernel Linux personalizzato

Kali Linux fornisce sempre un kernel Linux recente personalizzato22, Basato sulla versione presente in Debian Unstable. Ciò garantisce un solido supporto hardware, soprattutto per un'ampia gamma di dispositivi wireless.
Il kernel è stato patchato23 per il supporto all'iniezione wireless, dato che molti strumenti di valutazione della sicurezza wireless si basano su questa funzionalità.

Poiché molti dispositivi hardware richiedono file firmware aggiornati (che si trovano in /lib/firmware/), Kali li installa tutti per impostazione predefinita, incluso il firmware disponibile nella sezione non libera di Debian . Questi non vengono installati di default in Debian, perché sono closed-source e quindi non fanno parte di Debian propriamente detto.

### 1.4.4. Completamente personalizzabile

Kali Linux è stato creato da penetration tester per penetration tester, ma comprendiamo che non tutti saranno d'accordo con le nostre decisioni di progettazione o con la scelta degli strumenti da includere di default. Per questo motivo, ci assicuriamo sempre che Kali Linux sia facile da personalizzare in base alle proprie esigenze e preferenze. A tal fine, pubblichiamo la live-build24 Questa è la configurazione utilizzata per creare le immagini ufficiali di Kali, quindi puoi personalizzarla a tuo piacimento. È molto semplice partire da questa configurazione pubblicata e implementare diverse modifiche in base alle tue esigenze grazie alla versatilità di live-build.

Live-build include numerose funzionalità per modificare il sistema installato, installare file supplementari, installare pacchetti aggiuntivi, eseguire comandi arbitrari e modificare i valori preimpostati in debconf.

### 1.4.5. Un sistema operativo affidabile

Gli utenti di una distribuzione di sicurezza vogliono giustamente sapere che è affidabile e che è stata sviluppata in modo trasparente, consentendo a chiunque di ispezionare il codice sorgente. Kali Linux è sviluppato da un piccolo team25 di sviluppatori esperti che lavorano in modo trasparente e seguendo le migliori pratiche di sicurezza: caricano pacchetti sorgente firmati, che vengono poi compilati su daemon di compilazione dedicati.
I pacchetti vengono quindi sottoposti a checksum e distribuiti come parte di un repository firmato.

Il lavoro svolto sui pacchetti può essere completamente rivisto attraverso i repository Git dei pacchetti26 (che contengono tag firmati) che vengono utilizzati per creare i pacchetti sorgente di Kali. L'evoluzione di ciascun pacchetto può essere seguita anche tramite il tracker dei pacchetti di Kali27 .

---

22https://pkg.kali.org/pkg/linux 23https://gitlab.com/kalilinux/packages/linux/-/blob/kali/master/debian/patches/series 24https://gitlab.com/kalilinux/build-scripts/live-build-config 25https://www.kali.org/about-us/ 26https://gitlab.com/kalilinux/packages 27https://pkg.kali.org/

Machine Translated by Google

### 1.4.6. Utilizzabile su un'ampia gamma di dispositivi ARM

Kali Linux fornisce pacchetti binari per le architetture ARM armel, armhf e arm64. Grazie alle immagini di facile installazione fornite da Offensive Security, Kali Linux può essere distribuito su molti dispositivi interessanti, da smartphone e tablet a router Wi-Fi e computer di varie forme e dimensioni.

## 1.5. Politiche di Kali Linux

Sebbene Kali Linux si sforzi di seguire le politiche di Debian ogniqualvolta sia possibile, ci sono alcune aree in cui abbiamo fatto scelte di progettazione significativamente diverse a causa delle esigenze specifiche dei professionisti della sicurezza.

### 1.5.1. Servizi di rete disabilitati per impostazione predefinita

A differenza di Debian, Kali Linux disabilita per impostazione predefinita qualsiasi servizio installato che si metterebbe in ascolto su un'interfaccia di rete pubblica, come HTTP e SSH.

La logica alla base di questa decisione è quella di ridurre al minimo l'esposizione durante un penetration test, quando rivelare la propria presenza e rischiare di essere scoperti a causa di interazioni di rete impreviste è dannoso.

È comunque possibile abilitare manualmente qualsiasi servizio desiderato eseguendo il comando `sudo systemctl enable service`. Torneremo su questo argomento nel capitolo 5, "Configurazione di Kali Linux" [pagina 108], più avanti in questo libro.

### 1.5.2. Una raccolta selezionata di applicazioni

Debian si propone di essere il sistema operativo universale e impone pochissime limitazioni a ciò che viene pacchettizzato, a condizione che ogni pacchetto abbia un manutentore.

Al contrario, Kali Linux non include tutti gli strumenti di penetration testing disponibili. Il nostro obiettivo è piuttosto quello di fornire solo i migliori strumenti con licenza libera, in grado di coprire la maggior parte delle attività che un penetration tester potrebbe voler svolgere.

Gli sviluppatori Kali che lavorano come penetration tester guidano il processo di selezione e noi sfruttiamo la loro esperienza e competenza per fare scelte ponderate. In alcuni casi si tratta di una questione di fatti, ma ci sono altre scelte più complesse che si riducono semplicemente a preferenze personali.

Ecco alcuni dei punti presi in considerazione durante la valutazione di una nuova candidatura:

- L'utilità dell'applicazione in un contesto di penetration testing • La funzionalità unica delle caratteristiche dell'applicazione

Machine Translated by Google

- La licenza dell'applicazione
- I requisiti di risorse dell'applicazione

Mantenere un repository di strumenti di penetration testing aggiornato e utile è un compito impegnativo. Noi Accettiamo suggerimenti per nuovi strumenti all'interno di una categoria dedicata *(Richieste di nuovi strumenti)* nel Kali Bug Tracker[28]. Le richieste di nuovi strumenti vengono accolte con maggiore favore quando la proposta è ben presentata, includendo una spiegazione del perché lo strumento sia utile, come si confronti con altre applicazioni simili e così via.

## 1.6. Riepilogo

In questo capitolo ti abbiamo presentato Kali Linux, fornito un po' di storia, passato attraverso alcuni delle caratteristiche principali e abbiamo presentato diversi casi d'uso. Abbiamo anche discusso alcuni dei politiche che abbiamo adottato durante lo sviluppo di Kali Linux.

Suggerimenti riassuntivi:

- Kali Linux[29] è una distribuzione Linux per audit di sicurezza pronta per le aziende basata su Debian GNU/Linux. Kali è destinato ai professionisti della sicurezza e agli amministratori IT, consentendo loro di condurre test di penetrazione avanzati, analisi forensi e audit di sicurezza.
- A differenza della maggior parte dei sistemi operativi più diffusi, Kali Linux è una distribuzione rolling, il che significa che *riceverai aggiornamenti ogni singolo giorno.*
- La distribuzione Kali Linux è basata su Debian Testing[30]. Pertanto, la maggior parte dei pacchetti I file disponibili in Kali Linux provengono direttamente da questo repository Debian.
- Sebbene l'obiettivo di Kali possa essere riassunto rapidamente con "penetration testing e audit di sicurezza", esistono diversi casi d'uso, tra cui gli amministratori di sistema che desiderano monitorare i propri reti, analisi forense, installazione di dispositivi embedded, monitoraggio wireless, installazione su piattaforme mobili e altro ancora.
- I menu di Kali semplificano l'accesso agli strumenti per vari compiti e attività, tra cui: analisi delle vulnerabilità, analisi delle applicazioni web, valutazione dei database, attacchi alle password, attacchi wireless, reverse engineering, strumenti di sfruttamento, sniffing e spoofing, strumenti di post-sfruttamento, strumenti forensi, strumenti di reporting e strumenti di ingegneria sociale.
- Kali Linux ha molte funzionalità avanzate tra cui: utilizzo come sistema live (non installato), una modalità forense robusta e sicura, un kernel Linux personalizzato, la possibilità di personalizzare completamente il sistema, un sistema operativo di base affidabile e sicuro, capacità di installazione ARM, criteri di rete predefiniti sicuri e una serie selezionata di applicazioni.

Nel prossimo capitolo (capitolo 2, "Introduzione a Kali Linux" [pagina 14]), ci tufferemo e Prova Kali Linux grazie alla sua modalità live.

28https://bugs.kali.org/
29https://www.kali.org
30https://www.debian.org/releases/testing/

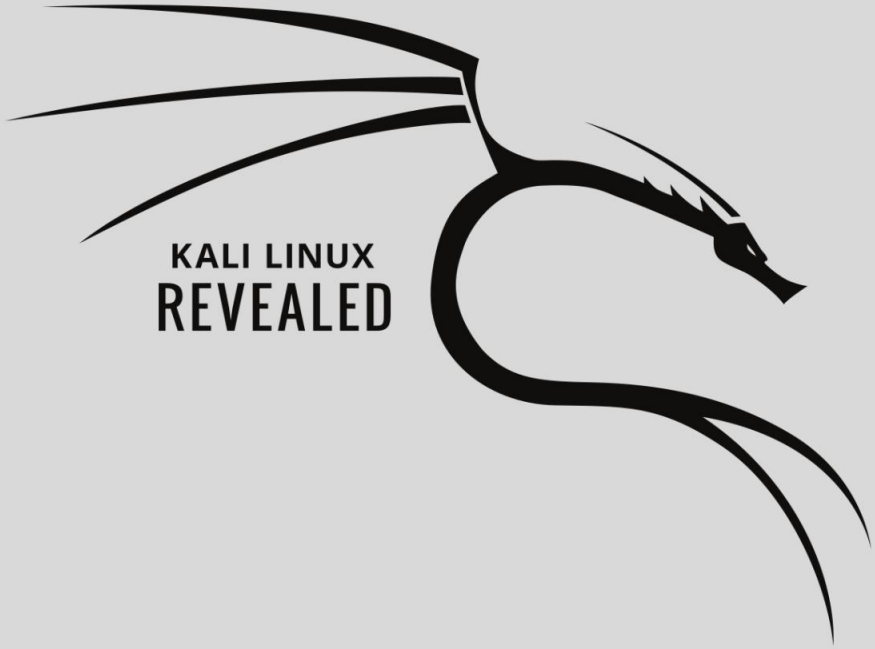
Machine Translated by Google

**Parole chiave**

**Scaricamento**

**immagine ISO**

**Avvio dal vivo**



Machine Translated by Google

Capitolo

# Per iniziare con Kali Linux **2**

Contenuto

Download di un'immagine ISO di Kali 14 Avvio di un'immagine ISO di Kali in modalità Live 24 Sommario 44

Machine Translated by Google

A differenza di altri sistemi operativi, Kali Linux semplifica l'avvio grazie alla disponibilità di *un'immagine disco live ,* che permette di avviare il sistema direttamente dall'immagine scaricata, senza dover seguire alcuna procedura di installazione preliminare. Questo significa che è possibile utilizzare la stessa immagine per scopi di test, come unità USB o DVD-ROM avviabile in ambito forense, oppure per installarla in modo permanente su hardware fisico o virtuale.

Proprio per questa semplicità, è facile dimenticare che è necessario adottare alcune precauzioni. Gli utenti di Kali sono spesso bersaglio di malintenzionati, siano essi gruppi sponsorizzati da stati, elementi della criminalità organizzata o singoli hacker. La natura open source di Kali Linux rende relativamente facile creare e distribuire versioni contraffatte, quindi è fondamentale acquisire l'abitudine di scaricare da fonti originali e di verificarne l'integrità e l'autenticità. Questo è particolarmente importante per i professionisti della sicurezza che spesso hanno accesso a reti sensibili e gestiscono dati dei clienti.

## 2.1. Download di un'immagine ISO di Kali

### 2.1.1. Dove scaricare

L'unica fonte ufficiale di immagini ISO di Kali Linux è la sezione Download del sito web di Kali. Data la sua popolarità, numerosi siti offrono immagini di Kali da scaricare, ma non dovrebbero essere considerate affidabili e potrebbero essere infette da malware o causare danni irreparabili al sistema.

ÿ https://www.kali.org/downloads/

Il sito web è accessibile tramite *HTTPS,* il che rende difficile l'impersonificazione. Non è sufficiente essere in grado di effettuare un attacco man-in-the-middle, poiché l'attaccante avrebbe bisogno anche di un certificato www.kali.org firmato da un'autorità di certificazione Transport Layer Security (TLS) di cui si fida il browser della vittima. Poiché le autorità di certificazione esistono proprio per prevenire questo tipo di problema, rilasciano certificati solo a persone la cui identità è stata verificata e che hanno fornito la prova di controllare il sito web corrispondente.

**cdimage.kali.org** I link presenti nella pagina di download puntano al dominio cdimage.kali.org , che reindirizza a un mirror vicino a te, migliorando la velocità di trasferimento e riducendo al contempo il carico sui server centrali di Kali.

Qui potete trovare un elenco degli specchi disponibili:

ÿ https://cdimage.kali.org/README.mirrorlist

### 2.1.2. Cosa scaricare

La pagina di download ufficiale mostra un breve elenco di immagini ISO, come illustrato nella Figura 2.1, "Elenco delle immagini disponibili per il download" [pagina 15].

Machine Translated by Google

# Download Kali Linux Images

We generate fresh Kali Linux image files every few months, which we make available for download. This page provides the links to download Kali Linux in its latest official release. For a release history, check our Kali Linux Releases page. Please note: You can find unofficial, untested weekly releases at http://cdimage.kali.org/kali-weekly/. Downloads are **rate limited to 5 concurrent connections**.

| Image Name | Torrent | Version | Size | SHA256Sum |
|---|---|---|---|---|
| Kali Linux 64-Bit (Installer) | Torrent | 2020.3 | 3.7G | f3b303ad328f6f7de6d26ac5fe41a3c10e2dfeda431a039323fc504acab4acfc |
| Kali Linux 64-Bit (Live) | Torrent | 2020.3 | 3.0G | 1a0b2ea83f48861dd3f3babd5a2892a14b30a7234c8c9b5013a6507d1401874f |
| Kali Linux 64-Bit (NetInstaller) | Torrent | 2020.3 | 430M | 950e2ff20392f410778f9d44b4f5c27f6a8e59c00a6eeb2c650b3a15fafa5f13 |
| Kali Linux 32-Bit (Installer) | Torrent | 2020.3 | 3.3G | 90a0d033a332de7b9923b6ff8409b178dc837242ebe7d55a1b3f0fafaded0152 |
| Kali Linux 32-Bit (Live) | Torrent | 2020.3 | 2.6G | 6ba1b1990d07be81428e48458b858f20d3c8273248d53aa2e6343af520bd32b8 |
| Kali Linux 32-Bit (NetInstaller) | Torrent | 2020.3 | 425M | 65cec6093d2154c6f931c423f9d1f4c4a902af9cc715e802467570d83a8cda80 |

**Figura 2.1** Elenco delle immagini disponibili per il download

Machine Translated by Google

Tutte le immagini disco etichettate come 64 bit o 32 bit si riferiscono a immagini compatibili con le CPU presenti nella maggior parte dei computer desktop e portatili moderni. Se stai scaricando un'immagine per utilizzarla su una macchina relativamente recente, è molto probabile che contenga un processore a 64 bit. In caso di dubbi, non preoccuparti: tutti i processori a 64 bit sono in grado di eseguire istruzioni a 32 bit. Puoi sempre scaricare ed eseguire l'immagine a 32 bit. Il contrario, tuttavia, non è vero. Consulta la barra laterale per informazioni più dettagliate.

Se hai intenzione di installare Kali su un dispositivo basato su ARM, devi fare riferimento a *Offensive Security* pagina di download1 per l'elenco dei dispositivi disponibili.

**La mia CPU è a 64 bit o a 32 bit?**

In Microsoft Windows, è possibile trovare queste informazioni eseguendo l' applicazione Informazioni di sistema (che si trova nella cartella Accessori > Utilità di sistema). Nella schermata Riepilogo sistema, è possibile esaminare il campo Tipo di sistema: conterrà "PC basato su x64" per una CPU a 64 bit o "PC basato su x86" per una CPU a 32 bit.

Su OS X/macOS non esiste un'applicazione standard che mostri queste informazioni, ma è comunque possibile dedurle dall'output del comando uname -m eseguito nel terminale.
Su un sistema con kernel a 64 bit (che può essere eseguito solo su una CPU a 64 bit) verrà restituito x86_64 , su un sistema con kernel a 32 bit verrà restituito i386 o qualcosa di simile (i486, i586 o i686), e su un sistema con kernel arm64 verrà restituito arm64. Qualsiasi kernel a 32 bit può essere eseguito su una CPU a 64 bit, ma poiché Apple controlla sia l'hardware che il software, è improbabile che si trovi questa configurazione.

In ambiente Linux, è possibile esaminare il campo flags nel file virtuale /proc/cpuinfo . Se contiene l' attributo lm , la CPU è a 64 bit; altrimenti, è a 32 bit. Il seguente comando da riga di comando mostrerà il tipo di CPU in uso:

```
$ grep -qP '^flags\s*:.*\blm\b' /proc/cpuinfo && echo 64-bit
        ÿ || echo 32 bit 64 bit
```

Ora che sapete se vi serve un'immagine a 64 o 32 bit, resta solo un ultimo passaggio: selezionare il tipo di immagine. Le immagini disponibili differiscono per la modalità di installazione. Le immagini Installer e NetInstaller , specializzate per un'installazione semplice con opzioni di installazione selezionabili, non consentono di avviare il sistema live. L' immagine Live , invece, permette di avviare il sistema live o di iniziare il processo di installazione, sebbene non disponga delle opzioni di selezione presenti nelle immagini di installazione. Queste opzioni includono la scelta dell'ambiente desktop e dei pacchetti da installare. In questo libro utilizzeremo l'immagine Live.

Una volta scelta l'immagine desiderata, è possibile scaricarla cliccando sul titolo nella riga corrispondente. In alternativa, è possibile scaricare l'immagine dalla rete peer-to-peer BitTorrent cliccando su "Torrent", a condizione di disporre di un client BitTorrent con estensione .torrent .

Mentre l'immagine ISO scelta viene scaricata, è necessario prendere nota del checksum scritto nella colonna sha256sum. Una volta scaricata l'immagine, utilizzare questo checksum per verificare che

[1] https://www.offensive-security.com/kali-linux-arm-images/

Machine Translated by Google

L'immagine scaricata corrisponde a quella pubblicata online dal team di sviluppo di Kali (vedere la sezione 2.1.3, "Verifica dell'integrità e dell'autenticità" [pagina 17]).

### 2.1.3. Verifica dell'integrità e dell'autenticità

I professionisti della sicurezza devono verificare l'integrità dei propri strumenti non solo per proteggere i propri dati e le proprie reti, ma anche quelli dei propri clienti. Sebbene la pagina di download di Kali e i relativi link siano protetti da TLS, Kali si affida a una rete di mirror esterni per la distribuzione dell'immagine, il che significa che non bisogna fidarsi ciecamente di ciò che si scarica. Il mirror a cui si viene indirizzati potrebbe essere stato compromesso, oppure si potrebbe essere vittime di un attacco.

Per ovviare a questo problema, il progetto Kali fornisce sempre i checksum delle immagini che distribuisce. Tuttavia, affinché tale verifica sia efficace, è necessario essere certi che il checksum ottenuto corrisponda effettivamente al checksum pubblicato dagli sviluppatori di Kali Linux. Esistono diversi modi per accertarsene.

#### Affidarsi al sito web protetto da TLS

Quando si recupera il checksum da una pagina web di download protetta da TLS, la sua origine è garantita indirettamente dal modello di sicurezza dei certificati X.509: il contenuto visualizzato proviene da un sito web che è effettivamente sotto il controllo della persona che ha richiesto il certificato TLS.

Ora dovresti generare il checksum dell'immagine scaricata e assicurarti che corrisponda a quello che hai registrato dal sito web di Kali:

```
$ sha256sum kali-linux-2020.3-live-amd64.iso
1a0b2ea83f48861dd3f3babd5a2892a14b30a7234c8c9b5013a6507d1401874f kali-linux-2020.3-live-amd64.iso
```

Se il checksum generato corrisponde a quello presente sulla pagina di download di Kali Linux, il file è corretto. Se i checksum differiscono, si è verificato un problema, sebbene ciò non indichi necessariamente una compromissione o un attacco; i download a volte si corrompono durante il transito su Internet. Prova a scaricare nuovamente il file da un altro mirror ufficiale di Kali, se possibile (vedi "cdimage.kali.org" [pagina 14] per maggiori informazioni sui mirror disponibili).

#### Affidarsi alla rete di fiducia di PGP

Se non ti fidi di HTTPS per l'autenticazione, sei un po' paranoico, ma a ragione. Esistono molti esempi di autorità di certificazione gestite male che hanno emesso certificati falsi, poi utilizzati in modo improprio. Potresti anche essere vittima di un attacco "man-in-the-middle" "amichevole", implementato su molte reti aziendali, che utilizza un archivio di certificati personalizzato, integrato nel browser, che presenta certificati falsi ai siti web crittografati, consentendo ai revisori aziendali di monitorare il traffico crittografato.

Machine Translated by Google

Per casi come questo, forniamo anche una chiave GnuPG che utilizziamo per firmare i checksum delle immagini che forniamo. Gli identificativi della chiave e le sue impronte digitali sono mostrati qui:

```
pub rsa4096 2012-03-05 [SC] [scadenza: 2023-01-16]
      44C6 513A 8E4F B3D3 0875 F758 ED44 4FF0 7D8D 0BF6
uid Kali Linux Repository <devel@kali.org> sub rsa4096 2012-03-05 [E] [expires: 2023-01-16]
```

Questa chiave fa parte di una *rete globale di fiducia* perché è stata firmata almeno da me (Raphaël Hertzog) e io faccio parte di questa rete di fiducia grazie al mio intenso utilizzo di GnuPG come sviluppatore Debian.

Il modello di sicurezza PGP/GPG è davvero unico. Chiunque può generare una chiave con qualsiasi identità, ma ci si fida di quella chiave solo se è stata firmata da un'altra chiave di cui ci si fida già. Quando si firma una chiave, si certifica di aver incontrato il detentore della chiave e di essere certi che l'identità associata sia corretta. Inoltre, si definisce l'insieme iniziale di chiavi di cui ci si fida, che ovviamente include la propria chiave.

Questo modello presenta delle limitazioni, quindi puoi scegliere di scaricare la chiave pubblica di Kali tramite HTTPS (o da un server di chiavi) e decidere semplicemente di fidarti perché la sua impronta digitale corrisponde a quella che abbiamo annunciato in più punti, incluso quanto riportato sopra in questo libro:

```
$ wget -q -O - https://archive.kali.org/archive-key.asc | gpg --import [ o ] $ gpg --keyserver hkp://keys.gnupg.net
 --recv-
key 44C6513A8E4FB3D30875F758ED444FF07D8D0BF6 gpg: chiave ED444FF07D8D0BF6: chiave pubblica "Kali Linux Repository <devel@kali.org>"
importata gpg: Numero totale elaborato: 1 importato: 1 gpg: [...] $ gpg --fingerprint 44C6513A8E4FB3D30875F758ED444FF07D8D0BF6 [...]

      44C6 513A 8E4F B3D3 0875 F758 ED44 4FF0 7D8D 0BF6
[...]
```

Dopo aver recuperato la chiave, è possibile utilizzarla per verificare i checksum delle immagini distribuite. Scarichiamo il file contenente i checksum (SHA256SUMS) e il file di firma associato (SHA256SUMS.gpg) e verifichiamo la firma:

```
$ wget http://cdimage.kali.org/current/SHA256SUMS [...] $ wget http://

cdimage.kali.org/current/SHA256SUMS.gpg [...] $ gpg --verify SHA256SUMS.gpg

SHA256SUMS gpg: Firma creata martedì 18 agosto 2020 alle
10:31:15 EDT
gpg:                utilizzando la chiave RSA 44C6513A8E4FB3D30875F758ED444FF07D8D0BF6
gpg: Firma valida da "Kali Linux Repository <devel@kali.org>"
```

Se ricevi il messaggio "Firma valida", puoi fidarti del contenuto del file SHA256SUMS e usarlo per verificare i file scaricati. In caso contrario, c'è un problema. Dovresti controllare di aver scaricato i file da un mirror legittimo di Kali Linux.

Machine Translated by Google

Si noti che è possibile utilizzare la seguente riga di comando per verificare che il file scaricato abbia lo stesso checksum elencato in SHA256SUMS, a condizione che il file ISO scaricato si trovi nella stessa directory:

```
$ grep kali-linux-2020.3-live-amd64.iso SHA256SUMS | sha256sum -c kali-linux-2020.3-live-amd64.iso: OK
```

Se non ricevi una risposta "OK" , significa che il file che hai scaricato è diverso da quello rilasciato nuovamente dal team di Kali. Non è affidabile e non dovrebbe essere utilizzato.

### 2.1.4. Copia dell'immagine su un DVD-ROM o una chiavetta USB

A meno che non si desideri eseguire Kali Linux in una macchina virtuale, l'immagine ISO di per sé ha un'utilità limitata. È necessario masterizzarla su un DVD-ROM o copiarla su una chiavetta USB per poter avviare il computer con Kali Linux. Abbiamo scelto l'immagine live di Kali perché desideriamo avviare il sistema da una chiavetta USB, il che ci permette di utilizzare un ambiente live o di installare la configurazione predefinita di Kali Linux.

Non tratteremo la procedura per masterizzare l'immagine ISO su un DVD-ROM, poiché varia notevolmente a seconda della piattaforma e dell'ambiente, ma nella maggior parte dei casi, facendo clic con il pulsante destro del mouse sul file .iso , verrà visualizzata una voce di menu contestuale che avvia un'applicazione per la masterizzazione di DVD-ROM. Provate!

Avvertimento



In questa sezione imparerai come sovrascrivere un disco qualsiasi con un'immagine ISO di Kali Linux. Verifica sempre attentamente il disco di destinazione prima di avviare l'operazione, poiché un singolo errore potrebbe causare la perdita completa dei dati e danneggiare irreparabilmente il tuo sistema.

#### Creazione di un'unità USB avviabile con Kali su Windows

Come prerequisito, è necessario scaricare e installare *Win32 Disk Imager:*

ÿ https://sourceforge.net/projects/win32diskimager/

Inserisci la chiavetta USB nel tuo PC con sistema operativo Microsoft Windows e annota il codice identificativo dell'unità ad essa associata (ad esempio, "E:\").

Avvia *Win32 Disk Imager* e scegli il file ISO di Kali Linux che desideri copiare sulla chiavetta USB.
Verifica che la lettera del dispositivo selezionato corrisponda a quella assegnata alla chiavetta USB. Una volta accertato di aver selezionato l'unità corretta, fai clic sul pulsante Scrivi e conferma che

Machine Translated by Google

Si desidera sovrascrivere il contenuto della chiavetta USB come mostrato nella Figura 2.2, "Win32 Disk Imager in azione" [pagina 20].

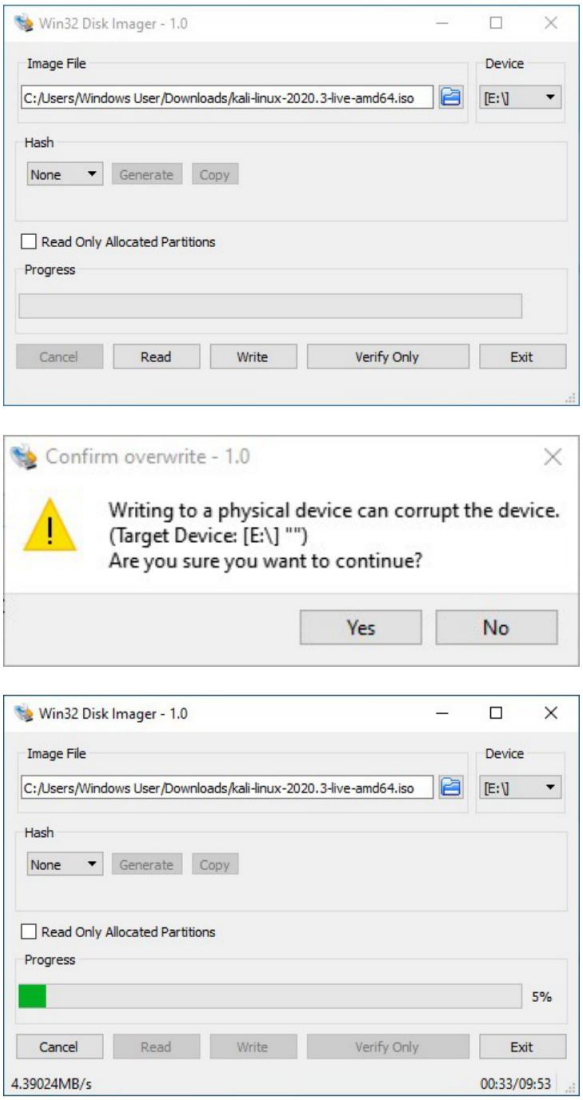



**Figura 2.2** Win32 Disk Imager in azione

Una volta completata la copia, espelli in modo sicuro l'unità USB dal tuo sistema Microsoft Windows. Ora puoi utilizzare il dispositivo USB per avviare Kali Linux.

Machine Translated by Google

## Creazione di un'unità USB avviabile con Kali Linux

Creare una chiavetta USB avviabile Kali Linux in un ambiente Linux è facile. L'ambiente desktop GNOME, installato di default in molte distribuzioni Linux, include un'utilità *Dischi* (in il pacchetto *gnome-disk-utility ).* Quel programma mostra un elenco di dischi, che si aggiorna dinamicamente quando colleghi o scolleghi un disco. Quando selezioni la tua chiavetta USB nell'elenco dei dischi, verranno visualizzate informazioni dettagliate che ti aiuteranno a confermare di aver selezionato il disco corretto. Nota che puoi Il nome del dispositivo si trova nella barra del titolo, come mostrato nella Figura 2.3, "Dischi GNOME" [pagina 21].

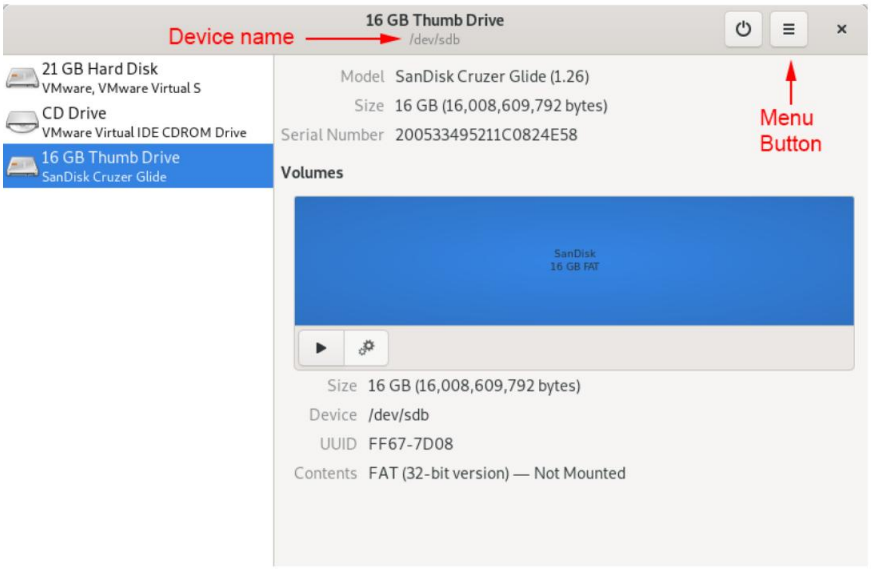



**Figura 2.3** Dischi GNOME

Fai clic sul pulsante del menu e seleziona Ripristina immagine disco... nel menu a comparsa visualizzato. Seleziona l'immagine ISO che hai precedentemente scaricato e fai clic su Avvia ripristino... come mostrato nella Figura 2.4, “Finestra di dialogo Ripristina immagine disco” [pagina 21].

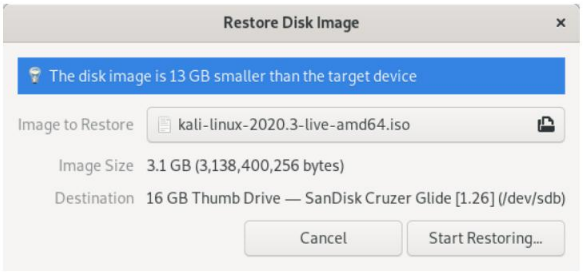



**Figura 2.4** Finestra di dialogo Ripristina immagine disco

Machine Translated by Google

Gustatevi una tazza di caffè mentre il processo di copia dell'immagine sulla chiavetta USB termina (Figura 2.5, "Avanzamento del ripristino dell'immagine" [pagina 22]).

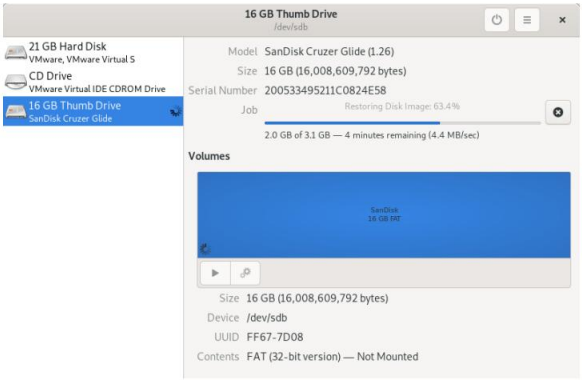



**Figura 2.5** Progressione del ripristino dell'immagine

**Crea la chiavetta USB avviabile Guida dal Comando Linea**

Sebbene la procedura grafica sia piuttosto semplice, l'operazione è altrettanto facile per gli utenti che utilizzano la riga di comando.

Quando inserisci la tua chiavetta USB, il kernel Linux la rileva e le assegna un nome, che viene visualizzato nei log del kernel. Puoi trovare il suo nome esaminando i log restituiti da dmesg.

```
$ dmesg
[...]
[ 2596.727036] usb 1-2.1: nuovo dispositivo USB ad alta velocità numero 7 che utilizza uhci_hcd [ 2597.023023] usb 1-2.1:
nuovo dispositivo USB trovato, idVendor=0781, idProduct=5575,
        ÿ bcdDevice= 1.26
[ 2597.023025] usb 1-2.1: Nuove stringhe del dispositivo USB: Mfr=1, Product=2, ÿ SerialNumber=3

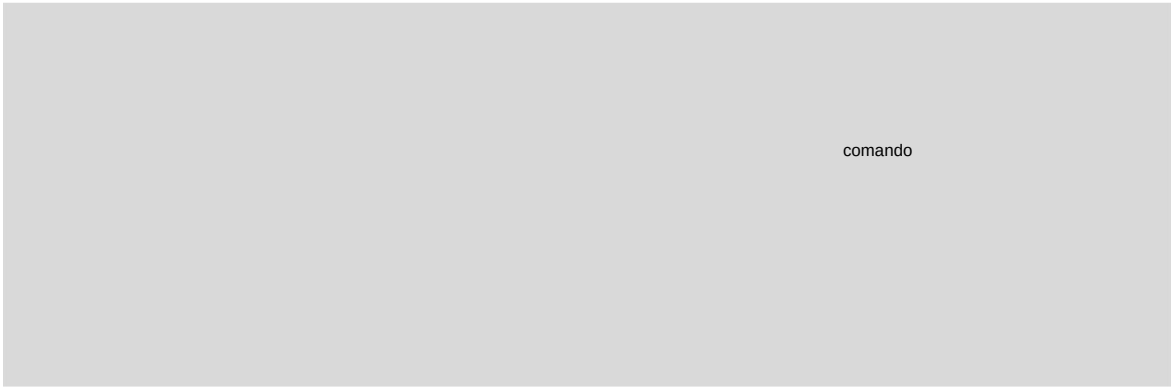
[ 2597.023026] usb 1-2.1: Prodotto: Cruzer Glide [ 2597.023026] usb 1-2.1:
Produttore: SanDisk [ 2597.023026] usb 1-2.1: Numero di serie:
200533495211C0824E58 [ 2597.025989] usb-storage 1-2.1:1.0: Dispositivo di archiviazione di
massa USB rilevato [ 2597.026064] scsi host3: usb-storage 1-2.1:1.0 [ 2598.055632] scsi 3:0:0:0: Accesso diretto
SanDisk Cruzer Glide ÿ PQ: 0 ANSI: 5
                                                                                    1.26

[ 2598.058596] sd 3:0:0:0: SCSI generico sg2 tipo 0 collegato [ 2598.063036] sd 3:0:0:0: [sdb]
31266816 blocchi logici da 512 byte: (16,0 GB
        ÿ /14,9 GiB)
[ 2598.067356] sd 3:0:0:0: [sdb] Protezione scrittura disattivata [ 2598.067361] sd
3:0:0:0: [sdb] Mode Sense: 43 00 00 00 [ 2598.074276] sd 3:0:0:0: [sdb] Cache di scrittura:
disabilitata, cache di lettura: abilitata, ÿ non supporta DPO o FUA [ 2598.095976] sdb: sdb1 [ 2598.108225] sd 3:0:0:0: [sdb]
        Disco rimovibile SCSI collegato
```

Ora che sai che la chiavetta USB è disponibile come /dev/sdb, puoi procedere a copiare l'immagine con il comando dd :

```
# dd if=kali-linux-2020.3-live-amd64.iso of=/dev/sdb
6129688+0 record in
6129688+0 record espresse
3138400256 byte (3,1 GB, 2,9 GiB) copiati, 678,758 s, 4,6 MB/s
```

Machine Translated by Google




Creazione di un'unità USB avviabile con Kali su OS X/macOS

OS X/macOS è basato su UNIX, quindi la procedura per creare un'unità USB avviabile con Kali Linux è simile a quella per Linux. Dopo aver scaricato e verificato il file ISO di Kali scelto, usa il comando dd per copiarlo sulla tua chiavetta USB.

Per identificare il nome del dispositivo della chiavetta USB, esegui il comando `diskutil list` per visualizzare l'elenco dei dischi disponibili sul sistema. Successivamente, inserisci la chiavetta USB ed esegui nuovamente il comando `diskutil list` . Il secondo output dovrebbe elencare un disco aggiuntivo. Puoi determinare il nome del dispositivo della chiavetta USB confrontando l'output di entrambi i comandi. Cerca una nuova riga che identifichi il tuo disco USB e prendi nota di `/dev/diskX`, dove *X* rappresenta l'ID del disco.

È necessario assicurarsi che la chiavetta USB non sia montata, operazione che può essere eseguita con un comando di smontaggio esplicito (supponendo che /dev/disk6 sia il nome del dispositivo della chiavetta USB):

```
$ diskutil unmount /dev/disk6
```

Ora procedi con l'esecuzione del comando dd . Questa volta, aggiungi un parametro supplementare: bs per la dimensione del blocco. Definisce la dimensione del blocco letto dal file di input e successivamente scritto nel file di output. Utilizzeremo anche il percorso del disco raw (indicato dalla *r* prima *di disk)* che consentirà velocità di scrittura più elevate.

```
# dd if=kali-linux-2020.3-live-amd64.iso of=/dev/rdisk2 bs=4m
748+1 record in
748+1 record pubblicati
3138400256 byte trasferiti in 713,156461 secondi (4400718 byte/sec)
```

Ecco fatto. La tua chiavetta USB è pronta e puoi usarla per avviare il sistema o per installare Kali Linux.

**Avvio da un disco alternativo su OS X/macOS**

Per avviare un sistema OS X/macOS da un'unità alternativa, apri il menu di avvio tenendo premuto il tasto Option subito dopo aver acceso il dispositivo e seleziona l'unità che desideri utilizzare.

Per ulteriori informazioni, consultare la knowledge base di Apple.2 .

Machine Translated by Google

## 2.2. Avvio di un'immagine ISO di Kali in modalità Live

### 2.2.1. Su un computer reale

Come prerequisito, è necessario disporre di una chiavetta USB preparata (come descritto nella sezione precedente) oppure di un DVD-ROM masterizzato con un'immagine ISO di Kali Linux.

Il BIOS/UEFI è responsabile del processo di avvio iniziale e può essere configurato tramite un software chiamato Setup. In particolare, consente agli utenti di scegliere il dispositivo di avvio preferito. In questo caso, è necessario selezionare l'unità DVD-ROM o l'unità USB, a seconda del dispositivo creato. A seconda del BIOS/UEFI in uso, potrebbe essere disponibile un'opzione di menu di avvio temporaneo che consente di modificare temporaneamente l'ordine di avvio.

L'avvio del Setup di solito prevede la pressione di un tasto specifico subito dopo l'accensione del computer. Questo tasto è spesso Canc o Esc, e talvolta F2, F8, F10 o F12. Nella maggior parte dei casi, la scelta viene visualizzata brevemente sullo schermo all'accensione del computer, prima del caricamento del sistema operativo.

Una volta configurato correttamente il BIOS/UEFI per l'avvio dal dispositivo, avviare Kali Linux è semplicemente una questione di inserire il DVD-ROM o collegare l'unità USB e accendere il computer.

**Disabilitare l'avvio protetto (Secure Boot):** Sebbene le immagini di Kali Linux possano essere avviate in modalità UEFI, non supportano l'avvio protetto. È necessario disabilitare questa funzione nel BIOS/UEFI del computer.

### 2.2.2. In una macchina virtuale

Le macchine virtuali offrono numerosi vantaggi agli utenti di Kali Linux. Sono particolarmente utili se si desidera provare Kali Linux senza doverlo installare in modo permanente sul proprio computer, oppure se si dispone di un sistema potente e si desidera eseguire più sistemi operativi contemporaneamente. Questa è una scelta popolare tra i penetration tester e i professionisti della sicurezza che necessitano di utilizzare l'ampia gamma di strumenti disponibili in Kali Linux, pur mantenendo il pieno accesso al proprio sistema operativo principale. Inoltre, offre la possibilità di archiviare o eliminare in modo sicuro la macchina virtuale e tutti i dati del cliente in essa contenuti, senza dover reinstallare l'intero sistema operativo.

Le funzionalità di snapshot del software di virtualizzazione consentono inoltre di sperimentare facilmente operazioni potenzialmente pericolose, come l'analisi di malware, offrendo al contempo una via d'uscita semplice ripristinando uno snapshot precedente.

Sono disponibili molti strumenti di virtualizzazione per tutti i principali sistemi operativi, *tra cui VirtualBox®, VMware Workstation®, Xen, KVM* e *Hyper-V ,* solo per citarne alcuni. In definitiva, utilizzerai quello più adatto alle tue esigenze, ma tratteremo i due più frequentemente utilizzati in un contesto desktop: *VirtualBox*® e

[2] https://support.apple.com/en-gb/guide/mac-help/mchlp1034/mac

Machine Translated by Google

*VMware Workstation®,* entrambi in esecuzione su Microsoft Windows 10. Se non hai vincoli imposti dalle policy aziendali o preferenze personali, ti consigliamo di provare prima VirtualBox, in quanto è gratuito, funziona bene, è (per lo più) open source ed è disponibile per la maggior parte dei sistemi operativi.

Nelle sezioni successive, daremo per scontato che abbiate già installato lo strumento di virtualizzazione appropriato e che abbiate familiarità con il suo funzionamento.

## Osservazioni preliminari

Per sfruttare appieno i vantaggi della virtualizzazione, è necessario disporre di una CPU con le funzionalità di virtualizzazione appropriate e queste non devono essere disabilitate dal BIOS/UEFI. Verificate la presenza delle opzioni "Intel® Virtualization Technology" e/o "Intel® VT-d Feature" nelle schermate di configurazione del computer.

È inoltre necessario disporre di un sistema operativo host a 64 bit, come l'architettura amd64 per le distribuzioni Linux basate su Debian, l'architettura x86_64 per le distribuzioni Linux basate su Red Hat e 64 bit per Microsoft Windows.

Se non si soddisfano i prerequisiti, lo strumento di virtualizzazione non funzionerà correttamente oppure sarà limitato all'esecuzione di soli sistemi operativi guest a 32 bit.

Poiché gli strumenti di virtualizzazione si integrano a basso livello con il sistema operativo host e l'hardware, spesso si verificano incompatibilità tra di essi. Non aspettatevi che questi strumenti funzionino correttamente contemporaneamente. Inoltre, gli utenti di Microsoft Windows devono tenere presente che le edizioni Professional o superiori includono *Hyper-V* preinstallato e abilitato, il che potrebbe interferire con il software di virtualizzazione scelto. Per disattivarlo, è necessario eseguire "Attiva o disattiva funzionalità di Windows" dalle Impostazioni di Windows.

## VirtualBox

Dopo l'installazione iniziale, la schermata principale di VirtualBox si presenta più o meno come nella Figura 2.6, "Schermata iniziale di VirtualBox" [pagina 26].

Machine Translated by Google

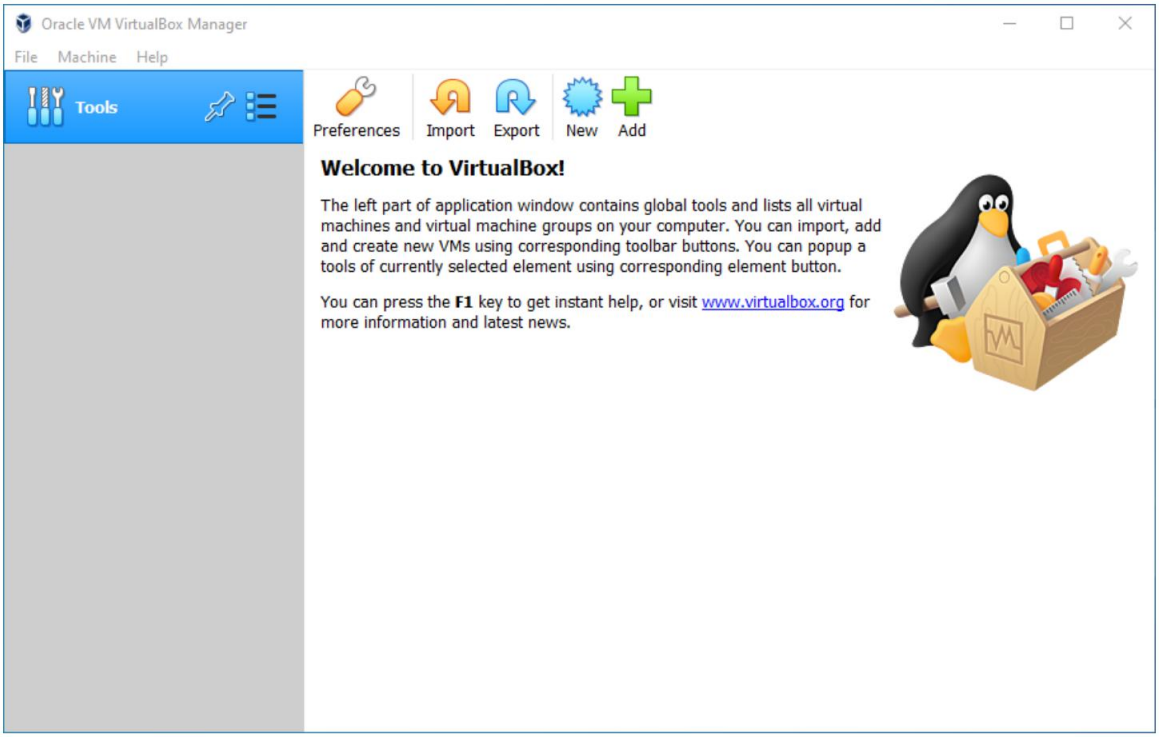



**Figura 2.6** Schermata iniziale di VirtualBox

Fai clic su Nuovo (Figura 2.7, "Nome e sistema operativo" [pagina 27]) per avviare una procedura guidata che ti accompagnerà attraverso i vari passaggi necessari per inserire tutti i parametri della nuova macchina virtuale.

Machine Translated by Google

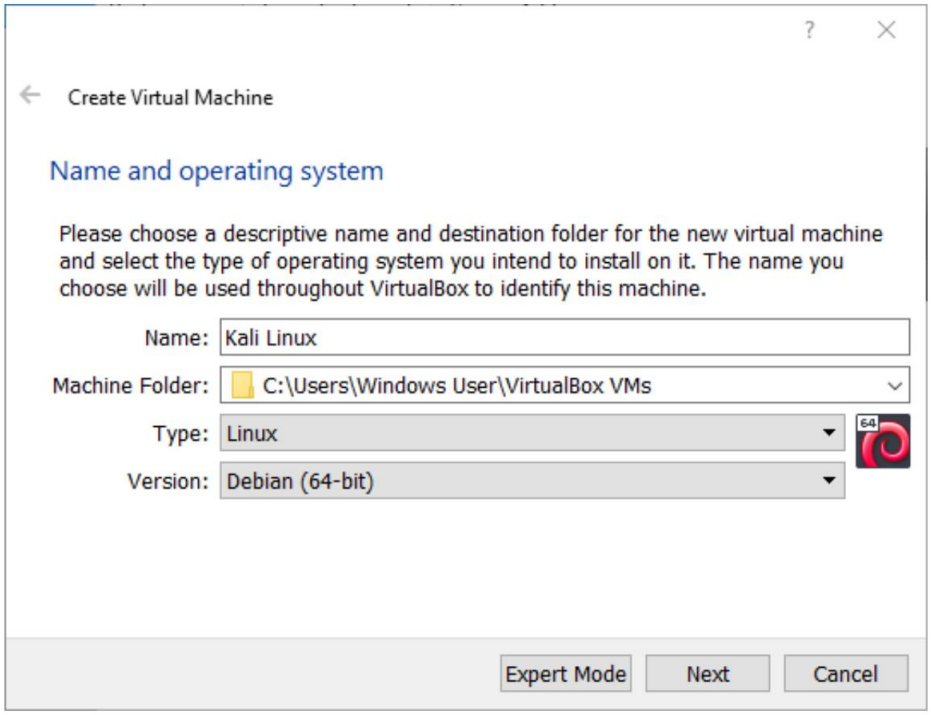



**Figura 2.7** Nome e sistema operativo

Nella prima fase, illustrata nella Figura 2.7, "Nome e sistema operativo" [pagina 27], è necessario assegnare un nome alla nuova macchina virtuale. Useremo "Kali Linux". È inoltre necessario indicare il tipo di sistema operativo da utilizzare. Poiché Kali Linux è basato su Debian GNU/Linux, selezionare "Linux" come tipo e "Debian (32 bit)" o "Debian (64 bit)" come versione. Sebbene qualsiasi altra versione di Linux funzioni probabilmente, questa impostazione aiuterà a distinguere le diverse macchine virtuali eventualmente installate.

Machine Translated by Google

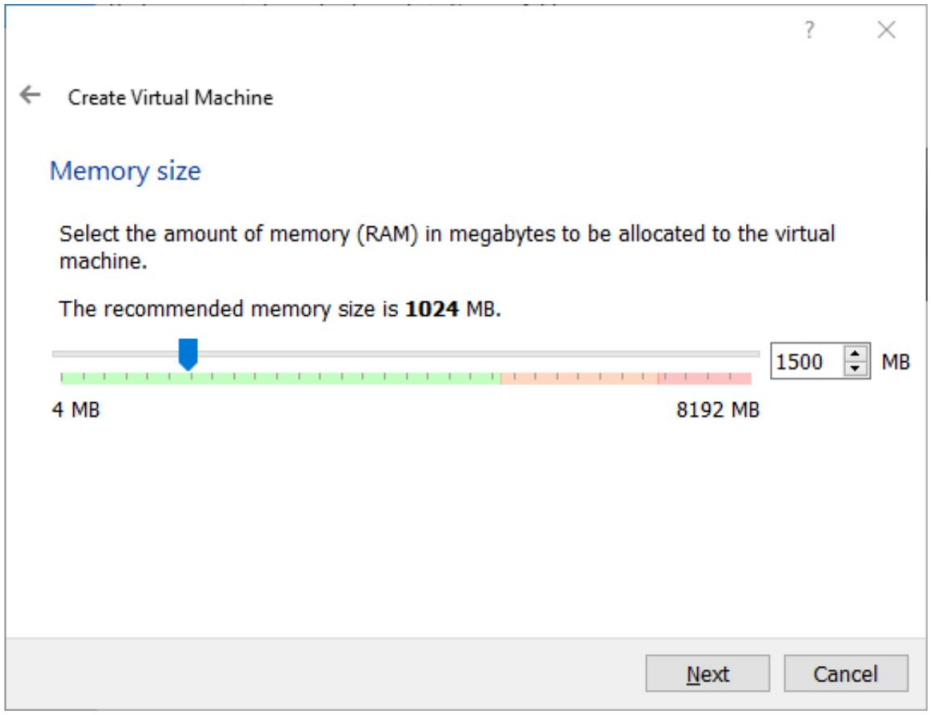



**Figura 2.8** Dimensione della memoria

Nella seconda fase, è necessario decidere quanta memoria allocare alla macchina virtuale. Sebbene la dimensione consigliata di 1024 MB sia accettabile per una macchina virtuale Debian che funge da server, non è assolutamente sufficiente per eseguire un sistema desktop Kali, soprattutto non per un sistema live di Kali Linux, poiché il sistema live utilizza la memoria per memorizzare le modifiche apportate al file system. Si consiglia di aumentare il valore a 1500 MB (Figura 2.8, "Dimensione della memoria" [pagina 28]) e si raccomanda vivamente di allocare non meno di 2048 MB di RAM. Per ulteriori informazioni, consultare la sezione 4.1, "Requisiti minimi di installazione" [pagina 66].

Machine Translated by Google

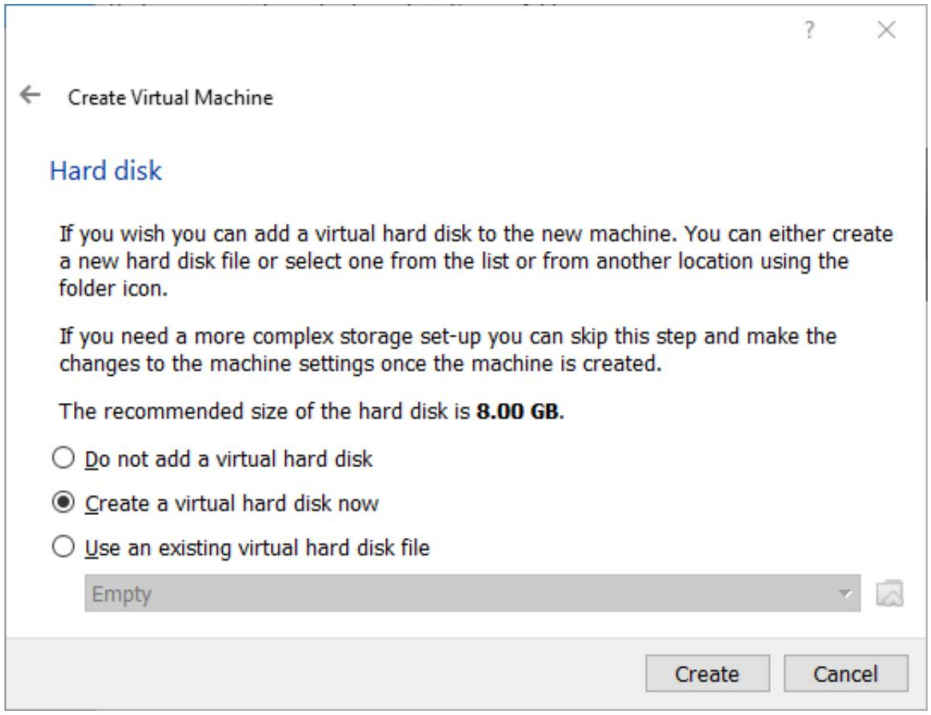



**Figura 2.9** Disco rigido

Nel terzo passaggio (mostrato nella Figura 2.9, "Disco rigido" [pagina 29]), viene richiesto di scegliere un disco rigido fisico o virtuale per la nuova macchina virtuale. Sebbene non sia necessario un disco rigido per eseguire Kali Linux come sistema live, aggiungine uno per quando mostreremo la procedura di installazione più tardi, in capitolo 4, "Installazione di Kali Linux" [pagina 66].

Machine Translated by Google

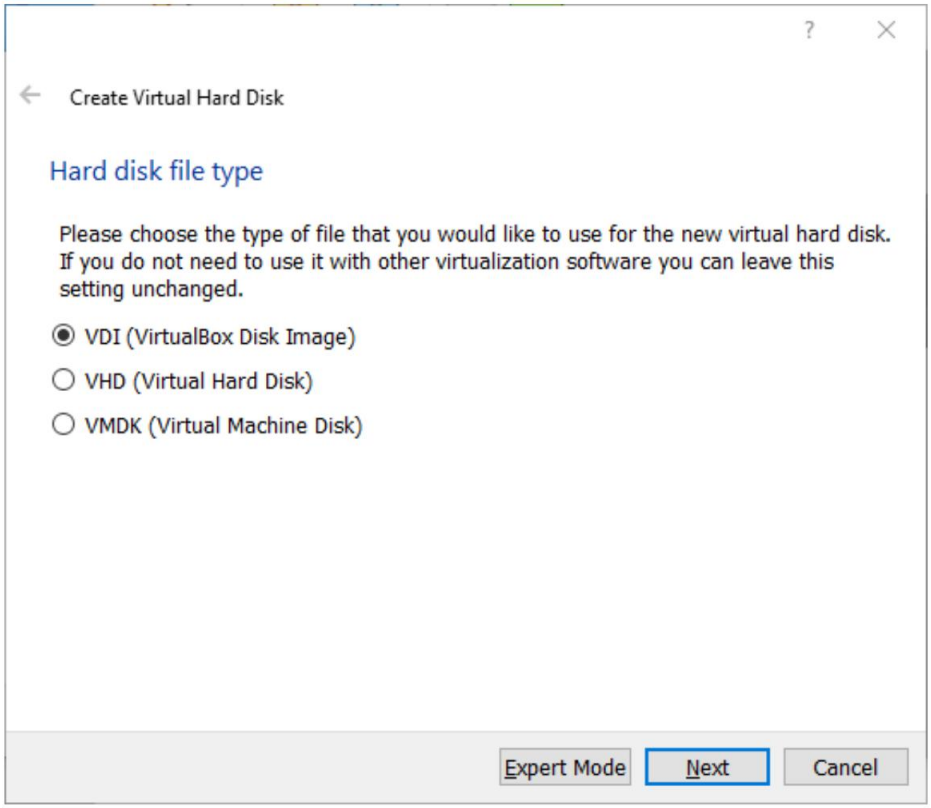



**Figura 2.10** Tipo di file del disco rigido

Il contenuto del disco rigido della macchina virtuale viene memorizzato sulla macchina host come file. VirtualBox è in grado di memorizzare il contenuto del disco rigido utilizzando più formati (mostrati nella Figura 2.10, "Tipo di file del disco rigido" [pagina 30]): l'impostazione predefinita (VDI) corrisponde al formato nativo di VirtualBox; VMDK è il formato utilizzato da VMware. Mantieni il valore predefinito, perché non hai alcun motivo per cambiarlo. La possibilità di utilizzare più formati è interessante soprattutto quando si desidera spostare un macchina virtuale da uno strumento di virtualizzazione a un altro.

Machine Translated by Google

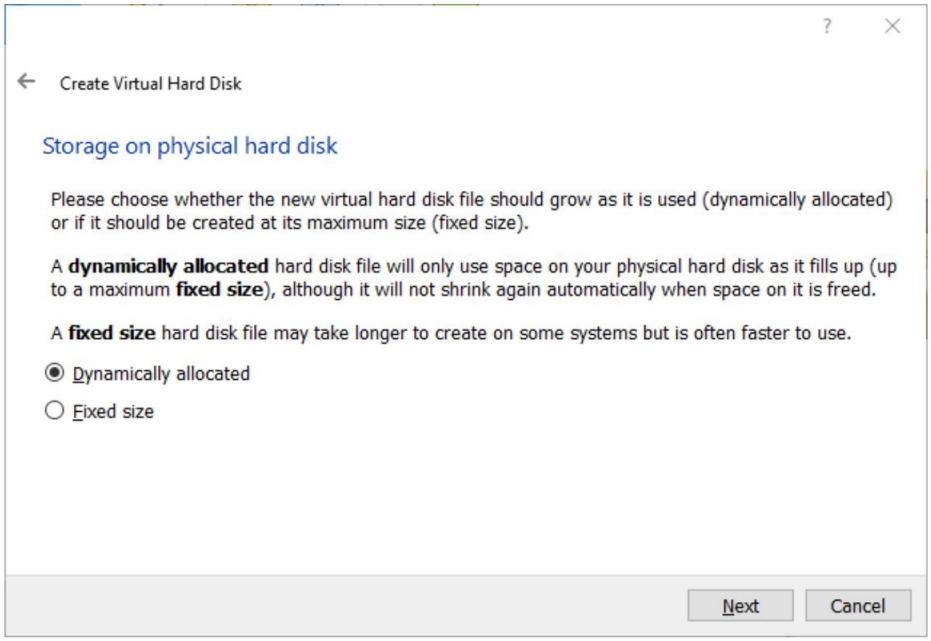



**Figura 2.11** Archiviazione su disco rigido fisico

Il testo esplicativo nella Figura 2.11, "Archiviazione su disco rigido fisico" [pagina 31], descrive chiaramente i vantaggi e gli svantaggi dell'allocazione dinamica e fissa del disco. In questo esempio, accettiamo la selezione predefinita (allocazione dinamica), poiché stiamo utilizzando un laptop con dischi SSD. Non vogliamo sprecare spazio e non avremo bisogno di prestazioni aggiuntive, dato che il computer è già abbastanza veloce.

Machine Translated by Google

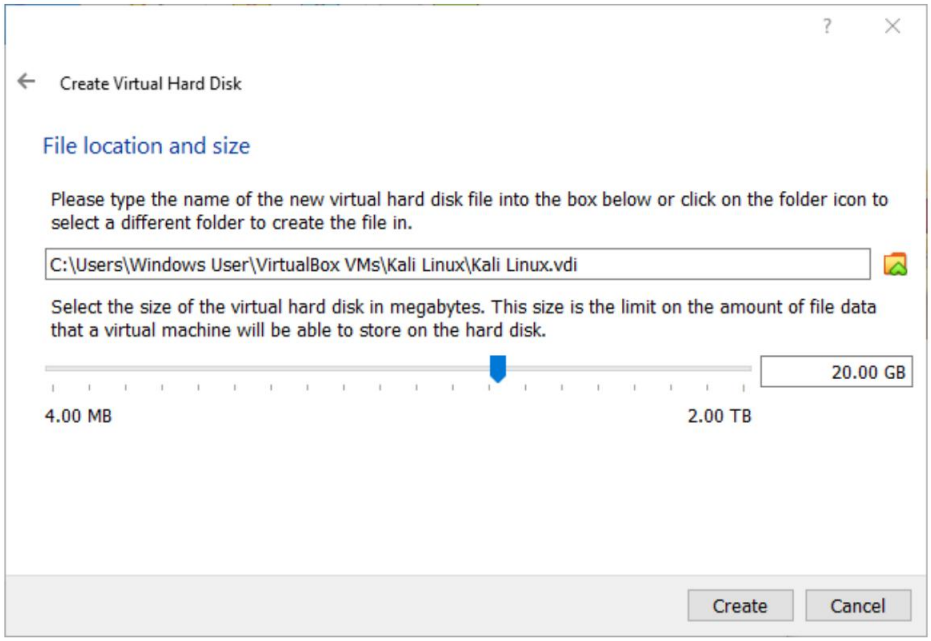



**Figura 2.12** Posizione e dimensione del file

La dimensione predefinita del disco rigido di 20 GB mostrata nella Figura 2.12, "Posizione e dimensione dei file" [pagina 32], è sufficiente per un'installazione standard di Kali Linux, quindi non la modificheremo. Per ulteriori informazioni sui requisiti di Kali, consultare la sezione 4.1, "Requisiti minimi di installazione" [pagina 66]. È anche possibile modificare il nome e la posizione dell'immagine disco. Questo può essere utile quando non si dispone di spazio sufficiente sul disco rigido, consentendo di memorizzare l'immagine disco su un'unità esterna.

Machine Translated by Google

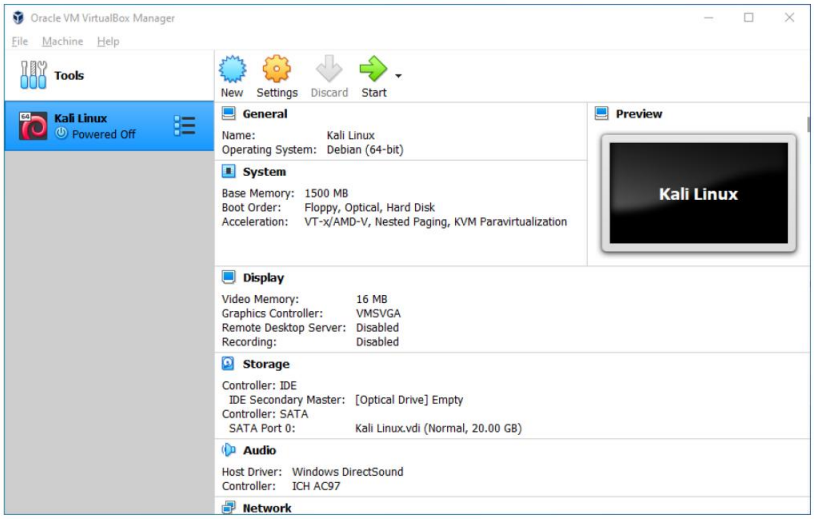



**Figura 2.13** La nuova macchina virtuale appare nell'elenco

La macchina virtuale è stata creata, ma non è ancora possibile eseguirla perché non è installato alcun sistema operativo. È inoltre possibile modificare alcune impostazioni. Fai clic su Impostazioni nella schermata Gestione macchine virtuali e analizziamo alcune delle impostazioni più utili.

Machine Translated by Google

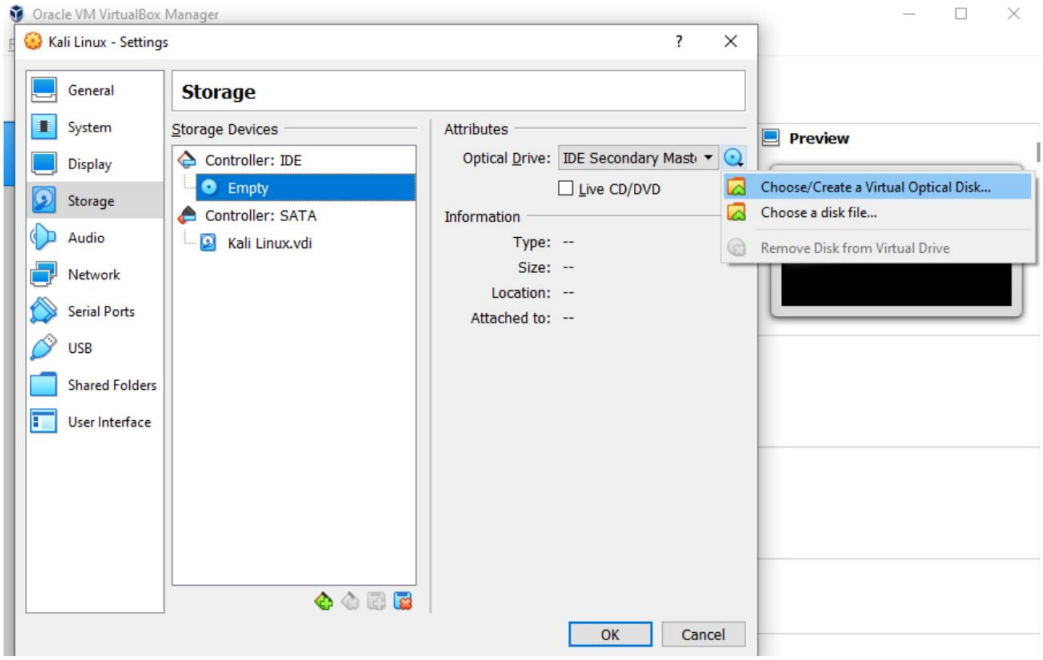



**Figura 2.14** Impostazioni di archiviazione

Nella schermata Archiviazione (Figura 2.14, “Impostazioni di archiviazione” [pagina 34]), dovresti associare Kali Immagine ISO di Linux con lettore CD/DVD-ROM virtuale. Innanzitutto, seleziona l'unità CD-ROM nell'elenco Struttura di archiviazione e poi fai clic sulla piccola icona del CD-ROM a destra per visualizzare un menu contestuale. dove è possibile scegliere il file del disco ottico virtuale…

Machine Translated by Google

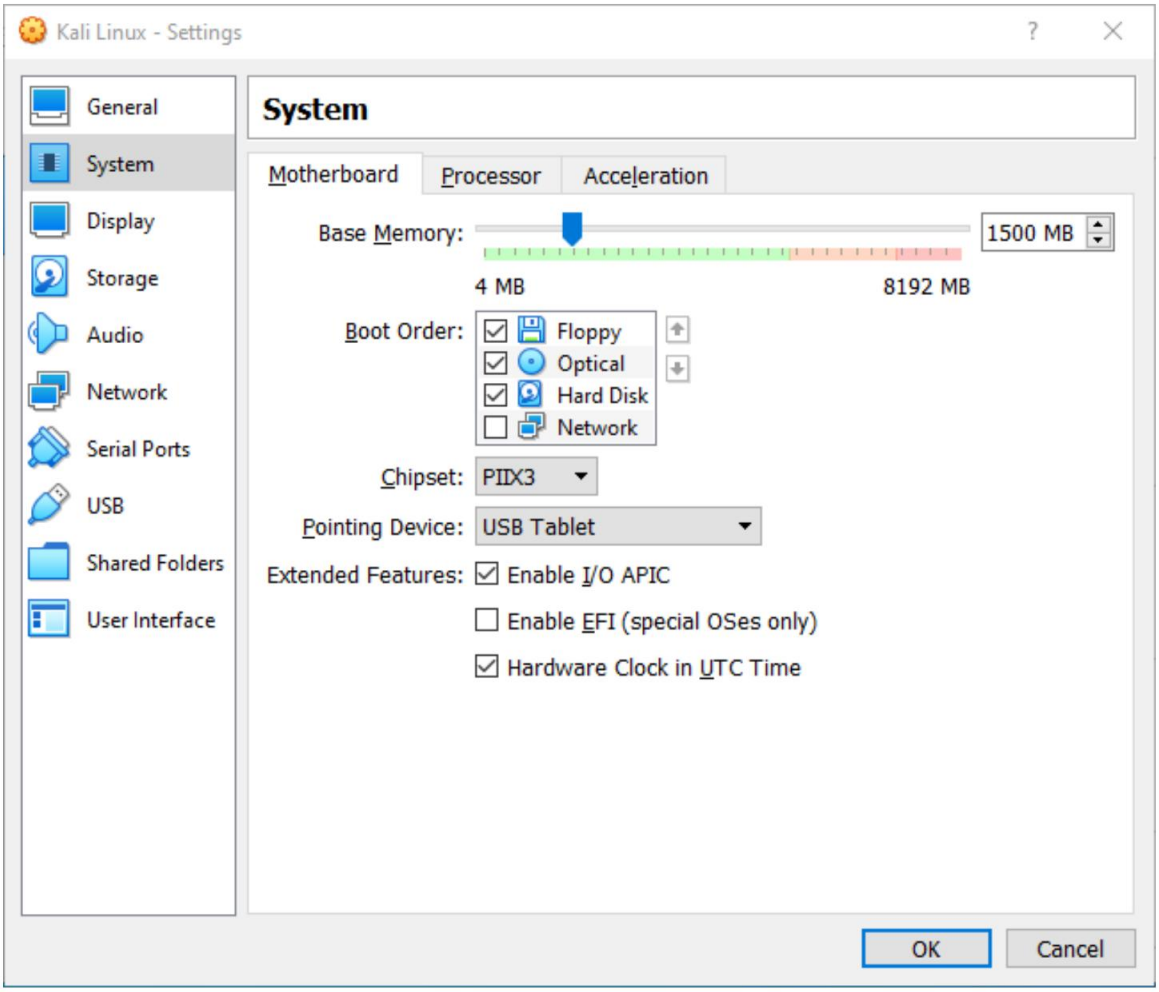



**Figura 2.15** Impostazioni di sistema: Scheda madre

Nella schermata Sistema (Figura 2.15, “Impostazioni di sistema: Scheda madre” [pagina 35]), troverai una scheda Scheda madre. Assicurati che l'ordine di avvio indichi che il sistema tenterà prima di avviarsi da qualsiasi dispositivo ottico prima di provare un disco rigido. Questa è anche la scheda in cui è possibile modificare la quantità della memoria allocata alla macchina virtuale, qualora se ne presentasse la necessità.

Machine Translated by Google

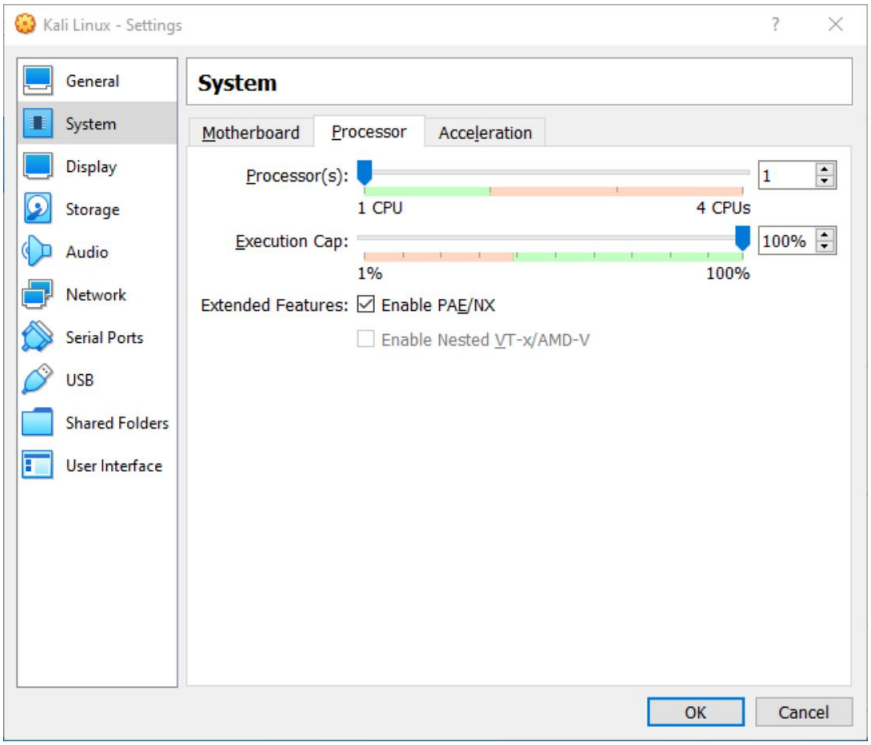



**Figura 2.16** Impostazioni di sistema: Processore

Nella stessa schermata, ma nella scheda "Processore" (Figura 2.16, "Impostazioni di sistema: Processore" [pagina 36]), è possibile regolare il numero di processori assegnati alla macchina virtuale. È fondamentale, soprattutto se si utilizza un'immagine a 32 bit, abilitare PAE/NX, altrimenti l'immagine di Kali non si avvierà poiché la variante del kernel predefinita utilizzata da Kali per i386 (denominata "686-pae") è compilata in modo da richiedere il supporto di Physical Address Extension (PAE) nella CPU.

Esistono molti altri parametri configurabili, come la configurazione di rete (che definisce come viene gestito il traffico sulla scheda di rete), ma le modifiche sopra descritte sono sufficienti per avviare un sistema live di Kali Linux funzionante. Infine, fai clic su Avvia e la macchina virtuale dovrebbe avviarsi correttamente, come mostrato nella Figura 2.17, "Schermata di avvio di Kali Linux in VirtualBox" [pagina 37]. In caso contrario, rivedi attentamente tutte le impostazioni e riprova.

Machine Translated by Google

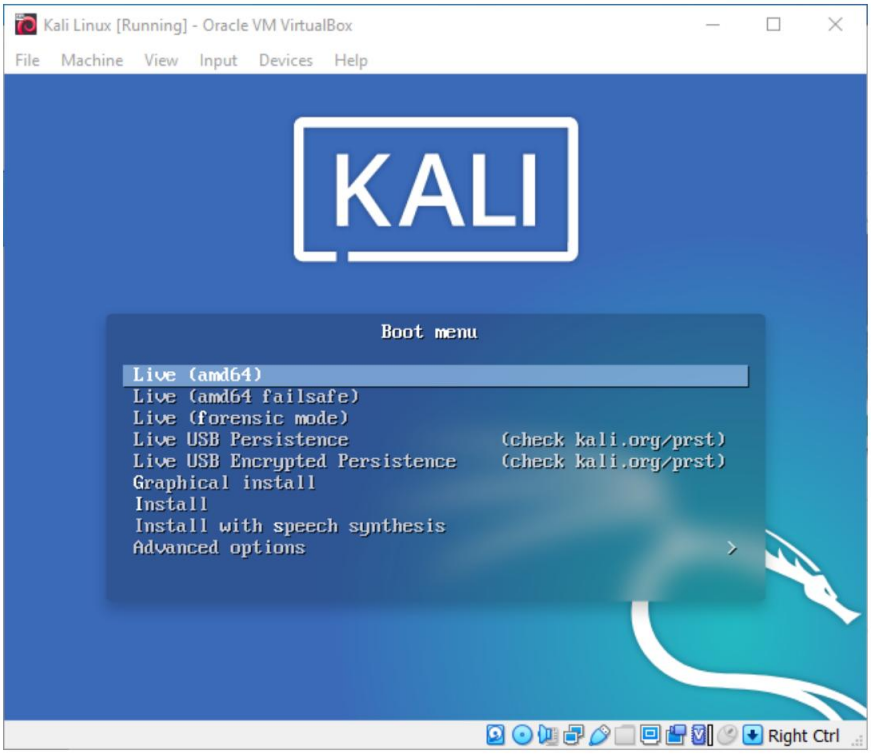



**Figura 2.17** Schermata di avvio di Kali Linux in VirtualBox

## Workstation VMware

*VMware Workstation* è molto simile a *VirtualBox* in termini di funzionalità e interfaccia utente, perché Entrambi sono progettati principalmente per l'utilizzo su desktop, ma la procedura di configurazione per una nuova macchina virtuale è leggermente diversa. Noi utilizzeremo *VMware Workstation Pro* Edition.

Machine Translated by Google

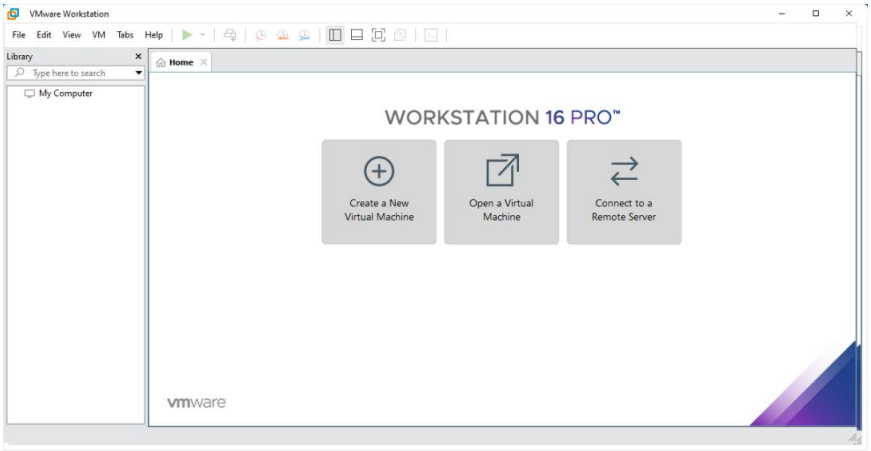



**Figura 2.18** Schermata iniziale di VMware

La schermata iniziale, mostrata nella Figura 2.18, "Schermata di avvio di VMware" [pagina 38], visualizza un grande pulsante "Crea una nuova macchina virtuale" che avvia una procedura guidata per accompagnarti nella creazione della tua macchina virtuale.




**Figura 2.19** Creazione guidata nuova macchina virtuale

Machine Translated by Google

Come primo passo, è necessario decidere se si desidera visualizzare le impostazioni avanzate durante il processo di installazione. In questo esempio, non ci sono requisiti particolari, quindi si può scegliere l'installazione tipica, come mostrato nella Figura 2.19, "Creazione guidata nuova macchina virtuale" [pagina 38].

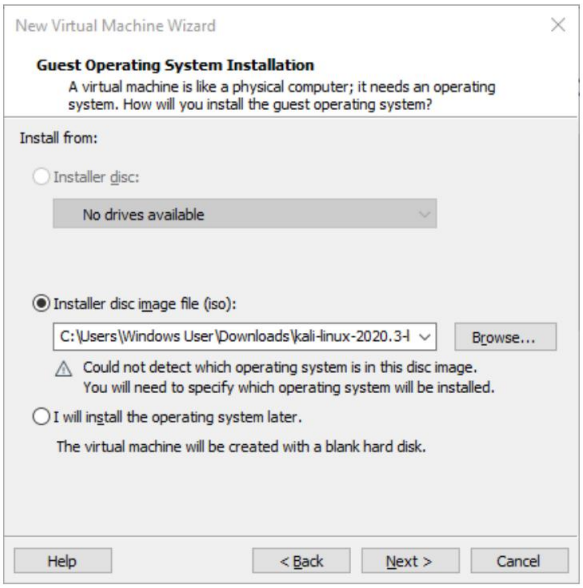



**Figura 2.20** Installazione del sistema operativo guest

La procedura guidata presuppone che si desideri installare immediatamente il sistema operativo e chiede di selezionare l'immagine ISO contenente il programma di installazione (Figura 2.20, "Installazione del sistema operativo guest" [pagina 39]). Selezionare "File immagine del disco di installazione (iso)" e fare clic su Sfoglia per selezionare il file immagine.

Machine Translated by Google

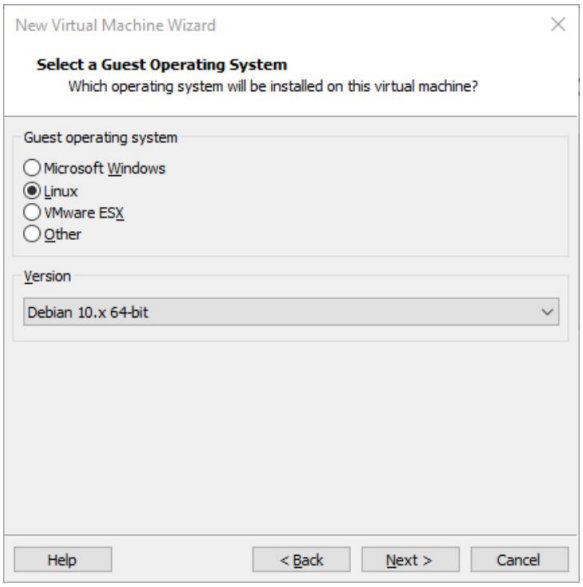



**Figura 2.21** Selezione di un sistema operativo guest

Quando il sistema operativo non può essere rilevato dall'immagine ISO selezionata, la procedura guidata chiede quale tipo di sistema operativo guest si intende eseguire. È necessario selezionare "Linux" come sistema operativo e "Debian 10.x 64-bit" come versione, come mostrato nella Figura 2.21, "Seleziona un sistema operativo guest" [pagina 40]. Selezioniamo "Debian 10.x" perché Kali Linux viene costantemente aggiornato all'ultima *versione* di Debian.

Machine Translated by Google

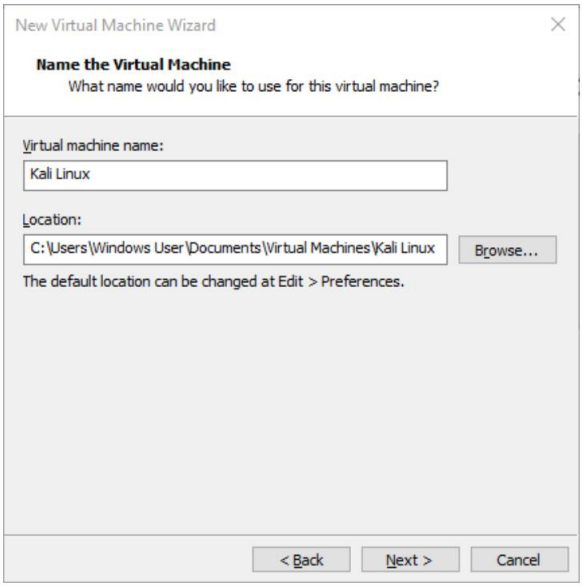



**Figura 2.22** Assegna un nome alla macchina virtuale

Scegli "Kali Linux" come nome della nuova macchina virtuale (Figura 2.22, "Assegna un nome alla macchina virtuale" [pagina 41]). Come con VirtualBox, hai anche la possibilità di salvare i file della macchina virtuale. in un luogo alternativo.

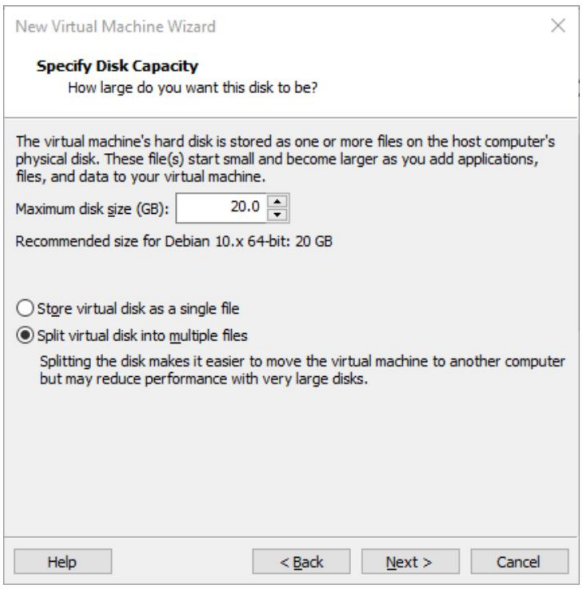



**Figura 2.23** Specificare la capacità del disco

Machine Translated by Google

La dimensione predefinita del disco rigido di 20 GB (Figura 2.23, "Specifica la capacità del disco" [pagina 41]) è solitamente sufficiente, ma è possibile regolarla qui in base alle proprie esigenze previste. A differenza di VirtualBox, che può utilizzare un singolo file di dimensioni variabili, VMware ha la capacità di memorizzare il contenuto del disco su più file. In entrambi i casi, l'obiettivo è quello di preservare lo spazio su disco dell'host.

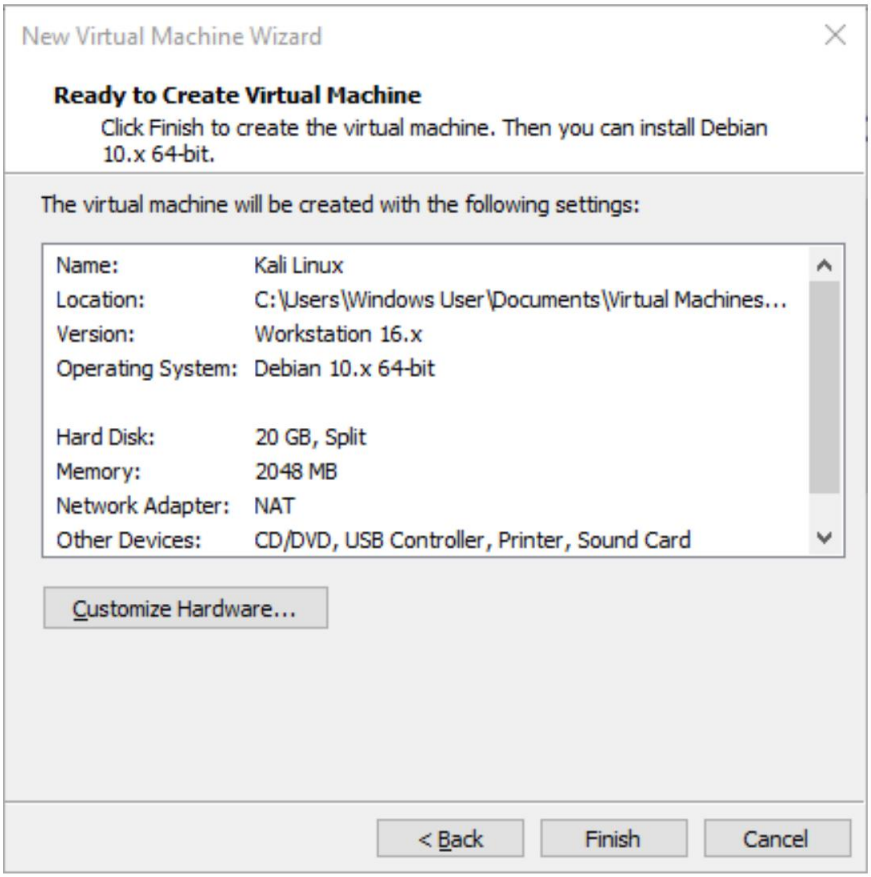



**Figura 2.24** Pronto per creare una macchina virtuale

VMware Workstation è ora configurato per creare la nuova macchina virtuale. Viene visualizzato un riepilogo delle scelte effettuate in modo da poter ricontrollare tutto prima di creare la macchina. Nota che il mago ha scelto di allocare 2048 MB di RAM alla macchina virtuale, che è sufficiente per le nostre esigenze. Se il valore assegnato è inferiore, non è sufficiente, quindi fai clic su Personalizza hardware... (Figura 2.24, "Pronto per creare una macchina virtuale" [pagina 42]) e modifica l'impostazione della memoria, come mostrato nella Figura 2.25, "Finestra di configurazione hardware" [pagina 43].

Machine Translated by Google

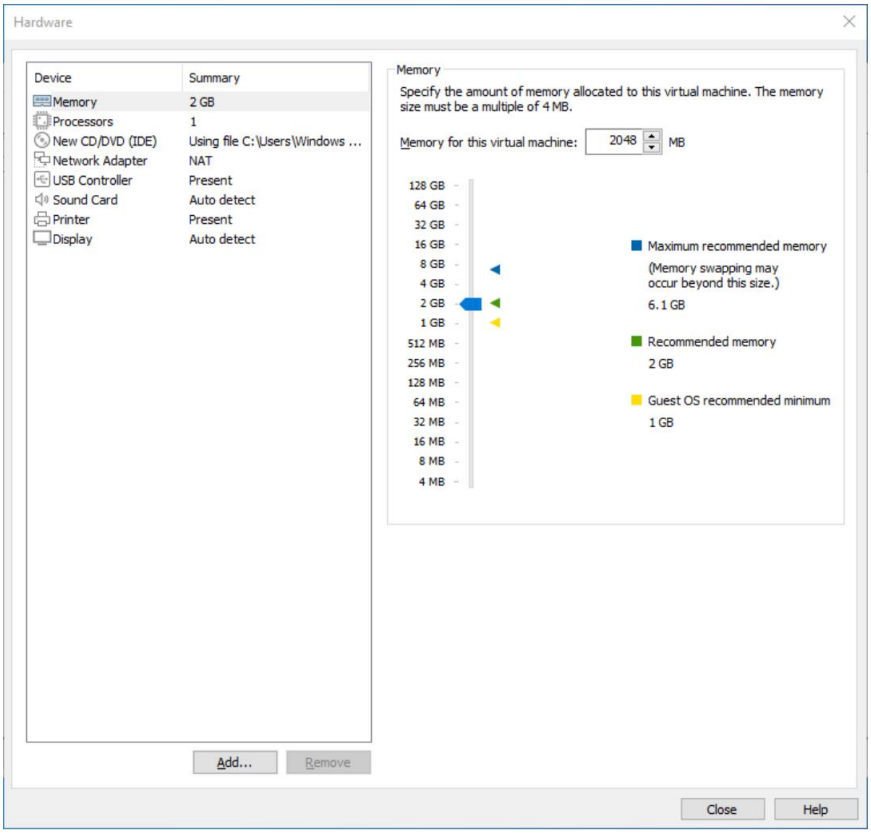



**Figura 2.25** Finestra di configurazione hardware

Dopo un ultimo clic su Fine (Figura 2.24, "Pronto per creare la macchina virtuale" [pagina 42]), la macchina virtuale è ora configurata e può essere avviata facendo clic su "Accendi questa macchina virtuale" come mostrato nella Figura 2.26, "Macchina virtuale Kali Linux pronta" [pagina 44].

Machine Translated by Google

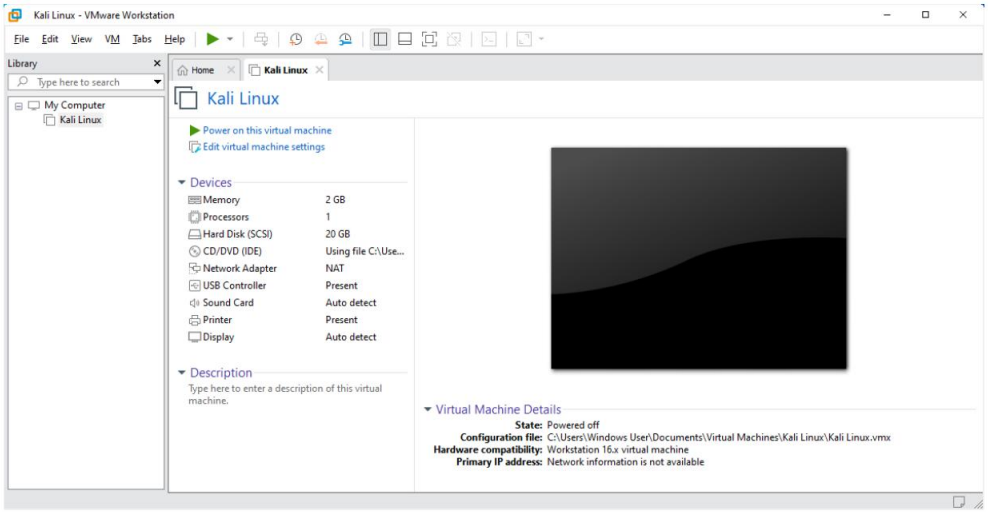



**Figura 2.26** Macchina virtuale Kali Linux pronta

## 2.3. Riepilogo

In questo capitolo, hai appreso le diverse immagini ISO di Kali Linux, come verificarle e scaricarle e come creare unità USB avviabili da esse su vari sistemi operativi. Abbiamo anche discusso di come avviare le unità USB e ripassato come configurare il BIOS/UEFI e le impostazioni di avvio su varie piattaforme hardware in modo che le unità USB si avviino correttamente.

Suggerimenti riassuntivi:

- www.kali.org è l'unico sito ufficiale per il download delle immagini ISO di Kali. Non scaricarle da altri siti, perché potrebbero contenere malware.
- Verifica sempre l'hash SHA256 dei tuoi download con il comando sha256sum per assicurarti l'integrità del file ISO scaricato. Se non corrisponde, riprova a scaricare il file o utilizza una fonte diversa.
- Se si desidera avviare Kali Linux su una macchina fisica, è necessario scrivere l'immagine ISO su un supporto di avvio. Utilizzare *Win32 Disk Imager* su Microsoft Windows, l' *utilità Dischi* su Linux con GNOME o il comando dd su Mac OS X/macOS/Linux. Prestare *molta attenzione* durante la scrittura dell'immagine. La selezione del disco sbagliato potrebbe danneggiare in modo permanente i dati presenti sul computer.
- Configura le schermate di configurazione BIOS/UEFI su un PC o tieni premuto il tasto Opzione su OS X/macOS per consentire l'avvio del computer dall'unità USB.
- I programmi per macchine virtuali come *VirtualBox* e *VMware Workstation Pro* sono particolarmente utili se vuoi provare Kali Linux ma non sei ancora pronto a installarlo in modo permanente su

Machine Translated by Google

la tua macchina o se disponi di un sistema potente e desideri eseguire più sistemi operativi simultaneamente.

Ora che hai un'installazione funzionante di Kali Linux, è il momento di approfondire alcuni fondamenti di Linux necessari per il funzionamento di base e avanzato di Kali. Se sei un utente Linux di livello intermedio o avanzato, considera di dare un'occhiata al capitolo successivo (capitolo 3, "Fondamenti di Linux" [pagina 48]).

Machine Translated by Google

**Parole chiave**

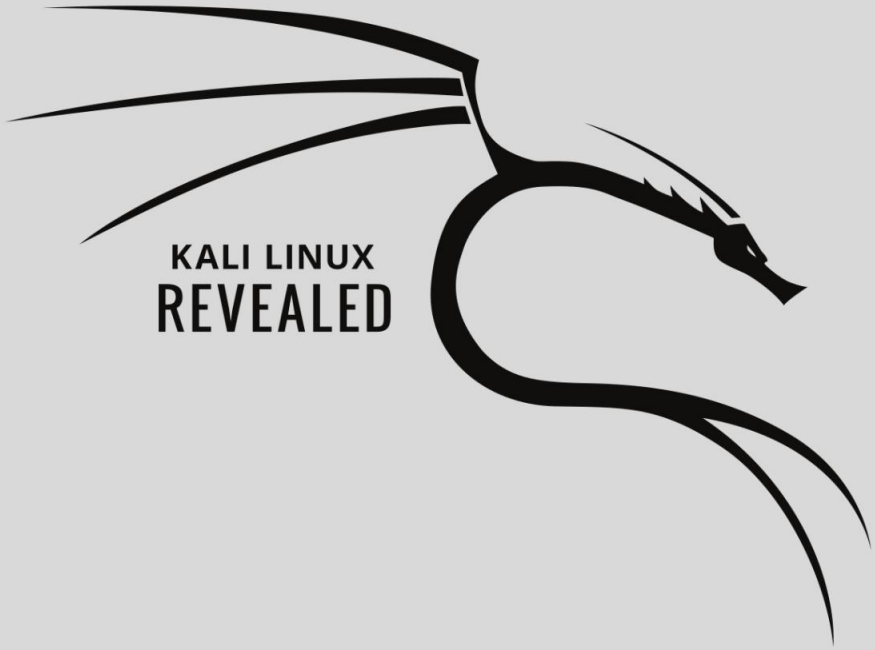
**Kernel di Linux**

**Spazio utente**

**Bash da riga di comando**

**Gerarchia del filesystem**

**Comandi Unix**



Machine Translated by Google

Capitolo

# Nozioni di base su Linux **3**

Contenuto

Cos'è Linux e cosa fa? 48
La riga di comando 51
Il file system 54
Comandi utili 56
Sommario 62

Machine Translated by Google

Prima di poter padroneggiare Kali Linux, è necessario avere familiarità con un sistema Linux generico. La competenza in Linux sarà molto utile, poiché una grande percentuale di servizi web, di posta elettronica e altri servizi Internet funzionano su server Linux.

In questa sezione, ci proponiamo di illustrare le basi di Linux, ma presupponiamo che tu abbia già familiarità con i sistemi informatici in generale, inclusi componenti come CPU, RAM, scheda madre e disco rigido, nonché controller di dispositivo e i relativi connettori.

# 3.1. Cos'è Linux e cosa fa?

Il termine "Linux" viene spesso utilizzato per riferirsi all'intero sistema operativo, ma in realtà Linux è il kernel del sistema operativo, che viene avviato dal boot loader, il quale a sua volta viene avviato dal BIOS/ UEFI. Il kernel svolge un ruolo simile a quello di un direttore d'orchestra: garantisce il coordinamento tra hardware e software. Questo ruolo include la gestione dell'hardware, dei processi, degli utenti, dei permessi e del file system. Il kernel fornisce una base comune a tutti gli altri programmi del sistema e in genere viene eseguito nell'anello *zero,* noto anche come *spazio kernel.*

**Spazio utente** Utilizziamo il termine spazio utente per raggruppare tutto ciò che accade al di fuori del kernel.

Tra i programmi in esecuzione nello spazio utente ci sono molte utilità principali del progetto GNU[1] La maggior parte di questi comandi è pensata per essere eseguita dalla riga di comando. È possibile utilizzarli negli script per automatizzare numerose attività. Per ulteriori informazioni sui comandi più importanti, consultare la sezione 3.4, "Comandi utili" [pagina 56].

Esaminiamo rapidamente i vari compiti gestiti dal kernel Linux.

### 3.1.1. Componenti hardware di pilotaggio

Il kernel ha il compito principale di controllare i componenti hardware del computer.
Il sistema rileva e configura i dispositivi all'accensione del computer o quando un dispositivo viene inserito o rimosso (ad esempio, una chiavetta USB). Li rende inoltre disponibili al software di livello superiore, tramite un'interfaccia di programmazione semplificata, in modo che le applicazioni possano sfruttarli senza dover gestire dettagli come lo slot di espansione in cui è inserita una scheda opzionale. L'interfaccia di programmazione fornisce anche un livello di astrazione; questo permette, ad esempio, a un software di videoconferenza di utilizzare una webcam indipendentemente dal produttore e dal modello. Il software può utilizzare l' interfaccia *Video for Linux* (V4L) e il kernel tradurrà le chiamate di funzione dell'interfaccia in comandi hardware effettivi necessari per la specifica webcam in uso.

Il kernel esporta i dati sull'hardware rilevato tramite i sistemi di file virtuali /proc/ e /sys/ . Le applicazioni spesso accedono ai dispositivi tramite file creati all'interno di /dev/. File specifici rappresentano...

[1] https://www.gnu.org/

Machine Translated by Google

unità disco recenti (ad esempio, /dev/sda), partizioni (/dev/sda1), mouse (/dev/input/mouse0), tastiere (/dev/input/event0), schede audio (/dev/snd/*), porte seriali (/dev/ttyS*) e altri componenti.

Esistono due tipi di file di dispositivo: *a blocchi* e *a caratteri.* Il primo ha le caratteristiche di un blocco di dati: ha una dimensione finita ed è possibile accedere ai byte in qualsiasi posizione del blocco. Il secondo si comporta come un flusso di caratteri. È possibile leggere e scrivere caratteri, ma non è possibile posizionarsi in una determinata posizione e modificare byte arbitrari. Per scoprire il tipo di un determinato file di dispositivo, esaminare la prima lettera nell'output di ls -l. È b, per i dispositivi a blocchi, o c, per i dispositivi a caratteri: $ **ls -l /dev/sda /dev/ttyS0** brw-rw---- 1 root disk 8, 0 Mar 21 08:44 /dev/sda crw-rw---- 1 root dialout 4, 64 Mar 30 08:59 /dev/ttyS0

Come ci si potrebbe aspettare, le unità disco e le partizioni utilizzano dispositivi a blocchi, mentre mouse, tastiera e porte seriali utilizzano dispositivi a caratteri. In entrambi i casi, l'interfaccia di programmazione include comandi specifici del dispositivo che possono essere richiamati tramite la chiamata di sistema *ioctl* .

### 3.1.2. Unificazione dei file system

I file system sono un aspetto fondamentale del kernel. I sistemi Unix-like unificano tutti gli archivi di file in un'unica gerarchia, consentendo a utenti e applicazioni di accedere ai dati conoscendone la posizione all'interno di tale gerarchia.

Il punto di partenza di questo albero gerarchico è chiamato radice, rappresentato dal carattere “/” .
Questa directory può contenere sottodirectory con nome. Ad esempio, la sottodirectory home di / si chiama /home/. Questa sottodirectory può a sua volta contenere altre sottodirectory, e così via. Ogni directory può anche contenere file, in cui verranno memorizzati i dati. Pertanto, /home/kali/Desktop/hello.txt si riferisce a un file chiamato hello.txt memorizzato nella sottodirectory Desktop della sottodirectory kali della directory home , presente nella directory principale. Il kernel effettua la traduzione tra questo sistema di denominazione e la posizione di memorizzazione su un disco.

A differenza di altri sistemi, Linux possiede un'unica gerarchia di questo tipo e può integrare dati provenienti da più dischi. Uno di questi dischi diventa la directory radice, mentre gli altri vengono *montati* in directory all'interno della gerarchia (il comando Linux si chiama mount). Questi altri dischi sono quindi disponibili tramite i *punti di mount.* Ciò consente di memorizzare le directory home degli utenti (tradizionalmente contenute in /home/) su un disco rigido separato, che conterrà la directory kali (insieme alle directory home degli altri utenti). Una volta montato il disco su /home/, queste directory diventano accessibili nelle loro posizioni abituali e percorsi come /home/kali/Desktop/hello.txt continuano a funzionare.

Esistono molti formati di file system, corrispondenti a diverse modalità di memorizzazione fisica dei dati sui dischi. I più noti sono *ext2, ext3* ed *ext4,* ma ne esistono anche altri. Ad esempio, *VFAT* è il file system storicamente utilizzato dai sistemi operativi DOS e Microsoft Windows. Il supporto di Linux per VFAT consente l'accesso ai dischi rigidi sia in Kali Linux che in Microsoft Windows.
In ogni caso, è necessario preparare un file system su un disco prima di poterlo montare e questa operazione è

Machine Translated by Google

nota come *formattazione.* Comandi come mkfs.ext4 (dove mkfs sta per *Make FileSystem)* gestiscono la formattazione. Questi comandi richiedono, come parametro, un file di dispositivo che rappresenta la partizione da formattare (ad esempio, /dev/sda1, la prima partizione sul primo disco). Questa operazione è distruttiva e dovrebbe essere eseguita una sola volta, a meno che non si desideri cancellare un filesystem e ricominciare da capo.

Esistono anche file system di rete, come NFS, che non memorizzano i dati su un disco locale. I dati vengono invece trasmessi attraverso la rete a un server che li memorizza e li recupera su richiesta.
Grazie all'astrazione del file system, non è necessario preoccuparsi di come viene collegato questo disco, poiché i file rimangono accessibili nel loro solito modo gerarchico.

### 3.1.3. Gestione dei processi

Un processo è un'istanza in esecuzione di un programma, che richiede memoria per memorizzare sia il programma stesso che i suoi dati operativi. Il kernel è responsabile della creazione e del monitoraggio dei processi. Quando un programma viene eseguito, il kernel riserva innanzitutto della memoria, carica il codice eseguibile dal file system in tale memoria e quindi avvia l'esecuzione del codice. Il kernel conserva informazioni su questo processo, la più visibile delle quali è un numero di identificazione noto come *identificatore di processo* (PID).

Come la maggior parte dei sistemi operativi moderni, quelli con kernel di tipo Unix, incluso Linux, sono in grado di gestire il multitasking. In altre parole, consentono al sistema di eseguire molti processi contemporaneamente.
In realtà, in un dato momento è in esecuzione un solo processo, ma il kernel suddivide il tempo della CPU in piccoli intervalli e li esegue uno alla volta. Poiché questi intervalli di tempo sono molto brevi (nell'ordine dei millisecondi), creano l'illusione di processi in esecuzione in parallelo, sebbene siano attivi solo durante il loro intervallo e inattivi per il resto del tempo. Il compito del kernel è quello di regolare i propri meccanismi di pianificazione per mantenere questa illusione, massimizzando al contempo le prestazioni complessive del sistema. Se gli intervalli di tempo sono troppo lunghi, l'applicazione potrebbe non risultare reattiva come desiderato. Se sono troppo brevi, il sistema perde tempo passando da un'attività all'altra troppo frequentemente. Queste decisioni possono essere affinate tramite le priorità dei processi, in cui i processi ad alta priorità vengono eseguiti per periodi più lunghi e con intervalli di tempo più frequenti rispetto ai processi a bassa priorità.

**Sistemi multiprocessore (e varianti)**

La limitazione descritta sopra, ovvero la possibilità di eseguire un solo processo alla volta, non si applica sempre: la restrizione effettiva è che può esserci un solo processo in esecuzione per core del processore. I sistemi multiprocessore, multicore o hyper-threading consentono l'esecuzione parallela di più processi. Lo stesso sistema di time-slicing viene comunque utilizzato per gestire i casi in cui ci sono più processi attivi rispetto ai core del processore disponibili. Questo non è insolito: un sistema di base, anche se perlopiù inattivo, ha quasi sempre decine di processi in esecuzione.
processi.

Il kernel consente l'esecuzione di diverse istanze indipendenti dello stesso programma, ma a ciascuna è consentito accedere solo alle proprie porzioni di tempo e alla propria memoria. I loro dati rimangono quindi indipendenti.

Machine Translated by Google

### 3.1.4. Gestione dei diritti

I sistemi Unix-like supportano più utenti e gruppi e consentono il controllo dei permessi. Nella maggior parte dei casi, un processo viene identificato dall'utente che lo ha avviato. A tale processo è consentito eseguire solo le azioni consentite al suo proprietario. Ad esempio, l'apertura di un file richiede che il kernel verifichi l'identità del processo rispetto ai permessi di accesso (per maggiori dettagli su questo esempio specifico, vedere la sezione 3.4.4, "Gestione dei diritti" [pagina 57]).

## 3.2. La riga di comando

Per "riga di comando" si intende un'interfaccia testuale che consente di inserire comandi, eseguirli e visualizzarne i risultati. È possibile eseguire un terminale (una schermata testuale all'interno del desktop grafico o la console testuale stessa al di fuori di qualsiasi interfaccia grafica) e un interprete di comandi al suo interno *(la shell).*

### 3.2.1. Come ottenere una riga di comando

Quando il sistema funziona correttamente, il modo più semplice per accedere alla riga di comando è avviare un terminale nella sessione desktop grafica.

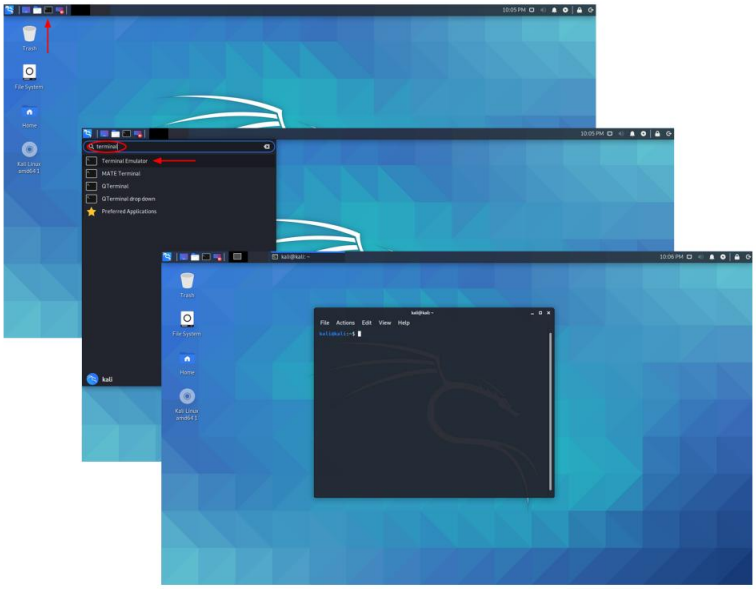



**Figura 3.1** Avvio del QTerminal

Machine Translated by Google

Ad esempio, su un sistema Kali Linux predefinito, QTerminal può essere avviato dall'elenco delle applicazioni preferite. È anche possibile digitare "terminale" nel menu delle applicazioni (quello che si attiva quando si sposta il mouse nell'angolo in alto a sinistra) e fare clic sull'icona dell'applicazione corretta che appare (Figura 3.1, "Avvio di QTerminal" [pagina 51]).

Nel caso in cui la tua interfaccia grafica non funzioni, puoi comunque accedere alla riga di comando tramite console virtuali (fino a sei di esse sono accessibili tramite le sei combinazioni di tasti da CTRL+ALT+F1 a CTRL+ALT+F6; il tasto CTRL può essere omesso se ti trovi già in modalità testuale, al di fuori dell'interfaccia grafica di Xorg o Wayland). Ti verrà mostrata una schermata di login molto semplice in cui dovrai inserire nome utente e password prima di ottenere l'accesso alla riga di comando con la relativa shell:

```
Kali GNU/Linux Rolling kali tty3

Accesso kali: kali
Password:
Linux kali 5.7.0-kali1-amd64 #1 SMP Debian 5.7.6-1kali2 (2020-07-01) X86_64

I programmi inclusi nel sistema Kali GNU/Linux sono software libero; i termini di distribuzione esatti per ciascun
programma sono descritti nei singoli file presenti in /usr/share/doc/*/copyright.

Kali GNU/Linux viene fornito SENZA ALCUNA GARANZIA, nella misura consentita dalla legge
applicabile. kali@kali:~$
```

Il programma che gestisce l'input e esegue i comandi si chiama *shell* (o interprete della riga di comando). La shell predefinita fornita in Kali Linux è *Bash* (acronimo di *Bourne Again SHell).*
Il carattere finale "$" o "#" indica che la shell è in attesa del tuo input. Indica inoltre se Bash ti riconosce come utente normale (nel primo caso con il dollaro, $) o come superutente (nel secondo caso con il simbolo di cancelletto, #).

### 3.2.2. Nozioni di base della riga di comando: Esplorazione della struttura delle directory e gestione dei file

Questa sezione fornisce solo una breve panoramica dei comandi trattati, ognuno dei quali presenta numerose opzioni non descritte qui; si prega pertanto di consultare l'ampia documentazione disponibile nelle rispettive pagine del manuale. Nei penetration test, dopo un exploit riuscito, si ottiene spesso l'accesso alla shell di un sistema, anziché un'interfaccia utente grafica. La padronanza della riga di comando è essenziale per il successo di un professionista della sicurezza.

Una volta aperta una sessione, il comando pwd (che sta per *print working directory)* visualizza la posizione corrente nel filesystem. La directory corrente viene cambiata con il comando cd directory (cd sta per *change directory).* Quando non si specifica la directory di destinazione, si viene portati alla propria directory home. Quando si usa cd - (trattino), si torna alla directory di lavoro precedente (quella in uso prima dell'ultima chiamata a cd ). La directory padre è sempre chiamata .. (due punti), mentre

Machine Translated by Google

la directory corrente è anche nota come . (un punto). Il comando ls consente *di elencare* il contenuto di una directory. Se non si forniscono parametri, ls opera sulla directory corrente.

```
$ pwd
/home/kali
$ cd Desktop
$ pwd
/home/kali/Desktop
$ cd .
$ pwd
/home/kali/Desktop
$ cd ..
$ pwd
/home/kali
$ ls
Download desktop Immagini Modelli
Documenti Musica Pubblico Video
```

È possibile creare una nuova directory con mkdir directory e rimuovere una directory esistente (vuota). con rmdir directory. Il comando mv consente *di spostare* e rinominare file e directory; *la rimozione* di un file si effettua con rm file, mentre la copia di un file si effettua con cp file-origine file-destinazione.

```
$ mkdir test
$ ls
Desktop          Download Immagini Modelli Video
Documenti Musica $ mv          Pubblico       test
test nuovo
$ ls
Desktop          Scarica nuovi                 Pubblico       Video
Documenti Musica                Modelli di immagini
$ rmdir new
$ ls
Desktop          Download Immagini Modelli Video
Documenti Musica                Pubblico
```

La shell esegue ogni comando eseguendo il primo programma con il nome specificato che trova in una directory elencata nella variabile d'ambiente PATH . Molto spesso, questi programmi si trovano in /bin, /sbin, /usr/bin o /usr/sbin. Ad esempio, il comando ls si trova in /bin/ls; il quale Il comando segnala la posizione di un determinato eseguibile. A volte il comando viene gestito direttamente dalla shell, nel qual caso si chiama comando integrato della shell (cd e pwd sono tra questi); Il comando type consente di interrogare il tipo di ciascun comando.

```
$ echo $PATH
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
$ che ls
/bin/ls
$ tipo rm
```

Machine Translated by Google

```
rm è /bin/rm $ type
cd cd è un
comando integrato della shell
```

Si noti l'utilizzo del comando echo , che si limita a visualizzare una stringa sul terminale. In questo caso, viene utilizzato per stampare il contenuto di una variabile d'ambiente, poiché la shell sostituisce automaticamente le variabili con i loro valori prima di eseguire il comando.

**Variabili d'ambiente** Le variabili d'ambiente consentono di memorizzare impostazioni globali per la shell o per altri programmi. Sono contestuali ma ereditabili. Ad esempio, ogni processo ha il proprio set di variabili d'ambiente (sono contestuali). Le shell, come le shell di login, possono dichiarare variabili che verranno passate ad altri programmi che eseguono (sono ereditabili).

Queste variabili possono essere definite a livello di sistema in /etc/profile o per singolo utente in ~/.profile , ma è preferibile inserire le variabili non specifiche degli interpreti della riga di comando in /etc/environment, poiché tali variabili verranno iniettate in tutte le sessioni utente grazie a un modulo di autenticazione plug-in (PAM), anche quando non viene eseguita alcuna shell.

## 3.3. Il file system

### 3.3.1. Lo standard della gerarchia del filesystem

Come altre distribuzioni Linux, Kali Linux è organizzato in modo coerente con lo *standard di gerarchia dei filesystem* (FHS), consentendo agli utenti di altre distribuzioni Linux di orientarsi facilmente in Kali. L'FHS definisce lo scopo di ciascuna directory. Le directory di primo livello sono descritte come segue.

- /bin/: programmi di base
- /boot/: kernel di Kali Linux e altri file necessari per il suo processo di avvio iniziale • /
  dev/: file di dispositivo
- /etc/: file di configurazione • /
  home/: file personali dell'utente • /
  lib/: librerie di base
- /media/: punti di montaggio per dispositivi rimovibili (CD/DVD-ROM, chiavette USB e così via)
- /mnt/: punto di montaggio
  temporaneo • /opt/: applicazioni aggiuntive fornite da terze
  parti • /root/: file personali dell'amministratore (root) • /
  run/: dati di runtime volatili che non persistono dopo i riavvii (non ancora inclusi nel FHS)

Machine Translated by Google

• /sbin/: programmi di sistema • /

srv/: dati utilizzati dai server ospitati su questo sistema • /tmp/: file

temporanei (questa directory viene spesso svuotata all'avvio) • /usr/: applicazioni

(questa directory è ulteriormente suddivisa in bin, sbin, lib secondo la stessa logica della directory root) Inoltre, /usr/share/ contiene dati indipendenti dall'architettura. La directory /usr/local/ è destinata all'uso da parte dell'amministratore per l'installazione manuale delle applicazioni senza sovrascrivere i file gestiti dal sistema di pacchettizzazione (dpkg).

• /var/: dati variabili gestiti dai servizi. Include file di log, code, spool e cache. • /proc/ e /sys/ sono specifici del kernel

Linux (e non fanno parte dell'FHS). Vengono utilizzati dal kernel per esportare dati nello spazio utente.

### 3.3.2. La directory home dell'utente

Il contenuto della directory home di un utente non è standardizzato, ma esistono comunque alcune convenzioni degne di nota. Una di queste è che la directory home di un utente viene spesso indicata con una tilde ("~"). È utile saperlo perché gli interpreti dei comandi sostituiscono automaticamente la tilde con la directory corretta (che è memorizzata nella variabile d'ambiente HOME e il cui valore usuale è /home/user/).

Tradizionalmente, i file di configurazione delle applicazioni vengono spesso memorizzati direttamente nella directory home dell'utente, ma i nomi dei file di solito iniziano con un punto (ad esempio, il client di posta elettronica mutt memorizza la sua configurazione in ~/.muttrc). Si noti che i nomi dei file che iniziano con un punto sono nascosti per impostazione predefinita; il comando ls li elenca solo quando si utilizza l'opzione -a e i gestori di file grafici devono essere configurati esplicitamente per visualizzare i file nascosti.

Alcuni programmi utilizzano anche più file di configurazione organizzati in un'unica directory (ad esempio, ~/.ssh/). Alcune applicazioni (come il browser web Firefox) utilizzano inoltre la propria directory per memorizzare una cache dei dati scaricati. Ciò significa che queste directory possono finire per occupare molto spazio su disco.

Questi file di configurazione memorizzati direttamente nella tua directory home, spesso indicati collettivamente come *dotfiles,* si sono moltiplicati a tal punto che queste directory possono risultare piuttosto ingombranti. Fortunatamente, uno sforzo guidato collettivamente sotto l'egida di FreeDesktop.org2 L'iniziativa ha portato alla definizione della specifica XDG Base Directory Specification, una convenzione che mira a ripulire questi file e directory. Questa specifica stabilisce che i file di configurazione devono essere memorizzati in ~/.config, i file di cache in ~/.cache e i file di dati dell'applicazione in ~/.local (o nelle sue sottodirectory).
Questa convenzione sta lentamente prendendo piede.

Gli ambienti desktop grafici solitamente dispongono di collegamenti per visualizzare il contenuto della directory ~/Desktop/ (o la traduzione appropriata per i sistemi non configurati in inglese).

[2] https://www.freedesktop.org/

Machine Translated by Google

Infine, il sistema di posta elettronica a volte memorizza le email in arrivo nella directory ~/Mail/ .

## 3.4. Comandi utili

### 3.4.1. Visualizzazione e modifica di file di testo

Il comando `cat file` (pensato per *concatenare* i file sul dispositivo di output standard) legge un file e ne visualizza il contenuto sul terminale. Se il file è troppo grande per essere visualizzato a schermo, è possibile utilizzare un gestore di pagine come `less` (o ` more`) per visualizzarlo pagina per pagina.

Il comando `editor` avvia un editor di testo (come Vi o Nano) e consente di creare, modificare e leggere file di testo. I file più semplici possono talvolta essere creati direttamente dall'interprete dei comandi grazie al reindirizzamento: `command > file` crea un file chiamato `*file*` contenente l'output del comando specificato. `command >> file` è simile, tranne per il fatto che aggiunge l'output del comando al file anziché sovrascriverlo.

```
$ echo "Kali è fantastica!" > kali-rules.txt $ cat kali-rules.txt

Kali regna sovrana!
$ echo "Kali è la migliore!" >> kali-rules.txt $ cat kali-rules.txt Kali è
fantastica!

Kali è la migliore!
```

### 3.4.2. Ricerca di file e all'interno dei file

Il comando find directory criteria cerca i file nella gerarchia *della directory* in base a diversi criteri. Il criterio più comunemente usato è -name filename, che consente di cercare un file per nome. È possibile utilizzare anche caratteri jolly comuni come nella ricerca per nome file. **“*”**

```
$ find /etc -name hosts /etc/hosts /
etc/avahi/hosts
$ find /etc -name ”hosts*” /
etc/hosts /etc/hosts.allow /etc/hosts.deny /
etc/avahi/hosts
```

Il comando `grep expression files` cerca nel contenuto dei file ed estrae le righe che corrispondono all'espressione regolare. L'aggiunta dell'opzione `-r` abilita una ricerca ricorsiva in tutti i file contenuti nella directory. Questo permette di cercare un file anche conoscendone solo una parte del contenuto.

Machine Translated by Google

### 3.4.3. Gestione dei processi

Il comando ps aux elenca i processi attualmente in esecuzione e ne consente l'identificazione mostrando il PID. Una volta noto il *PID* di un processo, il comando kill -signal pid permette di inviargli un segnale (se si è il proprietario del processo). Esistono diversi segnali; i più comunemente usati sono TERM (una richiesta di terminazione controllata) e KILL (una terminazione forzata).

L'interprete dei comandi può anche eseguire programmi in background se il comando è seguito da "&". Utilizzando la e commerciale (&), si riprende immediatamente il controllo della shell anche se il comando è ancora in esecuzione (nascosto come processo in background). Il comando jobs elenca i processi in esecuzione in background; eseguendo fg %job-number (per *foreground)* si riporta un processo in primo piano. Quando un comando è in esecuzione in primo piano (sia perché è stato avviato normalmente, sia perché è stato riportato in primo piano con fg), la combinazione di tasti Control+Z mette in pausa il processo e riprende il controllo della riga di comando. Il processo può quindi essere riavviato in background con bg %job-number (per *background).*

### 3.4.4. Gestione dei diritti

Linux è un sistema multiutente, quindi è necessario fornire un sistema di permessi per controllare l'insieme delle operazioni autorizzate su file e directory, che include tutte le risorse e i dispositivi di sistema (in un sistema Unix, ogni dispositivo è rappresentato da un file o una directory). Questo principio è comune a tutti i sistemi di tipo Unix.

Ogni file o directory ha autorizzazioni specifiche per tre categorie di utenti:

- Il suo proprietario (simboleggiato da u, come in Utente)
- Il suo gruppo proprietario (simboleggiato da g, come in Gruppo), che rappresenta tutti i membri del gruppo
- Gli altri (simboleggiati da o, come in Altro)

È possibile combinare tre tipi di diritti:

- Lettura (simboleggiata da r, come in Read);
- Scrittura (o modifica, simboleggiata da w, come in Write);
- Esecuzione (simboleggiata da x, come in eXecute).

Nel caso di un file, questi diritti sono facilmente comprensibili: l'accesso in lettura consente di leggere il contenuto (inclusa la copia), l'accesso in scrittura consente di modificarlo e l'accesso in esecuzione consente di eseguirlo (il che funzionerà solo se si tratta di un programma).

| | |
|---|---|
| **Eseguibili setuid e setgid** | Due diritti particolari sono rilevanti per i file eseguibili: setuid e setgid (simboleggiati con la lettera “s”). Si noti che si parla spesso di bit, poiché ciascuno di questi valori booleani può essere rappresentato da 0 o 1. Questi due diritti consentono a qualsiasi utente di eseguire il programma con i diritti del proprietario o del gruppo, rispettivamente. Questo meccanismo |

Machine Translated by Google

Consente l'accesso a funzionalità che richiedono autorizzazioni di livello superiore rispetto a quelle normalmente disponibili.

Poiché un programma root con privilegi setuid viene eseguito sistematicamente con l'identità di superutente, è fondamentale garantirne la sicurezza e l'affidabilità. Qualsiasi utente in grado di eludere un programma root con privilegi setuid per eseguire un comando a propria scelta potrebbe impersonare l'utente root e ottenere tutti i diritti sul sistema. I penetration tester cercano regolarmente questo tipo di file quando accedono a un sistema, come metodo per elevare i propri privilegi.

Una directory viene gestita in modo diverso da un file. L'accesso in lettura consente di consultare l'elenco del suo contenuto (file e directory); l'accesso in scrittura consente di creare o eliminare file; e l'accesso in esecuzione consente di attraversare la directory per accedere al suo contenuto (ad esempio, con il comando cd ). La possibilità di attraversare una directory senza poterla leggere dà all'utente il permesso di accedere alle voci in essa contenute che sono note per nome, ma non di trovarle senza conoscerne il contenuto.
nome esatto.

SICUREZZA

**Imposta la directory e** il bit sticky

Il bit setgid si applica anche alle directory. A qualsiasi elemento appena creato in tali directory viene automaticamente assegnato il gruppo proprietario della directory padre, anziché ereditare il gruppo principale del creatore come di consueto. Per questo motivo, non è necessario cambiare il proprio gruppo principale (con il comando newgrp ) quando si lavora in una struttura di directory condivisa tra più utenti dello stesso gruppo dedicato.

Il bit sticky (simboleggiato dalla lettera "t") è un permesso utile solo nelle directory. Viene utilizzato soprattutto per le directory temporanee in cui tutti hanno accesso in scrittura (come /tmp/): limita la cancellazione dei file in modo che solo il proprietario del file o il proprietario della directory padre possano eliminarli. Senza questo bit sticky, chiunque potrebbe cancellare i file di altri utenti in /tmp/.

Tre comandi controllano i permessi associati a un file:

- chown user file cambia il proprietario del file • chgrp
- group file modifica il gruppo del proprietario •
- chmod rights file modifica i permessi del file

MANCIA

**Modifica dell'utente e del gruppo**

Spesso si desidera cambiare il gruppo di un file contemporaneamente al cambio del proprietario. Il comando chown ha una sintassi specifica per questo scopo: chown utente:gruppo
file

Esistono due modi per rappresentare i diritti. Tra questi, la rappresentazione simbolica è probabilmente la più facile da comprendere e ricordare. Essa si basa sui simboli letterali menzionati in precedenza. È possibile definire i diritti per ciascuna categoria di utenti (u/g/o), specificandoli esplicitamente (con =), aggiungendo (+) o sottraendo (-). Pertanto, la formula u=rwx,g+rw,or assegna al proprietario i diritti di lettura, scrittura ed esecuzione, aggiunge i diritti di lettura e scrittura per il gruppo del proprietario e rimuove i diritti di lettura per gli altri utenti.

Machine Translated by Google

I diritti non modificati dall'aggiunta o dalla sottrazione in tale comando rimangono invariati. La lettera a, per tutti, comprende tutte e tre le categorie di utenti, quindi a=rx concede a tutte e tre le categorie gli stessi diritti (lettura ed esecuzione, ma non scrittura).

La rappresentazione numerica (ottale) associa a ciascun diritto un valore: 4 per la lettura, 2 per la scrittura e 1 per l'esecuzione. Associamo a ogni combinazione di diritti la somma delle tre cifre e assegniamo un valore a ciascuna categoria di utenti, nell'ordine usuale (proprietario, gruppo, altri).

Ad esempio, il comando chmod 754 file imposterà i seguenti permessi: lettura, scrittura ed esecuzione per il proprietario (poiché 7 = 4 + 2 + 1); lettura ed esecuzione per il gruppo (poiché 5 = 4 + 1); sola lettura per gli altri. Lo 0 significa nessun permesso; quindi chmod 600 file consente i permessi di lettura e scrittura per il proprietario e nessun permesso per nessun altro. Le combinazioni di permessi più frequenti sono 755 per i file eseguibili e le directory e 644 per i file di dati.

Per rappresentare diritti speciali, è possibile anteporre una quarta cifra a questo numero secondo lo stesso principio, dove i bit setuid, setgid e sticky sono rispettivamente 4, 2 e 1. Il comando chmod 4754 assocerà il bit setuid ai diritti precedentemente descritti.

Tieni presente che l'uso della notazione ottale consente solo di impostare tutti i diritti contemporaneamente su un file; non puoi usarla per aggiungere un nuovo diritto, come l'accesso in lettura per il proprietario del gruppo, poiché devi tenere conto dei diritti esistenti e calcolare il nuovo valore numerico corrispondente.

La rappresentazione ottale viene utilizzata anche con il comando umask , che serve a limitare i permessi sui file appena creati. Quando un'applicazione crea un file, assegna permessi indicativi, sapendo che il sistema rimuoverà automaticamente i diritti definiti con umask. Digitando umask in una shell, si vedrà una maschera come 0022. Questa è semplicemente una rappresentazione ottale dei diritti da rimuovere sistematicamente (in questo caso, i diritti di scrittura per il gruppo e gli altri utenti).

Se gli si assegna un nuovo valore ottale, il comando umask modifica la maschera. Utilizzato in un file di inizializzazione della shell (ad esempio, ~/.bash_profile), cambierà effettivamente la maschera predefinita per le sessioni di lavoro.

MANCIA

### Operazione ricorsiva

A volte è necessario modificare i permessi di un'intera struttura di directory. Tutti i comandi sopra riportati hanno un'opzione -R per operare in modo ricorsivo nelle sottocartelle.

La distinzione tra directory e file a volte causa problemi con le operazioni ricorsive. Per questo motivo è stata introdotta la lettera "X" nella rappresentazione simbolica dei permessi. Essa rappresenta il diritto di esecuzione, che si applica solo alle directory (e non ai file che non dispongono di tale diritto). Pertanto, il comando `chmod -R a+X directory` aggiungerà i permessi di esecuzione per tutte le categorie di utenti (a) solo per tutte le sottodirectory e i file per i quali almeno una categoria di utenti (anche se unico proprietario) possiede già i permessi di esecuzione.

Machine Translated by Google

### 3.4.5. Acquisizione di informazioni e registri di sistema

Il comando free visualizza informazioni sulla memoria; (df (per *disk free)* riporta la memoria disponibile Spazio su disco su ciascuno dei dischi montati nel file system. La sua opzione -h (per *la leggibilità umana)* converte le dimensioni in un'unità più leggibile (di solito mebibyte o gibibyte). Allo stesso modo, il comando free supporta le opzioni -m e -g e visualizza i suoi dati in mebibyte o in gibibyte, rispettivamente.

```
$ gratuito
                totale        usato      gratuito  buff/cache condivisi disponibili
Mem:          2052944        661232        621208       10520      770504     1359916
                    0             0             0
Scambio: $ df
Filesystem udev  blocchi da 1K  Usato Disponibile Utilizzo% Montato su
                      1014584      0   1014584   0% /dev
tmpfs /               205296   8940    196356   5% /esecuzione
dev/vda1            30830588 11168116 18073328  39% /
tmpfs                 1026472    456   1026016   1% /dev/shm
tmpfs                    5120      0      5120   0% /run/lock
tmpfs                 1026472      0   1026472   0% /sys/fs/cgroup
tmpfs                  205296     36    205260   1% /run/user/132
tmpfs                  205296     24    205272   1% /run/user/0
```

Il comando id visualizza l'identità dell'utente che esegue la sessione insieme all'elenco dei gruppi appartengono a. Poiché l'accesso ad alcuni file o dispositivi potrebbe essere limitato ai membri del gruppo, verifica L'adesione a gruppi disponibili potrebbe essere utile.

```
$ id
uid=1000(kali) gid=1000(kali) gruppi=1000(kali),27(sudo)
```

Il comando uname -a restituisce una singola riga che documenta il nome del kernel (Linux), il nome host, la release del kernel, la versione del kernel, il tipo di macchina (una stringa di architettura come x86_64), e il nome del sistema operativo (GNU/Linux). L'output di questo comando dovrebbe di solito essere incluso nei report di bug poiché definisce chiaramente il kernel in uso e la piattaforma hardware sono in esecuzione.

```
$ uname -a
Linux kali 5.8.0-kali3-amd64 #1 SMP Debian 5.8.14-1kali1 (2020-10-13) x86_64 GNU/Linux
```

Tutti questi comandi forniscono informazioni in tempo reale, ma spesso è necessario consultare i log per capire cosa è successo sul computer. In particolare, il kernel emette messaggi che memorizza in un buffer circolare ogni volta che accade qualcosa di interessante (come l'inserimento di un nuovo dispositivo USB, un'operazione del disco rigido non riuscita o il rilevamento iniziale dell'hardware all'avvio). È possibile recuperare il kernel registri con il comando dmesg .

Il journal di Systemd memorizza anche più log (output stdout/stderr dei servizi, messaggi syslog, log del kernel) e ne semplifica l'interrogazione con journalctl. Senza argomenti, si limita a scaricare

Machine Translated by Google

Tutti i log disponibili in ordine cronologico. Con l' opzione -r , l'ordine viene invertito in modo che i messaggi più recenti vengano visualizzati per primi. Con l' opzione -f , vengono stampate continuamente le nuove voci di log man mano che vengono aggiunte al database. L' opzione -u consente di limitare i messaggi a quelli emessi da una specifica unità systemd (es: journalctl -u ssh.service).

### 3.4.6. Scoperta dell'hardware

Il kernel esporta molti dettagli sull'hardware rilevato tramite i filesystem virtuali /proc/ e /sys/ . Diversi strumenti riassumono questi dettagli. Tra questi, lspci (nel pacchetto *pciutils )* elenca i dispositivi PCI, lsusb (nel pacchetto *usbutils )* elenca i dispositivi USB e lspcmcia (nel pacchetto *pcmcia-tils )* elenca le schede PCMCIA. Questi strumenti sono molto utili per identificare il modello esatto di un dispositivo. Tale identificazione consente anche ricerche più precise sul web, che a loro volta portano a documenti più pertinenti. Si noti che i pacchetti *pciutils* e *usbutils* sono già installati nel sistema Kali di base, mentre *pcmciautils* deve essere installato con apt update seguito da apt install pcmciautils. Approfondiremo l'installazione e la gestione dei pacchetti nella sezione 8.2, "Interazione di base con i pacchetti" [pagina 181].

**Esempio 3.1** Esempio di informazioni fornite da lspci e lsusb

```
$ lspci [...]

00:02.1 Controller display: Intel Corporation Mobile 915GM/GMS/910GML Express Graphics Controller (rev 03) 00:1c.0 Bridge PCI: Intel Corporation
82801FB/FBM/FR/FW/FRW (famiglia ICH6) Porta PCI Express 1 (rev 03) 00:1d.0 Controller USB: Intel Corporation 82801FB/FBM/FR/FW/FRW
(famiglia ICH6) USB UHCI #1 (rev 03) [...]

01:00.0 Controller Ethernet: Broadcom Corporation NetXtreme BCM5751 Gigabit Ethernet PCI Express (rev 01)
02:03.0 Controller di rete: Intel Corporation PRO/Wireless 2200BG Network Connection (rev 05) $ lsusb Bus 005 Dispositivo 004: ID
413c:a005
Dell Computer Corp.
Bus 005 Dispositivo 008: ID 413c:9001 Dell Computer Corp.
Bus 005 Dispositivo 007: ID 045e:00dd Microsoft Corp.
Bus 005 Dispositivo 006: ID 046d:c03d Logitech, Inc. [...]

Bus 002 Dispositivo 004: ID 413c:8103 Dell Computer Corp. Wireless 350 Bluetooth
```

Questi programmi dispongono di un'opzione -v che elenca informazioni molto più dettagliate (ma di solito non necessarie). Infine, il comando lsdev (nel pacchetto *procinfo )* elenca le risorse di comunicazione utilizzate dai dispositivi.

Il programma lshw è una combinazione dei programmi sopra menzionati e visualizza una descrizione dettagliata dell'hardware rilevato in modo gerarchico. È consigliabile allegare l'output completo a qualsiasi segnalazione di problemi di supporto hardware.

Machine Translated by Google

## 3.5. Riepilogo

In questa sezione, abbiamo fatto un rapido excursus sul panorama di Linux. Abbiamo parlato del kernel e dello spazio utente, ripassato molti comandi comuni della shell di Linux, discusso dei processi e di come gestirli, ripassato i concetti di sicurezza per utenti e gruppi, parlato di FHS e visitato alcune delle directory e dei file più comuni presenti in Kali Linux.

Suggerimenti riassuntivi:

- Il termine Linux viene spesso utilizzato per riferirsi all'intero sistema operativo, ma in realtà Linux stesso è il kernel del sistema operativo che viene avviato dal boot loader, il quale a sua volta viene avviato dal BIOS/UEFI.
- Lo spazio utente si riferisce a tutto ciò che accade al di fuori del kernel. Tra i programmi in esecuzione nello spazio utente, ci sono molte utilità principali del progetto GNU[3] La maggior parte di questi programmi è pensata per essere eseguita dalla riga di comando (un'interfaccia testuale che consente di inserire comandi, eseguirli e visualizzarne i risultati). Una shell esegue i comandi all'interno di tale interfaccia.
- I comandi comuni includono: pwd (stampa la directory di lavoro), cd (cambia directory), ls (elenca il contenuto di file o directory), mkdir (crea directory), rmdir (rimuovi directory), mv, rm e cp (spostano, rimuovono o copiano rispettivamente file o directory), cat (concatena o mostra file), less/more (mostra i file una pagina alla volta), editor (avvia un editor di testo), find (individua un file o una directory), free (visualizza le informazioni sulla memoria), df (mostra lo spazio libero su disco), id (visualizza l'identità dell'utente insieme all'elenco dei gruppi a cui appartiene), dmesg (esamina i log del kernel) e journalctl (mostra tutti i log disponibili). • È possibile

  ispezionare l'hardware su un sistema Kali con diversi comandi: lspci (elenca i dispositivi PCI), lsusb (elenca i dispositivi USB) e lspcmcia elenca le schede PCMCIA.
- Un processo è un'istanza in esecuzione di un programma, che richiede memoria per memorizzare sia il programma stesso che i suoi dati operativi. È possibile gestire i processi con comandi come: ps (mostra i processi), kill (termina i processi), bg (invia un processo in background), fg (porta un processo in background in primo piano) e jobs (mostra i processi in background).
- I sistemi Unix-like sono multiutente. Supportano più utenti e gruppi e consentono il controllo delle azioni in base ai permessi. È possibile gestire i diritti su file e directory con diversi comandi, tra cui: chmod (modifica i permessi), chown (modifica il proprietario) e chgrp (modifica il gruppo).

- Come altre distribuzioni Linux professionali, Kali Linux è organizzato in modo coerente con lo *standard di gerarchia dei filesystem* (FHS), consentendo agli utenti provenienti da altre distribuzioni Linux di orientarsi facilmente in Kali.
- Tradizionalmente, i file di configurazione delle applicazioni vengono memorizzati nella directory home dell'utente, in file o directory nascosti che iniziano con un punto.

[3] https://www.gnu.org/

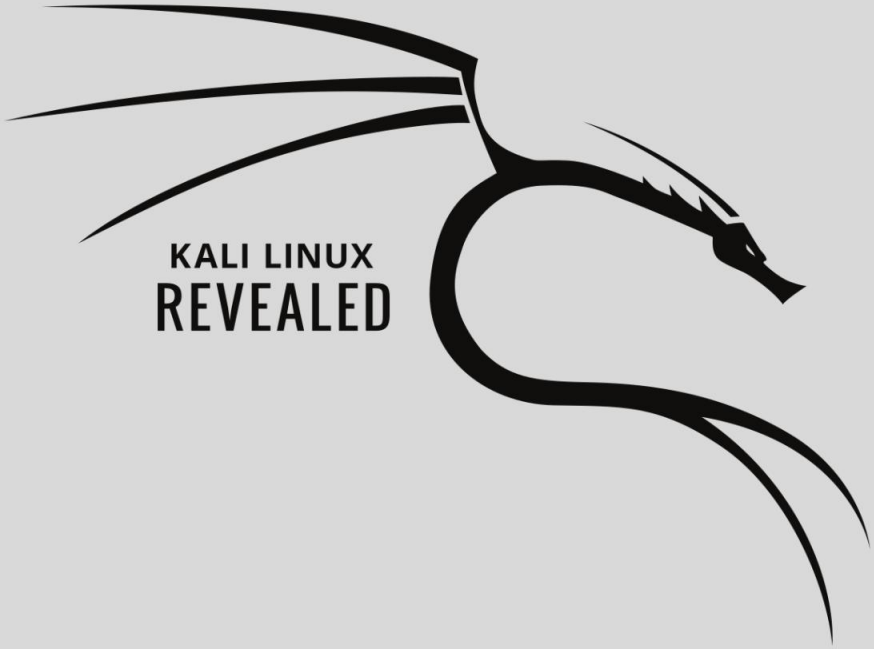
Machine Translated by Google

Ora che hai familiarità con i fondamenti di Linux, procediamo con l'installazione e l'avvio di Kali Linux.

Machine Translated by Google

**Parole chiave**

**Installazione**
**Installazione senza supervisione**
**Dispositivi ARM**
**Risoluzione dei problemi**



Machine Translated by Google

Capitolo

# 4

# Installazione di Kali Linux

Contenuto

Requisiti minimi di installazione 66
Installazione passo passo su un disco rigido 66
Installazioni non presidiate 95
Installazioni ARM 98
Risoluzione dei problemi di installazione 99
Sommario 104

Machine Translated by Google

In questo capitolo, ci concentreremo sul processo di installazione di Kali Linux. Innanzitutto, analizzeremo i requisiti minimi di installazione (sezione 4.1, "Requisiti minimi di installazione" [pagina 66]) per garantire che il sistema, reale o virtuale, sia ben configurato per gestire il tipo di installazione che si intende effettuare. Successivamente, esamineremo ogni fase del processo di installazione (sezione 4.2, "Installazione passo passo su un disco rigido" [pagina 66]) sia per un'installazione standard, sia per un'installazione più sicura che prevede un file system completamente crittografato. Parleremo anche *del preseeding,* che consente installazioni automatiche (sezione 4.3, "Installazioni automatiche" [pagina 95]) fornendo risposte predefinite alle domande di installazione. Mostreremo inoltre come installare Kali Linux su diversi dispositivi ARM (sezione 4.4, "Installazioni ARM" [pagina 98]), estendendo così le capacità di Kali ben oltre il desktop. Infine, vi mostreremo cosa fare nel raro caso di un errore di installazione (sezione 4.5, "Risoluzione dei problemi di installazione" [pagina 99]), in modo che possiate affrontare il problema e completare con successo un'installazione complessa.

## 4.1. Requisiti minimi di installazione

I requisiti di installazione per Kali Linux variano a seconda di ciò che si desidera installare. Nella configurazione base, è possibile installare Kali come server Secure Shell (SSH) senza ambiente desktop, utilizzando appena 128 MB di RAM (512 MB consigliati) e 2 GB di spazio su disco. Nella configurazione più completa, se si opta per l'installazione dell'ambiente desktop predefinito Xfce e del metapackage *kali-linux-default ,* è consigliabile puntare ad almeno 2048 MB di RAM e 20 GB di spazio su disco.

Oltre ai requisiti di RAM e disco rigido, il computer deve disporre di una CPU supportata da almeno una delle architetture amd64, i386 o arm64.

## 4.2. Installazione passo passo su un disco rigido

In questa sezione, si presume che tu disponga di un'unità USB o di un DVD avviabile (vedi la sezione 2.1.4, "Copia dell'immagine su un DVD-ROM o una chiavetta USB" [pagina 19] per i dettagli su come preparare tale unità) e che tu abbia avviato il sistema da essa per iniziare il processo di installazione.

### 4.2.1. Installazione semplice

Innanzitutto, esamineremo un'installazione standard di Kali, con un file system non crittografato.

#### Avvio e avvio del programma di installazione

Una volta avviato il BIOS/UEFI dall'unità USB o dal DVD-ROM, viene visualizzato il menu del boot loader isolinux, come mostrato nella Figura 4.1, "Schermata di avvio" [pagina 67]. In questa fase, il kernel Linux non è ancora caricato; questo menu consente di scegliere il kernel da avviare e di inserire parametri opzionali da trasferirgli durante il processo.

Machine Translated by Google

Utilizzando i tasti freccia per eseguire un'installazione standard, scegli Installazione grafica o Installa (per la classica modalità testuale), quindi premi il tasto Invio per avviare la parte restante del processo di installazione.

Ogni voce di menu nasconde una specifica riga di comando di avvio, che può essere configurata a piacere premendo il tasto Tab prima di confermare la voce e avviare il sistema.

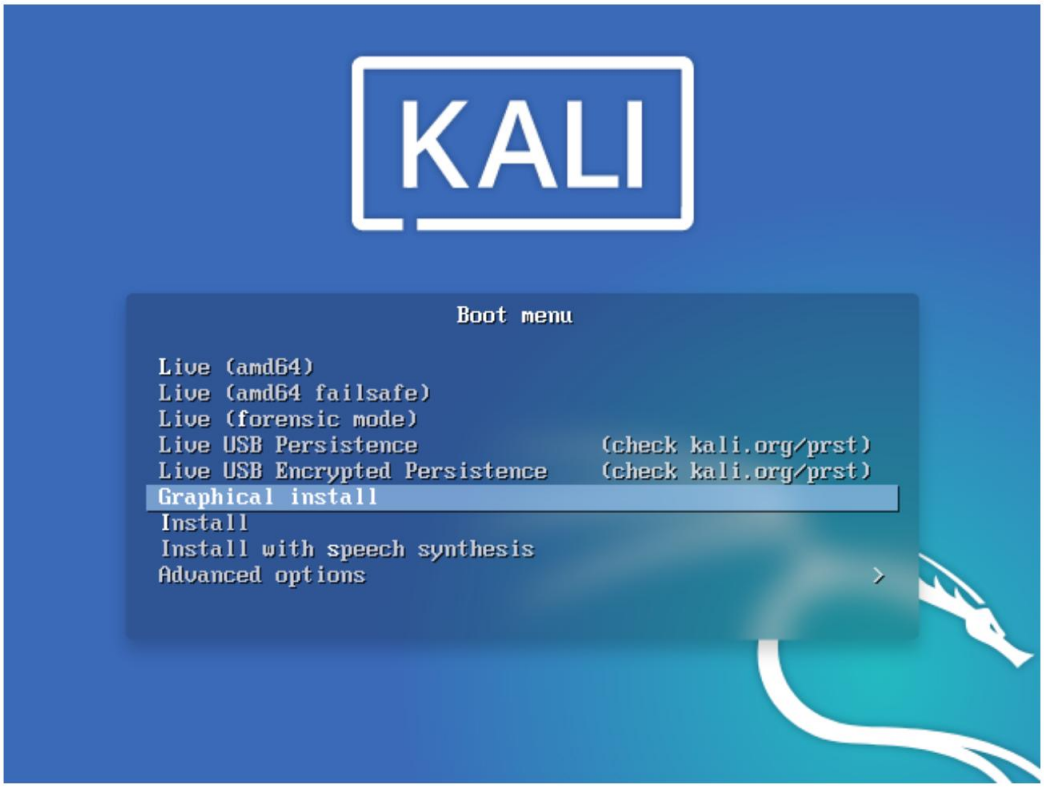



**Figura 4.1** Schermata di avvio

Una volta avviato, il programma di installazione vi guiderà passo passo attraverso il processo. Analizzeremo in dettaglio ciascuno di questi passaggi. Tratteremo l'installazione da un'immagine live standard di Kali Linux; le installazioni da un file mini.iso potrebbero presentare lievi differenze. Tratteremo anche l'installazione in modalità grafica, la cui unica differenza rispetto alla classica installazione in modalità testuale è l'aspetto.
Le due versioni pongono le stesse domande e presentano le stesse opzioni.

## Selezione della lingua

Come mostrato nella Figura 4.2, “Selezione della lingua” [pagina 68], il programma di installazione inizia in inglese ma il primo passaggio consente di scegliere la lingua che verrà utilizzata per il resto dell'installazione.

Machine Translated by Google

processo di installazione. Questa scelta della lingua viene utilizzata anche per definire opzioni predefinite più pertinenti nelle fasi successive (in particolare il layout della tastiera).

**Navigare con il Tastiera**

Alcuni passaggi del processo di installazione richiedono l'inserimento di informazioni. Queste schermate presentano diverse aree che possono essere selezionate (area di inserimento testo, caselle di controllo, elenco di opzioni, pulsanti OK e Annulla) e il tasto Tab consente di spostarsi da una all'altra.

In modalità di installazione grafica, è possibile utilizzare il mouse come si farebbe normalmente su un desktop grafico installato.

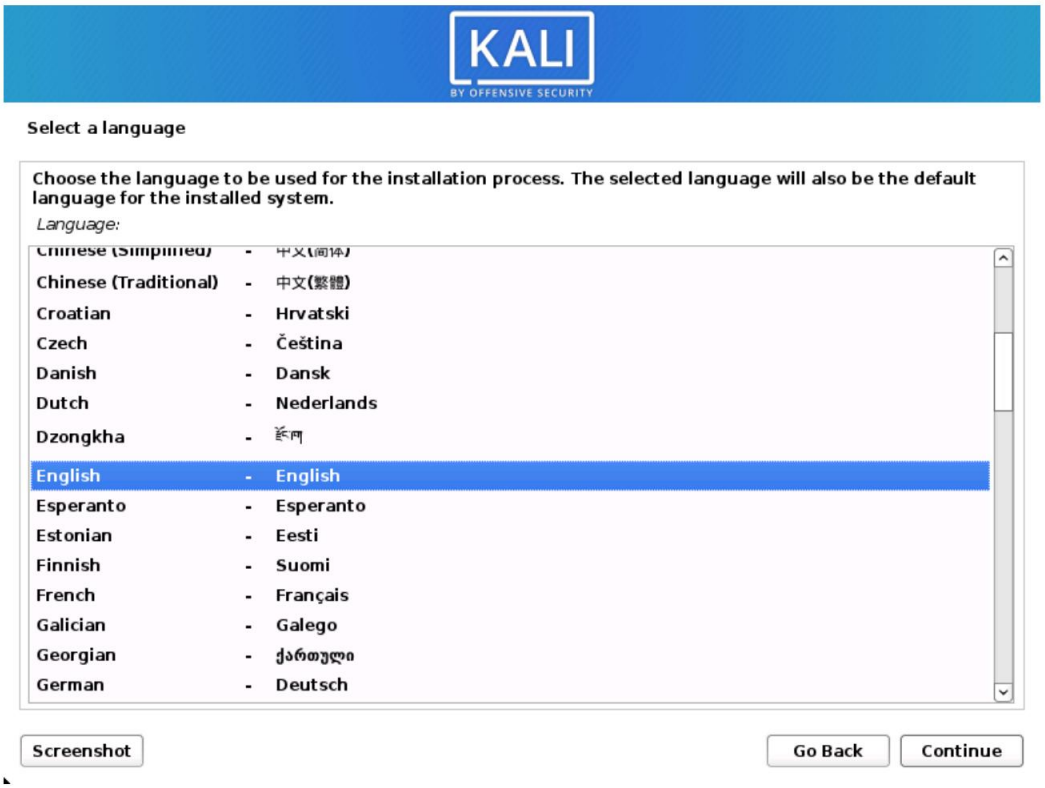



**Figura 4.2** Selezione della lingua

## Selezione del Paese

Il secondo passaggio (Figura 4.3, “Selezione del Paese” [pagina 69]) consiste nello scegliere il proprio Paese. Insieme alla lingua, queste informazioni consentono al programma di installazione di offrire il layout di tastiera più appropriato. Ciò influenzerà anche la configurazione del fuso orario. Negli Stati Uniti, viene consigliata una tastiera QWERTY standard e il programma di installazione propone una scelta di fusi orari appropriati.

Machine Translated by Google

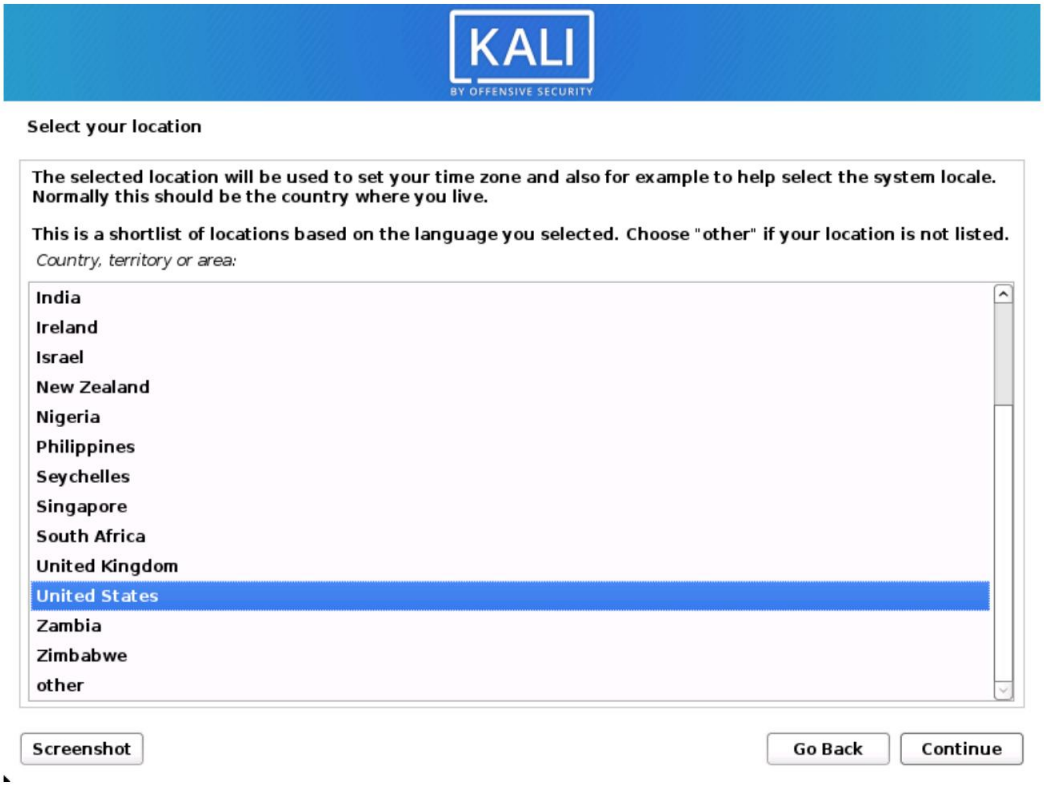



**Figura 4.3** Selezione del Paese

Selezione del layout della tastiera

La tastiera proposta in inglese americano corrisponde al layout QWERTY standard, come mostrato nella Figura 4.4, "Scelta della tastiera" [pagina 70].

Machine Translated by Google

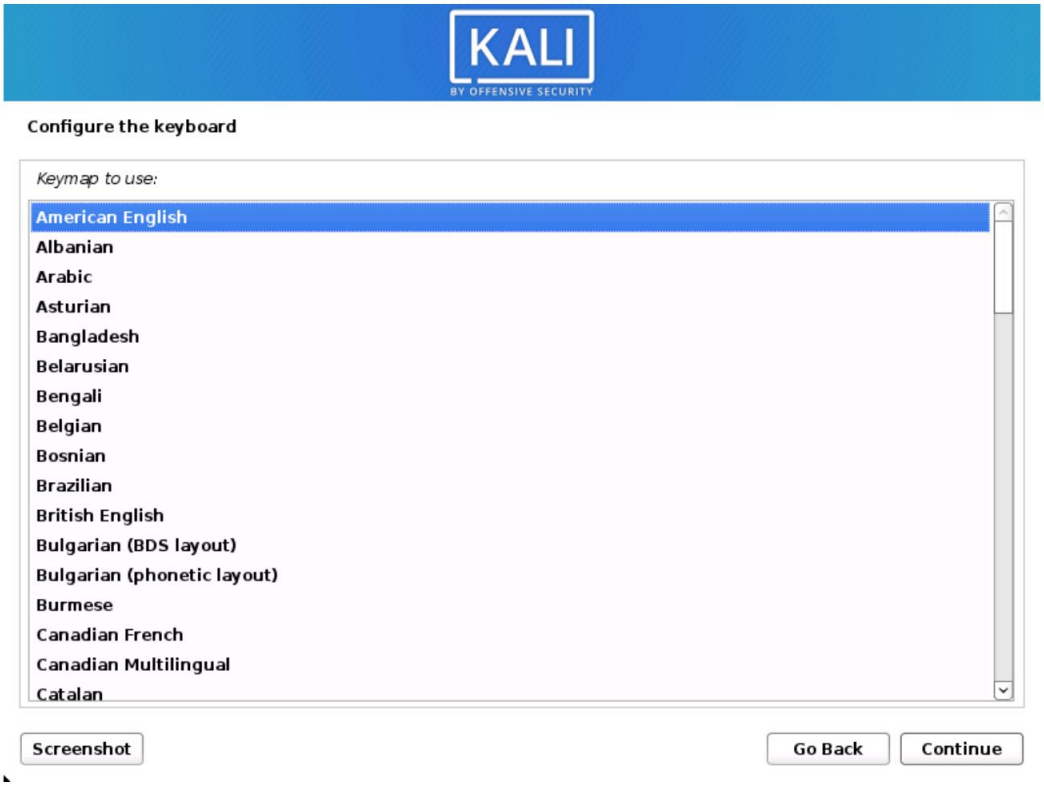



**Figura 4.4** Scelta della tastiera

### Rilevamento dell'hardware

Nella stragrande maggioranza dei casi, la fase di rilevamento dell'hardware è completamente automatica. Il programma di installazione rileva l'hardware e tenta di identificare il dispositivo di avvio utilizzato per accedervi. Carica i moduli corrispondenti ai vari componenti hardware rilevati e quindi monta il dispositivo di avvio per leggerne il contenuto. I passaggi precedenti sono completamente contenuti nell'immagine di avvio presente sul dispositivo di avvio, un file di dimensioni limitate che viene caricato in memoria dal bootloader all'avvio da tale dispositivo.

### Componenti di caricamento

Ora che il contenuto del dispositivo di avvio è disponibile, il programma di installazione carica tutti i file necessari per proseguire. Ciò include i driver aggiuntivi per l'hardware rimanente (in particolare la scheda di rete), nonché tutti i componenti del programma di installazione.

Machine Translated by Google

### Rilevamento dell'hardware di rete

In questa fase, il programma di installazione tenterà di identificare automaticamente la scheda di rete e caricare il modulo corrispondente. Se il rilevamento automatico fallisce, è possibile selezionare manualmente il modulo da caricare. Se tutti Se altrimenti fallisce, è possibile caricare un modulo specifico da un dispositivo rimovibile. Quest'ultima soluzione è solitamente necessario solo se il driver appropriato non è incluso nel kernel Linux standard, ma disponibile altrove, ad esempio sul sito web del produttore.

Questo passaggio deve assolutamente avere successo per le installazioni di rete (come quelle effettuate all'avvio) da un mini.iso), poiché i pacchetti Debian devono essere caricati dalla rete.

### Configurazione della rete

Per automatizzare il più possibile il processo, il programma di installazione tenta una configurazione automatica della rete utilizzando il protocollo DHCP (Dynamic Host Configuration Protocol) (per IPv4 e IPv6) e Il protocollo di individuazione dei vicini di ICMPv6 (per IPv6), come mostrato nella Figura 4.5, "Autoconfigurazione di rete" [pagina 71].

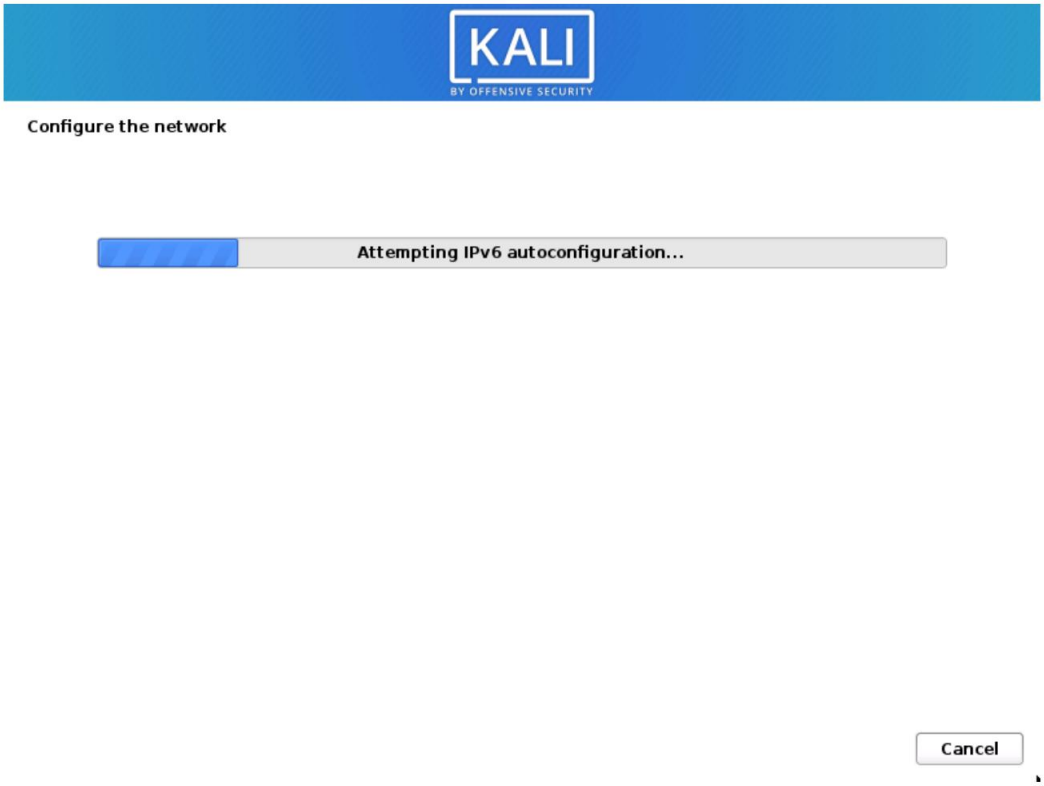



**Figura 4.5** Autoconfigurazione di rete

Machine Translated by Google

Se la configurazione automatica non riesce, il programma di installazione offre ulteriori opzioni: riprovare con una normale configurazione DHCP, tentare la configurazione DHCP specificando il nome del computer oppure impostare una configurazione di rete statica.

Quest'ultima opzione richiede un indirizzo IP, una maschera di sottorete, un indirizzo IP per un potenziale gateway, un nome macchina e un nome di dominio.

**Configurazione senza DHCP**

Se la rete locale è dotata di un server DHCP che non si desidera utilizzare perché si preferisce definire un indirizzo IP statico per il computer durante l'installazione, è possibile aggiungere l' opzione **`netcfg/use_dhcp=false`** all'avvio. È sufficiente modificare la voce di menu desiderata premendo il tasto Tab e aggiungendo l'opzione desiderata prima di premere Invio.

Creazione utente

Il programma di installazione richiede la creazione di un nuovo utente (Figura 4.6, "Crea utente" [pagina 73]) poiché crea automaticamente un account utente nel gruppo "sudo". Ciò significa che l'utente dispone di pieni privilegi amministrativi tramite il comando sudo . Questo è utile perché molti elementi sono accessibili solo tramite privilegi amministrativi.

Il programma di installazione richiede sia un nome utente per l'account che una password. Per evitare errori di inserimento, verrà richiesta la conferma della password.

Machine Translated by Google

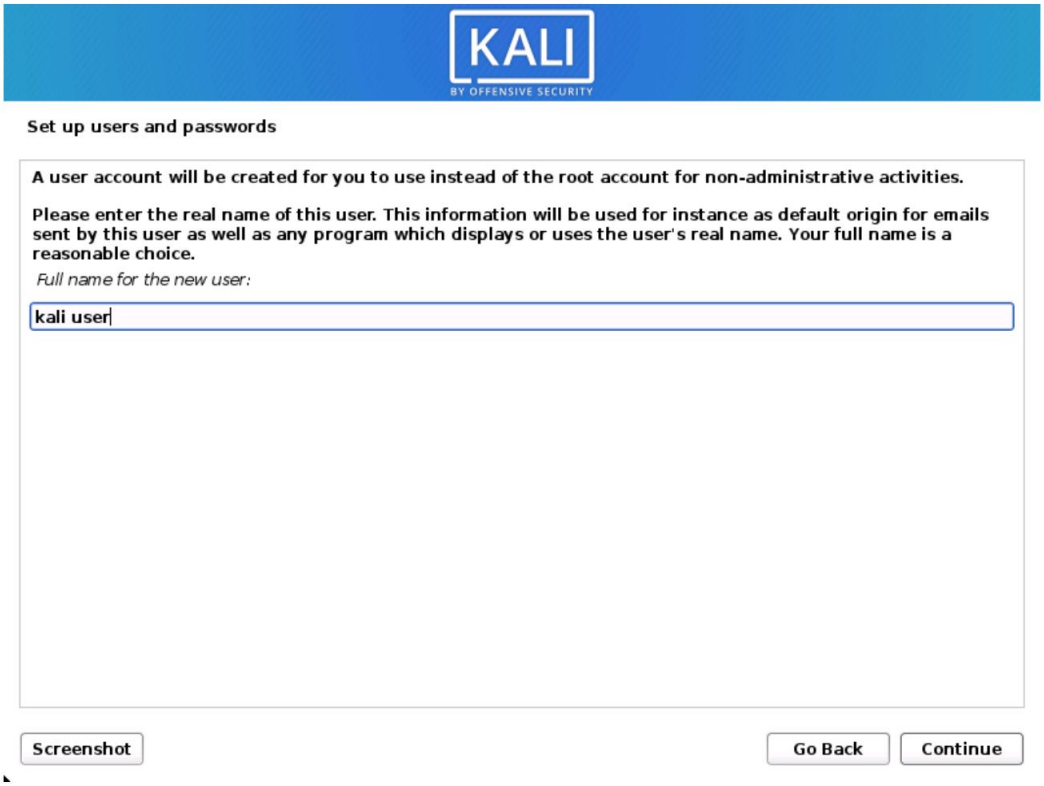



**Figura 4.6** Creazione utente

**L'utente predefinito Password**

La password predefinita dell'utente dovrebbe essere lunga (almeno otto caratteri) e impossibile da indovinare, poiché gli hacker prendono di mira computer e server connessi a Internet con strumenti automatizzati, tentando di accedere con password ovvie. Talvolta gli hacker sfruttano attacchi a dizionario, utilizzando numerose combinazioni di parole e numeri come password. Evitate di utilizzare i nomi di figli o genitori e le date di nascita, perché sono facilmente indovinabili.

Queste considerazioni sono ugualmente applicabili alle password di altri utenti, ma le conseguenze di un account compromesso sono meno drastiche per gli utenti senza privilegi sudo.

Se ti manca l'ispirazione, non esitare a utilizzare un generatore di password, come pwgen (che si trova nell'omonimo pacchetto, già incluso nell'installazione base di Kali).

Machine Translated by Google

## Impostazione dell'orologio

Se la rete è disponibile, l'orologio interno del sistema verrà aggiornato da un server NTP (Network Time Protocol). Questo è vantaggioso perché garantisce che i timestamp nei log siano corretti fin dal primo avvio.

Se il tuo Paese si estende su più fusi orari, ti verrà chiesto di selezionare il fuso orario che desideri utilizzare, come mostrato nella Figura 4.7, "Selezione del fuso orario" [pagina 74].

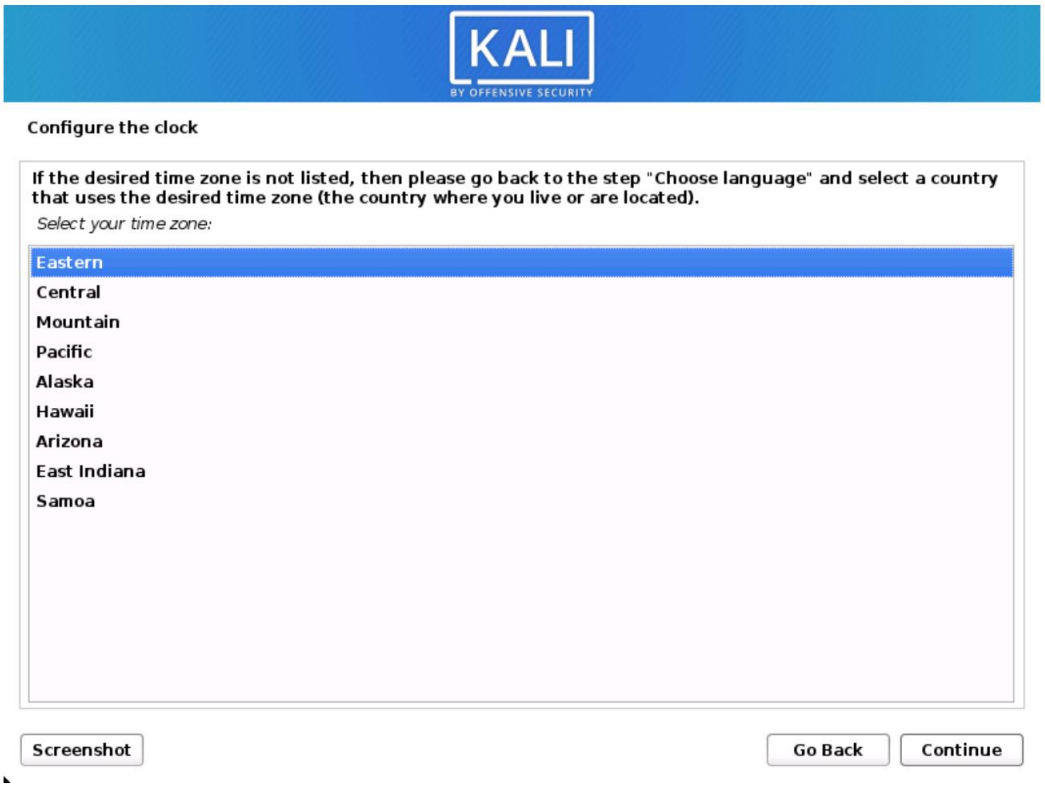



**Figura 4.7** Selezione del fuso orario

## Rilevamento di dischi e altri dispositivi

Questo passaggio rileva automaticamente i dischi rigidi su cui Kali potrebbe essere installato, ognuno dei quali verrà presentato nel passaggio successivo: il partizionamento.

Machine Translated by Google



*Il partizionamento* è una fase indispensabile dell'installazione, che consiste nel suddividere lo spazio disponibile sui dischi rigidi in sezioni distinte *(partizioni)* in base alla funzione prevista del computer e di tali partizioni. Il partizionamento implica anche la scelta del file system da utilizzare. Tutte queste decisioni influenzeranno le prestazioni, la sicurezza dei dati e l'amministrazione del server.

La fase di partizionamento è tradizionalmente complessa per i nuovi utenti. Tuttavia, i file system e le partizioni di Linux, inclusa la memoria virtuale (o partizione *di swap ),* devono essere definiti poiché costituiscono le fondamenta del sistema. Questa operazione può diventare complicata se sul computer è già installato un altro sistema operativo e si desidera che i due coesistano. In tal caso, è necessario assicurarsi di non modificare le partizioni di quest'ultimo o, se necessario, ridimensionarle senza causare danni.

Per adattarsi agli schemi di partizionamento più comuni (e più semplici), la maggior parte degli utenti preferirà la modalità *Guidata ,* che consiglia le configurazioni di partizionamento e fornisce suggerimenti in ogni fase del processo. Gli utenti più esperti apprezzeranno la modalità *Manuale ,* che consente configurazioni più avanzate. Ciascuna modalità condivide alcune funzionalità.

**Partizionamento guidato** La prima schermata dello strumento di partizionamento (Figura 4.8, "Scelta della modalità di partizionamento" [pagina 76]) presenta i punti di accesso per le modalità di partizionamento guidato e manuale. "Guidato - usa l'intero disco" è lo schema di partizionamento più semplice e comune, che allocherà un intero disco a Kali Linux.

Le due opzioni successive utilizzano Logical Volume Manager (LVM) per configurare partizioni logiche (anziché fisiche), eventualmente crittografate. Approfondiremo LVM e la crittografia più avanti in questo capitolo, nella sezione 4.2.2, "Installazione su un file system completamente crittografato" [pagina 88].

Infine, l'ultima opzione avvia il partizionamento manuale, che consente schemi di partizionamento più avanzati, come l'installazione di Kali Linux insieme ad altri sistemi operativi. Tratteremo la modalità manuale nella prossima sezione ("Attenzione: il boot loader e il dual boot" [pagina 87]).

In questo esempio, assegneremo un intero disco rigido a Kali, quindi selezioniamo "Guidata - usa l'intero disco" per procedere al passaggio successivo.

Machine Translated by Google

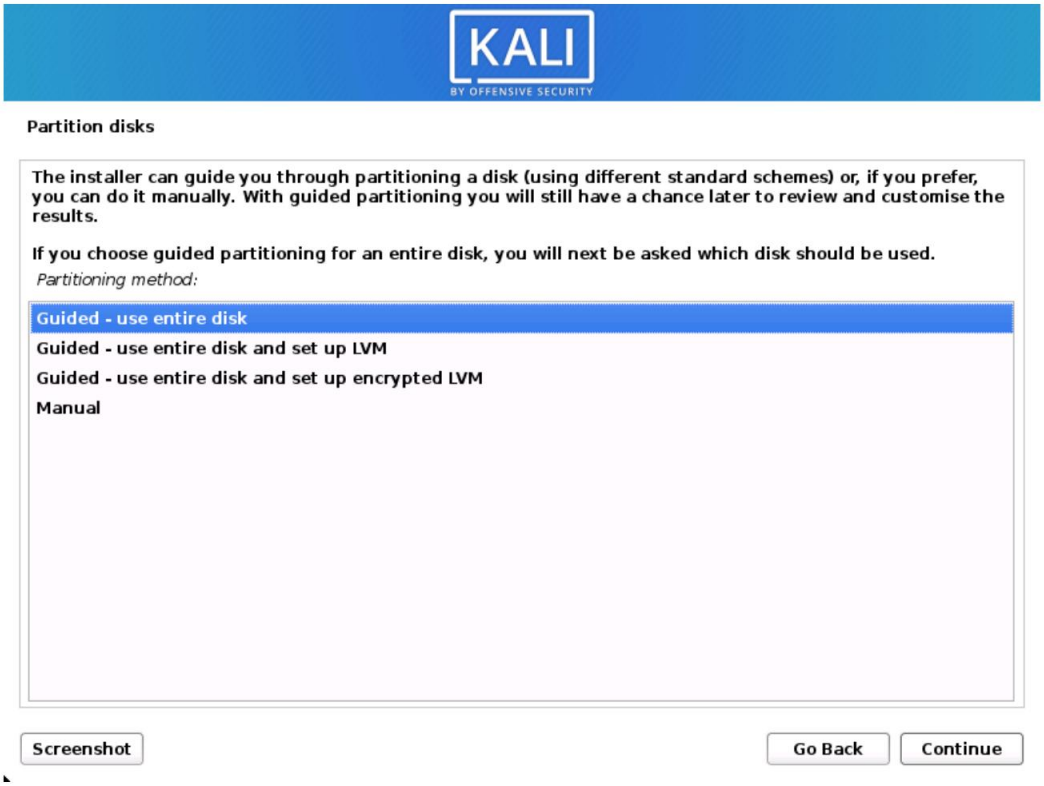



**Figura 4.8** Scelta della modalità di partizionamento

La schermata successiva (mostrata nella Figura 4.9, "Disco da utilizzare per il partizionamento guidato" [pagina 77]) consente di scegliere il disco su cui verrà installato Kali selezionando la voce corrispondente (ad esempio, "SCSI3 (0,0,0) (sda) - 21,5 GB VMware, VMware Virtual S"). Una volta selezionata, il partizionamento guidato proseguirà. Questa opzione cancellerà tutti i dati presenti su questo disco, quindi scegliete con attenzione.

Machine Translated by Google

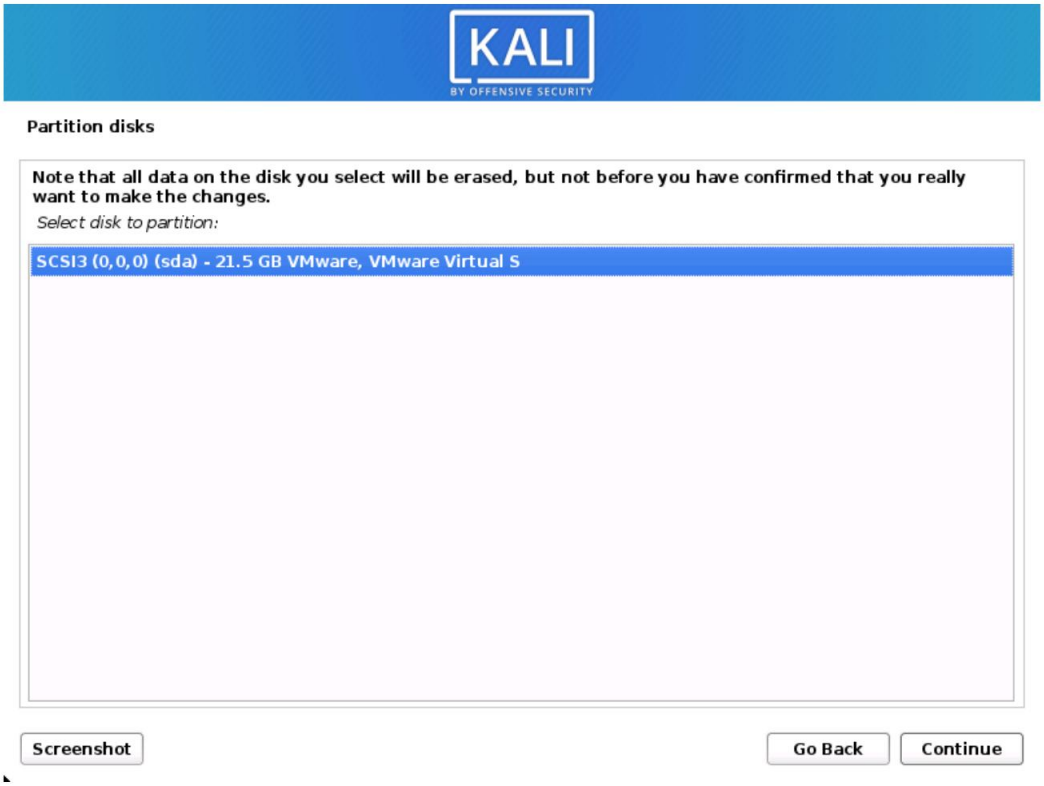



**Figura 4.9** Disco da utilizzare per il partizionamento guidato

Successivamente, lo strumento di partizionamento guidato offre tre metodi di partizionamento, che corrispondono a diversi utilizzi, come mostrato nella Figura 4.10, "Allocazione guidata delle partizioni" [pagina 78].

Machine Translated by Google

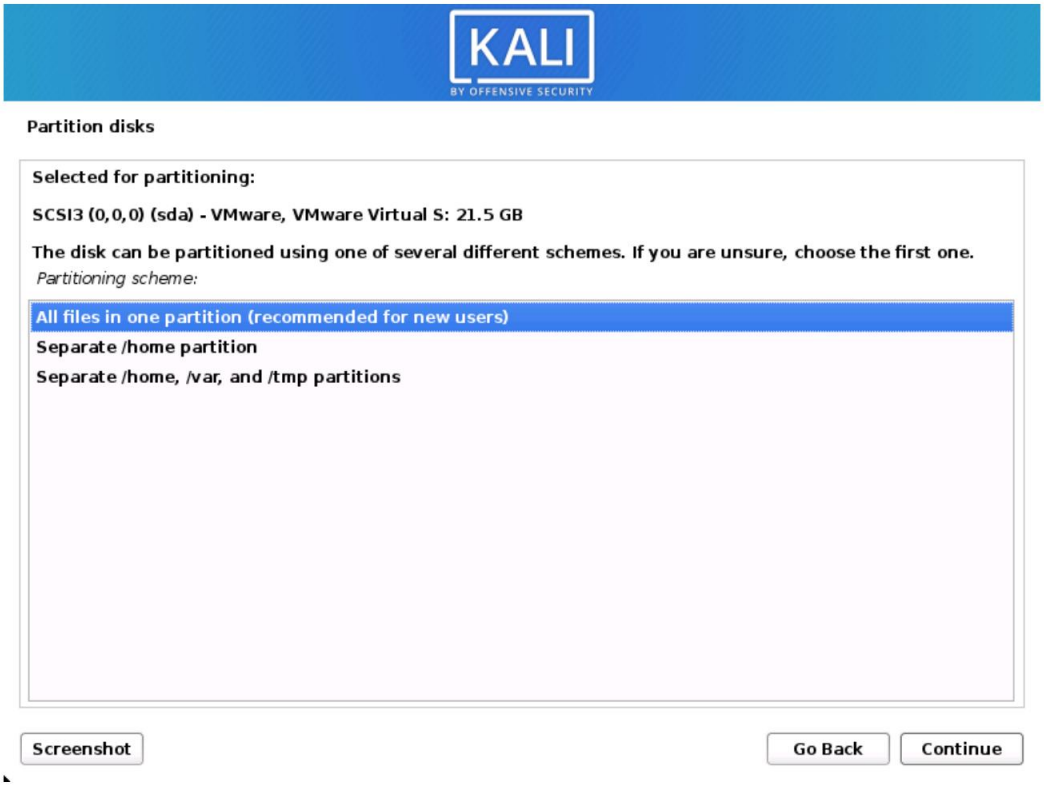



**Figura 4.10** Allocazione guidata delle partizioni

Il primo metodo si chiama "Tutti i file in un'unica partizione". L'intero albero del sistema Linux viene memorizzato in un unico file system, corrispondente alla directory radice ("/") . Questo schema di partizionamento semplice e robusto funziona perfettamente per sistemi personali o a utente singolo. Nonostante il nome, in realtà verranno create due partizioni: la prima conterrà l'intero sistema, la seconda la memoria virtuale (o "swap").

Il secondo metodo, " Partizione /home/ separata ", è simile, ma divide la gerarchia dei file in due: una partizione contiene il sistema Linux (/) e la seconda contiene le "directory home" (ovvero i dati dell'utente, nei file e nelle sottodirectory disponibili in /home/). Un vantaggio di questo metodo è la facilità di preservare i dati dell'utente in caso di reinstallazione del sistema.

L'ultimo metodo di partizionamento, denominato "Partizioni separate per /home, /var e /tmp ", è adatto a server e sistemi multiutente. Divide la struttura delle directory in numerose partizioni: oltre alla directory principale (/) e alle partizioni per gli account utente (/home/) , prevede anche partizioni per i dati del software del server (/var/) e per i file temporanei (/tmp/). Un vantaggio di questo metodo è che gli utenti finali non possono bloccare il server occupando tutto lo spazio disponibile sul disco rigido (possono riempire solo /tmp/ e /home/). Allo stesso tempo, i dati di servizio (in particolare i log) non possono più intasare il resto del sistema.

Machine Translated by Google

Dopo aver scelto il tipo di partizione, il programma di installazione visualizza un riepilogo delle selezioni sullo schermo sotto forma di mappa delle partizioni (Figura 4.11, "Convalida del partizionamento" [pagina 79]). È possibile modificare ciascuna partizione singolarmente selezionandola. Ad esempio, è possibile scegliere un altro file system se quello standard *(ext4)* non è appropriato. Nella maggior parte dei casi, tuttavia, il partizionamento proposto è ragionevole ed è possibile accettarlo selezionando "Termina il partizionamento e scrivi le modifiche sul disco". Può sembrare superfluo dirlo, ma scegliete con attenzione poiché questa operazione cancellerà il contenuto del disco selezionato.

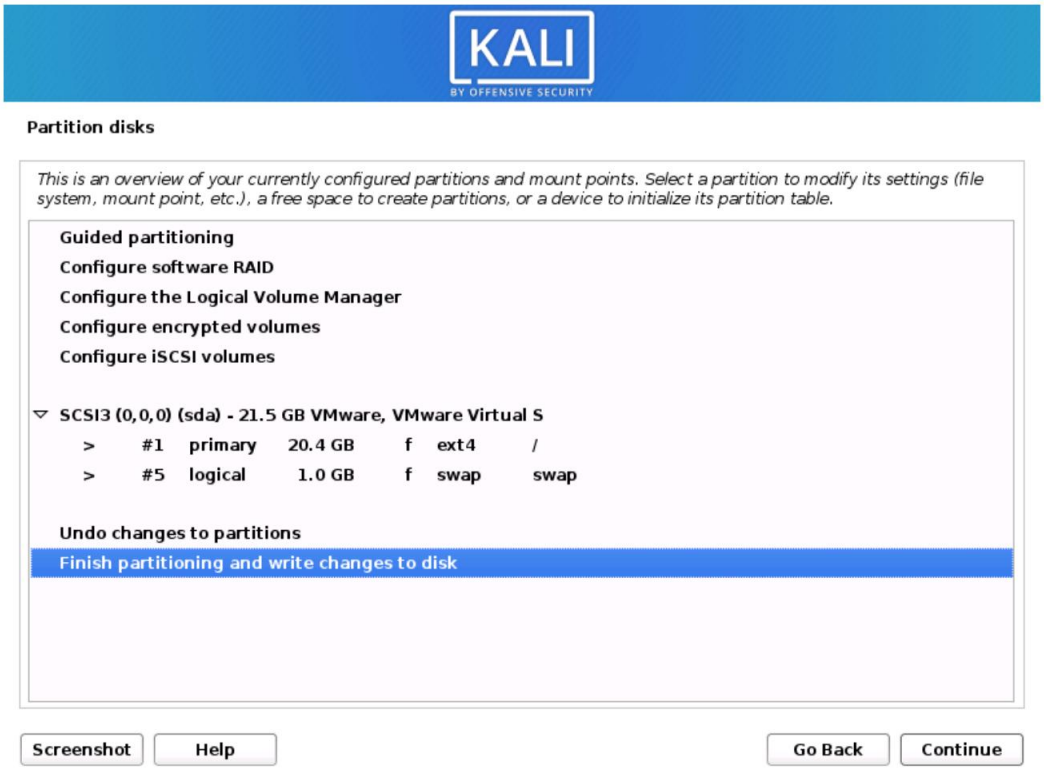



**Figura 4.11** Convalida del partizionamento

**Partizionamento manuale** Selezionando Manuale nella schermata principale "Partiziona dischi" (Figura 4.8, "Scelta della modalità di partizionamento" [pagina 76]) si ottiene una maggiore flessibilità, che consente di scegliere configurazioni più avanzate e di specificare lo scopo e le dimensioni di ciascuna partizione. Ad esempio, questa modalità permette di installare Kali insieme ad altri sistemi operativi, abilitare un array ridondante di dischi indipendenti (RAID) basato su software per proteggere i dati da guasti del disco rigido e ridimensionare in modo sicuro le partizioni esistenti senza perdere dati, tra le altre cose.

Se sei un utente poco esperto e lavori su un sistema con dati preesistenti, presta molta attenzione a questa procedura di configurazione, poiché è molto facile commettere errori che potrebbero causare la perdita di dati.

Machine Translated by Google

| | |
|---|---|
| **Ridurre le dimensioni di una finestra Partizione** | Per installare Kali Linux accanto a un sistema operativo esistente (Microsoft Windows o altro), è necessario disporre di spazio libero sul disco rigido per le partizioni dedicate a Kali. Nella maggior parte dei casi, ciò significa ridurre una partizione esistente e riutilizzare lo spazio liberato.<br><br>Se si utilizza la modalità di partizionamento manuale, il programma di installazione può ridurre facilmente una partizione di Microsoft Windows. È sufficiente selezionare la partizione di Microsoft Windows e immettere la nuova dimensione (questa procedura è valida sia per le partizioni FAT che NTFS). |

La prima schermata del programma di installazione manuale è in realtà identica a quella mostrata nella Figura 4.11, "Convalida delle partizioni" [pagina 79], con la differenza che non include nuove partizioni da creare. Sarà poi compito dell'utente aggiungerle.

Innanzitutto, verrà visualizzata l'opzione "Partizionamento guidato", seguita da diverse opzioni di configurazione. Successivamente, il programma di installazione mostrerà i dischi disponibili, le relative partizioni e l'eventuale spazio libero non ancora partizionato. Come di consueto, è possibile selezionare ciascun elemento visualizzato e premere il tasto Invio per interagire con esso.

Se il disco è completamente nuovo, potrebbe essere necessario creare una tabella delle partizioni. Per farlo, seleziona il disco. Una volta completata l'operazione, dovresti visualizzare lo spazio libero disponibile sul disco.

Per utilizzare questo spazio libero, è necessario selezionarlo e il programma di installazione offrirà due modi per creare partizioni in quello spazio.

Machine Translated by Google




**Figura 4.12** Creazione di partizioni nello spazio libero

La prima operazione creerà una singola partizione con le caratteristiche (inclusa la dimensione) a vostra scelta. La seconda operazione utilizzerà tutto lo spazio libero e creerà al suo interno più partizioni con l'aiuto della procedura guidata di partizionamento (vedere la sezione 4.2.1.12.1, "Partizionamento guidato" [pagina 75]). Questa opzione è particolarmente interessante quando si desidera installare Kali insieme a un altro sistema operativo, ma senza dover gestire nel dettaglio la configurazione delle partizioni. L'ultima voce mostrerà i numeri di cilindro/testina/settore di inizio e fine dello spazio libero.

Quando si seleziona "Crea una nuova partizione", si accede alla fase principale della procedura di partizionamento manuale. Dopo aver selezionato questa opzione, verrà richiesto di specificare la dimensione della partizione. Se il disco utilizza una tabella delle partizioni MSDOS, sarà possibile creare una partizione primaria o logica. (Cose da sapere: è possibile avere solo quattro partizioni primarie, ma molte più partizioni logiche. La partizione contenente /boot, e quindi il kernel, deve essere primaria; le partizioni logiche risiedono in una partizione estesa, che occupa una delle quattro partizioni primarie.) A questo punto dovrebbe apparire la schermata di configurazione generica delle partizioni:

Machine Translated by Google

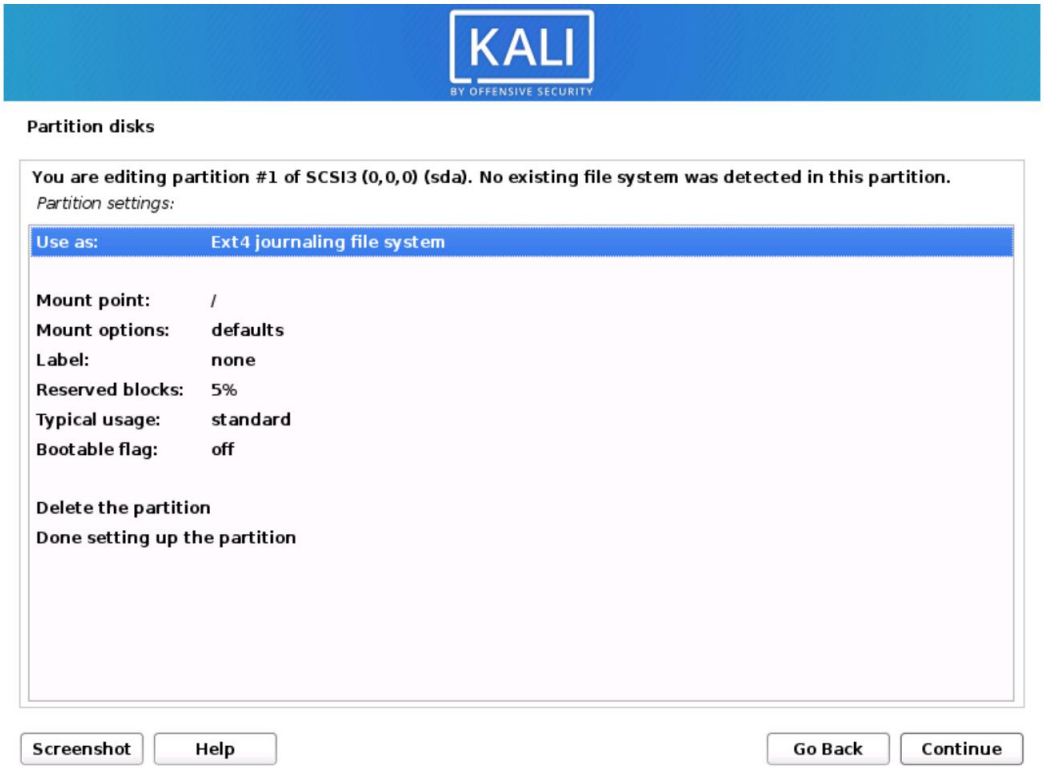



**Figura 4.13** Schermata di configurazione della partizione

Per riassumere questo passaggio di partizionamento manuale, diamo un'occhiata a cosa puoi fare con il nuovo partizione. Puoi:

- Formattalo e includilo nell'albero dei file scegliendo un punto di montaggio. Il punto di montaggio è il directory che ospiterà il contenuto del file system sulla partizione selezionata. Pertanto, una partizione montata su /home/ è tradizionalmente destinata a contenere i dati dell'utente, mentre "/" è nota come *radice* dell'albero dei file e quindi radice della partizione che effettivamente ospitare il sistema Kali.
- Usalo come *partizione di swap.* Quando il kernel Linux non ha memoria libera sufficiente, memorizza le parti inattive della RAM in una speciale partizione di swap sul disco rigido. Il sottosistema di memoria virtuale rende questo processo trasparente alle applicazioni. Per simulare la memoria aggiuntiva, Microsoft Windows utilizza un file di swap (paginazione) contenuto direttamente in un file system. Viceversa, Linux utilizza una partizione dedicata a questo scopo, da cui il termine partizione di swap.
- Trasformarlo in un “volume fisico per la crittografia” per proteggere la riservatezza dei dati su determinate partizioni. Questo caso è automatizzato nella partizione guidata. Per ulteriori informazioni, consultare la sezione 4.2.2, "Installazione su un file system completamente crittografato" [pagina 88].

Machine Translated by Google

- Trasformalo in un "volume fisico per LVM" (non trattato in questo libro). Tieni presente che questa funzione viene utilizzata dal partizionamento guidato quando configuri partizioni crittografate.
- Utilizzalo come dispositivo RAID (argomento non trattato in questo libro).
- Scegli di non utilizzare la partizione e lasciala invariata.

Al termine, è possibile annullare il partizionamento manuale selezionando "Annulla modifiche alle partizioni" oppure salvare le modifiche sul disco selezionando "Termina partizionamento e salva le modifiche sul disco" dalla schermata di installazione manuale (Figura 4.11, "Convalida del partizionamento" [pagina 79]).

## Copia dell'immagine live

Il passaggio successivo, che non richiede alcuna interazione da parte dell'utente, copia il contenuto dell'immagine live nel file system di destinazione, come mostrato nella Figura 4.14, "Copia dei dati dall'immagine live" [pagina 83].




**Figura 4.14** Copia dei dati dall'immagine in tempo reale

Machine Translated by Google



Se si desidera utilizzare un mirror locale anziché http.kali.org, è possibile specificarne il nome sulla riga di comando del kernel (all'avvio) con una sintassi simile a questa: mirror/http/hostname=my.own.mirror.

Il programma di installazione propone di utilizzare un *proxy HTTP* , come mostrato nella Figura 4.15, "Utilizzo di un proxy HTTP" [pagina 84]. Un proxy HTTP è un server che inoltra le richieste HTTP per gli utenti della rete. A volte contribuisce ad accelerare i download mantenendo una copia dei file che sono stati trasferiti attraverso di esso (in questo caso si parla di proxy di caching). In alcuni casi, è l'unico modo per accedere a un server web esterno; in tali casi, il programma di installazione sarà in grado di scaricare i pacchetti Debian solo se si compila correttamente questo campo durante l'installazione. Se non si fornisce un indirizzo proxy, il programma di installazione tenterà di connettersi direttamente a Internet.

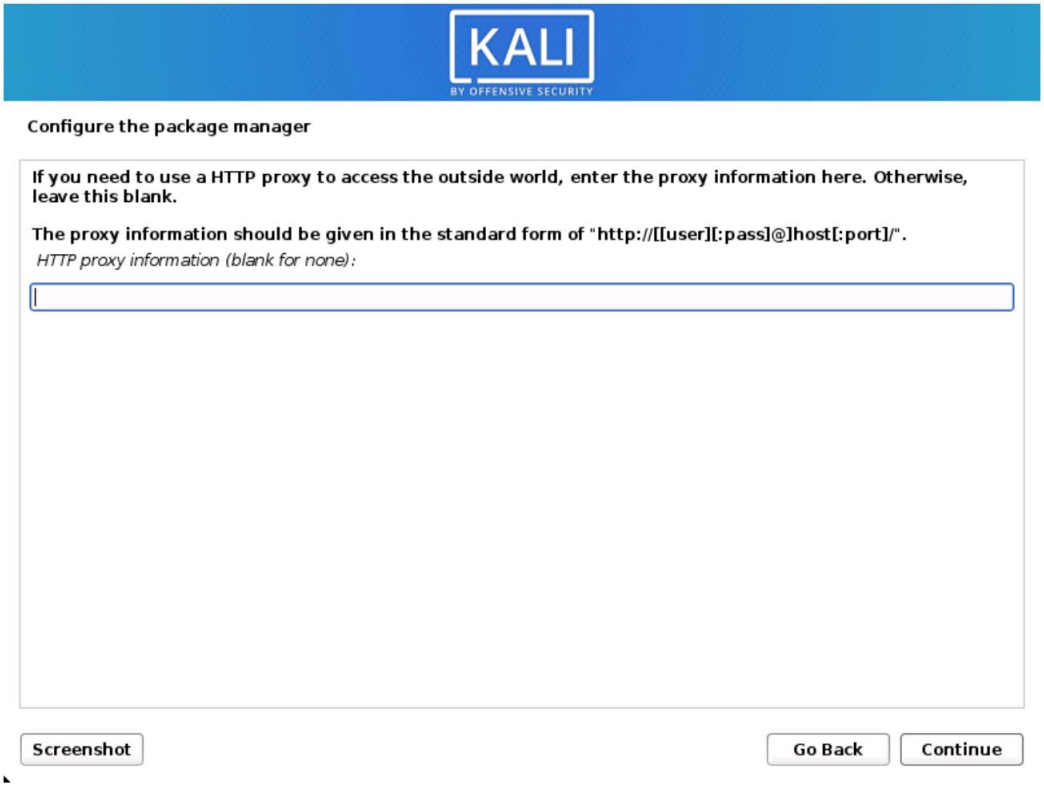



**Figura 4.15** Utilizzo di un proxy HTTP

Successivamente, i file Packages.xz e Sources.xz verranno scaricati automaticamente per aggiornare l'elenco dei pacchetti riconosciuti da APT.

Machine Translated by Google

Installazione dei metapackage

Se stai installando il sistema utilizzando l'immagine di installazione o l'immagine di installazione di rete, ora ti verrà data la possibilità di scegliere quali pacchetti installare. Tieni presente che, se utilizzi l'immagine di installazione di rete, sarà necessario l'accesso a Internet. Potrai scegliere l'ambiente desktop e gli strumenti da includere. Puoi modificare queste selezioni in qualsiasi momento dopo l'installazione di Kali Linux, anche se utilizzi un'immagine live per installarlo.

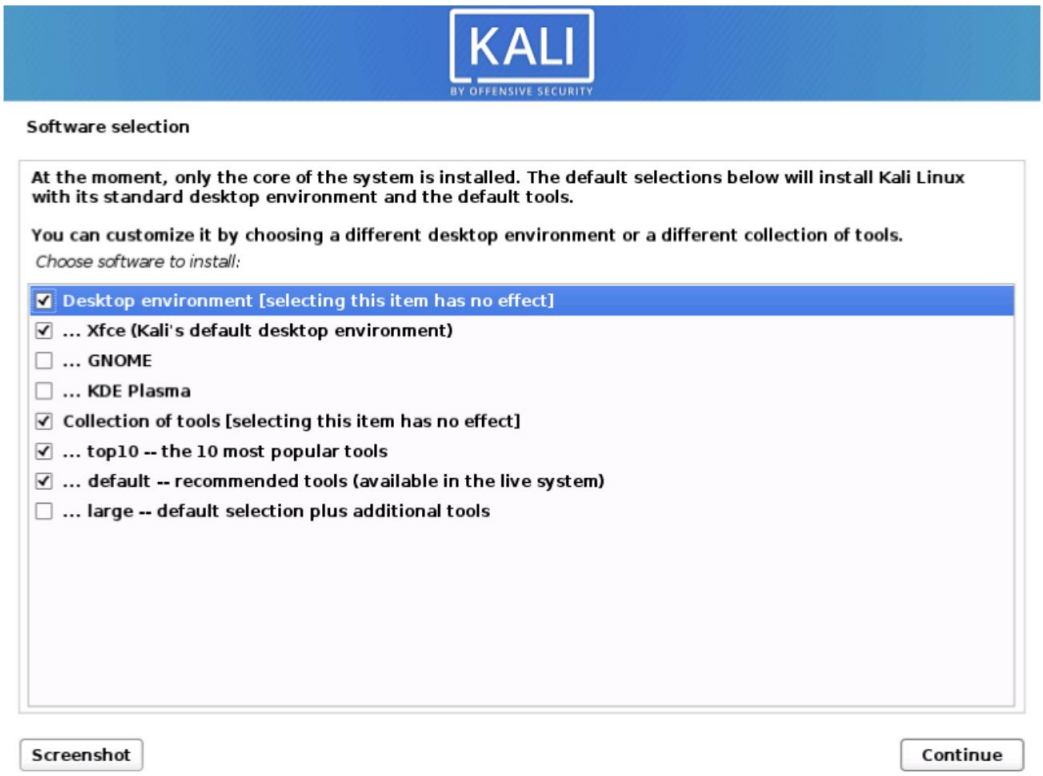



**Figura 4.16** Installazione dei metapackage

Installazione del boot loader GRUB

Il boot loader è il primo programma avviato dal BIOS. Questo programma carica il kernel Linux in memoria e lo esegue. Il boot loader offre spesso un menu che consente di scegliere il kernel da caricare o il sistema operativo da avviare.

Machine Translated by Google

Grazie alla sua superiorità tecnica, GRUB è il boot loader predefinito installato da Kali: funziona con la maggior parte dei file system e quindi non richiede un aggiornamento dopo ogni installazione di un nuovo kernel, poiché legge la sua configurazione durante l'avvio e trova la posizione esatta del nuovo kernel.

È necessario installare GRUB nel Master Boot Record (MBR) a meno che non si disponga già di un altro sistema Linux installato in grado di avviare Kali Linux. Come indicato nella Figura 4.17, "Installare il boot loader GRUB su un disco rigido" [pagina 86], la modifica dell'MBR renderà non avviabili i sistemi operativi non riconosciuti che dipendono da esso, finché non si corregge la configurazione di GRUB.

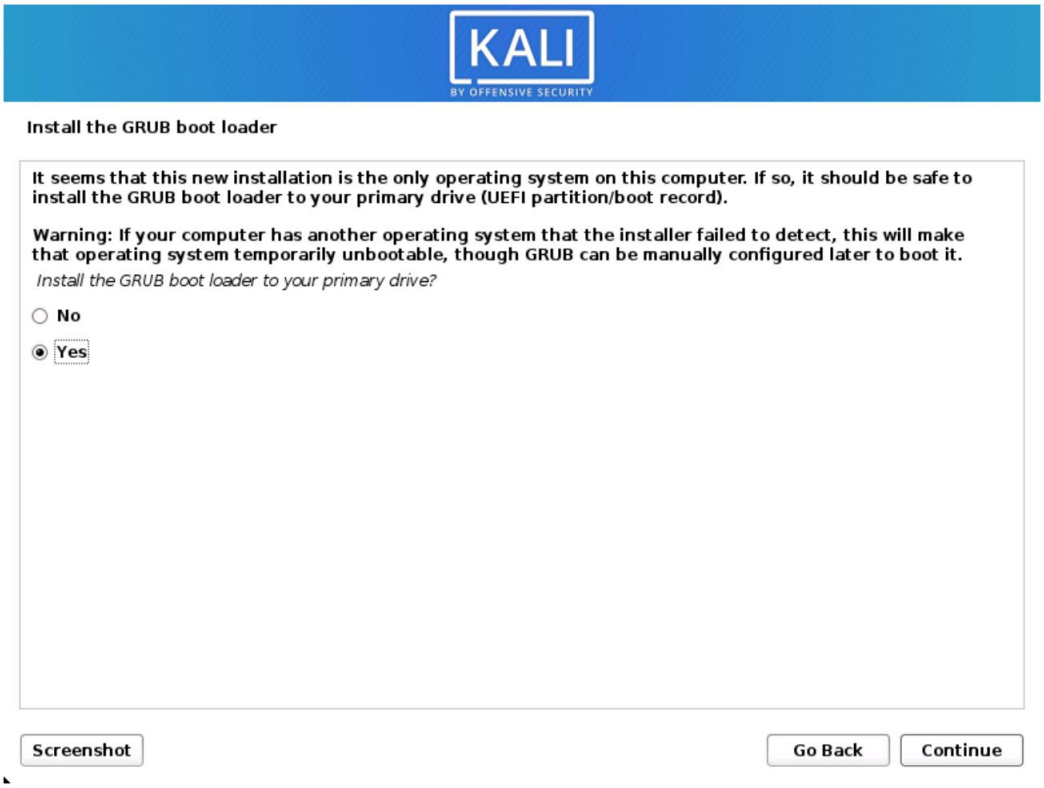



**Figura 4.17** Installazione del boot loader GRUB su un disco rigido

In questa fase (Figura 4.18, "Dispositivo per l'installazione del boot loader" [pagina 87]), è necessario selezionare il dispositivo su cui verrà installato GRUB. Dovrebbe essere l'unità di avvio corrente.

Machine Translated by Google

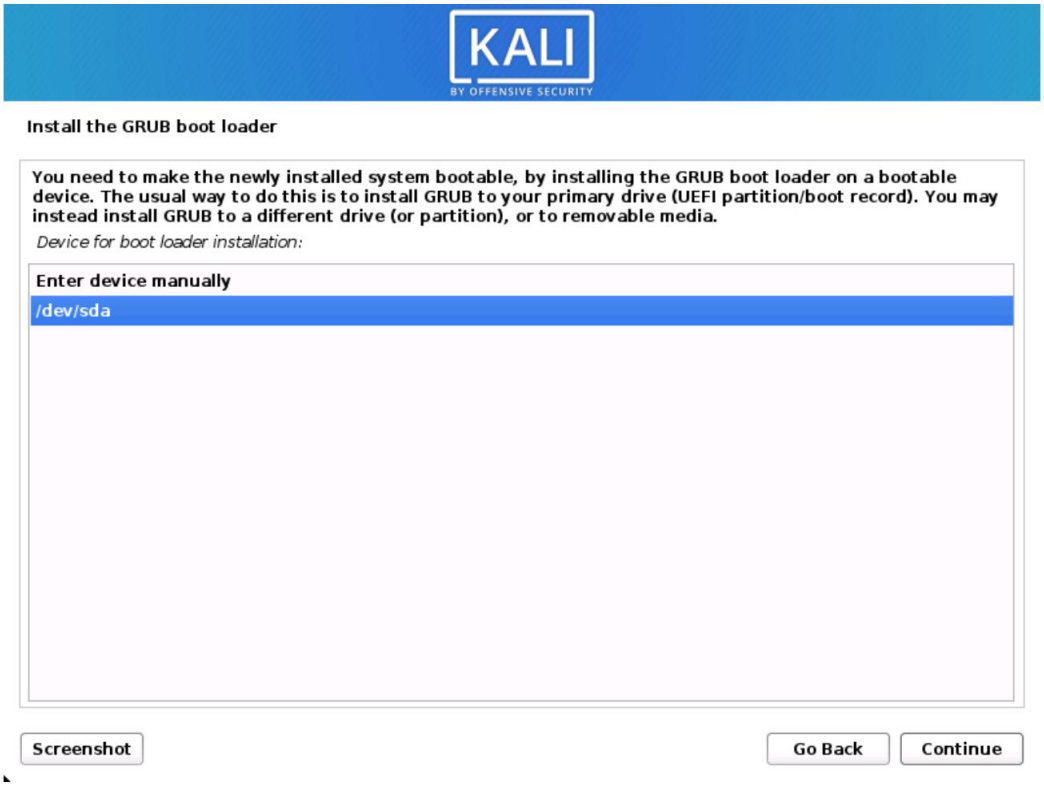



**Figura 4.18** Dispositivo per l'installazione del boot loader

Per impostazione predefinita, il menu di avvio proposto da GRUB mostra tutti i kernel Linux installati, nonché qualsiasi altro sistema operativo rilevato. Per questo motivo, è consigliabile accettare l'offerta di installarlo nel Master Boot Record. Mantenere versioni precedenti del kernel preserva la possibilità di avviare il sistema nel caso in cui il kernel installato più di recente sia difettoso o non sia ben adattato all'hardware. Pertanto, si consiglia di mantenere installate alcune versioni precedenti del kernel.

**Attenzione: il Boot Loader e il Dual Boot**

Questa fase del processo di installazione rileva i sistemi operativi già installati sul computer e aggiunge automaticamente le voci corrispondenti al menu di avvio. Tuttavia, non tutti i programmi di installazione lo fanno.

In particolare, se installi (o reinstalli) Microsoft Windows in seguito, il boot loader verrà cancellato. Kali sarà ancora presente sul disco rigido, ma non sarà più accessibile dal menu di avvio. Dovrai quindi avviare il programma di installazione di Kali con il

Il parametro **rescue/enable=true** nella riga di comando del kernel consente di reinstallare il boot loader. Questa operazione è descritta in dettaglio nel manuale di installazione di Debian.

ÿ https://www.debian.org/releases/stable/amd64/ch08s06.en.html

Machine Translated by Google

### Completamento dell'installazione e riavvio

Ora che l'installazione è completa, il programma ti chiede di scollegare l'unità USB o di rimuovere il DVD-ROM dal lettore in modo che il tuo computer possa avviarsi nel tuo nuovo sistema Kali dopo Il programma di installazione riavvia il sistema (Figura 4.19, "Installazione completata" [pagina 88]).

Infine, il programma di installazione eseguirà alcune operazioni di pulizia, come la rimozione dei pacchetti specifici per la creazione dell'ambiente live. Rileverà inoltre se Kali Linux è stato installato in una macchina virtuale. (VM) e installa automaticamente tutti gli strumenti guest per facilitare l'integrazione tra l'host e il guest Kali.

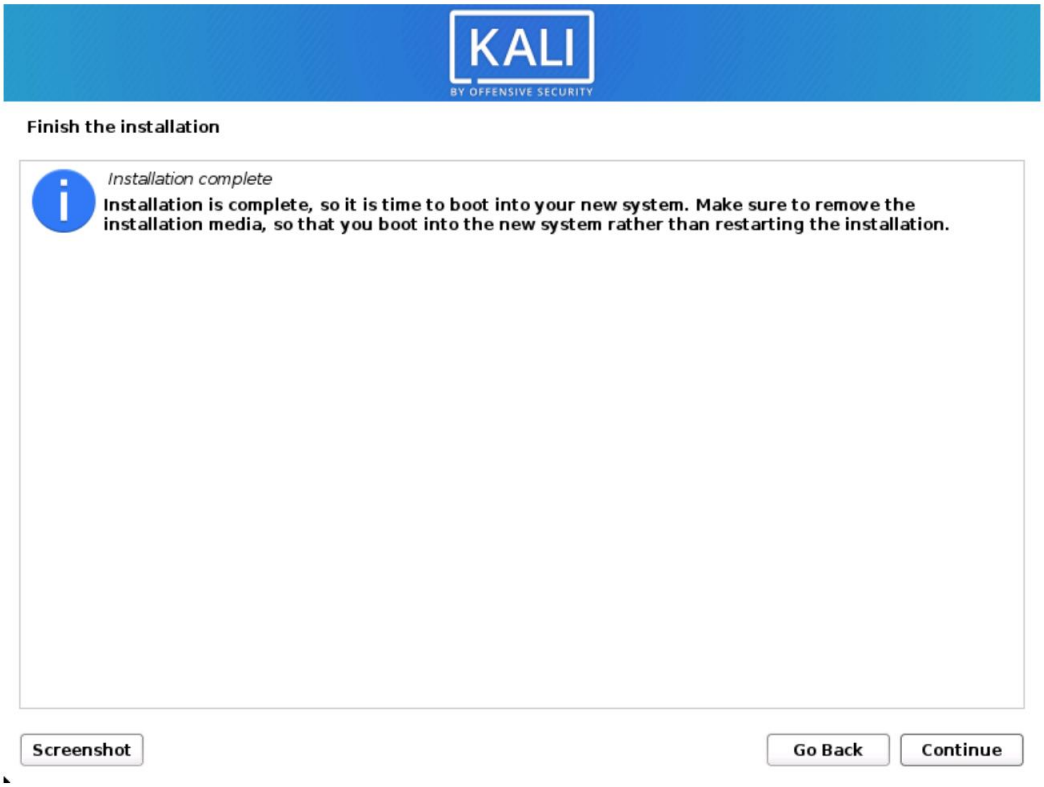



**Figura 4.19** Installazione completata

### 4.2.2. Installazione su un file system completamente crittografato

Per garantire la riservatezza dei tuoi dati, puoi impostare partizioni crittografate. Questo proteggerà i tuoi dati se il tuo laptop o disco rigido viene perso o rubato. Lo strumento di partizionamento può aiutarti in questo processo, sia in modalità guidata che manuale.

Machine Translated by Google

La modalità di partizionamento guidato combinerà l'utilizzo di due tecnologie: Linux Unified Key Setup (LUKS) per la crittografia delle partizioni e Logical Volume Management (LVM) per la gestione dinamica dello storage. Entrambe le funzionalità possono essere configurate anche tramite la modalità di partizionamento manuale.

## Introduzione a LVM

Innanzitutto, parliamo di LVM. Nella terminologia di LVM, una *partizione virtuale* è un volume logico, che fa parte di un *gruppo di volumi,* ovvero un'associazione di più volumi fisici. I volumi fisici sono partizioni reali (o partizioni virtuali esportate da altre astrazioni, come un dispositivo RAID software o una partizione crittografata).

Grazie alla sua capacità di eliminare la distinzione tra partizioni "fisiche" e "logiche", LVM consente di creare partizioni "virtuali" che si estendono su più dischi. I vantaggi sono duplici: la dimensione delle partizioni non è più limitata dai singoli dischi, ma dal loro volume complessivo, ed è possibile ridimensionare le partizioni esistenti in qualsiasi momento, ad esempio dopo aver aggiunto un disco.

Questa tecnica funziona in modo molto semplice: ogni volume, sia fisico che logico, viene suddiviso in blocchi della stessa dimensione, che LVM correla. L'aggiunta di un nuovo disco comporta la creazione di un nuovo volume fisico, fornendo nuovi blocchi che possono essere associati a qualsiasi gruppo di volumi. Tutte le partizioni del gruppo di volumi possono quindi sfruttare appieno lo spazio aggiuntivo allocato.

## Introduzione a LUKS

Per proteggere i tuoi dati, puoi aggiungere un livello di crittografia al di sotto del file system che preferisci. Linux (e in particolare il driver *dm-crypt )* utilizza il device mapper per creare la partizione virtuale (il cui contenuto è protetto) basandosi su una partizione sottostante che memorizzerà i dati in forma crittografata (grazie a LUKS). LUKS standardizza la memorizzazione dei dati crittografati, nonché le meta-informazioni che indicano gli algoritmi di crittografia utilizzati.

Configureremo LUKS come parte della nostra funzionalità "nuke" più avanti in "Aggiunta di una password Nuke per una maggiore sicurezza" [pagina 250].

**Partizione di swap crittografata:** quando si utilizza una partizione crittografata, la chiave di crittografia viene memorizzata nella memoria RAM e, in caso di ibernazione, il laptop copia la chiave, insieme ad altri contenuti della RAM, nella partizione di swap del disco rigido. Poiché chiunque abbia accesso al file di swap (incluso un tecnico o un ladro) potrebbe estrarre la chiave e decrittografare i dati, il file di swap deve essere protetto tramite crittografia.

Per questo motivo, il programma di installazione ti avviserà se tenti di utilizzare una partizione crittografata insieme a una partizione di swap non crittografata.

Machine Translated by Google



La procedura di installazione di LVM crittografato è identica a quella di un'installazione standard, ad eccezione della fase di partizionamento (Figura 4.20, "Partizionamento guidato con LVM crittografato" [pagina 90]), in cui si seleziona "Guidato - usa l'intero disco e configura LVM crittografato". Il risultato sarà un sistema che non potrà essere avviato o a cui non sarà possibile accedere finché non verrà fornita la passphrase di crittografia. In questo modo i dati presenti sul disco verranno crittografati e protetti.

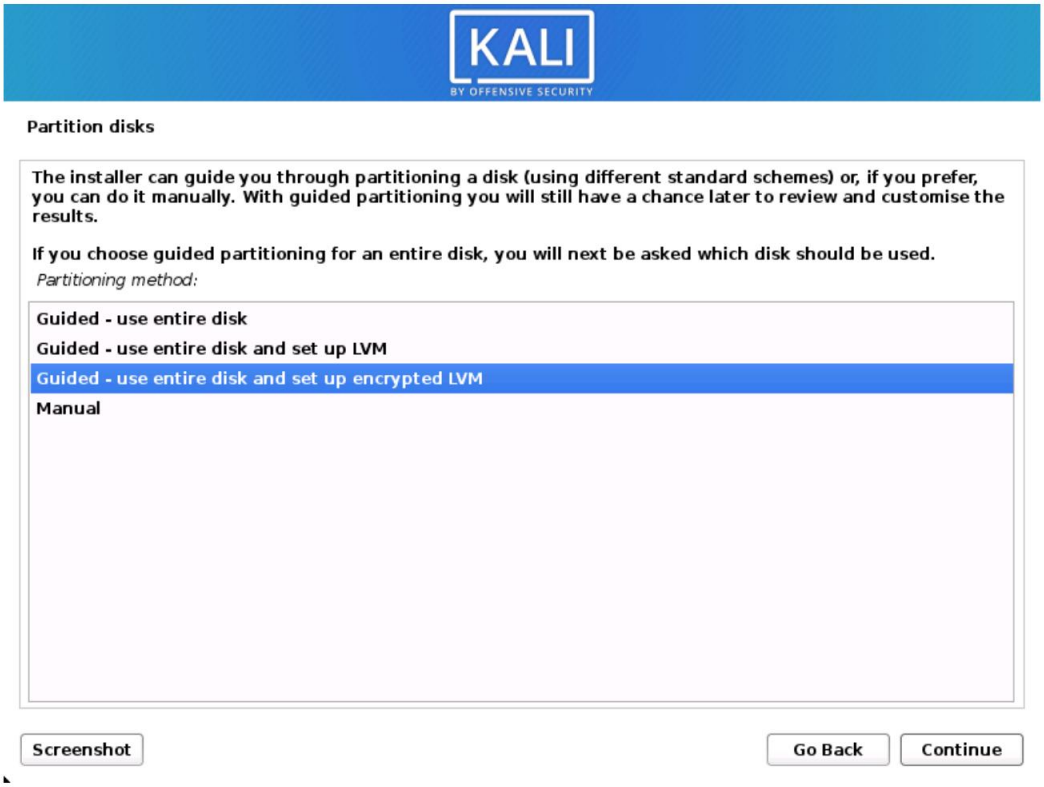



**Figura 4.20** Partizionamento guidato con LVM crittografato

Il programma di installazione del partizionamento guidato assegnerà automaticamente una partizione fisica per l'archiviazione dei dati crittografati, come mostrato nella Figura 4.21, "Conferma delle modifiche alla tabella delle partizioni" [pagina 91]. A questo punto, il programma di installazione confermerà le modifiche prima che vengano scritte sul disco.

Machine Translated by Google

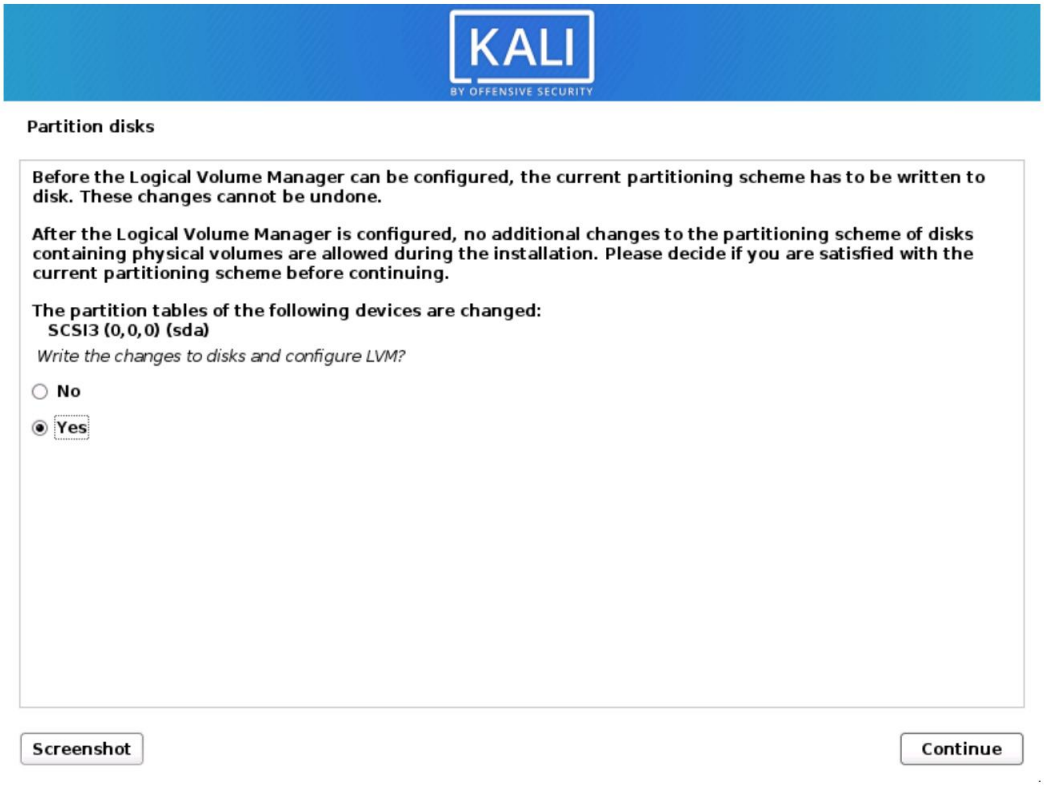



**Figura 4.21** Conferma le modifiche alla tabella delle partizioni

Questa nuova partizione viene quindi inizializzata con dati casuali, come mostrato nella Figura 4.22, "Cancellazione dei dati su una partizione crittografata" [pagina 92]. In questo modo, le aree contenenti dati diventano indistinguibili dalle aree non utilizzate, rendendo più difficile rilevare e, di conseguenza, attaccare i dati crittografati.

Machine Translated by Google

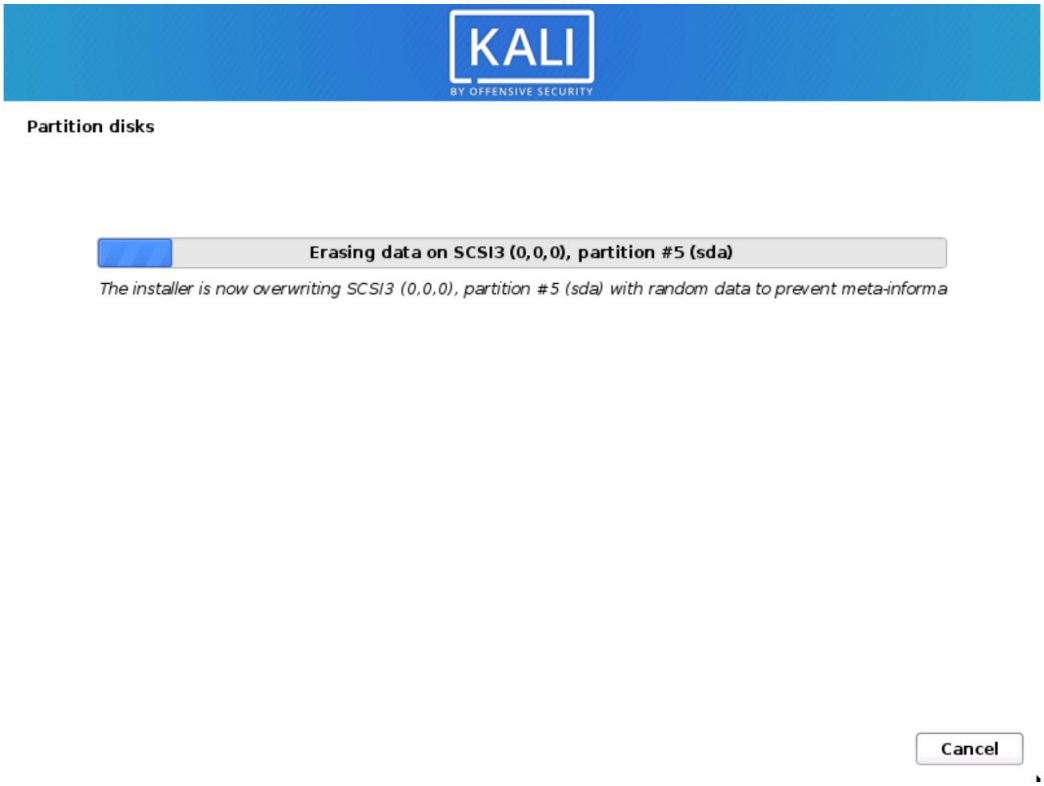



**Figura 4.22** Cancellazione dei dati su una partizione crittografata

Successivamente, il programma di installazione ti chiede di immettere una passphrase di crittografia (Figura 4.23, "Immetti la tua passphrase di crittografia" [pagina 93]). Per visualizzare il contenuto della partizione crittografata, dovrai

È necessario inserire questa passphrase ogni volta che si riavvia il sistema. Prestare attenzione all'avviso presente nel programma di installazione:

La sicurezza del tuo sistema crittografato dipenderà esclusivamente da questa passphrase.

Machine Translated by Google

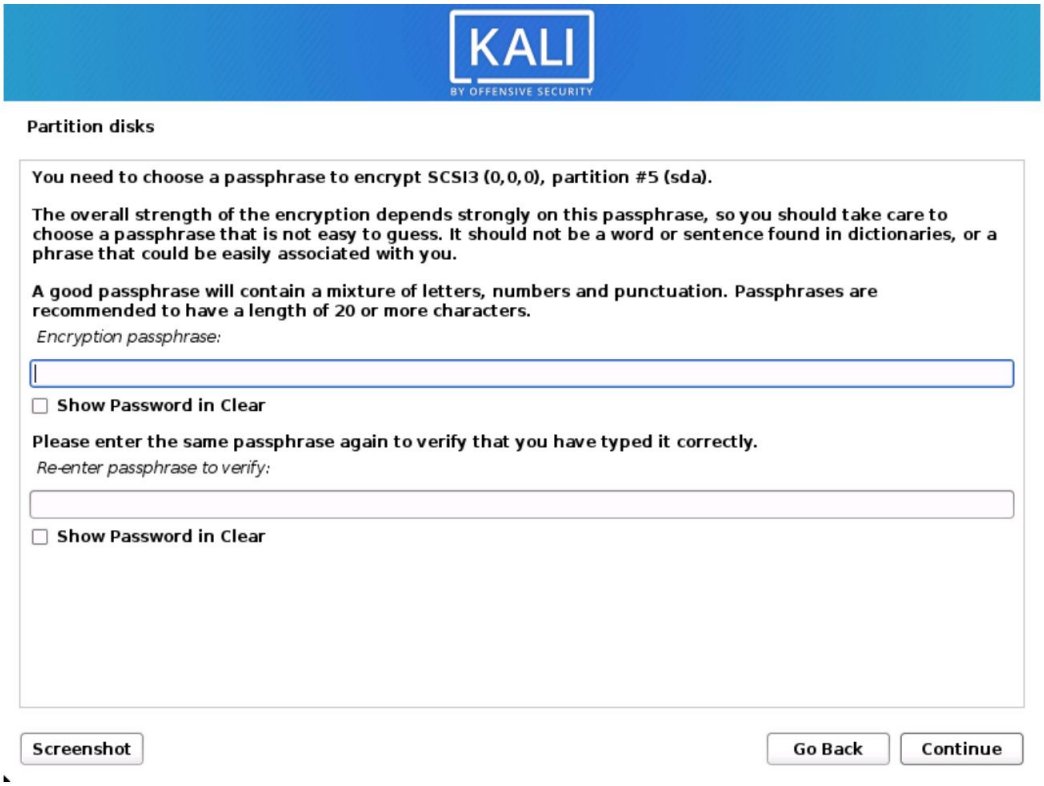



**Figura 4.23** Inserisci la tua frase di crittografia

Lo strumento di partizionamento ora ha accesso a una nuova partizione virtuale il cui contenuto è memorizzato in forma crittografata nella partizione fisica sottostante. Poiché LVM utilizza questa nuova partizione come partizione fisica volume, può proteggere diverse partizioni (o volumi logici LVM) con la stessa chiave di crittografia, inclusa la partizione di swap (vedi riquadro "Partizione di swap crittografata" [pagina 89]). Qui, LVM non è utilizzato per facilitare l'estensione della dimensione di archiviazione, ma solo per la comodità dell'indirezione Consente di suddividere una singola partizione crittografata in più volumi logici.

## Fine della partizione guidata con LVM crittografato

Successivamente, viene visualizzato lo schema di partizionamento risultante (Figura 4.24, "Convalida del partizionamento per l'installazione LVM crittografata" [pagina 94]) in modo da poter modificare le impostazioni secondo necessità.

Machine Translated by Google

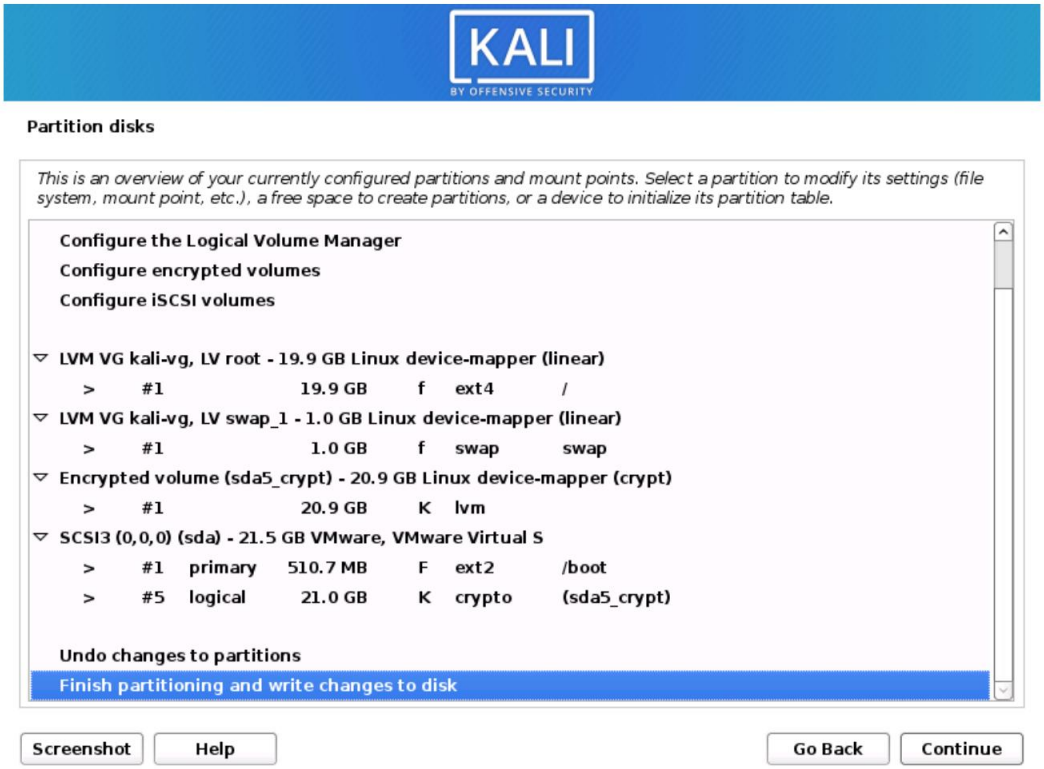



**Figura 4.24** Convalida del partizionamento per l'installazione LVM crittografata

Infine, dopo aver convalidato la configurazione delle partizioni, lo strumento richiede la conferma per scrivere le modifiche sui dischi, come mostrato nella Figura 4.25, "Conferma delle partizioni da formattare" [pagina 95].

Machine Translated by Google

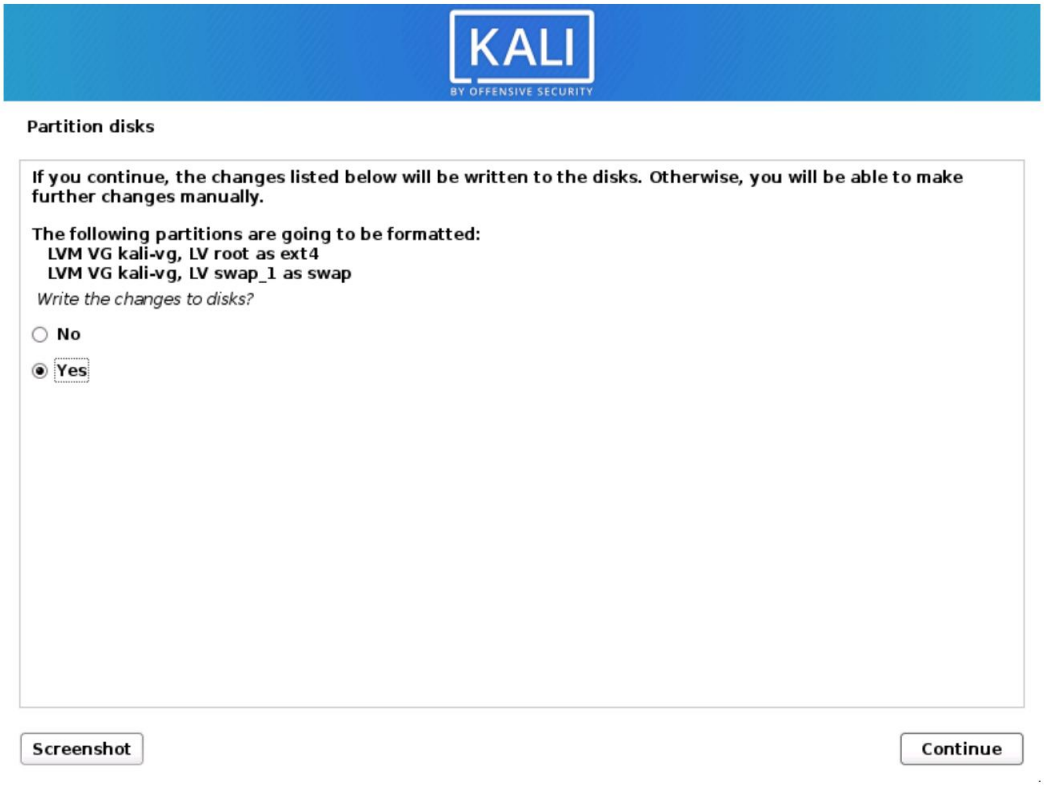



**Figura 4.25** Conferma le partizioni da formattare

Infine, il processo di installazione prosegue come di consueto, secondo quanto documentato nella sezione 4.2.1.14, "Configurazione del gestore di pacchetti (apt)" [pagina 84].

## 4.3. Installazioni non presidiate

I programmi di installazione di Debian e Kali sono molto modulari: a livello base, eseguono semplicemente una serie di script (confezionati in piccoli pacchetti chiamati udeb, ovvero µdeb o micro-deb) uno dopo l'altro. Ogni script si basa su debconf (vedi "Lo strumento debconf " [pagina 220]), che interagisce con l'utente e memorizza i parametri di installazione. Per questo motivo, il processo di installazione può essere automatizzato anche tramite il preseeding di debconf, una funzione che consente di fornire risposte automatiche alle domande di installazione.

Machine Translated by Google

#### 4.3.1. Preimpostazione delle risposte

Esistono diversi modi per preimpostare le risposte per l'installatore. Ogni metodo presenta vantaggi e svantaggi. A seconda del momento in cui avviene la preimpostazione, le domande che possono essere preimpostate variano.

##### Con parametri di avvio

È possibile preimpostare qualsiasi domanda di installazione con parametri di avvio che finiscono nella riga di comando del kernel, accessibile tramite /proc/cmdline. Alcuni bootloader consentono di modificare questi parametri in modo interattivo (il che è pratico a scopo di test), ma se si desidera che le modifiche siano permanenti, sarà necessario modificare la configurazione del bootloader.

È possibile utilizzare direttamente l'identificativo completo delle domande di debconf (come debian-installer/language=en) oppure utilizzare le abbreviazioni per le domande più comuni (come language=en o hostname=kali). Vedi l' elenco completo1 degli alias nel manuale di installazione di Debian.

Non ci sono restrizioni sulle domande che è possibile preimpostare, poiché i parametri di avvio sono disponibili fin dall'inizio del processo di installazione e vengono elaborati molto presto. Tuttavia, il numero di parametri di avvio è limitato a 32 e molti di questi sono già utilizzati di default. È inoltre importante tenere presente che la modifica della configurazione del boot loader può talvolta risultare complessa.

Nella sezione 9.3, "Creazione di immagini ISO live personalizzate di Kali" [pagina 241], imparerai anche come modificare la configurazione di isolinux quando generi la tua immagine ISO di Kali.

##### Con un file preimpostato nell'Initrd

È possibile aggiungere un file denominato preseed.cfg nella directory principale dell'initrd del programma di installazione ( ovvero l'initrd utilizzato per avviare il programma). Solitamente, ciò richiede la ricompilazione del pacchetto sorgente debian-installer per generare nuove versioni dell'initrd. Tuttavia, live-build offre un metodo più pratico per farlo, descritto in dettaglio nella sezione 9.3, "Creazione di immagini ISO live personalizzate di Kali" [pagina 241].

Questo metodo non presenta alcuna restrizione sulle domande che è possibile preimpostare, poiché il file di preimpostazione è disponibile immediatamente dopo l'avvio. In Kali, utilizziamo già questa funzionalità per personalizzare il comportamento del programma di installazione ufficiale di Debian.

##### Con un file preimpostato nel supporto di avvio

È possibile aggiungere un file di preimpostazione al supporto di avvio (DVD o chiavetta USB); la preimpostazione avverrà quindi non appena il supporto viene montato, ovvero subito dopo le domande relative alla lingua e al layout della tastiera. Il parametro di avvio preseed/file può essere utilizzato per indicare la posizione del file di preseeding (per

[1] https://www.debian.org/releases/stable/amd64/apbs02#preseed-aliases

Machine Translated by Google

ad esempio, /cdrom/preseed.cfg quando si installa da un DVD-ROM, oppure /hd-media/preseed.cfg quando si installa da una chiavetta USB).

Potrebbe non essere possibile preimpostare le risposte alle opzioni di lingua e paese, poiché il file di preimpostazione viene caricato in una fase successiva del processo, dopo il caricamento dei driver hardware. D'altro canto, la modalità live-build semplifica l'inserimento di un file supplementare nelle immagini ISO generate (vedere la sezione 9.3, "Creazione di immagini ISO live personalizzate di Kali" [pagina 241]).

### Con un file preimpostato caricato dalla rete

È possibile rendere disponibile un file preseed in rete tramite un server web e indicare al programma di installazione di scaricare tale file preseed aggiungendo il parametro di avvio preseed/url=http://server/preseed.cfg (oppure utilizzando l' alias URL ).

Tuttavia, quando si utilizza questo metodo, è importante ricordare che la rete deve essere prima configurata. Ciò significa che le domande di debconf relative alla rete (in particolare hostname e nome di dominio) e tutte le domande precedenti (come lingua e paese) non possono essere preimpostate con questo metodo.
Questo metodo viene spesso utilizzato in combinazione con parametri di avvio che precedono tali domande specifiche.

Questo metodo di preinstallazione è il più flessibile, in quanto consente di modificare la configurazione di installazione senza cambiare il supporto di installazione.

| | |
|---|---|
| **Ritardare il linguaggio, Paese, Tastiera Domande** | Per ovviare alla limitazione di non poter preimpostare le domande relative a lingua, paese e tastiera, è possibile aggiungere il parametro di avvio auto-install/enable=true (o auto=true). Con questa opzione, le domande verranno poste in un secondo momento, dopo la configurazione della rete e quindi dopo il download del file di preimpostazione.<br>Lo svantaggio è che i primi passaggi (in particolare la configurazione di rete) avverranno sempre in inglese e, in caso di errori, l'utente dovrà navigare tra le schermate in inglese (con una tastiera configurata in QWERTY). |

#### 4.3.2. Creazione di un file preimpostato

Un file preseed è un file di testo semplice in cui ogni riga contiene la risposta a una domanda di Debconf.
Una riga è divisa in quattro campi separati da spazi bianchi (spazi o tabulazioni). Ad esempio, di mirror/- suite string kali-rolling:

- Il primo campo indica il proprietario della domanda. Ad esempio, "di" viene utilizzato per le domande relative al programma di installazione. Potresti anche vedere il nome di un pacchetto, per le domande provenienti da pacchetti De-bian (come in questo esempio: atftpd atftpd/use_inetd boolean false). • Il

secondo campo è un identificatore per la domanda. • Il terzo

campo elenca il tipo di domanda.

Machine Translated by Google

- Il quarto e ultimo campo contiene il valore della risposta attesa. Si noti che deve essere separato dal terzo campo da un singolo spazio; gli spazi aggiuntivi sono considerati parte del valore.

Il modo più semplice per scrivere un file preseed è installare un sistema manualmente. Successivamente, il comando debconf-get-selections --installer fornirà le risposte che hai fornito al programma di installazione. Puoi ottenere risposte specifiche per altri pacchetti con debconf-get-selections.
Tuttavia, una soluzione più pulita consiste nello scrivere manualmente il file preseed, partendo da un esempio e consultando la documentazione. Con questo approccio, è possibile preimpostare solo le domande per le quali è necessario sovrascrivere la risposta predefinita. Specificando il parametro di avvio priority=critical, si indica a Debconf di porre solo le domande critiche e di utilizzare la risposta predefinita per le altre.

**Guida all'installazione Appendice**

La guida all'installazione di Debian, disponibile online, include una documentazione dettagliata sull'utilizzo di un file preseed in un'appendice. Include anche un file di esempio dettagliato e commentato, che può servire da base per personalizzazioni locali.

ÿ https://www.debian.org/releases/stable/amd64/apb

ÿ https://www.debian.org/releases/stable/example-preseed.txt

Tieni presente, tuttavia, che i link sopra riportati documentano la versione stabile di Debian, mentre Kali utilizza la versione di test, quindi potresti riscontrare lievi differenze. Puoi anche consultare il manuale di installazione disponibile sul sito web del progetto Debian-installer. Potrebbe essere più aggiornato.

## 4.4. Installazioni ARM

Kali Linux funziona su una vasta gamma di dispositivi basati su ARM (computer portatili, computer embedded e schede di sviluppo, ad esempio), ma non è possibile utilizzare il tradizionale programma di installazione di Kali su questi dispositivi poiché spesso presentano requisiti specifici in termini di configurazione del kernel o del boot loader.

Per rendere questi dispositivi più accessibili agli utenti di Kali, Offensive Security ha sviluppato degli script per creare immagini disco[2] che sono pronte per l'uso con vari dispositivi ARM. Forniscono queste immagini pregenerate, pronte per il download sul loro sito web:

ÿ https://www.offensive-security.com/kali-linux-arm-images/

Grazie alla disponibilità di queste immagini, l'installazione di Kali su un dispositivo ARM risulta notevolmente semplificata. Ecco i passaggi fondamentali:

1. Scarica l'immagine per il tuo dispositivo ARM e assicurati che il checksum corrisponda a quello fornito sul sito web (vedi la sezione 2.1.3, "Verifica dell'integrità e dell'autenticità" [pagina 17] per le istruzioni su come farlo). Tieni presente che le immagini sono solitamente compresse con xz; assicurati di decomprimerle con unxz.

[2] https://gitlab.com/kalilinux/build-scripts/kali-arm

Machine Translated by Google

2. A seconda dello slot di espansione di memoria disponibile sul dispositivo ARM in uso, procurati una scheda SD, una scheda micro SD o un modulo controller multimediale integrato (eMMC) con una capacità di almeno 8 GB.

3. Copiare l'immagine scaricata sul dispositivo di archiviazione con dd. Il procedimento è simile a quello per copiare un'immagine ISO su una chiavetta USB (vedere la sezione 2.1.4, "Copia dell'immagine su un DVD-ROM o una chiavetta USB" [pagina 19]).

```
# dd if=kali-image.img of=/dev/something bs=512k
```

4. Inserisci la scheda SD/eMMC nel tuo dispositivo ARM.

5. Avvia il tuo dispositivo ARM ed effettua l'accesso *(utente "kali", password "kali").* Se non hai uno schermo collegato, dovrai scoprire l'indirizzo IP assegnato tramite DHCP e connetterti a tale indirizzo tramite SSH. Alcuni server DHCP dispongono di strumenti o interfacce web per visualizzare i lease correnti. Se non hai questa opzione, utilizza uno sniffer per cercare il traffico relativo ai lease DHCP oppure esegui una scansione ICMP/ ARP della rete locale.

6. Modificate la password utente predefinita e generate nuove chiavi host SSH, soprattutto se il dispositivo sarà permanentemente connesso a una rete pubblica! Questi passaggi sono relativamente semplici, consultate la sezione "Generazione di nuove chiavi host SSH " [pagina 115].

7. Goditi il tuo nuovo dispositivo ARM con Kali Linux!

| | |
|---|---|
| **Casi speciali e altro ancora Documentazione dettagliata** | Queste istruzioni sono generiche e, sebbene funzionino per la maggior parte dei dispositivi, esistono sempre delle eccezioni. Ad esempio, i Chromebook richiedono la modalità sviluppatore e altri dispositivi richiedono la pressione di un tasto specifico per l'avvio da supporti esterni.<br>Poiché i dispositivi ARM vengono aggiunti con una certa frequenza e le loro specifiche sono estremamente dinamiche, non tratteremo qui le istruzioni di installazione specifiche per i vari dispositivi ARM. In alternativa, consultare la sezione dedicata "Kali su ARM" del sito web della documentazione di Kali per informazioni su ciascun dispositivo ARM supportato da Offensive Security:<br>ÿ https://www.kali.org/docs/arm/ |

## 4.5. Risoluzione dei problemi di installazione

Il programma di installazione è piuttosto affidabile, ma potresti riscontrare bug o problemi esterni come: problemi di rete, mirror non funzionanti e spazio su disco insufficiente. Per questo motivo, è molto utile essere in grado di risolvere i problemi che si presentano durante il processo di installazione.

Quando l'installazione fallisce, verrà visualizzata una schermata piuttosto inutile come quella mostrata nella Figura 4.26, "Fase di installazione non riuscita" [pagina 100].

Machine Translated by Google

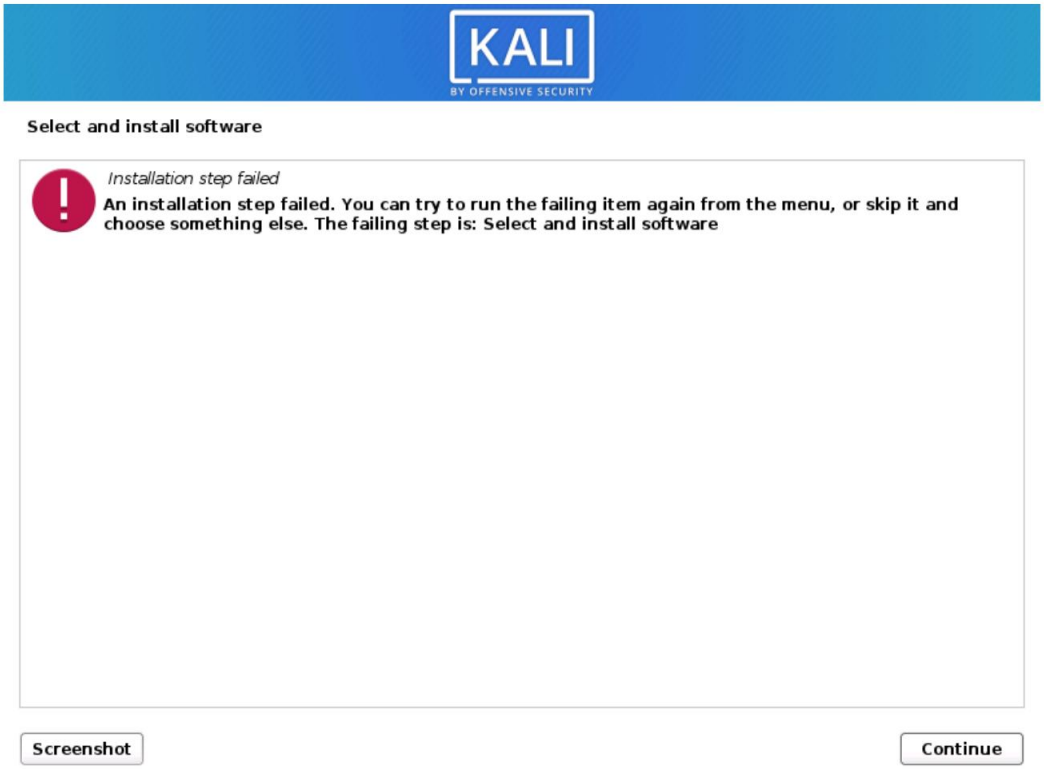



**Figura 4.26** Fase di installazione non riuscita

A questo punto, è utile sapere che il programma di installazione utilizza più console virtuali: la schermata principale che vedete è in esecuzione sulla quinta console (per il programma di installazione grafico, CTRL+ALT+F5) o sulla prima console (per il classico programma di installazione in modalità testuale, CTRL+ALT+F1). In entrambi i casi, la quarta console (CTRL+ALT+F4) visualizza i log di ciò che sta accadendo e di solito è possibile visualizzare lì un messaggio di errore più utile, come quello nella Figura 4.27, "Schermata di log del programma di installazione" [pagina 101], che indica che il programma di installazione ha esaurito lo spazio su disco.

Machine Translated by Google

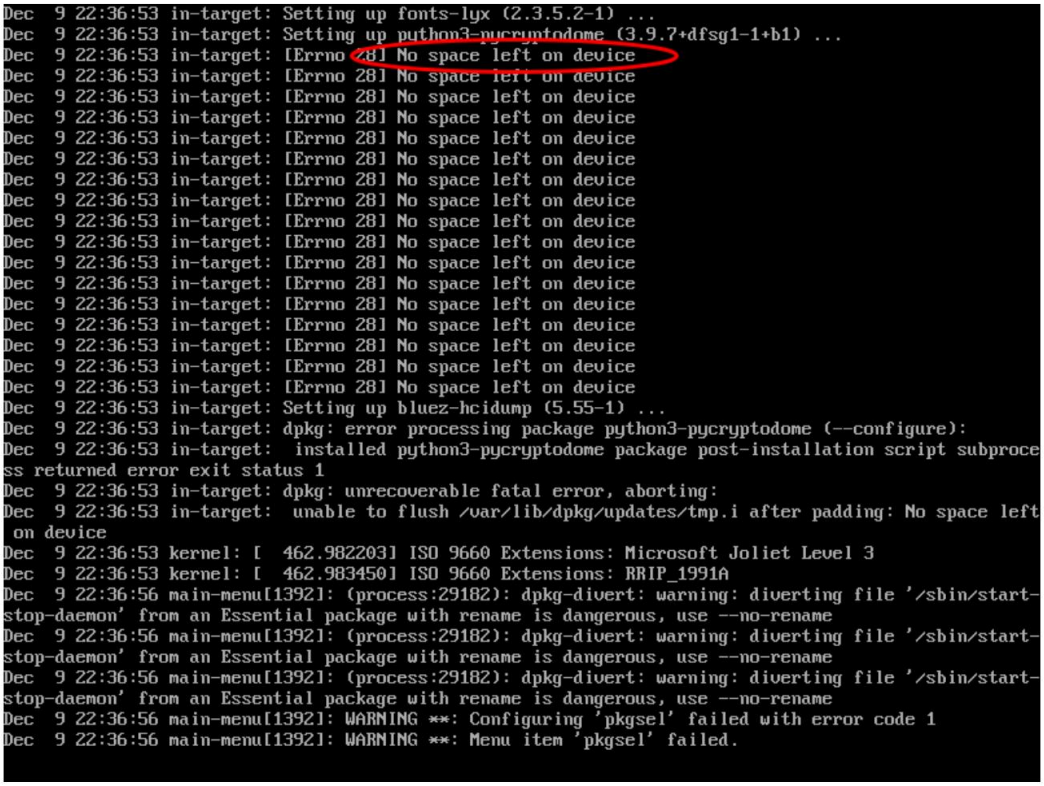



**Figura 4.27** La schermata di registro del programma di installazione

La seconda e la terza console (rispettivamente CTRL+ALT+F2 e CTRL+ALT+F3) ospitano shell che è possibile utilizzare per analizzare la situazione corrente in modo più dettagliato. La maggior parte degli strumenti da riga di comando sono forniti da BusyBox, quindi il set di funzionalità è piuttosto limitato, ma è sufficiente per risolvere la maggior parte dei problemi che è probabile incontrare.

| | |
|---|---|
| **Cosa si può fare nel Shell di installazione** | È possibile ispezionare e modificare il database debconf con debconf-get e debconf-set. Questi comandi sono particolarmente utili per testare i valori preimpostati. ues.<br><br>È possibile esaminare qualsiasi file (come il registro completo dell'installazione disponibile in / var/log/syslog) con cat o less. È possibile modificare qualsiasi file con nano, inclusi tutti i file installati sul sistema. Il file system root verrà montato su /target una volta completata la fase di partizionamento del processo di installazione.<br><br>Una volta configurato l'accesso alla rete, è possibile utilizzare wget e nc (netcat) per recuperare ed esportare dati tramite la rete. |

Una volta cliccato su Continua dalla schermata principale di errore del programma di installazione (Figura 4.26, "Fase di installazione non riuscita" [pagina 100]), verrai reindirizzato a una schermata che normalmente non vedrai mai (la schermata principale

Machine Translated by Google

Il menu mostrato nella Figura 4.28, "Menu principale del programma di installazione" [pagina 102], consente di avviare una fase di installazione dopo l'altra. Se sei riuscito a risolvere il problema tramite l'accesso alla shell (complimenti!), puoi riprovare la fase che ha fallito.

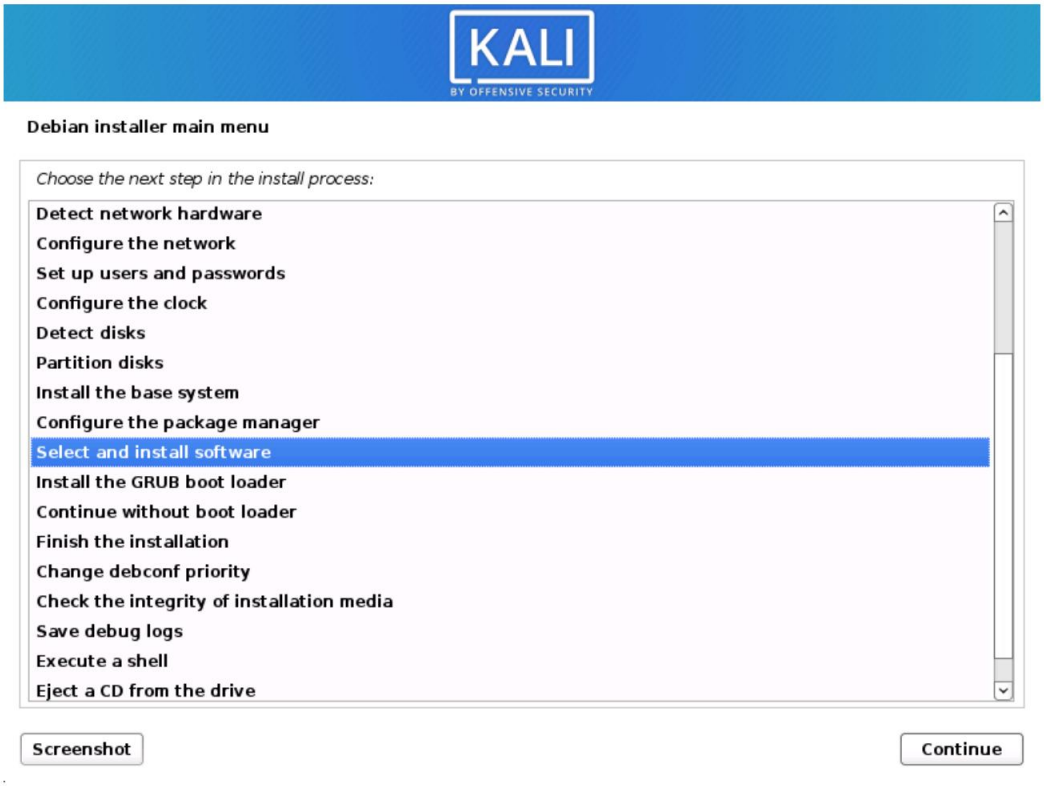



**Figura 4.28** Menu principale del programma di installazione

Se non riesci a risolvere il problema, potresti voler inviare una segnalazione di bug. La segnalazione deve includere i log del programma di installazione, che puoi recuperare tramite la funzione "Salva log di debug" del menu principale. Questa funzione offre diversi modi per esportare i log, come mostrato nella Figura 4.29, "Salva log di debug (1/2)" [pagina 103].

Machine Translated by Google

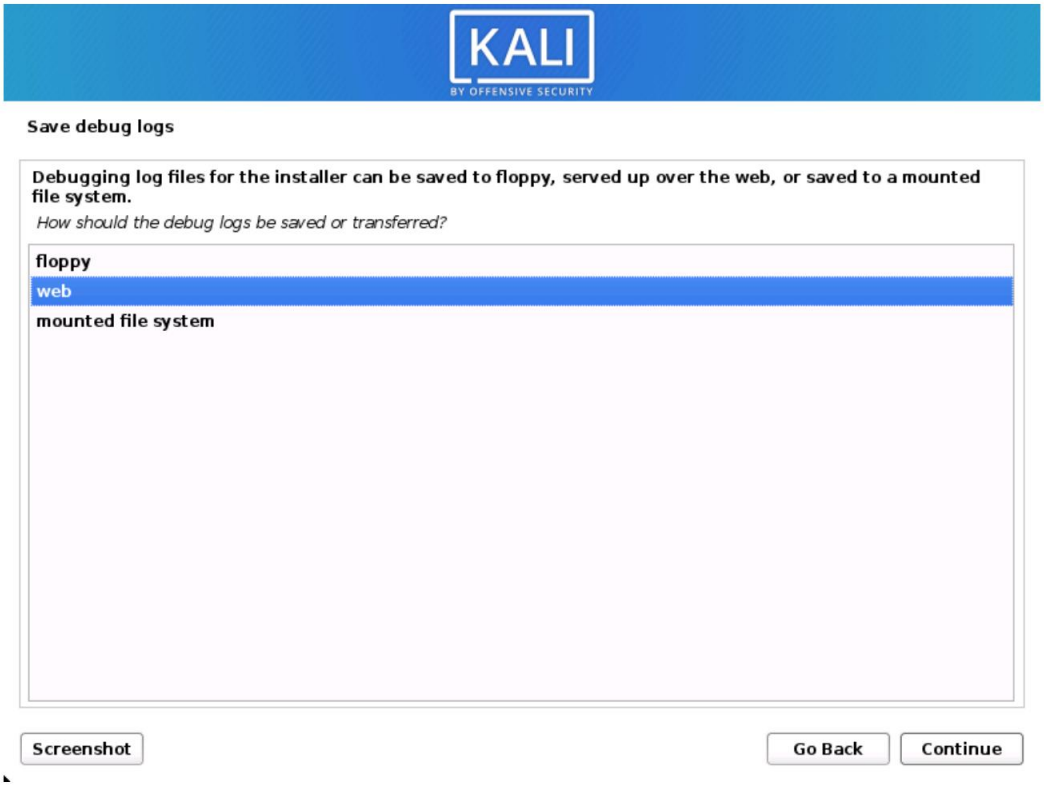



**Figura 4.29** Salvataggio dei log di debug (1/2)

Il metodo più conveniente, e quello che consigliamo, è lasciare che il programma di installazione avvii un web server che ospita i file di log (Figura 4.30, "Salva log di debug (2/2)" [pagina 104]). È quindi possibile avviare Apri un browser da un altro computer sulla stessa rete e scarica tutti i file di registro e le schermate che hai scattato utilizzando il pulsante Screenshot disponibile su ogni schermata.

Machine Translated by Google

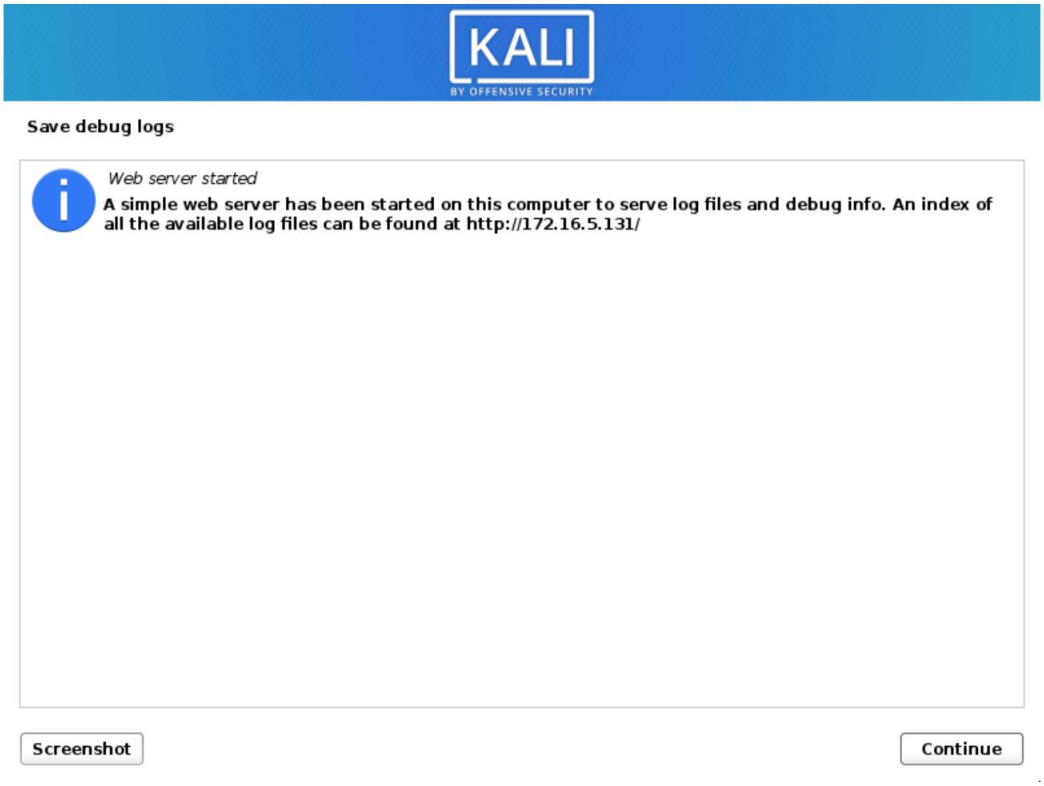



**Figura 4.30** Salvataggio dei log di debug (2/2)

## 4.6. Riepilogo

In questo capitolo ci siamo concentrati sul processo di installazione di Kali Linux. Abbiamo discusso i requisiti minimi di installazione di Kali Linux, il processo di installazione per file system standard e completamente crittografati, il preseeding, che consente installazioni automatiche, e come installare Kali Linux su vari architetture ARM. dispositivi e cosa fare nel raro caso di un errore di installazione.

Suggerimenti riassuntivi:

- I requisiti di installazione per Kali Linux variano da un server SSH di base senza desktop, da un minimo di 128 MB di RAM (512 MB consigliati) e 2 GB di spazio su disco, fino al metapackage *kali-linux-default* di fascia alta , con almeno 2048 MB di RAM e 20 GB di spazio su disco. Inoltre, Il tuo computer deve avere una CPU supportata da almeno una delle architetture amd64, i386 o arm64.

- Kali può essere facilmente installato come sistema operativo principale, insieme ad altri sistemi operativi tramite partizionamento e modifica del boot loader, oppure come macchina virtuale.

Machine Translated by Google

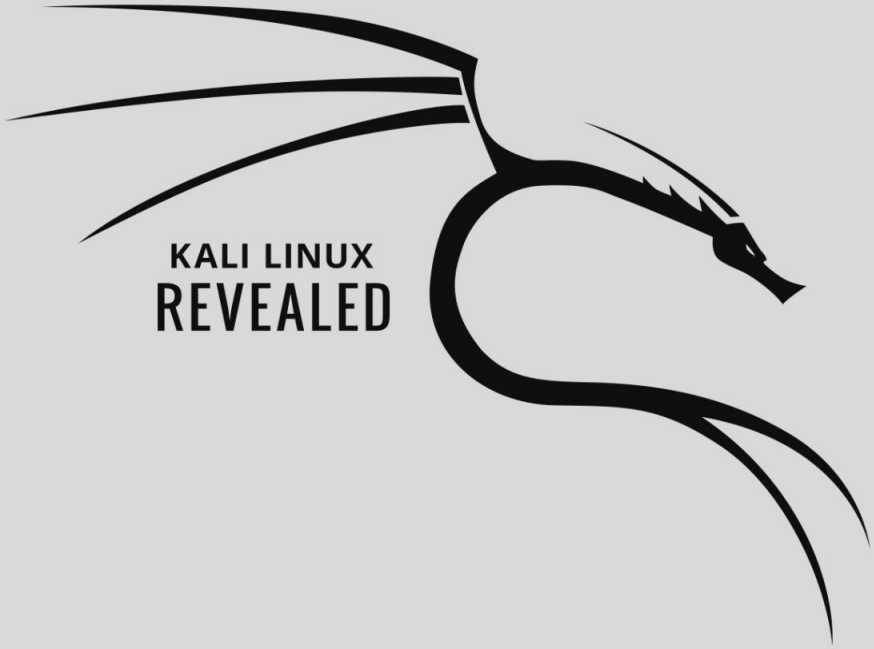
- Per garantire la riservatezza dei tuoi dati, puoi configurare partizioni crittografate. In questo modo i tuoi dati saranno protetti in caso di smarrimento o furto del tuo laptop o disco rigido.
- L'installazione può essere automatizzata anche tramite la preinstallazione di debconf, una funzione che consente di fornire risposte automatiche alle domande di installazione.
- Un file preseed è un file di testo semplice in cui ogni riga contiene la risposta a una domanda di Debconf. Ogni riga è suddivisa in quattro campi separati da spazi (spazi o tabulazioni). È possibile preimpostare le risposte al programma di installazione tramite i parametri di avvio, con un file preseed in initrd, con un file preseed sul supporto di avvio o con un file preseed dalla rete.
- Kali Linux funziona su una vasta gamma di dispositivi basati su ARM, come laptop, computer embedded e schede di sviluppo. L'installazione su ARM è piuttosto semplice. Scarica l'immagine appropriata, copiala su una scheda SD, un'unità USB o un modulo controller multimediale embedded (eMMC), collegalo, avvia il dispositivo ARM, individua il dispositivo sulla rete, accedi e modifica la password SSH e le chiavi host SSH.
- È possibile eseguire il debug delle installazioni non riuscite tramite console virtuali (accessibili con i tasti CTRL+ALT e i tasti funzione), i comandi debconf-get e debconf-set , leggendo il file di log /var/log/syslog oppure inviando una segnalazione di bug con i file di log recuperati tramite la funzione "Salva log di debug" del programma di installazione.

Ora che abbiamo parlato dei fondamenti di Linux e dell'installazione di Kali Linux, passiamo alla configurazione, in modo che possiate iniziare a personalizzare Kali in base alle vostre esigenze.

Machine Translated by Google

**Parole chiave**

**Rete**
**Utenti e gruppi**
**Fibre**
**Apache**
**PostgreSQL**
**SSH**



Machine Translated by Google

Capitolo

# 5

# Configurazione di Kali Linux

Contenuto

Configurazione della rete 108
Gestione degli utenti e dei gruppi Unix 112
Configurazione dei servizi 114
Servizi di gestione 121
Riepilogo 123

Machine Translated by Google

In questo capitolo, esamineremo i vari modi in cui è possibile configurare Kali Linux. Innanzitutto, nella sezione 5.1, "Configurazione della rete" [pagina 108], mostreremo come configurare la rete.
impostazioni tramite un ambiente grafico e la riga di comando. Nella sezione 5.2, "Gestione di Unix
Utenti e gruppi Unix" [pagina 112], parleremo di utenti e gruppi, mostrandoti come creare e modificare account utente, impostare password, disabilitare account e gestire gruppi. Infine,
discuteremo dei servizi nella sezione 5.3, "Configurazione dei servizi" [pagina 114] e spiegheremo come configurarli e mantenere i servizi generici e concentrarsi anche su tre servizi molto importanti e specifici: SSH, PostgreSQL e Apache.

## 5.1. Configurazione della rete

### 5.1.1. Sul desktop con NetworkManager

In una tipica installazione desktop, *NetworkManager* sarà già installato e potrà essere controllato e configurato tramite le impostazioni di sistema di Xfce e tramite il menu in alto a destra, come mostrato.
nella Figura 5.1, "Schermata di configurazione della rete" [pagina 108].

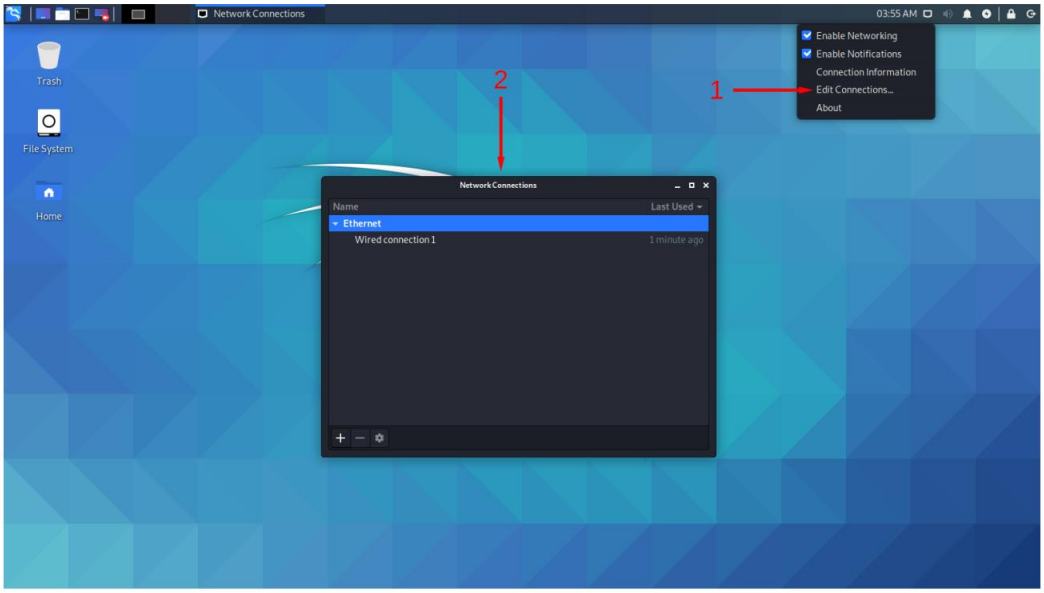



**Figura 5.1** Schermata di configurazione di rete.

La configurazione di rete predefinita si basa sul DHCP per ottenere un indirizzo IP, un server DNS e un gateway, ma è possibile utilizzare l'icona a forma di ingranaggio nell'angolo in basso a sinistra per modificare la configurazione in molti modi. (ad esempio: impostare l'indirizzo MAC, passare a una configurazione statica, abilitare o disabilitare IPv6 e aggiungere percorsi aggiuntivi). È possibile creare profili per salvare più configurazioni di rete cablata e facilmente

Machine Translated by Google

Passa da una modalità all'altra. Per le reti wireless, le impostazioni sono automaticamente associate al loro identificativo pubblico (SSID).

NetworkManager gestisce anche le connessioni tramite banda larga mobile (Wireless Wide Area Network WWAN) e tramite modem che utilizzano il protocollo point-to-point su Ethernet (PPPoE). Infine, offre l'integrazione con molti tipi di reti private virtuali (VPN) tramite plugin dedicati: SSH, OpenVPN, Cisco VPNC, PPTP, Strongswan. Dai un'occhiata ai pacchetti *network-manager-* ;* la maggior parte di essi non è installata di default.

## 5.1.2. Dalla riga di comando con Ifupdown

In alternativa, se si preferisce non utilizzare (o non si ha accesso a) un desktop grafico, è possibile configurare la rete con il pacchetto *ifupdown* già installato , che include gli strumenti ifup e ifdown . Questi strumenti leggono le definizioni dal file di configurazione /etc/network/interfaces e sono il cuore dello script di inizializzazione /etc/init.d/networking che configura la rete all'avvio del sistema.

**Utilizzo di sudo per accedere Privilegi amministrativi**

Il comando sudo (super user do) consente agli utenti privilegiati di eseguire comandi con permessi amministrativi. Ciò garantisce l'accesso completo a elementi che potrebbero essere riservati al solo utente root, come i programmi in /sbin/ o l'accesso alle opzioni di rete utili per i comuni strumenti di penetration testing.

Il comando accetta un argomento, ovvero il comando successivo che verrà eseguito con privilegi amministrativi. Un caso d'uso utile quando si ha a che fare con i servizi è quello di elevare i privilegi all'account utente root. Per elevare i privilegi all'utente root, useremo il comando su (utente sostitutivo) per creare una shell con i privilegi dell'utente root. Il comando utente sostitutivo accetta come argomento un account utente. Inoltre, il comando su ha un flag utile (--login, -l o -) per utilizzare l'ambiente di login dell'utente sostituito. Diversi comandi nel capitolo seguente richiedono l'uso di sudo, pertanto eleveremo i privilegi all'utente root per eseguire questi comandi senza problemi.

```
$ sudo su --login [sudo]
 password per kali: root@kali:~#
```

Ogni dispositivo di rete gestito da *ifupdown* può essere deconfigurato in qualsiasi momento con il comando ifdown network-device. Successivamente, è possibile modificare il file /etc/network/interfaces e riattivare la rete (con la nuova configurazione) con il comando ifup network-device.

Diamo un'occhiata a cosa possiamo inserire nel file di configurazione di ifupdown. Ci sono due direttive principali: `auto network-device`, che *indica a ifupdown* di configurare automaticamente l'interfaccia di rete non appena disponibile, e `iface network-device inet/inet6 type` per configurare una determinata interfaccia. Ad esempio, una semplice configurazione DHCP si presenta così:

```
auto lo
```

Machine Translated by Google

```
iface lo inet loopback

auto eth0
interfaccia eth0 inet dhcp
```

Si noti che la configurazione speciale per il dispositivo loopback deve essere sempre presente in questo file. Per configurare un indirizzo IP fisso, è necessario fornire maggiori dettagli, come l'indirizzo IP, la rete e l'indirizzo IP del gateway:

```
auto eth0 iface
eth0 inet static address 192.168.0.3
    netmask 255.255.255.0
    broadcast 192.168.0.255 network
    192.168.0.0 gateway 192.168.0.1
```

Per le interfacce wireless, è necessario disporre del pacchetto *wpasupplicant* (incluso in Kali per impostazione predefinita), che fornisce numerose opzioni wpa-* utilizzabili in /etc/network/interfaces. Consultare il file /usr/share/doc/wpasupplicant/README.Debian.gz per esempi e spiegazioni. Le opzioni più comuni sono wpa-ssid (che definisce il nome della rete wireless a cui connettersi) e wpa-psk (che definisce la passphrase o la chiave di protezione della rete).

```
iface wlan0 inet dhcp wpa-ssid
    MyNetWork wpa-psk
    plaintextsecret
```

### 5.1.3. Dalla riga di comando con systemd-networkd

Sebbene *ifupdown* sia lo strumento storico utilizzato da Debian e Kali, e sebbene sia ancora quello predefinito per le installazioni minimali, esiste uno strumento più recente che vale la pena considerare: *systemd-networkd.* La sua integrazione con il sistema di init *systemd* lo rende una scelta molto interessante. Non è specifico per le distribuzioni basate su Debian (a differenza di *ifupdown)* ed è stato progettato per essere molto piccolo, efficiente e relativamente facile da configurare se si conosce la sintassi dei file di unità di systemd. Questa è una scelta particolarmente interessante se si considera *NetworkManager* pesante e difficile da configurare.

È possibile configurare systemd-networkd posizionando i file .network nella directory /etc/systemd/network/ . In alternativa, è possibile utilizzare /lib/systemd/network/ per i file impacchettati o /run/systemd/network/ per i file generati in fase di esecuzione. Il formato di questi file è documentato in systemd.network(5) (vedere la sezione 6.1.1, "Pagine del manuale" [pagina 128]). La sezione [Match] indica le interfacce di rete a cui si applica la configurazione. È possibile specificare l'interfaccia in diversi modi, tra cui tramite indirizzo MAC (Media Access Control) o tipo di dispositivo. La sezione [Network] definisce la configurazione di rete.

Machine Translated by Google

**Esempio 5.1** Configurazione statica in /etc/systemd/network/50-static.network

```
[Incontro]
Nome=enp2s0

[Rete]
Indirizzo=192.168.0.15/24
Gateway=192.168.0.1
DNS=8.8.8.8
```

**Esempio 5.2** Configurazione basata su DHCP in /etc/systemd/network/80-dhcp.network

```
[Incontro]
Nome=en*

[Rete]
DHCP=sì
```

Tieni presente che system-networkd è disabilitato per impostazione predefinita, quindi se vuoi usarlo devi abilitarlo. Dipende inoltre da systemd-resolved per la corretta integrazione della risoluzione DNS, il che a sua volta richiede la sostituzione di /etc/resolv.conf con un collegamento simbolico a /run/systemd/resolve/resolv.conf, gestito da systemd-resolved.

```
# systemctl enable systemd-networkd #
systemctl enable systemd-resolved #
systemctl start systemd-networkd #
systemctl start systemd-resolved # ln -sf /
run/systemd/resolve/resolv.conf /etc/resolv.conf
```

Sebbene systemd-networkd presenti alcune limitazioni, come la mancanza di supporto integrato per le reti wireless, è possibile fare affidamento su una configurazione wpa_supplicant esterna preesistente per il supporto wireless. Tuttavia, è particolarmente utile nei container e nelle macchine virtuali ed è stato originariamente sviluppato per ambienti in cui la configurazione di rete di un container dipendeva dalla configurazione di rete del suo host. In questo scenario, systemd-networkd semplifica la gestione di entrambi i lati in modo coerente, supportando al contempo tutti i tipi di dispositivi di rete virtuali che potrebbero essere necessari in questo tipo di scenario (vedere systemd.netdev(5) nella sezione 6.1.1, "Pagine del manuale" [pagina 128]).

Machine Translated by Google

## 5.2. Gestione degli utenti e dei gruppi Unix

Il database degli utenti e dei gruppi Unix è costituito dai file di testo /etc/passwd (elenco degli utenti), /etc/shadow (password crittografate degli utenti), /etc/group (elenco dei gruppi) e /etc/gshadow (password crittografate dei gruppi). I loro formati sono documentati rispettivamente in passwd(5), shadow(5), group(5) e gshadow(5) (vedere la sezione 6.1.1, "Pagine del manuale" [pagina 128]). Sebbene questi file possano essere modificati manualmente con strumenti come vipw e vigr, esistono strumenti di livello superiore per eseguire le operazioni più comuni.

**Utilizzo di getent per consultare il database degli utenti**

Il comando getent (recupera voci) controlla i database di sistema (inclusi quelli di utenti e gruppi) utilizzando le apposite funzioni di libreria, che a loro volta richiamano i moduli del name service switch (NSS) configurati nel file /etc/nsswitch.conf . Il comando accetta uno o due argomenti: il nome del database da controllare e un'eventuale chiave di ricerca. Pertanto, il comando getent passwd kaliuser1 restituirà le informazioni dal database degli utenti relative all'utente kaliuser1.

```
# getent passwd kaliuser1
kaliuser1:x:1001:1001:Utente Kali
        ÿ ,4444,123-867-5309,321-867-5309:/home/kaliuser1:/bin/
        ÿ bash
```

### 5.2.1. Creazione di account utente

Sebbene Kali venga solitamente eseguito con privilegi di amministratore (sudo), potrebbe essere necessario creare account utente senza privilegi per diverse ragioni, soprattutto se si utilizza Kali come sistema operativo principale. Il metodo più comune per aggiungere un utente è tramite il comando `adduser` , che richiede come argomento il nome utente del nuovo utente da creare.

Il comando adduser pone alcune domande prima di creare l'account, ma il suo utilizzo è piuttosto semplice. Il suo file di configurazione, /etc/adduser.conf, include molte impostazioni interessanti.
È possibile, ad esempio, definire l'intervallo di identificatori utente (UID) utilizzabili, stabilire se gli utenti appartengono o meno a un gruppo comune, definire shell predefinite e altro ancora.

La creazione di un account attiva il popolamento della directory home dell'utente con il contenuto del template /etc/skel/ . Questo fornisce all'utente una serie di directory standard e file di configurazione.

In alcuni casi, sarà utile aggiungere un utente a un gruppo (diverso dal suo gruppo principale predefinito) per concedergli autorizzazioni aggiuntive. Ad esempio, un utente incluso nel gruppo *docker* ha pieno accesso ai comandi e ai servizi docker. Questo può essere ottenuto con un comando come

aggiungi utente gruppo utenti.

Machine Translated by Google

### 5.2.2. Modifica di un account o di una password esistenti

I seguenti comandi consentono di modificare le informazioni memorizzate in campi specifici dei database utente:

- passwd—consente a un utente normale di cambiare la propria password, che a sua volta aggiorna il file /etc/ file ombra .
- chfn—(CHange Full Name), riservato al superutente (root), modifica il GECOS o "gen- campo "informazioni generali".
- chsh—(CAMBIA SHell) cambia la shell di login dell'utente. Tuttavia, le opzioni disponibili saranno limitate a quelle elencate in /etc/shells; l'amministratore, d'altra parte, non è vincolato da questa restrizione e può impostare la shell su qualsiasi programma scelto. • chage—(CAMBIA AGE) consente

all'amministratore di modificare le impostazioni di scadenza della password passando il nome utente come argomento o elencando le impostazioni correnti utilizzando l' opzione utente -l .
In alternativa, è possibile forzare la scadenza di una password utilizzando il comando passwd -e user , che obbliga l'utente a cambiare la password al successivo accesso.

### 5.2.3. Disattivazione di un account

Potrebbe capitare di dover disabilitare un account (bloccare un utente) per motivi disciplinari, a fini di indagine o semplicemente in caso di assenza prolungata o definitiva dell'utente. Un account disabilitato significa che l'utente non può accedere al sistema o effettuare il login. L'account rimane attivo sul computer e nessun file o dato viene eliminato; è semplicemente inaccessibile. Questa operazione si effettua utilizzando il comando `passwd -l user` (blocca). La riattivazione dell'account avviene in modo simile, con l' opzione `-u` (sblocca).

### 5.2.4. Gestione dei gruppi Unix

I comandi addgroup e delgroup aggiungono o eliminano un gruppo, rispettivamente. Il comando groupmod modifica le informazioni di un gruppo (il suo gid o identificatore). Il comando gpasswdgroup cambia la password del gruppo, mentre il comando gpasswd -r group lo elimina.

**Lavorando con diversi Gruppi**

Ogni utente può appartenere a più gruppi. Il gruppo principale di un utente viene creato, per impostazione predefinita, durante la configurazione iniziale. Di default, ogni file creato da un utente appartiene sia all'utente stesso che al suo gruppo principale. Questa situazione non è sempre desiderabile; ad esempio, quando l'utente deve lavorare in una directory condivisa da un gruppo diverso dal suo gruppo principale. In questo caso, l'utente deve cambiare gruppo utilizzando uno dei seguenti comandi: `newgrp`, che avvia una nuova shell, oppure `sg`, che esegue semplicemente un comando utilizzando il gruppo alternativo specificato. Questi comandi consentono inoltre all'utente di unirsi a un gruppo a cui non appartiene attualmente. Se il gruppo è protetto da password, l'utente dovrà inserire la password appropriata prima dell'esecuzione del comando.

Machine Translated by Google

In alternativa, l'utente può impostare il bit setgid sulla directory, il che fa sì che i file creati in quella directory appartengano automaticamente al gruppo corretto. Per maggiori dettagli, vedere il riquadro "setgid directory e sticky bit" [pagina 58].

Il comando id visualizza lo stato attuale di un utente, con il suo identificativo personale ( variabile uid), il gruppo principale corrente ( variabile gid) e l'elenco dei gruppi a cui appartiene ( variabile groups).

## 5.3. Configurazione dei servizi

In questa sezione esamineremo i servizi (a volte chiamati daemon), ovvero programmi che vengono eseguiti in background e svolgono diverse funzioni per il sistema. Inizieremo parlando dei file di configurazione e proseguiremo spiegando il funzionamento di alcuni servizi importanti (come SSH, PostgreSQL e Apache) e come possono essere configurati.

La politica di Kali Linux prevede la disabilitazione predefinita di tutti i servizi di rete, un comportamento diverso da quello di altri sistemi operativi Linux. Per maggiori informazioni, consultare la sezione 1.5, "Politiche di Kali Linux" [pagina 10].

### 5.3.1. Configurazione di un programma specifico

Quando si desidera configurare un pacchetto sconosciuto, è necessario procedere per fasi. Innanzitutto, è consigliabile leggere la documentazione fornita dal manutentore del pacchetto, ovvero il file /usr/share/doc/package/README.
Il file di configurazione di Debian è un buon punto di partenza. Questo file spesso contiene informazioni sul pacchetto, inclusi riferimenti ad altra documentazione. Leggerlo per primo vi farà risparmiare molto tempo e vi eviterà molta frustrazione, poiché spesso descrive in dettaglio gli errori più comuni e le soluzioni ai problemi più frequenti.

Successivamente, è consigliabile consultare la documentazione ufficiale del software. Fare riferimento alla sezione 6.1, "Fonti della documentazione" [pagina 128], per suggerimenti su come trovare diverse fonti di documentazione. Il comando `dpkg -L package` elenca i file inclusi nel pacchetto; in questo modo è possibile identificare rapidamente la documentazione disponibile (così come i file di configurazione, situati in `/etc/`). Inoltre, il comando `dpkg -s package` visualizza i metadati del pacchetto e mostra eventuali pacchetti consigliati o suggeriti; in questi pacchetti è possibile trovare la documentazione o magari un'utilità che semplificherà la configurazione del software.

Infine, i file di configurazione sono spesso auto-documentati da numerosi commenti esplicativi che descrivono in dettaglio i vari valori possibili per ogni impostazione di configurazione. In alcuni casi, è possibile avviare il software semplicemente rimuovendo il commento da una singola riga del file di configurazione. In altri casi, nella directory /usr/share/doc/package/examples/ sono disponibili esempi di file di configurazione che possono servire da base per il proprio file di configurazione.

Machine Translated by Google

### 5.3.2. Configurazione di SSH per gli accessi remoti

SSH consente di accedere da remoto a una macchina, trasferire file o eseguire comandi. È uno strumento (ssh) e un servizio (sshd) standard del settore per la connessione remota alle macchine.

Sebbene il pacchetto *openssh-server* sia installato di default, il servizio *SSH* è disabilitato e quindi non viene avviato all'avvio del sistema. È possibile avviare manualmente il servizio SSH con il comando `systemctl start ssh` oppure configurarlo per l'avvio automatico all'avvio del sistema con il comando `systemctl enable ssh`.

Il servizio SSH ha una configurazione predefinita relativamente sensata, ma date le sue potenti funzionalità e la sua natura delicata, è bene sapere cosa si può fare con il suo file di configurazione, /etc/ssh/sshd_config. Tutte le opzioni sono documentate in sshd_config(5) (vedere la sezione 6.1.1, "Pagine del manuale" [pagina 128]).

La configurazione predefinita consente l'accesso tramite password. Se non si desidera questa opzione, è possibile disabilitarla impostando PasswordAuthentication su no. In tal caso, sarà necessario generare una chiave SSH. Il servizio SSH è in ascolto di default sulla porta 22, ma è possibile modificarla tramite la direttiva Port .

Per applicare le nuove impostazioni, è necessario eseguire il comando systemctl reload ssh.

**Generazione di un nuovo host SSH Chiavi**

Ogni server SSH possiede le proprie chiavi crittografiche, denominate "chiavi host SSH", memorizzate in /etc/ssh/ssh_host_*. Per garantire la riservatezza, queste chiavi devono essere mantenute private e non devono essere condivise tra più macchine.

Quando si installa il sistema copiando un'immagine disco completa (anziché utilizzare debian-installer come nel caso delle immagini ARM), l'immagine potrebbe contenere chiavi host SSH pregenerate che è necessario sostituire con chiavi appena generate. L'immagine probabilmente include anche una password utente predefinita che si desidera reimpostare contemporaneamente. È possibile eseguire tutte queste operazioni con i seguenti comandi:

```
# password

[...] #
rm /etc/ssh/ssh_host_* # dpkg-
reconfigure openssh-server # systemct
restart ssh
```

### 5.3.3. Configurazione dei database PostgreSQL

PostgreSQL è un server di database. Raramente è utile da solo, ma viene utilizzato da molti altri servizi per archiviare dati. Questi servizi generalmente accedono al server di database tramite la rete e di solito richiedono credenziali di autenticazione per potersi connettere. La configurazione di questi servizi richiede quindi la creazione di database PostgreSQL e account utente con privilegi appropriati sul database.

Machine Translated by Google

Per poterlo fare, dobbiamo avviare il servizio, quindi avviamolo con systemctl start postgresql.

**Supporto per più versioni di PostgreSQL**

Il pacchetto PostgreSQL consente l'installazione simultanea di più versioni del server di database. È inoltre possibile gestire più cluster (un cluster è un insieme di database gestiti dallo stesso postmaster). Per ottenere questo risultato, i file di configurazione vengono memorizzati in /etc/postgresql/version/cluster-name/.

Affinché i cluster possano funzionare in parallelo, a ciascun nuovo cluster viene assegnato il primo numero di porta disponibile (di solito 5433 per il secondo cluster). Il file postgresql.service è un file vuoto, il che semplifica l'esecuzione simultanea su tutti i cluster, poiché ogni cluster ha la propria unità (postgresql@version-cluster.service).

## Tipo di connessione e autenticazione del client

Per impostazione predefinita, PostgreSQL si mette in ascolto delle connessioni in entrata in due modi: sulla porta TCP 5432 dell'interfaccia local-host e sul socket basato su file /var/run/postgresql/.s.PGSQL.5432. Questa configurazione può essere modificata nel file postgresql.conf tramite diverse direttive: listen_addresses per gli indirizzi su cui rimanere in ascolto, port per la porta TCP e unix_socket_directories per definire la directory in cui vengono creati i socket basati su file.

A seconda del metodo di connessione, i client vengono autenticati in modi diversi. Il file di configurazione pg_hba.conf definisce chi è autorizzato a connettersi a ciascun socket e come avviene l'autenticazione. Per impostazione predefinita, le connessioni tramite socket basato su file utilizzano l'account utente Unix come nome utente di PostgreSQL e si presume che non sia richiesta ulteriore autenticazione. Sulla connessione TCP, PostgreSQL richiede all'utente di autenticarsi con un nome utente e una password (non un nome utente/password Unix, bensì una gestita da PostgreSQL stesso).

L' utente postgres è speciale e dispone di pieni privilegi amministrativi su tutti i database. Useremo questa identità per creare nuovi utenti e nuovi database.

## Creazione di utenti e database

Il comando createuser aggiunge un nuovo utente e dropuser lo rimuove. Allo stesso modo, il comando createdb aggiunge un nuovo database e dropdb lo rimuove. Ciascuno di questi comandi ha una propria pagina di manuale, ma qui ne analizzeremo alcune opzioni. Ogni comando agisce sul cluster predefinito (in esecuzione sulla porta 5432), ma è possibile passare l'opzione --port=port per modificare utenti e database di un cluster alternativo.

Questi comandi devono connettersi al server PostgreSQL per svolgere il loro compito e devono essere autenticati come un utente con privilegi sufficienti per poter eseguire l'operazione specificata. Il modo più semplice per ottenere questo risultato è utilizzare l' account Unix postgres e connettersi tramite il socket basato su file:

```
# su - postgres
```

Machine Translated by Google

```
postgres@kali:~$ createuser -P king_phisher
Inserisci la password per il nuovo ruolo:
Inseriscilo di nuovo:
postgres@kali:~$ createdb -T template0 -E UTF-8 -O king_phisher king_phisher postgres@kali:~$ exit
```

Nell'esempio precedente, l' opzione -P chiede a createuser di richiedere una password una volta creato il nuovo utente king_phisher . Analizzando il comando createdb , l'opzione -O definisce l'utente proprietario del nuovo database (che avrà quindi pieni diritti per creare tabelle, concedere autorizzazioni e così via). Vogliamo inoltre poter utilizzare stringhe Unicode, quindi aggiungiamo l' opzione -E UTF-8 per impostare la codifica, che a sua volta richiede l'utilizzo dell'opzione -T per selezionare un altro modello di database.

Ora possiamo verificare se riusciamo a connetterci al database tramite il socket in ascolto su localhost (-h localhost) come utente king_phisher (-U king_phisher): # **psql -h localhost -U**

```
king_phisher king_phisher Password for user king_phisher: psql
(9.5.2)

Connessione SSL (protocollo: TLSv1.2, cifratura: ECDHE-RSA-AES256-GCM-SHA384, bit: 256,
        ÿ compressione: disattivata)
Digita "help" per ricevere assistenza.

king_phisher=>
```

Come potete vedere, la connessione è andata a buon fine.

## Gestione dei cluster PostgreSQL

Innanzitutto, è opportuno notare che il concetto di "cluster PostgreSQL" è un'aggiunta specifica di Debian. e che non troverete alcun riferimento a questo termine nella documentazione ufficiale di PostgreSQL2 Dal punto . Da di vista degli strumenti PostgreSQL, un cluster di questo tipo non è altro che un'istanza di un server di database in esecuzione su una porta specifica.

Detto questo, il pacchetto *postgresql-common* di Debian fornisce diversi strumenti per gestire tali cluster: pg_createcluster, pg_dropcluster, pg_ctlcluster, pg_upgradecluster, pg_renamecluster e pg_lsclusters. Non tratteremo tutti questi strumenti in questa sede, ma è possibile consultare le rispettive pagine di manuale per ulteriori informazioni.

È importante sapere che quando si installa una nuova versione principale di PostgreSQL sul sistema, viene creato un nuovo cluster che verrà eseguito sulla porta successiva (di solito la 5433) e si continuerà a utilizzare la vecchia versione finché non si migrano i database dal vecchio cluster a quello nuovo.

È possibile recuperare un elenco di tutti i cluster e il loro stato con pg_lsclusters. Ancora più importante, è possibile automatizzare la migrazione del cluster all'ultima versione di PostgreSQL con

[1] https://wiki.debian.org/PostgreSql
[2] https://www.postgresql.org/docs/

Machine Translated by Google

pg_upgradecluster nome-cluster-vecchia-versione. Affinché questa operazione abbia successo, potrebbe essere necessario rimuovere prima il cluster (vuoto) creato per la nuova versione (con pg_dropcluster nome-cluster-nuova-versione). Il vecchio cluster non viene eliminato durante il processo, ma non verrà nemmeno avviato automaticamente. È possibile eliminarlo dopo aver verificato che il cluster aggiornato funzioni correttamente.

### 5.3.4. Configurazione di Apache

Una tipica installazione di Kali Linux include il server web Apache, fornito dal pacchetto *apache2 .* Essendo un servizio di rete, è disabilitato per impostazione predefinita. È possibile avviarlo manualmente con il comando `systemctl start apache2`.

Con la crescente diffusione di applicazioni distribuite come applicazioni web, è importante avere una certa conoscenza di Apache per poterle ospitare, sia per uso locale che per renderle disponibili in rete.

Apache è un server modulare e molte funzionalità sono implementate da moduli esterni che il programma principale carica durante la sua inizializzazione. La configurazione predefinita abilita solo i moduli più comuni, ma è facile abilitare nuovi moduli eseguendo il modulo a2enmod. Per disabilitare un modulo, utilizzare il modulo a2dismod . Questi programmi, in realtà, creano (o eliminano) solo collegamenti simbolici in /etc/apache2/mods-enabled/, che puntano ai file effettivi (memorizzati in /etc/apache2/mods-available/).

Sono disponibili molti moduli, ma due meritano di essere presi in considerazione inizialmente: PHP e SSL (utilizzato per TLS). Le applicazioni web scritte in PHP vengono eseguite dal server web Apache con l'aiuto del modulo dedicato fornito dal pacchetto *libapache-mod-php ,* la cui installazione abilita automaticamente il modulo.

Apache 2.4 include di default il modulo SSL necessario per il protocollo HTTPS (Hypertext Transfer Protocol Secure). È necessario prima abilitarlo con il comando `a2enmod ssl`, quindi aggiungere le direttive richieste ai file di configurazione. Un esempio di configurazione è disponibile in `/etc/apache2/sites-available/default-ssl.conf`. Consultare la pagina https://httpd.apache.org/docs/2.4/mod/mod_ssl.html . per ulteriori informazioni.

L'elenco completo dei moduli standard di Apache è disponibile online all'indirizzo https://httpd.apache.org/docs/2.4/mod/index.html .

Con la sua configurazione predefinita, il server web è in ascolto sulla porta 80 (come configurato in /etc/apache2/ports.conf) e serve le pagine dalla directory /var/www/html/ per impostazione predefinita (come configurato in /etc/apache2/sites-enabled/000-default.conf).

#### Configurazione degli host virtuali

Un host virtuale è un'identità aggiuntiva per il server web. Lo stesso processo Apache può servire più siti web (ad esempio www.kali.org e www.offensive-security.com) perché le richieste HTTP incorporano

Machine Translated by Google

sia il nome del sito web richiesto che la parte locale dell'URL (questa funzionalità è nota come *host virtuali basati sul nome).*

La configurazione predefinita di Apache 2 abilita gli host virtuali basati sul nome. Inoltre, un host virtuale predefinito è definito nel file /etc/apache2/sites-enabled/000-default.conf ; questo host virtuale verrà utilizzato se non viene trovato alcun host corrispondente alla richiesta inviata dal client.

Importante



Le richieste relative a host virtuali sconosciuti verranno sempre gestite dal primo host virtuale definito, motivo per cui il pacchetto include un file di configurazione 000-default.conf , che viene ordinato per primo rispetto a tutti gli altri file che potresti creare.

Ciascun host virtuale aggiuntivo viene quindi descritto da un file memorizzato in /etc/apache2/sites-available/.
Il file viene solitamente denominato con il nome host del sito web seguito dal suffisso .conf (ad esempio: www.kali.org.conf).
È quindi possibile abilitare il nuovo host virtuale con il comando a2ensite www.kali.org.
Ecco una configurazione minima di virtual host per un sito web i cui file sono archiviati in /srv/www.kali.org/www/ (definito con l' opzione DocumentRoot ):

```
<VirtualHost *:80>
ServerName www.kali.org ServerAlias
kali.org DocumentRoot /srv/
www.kali.org/www </VirtualHost>
```

Potresti anche valutare l'aggiunta delle direttive CustomLog e ErrorLog per configurare Apache in modo che i log vengano scritti in file dedicati all'host virtuale.

## Direttive comuni

Questa sezione esamina brevemente alcune delle direttive di configurazione di Apache più comunemente utilizzate.

Il file di configurazione principale di solito include diversi blocchi Directory ; questi consentono di specificare comportamenti differenti per il server a seconda della posizione del file servito. Un blocco di questo tipo include comunemente le direttive Options e AllowOverride :

```
<Directory /var/www>
Le opzioni includono FollowSymLinks
Consenti la sovrascrittura di tutto
DirectoryIndex index.php index.html index.htm </Directory>
```

Machine Translated by Google

La direttiva DirectoryIndex contiene un elenco di file da provare quando la richiesta del client corrisponde a una directory. Il primo file presente nell'elenco viene utilizzato e inviato come risposta.

La direttiva Options è seguita da un elenco di opzioni da abilitare. Il valore None disabilita tutte le opzioni; di conseguenza, All le abilita tutte tranne MultiViews. Le opzioni disponibili includono:

- ExecCGI: indica che è possibile eseguire script CGI.
- FollowSymLinks: indica al server che i collegamenti simbolici possono essere seguiti e che la risposta deve contenere il contenuto della destinazione di tali collegamenti.
- SymLinksIfOwnerMatch: indica al server di seguire i collegamenti simbolici, ma solo quando il collegamento e la sua destinazione hanno lo stesso proprietario.
- Include: abilita *le Server Side Includes* (SSI). Si tratta di direttive incorporate nelle pagine HTML ed eseguite al volo per ogni richiesta.
- Indici: indica al server di elencare il contenuto di una directory se la richiesta HTTP inviata dal client punta a una directory priva di un file di indice (ovvero, quando in tale directory non esistono file menzionati dalla direttiva DirectoryIndex ).
- MultiViews: consente la negoziazione dei contenuti; questa funzionalità può essere utilizzata dal server per restituire una pagina web corrispondente alla lingua preferita configurata nel browser.

**Richiesta di autenticazione** In alcune circostanze, l'accesso a una parte di un sito web deve essere limitato, in modo che solo gli utenti legittimi che forniscono un nome utente e una password possano accedere ai contenuti.

Il file .htaccess contiene direttive di configurazione di Apache che vengono applicate ogni volta che una richiesta riguarda un elemento della directory in cui è memorizzato il file .htaccess . Queste direttive sono ricorsive, estendendo il loro ambito a tutte le sottodirectory.

La maggior parte delle direttive che possono essere inserite in un blocco Directory sono valide anche in un file .htaccess . La direttiva AllowOverride elenca tutte le opzioni che possono essere abilitate o disabilitate tramite .htaccess. Un utilizzo comune di questa opzione è quello di limitare ExecCGI, in modo che l'amministratore possa scegliere quali utenti sono autorizzati a eseguire programmi con l'identità del server web (l' utente www-data ).

**Esempio 5.3** File .htaccess che richiede l'autenticazione

```
Richiede un utente valido
Nome autorizzazione "Cartella privata"
Tipo di autorizzazione di base
File utente di autorizzazione /etc/apache2/authfiles/htpasswd-private
```

Machine Translated by Google

| | |
|---|---|
| **Autenticazione di base**<br>**Non offre alcuna sicurezza** | Il sistema di autenticazione utilizzato nell'esempio precedente (Basic) offre una sicurezza minima, poiché la password viene inviata in chiaro (è codificata solo in base64, una semplice codifica e non un metodo di crittografia). È importante notare che anche i documenti protetti da questo meccanismo transitano sulla rete in chiaro. Se la sicurezza è fondamentale, l'intera sessione HTTP dovrebbe essere crittografata con Transport Layer Security (TLS). |

Il file /etc/apache2/authfiles/htpasswd-private contiene un elenco di utenti e password; viene comunemente gestito tramite il comando htpasswd . Ad esempio, il seguente comando viene utilizzato per aggiungere un utente o modificarne la password:

```
# htpasswd /etc/apache2/authfiles/htpasswd-private user
Nuova password:
Reinserisci la nuova password:
Aggiunta password per l'utente utente
```

**Limitazione dell'accesso** La direttiva Require controlla le restrizioni di accesso per una directory (e le sue sottodirectory, in modo ricorsivo).

Può essere utilizzato per limitare l'accesso in base a diversi criteri; ci limiteremo a descrivere la limitazione dell'accesso basata sull'indirizzo IP del client, ma può essere reso molto più potente, soprattutto quando diverse direttive Require vengono combinate all'interno di un blocco RequireAll .

Ad esempio, è possibile limitare l'accesso alla rete locale con la seguente direttiva:

```
Richiede l'indirizzo IP 192.168.0.0/16
```

## 5.4. Gestione dei servizi

Kali utilizza systemd come sistema di init, che non solo è responsabile della sequenza di avvio, ma funge anche da gestore di servizi completo, avviando e monitorando i servizi. È possibile interrogare

e controllare systemd tramite systemctl. Senza argomenti, viene eseguito il comando systemctl list-units , che restituisce un elenco delle *unità attive.* Eseguendo systemctl status, l'output mostra una panoramica gerarchica dei servizi in esecuzione. Confrontando i due output, si nota immediatamente che esistono diversi tipi di unità e che i servizi sono solo uno di questi.

Ogni servizio è rappresentato da *un'unità di servizio,* descritta da un file di servizio solitamente distribuito in /lib/systemd/system/ (o /run/systemd/system/, o /etc/systemd/system/; sono elencati in ordine crescente di importanza e l'ultimo ha la precedenza). Ciascuno può essere modificato da altri file service-name.service.d/ *.conf presenti nello stesso insieme di directory. Questi file di unità sono file di testo semplice il cui formato è ispirato ai ben noti file "*.ini" di Microsoft Windows, con chiave

Machine Translated by Google

= coppie valore-valore raggruppate tra le intestazioni [section] . Qui vediamo un file di servizio di esempio per /lib/systemd/system/ssh.service:

```
[Unità]
Descrizione=Server OpenBSD Secure Shell Dopo=rete.target
auditd.service ConditionPathExists=!/etc/ssh/
sshd_not_to_be_run

[Servizio]
File ambiente=-/etc/default/ssh
ExecStart=/usr/sbin/sshd -D $SSHD_OPTS
ExecReload=/bin/kill -HUP $MAINPID
Modalità di uccisione=processo
Riavvia=in caso di errore
RestartPreventExitStatus=255
Tipo=notifica

[Installare]
WantedBy=multi-user.target
Alias=sshd.service
```

Le unità target sono un altro elemento fondamentale dell'architettura di systemd. Rappresentano uno stato desiderato che si vuole raggiungere in termini di unità attivate (ovvero un servizio in esecuzione nel caso delle unità di servizio). La loro funzione principale è quella di raggruppare le dipendenze da altre unità. All'avvio del sistema, vengono abilitate le unità necessarie per raggiungere il target predefinito (che è un collegamento simbolico al target grafico, il quale a sua volta dipende dal target multiutente). Pertanto, tutte le dipendenze di questi target vengono attivate durante l'avvio.

Tali dipendenze vengono espresse tramite la direttiva Wants sull'unità di destinazione. Tuttavia, non è necessario modificare l'unità di destinazione per aggiungere nuove dipendenze: è possibile anche creare un collegamento simbolico che punta all'unità dipendente nella directory /etc/systemd/system/target-name.target.wants/ . Ed è esattamente ciò che fa il comando systemctl enable foo.service . Quando si abilita un servizio, si indica a systemd di aggiungere una dipendenza dalle destinazioni elencate nella voce WantedBy della sezione [Install] del file dell'unità di servizio. Viceversa, il comando systemctl disable foo.service elimina lo stesso collegamento simbolico e quindi la dipendenza.

I comandi enable e disable non modificano lo stato attuale dei servizi. Influenzano solo ciò che accadrà al successivo avvio. Se si desidera avviare immediatamente il servizio, è necessario eseguire il comando `systemctl start foo.service`. Al contrario, è possibile arrestarlo con `systemctl stop foo.service`. È inoltre possibile verificare lo stato attuale di un servizio con il comando `systemctl status foo.service`, che include anche le ultime righe del log associato. Dopo aver modificato la configurazione di un servizio, potrebbe essere necessario ricaricarlo o riavviarlo: queste operazioni si eseguono rispettivamente con i comandi `systemctl reload foo.service` e `systemctl restart foo.service` .

```
# systemctl status postgresql
```

Machine Translated by Google

```
• postgresql.service - RDBMS PostgreSQL
      Caricato: caricato (/lib/systemd/system/postgresql.service; disabilitato; preimpostazione del fornitore:
           ÿ disabilitato)
     Attivo: inattivo (morto)
# ls -al /etc/systemd/system/multi-user.target.wants/postgresql.service ls: impossibile accedere
a '/etc/systemd/system/multi-user.target.wants/postgresql.service': No
       ÿ tale file o directory # systemctl
enable postgresql [...] # ls -al /etc/

systemd/system/multi-user.target.wants/postgresql.service lrwxrwxrwx 1 root root 38 26 gen
19:09 /etc/systemd/system/multi-user.target.wants/
       ÿ postgresql.service -> /lib/systemd/system/postgresql.service
# systemctl status postgresql •
postgresql.service - RDBMS PostgreSQL
      Caricato: caricato (/lib/systemd/system/postgresql.service; abilitato; preimpostazione del fornitore:
           ÿ disabilitato)
     Attivo: inattivo (morto) #
systemctl start postgresql # systemctl
status postgresql • postgresql.service -
RDBMS PostgreSQL
         Caricato: caricato (/lib/systemd/system/postgresql.service; abilitato; preimpostazione del fornitore:
              ÿ disabilitato)
        Attivo: attivo (uscito) da martedì 26 gennaio 2021 19:10:31 EST; 5 secondi fa
       Processo: 1495 ExecStart=/bin/true (codice=uscito, stato=0/SUCCESSO)
     PID principale: 1495 (codice=uscito, stato=0/SUCCESSO)

26 gen 19:10:31 kali-rolling systemd[1]: Avvio del RDBMS PostgreSQL...
26 gen 19:10:31 kali-rolling systemd[1]: Avviato il RDBMS PostgreSQL.
```

## 5.5. Riepilogo

In questo capitolo abbiamo imparato a configurare Kali Linux. Abbiamo configurato le impostazioni di rete, parlato di utenti e gruppi e discusso di come creare e modificare account utente, impostare password, disabilitare account e gestire gruppi. Infine, abbiamo parlato dei servizi e spiegato come configurare e gestire servizi generici, in particolare SSH, PostgreSQL e Apache.

Suggerimenti riassuntivi:

- In una tipica installazione desktop, *NetworkManager* sarà già installato e potrà essere controllato e configurato tramite le impostazioni di sistema di Xfce e tramite il menu in alto a destra.
- È possibile configurare la rete dalla riga di comando con gli strumenti ifup e ifdown , che leggono le istruzioni dal file di configurazione /etc/network/interfaces . Uno strumento ancora più recente, *systemd-networkd,* funziona con il sistema di init *systemd .*

Machine Translated by Google

- Per impostazione predefinita, il database degli utenti e dei gruppi Unix è costituito dai file di testo /etc/passwd (elenco degli utenti), /etc/shadow (password crittografate degli utenti), /etc/group (elenco dei gruppi) e /etc/gshadow (password crittografate dei gruppi).
- È possibile utilizzare il comando getent per consultare il database degli utenti e altri database di sistema.
- Il comando adduser pone alcune domande prima di creare l'account, ma è un modo semplice per creare un nuovo account utente. • Diversi

comandi possono essere utilizzati per modificare campi specifici nel database degli utenti, tra cui: passwd (cambia la password), chfn (cambia il nome completo e il campo GECOS, o informazioni generali), chsh (cambia la shell di login), chage (cambia la durata della password) e passwd -e user (obbliga l'utente a cambiare la password al successivo accesso). • Ogni utente può

essere membro di uno o più gruppi. Diversi comandi possono essere utilizzati per modificare l'identità del gruppo: newgrp cambia l'ID del gruppo corrente, sg esegue un comando utilizzando il gruppo alternativo fornito, il bit setgid può essere impostato su una directory, facendo sì che i file creati in quella directory appartengano automaticamente al gruppo corretto. Inoltre, il comando id visualizza lo stato corrente di un utente, incluso un elenco della sua appartenenza ai gruppi.

- Puoi avviare SSH manualmente con systemctl start ssh oppure abilitarlo in modo permanente con systemctl enable ssh.
- PostgreSQL è un server di database. Raramente è utile da solo, ma viene utilizzato da molti altri servizi per archiviare dati.
- Una tipica installazione di Kali Linux include il server web Apache, fornito dal pacchetto *apache2* . Essendo un servizio di rete, è disabilitato per impostazione predefinita. È possibile avviarlo manualmente con il comando systemctl start apache2.
- Con la sua configurazione predefinita, Apache è in ascolto sulla porta 80 (come configurato in /etc/apache2/ports.conf) e serve le pagine dalla directory /var/www/html/ per impostazione predefinita (come configurato in /etc/apache2/sites-enabled/000-default.conf).

Ora che abbiamo affrontato i fondamenti di Linux e l'installazione e configurazione di Kali Linux, vediamo come risolvere i problemi di Kali e vi insegneremo alcuni strumenti e trucchi per far ripartire il sistema quando incontrate delle difficoltà.

Machine Translated by Google

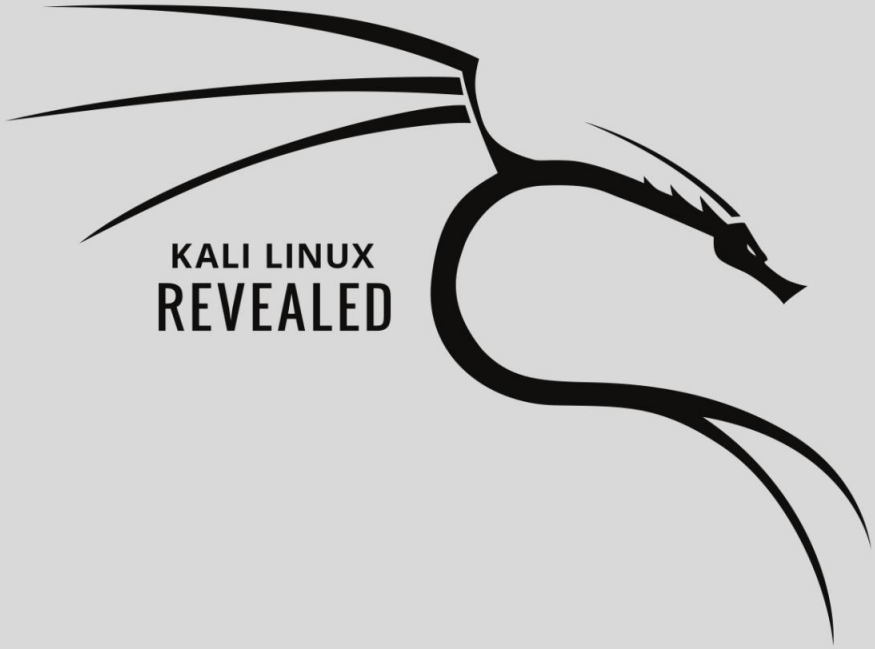


Machine Translated by Google

**Parole chiave**

**Documentazione**
**Forum**
**Canale IRC**

**Segnalazione di bug**



Machine Translated by Google

Capitolo

# Aiutarsi da soli e **6**

## Ottenere aiuto

Contenuto

Fonti di documentazione 128 Comunità Kali Linux 132 Come inviare una buona segnalazione di bug 134 Sommario 151

Machine Translated by Google

Non importa quanti anni di esperienza tu abbia, è indubbio che prima o poi ti imbatterai in un problema. Risolvere quel problema spesso significa comprenderlo e poi sfruttare diverse risorse per trovare una soluzione o una via d'uscita.

In questo capitolo, analizzeremo le diverse fonti di informazione disponibili e le migliori strategie per trovare l'aiuto di cui hai bisogno o la soluzione a un problema che potresti incontrare. Ti guideremo anche alla scoperta di alcune delle risorse della community di Kali Linux, tra cui forum e il canale IRC (Internet Relay Chat). Infine, introdurremo la segnalazione dei bug e ti mostreremo come sfruttare i sistemi di segnalazione per risolvere i problemi, illustrandoti anche le strategie per inviare la tua segnalazione di bug in modo che i problemi non documentati possano essere gestiti in modo rapido ed efficace.

## 6.1. Fonti della documentazione

Prima di poter comprendere cosa accade realmente quando si verifica un problema, è necessario conoscere il ruolo teorico svolto da ciascun programma coinvolto. Uno dei modi migliori per farlo è consultare la documentazione del programma. Iniziamo esaminando dove, esattamente, è possibile trovare la documentazione, dato che spesso è dispersa.

**Come evitare di dover leggere il manuale**

**Risposte**

Questo acronimo sta per "leggi il fottuto manuale", ma può anche essere esteso in una variante più amichevole, "leggi il bel manuale". Questa frase viene talvolta usata in risposte (brevi) alle domande dei neofiti. È piuttosto brusca e tradisce una certa irritazione per una domanda posta da qualcuno che non si è nemmeno preso la briga di leggere la documentazione. Alcuni sostengono che questa risposta classica sia meglio di nessuna risposta, poiché almeno lascia intendere che la risposta si trova nella documentazione.

Quando pubblichi domande, non offenderti necessariamente per qualche risposta del tipo "Leggi il manuale", ma fai il possibile per dimostrare di aver dedicato del tempo alla ricerca prima di pubblicare la domanda; cita le fonti che hai consultato e descrivi i vari passaggi che hai seguito personalmente per trovare le informazioni. Questo dimostrerà che non sei pigro e che stai davvero cercando di imparare. Seguire le linee guida di Eric Raymond è un buon modo per evitare gli errori più comuni e ottenere risposte utili.

ÿ http://catb.org/~esr/faqs/smart-questions.html

### 6.1.1. Pagine del manuale

Le pagine del manuale (man), pur essendo relativamente concise nello stile, contengono una grande quantità di informazioni essenziali. Per visualizzare una pagina del manuale, è sufficiente digitare man pagina-manuale. La pagina del manuale di solito corrisponde al nome del comando. Ad esempio, per conoscere le opzioni disponibili per il comando cp , si digita man cp al prompt dei comandi.

Le pagine del manuale non documentano solo i programmi accessibili dalla riga di comando, ma anche i file di configurazione, le chiamate di sistema, le funzioni della libreria C e così via. A volte i nomi possono entrare in conflitto.

Machine Translated by Google

Ad esempio, il comando `read` della shell ha lo stesso nome della chiamata di sistema `read` . Per questo motivo le pagine del manuale sono organizzate nelle seguenti sezioni numerate:

1. Comandi eseguibili dalla riga di comando
2. Chiamate di sistema (funzioni fornite dal kernel)
3. Funzioni di libreria (fornite dalle librerie di sistema)
4. Dispositivi (nei sistemi Unix-like, si tratta di file speciali, solitamente posizionati nella directory /dev/ )
5. File di configurazione (formati e convenzioni)
6. Giochi
7. Insiemi di macro e standard
8. Comandi di amministrazione del sistema
9. Routine del kernel

È possibile specificare la sezione della pagina del manuale che si sta cercando: per visualizzare la documentazione per la chiamata di sistema read , dovresti digitare man 2 read. Quando non viene specificata esplicitamente alcuna sezione, il verrà mostrata la prima sezione che ha una pagina manuale con il nome richiesto. Quindi, ombra dell'uomo restituisce shadow(5) perché non ci sono pagine di manuale per *shadow* nelle sezioni 1–4.

Certo, se non conosci i nomi dei comandi, il manuale non ti sarà di grande aiuto.
a te utile. Inserisci il comando apropos , che cerca nelle pagine del manuale (o più specificamente nelle loro brevi descrizioni) per qualsiasi parola chiave fornita. Il comando apropos restituisce quindi un elenco delle pagine del manuale il cui riepilogo menziona le parole chiave richieste insieme alla riga singola riassunto dalla pagina del manuale. Se scegli bene le tue parole chiave, troverai il nome del comando di cui hai bisogno.

**Esempio 6.1** Trovare cp con apropos

```
$ a proposito di "copia file"
cp (1) - copia file e directory
cpio (1) - copia file da e verso gli archivi
gvfs-copy (1)          - Copia file
gvfs-move (1)          - Copia file
hcopy (1) - copia file da o verso un volume HFS
installa (1) - copia i file e imposta gli attributi
ntfscp (8)             - Copiare il file su un volume NTFS.
```

**Consultare la documentazione seguendo i link**

Molte pagine di manuale hanno una sezione “Vedi anche”, di solito verso la fine del documento, che rimanda ad altre pagine del manuale pertinenti a comandi simili o a documentazione esterna. Puoi utilizzare questa sezione per trovare la documentazione pertinente anche quando

La prima scelta non è ottimale.

Machine Translated by Google

Oltre a man, è possibile utilizzare anche konqueror (in KDE) e yelp (in GNOME) per cercare nelle pagine del manuale.

### 6.1.2. Documenti informativi

Il progetto GNU ha redatto i manuali per la maggior parte dei suoi programmi nel formato *info ;* per questo motivo molte pagine di manuale rimandano alla documentazione *info* corrispondente . Questo formato offre alcuni vantaggi, ma il programma predefinito per visualizzare questi documenti (chiamati anche info) è leggermente più complesso. Si consiglia di utilizzare pinfo (dal pacchetto *pinfo ).* Per installarlo, è sufficiente eseguire apt update seguito da apt install pinfo (vedere la sezione 8.2.2.2, "Installazione di pacchetti con APT" [pagina 183]).

La documentazione *informativa* ha una struttura gerarchica e, se si richiama pinfo senza parametri, verrà visualizzato un elenco dei nodi disponibili al primo livello. Solitamente, i nodi riportano il nome dei comandi corrispondenti.

È possibile utilizzare i tasti freccia per navigare tra i nodi. In alternativa, si può anche utilizzare un browser grafico (che è molto più intuitivo) come Konqueror o Yelp.

Per quanto riguarda le traduzioni linguistiche, il sistema *informativo* è sempre in inglese e non si presta alla traduzione, a differenza del sistema delle pagine man . Tuttavia, quando si chiede al programma pinfo di visualizzare una pagina *informativa* inesistente , questo utilizzerà la pagina *man* corrispondente (se esiste), che potrebbe essere tradotta.

### 6.1.3. Documentazione specifica del pacchetto

Ogni pacchetto include la propria documentazione e persino i programmi meno documentati generalmente dispongono di un file README contenente informazioni interessanti e/o importanti. Questa documentazione viene installata nella directory /usr/share/doc/package/ (dove *package* rappresenta il nome del pacchetto). Se la documentazione è particolarmente corposa, potrebbe non essere inclusa nel pacchetto principale del programma, ma potrebbe essere spostata in un pacchetto dedicato, solitamente denominato package-doc.
Il pacchetto principale generalmente consiglia il pacchetto di documentazione in modo da poter trovare facilmente Esso.

La directory /usr/share/doc/package/ contiene anche alcuni file forniti da Debian, che completano la documentazione specificando le particolarità o i miglioramenti del pacchetto rispetto a un'installazione tradizionale del software. Il file README.Debian indica inoltre tutti gli adattamenti apportati per conformarsi alla Debian Policy1 . Il file changelog.Debian.gz consente all'utente di seguire le modifiche apportate al pacchetto nel tempo; è molto utile per cercare di capire cosa è cambiato tra due versioni installate che non hanno lo stesso comportamento. Infine, a volte è presente un file NEWS.Debian.gz che documenta le principali modifiche al programma che possono interessare direttamente l'amministratore.

[1] https://www.debian.org/doc/debian-policy/

Machine Translated by Google

### 6.1.4. Siti web

In molti casi, è possibile trovare siti web utilizzati per distribuire software libero e per riunire la comunità di sviluppatori e utenti. Questi siti sono ricchi di informazioni utili in vari formati, come documentazione ufficiale, domande frequenti (FAQ) e archivi di mailing list. Nella maggior parte dei casi, le FAQ o gli archivi delle mailing list affrontano i problemi che si sono riscontrati. Quando si cercano informazioni online, è estremamente utile padroneggiare la sintassi di ricerca. Un consiglio rapido: provate a limitare la ricerca a un dominio specifico, come quello dedicato al programma che vi sta dando problemi. Se la ricerca restituisce troppe pagine o se i risultati non corrispondono a ciò che cercate, potete aggiungere la parola chiave **"kali"** o **"debian"** per filtrare i risultati e trovare informazioni pertinenti.

| | |
|---|---|
| **Dall'errore a un Soluzione** | Se il software restituisce un messaggio di errore molto specifico, inseriscilo in un motore di ricerca (tra virgolette doppie, ", per cercare la frase completa, anziché le singole parole chiave). Nella maggior parte dei casi, i primi risultati conterranno la risposta che cerchi.<br><br>In altri casi, riceverete errori molto generici, come "Permesso negato". In questo caso, è meglio verificare i permessi degli elementi coinvolti (file, ID utente, gruppi, ecc.). Insomma, non prendete l'abitudine di usare sempre un motore di ricerca per trovare una soluzione al vostro problema. Scoprirete che è fin troppo facile dimenticare di usare il buon senso. |

Se non conosci l'indirizzo del sito web del software, esistono diversi modi per trovarlo. Innanzitutto, cerca il campo "Homepage" nelle meta-informazioni del pacchetto (ad esempio, con il comando `apt show package`). In alternativa, la descrizione del pacchetto potrebbe contenere un link al sito web ufficiale del programma. Se non viene indicato alcun URL, il gestore del pacchetto potrebbe averlo incluso nel file `/usr/share/ doc/package/copyright` . Infine, puoi provare a utilizzare un motore di ricerca (come Google, Bing, DuckDuckGo, ecc.) per trovare il sito web del software.

### 6.1.5. Documentazione di Kali su kali.org/docs/

Il progetto Kali mette a disposizione una raccolta di documentazione utile all'indirizzo https://www.kali.org/docs/. Sebbene questo libro tratti gran parte di ciò che è necessario sapere su Kali Linux, la documentazione in esso contenuta potrebbe comunque risultare utile, in quanto presenta istruzioni dettagliate (simili a guide pratiche) su molti argomenti.

ÿ https://www.kali.org/docs/

Analizziamo i vari argomenti trattati:

- Introduzione: documentazione che descrive cos'è Kali Linux e tutte le sue caratteristiche.
- Installazione: vari documenti che descrivono l'installazione di Kali Linux, incluso come installarlo in parallelo con altri sistemi operativi.

Machine Translated by Google

- Virtualizzazione: vari documenti che descrivono come creare macchine virtuali Kali Linux tramite diversi software
- USB: documentazione che descrive come creare una chiavetta USB avviabile live con

Kali Linux • Kali Linux su ARM: numerose guide su come eseguire Kali Linux su vari dispositivi basati

su ARM • Container: documentazione che descrive come utilizzare Kali Linux in container come Docker o LXC

- WSL: vari documenti contenenti informazioni sui possibili modi di utilizzare Kali Linux tramite il Sottosistema Windows per Linux •

Cloud: documentazione che descrive come creare istanze cloud di Kali Linux • Kali

NetHunter: documentazione su tutto ciò che riguarda la versione mobile di Kali • Uso

generale: vari documenti sui casi d'uso tipici di Kali Linux e risposte a varie domande che potrebbero essere poste

- Strumenti: documentazione sugli strumenti inclusi in Kali Linux
- Risoluzione dei problemi: vari documenti che contengono informazioni che possono essere utili per la risoluzione dei problemi
- Sviluppo: documentazione che descrive molti aspetti del processo di creazione di Kali Linux •

Comunità: documentazione che descrive come partecipare alla comunità di Kali Linux • Politica:

spiegazioni su cosa rende Kali Linux speciale rispetto ad altre distribuzioni Linux distribuzioni

### 6.2. Comunità Kali Linux

Esistono numerose community di Kali Linux in tutto il mondo che utilizzano diversi strumenti di comunicazione (forum, chat in tempo reale e social network, ad esempio). In questa sezione, presenteremo solo due community ufficiali di Kali Linux.

#### 6.2.1. Forum su forums.kali.org

I forum ufficiali della community del progetto Kali Linux si trovano all'indirizzo forums.kali.org2 .
Come in ogni forum online, è necessario creare un account per poter pubblicare messaggi e il sistema memorizza i messaggi che hai già visualizzato, facilitando così il monitoraggio delle conversazioni.

Prima di pubblicare un messaggio, è necessario leggere il regolamento del forum:

ÿ https://www.kali.org/docs/community/kali-linux-community-forums/

[2] https://forums.kali.org/

Machine Translated by Google

Non le copieremo qui, ma è importante notare che non è consentito parlare di attività illegali come l'intrusione nelle reti altrui. È necessario essere rispettosi degli altri membri della community per creare un ambiente accogliente. La pubblicità è vietata ed è opportuno evitare discussioni fuori tema. Sono presenti categorie a sufficienza per trattare qualsiasi argomento relativo a Kali Linux.

### 6.2.2. Canale IRC #kali-linux su Freenode

IRC è un sistema di chat in tempo reale. Le discussioni avvengono in stanze di chat chiamate *canali* e sono generalmente incentrate su un argomento o una comunità specifici. Il progetto Kali Linux utilizza il canale #kali-linux su Freenode3. rete (è possibile utilizzare chat.freenode.net come server IRC, sulla porta 6667 per una connessione crittografata TLS o sulla porta 6666 per una connessione in chiaro).

Per partecipare alle discussioni su IRC, è necessario utilizzare un client IRC come hexchat (in modalità grafica) o irssi (in modalità console). È disponibile anche un client web all'indirizzo webchat.freenode.net4 .

Sebbene sia davvero facile unirsi alla conversazione, dovresti essere consapevole che i canali IRC hanno le proprie regole e che ci sono operatori di canale (il loro nickname è preceduto da @ quando si utilizza HexChat5 Il client IRC (che può far rispettare le regole) può espellerti dal canale (o addirittura bannarti se continui a violare le regole). Il canale #kali-linux non fa eccezione. Le regole sono documentate qui:

ÿ https://www.kali.org/docs/community/kali-linux-irc-channel/

Per riassumere le regole: devi essere amichevole, tollerante e ragionevole. Dovresti evitare discussioni fuori tema. In particolare, sono vietate le discussioni su attività illegali, software pirata, politica e religione. Tieni presente che il tuo indirizzo IP sarà visibile agli altri.

Se vuoi chiedere aiuto, segui i consigli elencati in "Come evitare risposte tipo RTFM" [pagina 128]: fai prima le tue ricerche e condividi i risultati. Quando ti vengono richieste informazioni supplementari, forniscile accuratamente (se devi fornire un output dettagliato, non incollarlo direttamente nel canale, ma usa un servizio come Pastebin6). e pubblica solo l'URL di Pastebin).

Non aspettarti una risposta immediata. Sebbene IRC sia una piattaforma di comunicazione in tempo reale, i partecipanti si connettono da tutto il mondo, quindi i fusi orari e gli orari di lavoro variano. Potrebbero volerci alcuni minuti o ore prima che qualcuno risponda alla tua domanda. Tuttavia, quando altri includono il tuo nickname in una risposta, questo verrà evidenziato e la maggior parte dei client IRC ti avviserà, quindi lascia il tuo client connesso e sii paziente.

[3] https://freenode.net/
[4] https://webchat.freenode.net/
[5] https://hexchat.github.io/
[6] https://pastebin.com/

Machine Translated by Google



Se tutti i tuoi tentativi di risolvere un problema falliscono, è possibile che il problema sia dovuto a un bug nel programma. In questo caso, il problema potrebbe aver generato una segnalazione di bug. Puoi cercare le segnalazioni di bug per trovare una soluzione al tuo problema, ma vediamo prima la procedura per segnalare un bug a Kali, Debian o direttamente agli sviluppatori del progetto, in modo da comprendere il processo qualora dovessi inviare la tua segnalazione.

L'obiettivo di una segnalazione di bug è fornire informazioni sufficienti affinché gli sviluppatori o i manutentori del programma (presumibilmente) difettoso possano riprodurre il problema, eseguire il debug del suo comportamento e sviluppare una soluzione. Ciò significa che la segnalazione del bug deve contenere informazioni appropriate ed essere indirizzata alla persona o al team di progetto corretto. La segnalazione deve inoltre essere ben scritta e completa, per garantire una risposta più rapida.

La procedura esatta per la segnalazione di un bug varia a seconda di dove la si invia (Kali, Debian o gli sviluppatori del progetto principale), ma esistono alcune raccomandazioni generali valide in tutti i casi. In questo capitolo analizzeremo tali raccomandazioni.

### 6.3.1. Raccomandazioni generiche

Analizziamo alcuni consigli e linee guida generali che vi aiuteranno a inviare una segnalazione di bug chiara, completa e che aumenti le probabilità che il problema venga risolto dagli sviluppatori in tempi brevi.

## Come comunicare

**Scrivi il tuo rapporto in inglese.** La comunità del software libero è internazionale e, a meno che tu non conosca il tuo interlocutore, dovresti usare un inglese semplice. Se sei madrelingua inglese, usa frasi semplici ed evita costruzioni che potrebbero risultare difficili da comprendere per chi ha una conoscenza limitata dell'inglese. Anche se la maggior parte degli sviluppatori è molto intelligente, non tutti hanno una solida conoscenza della lingua inglese. È meglio non dare mai nulla per scontato.

**Siate rispettosi del lavoro degli sviluppatori.** Ricordate che la maggior parte degli sviluppatori di software libero (inclusi quelli di Kali Linux) sono persone di buon cuore che dedicano il loro limitato tempo libero a lavorare sul software che voi utilizzate gratuitamente. Molti lo fanno per altruismo. Pertanto, quando segnalate un bug, siate rispettosi (anche se il bug sembra un errore evidente dello sviluppatore) e non date per scontato che vi debbano una soluzione. Ringraziateli invece per il loro contributo.

Se sai come modificare e ricompilare il software, offriti di aiutare gli sviluppatori a testare le patch che ti invieranno. Questo dimostrerà loro che sei disposto a investire anche il tuo tempo.

Machine Translated by Google

**Siate reattivi e pronti a fornire ulteriori informazioni.** In alcuni casi, lo sviluppatore vi contatterà chiedendovi maggiori informazioni o di provare a riprodurre il problema, magari utilizzando opzioni diverse o un pacchetto aggiornato. Cercate di rispondere a queste richieste il più rapidamente possibile. Prima invierete la vostra risposta, maggiori saranno le probabilità che riescano a risolvere il problema velocemente, finché l'analisi iniziale è ancora fresca nella loro memoria.

Pur dovendo puntare a una risposta rapida, è bene non avere fretta: i dati inviati devono essere corretti e contenere tutto ciò che gli sviluppatori hanno richiesto. Potrebbero irritarsi se dovessero chiedere qualcosa una seconda volta.

## Cosa includere nella segnalazione di bug

**Istruzioni per riprodurre il problema** Per poter riprodurre il problema, gli sviluppatori devono sapere cosa stai utilizzando, da dove lo hai scaricato e come lo hai installato.

È necessario fornire istruzioni precise e dettagliate, passo dopo passo, che descrivano come riprodurre il problema. Se hai bisogno di dati per riprodurre il problema, allega il file corrispondente alla segnalazione di bug. Cerca di fornire le istruzioni minime necessarie per riprodurre il bug.

**Fornisci un contesto e definisci le tue aspettative.** Spiega cosa stavi cercando di fare e come ti aspettavi che il programma si comportasse.

In alcuni casi, il bug si manifesta solo perché si sta utilizzando il programma in un modo per cui non è stato progettato dagli sviluppatori. Spiegando cosa si stava cercando di fare, si permetterà agli sviluppatori di capire chiaramente quando questo è il caso.

In alcuni altri casi, il comportamento che descrivi come un bug potrebbe in realtà essere il comportamento normale. Esplicita chiaramente cosa ti aspettavi che il programma facesse. Questo chiarirà la situazione agli sviluppatori. Potrebbero decidere di migliorare il comportamento o la documentazione, ma almeno sapranno che il comportamento del loro programma sta creando confusione ad alcuni utenti!

**Sii specifico.** Includi i numeri di versione del software che utilizzi, eventualmente anche quelli delle sue dipendenze. Quando fai riferimento a qualcosa che hai scaricato, includi l'URL completo.

Quando ricevi un messaggio di errore, riportalo esattamente come lo hai visualizzato. Se possibile, includi una copia dell'output a schermo o uno screenshot. Allega una copia di qualsiasi file di registro pertinente, assicurandoti di rimuovere prima eventuali dati sensibili.

**Indica possibili soluzioni o workaround.** Prima di inviare la segnalazione di bug, probabilmente hai già provato a risolvere il problema. Spiega cosa hai provato e quali risultati hai ottenuto. Sii molto chiaro su cosa è un dato di fatto e cosa era solo una tua ipotesi.

Se hai effettuato una ricerca su Internet e hai trovato delle spiegazioni relative a un problema simile, puoi menzionarle, in particolare se hai trovato altre segnalazioni di bug simili nei sistemi di tracciamento dei bug.

Machine Translated by Google

Se hai trovato un modo per ottenere il risultato desiderato senza attivare il bug, ti preghiamo di documentarlo. Questo aiuterà altri utenti che potrebbero riscontrare lo stesso problema.

**Segnalazioni di bug dettagliate vanno bene.** Una segnalazione di bug di due righe non è sufficiente; fornire tutte le informazioni necessarie richiede solitamente diversi paragrafi (o a volte pagine) di testo.

Fornisci tutte le informazioni possibili. Cerca di attenerti a ciò che è rilevante, ma in caso di dubbio, è meglio dare troppe informazioni che troppo poche.

Se la segnalazione del bug è molto lunga, prenditi del tempo per strutturare il contenuto e fornisci un breve riassunto all'inizio.

## Suggerimenti vari

**Evitate di inviare segnalazioni di bug duplicate.** Nel mondo del software libero, tutti i sistemi di tracciamento dei bug sono pubblici. È possibile consultare le segnalazioni aperte e persino utilizzare una funzione di ricerca. Pertanto, prima di inviare una nuova segnalazione di bug, cercate di verificare se il vostro problema è già stato segnalato da qualcun altro.

Se trovi una segnalazione di bug già esistente, iscriviti e, se possibile, aggiungi informazioni supplementari. Non pubblicare commenti per dare risalto alla segnalazione, come "Anch'io" o "+1"; non servono a nulla. Puoi però indicare la tua disponibilità a ulteriori test se chi ha segnalato il bug non lo ha previsto.

Se non hai trovato alcuna segnalazione relativa al tuo problema, procedi pure ad aprirne una. Se invece hai trovato segnalazioni simili, assicurati di menzionarle.

**Assicurati di utilizzare la versione più recente.** Per gli sviluppatori è molto frustrante ricevere segnalazioni di bug per problemi che hanno già risolto o che non riescono a riprodurre con la versione che stanno utilizzando (gli sviluppatori usano quasi sempre la versione più recente del loro prodotto). Anche quando le versioni precedenti vengono ancora supportate dagli sviluppatori, l'assistenza è spesso limitata alle correzioni di sicurezza e ai problemi più gravi. Sei sicuro che il tuo bug rientri in questa categoria?

Per questo motivo, prima di inviare una segnalazione di bug, è necessario assicurarsi di utilizzare la versione più recente del sistema e dell'applicazione problematici e di essere in grado di riprodurre il problema in tale situazione.

Se Kali Linux non offre l'ultima versione dell'applicazione, hai delle soluzioni alternative: puoi provare a installare manualmente l'ultima versione in una macchina virtuale temporanea, oppure puoi consultare il Changelog ufficiale (o qualsiasi registro storico nel sistema di controllo versione scelto) per verificare che non ci siano state modifiche che possano risolvere il problema riscontrato (e in tal caso segnalare il bug anche se non hai provato l'ultima versione).

**Non raggruppare più problemi in un'unica segnalazione di bug .** Segnala un bug per ogni problema. In questo modo, le discussioni successive non diventeranno troppo confuse e ogni bug potrà essere risolto secondo la propria tempistica. Se non lo fai, o il singolo bug dovrà essere riutilizzato più volte e potrà essere chiuso solo quando tutti i problemi saranno stati risolti, oppure gli sviluppatori dovranno inviare le segnalazioni supplementari che avresti dovuto creare fin dall'inizio.

Machine Translated by Google

### 6.3.2. Dove inviare una segnalazione di bug

Per poter decidere dove segnalare il bug, è necessario comprendere a fondo il problema e aver identificato in quale parte del software risiede.

Idealmente, si individua il problema in un file del sistema e quindi si può usare dpkg per scoprire quale pacchetto possiede quel file e da dove proviene. Supponiamo di aver trovato un bug in un'applicazione grafica. Dopo aver esaminato l'elenco dei processi in esecuzione (l'output di ps auxf), si scopre che l'applicazione è stata avviata con l' eseguibile /usr/bin/cherrytree :

```
$ dpkg -S /usr/bin/cherrytree cherrytree: /usr/
bin/cherrytree $ dpkg -s cherrytree | grep ^Version:
Version: 0.38.8-0kali1
```

Scopri che /usr/bin/cherrytree è fornito dal pacchetto cherrytree , che è nella versione 0.38.8-0kali1. Il fatto che la stringa di versione contenga "kali" ti indica che il pacchetto proviene da Kali Linux (o è stato modificato da Kali Linux). Qualsiasi pacchetto che non abbia "kali" nella sua stringa di versione (o nel suo nome) proviene direttamente da Debian (in generale da Debian Testing).

**Ricontrollare prima Segnalazione di bug Sabiano**

Se si riscontra un bug in un pacchetto importato direttamente da Debian, idealmente andrebbe segnalato e corretto da Debian. Tuttavia, prima di farlo, è necessario assicurarsi che il problema sia riproducibile su un sistema Debian standard, poiché Kali potrebbe averlo causato modificando altri pacchetti o dipendenze.

Il modo più semplice per farlo è configurare una macchina virtuale con Debian Testing. Puoi trovare un'immagine ISO di installazione di Debian Testing sul sito web di Debian Installer:

ÿ https://www.debian.org/devel/debian-installer/

Se riesci a confermare il problema nella macchina virtuale, puoi segnalare il bug a Debian eseguendo il comando `reportbug` all'interno della macchina virtuale e seguendo le istruzioni fornite.

La maggior parte delle segnalazioni di bug relative al comportamento delle applicazioni dovrebbe essere indirizzata ai rispettivi progetti di origine, tranne nei casi di problemi di integrazione: in tal caso, il bug è dovuto a un errore nel modo in cui il software viene impacchettato e integrato in Debian o Kali. Ad esempio, se un'applicazione offre opzioni in fase di compilazione che il pacchetto non abilita o se l'applicazione non funziona a causa di una libreria mancante (evidenziando quindi una dipendenza mancante nelle meta-informazioni del pacchetto), si potrebbe avere un problema di integrazione. Quando non si è certi della natura del problema, è generalmente consigliabile segnalarlo a entrambi i progetti e confrontarli.

Identificare il progetto a monte e trovare dove segnalare il bug è solitamente facile. Basta consultare il sito web del progetto a monte, il cui indirizzo è riportato nel campo "Homepage" dei metadati del pacchetto:

Machine Translated by Google

```
$ dpkg -s wpscan | grep ^Homepage:
Homepage: http://www.wpscan.org
```

### 6.3.3. Come segnalare un bug

#### Segnalazione di bug in Kali

Kali utilizza un sistema di tracciamento dei bug basato sul web, disponibile all'indirizzo https://bugs.kali.org/ dove puoi consultare tutte le segnalazioni di bug in forma anonima, ma se desideri commentare o inviare una nuova segnalazione di bug, dovrai registrare un account.

**Registrazione di un account per il bug tracker** Per iniziare, è sufficiente fare clic su *"Registrati per un nuovo account"* sul sito web del bug tracker, come mostrato nella Figura 6.1, "Pagina iniziale del Kali Bug Tracker" [pagina 138].

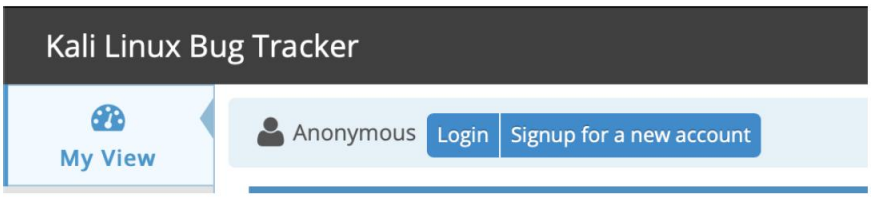



**Figura 6.1** Pagina iniziale di Kali Bug Tracker

Successivamente, inserisci un nome utente, un indirizzo e-mail e la risposta al CAPTCHA. Quindi fai clic sul pulsante Registrati per procedere (Figura 6.2, "Pagina di registrazione" [pagina 139]).

Machine Translated by Google

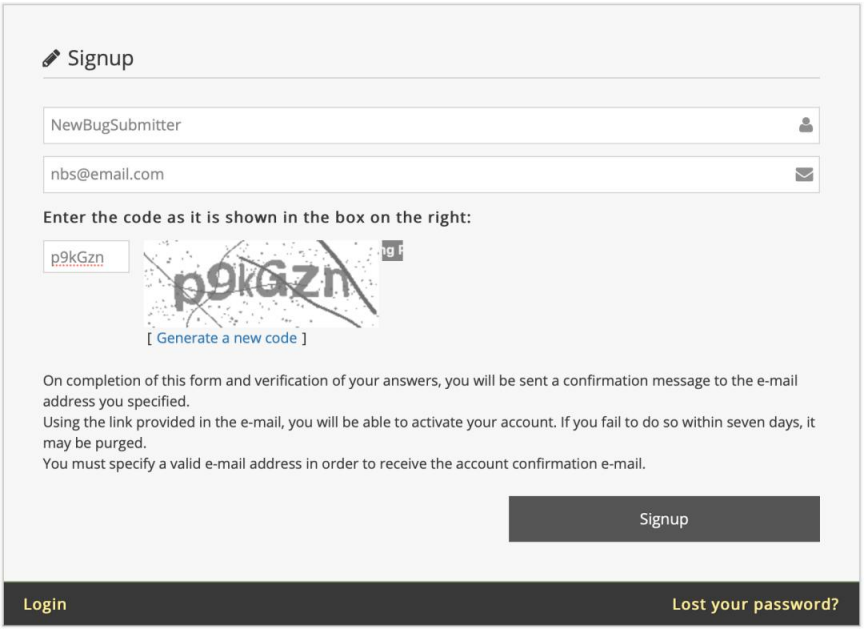



**Figura 6.2** Pagina di registrazione

In caso di successo, la pagina successiva (Figura 6.3, "Pagina di conferma della registrazione" [pagina 139]) ti informerà che la registrazione dell'account è stata elaborata e il sistema di tracciamento dei bug invierà un'e-mail di conferma all'indirizzo che hai fornito. Dovrai cliccare sul link presente nell'e-mail per attivare il tuo account.

Una volta attivato il tuo account, fai clic su Procedi per accedere alla pagina di login del sistema di segnalazione bug.

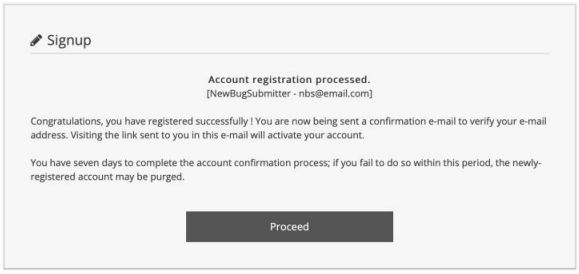



**Figura 6.3** Pagina di conferma dell'iscrizione

Machine Translated by Google

**Creazione della segnalazione** Per iniziare la segnalazione, accedi al tuo account e fai clic sul link "Segnala un problema" nella pagina iniziale. Ti verrà mostrato un modulo con molti campi da compilare, come illustrato nella Figura 6.4, "Modulo per segnalare un bug" [pagina 140].

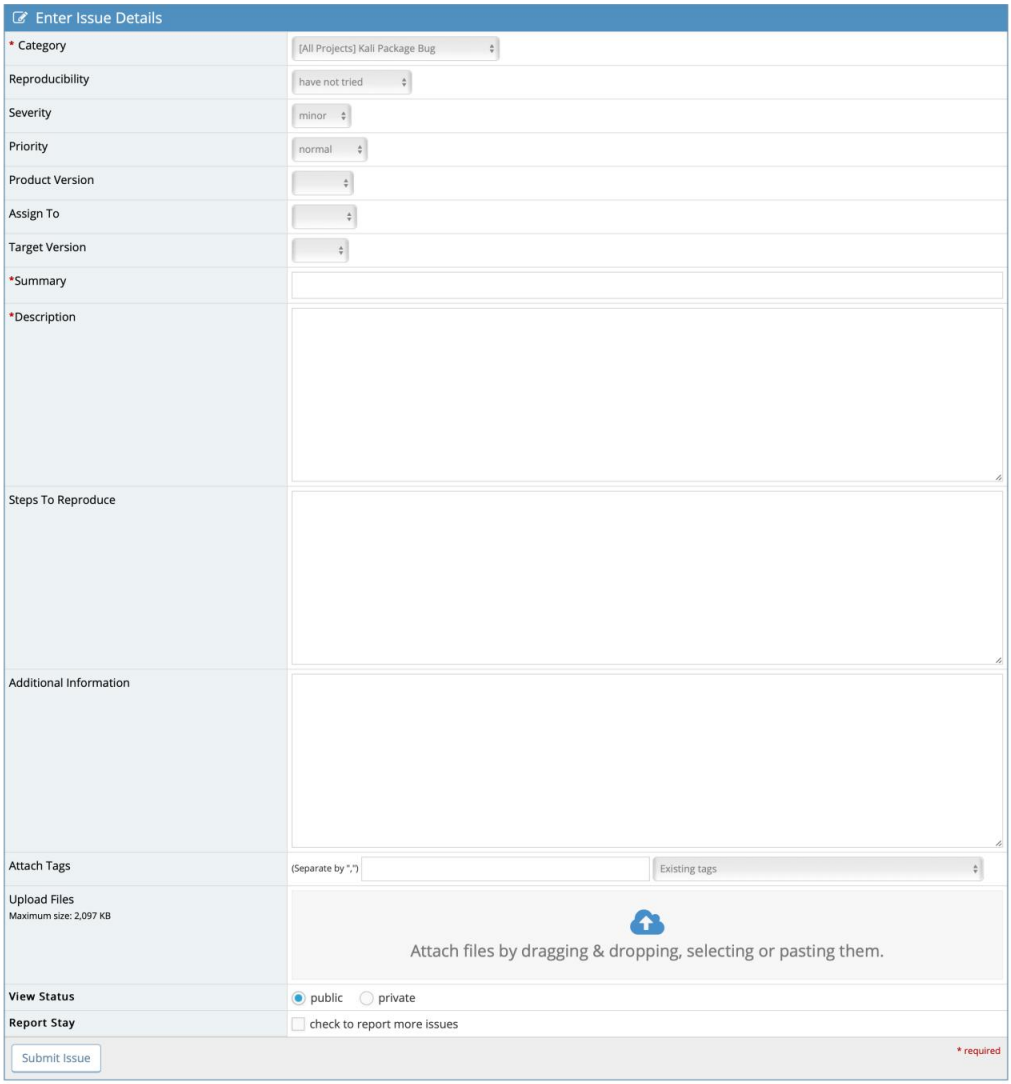



**Figura 6.4** Modulo per segnalare un bug

Ecco un riepilogo di tutti i campi del modulo:

**Categoria (obbligatoria)** Questo campo descrive la categoria del bug che stai segnalando. Le segnalazioni che possono essere attribuite a un pacchetto specifico devono essere inviate a Kali Package Bug o Kali

Machine Translated by Google

Categorie di miglioramento del pacchetto. Per altre segnalazioni, utilizzare le categorie Bug generali o Richieste di funzionalità. Le categorie rimanenti sono per casi d'uso specifici: Aggiornamento strumento può essere utilizzato per notificare agli sviluppatori di Kali la disponibilità di una nuova versione di un software incluso in Kali. Richieste di nuovi strumenti può essere utilizzato per suggerire nuovi strumenti da includere e integrare nella distribuzione di Kali. Siti web e documentazione di Kali può essere utilizzato per segnalare bug o aggiornamenti relativi ai vari siti web di Kali. Aggiunta strumento in coda è riservata al team degli strumenti di Kali, quando è stata concordata l'aggiunta di uno strumento a Kali.

**Riproducibilità** Questo campo documenta se il problema è riproducibile in modo prevedibile o se si verifica solo in modo parzialmente casuale.

**Gravità e priorità.** È preferibile lasciare questi campi invariati, poiché sono destinati principalmente agli sviluppatori. Possono utilizzarli per ordinare l'elenco dei problemi in base alla gravità e alla priorità con cui devono essere gestiti.

**Versione del prodotto** Questo campo dovrebbe indicare la versione di Kali Linux in uso (o quella più simile a quella in uso). Pensaci bene prima di segnalare un problema su una versione obsoleta non più supportata.

**Assegna a e Versione di destinazione** Anche questi campi è meglio lasciarli invariati, poiché sono pensati principalmente per gli sviluppatori. Possono usarli per indicare quale sviluppatore si sta occupando del problema e quando dovrebbe essere risolto.

**Riepilogo (obbligatorio)** Questo è essenzialmente il titolo della tua segnalazione di bug ed è la prima cosa che le persone vedranno. Assicurati che comunichi il motivo per cui stai inviando la segnalazione. Evita descrizioni generiche come "X non funziona" e opta invece per "X fallisce con l'errore Y in condizioni Z".

**Descrizione (obbligatoria)** Questa è la parte centrale del tuo rapporto. Qui devi inserire tutte le informazioni raccolte sul problema che stai riscontrando. Non dimenticare di includere tutti i suggerimenti forniti nella sezione precedente.

**Passaggi per riprodurre** In questo campo, elenca tutte le istruzioni dettagliate che spiegano come attivare il problema. problema.

**Informazioni aggiuntive** In questa sezione, puoi fornire qualsiasi informazione aggiuntiva che ritieni rilevante per il problema. Se disponi di una soluzione o di una soluzione alternativa al problema, ti preghiamo di fornirla in questa sezione.

**Aggiungi tag** Questa sezione è preferibile non modificarla. I tag vengono utilizzati dagli sviluppatori per facilitare l'accesso a segnalazioni di bug simili.

**Carica file** Non tutto può essere spiegato con semplice testo. Questo campo consente di allegare file a piacere ai report: screenshot per mostrare l'errore, documenti di esempio che causano il problema, file di log, ecc.

Machine Translated by Google

**Visualizza stato** Lascia questo campo impostato su "pubblico" in modo che tutti possano vedere la tua segnalazione di bug. Usa "privato" solo per le segnalazioni relative alla sicurezza contenenti informazioni su vulnerabilità di sicurezza non divulgate.

Come inviare una segnalazione di bug in Debian

Debian utilizza un sistema di tracciamento dei bug (principalmente) basato sulla posta elettronica, noto come Debbugs. Per aprire una nuova segnalazione di bug, è necessario inviare un'email (con una sintassi specifica) a submit@bugs.debian.org. Questo assegnerà un numero di bug *XXXXXX* e vi informerà che potete inviare ulteriori informazioni scrivendo a XXXXXX@bugs.debian.org. Ogni bug è associato a un pacchetto Debian. È possibile visualizzare tutti i bug di un determinato pacchetto (incluso il bug che si intende segnalare) all'indirizzo https://bugs.debian.org/package. È possibile consultare la cronologia di un determinato bug all'indirizzo https://bugs.debian.org/XXXXXX.

**Configurazione di Reportbug:** Sebbene sia possibile segnalare un bug con una semplice e-mail, consigliamo di utilizzare Reportbug perché vi aiuterà a redigere una segnalazione completa con tutte le informazioni necessarie. Idealmente, dovresti eseguirlo da un sistema Debian (ad esempio, nella macchina virtuale in cui hai riprodotto il problema).

La prima esecuzione di reportbug avvia uno script di configurazione. Innanzitutto, seleziona un livello di competenza. Dovresti scegliere Novizio o Standard; noi usiamo quest'ultimo perché offre un controllo più preciso. Successivamente, seleziona un'interfaccia e inserisci i tuoi dati personali. Infine, seleziona un'interfaccia utente. Lo script di configurazione ti permetterà di utilizzare un agente di trasporto di posta locale, un server SMTP o, come ultima risorsa, un server SMTP Debian.

```
Benvenuto in reportbug! Dato che sembra sia la prima volta che utilizzi reportbug, ne configureremo il comportamento.
Queste impostazioni verranno salvate nel file "/home/kali/.reportbugrc", che potrai modificare a tuo piacimento.


Seleziona la modalità operativa predefinita per reportbug.

1 principiante      Offrire semplici istruzioni, evitando domande tecniche.

2 standard Offrire suggerimenti più estesi, tra cui chiedere informazioni su cose
                    che ci si aspetterebbe che un utente moderatamente esperto conosca Debian.


3 avanzato Come standard, ma presuppone che tu sappia qualcosa in più su Debian,
      ÿ inclusi “in entrata”.

4 esperti           Consente di bypassare la maggior parte delle procedure guidate e delle routine
                    di triage preliminari. Questa modalità non deve essere utilizzata da persone che non
                    hanno familiarità con le politiche e le procedure operative di Debian.
```

Machine Translated by Google

```
Seleziona la modalità: [principiante] standard
Scegli l'interfaccia predefinita per segnalare un bug.

1 testo Un'interfaccia utente di console orientata al testo

2 gtk2 Un'interfaccia utente grafica (GTK+).

3 urwid Un'interfaccia utente a console basata su menu

Seleziona interfaccia: testo
Reportbug avrà spesso accesso diretto a Internet? (Dovresti rispondere di sì a questa domanda, a meno che tu
non sappia cosa stai facendo e abbia intenzione di verificare se sono state inviate segnalazioni duplicate tramite
un altro canale.)
[Y|n|q|?]? Y Quale
nome reale devo usare per inviare segnalazioni di bug? [kali]> Raphaël Hertzog Quale
dei tuoi indirizzi email devo usare per
inviare segnalazioni di bug?
(Nota che questo indirizzo sarà visibile nel sistema di tracciamento dei bug, quindi potresti voler utilizzare un indirizzo
webmail o un altro indirizzo con buone funzionalità di filtraggio dello spam.) [kali@localhost.localdomain]>
buxy@kali.org Hai un "agente di
trasporto della posta" (MTA) come Exim, Postfix o SSMTP configurato
su questo computer per inviare posta a Internet? [y|N|q|?]? N Inserisci il nome del tuo host SMTP. Di solito si chiama
qualcosa come "mail.example.org" o "smtp.example.org". Se devi usare una porta diversa da quella predefinita, usa
il formato alternativo <host>:<porta>. Premi semplicemente INVIO se non ne hai uno o non lo sai, quindi verrà
utilizzato un host SMTP Debian.



>
Inserisci il nome del tuo server proxy. Questo parametro deve essere utilizzato solo se ti trovi dietro un firewall.
L'argomento PROXY deve essere formattato come un URL HTTP valido, includendo (se necessario) un numero
di porta; ad esempio, http://192.168.1.1:3128/. Premi semplicemente INVIO se non ne hai uno o non lo conosci.


>
File delle preferenze predefinite scritto. Per riconfigurarlo, esegui nuovamente reportbug con l'opzione "--configure".
```

**Utilizzo di Reportbug** Una volta completata la fase di configurazione, è possibile iniziare la segnalazione del bug vera e propria. Verrà richiesto il nome del pacchetto, ma è anche possibile specificarlo direttamente dalla riga di comando con il comando `reportbug package`.

```
Inserisci il nome del pacchetto in cui hai riscontrato un problema, oppure digita "altro" per segnalare un problema più
generico. Se non sai in quale pacchetto si trova il bug, contatta debian-user@lists.debian.org per ricevere assistenza.
```

Machine Translated by Google

```
> wireshark
```

Contrariamente al consiglio dato in precedenza, se non sai a quale pacchetto segnalare il bug, dovresti contattare un forum di supporto di Kali (descritto nella sezione 6.2, "Kali Linux Communities" [pagina 132]). Nel passaggio successivo, reportbug scarica l'elenco dei bug segnalati per il pacchetto specificato e ti permette di consultarli per vedere se riesci a trovare il tuo.

```
*** Benvenuto su reportbug. Usa il punto interrogativo (?) per ricevere aiuto quando richiesto. ***
Nota: le segnalazioni di bug vengono archiviate pubblicamente (compreso l'indirizzo email di chi le ha inviate).
Set di caratteri rilevato: UTF-8. Se non è
corretto, modifica le impostazioni locali.

Utilizza "Raphaël Hertzog" <buxy@kali.org> come indirizzo del mittente.
Ottenere lo stato di Wireshark...
Verifica dell'integrità della confezione...
Controllo la disponibilità di versioni più recenti su Madison...
Verrà inviato un report a Debian (secondo lsb_release).
Ricerca di segnalazioni di bug su Wireshark (fonte) in corso su Debian BTS...
Trovate 35 segnalazioni di bug:

Bug con gravità importante
    1) #478200 tshark: sembra ignorare i filtri di lettura durante la scrittura su... 2) #776206
    mergecap: Impossibile creare il file di output > 2GB 3) #780089 wireshark: "Su
    gnome wireshark non ha la barra del titolo. Fa...
Bug con gravità normale
    4) #151017 ethereal: le "Statistiche della gerarchia del protocollo" forniscono informazioni fuorvianti...
    5) #275839 non analizza correttamente la pipeline ESMTP [...] 35) #815122

 wireshark: aggiungi OID 1.3.6.1.4.1.11129.2.4.2
 (24-35/35) Il bug che hai trovato è elencato sopra [y|N|b|m|r|q|s|f|e|?]? ? y - Problema già segnalato;
aggiungi facoltativamente ulteriori informazioni.
N - (predefinito) Problema non elencato sopra; eventualmente controlla altro. b - Apri
l'elenco completo dei bug in un browser web. m - Ottieni maggiori
informazioni su un bug (puoi anche inserire un numero senza prima selezionare "m"). r -
      Visualizza nuovamente gli ultimi bug
 mostrati. q - Mi annoio; esci. s - Salta i problemi
rimanenti; invia subito una nuova
segnalazione. f - Filtra l'elenco dei bug utilizzando un modello. e - Apri la
segnalazione utilizzando un client di posta
elettronica.
? - Visualizza questa guida.
 (24-35/35) Il bug che hai trovato è elencato sopra [y|N|b|m|r|q|s|f|e|?]? n Il manutentore di wireshark
è 'Balint Reczey <balint@balintreczey.hu>'.
Ricerca delle dipendenze di Wireshark...
```

Se il tuo bug risulta già segnalato, puoi scegliere di inviare informazioni aggiuntive; in caso contrario, sei invitato a inviare una nuova segnalazione.

Machine Translated by Google

Descrivi brevemente il problema (massimo 100 caratteri). Questa sarà la descrizione dell'oggetto dell'email di segnalazione bug , quindi
mantieni il riepilogo il più conciso possibile, ad esempio: "impossibile inviare l'email di segnalazione bug ".

o "non inizia con l'opzione -q specificata" (inserisci Ctrl+c per uscire da reportbug senza
ÿ segnalazione di un bug). >
**non analizza il protocollo foobar** Riscrittura soggetto
a 'wireshark: non analizza il protocollo foobar'

Dopo aver fornito un breve riassunto del problema, è necessario valutarne la gravità lungo una scala più ampia:

Come valuteresti la gravità di questo problema o di questa segnalazione?

1 critico fa sì che software non correlati sul sistema (o l'intero sistema) si guastino,
ÿ o causa gravi perdite di dati o introduce una falla di sicurezza nei sistemi in cui ÿ installi

il pacchetto. rende
la perdita il pacchetto in questione inutilizzabile dalla maggior parte o da tutti gli utenti, oppure 2 gravi ÿ causano
di dati o introducono una falla di sicurezza che consente l'accesso agli account ÿ degli utenti che

utilizzare il pacchetto. è
3 gravi ÿ una grave violazione della politica Debian (vale a dire, il problema è un
violazioni di una direttiva 'must' o 'required'); possono o meno influire sull'usabilità del pacchetto. Si noti che le violazioni non
gravi delle policy possono
essere bug 'normali', ' ÿ minori' o 'wishlist'. (I manutentori dei pacchetti possono anche designare altri bug
come 'gravi' e quindi critici per il rilascio; tuttavia, gli utenti finali non dovrebbero farlo ) . Per l'elenco
canonico dei problemi che meritano una
gravità grave , è possibile fare riferimento a questa pagina web: http://release.debian.org/testing/rc_policy.txt. un
bug che ha un effetto importante sull'usabilità di un pacchetto, senza renderlo completamente
inutilizzabile per tutti.

4 importanti

5 does-not-build è un bug che impedisce la compilazione del pacchetto dal codice sorgente. (Si tratta di un ÿ 'gravità virtuale'.) 6 normale

Un bug che non compromette l'usabilità dell'intero pacchetto; ad esempio , un problema con una particolare
opzione o voce di menu. Errori di ortografia e altri piccoli errori estetici che non influiscono sulla
7 minore funzionalità principale del pacchetto. 8 suggerimenti e richieste di nuove funzionalità.

Seleziona un livello di gravità: [normale]

In caso di dubbi, mantieni il livello di gravità predefinito su normale.

È inoltre possibile aggiungere dei tag al report con alcune parole chiave:

Machine Translated by Google

Qualcuna delle seguenti condizioni si applica a questo rapporto?

1 a11y 2 Questo bug riguarda l'accessibilità del pacchetto.
di Questo bug è rilevante per lo sviluppo di debian-installer.
3 ftbfs Il pacchetto non riesce a essere compilato dal codice sorgente.
4 ipv6 Questo bug riguarda il supporto per il protocollo Internet versione 6.
5 l10n Questo bug segnala un problema di localizzazione/internazionalizzazione.
6 lfs Questo bug influisce sul supporto per file di grandi dimensioni (oltre 2 gigabyte).
7 nuovo arrivato Questo bug ha una soluzione nota ma il manutentore richiede qualcun altro
ÿ Implementalo.
8 patch Stai includendo una patch per risolvere questo problema.
9 a monte Questo bug riguarda la parte a monte del pacchetto.
10 nessuno

Seleziona i tag: (uno alla volta) [nessuno]

La maggior parte dei tag sono piuttosto specifici, ma se la tua segnalazione include una correzione, dovresti selezionare il tag "patch" .

Una volta completato questo passaggio, reportbug apre un editor di testo con un modello che dovresti modificare (Esempio 6.2, "Modello generato da reportbug" [pagina 146]). Contiene alcune domande a cui dovresti rispondere.
dovrebbe eliminare e rispondere, così come alcune informazioni sul tuo sistema che sono state raccolte automaticamente. Nota come sono strutturate le prime righe. Non dovrebbero essere modificate in quanto
verrà analizzato dal sistema di tracciamento dei bug per assegnare la segnalazione al pacchetto corretto.

**Esempio 6.2** Modello generato da reportbug

Oggetto: Wireshark: non analizza il protocollo foobar

Pacchetto: wireshark
Versione: 3.2.5-1
Gravità: normale

Gentile addetto alla manutenzione,

*** Giornalista, la preghiamo di valutare la possibilità di rispondere a queste domande, ove opportuno. ***

* Quali sono state le cause di questa situazione?
* Cosa hai fatto (o non fatto) esattamente che è stato efficace (o inefficace)?
* Qual è stato l'esito di questa azione?
Quale risultato ti aspettavi invece?

*** Fine del modello - rimuovere queste righe del modello ***

Machine Translated by Google

```
-- Informazioni di sistema:
ID distributore: Kali
Descrizione:    Kali GNU/Linux Rolling 2020.3
Pubblicazione:
Nome in codice:    kali-rolling
Architettura: x86_64

Kernel: Linux 5.7.0-kali1-amd64 (SMP con 4 thread CPU)
Flag di contaminazione del kernel: TAINT_UNSIGNED_MODULE
Locale: LANG=en_US.utf8, LC_CTYPE=en_US.utf8 (charmap=UTF-8), LANGUAGE non impostato Shell: /bin/sh
collegato a /usr/bin/dash Init: systemd (tramite /run/
systemd/system)
LSM: AppArmor: abilitato

Versioni dei pacchetti da cui dipende Wireshark: ii wireshark-
qt 3.2.5-1

Wireshark non consiglia alcun pacchetto.

Wireshark non suggerisce alcun pacchetto.

-- nessuna informazione di debconf
```

Una volta salvato il report e chiuso l'editor di testo, si torna a Reportbug, che offre numerose altre opzioni e la possibilità di inviare il report risultante.

```
Generazione di un editor sensato...
La segnalazione verrà inviata al "Debian Bug Tracking System" <submit@bugs.debian.org> Invia
questa segnalazione su Wireshark (e per modificare) [Y|n|a|c|e|i|l|m|p|q|d|t|s|?]? ?
Y - (predefinito) Invia la segnalazione di bug via e-mail. n - Non inviare la
segnalazione di bug; salvala invece in un file temporaneo (esce da reportbug). a - Allega un file. c - Cambia editor e modifica di nuovo. e - Modifica di nuovo la
segnalazione di bug. i - Includi un file di testo. l
- Invia il messaggio tramite il pager. m -
Scegli un programma di posta
elettronica per modificare la segnalazione. p - Stampa il
messaggio su stdout. q - Salvalo in un file temporaneo ed esci.
d - Scollega un file allegato. t - Aggiungi tag.
s - Aggiungi un destinatario X-Debbugs-CC (un CC ma dopo
l'elaborazione BTS).


? - Visualizza questa guida.
Invia questo report su Wireshark (e per modificare) [Y|n|a|c|e|i|l|m|p|q|d|t|s|?]? Y Salvataggio di un
backup del report in /tmp/reportbug-wireshark-backup-20210328-19073-87oJWJ Connessione a reportbug.debian.org
tramite SMTP...

Segnalazione di bug inviata a: "Debian Bug Tracking System" <submit@bugs.debian.org>. Le copie
verranno inviate dopo l'elaborazione a:
    buxy@kali.org
```

Machine Translated by Google

Se desideri fornire ulteriori informazioni, attendi di ricevere il numero di tracciamento del bug via e-mail; potrai quindi inviare qualsiasi informazione aggiuntiva a n@bugs.debian.org (ad esempio 999999@bugs.debian.org), dove n è il numero del bug. Normalmente riceverai una conferma via e-mail con il numero di segnalazione del bug entro un'ora; se non hai ricevuto alcuna conferma, significa che la procedura di segnalazione del bug non è andata a buon fine (errore di reportbug o MTA, manutenzione del BTS, ecc.).

### Segnalazione di bug in un altro progetto di software libero

Esiste una grande varietà di progetti software libero, che utilizzano flussi di lavoro e strumenti differenti. Questa diversità si riflette anche nei sistemi di tracciamento dei bug. Mentre molti progetti sono ospitati su GitHub e utilizzano le "Issues" di GitHub per tenere traccia dei bug, molti altri ospitano i propri sistemi di tracciamento, basati su Bugzilla, Trac, Redmine, Flyspray e altri ancora. La maggior parte di questi sistemi è basata sul web e richiede la registrazione di un account per inviare una nuova segnalazione.

Non tratteremo tutti i tracker qui. Sta a voi imparare le specificità dei vari tracker per altri progetti software liberi, ma da quando GitHub[7] è relativamente popolare, quindi lo esamineremo brevemente. Come con altri tracker, è necessario prima creare un account ed effettuare l'accesso. Successivamente, fare clic sulla scheda Issues, come mostrato nella Figura 6.5, "Pagina principale di un progetto GitHub" [pagina 149].

[7] https://github.com/

Machine Translated by Google

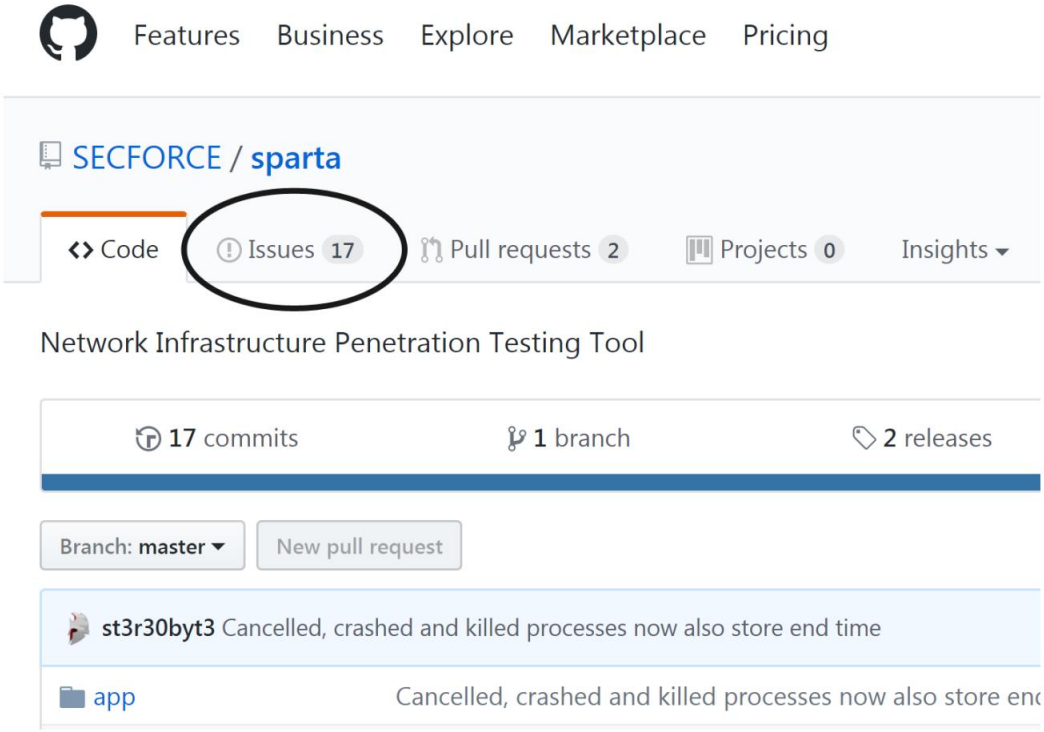



**Figura 6.5** Pagina principale di un progetto GitHub

A questo punto puoi sfogliare (e cercare) l'elenco dei problemi aperti. Una volta accertato che il tuo bug non sia ancora stato segnalato, puoi fare clic sul pulsante "Nuovo problema" (Figura 6.6, "Pagina dei problemi di un progetto GitHub" [pagina 150]).

Machine Translated by Google

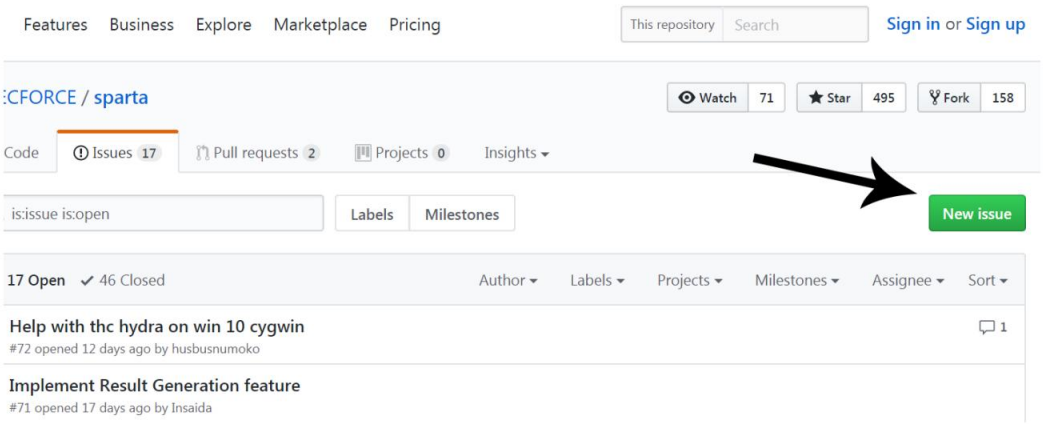



**Figura 6.6** Pagina dei problemi di un progetto GitHub

Ora ti trovi su una pagina in cui devi descrivere il tuo problema (Figura 6.7, "Modulo GitHub per segnalare un nuovo problema" [pagina 150]). GitHub offre una funzionalità di modelli che consente al proprietario del repository di definire un modello personalizzato per la segnalazione dei problemi; tuttavia, sembra che questo repository non ne abbia uno configurato. Il meccanismo di segnalazione dei bug è comunque piuttosto semplice e permette di allegare file, applicare la formattazione al testo e molto altro. Naturalmente, per ottenere risultati ottimali, assicurati di seguire le nostre linee guida per la creazione di una segnalazione dettagliata e ben descritta.

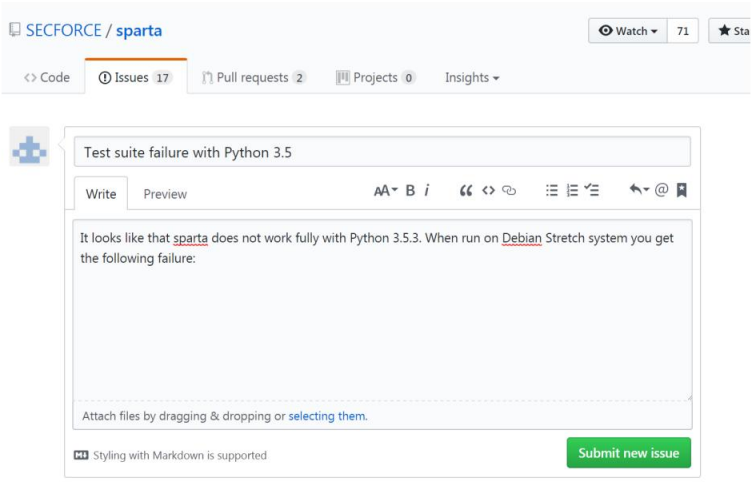



**Figura 6.7** Modulo GitHub per segnalare un nuovo problema

Machine Translated by Google

### 6.4. Riepilogo

In questa sezione, abbiamo discusso vari metodi per aiutarvi a trovare documentazione e informazioni sui programmi e come ottenere assistenza per i problemi che potreste incontrare. Abbiamo esaminato le pagine di manuale e di informazione e i comandi apropos e info . Abbiamo parlato dei sistemi di tracciamento dei bug, fornito alcuni suggerimenti su come cercare e inviare segnalazioni di bug efficaci e offerto alcuni consigli per aiutarvi a capire chi è il responsabile del programma o del progetto in questione.

Suggerimenti riassuntivi:

- Prima di poter comprendere cosa accade realmente quando si verifica un problema, è necessario conoscere il ruolo teorico svolto da ciascun programma coinvolto nel problema. Uno dei modi migliori per farlo è consultare la documentazione del programma.
- Per visualizzare una pagina del manuale, è sufficiente digitare man manual-page, sostituendo il nome del comando con il nome del comando. dopo un numero di sezione facoltativo.
- Il comando apropos restituisce un elenco di pagine di manuale il cui riepilogo menziona le parole chiave richieste, insieme al riepilogo di una riga tratto dalla pagina di manuale.
- Il progetto GNU ha redatto manuali per la maggior parte dei suoi programmi nel formato *info* . Per questo motivo, molte pagine di manuale rimandano alla documentazione *info* corrispondente.
- Ogni pacchetto include la propria documentazione e persino i programmi meno documentati generalmente dispongono di un file README contenente informazioni interessanti e/o importanti. Questa documentazione è installata nella directory /usr/share/doc/package/ .
- Nella maggior parte dei casi, le FAQ o gli archivi della mailing list del sito web ufficiale di un programma potrebbero risolvere i problemi che hai riscontrato.
- Il progetto Kali mette a disposizione una raccolta di documentazione utile all'indirizzo https://www.kali.org/docs/.
- Il progetto Kali Linux utilizza il canale #kali-linux su Freenode8 Rete IRC. È possibile utilizzare chat.freenode.net come server IRC, sulla porta 6667 per una connessione crittografata TLS o sulla porta 6666 per una connessione in chiaro. Per partecipare alle discussioni su IRC, è necessario utilizzare un client IRC come hexchat (in modalità grafica) o irssi (in modalità console). È disponibile anche un client web all'indirizzo webchat.freenode.net9 .
- I forum ufficiali della comunità per il progetto Kali Linux si trovano all'indirizzo forums.kali.org10 • Se scopri un bug in un programma, puoi cercare segnalazioni di bug o inviarne una tua. Assicurati di seguire le linee guida che abbiamo delineato per garantire che la tua segnalazione sia chiara, completa e aumenti le probabilità che il bug venga risolto dagli sviluppatori in tempi brevi.

[8] https://freenode.net/
[9] https://webchat.freenode.net/
10https://forums.kali.org/

Machine Translated by Google

- Alcune segnalazioni di bug dovrebbero essere inviate a Kali, mentre altre possono essere inviate al lato Debian. Un comando come **`dpkg -s package-name | grep ^Version:** ` mostrerà il numero di versione e verrà contrassegnato come "kali" se si tratta di un pacchetto modificato da Kali. • Identificare un progetto

upstream e trovare dove inviare la segnalazione di bug è solitamente facile. È sufficiente consultare il sito web upstream indicato nel campo "Homepage" dei metadati del pacchetto.

- Kali utilizza un sistema di segnalazione bug basato sul web, disponibile all'indirizzo https://bugs.kali.org/ dove puoi consultare tutte le segnalazioni di bug in forma anonima, ma se desideri commentare o inviare una nuova segnalazione di bug, dovrai registrare un account.
- Debian utilizza un sistema di tracciamento dei bug (principalmente) basato sulla posta elettronica, noto come Debbugs. Per segnalare un nuovo bug, è possibile inviare un'email (con una sintassi specifica) all'indirizzo submit@bugs.debian.org oppure utilizzare il comando reportbug , che guiderà l'utente attraverso la procedura.
- Sebbene molti progetti siano ospitati su GitHub e utilizzino le "Issues" di GitHub per tenere traccia dei bug, molti altri gestiscono i propri sistemi di tracciamento. Potrebbe essere necessario informarsi sulle basi dei sistemi di tracciamento dei bug di terze parti se si ha bisogno di segnalare un problema.

Ora che disponi degli strumenti di base per navigare in Linux, installare e configurare Kali, risolvere i problemi del sistema e ottenere assistenza, è il momento di esaminare come proteggere Kali in modo da salvaguardare la tua installazione e i dati dei tuoi clienti.

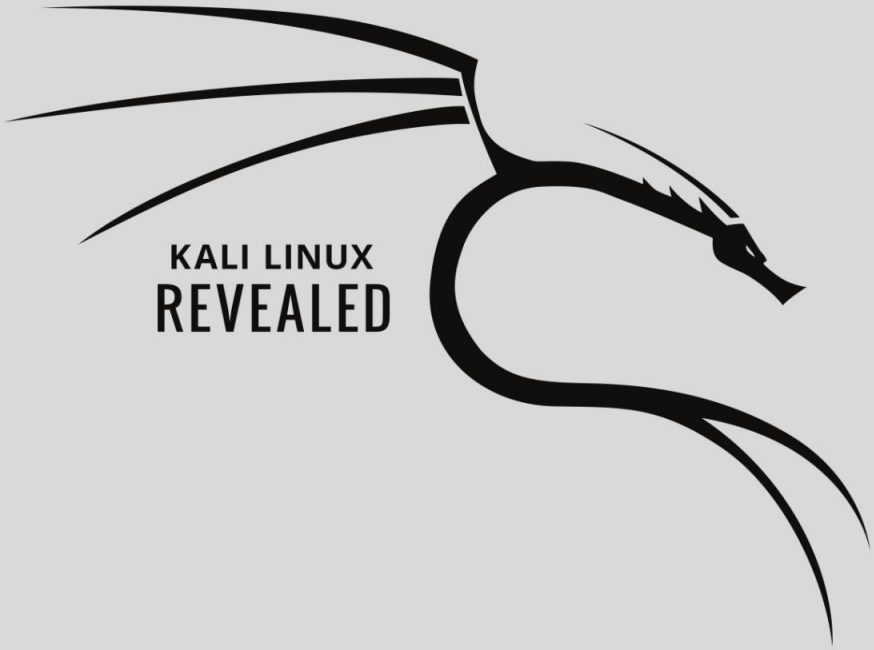
Machine Translated by Google



Machine Translated by Google

**Parole chiave**

**Politica di sicurezza**
**Firewall**
**iptables**
**Monitoraggio**
**Registrazione**



Machine Translated by Google

Capitolo

# 7 Protezione e Monitoraggio di Kali Linux

Contenuto

Definizione di una politica di sicurezza 156 Possibili misure di sicurezza 158 Protezione dei servizi di rete 159
Firewall o filtro pacchetti 159 Monitoraggio e registrazione 167 Sommario 171

Machine Translated by Google

Man mano che inizi a utilizzare Kali Linux per attività sempre più delicate e di maggiore responsabilità, probabilmente dovrai prendere più seriamente la sicurezza della tua installazione. In questo capitolo, analizzeremo innanzitutto le politiche di sicurezza, evidenziando i vari punti da considerare nella definizione di una politica di questo tipo e delineando alcune delle minacce per il tuo sistema e per te in quanto professionista della sicurezza. Discuteremo anche le misure di sicurezza per sistemi desktop e portatili, concentrandoci su firewall e filtraggio dei pacchetti. Infine, parleremo degli strumenti e delle strategie di monitoraggio e ti mostreremo come implementarli al meglio per rilevare potenziali minacce al tuo sistema.

### 7.1. Definizione di una politica di sicurezza

È impraticabile parlare di sicurezza in termini generali, poiché il concetto comprende una vasta gamma di idee, strumenti e procedure, nessuno dei quali è universalmente applicabile. La scelta tra questi richiede una chiara definizione degli obiettivi. Proteggere un sistema inizia con la risposta ad alcune domande. Affrettarsi a implementare un insieme arbitrario di strumenti rischia di focalizzarsi sugli aspetti sbagliati della sicurezza.

Di solito è meglio definire un obiettivo specifico. Un buon approccio per facilitare tale definizione inizia con le seguenti domande:

- *Cosa* stai cercando di proteggere? La politica di sicurezza sarà diversa a seconda che tu voglia proteggere computer o dati. In quest'ultimo caso, devi anche sapere quali dati. • Da cosa stai cercando di proteggerti ?

  Si tratta di una fuga di dati riservati? Di una perdita accidentale di dati? Di una perdita di fatturato causata da un'interruzione del servizio?

- Inoltre, *da chi* stai cercando di proteggerti? Le misure di sicurezza saranno molto diverse a seconda che si tratti di proteggersi da un errore di battitura da parte di un normale utente del sistema o di proteggersi da un gruppo di aggressori esterni determinati.

Il termine "rischio" viene solitamente utilizzato per riferirsi collettivamente a questi tre fattori: cosa proteggere, cosa prevenire e chi potrebbe causarlo. La modellazione del rischio richiede risposte a queste tre domande. A partire da questo modello di rischio, è possibile elaborare una politica di sicurezza e implementarla con azioni concrete.

**Domande continue** Bruce Schneier, esperto mondiale in materia di sicurezza (non solo informatica), cerca di sfatare uno dei miti più importanti della sicurezza con un motto: "La sicurezza è un processo, non un prodotto". Le risorse da proteggere cambiano nel tempo, così come le minacce e i mezzi a disposizione dei potenziali aggressori. Anche se una politica di sicurezza è stata inizialmente progettata e implementata alla perfezione, non bisogna mai adagiarsi sugli allori. Le componenti di rischio si evolvono e la risposta a tali rischi deve evolversi di conseguenza.

Anche i vincoli aggiuntivi meritano di essere presi in considerazione, in quanto possono limitare la gamma di politiche disponibili. Fino a che punto sei disposto ad arrivare per proteggere un sistema? Questa domanda ha un impatto importante sulla politica da implementare. Troppo spesso, la risposta è definita solo in termini di costi monetari,

Machine Translated by Google

Tuttavia, occorre considerare anche altri elementi, come ad esempio il disagio arrecato agli utenti del sistema o il degrado delle prestazioni.

Una volta modellato il rischio, si può iniziare a pensare alla progettazione di una vera e propria politica di sicurezza.

Quando si decide il livello di protezione da adottare, possono entrare in gioco degli estremi. Da un lato, può essere estremamente semplice garantire una sicurezza di base del sistema.

Ad esempio, se il sistema da proteggere consiste unicamente in un computer di seconda mano, il cui unico utilizzo è quello di sommare qualche numero a fine giornata, decidere di non adottare misure di protezione particolari sarebbe del tutto ragionevole. Il valore intrinseco del sistema è basso e il valore dei dati è nullo, poiché non sono memorizzati sul computer. Un potenziale aggressore che riuscisse a infiltrarsi in questo sistema otterrebbe solo una calcolatrice. Il costo della messa in sicurezza di un sistema del genere sarebbe probabilmente superiore al costo di una violazione.

All'estremo opposto, si potrebbe voler proteggere la riservatezza dei dati segreti nel modo più completo possibile, anteponendo tale priorità a qualsiasi altra considerazione. In questo caso, una risposta appropriata sarebbe la distruzione totale dei dati (cancellazione sicura dei file, distruzione dei dischi rigidi in frammenti, successiva dissoluzione di questi frammenti in acido e così via). Se sussiste l'ulteriore esigenza di conservare i dati per un utilizzo futuro (anche se non necessariamente immediatamente disponibili), e se il costo non rappresenta ancora un problema, un punto di partenza potrebbe essere l'archiviazione dei dati su lastre in lega di iridio-platino custodite in bunker antiatomici sotto varie montagne del mondo, ognuno dei quali (ovviamente) completamente segreto e sorvegliato da interi eserciti.

Per quanto estremi possano sembrare questi esempi, essi rappresenterebbero comunque una risposta adeguata a determinati rischi definiti, nella misura in cui sono il risultato di un processo di riflessione che tenga conto degli obiettivi da raggiungere e dei vincoli da rispettare. Quando scaturisce da una decisione ponderata, nessuna politica di sicurezza è più o meno rispettabile di un'altra.

Tornando a un caso più tipico, un sistema informativo può essere segmentato in sottosistemi coerenti e perlopiù indipendenti. Ogni sottosistema avrà i propri requisiti e vincoli, pertanto la valutazione del rischio e la definizione della politica di sicurezza dovrebbero essere effettuate separatamente per ciascuno di essi. Un buon principio da tenere a mente è che una piccola superficie di attacco è più facile da difendere di una grande. Anche l'organizzazione della rete dovrebbe essere progettata di conseguenza: i servizi sensibili dovrebbero essere concentrati su un numero limitato di macchine, e queste macchine dovrebbero essere accessibili solo tramite un numero minimo di percorsi o punti di controllo. La logica è semplice: è più facile proteggere questi punti di controllo che proteggere tutte le macchine sensibili dall'intero mondo esterno. È a questo punto che l'utilità del filtraggio di rete (inclusi i firewall) diventa evidente. Questo filtraggio può essere implementato con hardware dedicato, ma una soluzione più semplice e flessibile è quella di utilizzare un firewall software come quello integrato nel kernel Linux.

Machine Translated by Google

## 7.2. Possibili misure di sicurezza

Come spiegato nella sezione precedente, non esiste un'unica risposta alla domanda su come proteggere Kali Linux. Tutto dipende da come lo si utilizza e da cosa si cerca di proteggere.

### 7.2.1. Su un server

Se si utilizza Kali Linux su un server accessibile pubblicamente, è molto probabile che si desideri proteggere i servizi di rete modificando le password predefinite eventualmente configurate (vedere la sezione 7.3, "Protezione dei servizi di rete" [pagina 159]) e possibilmente limitandone l'accesso tramite un firewall (vedere la sezione 7.4, "Firewall o filtro pacchetti" [pagina 159]).

Se distribuisci account utente direttamente sul server o tramite uno dei servizi, è fondamentale impostare password complesse (in grado di resistere agli attacchi di forza bruta). Allo stesso tempo, potresti valutare l'installazione *di fail2ban,* che renderà molto più difficile forzare le password tramite attacchi di forza bruta sulla rete (filtrando gli indirizzi IP che superano un determinato limite di tentativi di accesso falliti). Installa *fail2ban* con il comando `apt update` seguito da `apt install fail2ban`.

Se gestisci servizi web, probabilmente vorrai ospitarli su HTTPS per impedire agli intermediari di rete di intercettare il tuo traffico (che potrebbe includere i cookie di autenticazione).

### 7.2.2. Su un laptop

Il portatile di un penetration tester non è soggetto agli stessi rischi di un server pubblico: ad esempio, è meno probabile che venga attaccato da script kiddies e, anche se dovesse succedere, probabilmente non avrà servizi di rete attivi.

Spesso, i rischi concreti si presentano quando ci si sposta da un cliente all'altro. Ad esempio, il computer portatile potrebbe essere rubato durante il viaggio o sequestrato dalla dogana. Per questo motivo, è consigliabile utilizzare la crittografia completa del disco (vedere la sezione 4.2.2, "Installazione su un file system completamente crittografato" [pagina 88]) ed eventualmente configurare anche la funzione "nuke" (vedere "Aggiunta di una password di nuke per una maggiore sicurezza" [pagina 250]): i dati raccolti durante gli incarichi sono riservati e richiedono la massima protezione.

Potrebbero essere necessarie anche regole firewall (vedere la sezione 7.4, "Firewall o filtro pacchetti" [pagina 159]), ma non per lo stesso scopo del server. Potreste voler bloccare tutto il traffico in uscita, ad eccezione di quello generato dall'accesso VPN. Questo serve come rete di sicurezza, in modo che, in caso di interruzione della VPN, ve ne accorgiate immediatamente (invece di dover ricorrere all'accesso alla rete locale). In questo modo, non divulgate gli indirizzi IP dei vostri clienti quando navigate sul web o svolgete altre attività online. Inoltre, se state svolgendo un'attività interna locale, è consigliabile mantenere il controllo di tutte le vostre attività per ridurre il rumore generato sulla rete, che potrebbe allertare il cliente e i suoi sistemi di difesa.

Machine Translated by Google

## 7.3. Protezione dei servizi di rete

In generale, è buona norma disabilitare i servizi che non si utilizzano. Kali semplifica questa operazione, poiché i servizi di rete sono disabilitati per impostazione predefinita.

Finché i servizi rimangono disattivati, non rappresentano una minaccia per la sicurezza. Tuttavia, è necessario prestare attenzione quando li si abilita perché:

- Di default non è presente alcun firewall, quindi se sono in ascolto su tutte le interfacce di rete, sono di fatto accessibili pubblicamente.
- Alcuni servizi non richiedono credenziali di autenticazione e consentono di impostarle al primo utilizzo; altri hanno credenziali predefinite (e quindi ampiamente conosciute). Assicurati di (re)impostare qualsiasi password con una che solo tu conosca.
- Molti servizi vengono eseguiti come root con pieni privilegi di amministratore, pertanto le conseguenze di un accesso non autorizzato o di una violazione della sicurezza sono solitamente gravi.

**Credenziali predefinite** Non elencheremo qui tutti gli strumenti che vengono forniti con credenziali predefinite, invece dovresti controllare il file README.Debian dei rispettivi pacchetti, così come kali.org/docs/1 e tools.kali.org2 per verificare se il servizio necessita di particolari precauzioni per essere garantito.

**Servizio SSH** Se si esegue in modalità live, la password dell'account kali è "kali". Pertanto, non è consigliabile abilitare SSH prima di aver modificato la password dell'account kali o prima di averne modificato la configurazione per disabilitare gli accessi basati su password.

Potresti anche voler generare nuove chiavi SSH host, se hai installato Kali tramite un'immagine pregenerata. Questo argomento è trattato in "Generazione di nuove chiavi SSH host"[pagina 115].

## 7.4. Firewall o filtro pacchetti

Un *firewall* è un dispositivo informatico, costituito da hardware, software o entrambi, che analizza i pacchetti di rete in entrata o in uscita (da o verso una rete locale) e permette il passaggio solo di quelli che soddisfano determinate condizioni predefinite.

Un gateway di rete con funzione di filtraggio è un tipo di firewall che protegge un'intera rete. Solitamente viene installato su una macchina dedicata configurata come gateway per la rete, in modo da poter analizzare tutti i pacchetti in entrata e in uscita dalla rete. In alternativa, un firewall locale è un servizio software che viene eseguito su una specifica macchina per filtrare o limitare l'accesso ad alcuni servizi su quella macchina, o eventualmente per impedire connessioni in uscita da software dannoso che un utente potrebbe aver installato, volontariamente o meno.

[1] https://www.kali.org/docs/introduction/default-credentials/
[2] https://tools.kali.org/

Machine Translated by Google

Il kernel Linux integra il firewall *netfilter* . Non esiste una soluzione preconfigurata per la configurazione di un firewall, poiché i requisiti di rete e degli utenti variano. Tuttavia, è possibile controllare *netfilter* dallo spazio utente tramite i comandi iptables e ip6tables . La differenza tra i due comandi è che il primo funziona su reti IPv4, mentre il secondo su reti IPv6. Poiché entrambi gli stack di protocolli di rete saranno probabilmente in uso per molti anni, sarà necessario utilizzare entrambi gli strumenti in parallelo.
È inoltre possibile utilizzare l'eccellente strumento fwbuilder , basato su interfaccia grafica , che fornisce una rappresentazione grafica delle regole di filtraggio.

Indipendentemente da come si decida di configurarlo, *netfilter* è l'implementazione del firewall di Linux, quindi analizziamo più da vicino il suo funzionamento.

### 7.4.1. Comportamento del filtro di rete

*Netfilter* utilizza quattro tabelle distinte, che memorizzano le regole che regolano tre tipi di operazioni sui pacchetti:

- il filtro riguarda le regole di filtraggio (accettazione, rifiuto o ignoramento di un pacchetto);
- nat (Network Address Translation) riguarda la traduzione degli indirizzi di origine o di destinazione e delle porte dei pacchetti; • mangle

  riguarda altre modifiche ai pacchetti IP (incluso il *campo ToS - Type of Service* - e le relative opzioni);

- Il formato raw consente altre modifiche manuali sui pacchetti prima che raggiungano la traccia di connessione. sistema di ing.

Ogni tabella contiene elenchi di regole chiamate *catene.* Il firewall utilizza catene standard per gestire i pacchetti in base a circostanze predefinite. L'amministratore può creare altre catene, che verranno utilizzate solo quando richiamate da una delle catene standard (direttamente o indirettamente).
La tabella dei filtri ha tre catene standard:

- INPUT: riguarda i pacchetti la cui destinazione è il firewall stesso;
- OUTPUT: riguarda i pacchetti emessi dal firewall; • FORWARD:

  riguarda i pacchetti che attraversano il firewall (che non è né la loro origine né la loro destinazione).

La tabella nat comprende anche tre catene standard:

- PREROUTING: modificare i pacchetti non appena arrivano;
- POSTROUTING: modificare i pacchetti quando sono pronti per essere inoltrati;
- OUTPUT: per modificare i pacchetti generati dal firewall stesso.

Queste catene sono illustrate nella Figura 7.1, "Come vengono chiamate le catene *di Netfilter* " [pagina 161].

Machine Translated by Google

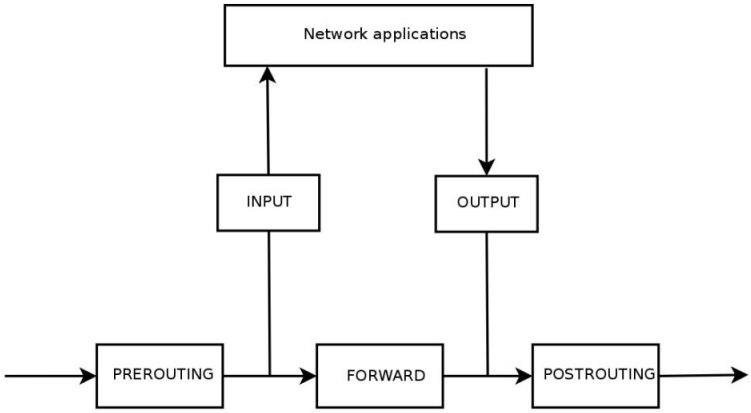



**Figura 7.1** Come vengono chiamate le catene di Netfilter

Ogni catena è un elenco di regole; ogni regola è un insieme di condizioni e un'azione da eseguire quando le condizioni vengono soddisfatte. Durante l'elaborazione di un pacchetto, il firewall analizza la catena appropriata, una regola dopo l'altra, e quando le condizioni per una regola vengono soddisfatte, salta (da qui l' opzione -j nei comandi con la sezione 7.4.2.2, "Regole" [pagina 163]) all'azione specificata per continuare l'elaborazione.
I comportamenti più comuni sono standardizzati e per essi esistono azioni dedicate. L'esecuzione di una di queste azioni standard interrompe l'elaborazione della catena, poiché il destino dei pacchetti è già segnato (salvo un'eccezione menzionata di seguito). Di seguito sono elencate le azioni *di Netfilter .*

• ACCETTA: consenti al pacchetto di proseguire. •

RIFIUTA: rifiuta il pacchetto con un pacchetto di errore ICMP (Internet Control Message Protocol) (l' opzione --reject-with type di iptables determina il tipo di errore da inviare).

• DROP: elimina (ignora) il pacchetto. •

LOG: registra (tramite syslogd) un messaggio con una descrizione del pacchetto. Si noti che questa azione non interrompe l'elaborazione e l'esecuzione della catena continua alla regola successiva, motivo per cui la registrazione dei pacchetti rifiutati richiede sia una regola LOG che una regola REJECT/DROP. I parametri comuni associati alla registrazione includono:

– --log-level, con valore predefinito warning, indica il livello di gravità di syslog . – --log-prefix consente di specificare un prefisso di testo per differenziare i messaggi registrati. – --log-tcp-sequence, --log-tcp-options e --log-ip-options indicano dati aggiuntivi da integrare nel messaggio: rispettivamente, il numero di sequenza TCP, le opzioni TCP e le opzioni IP.

• ULOG: registra un messaggio tramite ulogd, che può essere più adatto ed efficiente di syslogd per la gestione di un gran numero di messaggi; si noti che questa azione, come LOG, restituisce anche l'elaborazione alla regola successiva nella catena di chiamata.

• *chain_name:* salta alla catena specificata e valuta le sue regole.

Machine Translated by Google

- RETURN: interrompe l'elaborazione della catena corrente e ritorna alla catena chiamante; nel caso in cui la catena corrente sia una catena standard, non esiste una catena chiamante, quindi viene eseguita l'azione predefinita (definita con l'opzione -P di iptables) .

- SNAT (solo nella tabella nat ): applica *la traduzione degli indirizzi di rete di origine* (SNAT). Le opzioni aggiuntive descrivono le modifiche esatte da applicare, inclusa l' opzione --to-source address:port , che definisce il nuovo indirizzo IP e/o la porta di origine.

- DNAT (solo nella tabella nat ): applica *la traduzione degli indirizzi di rete di destinazione* (DNAT). Le opzioni aggiuntive descrivono le modifiche esatte da applicare, inclusa l' opzione --to-destination address:port , che definisce il nuovo indirizzo IP e/o la porta di destinazione.

- MASQUERADE (solo nella tabella nat ): applica *il masquerading* (un caso speciale di *Source NAT).*

- REINDIRIZZAMENTO (solo nella tabella nat ): reindirizza in modo trasparente un pacchetto a una determinata porta del firewall stesso; questo può essere utilizzato per configurare un proxy web trasparente che funziona senza alcuna configurazione lato client, poiché il client pensa di connettersi al destinatario mentre le comunicazioni in realtà passano attraverso il proxy. L' opzione --to-ports porta(e) indica la porta, o l'intervallo di porte, verso cui i pacchetti devono essere reindirizzati.

Altre azioni, in particolare quelle relative alla tabella di manipolazione , esulano dall'ambito di questo testo. Le pagine del manuale iptables(8) e ip6tables(8) contengono un elenco completo.

**Cos'è l'ICMP?** L'Internet Control Message Protocol (ICMP) è il protocollo utilizzato per trasmettere informazioni ausiliarie sulle comunicazioni. Verifica la connettività di rete con il comando ping , che invia un messaggio di richiesta di eco ICMP , al quale il destinatario deve rispondere con un messaggio di risposta di eco ICMP . Segnala a un firewall il rifiuto di un pacchetto, indica un overflow in un buffer di ricezione, propone un percorso migliore per i pacchetti successivi nella connessione e così via. Questo protocollo è definito da diversi documenti RFC. RFC777 e RFC792 sono stati i primi, ma molti altri hanno esteso e/o rivisto il protocollo.

ÿ http://www.faqs.org/rfcs/rfc777.html

ÿ http://www.faqs.org/rfcs/rfc792.html

A titolo informativo, un buffer di ricezione è una piccola area di memoria che memorizza i dati tra il momento in cui arrivano dalla rete e il momento in cui vengono elaborati dal kernel. Se quest'area è piena, non è possibile ricevere nuovi dati e il protocollo ICMP segnala il problema, in modo che il mittente possa rallentare la velocità di trasferimento (che idealmente dovrebbe stabilizzarsi dopo un certo periodo di tempo).

Si noti che, sebbene una rete IPv4 possa funzionare senza ICMP, ICMPv6 è strettamente necessario per una rete IPv6, poiché combina diverse funzioni che, nel mondo IPv4, erano distribuite tra ICMPv4, Internet Group Membership Protocol (IGMP) e Ad-dress Resolution Protocol (ARP). ICMPv6 è definito nella RFC4443.

ÿ http://www.faqs.org/rfcs/rfc4443.html

Machine Translated by Google

## 7.4.2. Sintassi di iptables e ip6tables

I comandi iptables e ip6tables vengono utilizzati per manipolare tabelle, catene e regole. L' opzione -t table indica su quale tabella operare (per impostazione predefinita, filter).

### Comandi

Di seguito sono elencate le principali opzioni per interagire con le catene:

- -L chain elenca le regole nella catena. Questa opzione viene comunemente utilizzata con l' opzione -n per disabilitare la risoluzione dei nomi (ad esempio, iptables -n -L INPUT visualizzerà le regole relative ai pacchetti in entrata).
- -N chain crea una nuova catena. È possibile creare nuove catene per diversi scopi, tra cui testare un nuovo servizio di rete o difendersi da un attacco di rete.
- -X chain elimina una catena vuota e inutilizzata (ad esempio, iptables -X ddos-attack).
- Una regola a catena aggiunge una regola alla fine della catena data. Ricorda che le regole vengono elaborate dall'alto verso il basso, quindi tieni presente questo aspetto quando aggiungi le regole.
- -Ichain rule_num rule inserisce una regola prima della regola *numberrule_num.* Come per l' opzione -A , tieni presente l'ordine di elaborazione quando inserisci nuove regole in una catena.
- -D chain rule_num (o -D chain rule) elimina una regola in una catena; la prima sintassi identifica la regola da eliminare tramite il suo numero (iptables -L --line-numbers visualizzerà questi numeri), mentre la seconda la identifica tramite il suo contenuto.
- L'opzione -F '' chain'' svuota una catena (cancella tutte le sue regole). Ad esempio, per eliminare tutte le regole relative ai pacchetti in uscita, si esegue il comando iptables -F OUTPUT. Se non viene specificata alcuna catena, vengono eliminate tutte le regole presenti nella tabella.
- L'opzione -P chain action definisce l'azione predefinita, o ''policy'', per una determinata catena; si noti che solo le catene standard possono avere tale policy. Per bloccare tutto il traffico in entrata per impostazione predefinita, è necessario eseguire il comando iptables -P INPUT DROP.

### Regole

Ogni regola è espressa come condizioni -j azione opzioni_azione. Se più condizioni sono descritte nella stessa regola, il criterio è la congiunzione ( AND *logico)* delle condizioni, che è almeno altrettanto restrittiva di ciascuna singola condizione.

La condizione -p relativa al protocollo corrisponde al campo protocollo del pacchetto IP. I valori più comuni sono tcp, udp, icmp e icmpv6. Questa condizione può essere integrata con condizioni sulle porte TCP, tramite clausole come --source-port porta e --destination -port porta.

Machine Translated by Google

**Negazione delle condizioni** Anteponendo un punto esclamativo a una condizione, quest'ultima viene negata. Ad esempio, negando una condizione sull'opzione -p corrisponde a "qualsiasi pacchetto con un protocollo diverso rispetto a quella specificata." Questo meccanismo di negazione può essere applicato anche a tutte le altre condizioni.

L' opzione -s indirizzo o -s rete/maschera corrisponde all'indirizzo sorgente del pacchetto. Analogamente, l'opzione -d indirizzo o -d rete/maschera corrisponde all'indirizzo di destinazione.

La condizione -i interfaccia seleziona i pacchetti provenienti dall'interfaccia di rete specificata. -o interfaccia Seleziona i pacchetti in uscita su una specifica interfaccia.

La condizione di stato --state corrisponde allo stato di un pacchetto in una connessione (questo richiede modulo kernel ipt_conntrack , per il tracciamento delle connessioni). Lo stato NEW descrive un pacchetto che avvia una nuova connessione, ESTABLISHED corrisponde ai pacchetti appartenenti a una connessione già esistente e RELATED corrisponde ai pacchetti che avviano una nuova connessione correlata a una esistente (che è utile per le connessioni dati FTP nella modalità "attiva" del protocollo FTP).

Sono disponibili molte opzioni per iptables e ip6tables e padroneggiarle tutte richiede molto studio ed esperienza. Tuttavia, una delle opzioni che userai più spesso è la uno per bloccare il traffico di rete dannoso da un host o da un intervallo di host. Ad esempio, per bloccare silenziosamente Traffico in entrata dall'indirizzo IP 10.0.1.5 e dalla sottorete di classe C 31.13.74.0/24 :

```
# iptables -A INPUT -s 10.0.1.5 -j DROP
# iptables -A INPUT -s 31.13.74.0/24 -j DROP
# iptables -n -L INPUT
Catena INPUT (policy ACCEPT)
target prot opt source DROP all -- 10.0.1.5 destinazione
                                            0.0.0.0/0
GOCCIOLARE tutto -- 31.13.74.0/24 0.0.0.0/0
```

Un altro comando iptables comunemente utilizzato è quello di consentire il traffico di rete per un servizio specifico o porta. Per consentire agli utenti di connettersi tramite SSH, HTTP e IMAP, è possibile eseguire i seguenti comandi:

```
# iptables -A INPUT -m state --state NEW -p tcp --dport 22 -j ACCEPT
# iptables -A INPUT -m state --state NEW -p tcp --dport 80 -j ACCEPT
# iptables -A INPUT -m state --state NEW -p tcp --dport 143 -j ACCEPT
# iptables -n -L INPUT
Catena INPUT (policy ACCEPT)
target prot opt source DROP all -- 10.0.1.5 destinazione
all -- 31.13.74.0/24 DROP ACCEPT tcp -- 0.0.0.0/0
                                    0.0.0.0/0 ACCEPT tcp -- 0.0.0.0/0
ACCEPT tcp -- 0.0.0.0/0 0.0.0.0/0 stato NUOVO tcp dpt:22
                                    0.0.0.0/0 stato NUOVO tcp dpt:80
                                    0.0.0.0/0 stato NUOVO tcp dpt:143
```

È considerata una buona *pratica di igiene* informatica eliminare le regole vecchie e inutili. La più semplice Il modo per eliminare le regole iptables è fare riferimento alle regole tramite il numero di riga, che puoi recuperare con

Machine Translated by Google

l' opzione --line-numbers . Attenzione però: eliminando una regola, verranno rinumerate tutte le regole che appaiono più in basso nella catena.

```
# iptables -n -L INPUT --line-numbers
Catena INPUT (policy ACCEPT)
num target prot opt source 1 DROP all -- 10.0.1.5 all
-- 31.13.74.0/24 2 DROP 3 ACCEPT tcp -- 0.0.0.0/0 4
0.0.0.0/0 #                ACCEPT tcp -- 0.0.0.0/0 tcp --
iptables -D INPUT 2

5       ACCETTARE

# iptables -D INPUT 1
# iptables -n -L INPUT --line-numbers
Catena INPUT (policy ACCEPT)
num target prot opt source 1 ACCETTA tcp -- 0.0.0.0/0
2 ACCETTA tcp -- 0.0.0.0/0 3 ACCETTA tcp -- 0.0.0.0/0
```

```
destinazione
0.0.0.0/0
0.0.0.0/0
0.0.0.0/0
0.0.0.0/0
0.0.0.0/0

destinazione
0.0.0.0/0
0.0.0.0/0
0.0.0.0/0
```

```
stato NUOVO tcp dpt:22
stato NUOVO tcp dpt:80
stato NUOVO tcp dpt:143

stato NUOVO tcp dpt:22
stato NUOVO tcp dpt:80
stato NUOVO tcp dpt:143
```

Esistono condizioni più specifiche, a seconda delle condizioni generiche descritte sopra. Per
Per ulteriori informazioni, consultare le pagine del manuale per iptables(8) e ip6tables(8).

### 7.4.3. Creazione delle regole

La creazione di ogni regola richiede una chiamata a iptables o ip6tables. Digitando questi comandi
L'esecuzione manuale può essere noiosa, quindi le chiamate vengono solitamente memorizzate in uno script in modo che il sistema venga configurato automaticamente allo stesso modo ogni volta che la macchina si avvia. Questo script può essere scritto a mano ma può anche essere interessante prepararlo con uno strumento di alto livello come fwbuilder.

```
# apt install fwbuilder
```

Il principio è semplice. Nel primo passo, descrivi tutti gli elementi che saranno coinvolti nel regole effettive:

- Il firewall stesso, con le sue interfacce di rete
- Le reti, con i relativi intervalli IP
- I server
- Le porte appartenenti ai servizi ospitati sui server

Successivamente, crea le regole con semplici azioni di trascinamento sugli oggetti come mostrato nella Figura 7.2, “Finestra principale di Fwbuilder” [pagina 166]. Alcuni menu contestuali possono modificare la condizione (negandola, ad esempio). Quindi è necessario scegliere e configurare l'azione.

Per quanto riguarda IPv6, puoi creare due set di regole distinti per IPv4 e IPv6 oppure creare solo uno e lascia che fwbuilder traduca le regole in base agli indirizzi assegnati agli oggetti.

Machine Translated by Google

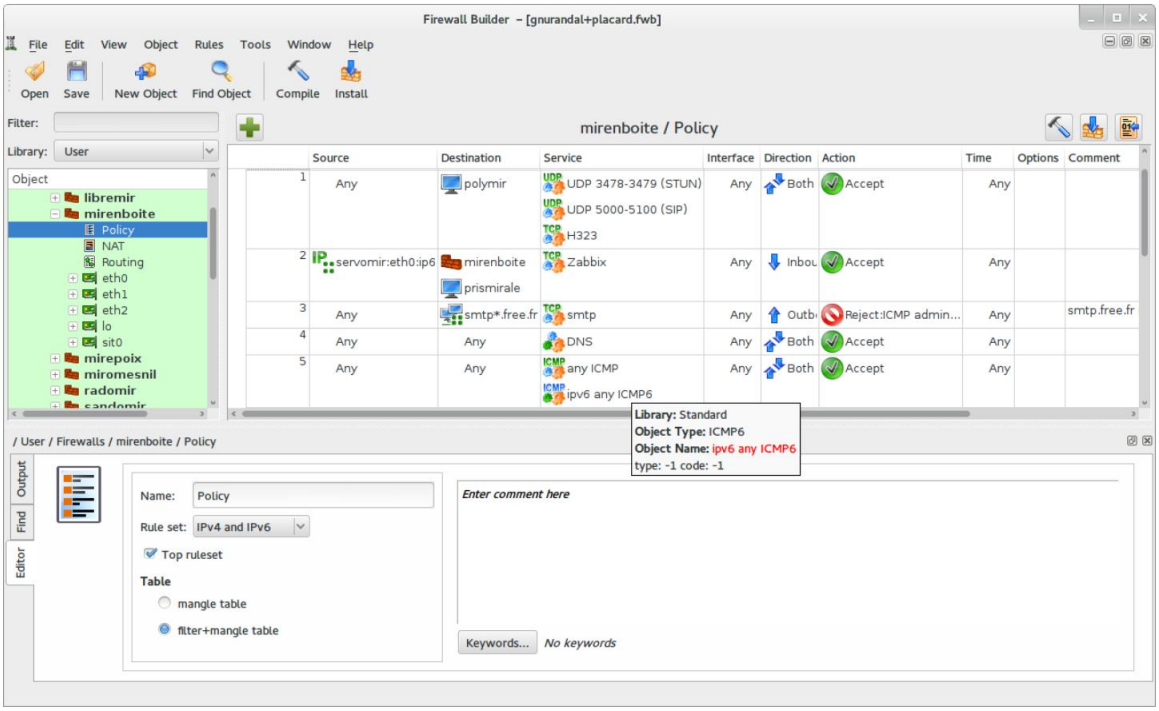



**Figura 7.2** Finestra principale di Fwbuilder

fwbuilder genererà uno script che configura il firewall in base alle regole definite dall'utente. La sua architettura modulare gli consente di generare script per diversi sistemi operativi, tra cui iptables per Linux, ipf per FreeBSD e pf per OpenBSD.

### 7.4.4. Installazione delle regole ad ogni avvio

Per applicare le regole del firewall ogni volta che la macchina viene avviata, è necessario registrare lo script di configurazione in una direttiva up del file /etc/network/interfaces . Nell'esempio seguente, lo script è memorizzato in /usr/local/etc/arrakis.fw (dove "arrakis" è il nome host della macchina).

```
auto eth0
interfaccia eth0 inet statica
        indirizzo 192.168.0.1
        rete 192.168.0.0
        Maschera di sottorete 255.255.255.0
        Trasmissione 192.168.0.255
        attiva /usr/local/etc/arrakis.fw
```

Machine Translated by Google

Questo esempio presuppone che si utilizzi *ifupdown* per configurare le interfacce di rete. Se si utilizza un altro strumento (come *NetworkManager* o *systemd-networkd),* consultare la relativa documentazione per scoprire come eseguire uno script dopo l'attivazione dell'interfaccia.

## 7.5. Monitoraggio e registrazione

La riservatezza e la protezione dei dati sono aspetti fondamentali della sicurezza, ma altrettanto importante è garantire la disponibilità dei servizi. In qualità di amministratore e professionista della sicurezza, è tua responsabilità assicurarti che tutto funzioni come previsto ed è tua iniziativa rilevare tempestivamente comportamenti anomali e cali di prestazioni. I software di monitoraggio e registrazione svolgono un ruolo chiave in questo aspetto della sicurezza, fornendo informazioni dettagliate su ciò che accade sul sistema e sulla rete.

In questa sezione esamineremo alcuni strumenti che possono essere utilizzati per monitorare diversi aspetti di un sistema Kali.

### 7.5.1. Monitoraggio dei log con logcheck

Il programma logcheck monitora i file di registro ogni ora per impostazione predefinita e invia messaggi di registro anomali tramite e-mail all'amministratore per ulteriori analisi.

L'elenco dei file monitorati è memorizzato in /etc/logcheck/logcheck.logfiles. I valori predefiniti funzionano correttamente se il file /etc/rsyslog.conf non è stato completamente modificato. logcheck può generare report

con diversi livelli di dettaglio: *paranoico, server* e *workstation. La modalità paranoica* è *molto* dettagliata e dovrebbe probabilmente essere limitata a server specifici come i firewall. La modalità *server* è quella predefinita ed è consigliata per la maggior parte dei server. *La modalità workstation* è ovviamente pensata per le workstation ed è estremamente concisa, filtrando un numero maggiore di messaggi rispetto alle altre opzioni.

In tutti e tre i casi, logcheck dovrebbe probabilmente essere personalizzato per escludere alcuni messaggi extra (a seconda dei servizi installati), a meno che non si desideri ricevere ogni ora lunghe e noiose email. Poiché il meccanismo di selezione dei messaggi è piuttosto complesso, la lettura del file /usr/share/doc/logcheck-database/ README.logcheck-database.gz è obbligatoria, sebbene impegnativa.

Le regole applicate possono essere suddivise in diverse tipologie:

- quelli che qualificano un messaggio come un tentativo di cracking (memorizzato in un file in /etc/logcheck/ cracking.d/ directory);
- tentativi di cracking ignorati (/etc/logcheck/cracking.ignore.d/); • quelli che

  classificano un messaggio come avviso di sicurezza (/etc/logcheck/violations.d/);
- ha ignorato gli avvisi di sicurezza (/etc/logcheck/violations.ignore.d/);
- infine, quelli relativi ai messaggi rimanenti (considerati come *eventi di sistema).*

Machine Translated by Google

I file *ignore.d* vengono utilizzati per (ovviamente) ignorare i messaggi. Ad esempio, un messaggio contrassegnato come tentativo di cracking o avviso di sicurezza (in base a una regola memorizzata nel file /etc/logcheck/violations.d/myfile ) può essere ignorato solo da una regola presente nel file /etc/logcheck/violations.ignore.d/myfile o /etc/logcheck/violations.ignore.d/myfile-extension .

Un evento di sistema viene sempre segnalato a meno che una regola in una delle directory /etc/logcheck/ignore.d.{paranoid,server,workstation}/ non indichi che l'evento debba essere ignorato. Naturalmente, vengono prese in considerazione solo le directory corrispondenti a livelli di verbosità pari o superiori alla modalità operativa selezionata.

**Parentesi graffe {} in un Comando**

L'uso delle parentesi graffe in un comando bash ha diverse funzioni. Nell'esempio precedente, le utilizziamo come scorciatoia per ripetere parti del comando. Bash espanderà quindi il comando prima di eseguirlo.

Nell'esempio seguente, il risultato sarà lo stesso: verranno creati tre file nella nostra directory home.

```
# touch /home/kali/file1.txt /home/kali/file2.txt /home/kali/
      ÿ file3.txt
# touch /home/kali/file{1,2,3}.txt
```

### 7.5.2. Monitoraggio dell'attività in tempo reale

top è uno strumento interattivo che visualizza un elenco dei processi attualmente in esecuzione. L'ordinamento predefinito si basa sulla quantità di utilizzo del processore e può essere ottenuto con il tasto P. Altri criteri di ordinamento includono l'ordinamento per memoria occupata (tasto M ), per tempo totale di elaborazione ( tasto T) e per identificativo del processo ( tasto N). Il tasto k termina un processo inserendo il suo identificativo. Il tasto r modifica la priorità di un processo.

Quando il sistema sembra sovraccarico, top è un ottimo strumento per individuare i processi che competono per il tempo del processore o che consumano troppa memoria. In particolare, è spesso interessante verificare se i processi che consumano risorse corrispondono ai servizi reali che la macchina è nota per ospitare. Un processo sconosciuto in esecuzione con l'utente "www-data" dovrebbe destare particolare attenzione ed essere approfondito, poiché probabilmente si tratta di un'istanza di software installata ed eseguita sul sistema tramite una vulnerabilità in un'applicazione web.

top è uno strumento molto flessibile e la sua pagina di manuale fornisce dettagli su come personalizzarne la visualizzazione e adattarla alle proprie esigenze e abitudini.

Lo strumento grafico xfce4-taskmanager è simile a top e offre all'incirca le stesse funzionalità.
Per gli utenti GNOME esiste gnome-system-monitor e per gli utenti KDE c'è ksysguard , entrambi molto simili.

Machine Translated by Google

### 7.5.3. Rilevamento dei cambiamenti

Una volta installato e configurato un sistema, la maggior parte dei file di sistema dovrebbe rimanere relativamente invariata fino a un eventuale aggiornamento. Pertanto, è consigliabile monitorare le modifiche ai file di sistema, poiché qualsiasi cambiamento inatteso potrebbe destare preoccupazione e richiedere un'indagine approfondita. Questa sezione presenta alcuni degli strumenti più comuni utilizzati per monitorare i file di sistema, rilevare le modifiche e, facoltativamente, inviare notifiche all'amministratore del sistema.

## Verifica dei pacchetti con dpkg --verify

Il comando `dpkg --verify` (o `dpkg -V`) è uno strumento interessante perché mostra i file di sistema che sono stati modificati (potenzialmente da un aggressore), ma questo output va preso con le pinze. Per svolgere il suo compito, dpkg si basa sui checksum memorizzati nel proprio database, che si trova sul disco rigido (in `/var/lib/dpkg/info/package.md5sums`). Un aggressore esperto modificherà quindi questi file in modo che contengano i nuovi checksum dei file compromessi, oppure un aggressore più avanzato comprometterà il pacchetto sul mirror Debian. Per proteggersi da questo tipo di attacco, è consigliabile utilizzare il sistema di verifica della firma digitale di APT (vedere la sezione 8.3.6, "Convalida dell'autenticità dei pacchetti" [pagina 208]) per verificare correttamente i pacchetti.

| | |
|---|---|
| **Cos'è un file? Impronta digitale?** | Ricordiamo che un'impronta digitale è un valore, spesso un numero (sebbene in notazione esadecimale), che contiene una sorta di firma per il contenuto di un file. Questa firma viene calcolata con un algoritmo (MD5, SHA1, SHA256 sono esempi ben noti) che garantisce, più o meno, che anche la minima modifica al contenuto del file si traduca in una modifica dell'impronta digitale; questo è noto come "effetto valanga". Una semplice impronta digitale numerica funge quindi da cartina di tornasole per verificare se il contenuto di un file è stato alterato. Questi algoritmi non sono reversibili; in altre parole, per la maggior parte di essi, conoscere un'impronta digitale non permette di risalire al contenuto corrispondente. I recenti progressi matematici sembrano indebolire l'assolutezza di questi principi, ma il loro utilizzo non è stato finora messo in discussione, poiché creare contenuti diversi che producano la stessa impronta digitale sembra ancora un'impresa piuttosto ardua. |

Eseguendo `dpkg -V` verranno verificati tutti i pacchetti installati e verrà stampata una riga per ogni file che non supera la verifica. Ogni carattere indica un test su specifici metadati. Sfortunatamente, dpkg non memorizza i metadati necessari per la maggior parte dei test e quindi visualizzerà dei punti interrogativi al loro posto. Attualmente solo il test del checksum può restituire un 5 sul terzo carattere (in caso di errore).

```
# dpkg -V ??
5?????? /lib/systemd/system/ssh.service ??5?????? c /etc/
libvirt/qemu/networks/default.xml ??5?????? c /etc/lvm/lvm.conf ??
5?????? c /etc/salt/roster
```

Nell'esempio precedente, dpkg segnala una modifica al file di servizio di SSH che l'amministratore ha apportato al file incluso nel pacchetto anziché utilizzare un override appropriato in /etc/systemd/system/ssh.service.

Machine Translated by Google

(che verrebbe memorizzato sotto /etc come qualsiasi modifica alla configurazione). Elenca inoltre più file di configurazione (identificati dalla lettera "c" nel secondo campo) che sono stati legittimamente modificati.

## Monitoraggio dei file: AIDE

Lo strumento Advanced Intrusion Detection Environment (AIDE) verifica l'integrità dei file e rileva eventuali modifiche rispetto a un'immagine precedentemente registrata del sistema valido. L'immagine è memorizzata come un database (/var/lib/aide/aide.db) contenente le informazioni rilevanti su tutti i file del sistema (impronte digitali, permessi, timestamp e così via).

È possibile installare AIDE eseguendo il comando `apt update` seguito da `apt install aide`. Il database verrà prima inizializzato con `aideinit`; successivamente, verrà eseguito quotidianamente (tramite lo script `/etc/cron.daily/aide` ) per verificare che non siano state apportate modifiche rilevanti. Quando vengono rilevate modifiche, AIDE le registra nei file di log (`/var/log/aide/*.log`) e invia i risultati all'amministratore tramite e-mail.

**Protezione del database:** Poiché AIDE utilizza un database locale per confrontare lo stato dei file, la validità dei suoi risultati è direttamente collegata alla validità del database. Se un utente malintenzionato ottiene i permessi di root su un sistema compromesso, sarà in grado di sostituire il database e cancellare le proprie tracce. Un modo per prevenire questa manomissione è quello di memorizzare i dati di riferimento su supporti di memorizzazione di sola lettura.

È possibile utilizzare le opzioni in /etc/default/aide per modificare il comportamento del pacchetto *aide* . La configurazione di AIDE vera e propria è memorizzata in /etc/aide/aide.conf e /etc/aide/aide.conf.d/ (in realtà, questi file vengono utilizzati solo da update-aide.conf per generare /var/lib/aide/aide.conf.autogenerated). La configurazione indica quali proprietà di quali file devono essere controllate.
Ad esempio, il contenuto dei file di log cambia regolarmente e tali modifiche possono essere ignorate purché i permessi di questi file rimangano invariati, mentre sia il contenuto che i permessi dei programmi eseguibili devono essere costanti. Sebbene non sia molto complessa, la sintassi di configurazione non è del tutto intuitiva e si consiglia di consultare la pagina del manuale aide.conf(5) per maggiori dettagli.

Ogni giorno viene generata una nuova versione del database in /var/lib/aide/aide.db.new; se tutte le modifiche registrate sono legittime, può essere utilizzata per sostituire il database di riferimento.

Tripwire è molto simile ad AIDE; persino la sintassi del file di configurazione è quasi identica. La principale novità introdotta da *Tripwire* è un meccanismo per firmare il file di configurazione, in modo che un utente malintenzionato non possa utilizzarlo per puntare a una versione diversa del database di riferimento.

Anche Samhain offre funzionalità simili, oltre ad alcune funzioni per il rilevamento dei rootkit (vedi "I pacchetti *checksecurity* e *chkrootkit/ rkhunter* " [pagina 171] di seguito). Può inoltre essere distribuito a livello globale su una rete e registrare le proprie tracce su un server centrale (con una firma).

Machine Translated by Google

| | |
|---|---|
| **I pacchetti** checksecurity **e** chkrootkit/rkhunter | Checksecurity è composto da diversi piccoli script che eseguono controlli di base sul sistema (ricerca di password vuote, nuovi file setuid e così via) e ti avvisano se vengono rilevate queste condizioni. Nonostante il nome esplicito, non dovresti affidarti esclusivamente a questo strumento per garantire la sicurezza di un sistema Linux.<br>I pacchetti chkrootkit e rkhunter rilevano la presenza di rootkit potenzialmente installati sul sistema. Ricordiamo che si tratta di software progettati per nascondere le compromissioni di un sistema, mantenendo al contempo il controllo della macchina in modo discreto. I test non sono affidabili al 100%, ma di solito possono segnalare potenziali problemi. |

## 7.6. Riepilogo

In questo capitolo abbiamo esaminato il concetto di politiche di sicurezza, evidenziando vari punti da considerare nella definizione di una politica di questo tipo e delineando alcune delle minacce al sistema e alla persona in quanto professionista della sicurezza. Abbiamo discusso delle misure di sicurezza per desktop e laptop, nonché dei firewall e del filtraggio dei pacchetti. Infine, abbiamo analizzato gli strumenti e le strategie di monitoraggio e mostrato come implementarli al meglio per rilevare potenziali minacce al sistema.

Suggerimenti riassuntivi:

- Prenditi del tempo per definire una politica di sicurezza completa.
- I rischi reali si presentano spesso quando ti sposti da un cliente all'altro. Ad esempio, il tuo laptop potrebbe essere rubato durante il viaggio o sequestrato dalla dogana. Preparati a queste spiacevoli eventualità utilizzando la crittografia completa del disco (vedi la sezione 4.2.2, "Installazione su un file system completamente crittografato" [pagina 88]) e valuta la possibilità di utilizzare la funzione Nuke (vedi "Aggiunta di una password Nuke per una maggiore sicurezza" [pagina 250]) per proteggere i dati dei tuoi clienti.
- Disabilita i servizi che non utilizzi. Kali semplifica questa operazione, poiché tutti i servizi di rete esterni sono disabilitati per impostazione predefinita.
- Se si esegue Kali su un server accessibile pubblicamente, modificare le password predefinite per i servizi eventualmente configurati (vedere la sezione 7.3, "Protezione dei servizi di rete" [pagina 159]) e limitarne l'accesso con un firewall (vedere la sezione 7.4, "Firewall o filtro pacchetti" [pagina 159]) prima di avviarli. • Utilizzare *fail2ban* per rilevare e

bloccare gli attacchi di indovinamento delle password e gli attacchi di forza bruta remota.
attacchi.

- Se gestisci servizi web, ospitali tramite HTTPS per impedire agli intermediari di rete di intercettare il tuo traffico (che potrebbe includere i cookie di autenticazione). • Il kernel Linux integra il

firewall *netfilter* . Non esiste una soluzione preconfigurata per la configurazione di un firewall, poiché i requisiti di rete e degli utenti sono diversi. Tuttavia, è possibile controllare *netfilter* dallo spazio utente con i comandi iptables e ip6tables .

- Implementare regole firewall (vedere la sezione 7.4, "Firewall o filtro pacchetti" [pagina 159]) per bloccare tutto il traffico in uscita tranne quello generato dal tuo accesso VPN. Questo è inteso come una misura di sicurezza

Machine Translated by Google

rete, in modo che quando la VPN non funziona te ne accorgi immediatamente (invece di ripiegare sull'accesso alla rete locale).

- top è uno strumento interattivo che visualizza un elenco dei processi attualmente in esecuzione.
- Il programma logcheck monitora i file di registro ogni ora per impostazione predefinita e invia messaggi di registro insoliti tramite e-mail all'amministratore per ulteriori analisi.
- dpkg --verify (o dpkg -V) visualizza i file di sistema che sono stati modificati (potenzialmente da un utente malintenzionato), ma si basa sui checksum, che possono essere alterati da un utente malintenzionato esperto.
- Lo strumento Advanced Intrusion Detection Environment (AIDE) verifica l'integrità dei file e rileva eventuali modifiche rispetto a un'immagine precedentemente registrata del sistema valido.
- Tripwire è molto simile ad AIDE ma utilizza un meccanismo per firmare il file di configurazione, in modo che un attaccante non possa farlo puntare a una versione diversa del database di riferimento.
- Considera l'uso di rkhunter, checksecurity e chkrootkit per aiutare a rilevare i rootkit su il tuo sistema.

Nel prossimo capitolo, approfondiremo i fondamenti di Debian (capitolo 8, "Gestione dei pacchetti Debian" [pagina 176]) e la gestione dei pacchetti. Comprenderete rapidamente la potenza che si cela dietro le radici Debian di Kali e imparerete come gli sviluppatori l'hanno sfruttata. Attenzione: il prossimo capitolo è piuttosto denso, ma è fondamentale comprendere le basi di Debian e la gestione dei pacchetti se volete diventare utenti esperti di Kali.

Machine Translated by Google

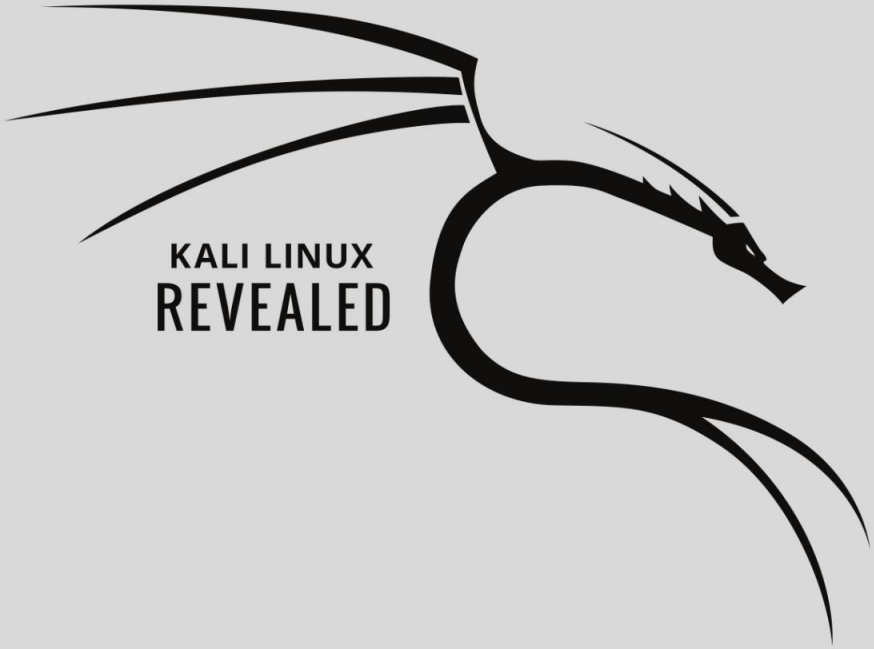


Machine Translated by Google

**Parole chiave**

**dpkg**
**apt**
**sources.list**

**Aggiornamenti Repository di pacchetti**



Machine Translated by Google

Capitolo

# Pacchetto Debian 8 Gestione

Contenuto

Introduzione all'APT 176 Interazione di base del pacchetto 181 Configurazione e utilizzo avanzati di APT 200
Riferimento ai pacchetti APT: Approfondimento sul sistema di pacchetti Debian 210 Sommario 222

Machine Translated by Google

Dopo aver appreso le basi di Linux, è il momento di imparare il sistema di gestione dei pacchetti di una distribuzione basata su Debian. In tali distribuzioni, inclusa Kali, il pacchetto Debian è il metodo standard per rendere il software disponibile agli utenti finali. Comprendere il sistema di gestione dei pacchetti vi fornirà una visione approfondita della struttura di Kali, vi permetterà di risolvere i problemi in modo più efficace e vi aiuterà a trovare rapidamente aiuto e documentazione per la vasta gamma di strumenti e utility inclusi in Kali Linux.

In questo capitolo, introdurremo il sistema di gestione dei pacchetti di Debian e presenteremo dpkg e la suite di strumenti APT. Uno dei principali punti di forza di Kali Linux risiede nella flessibilità del suo sistema di gestione dei pacchetti, che sfrutta questi strumenti per fornire installazioni, aggiornamenti, disinstallazioni e modifiche pressoché impeccabili di software applicativo e persino del sistema operativo stesso.
È fondamentale comprendere il funzionamento di questo sistema per sfruttare al meglio Kali e ottimizzare il proprio lavoro. I tempi delle compilazioni problematiche, degli aggiornamenti disastrosi e del debug di problemi con gcc, make e configure sono ormai lontani; tuttavia, il numero di applicazioni disponibili è esploso ed è necessario comprendere gli strumenti progettati per sfruttarle. Questa è un'abilità cruciale anche perché esistono diversi strumenti di sicurezza che, a causa di problemi di licenza o di altro tipo, non possono essere inclusi in Kali, ma per i quali sono disponibili pacchetti Debian da scaricare. È importante sapere come elaborare e installare questi pacchetti e come influiscono sul sistema, soprattutto quando qualcosa non va come previsto.

Cominceremo con una panoramica di base di APT, descriveremo la struttura e il contenuto dei pacchetti binari e sorgente, daremo un'occhiata ad alcuni strumenti e scenari di base e poi approfondiremo l'argomento per aiutarvi a sfruttare al massimo questo straordinario sistema di pacchetti e la relativa suite di strumenti.

## 8.1. Introduzione ad APT

Cominciamo con alcune definizioni di base, una panoramica e un po' di storia sui pacchetti Debian, a partire da dpkg e APT.

### 8.1.1. Relazione tra APT e dpkg

Un pacchetto Debian è un archivio compresso di un'applicazione software. Un *pacchetto binario* (un file .deb ) contiene file utilizzabili direttamente (come programmi o documentazione), mentre un *pacchetto sorgente* contiene il codice sorgente del software e le istruzioni necessarie per la creazione di un pacchetto binario. Un pacchetto Debian contiene i file dell'applicazione, nonché altri *metadati,* inclusi i nomi delle dipendenze necessarie all'applicazione e script che consentono l'esecuzione di comandi nelle diverse fasi del ciclo di vita del pacchetto (installazione, aggiornamenti e rimozione).

Lo strumento dpkg è stato progettato per elaborare e installare pacchetti .deb , ma se incontrava una dipendenza non soddisfatta (come una libreria mancante) che avrebbe impedito l'installazione del pacchetto, dpkg si limitava a elencare la dipendenza mancante, perché non aveva alcuna consapevolezza o logica integrata per trovare o elaborare i pacchetti che avrebbero potuto soddisfare tali dipendenze. L'Advanced Package Tool (APT)

Machine Translated by Google

Strumenti come apt e apt-get sono stati progettati per ovviare a queste carenze e possono risolvere automaticamente questi problemi. In questo capitolo parleremo sia di dpkg che degli strumenti APT.

Il comando base per la gestione dei pacchetti Debian sul sistema è dpkg, che esegue l'installazione o l'analisi dei pacchetti .deb e del loro contenuto. Tuttavia, dpkg ha solo una visione parziale dell'universo Debian: sa cosa è installato sul sistema e cosa viene fornito sulla riga di comando, ma non sa nulla degli altri pacchetti disponibili. Pertanto, fallirà se una dipendenza non viene soddisfatta. APT risolve queste limitazioni.

APT è un insieme di strumenti che aiutano a gestire i pacchetti Debian, ovvero le applicazioni sul tuo sistema Debian. Puoi usare APT per installare e rimuovere applicazioni, aggiornare i pacchetti e persino aggiornare l'intero sistema. La magia di APT sta nel fatto che è un sistema completo di gestione dei pacchetti che non si limita a installare o rimuovere un pacchetto, ma considera i requisiti e le dipendenze dell'applicazione impacchettata (e persino i requisiti e le dipendenze di quest'ultima) e tenta di soddisfarli automaticamente. APT si basa su dpkg , ma se ne differenzia in quanto il primo installa il pacchetto più recente da una fonte online e si occupa di risolvere le dipendenze, mentre dpkg installa un pacchetto presente sul sistema locale e non risolve automaticamente le dipendenze.

Se avete abbastanza esperienza da ricordare la compilazione di programmi con gcc (anche con l'aiuto di utility come make e configure), probabilmente ricorderete che si trattava di un processo laborioso, soprattutto se l'applicazione aveva diverse dipendenze. Decifrando i vari avvisi e messaggi di errore, potevate individuare la parte del codice che non funzionava e, il più delle volte, il problema era dovuto a una libreria o dipendenza mancante. Dovevate quindi rintracciare la libreria o dipendenza mancante, correggerla e riprovare. Poi, con un po' di fortuna, la compilazione si completava, ma spesso la build falliva di nuovo, segnalando un'altra dipendenza non funzionante.

APT è stato progettato per alleviare questo problema, raccogliere i requisiti e le dipendenze dei programmi e risolverli. Questa funzionalità è disponibile fin da subito su Kali Linux, ma non è infallibile. È importante capire come funziona il sistema di pacchettizzazione di Debian e Kali perché sarà necessario installare pacchetti, aggiornare software o risolvere problemi relativi ai pacchetti. Utilizzerete APT nel vostro lavoro quotidiano con Kali Linux e in questo capitolo vi introdurremo ad APT e vi mostreremo come installare, rimuovere, aggiornare e gestire i pacchetti, e persino come spostare pacchetti tra diverse distribuzioni Linux. Parleremo anche di strumenti grafici che sfruttano APT, vi mostreremo come verificare l'autenticità dei pacchetti e approfondiremo il concetto di distribuzione rolling, una tecnica che fornisce aggiornamenti giornalieri al vostro sistema Kali.

Prima di entrare nel dettaglio e mostrarvi come utilizzare dpkg e APT per installare e gestire i pacchetti, è importante analizzare alcuni aspetti interni di APT e chiarire la terminologia ad esso correlata.

| | |
|---|---|
| **Fonte del pacchetto e Pacchetto sorgente** | Il termine sorgente può essere ambiguo. Un pacchetto sorgente, ovvero un pacchetto contenente il codice sorgente di un programma, non deve essere confuso con una sorgente di pacchetto, ovvero un repository (sito web, server FTP, CD/DVD-ROM, directory locale, ecc.) che contiene pacchetti. età. |

Machine Translated by Google

APT recupera i suoi pacchetti da un repository, un sistema di archiviazione dei pacchetti o, più semplicemente, da una "fonte di pacchetti". Il file /etc/apt/sources.list elenca i diversi repository (o fonti) che pubblicano i pacchetti Debian.

## 8.1.2. Comprensione del file sources.list

Il file sources.list è il file di configurazione chiave per definire le sorgenti dei pacchetti, ed è importante capire come è strutturato e come configurarlo, poiché APT non funzionerà senza un elenco di sorgenti di pacchetti correttamente definito. Analizziamo la sua sintassi, diamo un'occhiata ai vari repository utilizzati da Kali Linux e parliamo di mirror e reindirizzamento dei mirror; a quel punto sarai pronto per utilizzare APT.

Ogni riga attiva del file /etc/apt/sources.list (e dei file /etc/apt/sources.list.d/*.list ) contiene la descrizione di una sorgente, composta da tre parti separate da spazi. Le righe commentate iniziano con il carattere # :

```
#deb cdrom:[Debian GNU/Linux 2020.3 _Kali-rolling_ - Snapshot ufficiale amd64 LIVE/ ÿ INSTALLA Binario
    20200728-20:25]/ kali-last-snapshot contrib main non-free

deb http://http.kali.org/kali kali-rolling main non-free contrib
```

Analizziamo la sintassi di questo file. Il primo campo indica il tipo di sorgente:

- deb per i pacchetti binari, •
- deb-src per i pacchetti sorgente.

Il secondo campo indica l'URL di base della sorgente: può trattarsi di un mirror di Kali o di qualsiasi altro archivio di pacchetti configurato da terzi. L'URL può iniziare con file:// per indicare una sorgente locale installata nella gerarchia dei file del sistema, con http:// per indicare una sorgente accessibile da un server web, o con ftp:// per una sorgente disponibile su un server FTP. L'URL può anche iniziare con cdrom: per installazioni basate su CD/DVD-ROM/Blu-ray, sebbene questo sia meno frequente poiché i metodi di installazione basati su rete sono sempre più comuni.

Le voci cdrom descrivono il lettore CD/DVD-ROM in tuo possesso. A differenza di altre voci, un lettore CD/DVD-ROM non è sempre disponibile, poiché deve essere inserito nell'unità e solitamente è possibile leggere un solo disco alla volta. Per questi motivi, queste sorgenti vengono gestite in modo leggermente diverso e devono essere aggiunte tramite il programma apt-cdrom , solitamente eseguito con il parametro add . Quest'ultimo richiederà quindi l'inserimento del disco nell'unità e ne analizzerà il contenuto alla ricerca di file di pacchetti . Utilizzerà questi file per aggiornare il suo database dei pacchetti disponibili (questa operazione viene solitamente eseguita tramite il comando apt update ). Dopodiché, APT richiederà il disco se necessita di un pacchetto in esso contenuto.

La sintassi dell'ultimo campo dipende dalla struttura del repository. Nei casi più semplici, è possibile indicare facilmente una sottocartella (con una barra finale obbligatoria) della sorgente desiderata (spesso si tratta di un semplice "./", che si riferisce all'assenza di una sottocartella: i pacchetti si trovano quindi direttamente nella directory).

Machine Translated by Google

URL specificato). Ma nel caso più comune, i repository saranno strutturati come un mirror di Kali, con più distribuzioni, ognuna con più componenti. In questi casi, nomina la distribuzione scelta, quindi i componenti (o sezioni) da abilitare. Prendiamoci un momento per introdurre questi
sezioni.

Debian e Kali utilizzano tre sezioni per differenziare i pacchetti in base alle licenze scelte dagli autori di ciascun lavoro. Una differenza tra Debian e Kali è che Debian ha solo la sezione main abilitata di default, mentre Kali le ha tutte e tre abilitate di default. La sezione main contiene

tutti i pacchetti che sono pienamente conformi alle Linee guida per il software libero di Debian. L' ·

archivio non libero è diverso perché contiene software che non si conforma (completamente) a questi principi, ma che può comunque essere distribuito senza restrizioni. contrib (contributi) è un insieme

di software open source che non può funzionare senza alcuni elementi non liberi. Questi elementi possono includere software della sezione non libera o file non liberi come ROM di giochi, BIOS di console, ecc. contrib include anche software libero la cui compilazione richiede elementi proprietari, come VirtualBox, che richiede un compilatore non libero per compilare alcuni dei suoi file.

Ora diamo un'occhiata alle sorgenti dei pacchetti standard di Kali Linux, o repository.

### 8.1.3. Repository di Kali

Un file sources.list standard per un sistema che esegue Kali Linux fa riferimento a un repository (kali-rolling) e ai tre componenti menzionati in precedenza: main, contrib e non-free:

```
# Repository principale di
Kali deb http://http.kali.org/kali kali-rolling main contrib non-free
```

Diamo un'occhiata ai repository di Kali.

## Il repository Kali-Rolling

Questo è il repository principale per gli utenti finali. Dovrebbe sempre contenere pacchetti installabili e aggiornati. È gestito da uno strumento che unisce Debian Testing e i pacchetti specifici di Kali in modo da garantire che le dipendenze di ciascun pacchetto possano essere soddisfatte durante il kali-rolling. In altre parole, a meno di bug negli script dei manutentori, tutti i pacchetti dovrebbero essere installabili.

Poiché Debian Testing si evolve quotidianamente, lo stesso vale per Kali Rolling. Anche i pacchetti specifici di Kali vengono aggiornati regolarmente, monitorando le release upstream dei pacchetti più importanti.

[1] https://www.debian.org/social_contract#guidelines

Machine Translated by Google

## Il repository Kali-Dev

Questo repository non è destinato all'uso pubblico. È uno spazio in cui gli sviluppatori di Kali risolvono i problemi di dipendenza derivanti dall'integrazione dei pacchetti specifici di Kali in Debian Testing.

È anche il luogo in cui vengono caricati per primi i pacchetti aggiornati, quindi se hai bisogno di un aggiornamento rilasciato di recente che non ha ancora raggiunto kali-rolling, potresti riuscire a scaricarlo da questo repository.
Questo non è consigliato agli utenti normali.

## Mirror di Kali Linux

Gli estratti di sources.list sopra riportati fanno riferimento a http.kali.org: si tratta di un server che esegue MirrorBrain[2] che reindirizzerà le tue richieste HTTP a un mirror ufficiale vicino a te. MirrorBrain monitora ogni mirror per assicurarsi che sia funzionante e aggiornato; ti reindirizzerà sempre a un mirror valido.

**Debug di uno specchio Reindirizzamento**

Se riscontri un problema con il mirror (ad esempio perché l'aggiornamento di apt non riesce), puoi usare curl -sI per vedere dove vieni reindirizzato:

```
$ curl -sI http://http.kali.org/README HTTP/1.1 302 Found
Data: mercoledì 27 gennaio
2021 05:04:09 GMT Server: Apache/2.4.10 (Debian)

X-MirrorBrain-Mirror: kali.download X-MirrorBrain-Realm:
country Link: <http://http.kali.org/
README.meta4>; rel=describedby; ÿ type="application/metalink4+xml"

Link: <http://kali.download/kali/README>; rel=duplicate; pri
    ÿ =1; geo=us Link:
<http://mirrors.ocf.berkeley.edu/kali/README>; rel=
    ÿ duplicato; pri=2; geo=us
Link: <http://mirror.anquan.cl/kali/README>; rel=duplicate;
    ÿ pri=3; geo=cl
Link: <http://ftp.free.fr/pub/kali/README>; rel=duplicate;
    ÿ pri=4; geo=fr Link:
<http://archive-4.kali.org/kali/README>; rel=duplicate;
    ÿ pri=5; geo=fr Location:
http://kali.download/kali/README Content-Type: text/html;
charset=iso-8859-1
```

Se il problema persiste, è possibile modificare il file /etc/apt/sources.list e inserire manualmente il nome di un altro mirror funzionante noto al posto (o prima) della voce http.kali.org .

[2] http://mirrorbrain.org/

Machine Translated by Google

Abbiamo anche una seconda istanza di MirrorBrain: http.kali.org ospita i repository dei pacchetti, mentre cdimage.kali.org ospita le immagini ISO rilasciate.

ÿ http://cdimage.kali.org/

Se desideri richiedere un elenco di mirror ufficiali di Kali Linux, puoi aggiungere .mirrorlist a qualsiasi URL valido che punti a http.kali.org o cdimage.kali.org.

ÿ http://http.kali.org/README.mirrorlist

ÿ http://cdimage.kali.org/README.mirrorlist Questi elenchi

non sono esaustivi a causa di alcune limitazioni di MirrorBrain (in particolare, i mirror con restrizioni per alcuni paesi non compaiono nell'elenco a meno che non ci si trovi nel paese in questione). Tuttavia, contengono i migliori mirror: sono ben mantenuti e offrono un'ampia larghezza di banda.

## 8.2. Interazione di base con i pacchetti

Dopo aver acquisito una conoscenza di base del panorama APT, esaminiamo alcune interazioni fondamentali con i pacchetti, tra cui l'inizializzazione di APT, l'installazione, la rimozione e la disinstallazione dei pacchetti, e l'aggiornamento del sistema Kali Linux. Successivamente, abbandoniamo la riga di comando per dare un'occhiata ad alcuni strumenti grafici di APT.

### 8.2.1. Inizializzazione di APT

APT è un vasto progetto e insieme di strumenti, i cui piani originali prevedevano un'interfaccia grafica. Dal punto di vista del client, è incentrato sullo strumento da riga di comando apt-get e su apt, sviluppato successivamente per superare i difetti di progettazione di apt-get.

Esistono alternative grafiche sviluppate da terze parti, tra cui Synaptic e Aptitude, che tratteremo in seguito. Tendiamo a preferire Aptitude, che utilizzeremo negli esempi che seguono. Tuttavia, descriveremo nel dettaglio alcune delle principali differenze di sintassi tra i vari strumenti, man mano che si presenteranno.

Quando si utilizza APT, è necessario innanzitutto scaricare l'elenco dei pacchetti attualmente disponibili con il comando `apt update`. A seconda della velocità della connessione, questa operazione può richiedere del tempo, poiché le dimensioni dei vari elenchi di pacchetti, sorgenti e file di traduzione sono aumentate con lo sviluppo di Kali. Naturalmente, i set di installazione da CD/DVD-ROM sono molto più veloci, in quanto i file sono installati localmente sul computer.

Machine Translated by Google

### 8.2.2. Installazione dei pacchetti

Grazie all'accurata progettazione del sistema di pacchetti Debian, è possibile installare pacchetti, con o senza le relative dipendenze, in modo piuttosto semplice. Vediamo come installare un pacchetto con dpkg e apt.

#### Installazione di pacchetti con dpkg

dpkg è lo strumento principale che utilizzerai (direttamente o indirettamente tramite APT) quando devi installare un pacchetto. È anche la scelta ideale se lavori offline, poiché non richiede una connessione a Internet. Ricorda che dpkg non installerà le dipendenze che il pacchetto potrebbe richiedere. Per installare un pacchetto con dpkg, è sufficiente specificare l' opzione -i o --install e il percorso del file .deb. Questo presuppone che tu abbia precedentemente scaricato (o ottenuto in altro modo) il file .deb del pacchetto da installare.

```
# dpkg -i man-db_2.9.3-2_amd64.deb (Lettura
 del database... 309317 file e directory attualmente installati.)
Preparazione all'estrazione del file man-db_2.9.3-2_amd64.deb ...
Estrazione di man-db (2.9.3-2) su (2.9.3-2) ...
Configurazione di man-db (2.9.3-2) ...
Aggiornamento del database delle pagine del
manuale... man-db.service è un'unità disabilitata o statica non in esecuzione, non verrà avviata.
Elaborazione dei trigger per kali-menu (2020.4.0) ...
Elaborazione dei trigger per il supporto MIME (3.64) ...
```

Possiamo osservare i diversi passaggi eseguiti da dpkg e individuare il punto in cui si è verificato un eventuale errore. L' opzione -i o --install esegue automaticamente due passaggi: decomprime il pacchetto ed esegue gli script di configurazione. È possibile eseguire questi due passaggi in modo indipendente (come fa apt in background) rispettivamente con le opzioni --unpack e --configure :

```
# dpkg --unpack man-db_2.9.3-2_amd64.deb (Lettura
 del database... 309317 file e directory attualmente installati.)
Preparazione all'estrazione del file man-db_2.9.3-2_amd64.deb ...
Estrazione di man-db (2.9.3-2) su (2.9.3-2) ...
Elaborazione dei trigger per kali-menu (2020.4.0) ...
Elaborazione dei trigger per mime-support (3.64) ... # dpkg --
configure man-db Configurazione
di man-db (2.9.3-2) ...
Aggiornamento del database delle pagine del manuale...
```

Si noti che le righe "Trigger di elaborazione" si riferiscono al codice che viene eseguito automaticamente ogni volta che un pacchetto aggiunge, rimuove o modifica file in alcune directory monitorate. Ad esempio, il pacchetto *mime-support* monitora /usr/lib/mime/packages ed esegue il comando update-mime.

Machine Translated by Google

ogni volta che qualcosa cambia in quella directory (come /usr/lib/mime/packages/man-db nel caso specifico di man-db).

A volte dpkg non riesce a installare un pacchetto e restituisce un errore. Tuttavia, è possibile fare in modo che dpkg ignori questo errore e visualizzi solo un avviso tramite diverse opzioni --force-* . Eseguendo il comando dpkg --force-help verrà visualizzato un elenco completo di queste opzioni. Ad esempio, è possibile utilizzare dpkg per installare forzatamente zsh:

```
$ dpkg -i --force-overwrite zsh_5.8-5+b1_amd64.deb
```

Un errore frequente, che prima o poi incontrerete sicuramente, è la collisione di file. Quando un pacchetto contiene un file già installato da un altro pacchetto, dpkg si rifiuterà di installarlo.
Verranno quindi visualizzati i seguenti tipi di messaggi:

```
Estrazione di libgdm (da .../libgdm_3.8.3-2_amd64.deb) ... dpkg: errore durante l'elaborazione
di /var/cache/apt/archives/libgdm_3.8.3-2_amd64.deb (--unpack): ÿ tentativo di sovrascrivere '/usr/bin/gdmflexiserver', che è anche nel
        pacchetto gdm3 ÿ 3.4.1-9
```

In questo caso, se ritieni che la sostituzione di questo file non rappresenti un rischio significativo per la stabilità del tuo sistema (il che di solito è vero), puoi utilizzare --force-overwrite per sovrascrivere il file.

Sebbene siano disponibili molte opzioni --force-* , solo --force-overwrite è probabilmente quella che verrà utilizzata regolarmente. Queste opzioni esistono per situazioni eccezionali ed è meglio evitarle il più possibile per rispettare le regole imposte dal meccanismo di creazione dei pacchetti. Non dimenticate che queste regole garantiscono la coerenza e la stabilità del vostro sistema.

## Installazione dei pacchetti con APT

Sebbene APT sia molto più avanzato di dpkg e svolga molte più operazioni in background, interagire con i pacchetti è piuttosto semplice. È possibile aggiungere un pacchetto al sistema con un semplice comando `apt install package`. APT installerà automaticamente le dipendenze necessarie:

```
# apt install kali-tools-gpu Lettura degli
elenchi dei pacchetti... Fatto Creazione dell'albero
delle dipendenze Lettura delle
informazioni sullo stato... Fatto I seguenti pacchetti
aggiuntivi verranno installati: oclgausscrack truecrack

Verranno installati i seguenti NUOVI pacchetti: è necessario scaricare 2.602
kB di archivi.
Dopo questa operazione, verranno utilizzati 2.898 kB di spazio aggiuntivo sul disco.
Scarica:1 http://kali.download/kali kali-rolling/main amd64 oclgausscrack amd64 1.3-1kali3
        ÿ [30,7 kB]
Ottieni:2 http://kali.download/kali kali-rolling/main amd64 truecrack amd64 3.6+git20150326
        ÿ -0kali1 [2.558 kB]
```

Machine Translated by Google

```
Scarica:3 http://kali.download/kali kali-rolling/main amd64 kali-tools-gpu amd64 2021.1.0
        ÿ [12,6 kB]
Scaricati 2.602 kB in 1 secondo (2.645 kB/s)
Selezione del pacchetto oclgausscrack, precedentemente non selezionato.
(Lettura del database... 108127 file e directory attualmente installati.)
Preparazione all'estrazione del file .../oclgausscrack_1.3-1kali3_amd64.deb ...
Estrazione di oclgausscrack (1.3-1kali3) ...
Selezione del pacchetto truecrack, precedentemente non selezionato.
Preparazione all'estrazione di .../truecrack_3.6+git20150326-0kali1_amd64.deb ...
Estrazione di truecrack (3.6+git20150326-0kali1) ...
Selezione del pacchetto kali-tools-gpu, precedentemente non selezionato.
Preparazione all'estrazione del file .../kali-tools-gpu_2021.1.0_amd64.deb ...
Estrazione di kali-tools-gpu (2021.1.0) ...
Configurazione di oclgausscrack (1.3-1kali3) ...
Configurazione di truecrack (3.6+git20150326-0kali1) ...
Configurazione di kali-tools-gpu (2021.1.0) ...
Elaborazione dei trigger per man-db (2.9.3-2) ...
Elaborazione dei trigger per kali-menu (2020.4.0) ...
```

È possibile utilizzare anche `apt-get install package` o `aptitude install package`. Per la semplice installazione di pacchetti, svolgono essenzialmente la stessa funzione. Come vedremo in seguito, le differenze sono più significative per gli aggiornamenti o quando la risoluzione delle dipendenze non ha una soluzione perfetta.

Se sources.list elenca diverse distribuzioni, è possibile specificare la versione del pacchetto con apt install package=version, ma di solito è preferibile indicare la distribuzione di origine (kali-rolling o kali-dev) con apt install package/distribution .

```
# apt install zsh=5.7.1-1 # apt
install zsh/kali-dev
```

Come con dpkg, è possibile anche indicare ad apt di installare forzatamente un pacchetto e sovrascrivere i file con --force-overwrite, ma la sintassi è un po' particolare poiché l'argomento viene passato a dpkg:

```
# apt -o Dpkg::Options::=”--force-overwrite” install zsh
```

### 8.2.3. Aggiornamento di Kali Linux

Essendo una distribuzione rolling release, Kali Linux offre straordinarie capacità di aggiornamento. In questa sezione, vedremo quanto sia semplice aggiornare Kali e discuteremo le strategie per pianificare gli aggiornamenti.

Si consiglia di eseguire aggiornamenti regolari, in quanto installano gli aggiornamenti di sicurezza più recenti. Per aggiornare, utilizzare il comando `apt update` seguito da ` apt upgrade`, `apt-get upgrade` o `aptitude safe-upgrade`. Questi comandi cercano i pacchetti installati che possono essere aggiornati senza rimuovere alcun pacchetto. In altre parole, l'obiettivo è garantire l'aggiornamento meno invasivo possibile. Il comando apt-get

Machine Translated by Google

Lo strumento line è leggermente più esigente di aptitude o apt perché si rifiuta di installare pacchetti che non sono stati installati in precedenza.

Lo strumento apt in genere seleziona il numero di versione più recente.

Per indicare ad apt di utilizzare una distribuzione specifica durante la ricerca di pacchetti aggiornati, è necessario utilizzare l' opzione -t o --target-release , seguita dal nome della distribuzione desiderata (ad esempio: apt -t kali-rolling upgrade). Per evitare di specificare questa opzione ogni volta che si utilizza apt, è possibile aggiungere APT::Default-Release "kali-rolling"; nel file /etc/apt/apt.conf.d/local.

Per aggiornamenti più importanti, come gli aggiornamenti di versione principali, usa `apt full-upgrade`. Con questo comando, apt completerà l'aggiornamento anche se deve rimuovere alcuni pacchetti obsoleti o installare nuove dipendenze. Questo è anche il comando da utilizzare per i normali aggiornamenti del tuo sistema Kali Rolling. È così semplice che non ha quasi bisogno di spiegazioni: la reputazione di APT si basa proprio su questa fantastica funzionalità.

A differenza di apt e aptitude, apt-get non riconosce il comando full-upgrade . Invece, è necessario utilizzare apt-get dist-upgrade (aggiornamento della distribuzione), un comando ben noto che apt e aptitude accettano anche per la compatibilità con le versioni precedenti.

| | |
|---|---|
| **Sii consapevole di cose importanti Modifiche** | Per prevedere alcuni di questi problemi, è possibile installare il pacchetto apt-listchanges , che visualizza informazioni su possibili problemi all'inizio di un aggiornamento di pacchetto. Queste informazioni vengono compilate dai manutentori del pacchetto e inserite nei file / usr/share/doc/package/NEWS.Debian per vostra comodità. La lettura di questi file (eventualmente tramite apt-listchanges) dovrebbe aiutarvi a evitare spiacevoli sorprese. |

Essendo diventata una distribuzione rolling release, Kali può ricevere aggiornamenti più volte al giorno. Tuttavia, questa potrebbe non essere la strategia migliore. Quindi, con quale frequenza dovresti aggiornare Kali Linux? Non esiste una regola fissa, ma ci sono alcune linee guida che possono esserti d'aiuto. Dovresti aggiornare:

- Quando sei a conoscenza di un problema di sicurezza che viene risolto in un aggiornamento.
- Quando sospetti che una versione aggiornata possa risolvere un bug che stai riscontrando.
- Prima di segnalare un bug per assicurarti che sia ancora presente nell'ultima versione che hai disponibile.
- Abbastanza spesso da ricevere gli aggiornamenti di sicurezza di cui non si è a conoscenza.

Ci sono anche casi in cui è meglio non aggiornare. Ad esempio, potrebbe non essere una buona idea aggiornare:

- Se non puoi permetterti alcun problema (ad esempio, perché perdi la connessione internet o perché devi fare una presentazione al computer), è meglio rimandare l'aggiornamento a un secondo momento, quando avrai tempo a sufficienza per risolvere eventuali problemi sorti durante il processo.
- Se si è verificato di recente un cambiamento dirompente (o è ancora in corso) e si teme che non tutti i problemi siano stati ancora scoperti. Ad esempio, quando viene rilasciata una nuova versione di GNOME, non tutti

Machine Translated by Google

I pacchetti vengono aggiornati contemporaneamente ed è probabile che si trovino pacchetti con la vecchia e la nuova versione. Nella maggior parte dei casi questo non crea problemi e consente a tutti di rilasciare gli aggiornamenti progressivamente, ma ci sono sempre delle eccezioni e alcune applicazioni potrebbero non funzionare correttamente a causa

di tali discrepanze. • Se l' output di apt full-upgrade indica che verranno rimossi pacchetti che si considerano importanti per il proprio lavoro, è opportuno esaminare la situazione e cercare di capire perché apt intende rimuoverli. Forse i pacchetti sono attualmente danneggiati e in tal caso potrebbe essere opportuno attendere che siano disponibili versioni corrette, oppure sono obsoleti e si dovrebbero identificare i loro sostituti prima di procedere con l'aggiornamento completo.

In generale, consigliamo di aggiornare Kali almeno una volta a settimana. È certamente possibile aggiornarlo quotidianamente, ma non ha senso farlo più spesso. Anche se i nostri mirror vengono sincronizzati quattro volte al giorno, gli aggiornamenti provenienti da Debian di solito arrivano solo una volta al giorno.

### 8.2.4. Rimozione e eliminazione dei pacchetti

Rimuovere un pacchetto è persino più semplice che installarlo. Vediamo come rimuovere un pacchetto con dpkg e apt.

Per rimuovere un pacchetto con dpkg, è necessario specificare l' opzione -r o --remove , seguita dal nome del pacchetto. Questa rimozione, tuttavia, non è completa: tutti i file di configurazione, gli script di manutenzione, i file di log (log di sistema), i dati generati dal servizio (come il contenuto di una directory di un server LDAP o il contenuto di un database per un server SQL) e la maggior parte degli altri dati utente gestiti dal pacchetto rimangono intatti. L'opzione --remove semplifica la disinstallazione di un programma e la sua successiva reinstallazione con la stessa configurazione. Ricorda inoltre che le dipendenze non vengono rimosse. Considera questo esempio:

```
# dpkg --remove kali-tools-gpu (Lettura
 del database... 108172 file e directory attualmente installati.)
Rimozione di kali-tools-gpu (2021.1.0) ...
```

È possibile rimuovere i pacchetti dal sistema anche con il comando `apt remove package`. APT eliminerà automaticamente i pacchetti che dipendono dal pacchetto rimosso. Come nell'esempio di dpkg , i file di configurazione e i dati utente non verranno rimossi.

Aggiungendo dei suffissi ai nomi dei pacchetti, è possibile utilizzare apt (o apt-get e aptitude) per installare determinati pacchetti e rimuoverne altri dalla stessa riga di comando. Con il comando apt install , aggiungi "-" ai nomi dei pacchetti che desideri rimuovere. Con il comando apt remove , aggiungi "+" ai nomi dei pacchetti che desideri installare.

L'esempio seguente mostra due modi diversi per installare *il pacchetto 1* e rimuovere *il pacchetto 2.*

```
# apt install package1 package2- [...] # apt

remove package1+ package2
```

Machine Translated by Google

```
[...]
```

Questo può essere utilizzato anche per escludere pacchetti che altrimenti verrebbero installati, ad esempio a causa di un campo "Consiglia " (discusso più avanti nella sezione 8.4.1.3, "Campi Consigli, Suggerimenti e Miglioramenti " [pagina 214]). In generale, il risolutore di dipendenze utilizzerà queste informazioni come suggerimento per cercare soluzioni native alternative.

Per rimuovere tutti i dati associati a un pacchetto, è possibile disinstallarlo completamente con i comandi `dpkg -P package` o `apt purge package` . In questo modo il pacchetto e tutti i dati utente verranno rimossi e, nel caso di apt, verranno eliminate anche le dipendenze.

```
# dpkg -r debian-cd (Lettura
 del database... 333606 file e directory attualmente installati.)
Rimozione di debian-cd (3.1.32) ... # dpkg -P
debian-cd (Lettura del
 database ... 332950 file e directory attualmente installati.)
Rimozione di debian-cd (3.1.32) ...
Eliminazione dei file di configurazione per debian-cd (3.1.32) ...
```

Attenzione! Data la natura definitiva dell'eliminazione, non eseguite questa operazione con leggerezza. Perderete tutto ciò che è associato a quel pacchetto.

## 8.2.5. Ispezione dei pacchi

Successivamente, esaminiamo alcuni degli strumenti che possono essere utilizzati per analizzare i pacchetti Debian. Scopriremo i comandi dpkg, apt e apt-cache , che possono essere usati per interrogare e visualizzare il database dei pacchetti.

### Interrogazione del database di dpkg e ispezione dei file .deb

Inizieremo con alcune opzioni di dpkg che interrogano il database interno di dpkg. Questo database risiede sul filesystem in /var/lib/dpkg e contiene diverse sezioni, tra cui script di configurazione (/var/lib/dpkg/info), un elenco dei file installati dal pacchetto (/var/lib/dpkg/info/*.list) e lo stato di ciascun pacchetto installato (/var/lib/dpkg/status). È possibile utilizzare dpkg per interagire con i file presenti in questo database. Si noti che la maggior parte delle opzioni è disponibile in una versione estesa (una o più parole pertinenti, precedute da un doppio trattino) e in una versione abbreviata (una singola lettera, spesso l'iniziale di una parola della versione estesa, preceduta da un singolo trattino). Questa convenzione è così comune da essere uno standard POSIX.

Innanzitutto, diamo un'occhiata a --listfiles package (o -L), che elenca i file installati dal pacchetto specificato:

```
$ dpkg -L base-passwd /.
```

Machine Translated by Google

```
/usr /
usr/sbin /usr/
sbin/update-passwd /usr/share /usr/
share/lintian /usr/
share/lintian/overrides /usr/
share/lintian/overrides/base-passwd /usr/share/
doc-base /usr/share/doc-base/users-and-groups /usr/share/base-
passwd /usr/share/base-passwd/
group.master /usr/share/base-passwd/passwd.master /usr/
share/man /usr/share/man/pl /usr/
share/man/pl/man8 /usr/share/man/pl/man8/update-
passwd.8.gz [...] /usr/share/doc /usr/share/doc/base-passwd /
usr/share/doc/base-
passwd/users-and-
groups.txt.gz /usr/share/doc/base-
passwd/changelog.gz /usr/share/doc/base-passwd/copyright /usr/
 share/
doc/base-passwd/
README /usr/share/doc/base-passwd/
users-and-groups.html
```

Successivamente, dpkg --search file (o -S) trova tutti i pacchetti che contengono il file o il percorso passato come argomento. Ad esempio, per trovare il pacchetto contenente /bin/date:

```
$ dpkg -S /bin/date coreutils: /
bin/date
```

Il comando dpkg --status package (o -s) visualizza le intestazioni di un pacchetto installato. Ad esempio, per cercare le intestazioni del pacchetto coreutils :

```
$ dpkg -s coreutils
Pacchetto: coreutils
Stato: installazione OK installata
Priorità: obbligatoria Sezione:
utils Dimensione
installata: 13855 Manutentore:
Michael Stone <mstone@debian.org> Architettura: amd64 Multi-Arch:
foreign Versione: 8.23-3
Sostituisce: mktemp, realpath,
timeout
```

Machine Translated by Google

```
Pre-dipende: libacl1 (>= 2.2.51-8), libattr1 (>= 1:2.4.46-8), libc6 (>= 2.17),
        ÿ libselinux1 (>= 2.1.13)
Conflitti: timeout
Descrizione: Utilità principali di GNU
Questo pacchetto contiene le funzionalità di base per la manipolazione di file, shell e testo.
Utilità che si presume siano presenti su ogni sistema operativo.
 .
Nello specifico, questo pacchetto include:
arch base64 basename cat chcon chgrp chmod chown chroot cksum comm cp
csplit cut date dd df dir dircolors dirname du echo env expand expr
fattore falso gregge fmt piega gruppi testa hostid id installa unisci link ln
logname ls md5sum mkdir mkfifo mknod mktemp mv nice nl nohup nproc numfmt
od paste pathchk pinky pr printenv printf ptx pwd readlink realpath rm
 rmdir runcon sha*sum seq shred sleep sort split stat stty sum sync tac
tail tee test timeout touch tr true truncate tsort tty uname unexpand
utenti uniq unlink vdir wc chi whoami sì
Pagina iniziale: http://gnu.org/software/coreutils
```

Il comando dpkg --list (o -l) visualizza l'elenco dei pacchetti noti al sistema e i loro stato dell'installazione. Puoi anche usare grep sull'output per cercare determinati campi o fornire caratteri jolly (come b*) per cercare pacchetti che corrispondono a una particolare stringa di ricerca parziale. Questo mostrerà un riepilogo dei pacchetti. Ad esempio, per mostrare un elenco riassuntivo di tutti i pacchetti che inizia con la lettera 'b':

```
$ dpkg -l 'b*'
Desiderabile=Sconosciuto/Installa/Rimuovi/Svuota/Mantieni
 | Stato=Non/Installato/File di configurazione/Decompresso/Configurazione parziale/Installazione parziale/Attesa attivazione/Attivazione in sospeso
 |/ Err?=(nessuno)/Reinst-richiesto (Stato,Err: maiuscolo=cattivo)
 ||/ Nome Versione Architettura Descrizione
+++-==========================-==========================-============-======================
ii backdoor-factory 3.4.2+dfsg-4 all un backupninja un backuppc                    Patch per file binari ELF a 32/64 bit e win32/64 con shellcode
un balsa un base [...]                  <nessuno> <nessuno> (nessuna descrizione disponibile)
                                        <nessuno> <nessuno> (nessuna descrizione disponibile)
                                        <nessuno> <nessuno> (nessuna descrizione disponibile)
                                        <nessuno> <nessuno> (nessuna descrizione disponibile)
```

Il comando dpkg --contents file.deb (o -c) elenca tutti i file contenuti in un determinato file .deb :

```
$ dpkg -c /var/cache/apt/archives/gpg_2.2.20-1_amd64.deb
drwxr-xr-x root/root drwxr-xr-x                0 2020-03-23 15:05 ./
root/root drwxr-xr-x root/root                 0 2020-03-23 15:05 ./usr/
-rwxr-xr-x root/root 1062832                   0 2020-03-23 15:05 ./usr/bin/
 2020-03-23 15:05 ./usr/bin/gpg
drwxr-xr-x root/root 0 2020-03-23 15:05 ./usr/share/
drwxr-xr-x root/root 0 2020-03-23 15:05 ./usr/share/doc/
drwxr-xr-x root/root 0 2020-03-23 15:05 ./usr/share/doc/gpg/
 -rw-r--r-- radice/radice                     677 2020-03-23 14:45 ./usr/share/doc/gpg/NEWS.Debian.gz
 -rw-r--r-- radice/radice                   24353 2020-03-23 15:05 ./usr/share/doc/gpg/changelog.Debian.gz
 -rw-r--r-- radice/radice                  384091 2020-03-20 11:38 ./usr/share/doc/gpg/changelog.gz
```

Machine Translated by Google

```
-rw-r--r-- root/root drwxr-xr-x root/root drwxr-xr-x root/root -rw-r--r-- root/root
                                    10555 2020-03-23 15:04 ./usr/share/doc/gpg/copyright 0 2020-03-23 15:05 ./usr/share/man/ 0 2020-03-23 15:05 ./usr/share/man/man1/

                                    46139 2020-03-23 15:05 ./usr/share/man/man1/gpg.1.gz
```

Il comando dpkg --info file.deb (o -I) visualizza le intestazioni del file .deb specificato :

```
$ dpkg -I /var/cache/apt/archives/gpg_2.2.20-1_amd64.deb
 Nuovo pacchetto Debian, versione 2.0. Dimensione
 894224 byte: archivio di controllo = 1160 byte. 1219 byte, controllo 374 byte,
       md5sums Pacchetto: gpg Sorgente: gnupg2 Versione:
        2.2.20-1 Architettura: amd64 Manutentore: Debian GnuPG
 Maintainers <pkg-
 gnupg-
 maint@lists.alioth.debian.org>
 Dimensione installata: 1505
 Dipendenze: gpgconf (= 2.2.20-1), libassuan0 (>= 2.5.0), libbz2-1.0, libc6 (>= 2.25), ÿ libgcrypt20 (>= 1.8.0), libgpg-error0 (>= 1.35),
 libreadline8 (>= 6.0), ÿ libsqlite3-0
 (>= 3.7.15), zlib1g (>= 1:1.1.4)


 Raccomanda: gnupg (= 2.2.20-1)
 Interruzioni: gnupg (<< 2.1.21-4)
 Sostituisce: gnupg (<< 2.1.21-4)
 Sezione: utilità
 Priorità: opzionale Multi-Arch:
 foreign Pagina iniziale: https://
 www.gnupg.org/ Descrizione: GNU Privacy Guard --
 operazioni minimaliste con chiave pubblica GnuPG è lo strumento GNU per la comunicazione sicura e
   l'archiviazione dei dati.
   Può essere utilizzato per crittografare i dati e per creare firme digitali.
   Include una funzionalità avanzata di gestione delle chiavi ed è conforme allo standard Internet OpenPGP
   proposto, come descritto nella RFC4880. [...]
```

25 righe 6 righe

È inoltre possibile utilizzare dpkg per confrontare i numeri di versione dei pacchetti con l' opzione --compare-versions , che viene spesso richiamata da programmi esterni, inclusi gli script di configurazione eseguiti dallo stesso dpkg . Questa opzione richiede tre parametri: un numero di versione, un operatore di confronto e un secondo numero di versione. I diversi operatori possibili sono: lt (strettamente minore di), le (minore o uguale a), eq (uguale a), ne (diverso da), ge (maggiore o uguale a) e gt (strettamente maggiore di). Se il confronto è corretto, dpkg restituisce 0 (successo); in caso contrario, restituisce un valore diverso da zero (che indica un errore). Si considerino i seguenti confronti:

```
$ dpkg --compare-versions 1.2-3 gt 1.1-4 $ echo $? 0
```

Machine Translated by Google

```
$ dpkg --compare-versions 1.2-3 lt 1.1-4 $ echo $? 1


$ dpkg --compare-versions 2.6.0pre3-1 lt 2.6.0-1 $ echo $?

1
```

Si noti l'inaspettato errore dell'ultimo confronto: per dpkg, la stringa "pre" (che di solito indica una versione preliminare) non ha un significato particolare e dpkg la interpreta semplicemente come una stringa, nel qual caso "2.6.0pre3-1" è alfabeticamente maggiore di "2.6.0-1". Quando vogliamo che il numero di versione di un pacchetto indichi che si tratta di una versione preliminare, utilizziamo il carattere tilde, "~":

```
$ dpkg --compare-versions 2.6.0~pre3-1 lt 2.6.0-1 $ echo $?

0
```

## Interrogazione del database dei pacchetti disponibili con apt-cache e apt

Il comando apt-cache può visualizzare gran parte delle informazioni memorizzate nel database interno di APT. Queste informazioni costituiscono una sorta di cache, poiché vengono raccolte dalle diverse fonti elencate nel file sources.list . Ciò avviene durante l' operazione di aggiornamento di apt .

VOCABOLARIO

**Cache**

Una cache è un sistema di archiviazione temporanea utilizzato per velocizzare l'accesso frequente ai dati quando il metodo di accesso usuale risulta oneroso (in termini di prestazioni). Questo concetto può essere applicato in numerose situazioni e a diverse scale, dal cuore dei microprocessori fino ai sistemi di archiviazione di fascia alta.

Nel caso di APT, i file di riferimento dei pacchetti sono quelli presenti sui mirror di Debian. Detto questo, sarebbe molto inefficace effettuare ogni ricerca attraverso i database online dei pacchetti. Ecco perché APT memorizza una copia di quei file (in /var/lib/apt/lists/) e le ricerche vengono eseguite all'interno di questi file locali. Allo stesso modo, /var/cache/apt/archives/ contiene una copia memorizzata nella cache dei pacchetti già scaricati per evitare di scaricarli nuovamente in caso di reinstallazione.

Per evitare un utilizzo eccessivo dello spazio su disco durante gli aggiornamenti frequenti, è consigliabile pulire regolarmente la directory /var/cache/apt/archives/ . A tale scopo, è possibile utilizzare due comandi: apt clean (o apt-get clean) svuota completamente la directory; apt autoclean (apt-get autoclean) rimuove solo i pacchetti che non possono più essere scaricati perché sono stati rimossi dal mirror e sono quindi inutili. Si noti che il parametro di configurazione APT::Clean-Installed può essere utilizzato per impedire la rimozione dei file .deb attualmente installati. Inoltre, si tenga presente che apt elimina i file scaricati una volta installati, quindi questo è rilevante soprattutto quando si utilizzano altri strumenti.

Il comando apt-cache può eseguire ricerche di pacchetti basate su parole chiave con apt-cache search keyword. Può anche visualizzare le intestazioni delle versioni disponibili del pacchetto con apt-cache show package. Questo comando fornisce la descrizione del pacchetto, le sue dipendenze e il nome del suo

Machine Translated by Google

manutentore. Questa funzionalità è particolarmente utile per determinare i pacchetti installati tramite metapackage, come *kali-tools-wireless, kali-tools-web* e *kali-tools-gpu.* Si noti che apt search, apt show, aptitude search e aptitude show funzionano allo stesso modo.

**Un'alternativa: axi-cache** apt-cache search è uno strumento molto rudimentale, che implementa sostanzialmente grep sulle descrizioni dei pacchetti. Spesso restituisce troppi risultati o nessuno, quando vengono incluse troppe parole chiave.

Il termine di ricerca axi-cache, d'altro canto, fornisce risultati migliori, ordinati per rilevanza. Utilizza il motore di ricerca Xapian e fa parte del pacchetto apt-xapian-index , che indicizza tutte le informazioni sui pacchetti (e altro ancora, come i file .desktop di tutti i pacchetti Debian). Riconosce i tag e restituisce i risultati in pochi millisecondi.

```
$ axi-cache ricerca forensica grafica 7 risultati trovati.

Risultati 1-7: 100%
autopsia - interfaccia grafica per SleuthKit 94% forensics-all-gui - Ambiente
forense Debian - GUI
        ÿ componenti (metapackage)
87% forensics-extra-gui - Ambiente forense - interfaccia grafica aggiuntiva
        ÿ componenti (metapackage) 86% forensics-
colorize - mostra le differenze tra i file utilizzando
        ÿ grafica a colori 44% gpart -
Indovina la tabella delle partizioni del disco del PC, trova le partizioni perse ÿ

39% testdisk - Strumento di scansione delle partizioni e di recupero del disco e
        ÿ Strumento di recupero file PhotoRec
8% texlive-publishers - TeX Live: stili dell'editore, tesi,
        ÿ ecc.
Altri termini: strumenti esperti autopsia immagine penetration tester etici
        ÿ hacker
Altri tag: admin::forensics security::forensics admin::
        ÿ interfaccia di ripristino::amministratore riga di comando::ambito di avvio:: ÿ ruolo di
        utilità::programma
```

Alcune funzionalità sono utilizzate meno frequentemente. Ad esempio, `apt-cache policy` visualizza le priorità delle sorgenti dei pacchetti, nonché quelle dei singoli pacchetti. Un altro esempio è `apt-cache dumpavail`, che visualizza le intestazioni di tutte le versioni disponibili di tutti i pacchetti. `apt-cache pkgnames` visualizza l'elenco di tutti i pacchetti che compaiono almeno una volta nella cache.

### 8.2.6. Risoluzione dei problemi

Prima o poi, durante l'utilizzo di un pacchetto software, potrebbe presentarsi un problema. In questa sezione, illustreremo alcuni passaggi di base per la risoluzione dei problemi e forniremo alcuni strumenti che vi aiuteranno a trovare una possibile soluzione.

Machine Translated by Google



Nonostante gli sforzi dei manutentori di Debian o Kali, un aggiornamento di sistema non è sempre così semplice come si spera. Le nuove versioni del software potrebbero essere incompatibili con le precedenti (ad esempio, il loro comportamento predefinito o il formato dei dati potrebbero essere cambiati), oppure potrebbero verificarsi bug nonostante i test effettuati dai manutentori dei pacchetti e dagli utenti di Debian Unstable.

**Sfruttare le segnalazioni di bug** A volte può capitare che una nuova versione di un software non funzioni affatto. Questo accade generalmente se l'applicazione non è particolarmente popolare e non è stata testata a sufficienza. La prima cosa da fare è consultare il bug tracker di Kali. e nel sistema di tracciamento dei bug di Debian4 Visita https://bugs.debian.org/package e verifica se il problema è già stato segnalato. In caso contrario, segnalalo tu stesso (vedi la sezione 6.3, "Segnalazione di un bug efficace" [pagina 134] per istruzioni dettagliate). Se il problema è già noto, la segnalazione e i relativi messaggi sono solitamente un'ottima fonte di informazioni. In alcuni casi, esiste già una patch, resa disponibile nella segnalazione stessa; puoi quindi ricompilare localmente una versione corretta del pacchetto difettoso (vedi la sezione 9.1, "Modifica dei pacchetti Kali" [pagina 228]). In altri casi, gli utenti potrebbero aver trovato una soluzione alternativa al problema e aver condiviso le proprie informazioni nelle risposte alla segnalazione; tali istruzioni potrebbero aiutarti a risolvere il problema in attesa del rilascio di una correzione o di una patch. Nella migliore delle ipotesi, il pacchetto potrebbe essere già stato corretto e potresti trovare i dettagli nella segnalazione.

**Downgrade a una versione funzionante** Quando il problema è una chiara regressione (dove la versione precedente funzionava), è possibile provare a effettuare il downgrade del pacchetto. In questo caso, sarà necessaria una copia della vecchia versione. Se si ha accesso alla vecchia versione in uno dei repository configurati in APT, è possibile utilizzare un semplice comando a riga singola per effettuare il downgrade (vedere la sezione 8.2.2.2, "Installazione di pacchetti con APT" [pagina 183]). Tuttavia, con il sistema di rilascio rolling release di Kali, di solito si trova una sola versione di ciascun pacchetto alla volta.

Puoi comunque provare a trovare il vecchio file .deb e installarlo manualmente con dpkg. I vecchi file .deb si possono trovare in diverse posizioni:

- Nella cache di APT in /var/cache/apt/archives/
- Nella directory del pool sul tuo mirror Kali abituale (i pacchetti rimossi e obsoleti vengono conservati per tre o quattro giorni per evitare problemi con gli utenti che non dispongono degli indici dei pacchetti più recenti)
- In https://snapshot.debian.org/ se il pacchetto interessato è stato fornito da Debian e non da Kali; questo servizio conserva le versioni storiche di tutti i pacchetti Debian

[3] https://bugs.kali.org/

[4] https://bugs.debian.org/

Machine Translated by Google

**Gestione degli script di manutenzione non funzionanti** A volte l'aggiornamento viene interrotto perché uno degli script di manutenzione del pacchetto non funziona (di solito si tratta di postinst). In questi casi, è possibile provare a diagnosticare il problema ed eventualmente trovare una soluzione modificando lo script problematico.

In questo caso, ci basiamo sul fatto che gli script di manutenzione sono memorizzati in /var/lib/dpkg/info/ e che possiamo esaminarli e modificarli.

Poiché gli script di manutenzione sono solitamente semplici script di shell, è possibile aggiungere una riga `set -x` subito dopo la riga `shebang` e configurarli per essere rieseguiti (con `dpkg --configure -a` per `postinst`) per vedere con precisione cosa sta succedendo e dove si verifica l'errore. Questo output può anche integrare efficacemente qualsiasi segnalazione di bug che potresti inviare.

Grazie a queste nuove conoscenze, è possibile risolvere il problema alla radice oppure trasformare il comando non funzionante in uno funzionante (ad esempio aggiungendo || true alla fine della riga).

Tieni presente che questo suggerimento non funziona in caso di errore durante la preinstallazione , poiché lo script viene eseguito prima ancora che il pacchetto venga installato, quindi non si trova ancora nella sua posizione finale. Funziona invece per postrm e prerm, anche se in questo caso sarà necessario eseguire la rimozione (o l'aggiornamento) di un pacchetto per attivarli.

Il file di registro di dpkg

Lo strumento dpkg tiene un registro di tutte le sue azioni in /var/log/dpkg.log. Questo registro è estremamente dettagliato, poiché descrive in dettaglio tutte le fasi di ogni pacchetto. Oltre a offrire un modo per tracciare il comportamento di dpkg, aiuta a tenere traccia della cronologia dello sviluppo del sistema: è possibile trovare il momento esatto in cui ogni pacchetto è stato installato o aggiornato, e queste informazioni possono essere estremamente utili per comprendere un recente cambiamento di comportamento. Inoltre, poiché tutte le versioni vengono registrate, è facile confrontare le informazioni con il file changelog.Debian.gz per i pacchetti in questione, o anche con le segnalazioni di bug online.

```
# tail /var/log/dpkg.log
2021-01-06 23:16:37 status installed kali-tools-gpu:amd64 2021.1.0 2021-01-06
23:16:37 remove kali-tools-gpu:amd64 2021.1.0 <none> 2021-01-06 23:16:37
status half-configured kali-tools-gpu:amd64 2021.1.0 2021-01-06 23:16:37 status half-installed
kali-tools-gpu:amd64 2021.1.0 2021-01-06 23:16:37 status config-files kali-tools-gpu:amd64
2021.1.0 2021-01-06 23:16:37 stato non installato kali-tools-gpu:amd64 <nessuno>
```

## Reinstallazione dei pacchetti con apt --reinstall e aptitude reinstall

Quando si danneggia accidentalmente il sistema eliminando o modificando determinati file, il modo più semplice per ripristinarli è reinstallare il pacchetto interessato. Sfortunatamente, il sistema di gestione dei pacchetti rileva che il pacchetto è già installato e si rifiuta gentilmente di reinstallarlo. Per evitare ciò, utilizzare l' opzione --reinstall dei comandi apt e apt-get . Il seguente comando reinstalla *postfix* anche se è già presente:

Machine Translated by Google

```
# apt --reinstall installa postfix
```

La riga di comando di aptitude è leggermente diversa, ma raggiunge lo stesso risultato con il suffisso aptitude reinstall. Il comando dpkg non impedisce la reinstallazione, ma raramente viene richiamato direttamente.

**Non utilizzare apt --reinstall per ripristinare da un attacco**

L'utilizzo del comando apt --reinstall per ripristinare i pacchetti modificati durante un attacco non riporterà certamente il sistema allo stato precedente.

Dopo un attacco, non ci si può fidare di nulla: dpkg e apt potrebbero essere stati sostituiti da programmi dannosi, che non reinstallano i file come desiderato. L'attaccante potrebbe anche aver modificato o creato file al di fuori del controllo di dpkg.

Ricorda che con apt puoi specificare anche una distribuzione specifica, il che significa che puoi tornare a una versione precedente di un pacchetto (se ad esempio sai che funziona bene), a condizione che sia ancora disponibile in una delle sorgenti indicate nel file sources.list : # **apt install w3af/kali-dev**

## Sfruttare la forza per riparare le dipendenze interrotte

Se non si presta attenzione, l'utilizzo di un'opzione --force-* o qualche altro malfunzionamento può portare a un sistema in cui la famiglia di comandi APT si rifiuta di funzionare. In effetti, alcune di queste opzioni consentono l'installazione di un pacchetto anche quando una dipendenza non è soddisfatta o quando si verifica un conflitto. Il risultato è un sistema incoerente dal punto di vista delle dipendenze e i comandi APT si rifiuteranno di eseguire qualsiasi azione tranne quelle che riportano il sistema a uno stato coerente (spesso si tratta di installare la dipendenza mancante o rimuovere un pacchetto problematico). Questo di solito si traduce in un messaggio come questo, ottenuto dopo aver installato una nuova versione *di rdesktop* ignorando la sua dipendenza da una versione più recente di *libc6:*

```
# apt full-upgrade [...]

Potresti voler eseguire il comando 'apt-get -f install' per correggere questi problemi.
I seguenti pacchetti presentano dipendenze non soddisfatte:
 rdesktop: Dipende: libc6 (>= 2.14) ma è installato 2.3.6.ds1-13etch7 E: Dipendenze non
soddisfatte. Prova a usare -f.
```

Se sei un amministratore coraggioso e certo della correttezza della tua analisi, puoi scegliere di ignorare una dipendenza o un conflitto e utilizzare l' opzione --force-* corrispondente . In questo caso, se desideri continuare a utilizzare apt o aptitude, devi modificare il file /var/lib/dpkg/status per eliminare o modificare la dipendenza o il conflitto che hai scelto di ignorare.

Questa manipolazione è un trucco maldestro e non dovrebbe mai essere utilizzata, se non nei casi più estremi di necessità. Molto spesso, una soluzione più appropriata è ricompilare il pacchetto che causa il problema.

Machine Translated by Google

il problema o utilizzare una nuova versione (potenzialmente corretta) da un repository che fornisce backport (i backport sono versioni più recenti ricompilate appositamente per funzionare in un ambiente precedente).

## 8.2.7. Frontend: attitudine e sinapsi

APT è un programma C++ il cui codice risiede principalmente nella libreria condivisa libapt-pkg . Grazie a questa libreria condivisa, si è aperta la strada alla creazione di interfacce utente (front-end), poiché il codice della libreria condivisa può essere facilmente riutilizzato. Storicamente, apt-get era stato progettato solo come front-end di test per libapt-pkg , ma il suo successo tende a oscurare questo fatto.

Nel corso del tempo, nonostante la popolarità delle interfacce a riga di comando come apt e apt-get, sono state sviluppate diverse interfacce grafiche. In questa sezione esamineremo due di queste interfacce: aptitude e synaptic.

### Attitudine

Aptitude, illustrato nella Figura 8.1, "Il gestore di pacchetti Aptitude " [pagina 196], è un programma interattivo utilizzabile in modalità semi-grafica sulla console. È possibile visualizzare l'elenco dei pacchetti installati e disponibili, consultare tutte le informazioni e selezionare i pacchetti da installare o rimuovere. Il programma è progettato specificamente per gli amministratori, pertanto il suo comportamento predefinito è molto più intelligente di quello di APT e la sua interfaccia è molto più intuitiva.

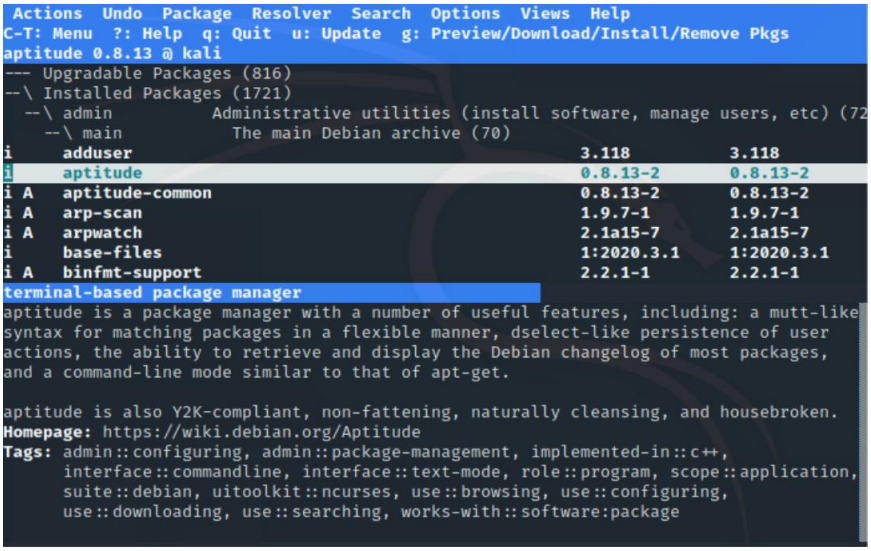



**Figura 8.1** Il gestore dei pacchetti di attitudine

Machine Translated by Google

Quando si esegue aptitude, viene visualizzato un elenco di pacchetti ordinati per stato (installati, non installati o installati ma non disponibili sui mirror), mentre altre sezioni mostrano attività, pacchetti virtuali e nuovi pacchetti apparsi di recente sui mirror. Per facilitare la navigazione tematica, sono disponibili altre visualizzazioni.

In tutti i casi, aptitude visualizza sullo schermo un elenco che combina categorie e pacchetti. Le categorie sono organizzate in una struttura ad albero, i cui rami possono essere espansi o compressi rispettivamente con i tasti Invio, [ e ]. Il tasto + serve per contrassegnare un pacchetto per l'installazione, - per contrassegnarlo per la rimozione e per eliminarlo definitivamente. Si noti che questi tasti possono essere utilizzati anche per le categorie, nel qual caso le azioni corrispondenti verranno applicate a tutti i pacchetti della categoria. Il tasto u aggiorna l'elenco dei pacchetti disponibili e Maiusc+u prepara un aggiornamento globale del sistema. Il tasto g passa a una visualizzazione di riepilogo delle modifiche richieste (e premendo nuovamente g le modifiche verranno applicate), e q esce dalla visualizzazione corrente. Se ci si trova nella visualizzazione iniziale, questo comando chiuderà aptitude.

**Documentazione di aptitude** Questa sezione non tratta i dettagli più specifici dell'utilizzo di aptitude, ma si concentra piuttosto sul fornire un kit di sopravvivenza per l'utente. aptitude è piuttosto ben documentato e consigliamo di utilizzare il suo manuale completo disponibile nel pacchetto aptitude-doc-en (vedere /usr/share/doc/aptitude/html/en/index.html) o all'indirizzo

ÿ https://www.debian.org/doc/manuals/aptitude/

.

Per cercare un pacchetto, puoi digitare / seguito da un modello di ricerca. Questo modello corrisponde al nome del pacchetto, ma può essere applicato anche alla descrizione (se preceduto da ~d), alla sezione (con ~s) o ad altre caratteristiche dettagliate nella documentazione. Gli stessi modelli possono essere utilizzati per filtrare l'elenco dei pacchetti visualizzati: premi il tasto l (come in *limit)* e inserisci il modello.

Gestire il *flag di installazione automatica* dei pacchetti Debian (vedi sezione 8.3.4, "Monitoraggio dei pacchetti installati automaticamente" [pagina 205]) è semplicissimo con aptitude. È possibile sfogliare l'elenco dei pacchetti installati e contrassegnarli come automatici con Maiusc+m oppure rimuovere il contrassegno con il tasto m. I pacchetti automatici vengono visualizzati con una "A" nell'elenco. Questa funzione offre anche un modo semplice per visualizzare i pacchetti in uso su una macchina, senza tutte le librerie e le dipendenze che non interessano. Il pattern correlato che può essere utilizzato con l (per attivare la modalità filtro) è ~i!~M. Specifica che si desidera visualizzare solo i pacchetti installati (~i) non contrassegnati come automatici (!~M).

**Utilizzando l'attitudine su Interfaccia a riga di comando** La maggior parte delle funzionalità di Aptitude è accessibile sia tramite l'interfaccia interattiva che tramite la riga di comando. Queste righe di comando risulteranno familiari agli utenti abituali di apt-get e apt-cache.

Le funzionalità avanzate di aptitude sono disponibili anche da riga di comando. È possibile utilizzare gli stessi modelli di ricerca dei pacchetti della versione interattiva. Ad esempio, se si desidera ripulire l'elenco dei pacchetti installati manualmente e si sa che nessuno dei programmi installati localmente richiede librerie o moduli Perl particolari, è possibile contrassegnare i pacchetti corrispondenti come automatici con un singolo comando:

Machine Translated by Google

```
# aptitude markauto '~slibs|~sperl'
```

Qui si può chiaramente vedere la potenza del sistema di ricerca di Aptitude, che consente la selezione istantanea di tutti i pacchetti nelle sezioni libs e perl .

Attenzione: se alcuni pacchetti sono contrassegnati come automatici e nessun altro pacchetto dipende da essi, verranno rimossi immediatamente (previa richiesta di conferma).

**Gestione di raccomandazioni, suggerimenti e attività** Un'altra caratteristica interessante di aptitude è il fatto che rispetta le raccomandazioni tra i pacchetti, pur dando agli utenti la possibilità di non installarli caso per caso. Ad esempio, il pacchetto *gnome* raccomanda *gdebi* (tra gli altri). Quando si seleziona il primo per l'installazione, anche il secondo verrà selezionato (e contrassegnato come automatico se non già installato sul sistema). Digitando g lo si noterà: *gdebi* compare nella schermata di riepilogo delle azioni in sospeso nell'elenco dei pacchetti installati automaticamente per soddisfare le dipendenze. Tuttavia, è possibile decidere di non installarlo deselezionandolo prima di confermare le operazioni.

Si noti che questa funzionalità di monitoraggio dei consigli non si applica agli aggiornamenti. Ad esempio, se una nuova versione di gnomere consiglia un pacchetto che in precedenza non raccomandava, il pacchetto non verrà contrassegnato per l'installazione. Tuttavia, verrà visualizzato nella schermata di aggiornamento in modo che l'amministratore possa comunque selezionarlo per l'installazione.

Vengono presi in considerazione anche i suggerimenti tra pacchetti, ma in modo adattato al loro specifico stato. Ad esempio, poiché *gnome* suggerisce *dia-gnome,* quest'ultimo verrà visualizzato nella schermata di riepilogo delle azioni in sospeso (nella sezione dei pacchetti suggeriti da altri pacchetti). In questo modo, è visibile e l'amministratore può decidere se prendere in considerazione il suggerimento o meno. Poiché si tratta solo di un suggerimento e non di una dipendenza o di una raccomandazione, il pacchetto non verrà selezionato automaticamente: la sua selezione richiede un intervento manuale (pertanto, il pacchetto non verrà contrassegnato come automatico).

Sempre in quest'ottica, ricordate che Aptitude sfrutta in modo intelligente il concetto di attività. Poiché le attività vengono visualizzate come categorie nelle schermate degli elenchi di pacchetti, è possibile selezionare un'attività completa per l'installazione o la rimozione, oppure sfogliare l'elenco dei pacchetti inclusi nell'attività per selezionarne un sottoinsieme più piccolo.

**Algoritmi di risoluzione migliori** Per concludere questa sezione, notiamo che aptitude ha algoritmi più elaborati rispetto ad apt quando si tratta di risolvere situazioni difficili. Quando viene richiesto un insieme di azioni e quando queste azioni combinate porterebbero a un sistema incoerente, aptitude valuta diversi scenari possibili e li presenta in ordine di rilevanza decrescente. Tuttavia, questi algoritmi non sono infallibili. Fortunatamente, c'è sempre la possibilità di selezionare manualmente le azioni da eseguire. Quando le azioni attualmente selezionate portano a contraddizioni, la parte superiore dello schermo indica un numero di pacchetti danneggiati (è possibile navigare direttamente verso tali pacchetti)

Machine Translated by Google

premendo b). Quindi puoi creare manualmente una soluzione. In particolare, puoi accedere alle diverse versioni disponibili selezionando il pacchetto con Invio. Se la selezione di una di queste versioni risolve il problema, non esitare a utilizzare la funzione. Quando il numero di pacchetti danneggiati si riduce a zero, puoi tranquillamente tornare alla schermata di riepilogo delle azioni in sospeso per un ultimo controllo prima di applicarle.

**Log di Aptitude** Come dpkg, aptitude tiene traccia delle azioni eseguite nel suo file di log (/var/log/aptitude). Tuttavia, poiché entrambi i comandi operano a un livello molto diverso, non è possibile trovare le stesse informazioni nei rispettivi file di log. Mentre dpkg registra tutte le operazioni eseguite sui singoli pacchetti passo dopo passo, aptitude fornisce una visione più ampia delle operazioni di alto livello, come un aggiornamento a livello di sistema.

Attenzione: questo file di registro contiene solo un riepilogo delle operazioni eseguite da aptitude. Se occasionalmente vengono utilizzati altri front-end (o persino dpkg stesso), il log di aptitude conterrà solo una visione parziale delle operazioni, quindi non è possibile farvi affidamento per ricostruire una cronologia affidabile del sistema.

## Sinaptico

Synaptic è un gestore di pacchetti grafico che offre un'interfaccia grafica pulita ed efficiente (mostrata nella Figura 8.2, " Gestore di pacchetti Synaptic" [pagina 200]) basata su GTK+. I suoi numerosi filtri preconfigurati consentono un accesso rapido ai pacchetti appena disponibili, ai pacchetti installati, ai pacchetti aggiornabili, ai pacchetti obsoleti e così via. Scorrendo questi elenchi, è possibile selezionare le operazioni da eseguire sui pacchetti (installazione, aggiornamento, rimozione, disinstallazione completa); queste operazioni non vengono eseguite immediatamente, ma vengono inserite in un elenco di attività. Un singolo clic su un pulsante conferma quindi le operazioni, che vengono eseguite in un'unica soluzione.

Machine Translated by Google

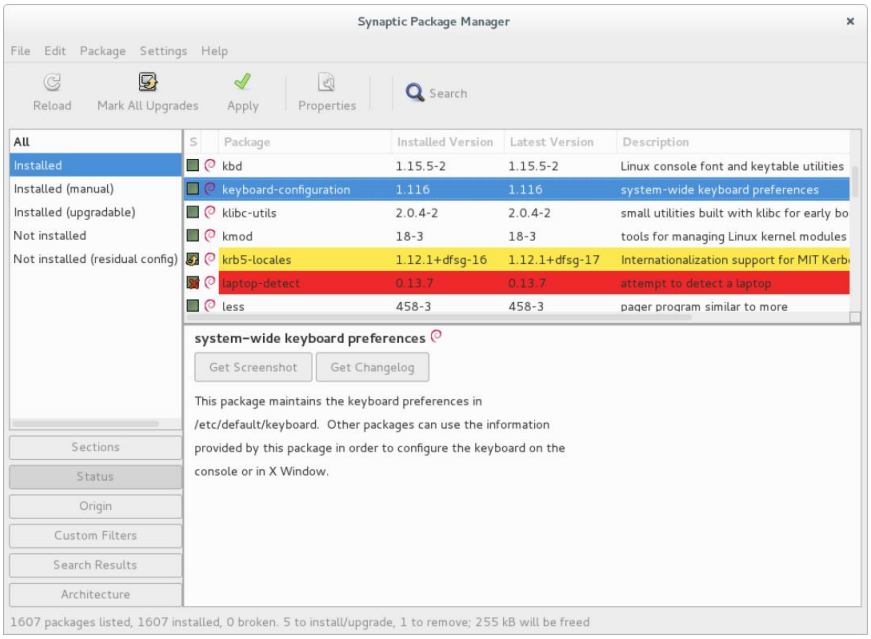



**Figura 8.2** Gestore di pacchetti sinaptici

## 8.3. Configurazione e utilizzo avanzati di APT

È giunto il momento di approfondire argomenti più avanzati. Innanzitutto, esamineremo la configurazione avanzata di APT, che vi permetterà di impostare opzioni più permanenti applicabili agli strumenti APT. Successivamente, mostreremo come manipolare le priorità dei pacchetti, aprendo la strada ad aggiornamenti e upgrade personalizzati e di precisione. Vi mostreremo anche come gestire più distribuzioni, in modo da poter iniziare a sperimentare con pacchetti provenienti da altre distribuzioni.
Successivamente, esamineremo come tenere traccia dei pacchetti installati automaticamente, una funzionalità che consente di gestire i pacchetti installati tramite dipendenze. Spiegheremo anche come il supporto multi-architettura apra le porte all'esecuzione di pacchetti creati per diverse architetture hardware. Infine, discuteremo i protocolli crittografici e le utilità disponibili che consentono di convalidare l'autenticità di ciascun pacchetto.

### 8.3.1. Configurazione di APT

Prima di addentrarci nella configurazione di APT, prendiamoci un momento per discutere il meccanismo di configurazione di un sistema basato su Debian. Storicamente, la configurazione veniva gestita tramite file di configurazione dedicati. Tuttavia, nei moderni sistemi Linux come Debian e Kali, le directory di configurazione con il suffisso .d stanno diventando sempre più comuni. Ogni directory rappresenta una configurazione

Machine Translated by Google

file che viene suddiviso in più file. In questo senso, tutti i file in /etc/apt/apt.conf.d/ sono istruzioni per la configurazione di APT. APT elabora i file in ordine alfabetico, in modo che i file successivi possano modificare gli elementi di configurazione definiti nei file precedenti.

Questa struttura offre una certa flessibilità agli amministratori e ai manutentori dei pacchetti, consentendo loro di apportare modifiche alla configurazione del software tramite l'aggiunta di file senza dover modificare un file esistente. Ciò è particolarmente utile per i manutentori dei pacchetti, poiché possono utilizzare questo approccio per adattare la configurazione di altri software e garantire la perfetta coesistenza con il proprio, senza violare la politica di Debian che vieta esplicitamente la modifica dei file di configurazione di altri pacchetti. Grazie al meccanismo di configurazione .d , non è necessario seguire manualmente le istruzioni di configurazione di più pacchetti , che si trovano in genere nel file /usr/share/doc/package/README.Debian del pacchetto , poiché il programma di installazione può inserire i file di configurazione.

| | |
|---|---|
| **Attenzione ai file di configurazione generati dalle directory .d** | Sebbene APT supporti nativamente la directory /etc/apt/apt.conf.d , non è sempre così. Per alcune applicazioni (come Exim, ad esempio), la directory .d è un'aggiunta specifica di Debian utilizzata come input per generare dinamicamente il file di configurazione canonico utilizzato dall'applicazione. In questi casi, i pacchetti forniscono un comando "update-*" (ad esempio: update-exim4.conf) che concatena i file dalla directory .d e sovrascrive il file di configurazione principale.<br><br>In questi casi, non è necessario modificare manualmente il file di configurazione principale, poiché le modifiche andranno perse alla successiva esecuzione del comando update-* . Inoltre, è importante non dimenticare di eseguire il comando precedente dopo aver modificato un file nella directory .d (altrimenti le modifiche non verranno applicate). |

Ora che abbiamo compreso il meccanismo di configurazione .d , vediamo come sfruttarlo per configurare APT. Come abbiamo già detto, è possibile modificare il comportamento di APT tramite argomenti da riga di comando per dpkg , come in questo esempio, che esegue un'installazione sovrascritta forzata di zsh:

```
# apt -o Dpkg::Options::=”--force-overwrite” install zsh
```

Ovviamente questo è molto macchinoso, soprattutto se si utilizzano spesso le opzioni, ma è anche possibile utilizzare la struttura di configurazione della directory .d per configurare alcuni aspetti di APT aggiungendo direttive a un file nella directory /etc/apt/apt.conf.d/ . Ad esempio, questa (e qualsiasi altra) direttiva può essere facilmente aggiunta a un file in /etc/apt/apt.conf.d/. Il nome di questo file è in qualche modo arbitrario, ma una convenzione comune è quella di utilizzare local o 99local:

```
$ cat /etc/apt/apt.conf.d/99local Dpkg::Options
{ ”--force-overwrite”;

}
```

Esistono molte altre utili opzioni di configurazione e certamente non possiamo trattarle tutte, ma una che prenderemo in considerazione riguarda la connettività di rete. Ad esempio, se puoi accedere solo al web

Machine Translated by Google

Se si utilizza un proxy, aggiungere una riga come Acquire::http::proxy "http://yourproxy:3128". Per un proxy FTP, utilizzare Acquire::ftp::proxy "ftp://yourproxy".

Per scoprire ulteriori opzioni di configurazione, leggere la pagina del manuale apt.conf(5) con il comando man apt.conf (per dettagli sulle pagine del manuale, vedere la sezione 6.1.1, "Pagine del manuale" [pagina 128]).

### 8.3.2. Gestione delle priorità dei pacchetti

Uno degli aspetti più importanti nella configurazione di APT è la gestione delle priorità associate a ciascuna sorgente di pacchetti. Ad esempio, potresti voler estendere il tuo sistema Kali Linux con uno o due pacchetti più recenti provenienti da Debian Unstable o Debian Experimental. È possibile assegnare una priorità a ciascun pacchetto disponibile (lo stesso pacchetto può avere diverse priorità a seconda della sua versione o della distribuzione che lo fornisce). Queste priorità influenzeranno il comportamento di APT: per ogni pacchetto, verrà sempre selezionata la versione con la priorità più alta (tranne nel caso in cui questa versione sia precedente a quella installata e la sua priorità sia inferiore a 1000).

APT definisce diverse priorità predefinite. Ogni versione di pacchetto installata ha una priorità di 100. Una versione non installata ha una priorità di 500 per impostazione predefinita, ma può arrivare a 990 se fa parte della release di destinazione (definita con l' opzione da riga di comando -t o con la direttiva di configurazione APT::Default-Release ).

È possibile modificare le priorità aggiungendo voci al file /etc/apt/preferences con i nomi dei pacchetti interessati, la loro versione, la loro origine e la loro nuova priorità.

APT non installerà mai una versione precedente di un pacchetto (ovvero un pacchetto il cui numero di versione è inferiore a quello del pacchetto attualmente installato), tranne quando la sua priorità è superiore a 1000.
APT installerà sempre il pacchetto con la priorità più alta che rispetti questo vincolo. Se due pacchetti hanno la stessa priorità, APT installa quello più recente (quello con il numero di versione più alto). Se due pacchetti della stessa versione hanno la stessa priorità ma differiscono nel contenuto, APT installa la versione non ancora installata (questa regola è stata creata per gestire il caso di un aggiornamento del pacchetto senza l'incremento del numero di revisione, che di solito è richiesto).

In termini più concreti, un pacchetto con priorità inferiore a 0 non verrà mai installato. Un pacchetto con priorità compresa tra 0 e 100 verrà installato solo se non è già installata un'altra versione dello stesso pacchetto. Con una priorità compresa tra 100 e 500, il pacchetto verrà installato solo se non è presente una versione più recente installata o disponibile in un'altra distribuzione. Un pacchetto con priorità compresa tra 501 e 990 verrà installato solo se non è presente una versione più recente installata o disponibile nella distribuzione di destinazione. Con una priorità compresa tra 990 e 1000, il pacchetto verrà installato a meno che la versione già installata non sia più recente. Una priorità superiore a 1000 comporterà sempre l'installazione del pacchetto, anche se ciò costringe APT a effettuare il downgrade a una versione precedente.

Quando APT controlla /etc/apt/preferences, prende in considerazione prima le voci più specifiche (spesso quelle che specificano il pacchetto in questione), poi quelle più generiche (incluse ad esempio tutte le voci di una distribuzione). Se esistono diverse voci generiche, viene utilizzata la prima corrispondenza. I criteri di selezione disponibili includono il nome del pacchetto e la sorgente che lo fornisce. Ogni pacchetto

Machine Translated by Google

La sorgente viene identificata dalle informazioni contenute in un file Release che APT scarica insieme ai file Packages . Questi file specificano l'origine, solitamente "Kali" per i pacchetti provenienti dai mirror ufficiali di Kali e "Debian" per i pacchetti provenienti dai mirror ufficiali di Debian, ma l'origine può anche essere il nome di una persona o di un'organizzazione per i repository di terze parti. Il file Release fornisce anche il nome della distribuzione insieme alla sua versione. Analizziamo la sua sintassi attraverso alcuni casi di studio realistici di questo meccanismo.

**Priorità di Debian Sperimentale**

Se hai incluso Debian experimental nel tuo file sources.list , i pacchetti corrispondenti non verranno quasi mai installati perché la loro priorità APT predefinita è 1. Questo è ovviamente un caso specifico, progettato per impedire agli utenti di installare per errore pacchetti di experimental. I pacchetti possono essere installati solo digitando apt install package/ experimental, ammesso ovviamente che tu sia consapevole dei rischi e dei potenziali problemi derivanti dall'utilizzo di versioni non convenzionali. È comunque possibile (anche se sconsigliato) trattare i pacchetti di experimental come quelli di altre distribuzioni, assegnando loro una priorità di 500. Questo si fa con una voce specifica in /etc/apt/preferences:

```
Pacchetto: *
Pin: rilascio a=sperimentale
Priorità PIN: 500
```

Supponiamo che tu voglia utilizzare solo i pacchetti di Kali e che i pacchetti Debian vengano installati solo quando esplicitamente richiesti. Puoi scrivere le seguenti voci nel file delle preferenze /etc/apt/ (o in qualsiasi file in /etc/apt/preferences.d/):

```
Pacchetto: *
Pin: rilascio o=Kali
Priorità PIN: 900

Pacchetto: *
Pin: release o=Debian
Priorità PIN: -10
```

Negli ultimi due esempi, avete visto a=experimental, che definisce il nome della distribuzione selezionata, e o=Kali e o=Debian, che limitano l'ambito ai pacchetti la cui origine è rispettivamente Kali e Debian.

Supponiamo ora di avere un server con diversi programmi locali che dipendono dalla versione 5.22 di Perl e di voler garantire che gli aggiornamenti non installino una versione diversa. È possibile utilizzare questa voce:

```
Pacchetto: perl Pin:
versione 5.22* Priorità Pin:
1001
```

La documentazione di riferimento per questo file di configurazione è disponibile nella pagina del manuale apt_preferences(5), che puoi visualizzare con man apt_preferences.

Machine Translated by Google

| | |
|---|---|
| **Aggiungere commenti in /etc/apt/preferences** | Non esiste una sintassi ufficiale per i commenti in /etc/apt/preferences, ma è possibile fornire alcune descrizioni testuali anteponendo uno o più campi Explanation a ciascuna voce:<br>Spiegazione: Il pacchetto xserver-xorg-video-intel fornito<br>Spiegazione: in ambito sperimentale può essere utilizzato in sicurezza<br>Pacchetto: xserver-xorg-video-intel<br>Pin: rilascio a=sperimentale<br>Priorità PIN: 500 |

## 8.3.3. Lavorare con diverse distribuzioni

Considerato che apt è uno strumento così straordinario, probabilmente vorrai immergerti nel suo mondo e iniziare a sperimentare con pacchetti provenienti da altre distribuzioni. Ad esempio, dopo aver installato un sistema Kali Rolling, potresti voler provare un pacchetto software disponibile in Kali Dev, Debian Unstable o Debian Experimental senza discostarti troppo dallo stato iniziale del sistema.

Anche se occasionalmente si possono riscontrare problemi mescolando pacchetti provenienti da distribuzioni diverse, apt gestisce tale coesistenza in modo molto efficace e limita i rischi (a condizione che le dipendenze dei pacchetti siano corrette). Innanzitutto, elenca tutte le distribuzioni utilizzate in /etc/apt/sources.list e definisci la tua distribuzione di riferimento con il parametro APT::Default-Release (vedi la sezione 8.2.3, "Aggiornamento di Kali Linux" [pagina 184]).

Supponiamo che Kali Rolling sia la tua distribuzione di riferimento, ma che Kali Dev e Debian Unstable siano anch'esse elencate nel tuo file sources.list . In questo caso, puoi usare `apt install package/unstable` per installare un pacchetto da Debian Unstable. Se l'installazione fallisce a causa di dipendenze non soddisfatte, puoi risolvere tali dipendenze all'interno di Unstable aggiungendo il parametro `-t un-stable` .

In questa situazione, gli aggiornamenti (upgrade e full-upgrade) vengono eseguiti all'interno di Kali Rolling, ad eccezione dei pacchetti già aggiornati a un'altra distribuzione: questi seguiranno gli aggiornamenti disponibili nelle altre distribuzioni. Spiegheremo questo comportamento con l'aiuto delle priorità predefinite impostate da APT più avanti. Non esitate a utilizzare la policy apt-cache (vedere il riquadro "Utilizzo della policy apt-cache" [pagina 204]) per verificare le priorità assegnate.

Tutto si basa sul presupposto che APT consideri solo i pacchetti di versione superiore o uguale a quella del pacchetto installato (supponendo che /etc/apt/preferences non sia stato utilizzato per forzare priorità superiori a 1000 per alcuni pacchetti).

| | |
|---|---|
| **Utilizzo di apt-cache policy** | Per comprendere meglio il meccanismo di priorità, non esitate a eseguire apt-cache policy per visualizzare la priorità predefinita associata a ciascuna sorgente di pacchetto. Potete anche utilizzare apt-cache policy package per visualizzare le priorità di tutte le versioni disponibili di un determinato pacchetto. |

Machine Translated by Google

Supponiamo di aver installato la versione 1 di un primo pacchetto da *Kali Rolling* e che le versioni 2 e 3 siano disponibili rispettivamente in *Kali Dev* e *Debian Unstable.* La versione installata ha priorità 100, mentre la versione disponibile in *Kali Rolling* (la stessa) ha priorità 990 (perché fa parte della release di destinazione). I pacchetti in *Kali Dev* e *Debian Unstable* hanno priorità 500 (la priorità predefinita di una versione non installata). La versione vincente è quindi la versione 1 con priorità 990.
Il pacchetto rimane in *Kali Rolling.*

Prendiamo come esempio un altro pacchetto la cui versione 2 è stata installata da *Kali Dev.* La versione 1 è disponibile in *Kali Rolling* e la versione 3 in *Debian Unstable.* La versione 1 (con priorità 990, quindi inferiore a 1000) viene scartata perché è inferiore alla versione installata. Rimangono quindi solo le versioni 2 e 3, entrambe con priorità 500. Di fronte a questa alternativa, APT seleziona la versione più recente, quella di *Debian Unstable.* Se non si desidera che un pacchetto installato da *Kali Dev* venga migrato a *Debian Unstable,* è necessario assegnare una priorità inferiore a 500 (ad esempio 490) ai pacchetti provenienti da *Debian Unstable.* È possibile modificare il file /etc/apt/preferences a questo scopo:

```
Pacchetto: *
Pin: rilascio a=instabile
Priorità PIN: 490
```

### 8.3.4. Monitoraggio dei pacchetti installati automaticamente

Una delle funzionalità essenziali di apt è il monitoraggio dei pacchetti installati esclusivamente tramite dipendenze. Questi pacchetti sono detti *automatici* e spesso includono librerie.

Grazie a queste informazioni, quando i pacchetti vengono rimossi, i gestori di pacchetti possono calcolare un elenco di pacchetti automatici che non sono più necessari (perché non ci sono pacchetti installati manualmente che dipendono da essi). Il comando `apt autoremove` rimuoverà questi pacchetti. Aptitude non dispone di questo comando perché li rimuove automaticamente non appena vengono identificati. In tutti i casi, gli strumenti visualizzano un messaggio chiaro che elenca i pacchetti interessati.

È buona norma contrassegnare come automatico qualsiasi pacchetto di cui non si abbia bisogno immediatamente, in modo che venga rimosso automaticamente quando non è più necessario. È possibile utilizzare `apt-mark auto package` per contrassegnare un determinato pacchetto come automatico, mentre `apt-mark manual package` fa l'opposto. `aptitude markauto` e `aptitude unmarkauto` funzionano allo stesso modo, sebbene offrano più funzionalità per contrassegnare più pacchetti contemporaneamente (vedere la sezione 8.2.7.1, "Aptitude" [pagina 196]). L'interfaccia interattiva basata su console di Aptitude semplifica anche la revisione del flag automatico su molti pacchetti.

Potresti voler sapere perché un pacchetto installato automaticamente è presente sul sistema. Per ottenere queste informazioni dalla riga di comando, puoi usare `aptitude why package` (apt e apt-get non hanno una funzione simile):

```
$ aptitude perché python-debian i
aptitude                Raccomanda apt-xapian-index i A
apt-xapian-index Dipende                python-debian (>= 0.1.15)
```

Machine Translated by Google

### 8.3.5. Sfruttare il supporto multi-arco

Tutti i pacchetti Debian hanno un campo Architecture nelle loro informazioni di controllo. Questo campo può contenere "all" (per i pacchetti indipendenti dall'architettura) oppure il nome dell'architettura di destinazione (come amd64 o armhf). In quest'ultimo caso, per impostazione predefinita, dpkg installerà il pacchetto solo se la sua architettura corrisponde all'architettura dell'host, come restituito da dpkg --print-architecture.

Questa restrizione garantisce che non si ottengano file binari compilati per un'architettura errata. Tutto sarebbe perfetto se non fosse che (alcuni) computer possono eseguire file binari per più architetture, sia nativamente (un sistema amd64 può eseguire file binari i386) sia tramite emulatori.

#### Abilitazione Multi-Arch

Il supporto multi-architettura per dpkg consente agli utenti di definire architetture esterne che possono essere installate sul sistema corrente. Questo si fa facilmente con dpkg --add-architecture, come nell'esempio seguente in cui è necessario aggiungere l'architettura i386 al sistema amd64 per eseguire applicazioni Microsoft Windows utilizzando Wine[5]. Esiste un comando corrispondente , `dpkg --remove-architecture`, per rimuovere il supporto di un'architettura diversa, ma può essere utilizzato solo quando non sono più installati pacchetti di tale architettura.

```
# dpkg --print-architecture amd64

# wine
sembra che wine32 manchi, dovresti installarlo. È necessario prima abilitare multiarch. Come root,
esegui "dpkg --add-architecture i386 & apt-get update & apt-get install wine32"


Utilizzo: wine PROGRAMMA [ARGOMENTI...] Esegue il programma specificato wine --help Visualizza questo aiuto
                ed esce wine --version Visualizza le informazioni sulla versione ed esce

# dpkg --add-architecture i386 # dpkg --print-foreign-
architectures i386 # apt update [...] # apt install wine32 [...]




Configurazione di libwine:i386 (1.8.6-5) ...
Configurazione di vdpau-driver-all:i386 (1.1.1-6) ...
Configurazione di wine32:i386 (1.8.6-5) ...
```

[5] https://www.winehq.org/

Machine Translated by Google

```
Configurazione di libasound2-plugins:i386 (1.1.1-1) ...
Trigger di elaborazione per libc-bin (2.24-9) # wine

Utilizzo: wine PROGRAMMA [ARGOMENTI...] Esegui il programma specificato wine --help wine --version
                                                    Visualizza questo messaggio di aiuto ed esci
                                                    Visualizza le informazioni sulla versione ed esci
# dpkg --remove-architecture i386 dpkg: errore:
impossibile rimuovere l'architettura 'i386' attualmente in uso dal database # dpkg --print-foreign-architectures i386
```

APT rileverà automaticamente quando dpkg è stato configurato per supportare architetture diverse e avvierà il download dei file dei pacchetti corrispondenti durante il processo di aggiornamento.

I pacchetti esterni possono quindi essere installati con il comando apt install package:architecture.

**Utilizzo di i386 proprietario Binari su amd64**

Esistono molteplici casi d'uso per il supporto multi-architettura, ma il più diffuso è la possibilità di eseguire binari a 32 bit (i386) su sistemi a 64 bit (amd64), soprattutto perché diverse applicazioni proprietarie popolari (come Skype) sono disponibili solo in versione a 32 bit.

## Modifiche relative a più archi

Per rendere il supporto multi-architettura effettivamente utile e utilizzabile, le librerie hanno dovuto essere riconfezionate e spostate in una directory specifica per l'architettura, in modo che più copie (destinate ad architetture diverse) potessero essere installate contemporaneamente. Tali pacchetti aggiornati contengono il campo di intestazione Multi-Arch: same per indicare al sistema di packaging che le diverse architetture del pacchetto possono essere installate insieme in sicurezza (e che tali pacchetti possono soddisfare solo le dipendenze di pacchetti della stessa architettu

```
$ dpkg -s libwine dpkg-
query: errore: --status richiede un nome di pacchetto valido ma 'libwine' non lo è: ambiguo
      ÿ nome del pacchetto 'libwine' con più di un'istanza installata

Utilizzare --help per assistenza sull'interrogazione dei pacchetti. $ dpkg -s
libwine:amd64 libwine:i386 | grep ^Multi Multi-Arch: same Multi-Arch: same $
dpkg -L libgcc1:amd64 |
grep .so [...] /usr/lib/x86_64-
linux-gnu/wine/libwine.so.1 $ dpkg -S /usr/share/doc/
 libwine/
copyright libwine:amd64, libwine:i386: /usr/share/doc/libwine/copyright
```

Vale la pena notare che Multi-Arch: gli stessi pacchetti devono avere i loro nomi qualificati con la loro architettura per essere identificabili in modo univoco. Questi pacchetti possono anche condividere file con altri

Machine Translated by Google

istanze dello stesso pacchetto; dpkg garantisce che tutti i pacchetti abbiano file identici bit per bit quando vengono condivisi. Inoltre, tutte le istanze di un pacchetto devono avere la stessa versione, quindi devono essere aggiornate insieme.

Il supporto multi-architettura comporta anche alcune interessanti sfide per quanto riguarda la gestione delle dipendenze. Per soddisfare una dipendenza è necessario un pacchetto contrassegnato come Multi-Arch: foreign oppure un pacchetto la cui architettura corrisponda a quella del pacchetto che dichiara la dipendenza (in questo processo di risoluzione delle dipendenze, si presume che i pacchetti indipendenti dall'architettura abbiano la stessa architettura dell'host). Una dipendenza può anche essere indebolita per consentire a qualsiasi architettura di soddisfarla, con la sintassi package:any , ma i pacchetti foreign possono soddisfare tale dipendenza solo se sono contrassegnati come Multi-Arch: allowed.

### 8.3.6. Convalida dell'autenticità del pacchetto

Gli aggiornamenti di sistema sono operazioni molto delicate ed è fondamentale assicurarsi di installare solo pacchetti ufficiali dai repository di Kali. Se il mirror di Kali che stai utilizzando è stato compromesso, un hacker potrebbe tentare di aggiungere codice dannoso a un pacchetto altrimenti legittimo.
Un pacchetto di questo tipo, se installato, potrebbe fare tutto ciò per cui è stato progettato dall'autore, inclusa la divulgazione di password o informazioni riservate. Per ovviare a questo rischio, Kali fornisce un sigillo antimanomissione per garantire, al momento dell'installazione, che un pacchetto provenga effettivamente dal suo fornitore ufficiale e non sia stato modificato da terzi.

Il sigillo funziona con una catena di hash crittografici e una firma. Il file firmato è il file Release , fornito dai mirror di Kali. Contiene un elenco dei file Packages (incluse le loro forme compresse, Packages.gz e Packages.xz, e le versioni incrementali), insieme ai relativi hash MD5, SHA1 e SHA256, che garantiscono che i file non siano stati manomessi. Questi file Packages contengono a loro volta un elenco dei pacchetti Debian disponibili sul mirror, insieme ai relativi hash, garantendo che anche il contenuto dei pacchetti stessi non sia stato alterato.

Le chiavi attendibili vengono gestite tramite il comando apt-key, presente nel pacchetto *apt* . Questo programma mantiene un portachiavi di chiavi pubbliche GnuPG, utilizzate per verificare le firme nei file Release.gpg disponibili sui mirror. È possibile utilizzarlo per aggiungere manualmente nuove chiavi (quando sono necessari mirror non ufficiali). Generalmente, tuttavia, sono sufficienti le chiavi ufficiali di Kali. Queste chiavi vengono aggiornate automaticamente dal pacchetto *kali-archive-keyring* (che inserisce i portachiavi corrispondenti in /etc/apt/trusted.gpg.d). Tuttavia, la prima installazione di questo pacchetto richiede cautela: anche se il pacchetto è firmato come qualsiasi altro, la firma non può essere verificata esternamente.
Gli amministratori più prudenti dovrebbero quindi verificare le impronte digitali delle chiavi importate prima di utilizzarle per installare nuovi pacchetti:

```
# apt-key fingerprint
Attenzione: apt-key è deprecato. Gestisci invece i file del portachiavi in trusted.gpg.d (vedi apt-key(8)). /etc/apt/trusted.gpg.d/debian-
archive-buster-automatic.gpg
 ---------------------------------------------------------------

pub rsa4096 2019-04-14 [SC] [scadenza: 2027-04-12]
          80D1 5823 B7FD 1561 F9F7 BCDD DC30 D7C2 3CBB ABEE
uid                   [sconosciuto] Chiave di firma automatica dell'archivio Debian (10/buster) <ftpmaster@debian.org>
```

Machine Translated by Google

```
sub rsa4096 2019-04-14 [S] [scadenza: 2027-04-12]

/etc/apt/trusted.gpg.d/debian-archive-buster-security-automatic.gpg
--------------------------------------------------------------------

pub rsa4096 2019-04-14 [SC] [scadenza: 2027-04-12]
      5E61 B217 265D A980 7A23 C5FF 4DFA B270 CAA9 6DFA
uid [ sconosciuto] Chiave di firma automatica dell'archivio di sicurezza Debian (10/buster) <ftpmaster@debian.org> sub rsa4096 2019-04-14 [S] [scadenza: 2027-04-12]


/etc/apt/trusted.gpg.d/debian-archive-buster-stable.gpg
-------------------------------------------------------

pub rsa4096 2019-02-05 [SC] [scadenza: 2027-02-03]
      6D33 866E DD8F FA41 C014 3AED DCC9 EFBF 77E1 1517 [ sconosciuto] Chiave
uid                   di rilascio stabile di Debian (10/buster) <debian-release@lists.debian.org>

/etc/apt/trusted.gpg.d/debian-archive-jessie-automatic.gpg
----------------------------------------------------------

pub rsa4096 2014-11-21 [SC] [scadenza: 2022-11-19]
      126C 0D24 BD8A 2942 CC7D F8AC 7638 D044 2B90 D010
uid                   [sconosciuto] Chiave di firma automatica dell'archivio Debian (8/jessie) <ftpmaster@debian.org>

/etc/apt/trusted.gpg.d/debian-archive-jessie-security-automatic.gpg
-------------------------------------------------------------------

pub rsa4096 2014-11-21 [SC] [scadenza: 2022-11-19]
      D211 6914 1CEC D440 F2EB 8DDA 9D6D 8F6B C857 C906
uid                   [sconosciuto] Chiave di firma automatica dell'archivio di sicurezza Debian (8/jessie) <ftpmaster@debian.org>

/etc/apt/trusted.gpg.d/debian-archive-jessie-stable.gpg
-------------------------------------------------------

pub rsa4096 2013-08-17 [SC] [scadenza: 2021-08-15]
      75DD C3C4 A499 F1A1 8CB5 F3C8 CBF8 D6FD 518E 17E1
uid                   [sconosciuto] Chiave di rilascio stabile di Jessie <debian-release@lists.debian.org>

/etc/apt/trusted.gpg.d/debian-archive-stretch-automatic.gpg
----------------------------------------------------------

pub rsa4096 2017-05-22 [SC] [scadenza: 2025-05-20]
      E1CF 20DD FFE4 B89E 8026 58F1 E0B1 1894 F66A EC98
uid                   [sconosciuto] Chiave di firma automatica dell'archivio Debian (9/stretch) <ftpmaster@debian.org>
sub rsa4096 2017-05-22 [S] [scadenza: 2025-05-20]

/etc/apt/trusted.gpg.d/debian-archive-stretch-security-automatic.gpg
--------------------------------------------------------------------

pub rsa4096 2017-05-22 [SC] [scadenza: 2025-05-20]
      6ED6 F5CB 5FA6 FB2F 460A E88E EDA0 D238 8AE2 2BA9
uid [ sconosciuto] Chiave di firma automatica dell'archivio di sicurezza Debian (9/stretch) <ftpmaster@debian.org> sub rsa4096 2017-05-22 [S] [scadenza: 2025-05-20]


/etc/apt/trusted.gpg.d/debian-archive-stretch-stable.gpg
-------------------------------------------------------

pub rsa4096 2017-05-20 [SC] [scadenza: 2025-05-18]
      067E 3C45 6BAE 240A CEE8 8F6F EF0F 382A 1A7B 6500
uid                   [sconosciuto] Chiave di rilascio stabile di Debian (9/stretch) <debian-release@lists.debian.org>

/etc/apt/trusted.gpg.d/kali-archive-keyring.gpg
-----------------------------------------------

pub rsa4096 2012-03-05 [SC] [scadenza: 2023-01-16]
      44C6 513A 8E4F B3D3 0875 F758 ED44 4FF0 7D8D 0BF6
uid                   [sconosciuto] Repository di Kali Linux <devel@kali.org>
sub rsa4096 2012-03-05 [E] [scadenza: 2023-01-16]
```

Quando si aggiunge una sorgente di pacchetti di terze parti al file sources.list , è necessario dire ad APT di fidarsi della corrispondente chiave di autenticazione GPG (altrimenti continuerà a segnalare che non può garantire l'autenticità dei pacchetti provenienti da quel repository). Il primo passo è ovviamente

Machine Translated by Google

per ottenere la chiave pubblica. Nella maggior parte dei casi, la chiave verrà fornita come un piccolo file di testo, che nei seguenti esempi chiameremo key.asc .

Per aggiungere la chiave al portachiavi attendibile, l'amministratore può eseguire il comando `apt-key add < key.asc >`. Un altro metodo consiste nell'utilizzare l' interfaccia grafica Synaptic : la scheda Autenticazione nel menu Impostazioni ÿ Repository offre la possibilità di importare una chiave dal file key.asc .

Per chi preferisce un'applicazione dedicata e maggiori dettagli sulle chiavi attendibili, è possibile utilizzare gui-apt-key (nell'omonimo pacchetto), una piccola interfaccia grafica che gestisce il portachiavi attendibile.

Una volta che le chiavi appropriate sono nel portachiavi, APT verificherà le firme prima di qualsiasi operazione rischiosa, in modo che le interfacce visualizzino un avviso se viene richiesto di installare un pacchetto la cui autenticità non può essere accertata.

## 8.4. Riferimento ai pacchetti APT: Approfondimento del sistema di pacchetti Debian tem

È giunto il momento di addentrarci a fondo nel sistema di pacchetti di Debian e Kali. A questo punto, andremo oltre gli strumenti e la sintassi per concentrarci sugli aspetti più tecnici del sistema di pacchettizzazione. Questa analisi approfondita vi aiuterà a comprendere il funzionamento di APT a livello fondamentale e vi fornirà spunti su come ottimizzare e personalizzare il vostro sistema Kali. Non è necessario memorizzare tutto il materiale di questa sezione, ma la guida e i materiali di riferimento vi saranno utili man mano che acquisirete maggiore familiarità con il sistema Kali Linux.

Finora, avete interagito con i dati dei pacchetti APT attraverso i vari strumenti progettati per interfacciarsi con essi. Ora, approfondiremo l'argomento ed esamineremo l'interno dei pacchetti, analizzando le *meta-informazioni* interne (ovvero le informazioni relative ad altre informazioni) utilizzate dagli strumenti di gestione dei pacchetti.

Questa combinazione di archivio di file e di metadati è direttamente visibile nella struttura di un file .deb , che è semplicemente un archivio ar , che concatena tre file:

```
$ ar t /var/cache/apt/archives/apt_1.4~beta1_amd64.deb debian-binary control.tar.gz
data.tar.xz
```

Il file debian-binary contiene un singolo numero di versione che descrive il formato dell'archivio:

```
$ ar p /var/cache/apt/archives/apt_1.4~beta1_amd64.deb debian-binary 2.0
```

L' archivio control.tar.gz contiene metadati:

```
$ ar p /var/cache/apt/archives/apt_1.4~beta1_amd64.deb control.tar.gz | tar -tzf - ./
```

Machine Translated by Google

```
./conffiles ./
control ./
md5sums ./
postinst ./
postrm ./
preinst ./
prerm ./
shlibs ./
triggers
```

Infine, l' archivio data.tar.xz (il formato di compressione potrebbe variare) contiene i file effettivi da installare sul file system:

```
$ ar p /var/cache/apt/archives/apt_1.4~beta1_amd64.deb data.tar.xz | tar -tJf - ./ ./etc/ ./etc/apt/ ./etc/apt/apt.conf.d/ ./etc/

apt/
apt.conf.d/
01autoremove ./etc/apt/
preferences.d/ ./etc/apt/sources.list.d/ ./etc/apt/
trusted.gpg.d/ ./etc/cron.daily/ ./etc/
cron.daily/apt-compat ./etc/kernel/ ./etc/
kernel/postinst.d/ ./etc/kernel/postinst.d/
apt-auto-removal ./etc/
logrotate.d/ ./etc/logrotate.d/apt ./lib/ ./lib/
systemd/ [...]
```

Tieni presente che in questo esempio stai visualizzando un pacchetto .deb nella cache degli archivi di APT e che il tuo archivio potrebbe contenere file con numeri di versione diversi da quelli mostrati.

In questa sezione, introdurremo le meta-informazioni contenute in ogni pacchetto e mostreremo come sfruttarle.

### 8.4.1. Il file di controllo

Cominceremo esaminando il file di controllo , contenuto nell'archivio control.tar.gz .
Il file di controllo contiene le informazioni più importanti relative al pacchetto. Utilizza una struttura simile alle intestazioni delle email e può essere visualizzato con il comando dpkg -I . Ad esempio, il file di controllo per *apt* ha questo aspetto:

Machine Translated by Google

```
$ dpkg -I apt_1.4~beta1_amd64.deb control Pacchetto: apt
Versione: 1.4~beta1
Architettura: amd64
Manutentore: APT Development
Team <deity@lists.debian.org> Dimensione installata: 3478 Dipendenze: adduser, gpgv | gpgv2 |
gpgv1, debian-archive-keyring,
init-system-helpers (>=
      ÿ 1.18~), libapt-pkg5.0 (>= 1.3~rc2), libc6 (>= 2.15), libgcc1 (>= 1:3.0), ÿ libstdc++6 (>= 5.2)

Raccomanda: gnupg | gnupg2 | gnupg1
Suggerisce: apt-doc, aptitude | synaptic | wajig, dpkg-dev (>= 1.17.2), powermgmt-base,
      ÿ python-apt
Interrompe: apt-utils (<< 1.3~exp2~)
Sostituisce: apt-utils (<< 1.3~exp2~)
Sezione: amministrazione
Priorità: importante
Descrizione: gestore di pacchetti da riga di comando
 Questo pacchetto fornisce strumenti da riga di comando per la ricerca, la gestione
 e l'interrogazione di informazioni sui pacchetti, offrendo un accesso di basso
 livello a tutte le funzionalità della libreria libapt-pkg.
 .
 Questi includono: apt-
  *
      get per il recupero di pacchetti e informazioni su di essi da fonti autenticate e per l'installazione,
      l'aggiornamento e la rimozione di pacchetti insieme alle loro dipendenze * apt-cache per interrogare
       le informazioni disponibili sui pacchetti installati

      nonché pacchetti installabili
  * apt-cdrom per utilizzare supporti rimovibili come sorgente per i pacchetti * apt-
  config come interfaccia per le impostazioni di configurazione * apt-key come
  interfaccia per gestire le chiavi di autenticazione
```

In questa sezione, ti guideremo attraverso il file di controllo e spiegheremo i vari campi. Ognuno di essi ti darà una migliore comprensione del sistema di confezionamento, ti offrirà un controllo di configurazione più preciso e ti fornirà le informazioni necessarie per risolvere eventuali problemi che potrebbero verificarsi.
verificarsi.

## Dipendenze: il campo Dipende

Le dipendenze del pacchetto sono definite nel campo Depends nell'intestazione del pacchetto. Si tratta di un elenco di condizioni che devono essere soddisfatte affinché il pacchetto funzioni correttamente; queste informazioni vengono utilizzate da strumenti come apt per installare le librerie richieste, nelle versioni appropriate che soddisfano le dipendenze del pacchetto da installare. Per ogni dipendenza, è possibile limitare l'intervallo di versioni che soddisfano tale condizione. In altre parole, è possibile esprimere il fatto che è necessario il pacchetto *libc6*

Machine Translated by Google

in una versione uguale o superiore a “2.15” (scritta “libc6 (>= 2.15)”). Gli operatori di confronto delle versioni sono i seguenti:

- <<: minore di;
- <=: minore o uguale a;
- =: uguale a (si noti che “2.6.1” non è uguale a “2.6.1-1”);
- >=: maggiore o uguale a;
- >>: maggiore di.

In un elenco di condizioni da soddisfare, la virgola funge da separatore, interpretata come un operatore logico "AND". Nelle condizioni, la barra verticale (“|”) esprime un “OR” logico (è un “OR” inclusivo, non un “o l’o” esclusivo). Avendo una priorità maggiore rispetto a “AND”, può essere utilizzata tutte le volte necessarie.
Pertanto, la dipendenza “(A OR B) AND C” si scrive A | B, C. Al contrario, l’espressione “A OR (B AND C)” dovrebbe essere scritta come “(A OR B) AND (A OR C)”, poiché il campo Dipendenze non tollera parentesi che modificano l’ordine di priorità tra gli operatori logici “OR” e “AND”.
Si scriverebbe quindi A | B, A | C. Vedi https://www.debian.org/doc/debian-policy/ch-relationships.html per ulteriori informazioni.

Il sistema di dipendenze è un buon meccanismo per garantire il corretto funzionamento di un programma, ma ha anche un altro utilizzo con i metapackage. Si tratta di pacchetti vuoti che descrivono unicamente le dipendenze.
I metapackage facilitano l'installazione di un gruppo coerente di programmi preselezionati dal gestore del metapackage; pertanto, il comando `apt install metapackage` installerà automaticamente tutti questi programmi utilizzando le dipendenze del metapackage. I pacchetti ` *gnome*`, `*kali-tools-wireless*` e `*kali-linux-large*` sono esempi di metapackage. Per ulteriori informazioni sui metapackage di Kali, consultare https://tools.kali.org/kali-metapackages

## Pre-dipendenti, un Dipendente più esigente

Le pre-dipendenze, elencate nel campo Pre-Dependsfield nelle intestazioni del pacchetto, completano le normali dipendenze; la loro sintassi è identica. Una normale dipendenza indica che il pacchetto in questione deve essere decompresso e configurato prima della configurazione del pacchetto che dichiara la dipendenza. Una pre-dipendenza stabilisce che il pacchetto in questione deve essere decompresso e configurato prima dell'esecuzione dello script di pre-installazione del pacchetto che dichiara la pre-dipendenza, ovvero prima della sua installazione.

Le predipendenze sono molto impegnative per apt perché impongono un vincolo rigoroso sull'ordine di installazione dei pacchetti. Pertanto, le predipendenze sono sconsigliate a meno che non siano assolutamente necessarie. Si raccomanda addirittura di consultare altri sviluppatori su debian-devel@lists.debian.org. prima di aggiungere una pre-dipendenza poiché in genere è possibile trovare un'altra soluzione alternativa.

Machine Translated by Google

## Raccomanda, suggerisce e migliora i campi

I campi "Consiglia" e "Suggerisce" descrivono le dipendenze non obbligatorie. Le dipendenze consigliate, le più importanti, migliorano considerevolmente le funzionalità offerte dal pacchetto, ma non sono indispensabili per il suo funzionamento. Le dipendenze suggerite, di importanza secondaria, indicano che alcuni pacchetti possono integrarsi e aumentarne l'utilità, ma è perfettamente lecito installarne uno senza gli altri.

È sempre consigliabile installare i pacchetti raccomandati, a meno che non si sappia esattamente perché non sono necessari. Viceversa, non è necessario installare i pacchetti suggeriti a meno che non si sappia perché sono necessari.

Il campo "Enhances" descrive anch'esso un suggerimento, ma in un contesto diverso. Si trova infatti nel pacchetto suggerito, e non nel pacchetto che beneficia del suggerimento. Il suo vantaggio risiede nella possibilità di aggiungere un suggerimento senza dover modificare il pacchetto interessato.
In questo modo, tutti i componenti aggiuntivi, i plug-in e le altre estensioni di un programma possono comparire nell'elenco dei suggerimenti relativi al software. Sebbene esista da diversi anni, quest'ultimo campo è ancora ampiamente ignorato da programmi come apt o synaptic. L'obiettivo originale era quello di permettere a un pacchetto come *xul-ext-adblock-plus* (un'estensione per Firefox) di dichiarare Enhances: firefox, firefox-esr e quindi di comparire nell'elenco dei pacchetti suggeriti associati a *firefox* e *firefox-esr.*

## Conflitti: il campo dei conflitti

Il campo Conflictsfield indica quando un pacchetto non può essere installato contemporaneamente a un altro. I motivi più comuni sono che entrambi i pacchetti includono un file con lo stesso nome, forniscono lo stesso servizio sulla stessa porta TCP (Transmission Control Protocol) o interferirebbero reciprocamente.

Se si verifica un conflitto con un pacchetto già installato, dpkg rifiuterà l'installazione, a meno che il nuovo pacchetto non specifichi di voler sostituire quello già presente; in tal caso, dpkg sceglierà di sostituire il vecchio pacchetto con il nuovo. APT segue sempre le tue istruzioni: se scegli di installare un nuovo pacchetto, ti offrirà automaticamente di disinstallare quello che crea il problema.

## Incompatibilità: il campo delle rotture

Il campo "Interruzioni" ha un effetto simile a quello del campo "Conflitti" , ma con un significato particolare. Segnala che l'installazione di un pacchetto potrebbe causare problemi a un altro pacchetto (o a specifiche versioni di quest'ultimo). In generale, questa incompatibilità tra due pacchetti è transitoria e la relazione "Interruzioni" si riferisce specificamente alle versioni incompatibili.

Machine Translated by Google

Quando un pacchetto entra in conflitto con un pacchetto già installato, dpkg si rifiuta di installarlo e apt tenta di risolvere il problema aggiornando il pacchetto che risulterebbe incompatibile a una versione più recente (che si presume sia stata corretta e, quindi, nuovamente compatibile).

Questo tipo di situazione può verificarsi in caso di aggiornamenti senza compatibilità con le versioni precedenti: ciò accade quando la nuova versione non è più compatibile con la versione precedente e causa un malfunzionamento in un altro programma senza che siano state previste soluzioni specifiche. Il campo "Interruzioni " aiuta a prevenire questo tipo di problemi.

### Elementi forniti: il campo Fornisce

Questo campo introduce l'interessante concetto di *pacchetto virtuale.* Esso svolge molteplici funzioni, ma due rivestono particolare importanza. La prima consiste nell'utilizzare un pacchetto virtuale per associarvi un servizio generico (il pacchetto fornisce il servizio). La seconda indica che un pacchetto sostituisce completamente un altro e che, a tal fine, può anche soddisfare le dipendenze che quest'ultimo soddisferebbe. È quindi possibile creare un pacchetto sostitutivo senza dover necessariamente utilizzare lo stesso nome del pacchetto originale.

**metapackage e Virtuale Pacchetto**

È fondamentale distinguere chiaramente i metapackage dai pacchetti virtuali. I primi sono pacchetti reali (inclusi i veri file .deb ), il cui unico scopo è esprimere le dipendenze.

I pacchetti virtuali, tuttavia, non esistono fisicamente; sono solo un mezzo per identificare i pacchetti reali sulla base di criteri logici comuni (ad esempio, il servizio offerto o la compatibilità con un programma standard o un pacchetto preesistente).

**Fornitura di un servizio** Analizziamo il primo caso più nel dettaglio con un esempio: si dice che tutti i server di posta, come *postfix* o *sendmail,* forniscano il pacchetto virtuale *mail-transport-agent .*
Pertanto, qualsiasi pacchetto che necessiti di questo servizio per funzionare (ad esempio un gestore di mailing list, come *smartlist* o *sympa)* dichiara semplicemente nelle sue dipendenze di richiedere un *mail-transport-agent,* anziché specificare un lungo ma incompleto elenco di possibili soluzioni. Inoltre, è inutile installare due server di posta sulla stessa macchina, motivo per cui ciascuno di questi pacchetti dichiara un conflitto con il pacchetto virtuale *mail-transport-agent .* Un conflitto tra un pacchetto e se stesso viene ignorato dal sistema, ma questa tecnica impedirà l'installazione di due server di posta affiancati.

**Intercambiabilità con un altro pacchetto** Il campo Provides è interessante anche quando il contenuto di un pacchetto è incluso in un pacchetto più grande. Ad esempio, il modulo Perl *libdigest-md5-perl* era un modulo opzionale in Perl 5.6 ed è stato integrato di serie in Perl 5.8. Pertanto, il pacchetto *perl* dalla versione 5.8 ha dichiarato Provides: libdigest-md5-perl in modo che le dipendenze da questo pacchetto siano soddisfatte se il sistema ha Perl 5.8 (o versioni successive). Il pacchetto *libdigest-md5-perl* stesso è stato eliminato, poiché non aveva più alcuna utilità quando le vecchie versioni di Perl sono state rimosse.

Machine Translated by Google

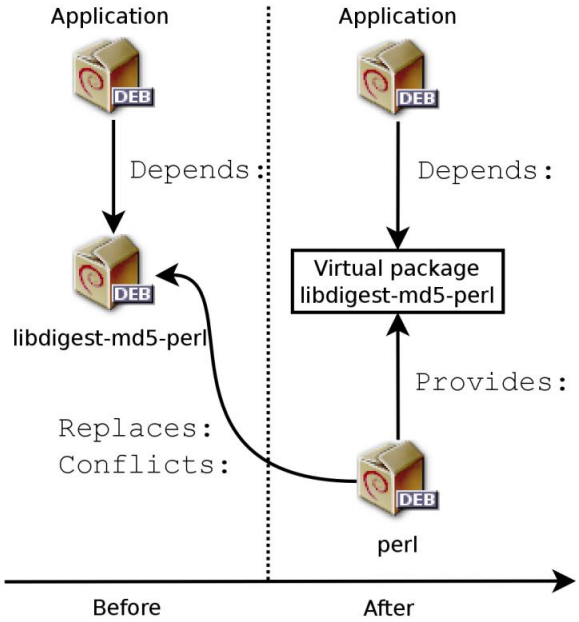



**Figura 8.3** Utilizzo di un campo Provides per non interrompere le dipendenze

Questa funzionalità è molto utile, poiché non è mai possibile prevedere gli imprevisti dello sviluppo ed è necessario potersi adattare alla ridenominazione e ad altre sostituzioni automatiche dei software obsoleti.

### Sostituzione dei file: il campo Sostituisce

Il campo Replaces indica che il pacchetto contiene file presenti anche in un altro pacchetto, ma che il pacchetto ha il diritto di sostituirli. Senza questa specifica, dpkg fallisce, affermando di non poter sovrascrivere i file di un altro pacchetto (tecnicamente, è possibile forzarlo a farlo con l' opzione --force-overwrite , ma questa non è considerata la procedura standard).
Ciò consente di identificare potenziali problemi e richiede al responsabile della manutenzione di studiare la questione prima di decidere se aggiungere o meno tale campo.

L'utilizzo di questo campo è giustificato quando cambiano i nomi dei pacchetti o quando un pacchetto viene incluso in un altro. Ciò accade anche quando il manutentore decide di distribuire i file in modo diverso tra vari pacchetti binari prodotti dallo stesso pacchetto sorgente: un file sostituito non appartiene più al vecchio pacchetto, ma solo a quello nuovo.

Se tutti i file di un pacchetto installato sono stati sostituiti, il pacchetto viene considerato rimosso. Infine, questo campo incoraggia dpkg a rimuovere il pacchetto sostituito in caso di conflitto.

Machine Translated by Google

### 8.4.2. Script di configurazione

Oltre al file di controllo , l' archivio control.tar.gz per ogni pacchetto Debian può contenere una serie di script (postinst, postrm, preinst, prerm) chiamati da dpkg in diverse fasi del processo elaborazione di un pacchetto. Possiamo usare dpkg -I per visualizzare questi file così come si trovano in un pacchetto .deb archivio:

```
$ dpkg -I /var/cache/apt/archives/zsh_5.3-1_amd64.deb | head
 Nuovo pacchetto Debian, versione 2.0.
 dimensione 814486 byte: archivio di controllo=2557 byte.
       838 byte, controllo      20 righe
      3327 byte, 969            43 righe          md5sums
       byte, 348 byte,          41 righe * postinst 20 righe * postrm      #!/bin/sh
       175 byte, 175            5 righe * preinst 5 righe * prerm          #!/bin/sh
       byte, Pacchetto:                                                    #!/bin/sh
       zsh                                                                 #!/bin/sh

 Versione: 5.3-1
$ dpkg -I zsh_5.3-1_amd64.deb preinst
#!/bin/sh
imposta -e
# Aggiunto automaticamente da dh_installdeb
dpkg-maintscript-helper symlink_to_dir /usr/share/doc/zsh zsh-common 5.0.7-3 -- "$@"
# Fine della sezione aggiunta automaticamente
```

La politica Debian[6] descrive in dettaglio ciascuno di questi file, specificando gli script chiamati e il argomenti che ricevono. Queste sequenze possono essere complicate, poiché se uno degli script fallisce, dpkg tenterà di ripristinare uno stato soddisfacente annullando l'installazione o la rimozione in corso (nella misura in cui ciò sia possibile).

**Il database dpkg** È possibile attraversare il database dpkg sul filesystem in /var/lib/dpkg/. Questa directory contiene un registro continuo di tutti i pacchetti che sono stati installati su il sistema. Tutti gli script di configurazione per i pacchetti installati sono memorizzati nel directory /var/lib/dpkg/info/ , sotto forma di file con prefisso del pacchetto nome:

```
$ ls /var/lib/dpkg/info/zsh.*
/var/lib/dpkg/info/zsh.list
/var/lib/dpkg/info/zsh.md5sums
/var/lib/dpkg/info/zsh.postinst
/var/lib/dpkg/info/zsh.postrm
/var/lib/dpkg/info/zsh.preinst
/var/lib/dpkg/info/zsh.prerm
```

Questa directory include anche un file con estensione .list per ogni pacchetto, contenente l'elenco dei file appartenenti a quel pacchetto:

[6] https://www.debian.org/doc/debian-policy/ch-maintainerscripts.html

Machine Translated by Google

```
$ head /var/lib/dpkg/info/zsh.list /. /bin /bin/zsh /bin/

zsh5 /
usr /usr/lib /
usr/lib/x86_64-
linux-
gnu /usr/lib/
x86_64-linux-gnu/zsh /usr/lib/x86_64-
linux-gnu/zsh/5.2 /usr/lib/x86_64-linux-gnu/zsh/
5.2/zsh [...]
```

Il file /var/lib/dpkg/status contiene una serie di blocchi di dati (nel formato del famoso file di intestazione della mail request for comment, RFC 2822) che descrivono lo stato di ciascun pacchetto. Anche le informazioni del file di controllo dei pacchetti installati vengono replicate al suo interno.

```
$ more /var/lib/dpkg/status
Pacchetto: gnome-characters
Stato: installazione OK installata
Priorità: facoltativa
Sezione: gnomo
Dimensioni installate: 1785
Manutentore: Debian GNOME Maintainers <pkg-gnome- ÿ
        maintainers@lists.alioth.debian.org> Architettura: amd64

Versione: 3.20.1-1
[...]
```

Analizziamo i file di configurazione e vediamo come interagiscono. In generale, lo script preinst viene eseguito prima dell'installazione del pacchetto, mentre postinst la segue. Allo stesso modo, prerm viene richiamato prima della rimozione di un pacchetto e postrm successivamente. L'aggiornamento di un pacchetto equivale alla rimozione della versione precedente e all'installazione di quella nuova. Non è possibile descrivere in dettaglio tutti i possibili scenari in questa sede, ma tratteremo i due più comuni: installazione/aggiornamento e rimozione.

Queste sequenze possono essere piuttosto confuse, ma una rappresentazione visiva può essere d'aiuto. Manoj Srivastava ha realizzato alcuni diagrammi[7] spiegando come gli script di configurazione vengono richiamati da dpkg. Diagrammi simili sono stati sviluppati anche dal progetto Debian Women[8] Sono un po' più semplici da capire, ma meno complete.

[7] https://people.debian.org/~srivasta/MaintainerScripts.html
[8] https://wiki.debian.org/MaintainerScripts

Machine Translated by Google

Attenzione

**Nomi simbolici del Sceneggiature**

Le sequenze descritte in questa sezione richiamano script di configurazione con nomi specifici, come old-prerm o new-postinst. Si tratta, rispettivamente, dello script prerm contenuto nella vecchia versione del pacchetto (installata prima dell'aggiornamento) e dello script postinst contenuto nella nuova versione (installata dall'aggiornamento).

### Sequenza di script per l'installazione e l'aggiornamento

Ecco cosa succede durante un'installazione (o un aggiornamento):

1. Per un aggiornamento, dpkg chiama old-prerm upgrade new-version.
2. Per un aggiornamento, dpkg esegue quindi new-preinst upgrade old-version; per una prima installazione, esegue new-preinst install. Può aggiungere la vecchia versione nell'ultimo parametro se il pacchetto è già stato installato e rimosso (ma non eliminato completamente, avendo conservato i file di configurazione).

3. I nuovi file del pacchetto vengono quindi decompressi. Se un file esiste già, viene sovrascritto, ma ne viene creata una copia di backup che viene temporaneamente memorizzata.

4. Per un aggiornamento, dpkg esegue old-postrm upgrade new-version. 5. dpkg

aggiorna tutti i dati interni (elenco dei file, script di configurazione, ecc.) e rimuove i backup dei file sostituiti. Questo è il punto di non ritorno: dpkg non ha più accesso a tutti gli elementi necessari per tornare allo stato precedente. 6. dpkg aggiornerà i file di configurazione, chiedendoti di

decidere se non è in grado di gestire automaticamente questa attività. I dettagli di questa procedura sono discussi nella sezione 8.4.3, "Checksum, Confiles" [pagina 220].

7. Infine, dpkg configura il pacchetto eseguendo new-postinst configure last-version-configured.

### Rimozione del pacco

Ecco cosa succede durante la rimozione di un pacco.

1. dpkg chiama prerm remove. 2.

dpkg rimuove tutti i file del pacchetto, ad eccezione dei file di configurazione e degli script di configurazione. 3. dpkg esegue postrm

remove. Tutti gli script di configurazione, tranne postrm, vengono rimossi.
Se non hai utilizzato l'opzione di eliminazione, il processo si interrompe qui.

4. Per una pulizia completa del pacchetto (comando emesso con dpkg --purge o dpkg -P), vengono eliminati anche i file di configurazione, nonché un certo numero di copie (*.dpkg-tmp, *.dpkg-old, *.dpkg-new) e file temporanei; dpkg esegue quindi postrm purge.

Machine Translated by Google

In alcuni casi, un pacchetto potrebbe utilizzare debconf per richiedere informazioni di configurazione: i quattro script descritti in precedenza vengono quindi integrati da uno script di configurazione progettato per acquisire tali informazioni. Durante l'installazione, questo script definisce in dettaglio quali domande porrà debconf . Le risposte vengono registrate nel database di debconf per riferimento futuro. Lo script viene generalmente eseguito da apt prima di installare i pacchetti uno per uno, in modo da raggruppare tutte le domande all'inizio del processo. Gli script di pre e post-installazione possono quindi utilizzare queste informazioni per operare secondo le vostre preferenze.

**Lo strumento debconf** è stato creato per risolvere un problema ricorrente in Debian. Tutti i pacchetti Debian che non potevano funzionare senza una configurazione minima ponevano domande tramite chiamate ai comandi echo e read negli script di shell postinst (e altri script simili). Ciò costringeva il programma di installazione a monitorare installazioni o aggiornamenti di grandi dimensioni per rispondere alle varie richieste di configurazione man mano che si presentavano. Grazie a debconf, queste interazioni manuali sono state quasi completamente eliminate.

Lo strumento debconf offre numerose funzionalità interessanti: richiede allo sviluppatore di specificare l'interazione con l'utente; permette la localizzazione di tutte le stringhe visualizzate (tutte le traduzioni sono memorizzate nel file template che descrive le interazioni); fornisce diverse modalità di visualizzazione per le domande (modalità testo, modalità grafica, non interattiva); e consente la creazione di un database centrale di risposte per condividere la stessa configurazione con più computer. La caratteristica più importante è la possibilità di presentare tutte le domande in sequenza, una dopo l'altra, prima di avviare un lungo processo di installazione o aggiornamento. In questo modo, è possibile dedicarsi ad altre attività mentre il sistema gestisce l'installazione in autonomia, senza dover rimanere a fissare lo schermo in attesa che vengano visualizzate le domande.

## 8.4.3. Checksum, Conflitti

Oltre agli script di manutenzione e ai dati di controllo già menzionati nelle sezioni precedenti, l' archivio control.tar.gz di un pacchetto Debian può contenere altri file interessanti:

```
# ar p /var/cache/apt/archives/bash_4.4-2_amd64.deb control.tar.gz | tar -tzf - ./

./conffiles ./
control ./
md5sums ./
postinst ./
postrm ./
preinst ./
prerm
```

Il primo, md5sums, contiene i checksum MD5 di tutti i file del pacchetto. Il suo principale vantaggio è che permette a dpkg --verify di verificare se questi file sono stati modificati dopo l'installazione.
Si noti che, qualora questo file non esistesse, dpkg lo genererà dinamicamente al momento dell'installazione (e lo memorizzerà nel database di dpkg come qualsiasi altro file di controllo).

Machine Translated by Google

Il file di configurazione elenca i file di pacchetto che devono essere gestiti come file di configurazione. I file di configurazione possono essere modificati dall'amministratore e dpkg tenterà di preservare tali modifiche durante un aggiornamento del pacchetto.

In pratica, in questa situazione, dpkg si comporta nel modo più intelligente possibile: se il file di configurazione standard non è cambiato tra le due versioni, non fa nulla. Se, invece, il file è stato modificato, tenterà di aggiornarlo. Sono possibili due casi: o l'amministratore non ha modificato il file di configurazione, nel qual caso dpkg installa automaticamente la nuova versione; oppure il file è stato modificato, nel qual caso dpkg chiede all'amministratore quale versione desidera utilizzare (quella vecchia con le modifiche o quella nuova fornita con il pacchetto). Per facilitare questa decisione, dpkg offre la possibilità di visualizzare un confronto che mostra le differenze tra le due versioni. Se si sceglie di mantenere la vecchia versione, la nuova verrà salvata nella stessa posizione in un file con estensione .dpkg-dist . Se si sceglie la nuova versione, la vecchia verrà conservata in un file con estensione .dpkg-old .
Un'altra azione disponibile consiste nell'interrompere momentaneamente dpkg per modificare il file e tentare di ripristinare le modifiche pertinenti (precedentemente identificate con diff). dpkg gestisce gli

aggiornamenti dei file di configurazione, ma, nel farlo, interrompe regolarmente il suo lavoro per chiedere input all'amministratore. Questo può richiedere tempo ed essere scomodo. Fortunatamente, è possibile istruire dpkg a rispondere automaticamente a queste richieste. L' opzione --force-confold mantiene la vecchia versione del file, mentre --force-confnew utilizzerà la nuova versione. Queste scelte vengono rispettate, anche se il file non è stato modificato dall'amministratore, il che solo raramente ha l'effetto desiderato. Aggiungendo l' opzione --force-confdef si indica a dpkg di decidere autonomamente quando possibile (in altre parole, quando il file di configurazione originale non è stato modificato) e di utilizzare --force-confnew o --force-confold solo negli altri casi.

Queste opzioni si applicano a dpkg, ma nella maggior parte dei casi l'amministratore lavorerà direttamente con i programmi aptitude o apt . È quindi necessario conoscere la sintassi utilizzata per indicare le opzioni da passare al comando dpkg (le loro interfacce a riga di comando sono molto simili).

```
# apt -o DPkg::options::=”--force-confdef” -o DPkg::options::=”--force-confold” full-
    ÿ aggiornamento
```

Queste opzioni possono essere memorizzate direttamente nella configurazione di apt . Per farlo, è sufficiente scrivere la seguente riga nel file /etc/apt/apt.conf.d/local :

```
DPkg::opzioni { "--force-confdef"; "--force-confold"; }
```

Includendo questa opzione nel file di configurazione, essa verrà utilizzata anche in un'interfaccia grafica come Aptitude.

Viceversa, è anche possibile forzare dpkg a porre domande sui file di configurazione. L' opzione --force-confask indica a dpkg di visualizzare le domande sui file di configurazione, anche nei casi in cui normalmente non sarebbero necessarie. Pertanto, quando si reinstalla un pacchetto con questa opzione, dpkg porrà nuovamente le domande per tutti i file di configurazione modificati dall'amministratore. Questo è molto comodo, soprattutto per reinstallare il file di configurazione originale se è stato eliminato e

Machine Translated by Google

Non è disponibile un'altra copia: una normale reinstallazione non funzionerà, perché dpkg considera la rimozione come una forma di modifica legittima e, pertanto, non installa il file di configurazione desiderato.

## 8.5. Riepilogo

In questa sezione, abbiamo approfondito la conoscenza del sistema di pacchetti Debian, discusso di Advanced Package Tool (APT) e dpkg, appreso le interazioni di base con i pacchetti, la configurazione e l'utilizzo avanzati di APT e analizzato più a fondo il sistema di pacchetti Debian con un breve riferimento al formato di file .deb . Abbiamo esaminato il file di controllo , gli script di configurazione, i checksum e il file di configurazione .

Suggerimenti

riassuntivi: Un pacchetto Debian è un archivio compresso di un'applicazione software. Contiene i file dell'applicazione, nonché altri metadati, inclusi i nomi delle dipendenze necessarie all'applicazione e gli script che consentono l'esecuzione di comandi nelle diverse fasi del ciclo di vita del pacchetto (installazione, rimozione, aggiornamenti).

Lo strumento dpkg , a differenza di apt e apt-get (della famiglia APT), non è a conoscenza di tutti i pacchetti disponibili che potrebbero essere utilizzati per soddisfare le dipendenze dei pacchetti. Pertanto, per gestire i pacchetti Debian, è probabile che si utilizzino questi ultimi strumenti, in quanto sono in grado di risolvere automaticamente i problemi di dipendenza.

È possibile utilizzare APT per installare e rimuovere applicazioni, aggiornare pacchetti e persino aggiornare l'intero sistema. Ecco i punti chiave da conoscere su APT e la sua configurazione:

- Il file sources.list è il file di configurazione chiave per definire le sorgenti dei pacchetti (o i repository che contengono i pacchetti). • Debian e Kali utilizzano

tre sezioni per differenziare i pacchetti in base alle licenze scelte dagli autori di ciascuna opera: main contiene tutti i pacchetti che sono pienamente conformi alle Linee guida sul software libero di Debian9 ; non-free contiene software che non è (completamente) conforme alle Linee guida del software libero ma può comunque essere distribuito senza restrizioni; e contrib (contributi) include software open source che non può funzionare senza alcuni elementi non-free.

- Kali gestisce diversi repository, tra cui: kali-rolling, che è il repository principale per gli utenti finali e dovrebbe sempre contenere pacchetti installabili e recenti; e kali-dev, che viene utilizzato dagli sviluppatori di Kali e non è destinato all'uso pubblico.
- Quando si utilizza APT, è necessario innanzitutto scaricare l'elenco dei pacchetti attualmente disponibili con il comando `apt update`.
- Puoi aggiungere un pacchetto al sistema con un semplice comando `apt install package`. APT installerà automaticamente le dipendenze necessarie. • Per

rimuovere un pacchetto, usa `apt remove package`. Questo comando rimuoverà anche le dipendenze inverse del pacchetto (ovvero i pacchetti che dipendono dal pacchetto da rimuovere).

[9] https://www.debian.org/social_contract#guidelines

Machine Translated by Google

- Per rimuovere tutti i dati associati a un pacchetto, è possibile "eliminare" il pacchetto con il comando apt purge package . A differenza della rimozione, questo comando non solo rimuoverà il pacchetto, ma anche i relativi file di configurazione e, talvolta, i dati utente associati.

Si consiglia di eseguire aggiornamenti regolari per installare gli aggiornamenti di sicurezza più recenti. Per aggiornare, utilizzare `apt update` seguito da ` apt upgrade`, `apt-get upgrade` o `aptitude safe-upgrade`. Questi comandi cercano i pacchetti installati che possono essere aggiornati senza rimuovere alcun pacchetto.

Per aggiornamenti più importanti, come gli aggiornamenti di versione principali, usa `apt full-upgrade`. Con questa istruzione, apt completerà l'aggiornamento anche se deve rimuovere alcuni pacchetti obsoleti o installare nuove dipendenze. Questo è anche il comando da utilizzare per gli aggiornamenti regolari del tuo sistema Kali Rolling. Rivedi i pro e i contro degli aggiornamenti che abbiamo descritto in questo capitolo.

Esistono diversi strumenti che possono essere utilizzati per analizzare i pacchetti Debian:

- dpkg --listfiles *package(or-L)* elenca i file installati dal pacchetto specificato. • dpkg --search file (or -S) trova tutti i pacchetti contenenti il file o il percorso passato in discussione.
- dpkg --list (o -l) visualizza l'elenco dei pacchetti noti al sistema e la loro installazione stato.
- dpkg --contents file.deb (o -c) elenca tutti i file in un particolare file .deb . • dpkg --info file.deb (o -l) visualizza le intestazioni del file .deb specificato . • I vari sottocomandi di apt-cache visualizzano gran parte delle informazioni memorizzate nel file di configurazione di APT. database interno.

Per evitare un utilizzo eccessivo del disco, è consigliabile eseguire regolarmente la pulizia della directory /var/cache/apt/archives/. Per questo scopo si possono usare due comandi: `apt clean` (o `apt-get clean`) svuota completamente la directory; `apt autoclean` (o `apt-get autoclean`) rimuove solo i pacchetti che non possono più essere scaricati perché sono scomparsi dal mirror e sono quindi inutili. `aptitude` è un programma interattivo che può essere utilizzato in modalità semi-grafica sulla console. È un programma estremamente robusto che può aiutarti a installare e risolvere i problemi dei pacchetti. `synaptic` è un gestore di pacchetti grafico che presenta un'interfaccia grafica pulita ed efficiente.

Come utente avanzato, puoi creare file in /etc/apt/apt.conf.d/ per configurare determinati aspetti di APT. Puoi anche gestire le priorità dei pacchetti, tenere traccia dei pacchetti installati automaticamente, lavorare con diverse distribuzioni o architetture contemporaneamente, utilizzare firme crittografiche per convalidare i pacchetti e aggiornare i file utilizzando le tecniche descritte in questo capitolo.

Nonostante gli sforzi dei manutentori di Debian o Kali, un aggiornamento di sistema non è sempre così agevole come spereremmo. Quando ciò accade, è possibile consultare il bug tracker di Kali10 e nel sistema di tracciamento dei bug di Debian11 su https://bugs.debian.org/package per verificare se il problema è già stato segnalato

10https://bugs.kali.org/ 11https://bugs.debian.org/

Machine Translated by Google

è stato segnalato. Puoi anche provare a eseguire il downgrade del pacchetto o a eseguire il debug e riparare un pacchetto non riuscito script di manutenzione.

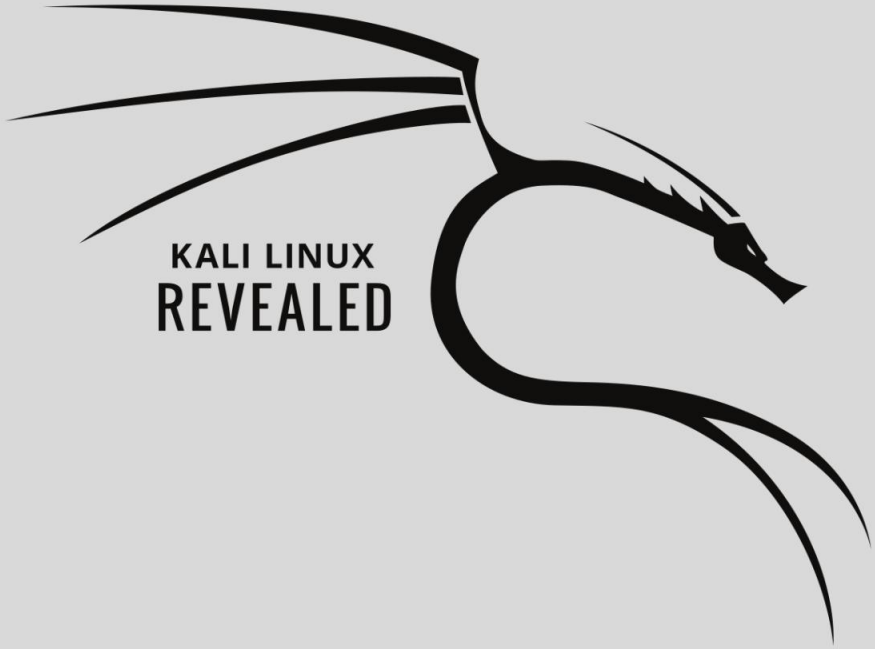
Machine Translated by Google



Machine Translated by Google

**Parole chiave**

**Pacchetti personalizzati**
**Kernel personalizzato**
**Immagini personalizzate in tempo reale**
**Persistenza**



Machine Translated by Google

Capitolo

# 9

# Utilizzo avanzato

Contenuto

Modifica dei pacchetti Kali 228
Ricompilazione del kernel Linux 237
Creazione di immagini ISO live personalizzate di Kali 241
Aggiungere la persistenza alla Live ISO con una chiave USB 246
Sommario 251

Machine Translated by Google

Kali è stata progettata come una piattaforma di penetration testing altamente modulare e personalizzabile, che consente un livello di personalizzazione e utilizzo piuttosto avanzato. Le personalizzazioni possono avvenire a diversi livelli, a partire dal codice sorgente. I sorgenti di tutti i pacchetti Kali sono disponibili pubblicamente. In questo capitolo, mostreremo come recuperare i pacchetti, modificarli e creare pacchetti personalizzati. Il kernel Linux rappresenta un caso particolare e, come tale, è trattato in una sezione dedicata (sezione 9.2, "Ricompilazione del kernel Linux" [pagina 237]), dove analizzeremo dove trovare i sorgenti, come configurare la compilazione del kernel e, infine, come compilarlo e creare i relativi pacchetti.

Il secondo livello di personalizzazione riguarda il processo di creazione delle immagini ISO live. Mostreremo come lo strumento di live-build offra numerosi punti di aggancio e opzioni di configurazione per personalizzare l'immagine ISO risultante, inclusa la possibilità di utilizzare pacchetti Debian personalizzati al posto di quelli disponibili sui mirror.

Discuteremo anche di come creare un'immagine ISO live persistente su una chiavetta USB, in grado di conservare file e modifiche al sistema operativo tra un riavvio e l'altro.

## 9.1. Modifica dei pacchetti Kali

La modifica dei pacchetti Kali è solitamente un compito dei collaboratori e degli sviluppatori di Kali: aggiornano i pacchetti con le nuove versioni upstream, modificano la configurazione predefinita per una migliore integrazione nella distribuzione o correggono i bug segnalati dagli utenti. Tuttavia, potresti avere esigenze specifiche non soddisfatte dai pacchetti ufficiali e, in tal caso, sapere come creare un pacchetto modificato può rivelarsi molto utile.

Potreste chiedervi perché dovreste preoccuparvi di questo pacchetto. Dopotutto, se dovete modificare un software, potete sempre scaricarne il codice sorgente (di solito con git) ed eseguire la versione modificata direttamente dal codice sorgente. Questo va bene quando è possibile e quando utilizzate la vostra directory home a questo scopo, ma se la vostra applicazione richiede un'installazione a livello di sistema (ad esempio, con un passaggio di `make install` ), inquinerete il vostro file system con file sconosciuti a dpkg e creerete presto problemi che non potranno essere rilevati dalle dipendenze dei pacchetti. Inoltre, con i pacchetti appropriati sarete in grado di condividere le vostre modifiche e distribuirle su più computer molto più facilmente, oppure di annullare le modifiche se avete scoperto che non funzionavano come sperato.

Quando potrebbe essere utile modificare un pacchetto? Vediamo alcuni esempi. Innanzitutto, supponiamo che siate utenti assidui di Social-Engineer Toolkit (SET) e che abbiate notato una nuova versione rilasciata dal repository principale, ma gli sviluppatori di Kali sono tutti impegnati in una conferenza e voi volete provarla immediatamente. In questo caso, desiderate aggiornare il pacchetto autonomamente. In un altro caso, ipotizziamo che stiate riscontrando difficoltà nel far funzionare la vostra scheda NFC MIFARE e che vogliate ricompilare "libfreefare" per abilitare i messaggi di debug, in modo da avere dati utili da fornire in una segnalazione di bug che state preparando. Infine, ipotizziamo che il programma "pyrit" si blocchi con un messaggio di errore criptico. Dopo una ricerca sul web, trovate un commit nel repository GitHub principale che dovrebbe risolvere il problema e desiderate ricompilare il pacchetto applicando questa correzione.

Machine Translated by Google

Esamineremo tutti questi esempi nelle sezioni seguenti. Cercheremo di generalizzare le spiegazioni in modo che possiate applicare al meglio le istruzioni ad altri casi, ma è impossibile coprire tutte le situazioni che potreste incontrare. In caso di problemi, usate il vostro buon senso per trovare una soluzione o cercate aiuto sui forum più appropriati (vedere il capitolo 6, "Aiutarsi da soli e chiedere aiuto" [pagina 128]).

Qualunque modifica si voglia apportare, il processo generale è sempre lo stesso: scaricare il pacchetto sorgente, estrarlo, apportare le modifiche e infine compilare il pacchetto. Tuttavia, per ogni passaggio, esistono spesso diversi strumenti in grado di gestire l'attività. Abbiamo selezionato gli strumenti più rilevanti e popolari, ma la nostra analisi non è esaustiva.

### 9.1.1. Reperire le fonti

La ricompilazione di un pacchetto Kali inizia con il recupero del suo codice sorgente. Un pacchetto sorgente è composto da più file: il file principale è il file *.dsc *(Debian Source Control)* poiché elenca gli altri file di accompagnamento, che possono essere file *.tar.gz, bz2, xz, a volte *.diff.gz o *.debian.tar.gz, bz2, xz .

I pacchetti sorgente sono archiviati su mirror di Kali accessibili tramite HTTP. È possibile utilizzare il browser web per scaricare tutti i file necessari, ma il modo più semplice per farlo è utilizzare il comando `apt source source_package_name` . Questo comando richiede una riga `deb-src` nel file `/etc/apt/sources.list` e file di indice aggiornati (ottenuti eseguendo `apt update`).
Di default, Kali non aggiunge la riga necessaria poiché pochi utenti di Kali hanno effettivamente bisogno di scaricare i pacchetti sorgente, ma è possibile aggiungerla facilmente (vedere il file di esempio nella sezione 8.1.3, "Repository di Kali" [pagina 179] e le relative spiegazioni nella sezione 8.1.2, "Comprendere il file sources.list " [pagina 178]).

```
$ apt source libfreefare Lettura degli
elenchi dei pacchetti... Fatto AVVISO: il pacchetto
'libfreefare' è gestito nel sistema di controllo versione 'Git' all'indirizzo: git://anonscm.debian.org/collab-maint/libnfc.git Utilizzare: git clone git://
anonscm.debian.org/collab-maint/libnfc.git per recuperare gli ultimi aggiornamenti
(eventualmente
non ancora rilasciati) del pacchetto.

È necessario scaricare 119 kB di archivi sorgente.
Scarica:1 http://kali.download/kali kali-rolling/main libfreefare 0.4.0-2.1 (dsc) [2.144 B]
Scarica:2 http://kali.download/kali kali-rolling/main libfreefare 0.4.0-2.1 (tar) [113 kB]
Scarica:3 http://kali.download/kali kali-rolling/main libfreefare 0.4.0-2.1 (diff) [3.732 B]
Scaricati 119 kB in 1s (100 kB/s) dpkg-source: info:
estrazione di libfreefare in libfreefare-0.4.0 dpkg-source: info: decompressione di libfreefare_0.4.0.orig.tar.gz
dpkg-source: info: decompressione di libfreefare_0.4.0-2.1.debian.tar.xz $ cd libfreefare-0.4.0 $ ls
AUTHORS ChangeLog CMakeLists.txt contrib $ ls debian changelog compat control copyright libfreefare0.install
libfreefare-bin.install libfreefare-

dev.install          cmake                    configure.ac COPIA esempi libfreefare                    m4          NOTIZIA     test
libfreefare-doc.install README.Source rules source watch          debian HACKING libfreefare.pc.in Makefile.am README TODO
```

In questo esempio, pur avendo ricevuto il pacchetto sorgente da un mirror di Kali, il pacchetto è identico a quello di Debian poiché la stringa di versione non contiene "kali". Ciò significa che non sono state apportate modifiche specifiche per Kali.

Se hai bisogno di una versione specifica del pacchetto sorgente, che al momento non è disponibile nei repository elencati in /etc/apt/sources.list, il modo più semplice per scaricarla è trovare l'URL del suo file .dsc cercandolo su https://pkg.kali.org/ e quindi passando quell'URL a dget (dal pacchetto *devscripts ).*

Machine Translated by Google

Dopo aver cercato l'URL del pacchetto sorgente libreefare disponibile in kali-dev, puoi scaricalo con dget. Prima scaricherà il file .dsc , poi lo analizzerà per sapere quali altri file vengono citati e quindi scaricati dalla stessa posizione:

```
$ gett http://http.kali.org/pool/main/libf/libfreefare/libfreefare_0.4.0+0~
        ÿ git1439352548.ffde4d-1.dsc
dget: recupero di http://http.kali.org/pool/main/libf/libfreefare/libfreefare_0.4.0+0~
        ÿ git1439352548.ffde4d-1.dsc
  % Totale % Ricevuto % Trasferito Velocità media Tempo Download Upload Totale Tempo Tempo corrente
                                                  Trascorso Velocità sinistra
100 362 100 362 0 0 1117 0 --:--:-- --:--:-- --:--:-- 1120
100 1935 100 1935 0 0 3252 0 --:--:-- --:--:-- --:--:-- 3252
dget: recupero di http://http.kali.org/pool/main/libf/libfreefare/libfreefare_0.4.0+0~
        ÿ git1439352548.ffde4d.orig.tar.gz
[...]
libfreefare_0.4.0+0~git1439352548.ffde4d-1.dsc:
dscverify: libfreefare_0.4.0+0~git1439352548.ffde4d-1.dsc non ha superato il controllo della firma:
gpg: ATTENZIONE: nessun comando fornito. Tentativo di indovinare cosa intendi...
gpg: Firma effettuata mercoledì 12 agosto 2015 alle 00:14:03 EDT
gpg: utilizzando la chiave RSA 43EF73F4BD8096DA
gpg: Impossibile verificare la firma: nessuna chiave pubblica
Validazione NON RIUSCITA!!
$ dpkg-source -x libfreefare_0.4.0+0~git1439352548.ffde4d-1.dsc
gpgv: Firma effettuata mercoledì 12 agosto 2015 alle 00:14:03 EDT
gpgv: utilizzando la chiave RSA 43EF73F4BD8096DA
gpgv: Impossibile verificare la firma: nessuna chiave pubblica
dpkg-source: avviso: impossibile verificare la firma su ./libfreefare_0.4.0+0~git1439352548
        ÿ .ffde4d-1.dsc
dpkg-source: info: estrazione di libfreefare in libfreefare-0.4.0+0~git1439352548.ffde4d
dpkg-source: info: estrazione di libfreefare_0.4.0+0~git1439352548.ffde4d.orig.tar.gz
dpkg-source: info: estrazione di libfreefare_0.4.0+0~git1439352548.ffde4d-1.debian.tar.xz
```

Vale la pena notare che dget non ha estratto automaticamente il pacchetto sorgente perché poteva non verificare la firma PGP sul pacchetto sorgente. Pertanto abbiamo eseguito questo passaggio manualmente con dpkg-source -x dsc-file. Puoi anche forzare l'estrazione del pacchetto sorgente passando --allow-unauthenticated o l'opzione -u . Inversamente, puoi usare --download-only per saltare la sorgente Fase di estrazione del pacchetto.

**Recupero delle fonti da Get**

Potresti aver notato che l' invocazione di apt source ti informa di un possibile Git repository utilizzato per mantenere il pacchetto. Potrebbe puntare a un repository Git Debian o in un repository Git di Kali.

Tutti i pacchetti specifici di Kali sono gestiti in repository Git ospitati su gitlab.com/-kalilinux/packages1 È possibile recuperare i sorgenti da quei repository con git clona https://gitlab.com/kalilinux/packages/source-package.git.

Machine Translated by Google

A differenza di quanto accade con `apt source`, l'albero dei pacchetti ottenuto non avrà le patch applicate automaticamente. Consulta la directory `debian/patches/` per informazioni sulle possibili modifiche apportate da Kali.

```
$ git clone https://gitlab.com/kalilinux/packages/kali-meta.
      ÿ git
Clonazione in 'kali-meta'... remoto: Conteggio
degli oggetti: 760, fatto. remoto: Compressione degli oggetti:
100% (614/614), fatto. remoto: Totale 760 (delta 279), riutilizzati 0 (delta 0)

Ricezione oggetti: 100% (760/760), 141,01 KiB | 0 byte/s,
      ÿ fatto.
Risoluzione dei delta: 100% (279/279), completata.
Verifica della connettività... completata. $ cd kali-
meta $ ls debian


$ ls debian
changelog compat control copyright rules source
```

È possibile utilizzare i repository Git come metodo alternativo per recuperare i sorgenti e quindi (in linea di massima) seguire le altre istruzioni di questa sezione. Tuttavia, quando gli sviluppatori Kali lavorano con questi repository, utilizzano un flusso di lavoro di packaging diverso e si avvalgono di strumenti del pacchetto git-buildpackage , che non tratteremo in questa sede. Per saperne di più su questi strumenti, consultare la documentazione.

ÿ https://honk.sigxcpu.org/piki/projects/git-buildpackage/

### 9.1.2. Installazione delle dipendenze di compilazione

Ora che hai i sorgenti, devi ancora installare le dipendenze di compilazione. Saranno necessarie per creare i pacchetti binari desiderati, ma probabilmente saranno richieste anche per le compilazioni parziali che potresti voler eseguire per testare le modifiche mentre le apporti.

Ogni pacchetto sorgente dichiara le proprie dipendenze di compilazione nel campo Build-Depends del file di controllo debian/ . Indichiamo ad apt di installarle (supponendo che ci si trovi in una directory contenente un pacchetto sorgente decompresso):

```
$ sudo apt build-dep ./ Nota: si
utilizza la directory './' per ottenere le dipendenze di compilazione Lettura degli elenchi dei
pacchetti... Fatto Creazione dell'albero delle
dipendenze Lettura delle informazioni
sullo stato... Fatto I seguenti NUOVI pacchetti verranno
installati:
    autoconf automake autopoint autotools-dev debhelper dh-autoreconf
```

[1] https://gitlab.com/kalilinux/packages

Machine Translated by Google

```
    dh-strip-nondeterminism gettext intltool-debian libarchive-zip-perl libfile-stripnondeterminism-perl
    libtool po-debconf 0 aggiornati, 13 installati di recente, 0 da rimuovere e 0
non aggiornati.
È necessario scaricare 4.456 kB di archivi.
Dopo questa operazione, verranno utilizzati 14,6 MB di spazio aggiuntivo sul disco.
Vuoi continuare? [S/n] [...]
```

In questo esempio, tutte le dipendenze di compilazione possono essere soddisfatte con i pacchetti disponibili su APT. Questo potrebbe non essere sempre vero, poiché lo strumento di compilazione kali-rolling non garantisce l'installabilità delle dipendenze di compilazione (vengono prese in considerazione solo le dipendenze dei pacchetti binari). In pratica, le dipendenze binarie e le dipendenze di compilazione sono spesso strettamente correlate e la maggior parte dei pacchetti avrà le proprie dipendenze di compilazione soddisfatte.

### 9.1.3. Apportare modifiche

Non possiamo trattare in questa sezione tutte le possibili modifiche che potresti voler apportare a un determinato pacchetto. Ciò equivarrebbe a insegnarti tutti i dettagli più minuziosi. dettagli sul packaging di Debian. Tuttavia, tratteremo i tre casi d'uso comuni presentati in precedenza e spiegheremo alcune parti inevitabili (come la gestione del file changelog ).

La prima cosa da fare è modificare il numero di versione del pacchetto in modo che i pacchetti ricompilati possano essere distinti dai pacchetti originali forniti da Debian o Kali. Per fare ciò, di solito si aggiunge un suffisso che identifica l'entità (persona o azienda) che applica le modifiche. Dato che buxy è il mio nickname IRC, lo userò come suffisso. Tale modifica si effettua al meglio con il comando dch *(Debian CHangelog)* del pacchetto *devscripts* , con un comando come dch --local buxy. Questo avvia un editor di testo (sensible-editor, che esegue l'editor assegnato nelle variabili d'ambiente VISUAL o EDITOR , oppure /usr/bin/editor in caso contrario), che consente di documentare le differenze introdotte da questa ricompilazione. Questo editor mostra che dch ha effettivamente modificato il file debian/changelog :

```
$ head -n 1 debian/changelog libfreefare
(0.4.0-2) unstable; urgency=low $ dch --local buxy [...] $ head
debian/changelog

libfreefare (0.4.0-2buxy1)
UNRELEASED; urgency=medium

    * Abilita l'opzione di configurazione --with-debug.

  -- Raphael Hertzog <buxy@kali.org> venerdì 22 gennaio 2021 10:36:00 -0400

libfreefare (0.4.0-2) instabile; urgenza=bassa
```

[2] https://www.debian.org/doc/manuals/maint-guide/

Machine Translated by Google

```
  * Aggiornare debian/copyright.
      Modificare la licenza in LGPL3+.
```

Se effettuate regolarmente tali modifiche, potreste voler impostare le variabili d'ambiente DEBFULLNAME e DEBEMAIL rispettivamente con il vostro nome completo e il vostro indirizzo email. I loro valori verranno utilizzati da molti strumenti di creazione pacchetti, incluso dch, che li inserirà nella riga di chiusura mostrata sopra (che inizia con " -- ").

### Applicazione di una toppa

In uno dei nostri casi d'uso, abbiamo scaricato il pacchetto pyritsource e vogliamo applicare una patch che abbiamo trovato nel repository Git originale. Si tratta di un'operazione comune e dovrebbe essere sempre semplice. Sfortunatamente, le patch possono essere gestite in modi diversi a seconda del formato del pacchetto sorgente e del flusso di lavoro di packaging Git utilizzato (quando Git viene utilizzato per la gestione del pacchetto).

**Con un pacchetto sorgente decompresso** Hai eseguito apt source pyrit e hai una directory pyrit-0.4.0 . Puoi applicare la tua patch direttamente con patch -p1 < file-patch:

```
$ apt source pyrit [...] $
 cd
pyrit-0.4.0 $ wget
https://github.com/JPaulMora/Pyrit/commit/14 ÿ
      ec997174b8e8fd20d22b6a97c57e19633f12a0.patch -O /tmp/pyrit-patch [...] $ patch -p1 </tmp/
 pyrit-
patch applicazione della patch al file cpyrit/
pcktools.py Blocco #1 riuscito alla riga 53 (offset
-1 righe). $ dch --local buxy "Applica la patch per
funzionare con scapy 2.3"
```

A questo punto, hai applicato manualmente le patch al codice sorgente e puoi già creare pacchetti binari della tua versione modificata (vedi la sezione 9.1.4, "Avvio della compilazione" [pagina 236]). Tuttavia, se provi a creare un pacchetto sorgente aggiornato, l'operazione fallirà, segnalando "modifiche upstream impreviste". Questo accade perché pyrit (come la maggior parte dei pacchetti sorgente) utilizza il formato sorgente (vedi il file debian/source/format ) noto come 3.0 (quilt), in cui le modifiche al codice upstream devono essere registrate in patch separate memorizzate in debian/patches/ e dove il file debian/patches/series indica l'ordine in cui le patch devono essere applicate. Puoi registrare le tue modifiche in una nuova patch eseguendo dpkg-source --commit:

```
$ dpkg-source --commit dpkg-
source: info: rilevate modifiche locali, i file modificati sono: pyrit-0.4.0/cpyrit/pckttools.py

Inserisci il nome della patch desiderata: fix-for-scapy-2.3.patch
```

Machine Translated by Google

```
dpkg-source: info: le modifiche locali sono state registrate in una nuova patch: pyrit-0.4.0/debian/ ÿ patches/fix-for-
        scapy-2.3.patch
$ tail -n 1 debian/patches/series fix-for-
scapy-2.3.patch
```

**Serie di patch Quilt** Questa convenzione di gestione delle patch è stata resa popolare da uno strumento chiamato quilt e il formato del pacchetto sorgente "3.0 (quilt)" è quindi compatibile con questo strumento, con la piccola differenza che utilizza debian/patches invece di patches. Questo strumento è disponibile nel pacchetto omonimo e puoi trovare un utile tutorial qui:

ÿ https://raphaelhertzog.com/2012/08/08/how-to-use-quilt-to-manage-patches-in-debian-packages/

Se il pacchetto sorgente utilizza il formato sorgente 1.0 o 3.0 (nativo), non è necessario registrare le modifiche apportate al progetto originale in una patch. Queste vengono automaticamente incluse nel pacchetto sorgente risultante.

**Con un repository Git** Se hai utilizzato Git per recuperare il pacchetto sorgente, la situazione è ancora più complessa. Esistono diversi flussi di lavoro Git e strumenti associati, e ovviamente non tutti i pacchetti Debian utilizzano gli stessi flussi di lavoro e strumenti. La distinzione già spiegata sul formato del sorgente rimane valida, ma devi anche verificare se le patch sono preapplicate nell'albero dei sorgenti o se sono memorizzate solo in debian/patches (in questo caso, vengono poi applicate in fase di compilazione).

Lo strumento più diffuso è *git-buildpackage.* È quello che utilizziamo per gestire tutti i repository su git-lab.com/kalilinux/packages. Quando lo si utilizza, le patch non vengono pre-applicate nell'albero dei sorgenti, ma vengono memorizzate in debian/patches. È possibile aggiungere manualmente le patch in quella directory ed elencarle in debian/patches/series , ma gli utenti di git-buildpackage tendono a utilizzare gbp pq per modificare l'intera serie di patch come un singolo ramo che è possibile estendere o riorganizzare a piacimento. Consultare le pagine del manuale di gbp-pq(1) per imparare come richiamarlo.

*git-dpm* (con il relativo comando omonimo) è un altro strumento di packaging git che si può trovare in uso. Registra i metadati in debian/.git-dpm e mantiene le patch applicate nell'albero dei sorgenti unendo un ramo costantemente riorganizzato che viene creato a partire dal contenuto di debian/patches.

### Modifica delle opzioni di compilazione

In genere è necessario modificare le opzioni di compilazione quando si desidera abilitare una funzionalità o un comportamento opzionale non attivato nel pacchetto ufficiale, oppure quando si desidera personalizzare i parametri impostati in fase di compilazione tramite un'opzione ./configure o tramite variabili definite nell'ambiente di compilazione.

In questi casi, le modifiche sono generalmente limitate a debian/rules, che gestisce i passaggi del processo di compilazione del pacchetto. Nei casi più semplici, le righe relative alla configurazione iniziale (./con-figure …) o alla compilazione vera e propria ($(MAKE) … o make …) sono facili da individuare. Se questi comandi non sono

Machine Translated by Google

Se richiamati esplicitamente, sono probabilmente un effetto collaterale di un altro comando esplicito; in tal caso, si prega di consultare la relativa documentazione per ulteriori informazioni su come modificare il comportamento predefinito. Con i pacchetti che utilizzano dh, potrebbe essere necessario aggiungere un override per i comandi dh_auto_configure o dh_auto_build (consultare le rispettive pagine di manuale per spiegazioni su come procedere).

Per rendere queste spiegazioni più concrete, applichiamole al nostro caso d'uso di esempio. Hai deciso di modificare libfreefare per passare l' opzione --enable-debug allo script ./configure in modo da ottenere un output più dettagliato dai tuoi strumenti di comunicazione in campo vicino (NFC) e inviare una segnalazione di bug migliore sulla tua scheda NFC Mifare non riconosciuta. Poiché il pacchetto utilizza dh per gestire il processo di compilazione, aggiungi (o in questo caso modifichi) il target override_dh_auto_configure . Ecco l'estratto corrispondente del file debian/rules di libfreefare :

```
override_dh_auto_configure: dh_auto_configure
    -- --without-cutter --disable-silent-rules --enable-debug
```

Confezionamento di una nuova versione a monte

Facciamo un esempio, visto che stiamo parlando di pacchettizzazione delle versioni upstream. Supponiamo che tu sia un utente esperto di SET e che tu abbia notato una nuova versione upstream (7.4.5) non ancora disponibile in Kali (che ha solo la versione 7.4.4). Vuoi creare un pacchetto aggiornato e provarlo. Si tratta di un aggiornamento di versione minore e quindi non ti aspetti che l'aggiornamento richieda modifiche a livello di pacchettizzazione.

Per aggiornare il pacchetto sorgente, estrai il nuovo archivio tarball dei sorgenti nella stessa directory del pacchetto sorgente corrente e copi la directory debian dal pacchetto sorgente corrente a quello nuovo. Infine, incrementi la versione in debian/changelog.

```
$ apt source set Lettura
degli elenchi dei pacchetti... Fatto AVVISO: il
pacchetto 'set' è gestito nel sistema di controllo versione 'Git' all'indirizzo: https://gitlab.com/kalilinux/packages/set.git Si prega di
utilizzare:

Esegui il comando `git clone https://gitlab.com/kalilinux/packages/set.git` per scaricare gli ultimi
aggiornamenti (eventualmente non ancora rilasciati) del pacchetto.
È necessario ottenere 42,3 MB di archivi sorgente. [...] dpkg-
 source:
avviso: impossibile verificare la firma su ./set_7.4.4-0kali1.dsc dpkg-source: info: estrazione del set in set-7.4.4 dpkg-source:
info: decompressione di set_7.4.4.orig.tar.gz dpkg-source: info: decompressione
di set_7.4.4-0kali1.debian.tar.xz dpkg-source: info: applicazione di edit-config-file dpkg-
source: info: applicazione di fix-path-interpreter.patch $ wget https://github.com/trustedsec/social-
engineer-toolkit/archive/7.4.5.tar.gz -O ÿ set_7.4.5.orig.tar.gz [...]
```

Machine Translated by Google

```
$ tar xvf set_7.4.5.orig.tar.gz [...] social-

engineer-toolkit-7.4.5/src/wireless/wifiattack.py $ cp -a set-7.4.4/debian social-
engineer-toolkit-7.4.5/debian $ cd social-engineer-toolkit-7.4.5 $ dch -v 7.4.5-0buxy1
"Nuova versione upstream"
```

Ecco fatto. Ora puoi compilare il pacchetto aggiornato.

A seconda del tipo di modifiche introdotte dalla nuova versione upstream, potrebbe essere necessario modificare anche le dipendenze di compilazione e di runtime, nonché installare nuovi file. Si tratta di operazioni molto più complesse che non vengono trattate in questo libro.

### 9.1.4. Avvio della compilazione

Una volta applicate tutte le modifiche necessarie ai sorgenti, è possibile iniziare a generare il pacchetto binario vero e proprio o il file .deb . L'intero processo è gestito dal comando dpkg-buildpackage e si presenta in questo modo:

```
$ dpkg-buildpackage -us -uc -b dpkg-
buildpackage: pacchetto sorgente libfreefare dpkg-buildpackage:
versione sorgente 0.4.0-2buxy1 dpkg-buildpackage: distribuzione
sorgente NON RILASCIATA dpkg-buildpackage: sorgente modificata da
Raphael Hertzog <buxy@kali.org> dpkg-buildpackage: architettura host amd64 [...] dh_builddeb



dpkg-deb: compilazione del pacchetto 'libfreefare0-dbgsym' in '../libfreefare0-dbgsym_0.4.0-2buxy1_amd64.deb'. dpkg-deb: compilazione del
pacchetto 'libfreefare0' in '../libfreefare0_0.4.0-2buxy1_amd64.deb'. dpkg-deb: compilazione del pacchetto 'libfreefare-dev' in '../
libfreefare-dev_0.4.0-2buxy1_amd64.deb'. dpkg-deb: compilazione del pacchetto 'libfreefare-bin-dbgsym' in '../libfreefare-bin-
dbgsym_0.4.0-2buxy1_amd64.deb'. dpkg-deb: compilazione del pacchetto 'libfreefare-bin' in '../libfreefare-bin_0.4.0-2buxy1_amd64.deb'. dpkg-deb:
compilazione del pacchetto 'libfreefare-doc' in '../libfreefare-doc_0.4.0-2buxy1_all.deb'. dpkg-genchanges -b >../
libfreefare_0.4.0-2buxy1_amd64.changes dpkg-genchanges: caricamento solo binario (nessun codice sorgente incluso) dpkg-source
  --after-build libfreefare-0.4.0 dpkg-buildpackage: caricamento solo binario (nessun codice
sorgente incluso)
```

Le opzioni -us e -uc disabilitano le firme su alcuni dei file generati (.dsc, .changes) perché questa operazione fallirà se non si dispone di una chiave GnuPG associata all'identità inserita nel file changelog . L' opzione -b richiede una "compilazione solo binaria". In questo caso, il pacchetto sorgente (.dsc) non verrà creato, ma solo i pacchetti binari (.deb) . Utilizzare questa opzione per evitare errori durante la compilazione del pacchetto sorgente: se non si sono registrate correttamente le modifiche nel sistema di gestione delle patch, questo potrebbe segnalare un errore e interrompere il processo di compilazione.

Come suggerito dai messaggi di dpkg-deb , i pacchetti binari generati sono ora disponibili nella directory principale (quella che ospita la directory del pacchetto sorgente). È possibile installarli con dpkg -i o apt install.

```
$ sudo apt install ../libfreefare0_0.4.0-2buxy1_amd64.deb \ ../libfreefare-
    bin_0.4.0-2buxy1_amd64.deb Lettura degli elenchi
dei pacchetti... Fatto
```

Machine Translated by Google

```
Creazione dell'albero delle dipendenze
Lettura delle informazioni sullo stato... Fatto Nota:
selezione di 'libfreefare0' invece di '../libfreefare0_0.4.0-2buxy1_amd64.deb' Nota: selezione di 'libfreefare-bin' invece di '../libfreefare-
bin_0.4.0-2buxy1_amd64.deb' I seguenti pacchetti verranno aggiornati: libfreefare-bin libfreefare0 2 aggiornati, 0 installati, 0 da rimuovere e 0
non aggiornati.


È necessario scaricare 0 B/69,4 kB di archivi.
Dopo questa operazione, verranno utilizzati 2.048 byte di spazio su disco aggiuntivo. [...]
```

Preferiamo `apt install` a `dpkg -i` perché gestisce correttamente le dipendenze mancanti. Tuttavia, fino a non molto tempo fa, era necessario utilizzare `dpkg` poiché `apt` non era in grado di gestire i file .deb al di fuori di qualsiasi repository.

**dpkg-buildpackage involucri**

Nella maggior parte dei casi, gli sviluppatori Debian utilizzano un programma di livello superiore come debuild; questo esegue dpkg-buildpackage come di consueto, ma aggiunge anche l'invocazione di un programma (lintian) che esegue numerosi controlli per convalidare il pacchetto generato rispetto alla policy Debian3 Questo script pulisce anche l'ambiente in modo che le variabili d'ambiente locali non inquinino la compilazione del pacchetto. Il comando debuild è uno degli strumenti della suite devscripts , che condividono una certa coerenza e configurazione per semplificare il lavoro dei manutentori.

## 9.2. Ricompilazione del kernel Linux

I kernel forniti da Kali includono il maggior numero possibile di funzionalità, nonché il numero massimo di driver, al fine di coprire il più ampio spettro di configurazioni hardware esistenti. Per questo motivo, alcuni utenti preferiscono ricompilare il kernel per includere solo ciò di cui hanno specificamente bisogno. Ci sono due ragioni per questa scelta. In primo luogo, è un modo per ottimizzare il consumo di memoria, poiché tutto il codice del kernel, anche se non viene mai utilizzato, occupa memoria fisica. Poiché le parti del kernel compilate staticamente non vengono mai spostate nello spazio di swap, la presenza di driver e funzionalità integrate che non vengono mai utilizzate comporterà un calo complessivo delle prestazioni del sistema.
In secondo luogo, la riduzione del numero di driver e di funzionalità del kernel riduce il rischio di problemi di sicurezza, poiché viene eseguita solo una frazione del codice del kernel disponibile.

[3] https://www.debian.org/doc/debian-policy/

Machine Translated by Google

Importante



Se scegliete di compilare il vostro kernel personalizzato, dovete accettarne le conseguenze: Kali non può garantire aggiornamenti di sicurezza per il vostro kernel personalizzato. Mantenendo il kernel fornito da Kali, potrete beneficiare degli aggiornamenti preparati dal Progetto Debian.

La ricompilazione del kernel è necessaria anche se si desidera utilizzare determinate funzionalità disponibili solo tramite patch (e non incluse nella versione standard del kernel).

**Il kernel Debian Manuale**

Il team del kernel Debian mantiene il Manuale del kernel Debian (disponibile anche nel pacchetto debian-kernel-handbook ) con una documentazione completa sulla maggior parte delle attività relative al kernel e su come vengono gestiti i pacchetti ufficiali del kernel Debian. Questo è il primo punto di riferimento da consultare se si necessitano ulteriori informazioni rispetto a quelle fornite in questa sezione.

ÿ https://kernel-team.pages.debian.net/kernel-handbook/

## 9.2.1. Introduzione e prerequisiti

Come prevedibile, Debian e Kali gestiscono il kernel sotto forma di pacchetto, un metodo insolito per la compilazione e l'installazione dei kernel. Poiché il kernel rimane sotto il controllo del sistema di packaging, può essere rimosso senza problemi o distribuito su più macchine. Inoltre, gli script associati a questi pacchetti automatizzano l'interazione con il bootloader e il generatore di initrd.

I sorgenti Linux upstream contengono tutto il necessario per creare un pacchetto Debian del kernel, ma è comunque necessario installare il pacchetto *build-essential* per assicurarsi di avere gli strumenti necessari per la compilazione. Inoltre, la fase di configurazione del kernel richiede il pacchetto *libncurses5-dev* . Infine, il pacchetto *fakeroot* consentirà la creazione del pacchetto Debian senza bisogno di privilegi amministrativi.

```
# apt install build-essential libncurses5-dev fakeroot
```

## 9.2.2. Reperire le fonti

Poiché i sorgenti del kernel Linux sono disponibili come pacchetto, è possibile recuperarli installando il pacchetto *linux-source-version* . Il comando apt-cache search ^linux-source dovrebbe elencare l'ultima versione del kernel pacchettizzata da Kali. Si noti che il codice sorgente contenuto in questi pacchetti

Machine Translated by Google

non corrisponde esattamente a quello pubblicato da Linus Torvalds e dagli sviluppatori del kernel4 Come tutte le distribuzioni, Debian e Kali applicano una serie di patch che potrebbero (o meno) essere integrate nella versione principale di Linux. Queste modifiche includono backport di correzioni/funzionalità/driver da versioni più recenti del kernel, nuove funzionalità non ancora (completamente) integrate nel ramo principale di Linux e, a volte, anche modifiche specifiche di Debian o Kali.

La parte restante di questa sezione si concentra sulla versione 4.9 del kernel Linux, ma gli esempi possono, ovviamente, essere adattati alla specifica versione del kernel che si desidera utilizzare.

In questo esempio, si presume che il pacchetto binario *linux-source-4.9* sia stato installato. Si noti che installiamo un pacchetto binario contenente i sorgenti upstream, ma non scarichiamo il pacchetto sorgente di Kali denominato *linux.*

```
# apt install linux-source-4.9 Lettura degli
elenchi dei pacchetti... Fatto Creazione
dell'albero delle dipendenze Lettura
delle informazioni sullo stato... Fatto I seguenti
pacchetti aggiuntivi verranno installati: bc libreadline7

Pacchetti consigliati:
    libncurses-dev | ncurses-dev libqt4-dev
Verranno installati i seguenti NUOVI pacchetti:
    bc libreadline7 linux-source-4.9
0 aggiornati, 3 installati di recente, 0 da rimuovere e 0 non aggiornati.
È necessario scaricare 95,4 MB di archivi.
Dopo questa operazione, verranno utilizzati 95,8 MB di spazio aggiuntivo sul disco.
Vuoi continuare? [S/n] s [...] # ls /usr/src linux-

config-4.9 linux-
patch-4.9-rt.patch.xz linux-source-4.9.tar.xz
```

Si noti che il pacchetto contiene /usr/src/linux-source-4.9.tar.xz, un archivio compresso dei sorgenti del kernel. È necessario estrarre questi file in una nuova directory (non direttamente in /usr/src/, poiché non sono necessari permessi speciali per compilare un kernel Linux). Una directory più appropriata è ~/kernel/ .

```
$ mkdir ~/kernel; cd ~/kernel $ tar -xaf /usr/
src/linux-source-4.9.tar.xz
```

### 9.2.3. Configurazione del kernel

Il passo successivo consiste nel configurare il kernel in base alle proprie esigenze. La procedura esatta dipende dagli obiettivi.

[4] https://www.kernel.org/

Machine Translated by Google

La compilazione del kernel dipende da un file di configurazione del kernel. Nella maggior parte dei casi, è consigliabile attenersi il più possibile alla configurazione proposta da Kali, che, come tutte le distribuzioni Linux, viene installata nella directory /boot . In questo caso, anziché riconfigurare tutto da zero, è sufficiente copiare il file /boot/config-version . La versione deve corrispondere alla versione del kernel attualmente in uso, che può essere individuata con il comando uname -r . Copiare il file in un file .config nella directory contenente i sorgenti del kernel.

```
$ cp /boot/config-4.9.0-kali1-amd64 ~/kernel/linux-source-4.9/.config
```

In alternativa, poiché il kernel fornisce configurazioni predefinite in arch/arch/configs/*_defconfig, è possibile applicare la configurazione selezionata con un comando come make x86_64_defconfig (nel caso di un PC a 64 bit) o make i386_defconfig (nel caso di un PC a 32 bit).

A meno che non dobbiate modificare la configurazione, potete fermarvi qui e passare alla sezione 9.2.4, "Compilazione e creazione del pacchetto" [pagina 241]. Se dovete apportare modifiche o se decidete di riconfigurare tutto da zero, dovete dedicare del tempo alla configurazione del kernel. Nella directory dei sorgenti del kernel sono presenti diverse interfacce dedicate che possono essere utilizzate richiamando il comando make target , dove *target* è uno dei valori

descritti di seguito. make menuconfig compila e avvia un'interfaccia di configurazione del kernel in modalità testuale (è qui che è richiesto il pacchetto *libncurses5-dev ),* che consente di navigare tra le numerose opzioni del kernel disponibili in una struttura gerarchica. Premendo la barra spaziatrice si modifica il valore dell'opzione selezionata, Invio conferma il pulsante selezionato in fondo allo schermo; Select torna al sottomenu selezionato; Exit chiude la schermata corrente e torna indietro nella gerarchia; Help visualizza informazioni più dettagliate sul ruolo dell'opzione selezionata. I tasti freccia consentono di spostarsi all'interno dell'elenco di opzioni e pulsanti. Per uscire dal programma di configurazione, selezionare Esci dal menu principale. Il programma offrirà quindi la possibilità di salvare le modifiche apportate; accettare se si è soddisfatti delle scelte effettuate.

Altre interfacce presentano caratteristiche simili, ma funzionano all'interno di interfacce grafiche più moderne, come make xconfig, che utilizza un'interfaccia grafica Qt, e make gconfig, che utilizza GTK+. Il primo richiede *libqt4-dev,* mentre il secondo dipende da *libglade2-dev* e *libgtk2.0-dev.*

**Gestione dei file .config obsoleti**

Quando si fornisce un file .config generato con una versione del kernel diversa (di solito precedente), è necessario aggiornarlo. È possibile farlo con il comando `make oldconfig`, che porrà in modo interattivo le domande corrispondenti alle nuove opzioni di configurazione. Se si desidera utilizzare la risposta predefinita a tutte le domande, è possibile utilizzare `make olddefconfig`. Con `make oldnoconfig`, verrà presupposta una risposta negativa a tutte le domande.

Machine Translated by Google

### 9.2.4. Compilazione e creazione del pacchetto

**Pulizia prima della ricostruzione** Se hai già compilato un kernel nella directory e desideri ricompilare tutto da zero (ad esempio perché hai modificato sostanzialmente la configurazione del kernel), dovrai eseguire make clean per rimuovere i file compilati. make distclean rimuove anche altri file generati, incluso il tuo file .config , quindi assicurati di farne prima un backup.

Una volta pronta la configurazione del kernel, un semplice comando `make deb-pkg` genererà fino a cinque pacchetti Debian nel formato standard .deb : `*linux-image-version*`, che contiene l'immagine del kernel e i moduli associati; `*linux-headers-version*`, che contiene i file di intestazione necessari per compilare moduli esterni; `*linux-firmware-image-version*`, che contiene i file del firmware necessari ad alcuni driver (questo pacchetto potrebbe mancare quando si compila dai sorgenti del kernel forniti da Debian o Kali); `linux-image-version-dbg`, che contiene i simboli di debug per l'immagine del kernel e i suoi moduli; e `*linux-libc-dev*`, che contiene i file di intestazione rilevanti per alcune librerie dello spazio utente come la libreria C di GNU (glibc).

La *versione* è definita dalla concatenazione della versione upstream (come definita dalle variabili VERSION, PATCHLEVEL, SUBLEVEL e EXTRAVERSION nel Makefile), del parametro di configurazione LOCALVERSION e della variabile d'ambiente LOCALVERSION . La versione del pacchetto riutilizza la stessa stringa di versione con una revisione aggiunta che viene regolarmente incrementata (e memorizzata in .version), a meno che non venga sovrascritta dalla variabile d'ambiente KDEB_PKGVERSION .

```
$ make deb-pkg LOCALVERSION=-custom KDEB_PKGVERSION=$(make kernelversion)-1 [...] $ ls ../
*.deb ../linux-
headers-4.9.0-kali1-custom_4.9.2-1_amd64.deb ../linux-image-4.9.0-kali1-
custom_4.9.2-1_amd64.deb ../linux-image-4.9.0-kali1-custom-
dbg_4.9.2-1_amd64.deb ../linux-libc-dev_4.9.2-1_amd64.deb
```

Per utilizzare effettivamente il kernel compilato, l'unico passaggio rimanente è installare i pacchetti necessari con `dpkg -i file.deb`. Il pacchetto "linux-image" è obbligatorio; è necessario installare il pacchetto "linux-headers" solo se si hanno moduli del kernel esterni da compilare, come nel caso di pacchetti "*-dkms" installati (verificare con `dpkg -l ”*-dkms” | grep ^ii`). Gli altri pacchetti in genere non sono necessari (a meno che non si sappia perché servono)!

## 9.3. Creazione di immagini ISO live personalizzate di Kali

Kali Linux offre un'enorme quantità di funzionalità e flessibilità fin da subito. Una volta installato Kali, con un po' di guida, creatività, pazienza e pratica, è possibile realizzare cose incredibili.

Machine Translated by Google

Tuttavia, è anche possibile personalizzare una build di Kali in modo che contenga file o pacchetti specifici (per aumentare o diminuire le prestazioni e le funzionalità) e possa eseguire automaticamente determinate funzioni. Ad esempio, l' immagine ISO di Kali di Doom5 e il punto di accesso wireless Kali Evil6 Sono entrambi progetti eccellenti che si basano su un'implementazione personalizzata di Kali Linux. Diamo un'occhiata al processo di creazione di un'immagine ISO personalizzata di Kali Linux.

Le immagini ISO ufficiali di Kali sono create con live-build7, Si tratta di un insieme di script che consente l'automazione e la personalizzazione complete di tutti gli aspetti della creazione di immagini ISO. La suite *live-build* utilizza un'intera struttura di directory come input per la sua configurazione. Memorizziamo questa configurazione e alcuni script di supporto associati in un repository Git chiamato live-build-config . Useremo questo repository come base per la creazione di immagini personalizzate.

Prima di procedere, è importante sapere che i comandi mostrati in questa sezione sono pensati per essere eseguiti su un sistema Kali Linux aggiornato. È molto probabile che non funzionino se eseguiti su un sistema non Kali o se il sistema non è aggiornato.

### 9.3.1. Installazione dei prerequisiti

Il primo passo consiste nell'installare i pacchetti necessari e nel recuperare il repository Git con la configurazione *di live-build* di Kali:

```
# apt install curl git live-build [...] # git clone https://
gitlab.com/kalilinux/build-scripts/live-build-config.git [...] # cd live-build-config # ls auto bin build_all.sh build.sh kali-
 config
README.md simple-cdd
```

A questo punto, è già possibile creare un'immagine ISO live di Kali aggiornata (ma non modificata) semplicemente eseguendo ./build.sh --verbose. La compilazione richiederà molto tempo per essere completata, poiché scaricherà tutti i pacchetti da includere. Al termine, troverete la nuova immagine ISO nella directory delle immagini .

### 9.3.2. Creazione di immagini live con diversi ambienti desktop

Il wrapper live-build build.sh che forniamo è responsabile della configurazione della directory di configurazione che live-build si aspetta di trovare. Può impostare diverse configurazioni a seconda dell'opzione --variant .

[5] https://www.offensive-security.com/kali-linux/kali-linux-iso-of-doom/
[6] https://www.offensive-security.com/kali-linux/kali-linux-evil-wireless-access-point/
[7] https://live-team.pages.debian.net/live-manual/html/live-manual/index.en.html

Machine Translated by Google

Lo script wrapper crea la directory di configurazione combinando i file provenienti da kali-config/common e kali-config/variant-X, dove *X* è il nome di una variante specificata con il parametro --variant .
Quando l'opzione non viene specificata esplicitamente, viene utilizzato "default" come nome della variante.

La directory kali-config contiene le directory per gli ambienti desktop più comuni:

- e17 per Enlightenment;
- gnome per GNOME;
- i3wm per il gestore di finestre corrispondente;
- kde per KDE;
- lxde per LXDE;
- mate per l'ambiente desktop Mate;
- xfce per Xfce.

Con questo singolo comando puoi creare facilmente un'immagine live di Kali utilizzando KDE come ambiente desktop:

```
# ./build.sh --variant kde --verbose
```

Questo concetto di *variante* consente alcune personalizzazioni predefinite di alto livello, ma se ti prendi il tempo di leggere il Manuale di sistema live di Debian[8] Scoprirai moltialtri modi per personalizzare le immagini, semplicemente modificando il contenuto dell'apposita sottocartella di kali-config.
Le sezioni seguenti forniranno alcuni esempi.

### 9.3.3. Modifica dell'insieme dei pacchetti installati

Una volta avviato, live-build installa tutti i pacchetti elencati nei file package-lists/*.list.chroot . La configurazione predefinita che forniamo include un file package-lists/kali.list.chroot , che elenca *kali-linux-default* (il metapackage principale che include tutti i pacchetti Kali da installare).
È possibile commentare questo pacchetto e inserirne un altro a propria scelta, oppure includere un insieme preciso di altri pacchetti. È anche possibile combinare entrambi gli approcci, partendo da un metapackage e aggiungendo pacchetti supplementari a propria scelta.

Con le liste di pacchetti, è possibile includere solo pacchetti già disponibili nel repository ufficiale di Kali. Tuttavia, se si dispone di pacchetti personalizzati, è possibile includerli nell'immagine live posizionando i file .deb in una directory packages.chroot (ad esempio kali-config/config-gnome/packages.chroot se si compila la variante GNOME). I metapackage sono

pacchetti vuoti il cui unico scopo è quello di avere molte dipendenze da altri pacchetti. Semplificano l'installazione di gruppi di pacchetti che si desidera installare spesso insieme.
Il pacchetto sorgente kali-meta compila tutti i metapacchetti forniti da Kali Linux:

[8] https://live-team.pages.debian.net/live-manual/html/live-manual.en.html

Machine Translated by Google

- kali-linux-core: il sistema base (viene utilizzato da tutti gli altri metapackage)
- kali-linux-headless: gli strumenti da riga di comando predefiniti per l'installazione di Kali Linux
- kali-linux-default: l'installazione predefinita di Kali Linux, sia da riga di comando che grafica.
- kali-linux-large: set di strumenti più ampio, che non sono usati così comunemente
- kali-linux-everything: metapackage di tutti i metapackage e altri pacchetti (quasi tutto ciò che Kali offre, quindi è davvero enorme!)
- kali-tools-top10: i dieci strumenti più popolari
- kali-tools-web: strumenti di valutazione delle applicazioni web
- kali-tools-passwords: strumenti per decifrare le password
- kali-tools-wireless: La raccolta di strumenti di valutazione wireless 802.11, Bluetooth, RFID e SDR e strumenti di analisi
- kali-tools-forensics: strumenti forensi (per trovare prove di quanto accaduto)
- kali-tools-802-11: strumenti di valutazione e analisi wireless
- kali-tools-bluetooth: Strumenti focalizzati sul Bluetooth
- kali-tools-crypto-stego: strumenti di crittografia e steganografia
- kali-tools-crypto-fuzzing: strumenti di fuzzing per attacchi
- kali-tools-gpu: strumenti che sfruttano la potenza di calcolo disponibile nella scheda grafica (strumenti che utilizzano la potenza di calcolo della scheda grafica).
- kali-tools-hardware: strumenti progettati per attaccare l'hardware
- kali-tools-rfid: Strumenti per l'identificazione a radiofrequenza (RFID)
- kali-tools-sdr: Strumenti per la radio definita via software (SDR)
- kali-tools-voip: Strumenti per il Voice Over IP
- kali-tools-windows-resources: Binari precompilati per Microsoft Windows

È possibile utilizzare questi metapackage quando si creano elenchi di pacchetti personalizzati per le build live. L'elenco completo dei metapackage disponibili e degli strumenti che includono è consultabile all'indirizzo https://tools.kali.org/kali-metapackages

**Presentazione di Debconf Pacchetti installati**

È possibile fornire file preseed di Debconf (vedere la sezione 4.3.2, "Creazione di un file preseed" [pagina 97] per le spiegazioni) come file preseed/*.cfg . Questi verranno utilizzati per configurare i pacchetti installati nel file system live.

Machine Translated by Google

### 9.3.4. Utilizzo degli hook per modificare il contenuto dell'immagine

Live-build offre degli hook che possono essere eseguiti in diverse fasi del processo di compilazione. Gli hook chroot sono script eseguibili che si installano come file hooks/live/*.chroot nella struttura di directory di configurazione e che vengono eseguiti all'interno del chroot. Sebbene chroot sia il comando che consente di modificare temporaneamente la directory radice del sistema operativo in una directory a scelta, viene utilizzato anche per estensione per designare una directory che ospita un intero albero di file system (alternativo). Questo è il caso di Live-build, dove la directory chroot è la directory in cui viene preparato il file system live. Poiché le applicazioni avviate in un chroot non possono accedere all'esterno di tale directory, lo stesso vale per gli hook chroot: è possibile utilizzare e modificare solo tutto ciò che è disponibile in quell'ambiente chroot. Ci affidiamo a questi hook per eseguire diverse personalizzazioni specifiche di Kali (vedere kali-config/common/hooks/live/kali-hacks.chroot).

Gli hook binari (hooks/live/*.binary) vengono eseguiti nel contesto del processo di compilazione (e non in un ambiente chroot) al termine del processo stesso. È possibile modificare il contenuto dell'immagine ISO creata, ma non del file system live, poiché a questo punto è già stato generato. In Kali, utilizziamo questa funzionalità per apportare alcune modifiche alla configurazione predefinita di isolinux generata da live-build. Ad esempio, si veda kali-config/common/hooks/live/persistence.binary, dove aggiungiamo le voci del menu di avvio che abilitano la persistenza.

### 9.3.5. Aggiunta di file nell'immagine ISO o nel filesystem live

Un'altra personalizzazione molto comune consiste nell'aggiungere file sia al file system live che all'immagine ISO.

È possibile aggiungere file al file system live posizionandoli nella loro posizione prevista al di sotto della directory di configurazione includes.chroot . Ad esempio, forniamo kali-config/common/includes.chroot/usr/lib/live/config/0031-kali-password, che nel file system live risulterà essere /usr/lib/live/config/0031-kali-password .

Gli script **di hook per l'avvio live,** installati come /lib/live/config/XXXX-name, vengono eseguiti dallo script di inizializzazione del pacchetto live-boot. Riconfigurano molti aspetti del sistema per adattarlo a un sistema live. È possibile aggiungere script personalizzati per personalizzare il sistema live in fase di esecuzione: ad esempio, vengono utilizzati per implementare un parametro di avvio personalizzato.

È possibile aggiungere file all'immagine ISO posizionandoli nella posizione prevista, al di sotto della directory includes.binary.config . Ad esempio, forniamo kali-config/common/includes.binary/isolinux/splash.png per sovrascrivere l'immagine di sfondo utilizzata dal bootloader Isolinux (che si trova in /isolinux/splash.png nel filesystem dell'immagine ISO).

Machine Translated by Google

## 9.4. Aggiungere la persistenza all'immagine ISO live con una chiave USB

### 9.4.1. La funzionalità di persistenza: spiegazioni

Successivamente, analizzeremo i passaggi necessari per aggiungere la persistenza a una chiavetta USB di Kali. Un sistema live è per sua natura effimero. Tutti i dati memorizzati sul sistema live e tutte le modifiche apportate vengono perse al riavvio. Per ovviare a questo problema, è possibile utilizzare una funzionalità del *live boot* chiamata persistenza, che viene abilitata quando i parametri di avvio includono la parola chiave "persistence ".

Poiché la modifica del menu di avvio non è un'operazione banale, l'immagine live di Kali include di default due voci di menu che abilitano la persistenza: Live USB Persistence e Live USB Encrypted Persistence, come mostrato nella Figura 9.1, "Voci di menu di persistenza" [pagina 246].

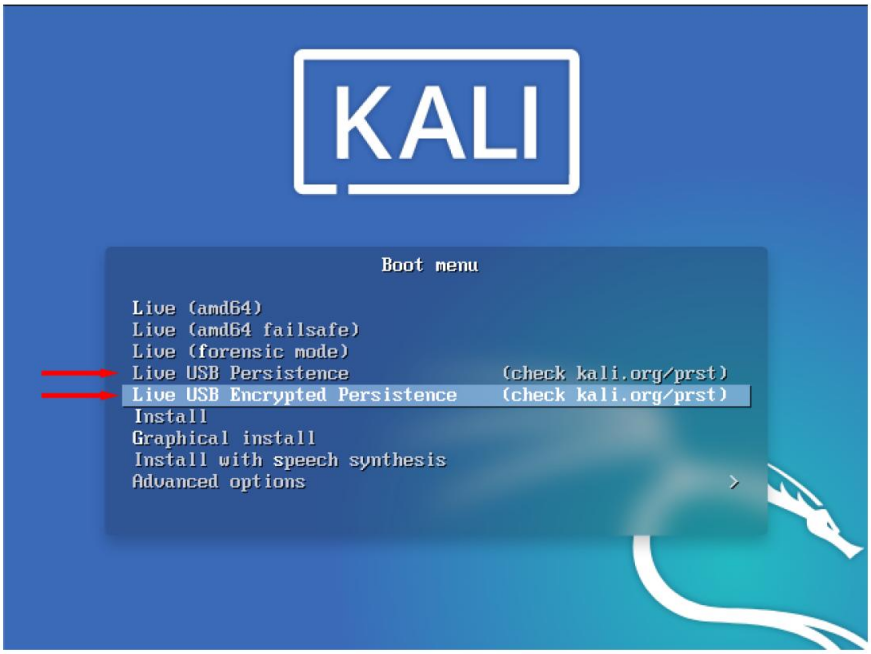



**Figura 9.1** Voci di menu persistenti

Quando questa funzione è abilitata, *l'avvio live* analizzerà tutte le partizioni alla ricerca di file system etichettati come persis-tence (che possono essere sovrascritti con il parametro di avvio persistence-label=value ) e il programma di installazione imposterà la persistenza delle directory elencate nel file persistence.conf presente in quella partizione (una directory per riga). Il valore speciale "/ union" abilita la persistenza completa di tutte le directory con un *mount union,* un overlay che memorizza solo le modifiche rispetto al file system sottostante. I dati delle directory persistenti vengono memorizzati nel file system che contiene il file persistence.conf corrispondente.

Machine Translated by Google

### 9.4.2. Configurazione della persistenza non crittografata su una chiave USB

In questa sezione, presupponiamo che tu abbia preparato una chiavetta USB live di Kali seguendo le istruzioni nella sezione 2.1.4, “Copia dell’immagine su un DVD-ROM o una chiavetta USB” [pagina 19] e che hai utilizzato una chiavetta USB abbastanza grande da contenere l'immagine ISO (circa 4 GB) e i dati delle directory che vogliamo persistere. Supponiamo inoltre che la chiave USB sia riconosciuta da Linux come /dev/sdb e che contiene solo le due partizioni che fanno parte dell'immagine ISO predefinita (/dev/sdb1 e /dev/sdb2). Fai molta attenzione quando esegui questa procedura. Puoi facilmente distruggere dati importanti se ripartizionare l'unità sbagliata.

Per aggiungere una nuova partizione, devi conoscere le dimensioni dell'immagine che hai copiato in modo da poterla creare la nuova partizione inizia dopo l'immagine live. Quindi usa parted per creare effettivamente la partizione. I comandi seguenti analizzano l'immagine ISO denominata kali-linux-2020.3-live-amd64.iso, che è Si presume che sia presente anche sulla chiavetta USB:

```
# parted /dev/sdb print
Modello: SanDisk Cruzer Glide (scsi)
Disco /dev/sdb: 16,0 GB
Dimensione del settore (logica/fisica): 512B/512B
Tabella delle partizioni: msdos
Flag del disco:

Numero Inizio Fine Misurare Tipo Flag del file system
 1 32,8 kB 3516 MB 3516 MB primario 3516 MB stivale, nascosto
 2 3517 MB 754 kB primario
# start=$(du --block-size=1MB kali-linux-2020.3-live-amd64.iso | awk '{print $1}')
# echo "La dimensione dell'immagine è di $start MB"
La dimensione dell'immagine è di 3518 MB
# parted -a optimal /dev/sdb mkpart primary ”${start}MB” 100%
Informazioni: Potrebbe essere necessario aggiornare il file /etc/fstab.

# parted /dev/sdb print
Modello: SanDisk Cruzer Glide (scsi)
Disco /dev/sdb: 16,0 GB
Dimensione del settore (logica/fisica): 512B/512B
Tabella delle partizioni: msdos
Flag del disco:

Numero Inizio Fine Misurare Tipo Flag del file system
 1 32,8 kB 3516 MB 3516 MB primario 3516 MB stivale, nascosto
 2 3517 MB 754 kB primario
 3 3518 MB 16,0 GB 12,5 GB primaria
```

Una volta creata la nuova partizione /dev/sdb3 , formattarla con un filesystem ext4 denominato "persistence". con l'aiuto del comando mkfs.ext4 (e della sua opzione -L per impostare l'etichetta). La partizione è quindi montato sulla directory /mnt e aggiungi il file di configurazione persistence.conf richiesto . Come

Machine Translated by Google

È fondamentale prestare sempre la massima attenzione quando si formatta un disco. Formattare il disco o la partizione sbagliata può comportare la perdita di informazioni preziose.

```
# mkfs.ext4 -L persistence /dev/sdb3 mke2fs 1.45.6 (20-
mar-2020)
Creazione del filesystem con 3049472 blocchi da 4k e 762528 inode. UUID del filesystem:
cedc7589-a002-4aae-8963-f5197d6d9d4a. Backup del superblock memorizzati sui
blocchi:
    32768, 98304, 163840, 229376, 294912, 819200, 884736, 1605632, 2654208

Allocazione delle tabelle di gruppo: completata
Scrittura delle tabelle inode: completata
Creazione del journal (16384 blocchi): completata Scrittura
dei superblock e delle informazioni di contabilità del filesystem: completata # mount /dev/sdb3 /mnt #
echo ”/ union” >/mnt/
persistence.conf # ls -l /mnt totale 20 drwx------ 2 root root
16384 10 maggio
13:31
lost+found
 -rw-r--r-- 1 radice radice                8 maggio 10 13:34 persistence.conf
# umount /mnt
```

La chiavetta USB è ora pronta e può essere utilizzata per l'avvio tramite la voce di menu "Live USB Persistence".

### 9.4.3. Configurazione della persistenza crittografata su una chiave USB

Live-boot è in grado di gestire anche i file system persistenti su partizioni crittografate. È quindi possibile proteggere i dati delle directory persistenti creando una partizione crittografata LUKS contenente i dati persistenti.

I passaggi iniziali sono gli stessi fino alla creazione della partizione, ma invece di formattarla con un file system ext4, si utilizza cryptsetup per inizializzarla come contenitore LUKS. Successivamente, si apre tale contenitore e si configura il file system ext4 nello stesso modo della configurazione non crittografata, ma invece di utilizzare la partizione /dev/sdb3 , si utilizza la partizione virtuale creata da cryptsetup. Questa partizione virtuale rappresenta il contenuto decrittografato della partizione crittografata, che è disponibile in /dev/mapper con il nome assegnato. Nell'esempio seguente, utilizzeremo il nome kali_persistence.

Anche in questo caso, assicurati di utilizzare l'unità e la partizione corrette.

```
# cryptsetup --verbose --verify-passphrase luksFormat /dev/sdb3

AVVERTIMENTO!
========
Questa operazione sovrascriverà in modo irreversibile i dati presenti su /dev/sdb3.

Sei sicuro? (Scrivi sì in maiuscolo): SÌ Inserisci la passphrase
per /dev/sdb3:
```

Machine Translated by Google

```
Verifica la passphrase: slot
chiave 0 creato.
Comando eseguito con successo.
# cryptsetup luksOpen /dev/sdb3 kali_persistence Inserisci la
passphrase per /dev/sdb3: # mkfs.ext4 -L
persistence /dev/mapper/kali_persistence mke2fs 1.45.6 (20-mar-2020)

Creazione del filesystem con 3045376 blocchi da 4k e 761856 inode. UUID del filesystem:
22adeb99-e32d-43e7-b9df-f04389dd0ba4. Backup del superblock memorizzati
sui blocchi:
    32768, 98304, 163840, 229376, 294912, 819200, 884736, 1605632, 2654208

Assegnazione dei tavoli di gruppo: completata
Scrittura delle tabelle inode: completata
Creazione del registro (16384 blocchi): completata
Scrittura dei superblock e delle informazioni di contabilità del filesystem: completata

# mount /dev/mapper/kali_persistence /mnt # echo "/
union" >/mnt/persistence.conf # umount /mnt #
cryptsetup
luksClose /dev/mapper/kali_persistence
```

### 9.4.4. Utilizzo di più archivi di persistenza

Se hai diverse esigenze per il tuo sistema live Kali, puoi utilizzare più filesystem con etichette diverse e indicare sulla riga di comando di avvio quale (o quale insieme di) filesystem deve essere utilizzato per la funzionalità di persistenza: questo si fa tramite il parametro di avvio persistence-label=label .

Supponiamo che tu sia un penetration tester professionista. Quando lavori per un cliente, utilizzi una partizione di persistenza crittografata per proteggere la riservatezza dei tuoi dati nel caso in cui la chiavetta USB venga rubata o compromessa. Allo stesso tempo, desideri poter mostrare Kali e del materiale promozionale archiviato in una partizione non crittografata della stessa chiavetta USB. Poiché non vuoi modificare manualmente i parametri di avvio a ogni avvio, desideri creare un'immagine live personalizzata con voci di menu di avvio dedicate.

Il primo passo consiste nel creare l'immagine ISO live personalizzata (seguendo la sezione 9.3, "Creazione di immagini ISO live personalizzate di Kali" [pagina 241] e in particolare la sezione 9.3.4, "Utilizzo degli hook per modificare il contenuto dell'immagine" [pagina 245]). La personalizzazione principale consiste nel modificare il file kali-config/common/hooks/live/persistence-menu.binary in modo che appaia come segue (si notino i parametri persistence-label ):

```
#!/bin/sh

se [ ! -d isolinux ]; allora cd binario

fi
```

Machine Translated by Google

```
cat >>isolinux/live.cfg <<END

etichetta live-demo
        Etichetta del menu ^Live USB con dati demo
        linux /live/vmlinuz initrd /live/
        initrd.img append boot=live
        username=root hostname=kali persistence-label=demo persistence

etichetta vivere-lavorare
        Etichetta del menu ^Live USB con dati di lavoro
        linux /live/vmlinuz initrd /live/
        initrd.img append boot=live
        username=root hostname=kali persistence-label=work persistence- ÿ encryption=luks persistence


FINE
```

Successivamente, creeremo la nostra immagine ISO personalizzata e la copieremo sulla chiavetta USB. Dopodiché, creeremo e inizializzeremo le due partizioni e i relativi file system che verranno utilizzati per la persistenza dei dati. La prima partizione non è crittografata (etichettata "demo"), mentre la seconda è crittografata (etichettata "work"). Supponendo che /dev/sdb sia la nostra chiavetta USB e che la dimensione della nostra immagine ISO personalizzata sia di 3000 MB, il risultato sarebbe il seguente:

```
# parted /dev/sdb mkpart primary 3000 MB 55% # parted /dev/
sdb mkpart primary 55% 100% # mkfs.ext4 -L demo /dev/
sdb3 [...] # mount /dev/sdb3 /mnt # echo ”/
 union”
>/mnt/persistence.conf #
umount /mnt # cryptsetup --verbose --verify-passphrase
luksFormat /dev/
sdb4 [...] # cryptsetup luksOpen /dev/sdb4 kali_persistence [...] # mkfs.ext4 -L work /dev/

mapper/kali_persistence [...] # mount /dev/mapper/kali_persistence /
 mnt #
echo ”/ union” >/mnt/persistence.conf # umount /mnt # cryptsetup

luksClose /dev/mapper/kali_persistence
```

E questo è tutto. Ora puoi avviare il sistema dalla chiavetta USB e selezionare le nuove voci del menu di avvio a seconda delle tue esigenze!

| | |
|---|---|
| **Aggiungere una password per Nuke per una maggiore sicurezza** | Kali fornisce il pacchetto cryptsetup-nuke-password che modifica gli script di avvio iniziali di cryptsetup per implementare una nuova funzionalità: è possibile impostare una password di eliminazione che, una volta utilizzata, distruggerà tutte le chiavi utilizzate per gestire la partizione crittografata. |

Machine Translated by Google

Questo può essere utile quando si viaggia spesso e si ha bisogno di un modo rapido per assicurarsi che i propri dati non possano essere recuperati. All'avvio, basta digitare la password di ripristino al posto di quella reale e sarà impossibile per chiunque (incluso voi) accedere ai vostri dati.

Prima di utilizzare questa funzione, è quindi consigliabile creare una copia di backup delle chiavi di crittografia e conservarla in un luogo sicuro.

È possibile configurare una password Nuke con questo comando (supponendo che il pacchetto sia installato):

```
# dpkg-reconfigure cryptsetup-nuke-password
```

Maggiori informazioni su questa funzionalità sono disponibili nel seguente tutorial:

ÿ https://www.kali.org/tutorials/nuke-kali-linux-luks/

## 9.5. Riepilogo

In questo capitolo abbiamo imparato a modificare i pacchetti sorgente di Kali, che rappresentano i componenti fondamentali di tutte le applicazioni distribuite con Kali. Abbiamo anche scoperto come personalizzare e installare il kernel di Kali. Successivamente, abbiamo discusso dell'ambiente di live build e di come creare un'immagine ISO personalizzata di Kali Linux. Abbiamo inoltre mostrato come creare installazioni di Kali su chiavetta USB, sia crittografate che non crittografate.

### 9.5.1. Riepilogo Suggerimenti per la modifica dei pacchetti Kali

La modifica dei pacchetti Kali è solitamente un compito dei collaboratori e degli sviluppatori di Kali, ma potresti avere esigenze specifiche non soddisfatte dai pacchetti ufficiali e sapere come creare un pacchetto modificato può essere molto utile, soprattutto se desideri condividere le tue modifiche, distribuirle internamente o ripristinare il software a uno stato precedente in modo pulito.

Quando si ha bisogno di modificare un software, la tentazione potrebbe essere quella di scaricare il codice sorgente, apportare le modifiche e utilizzare il software modificato. Tuttavia, se l'applicazione richiede un'installazione a livello di sistema (ad esempio con un passaggio di `make install` ), si finirà per *inquinare* il file system con file sconosciuti a dpkg , creando presto problemi che non possono essere rilevati dalle dipendenze dei pacchetti. Inoltre, questo tipo di modifica del software è più complicato da condividere.

Quando si crea un pacchetto modificato, il processo generale è sempre lo stesso: si scarica il pacchetto sorgente, lo si estrae, si apportano le modifiche e infine si compila il pacchetto. Per ogni passaggio, spesso esistono diversi strumenti in grado di gestire ciascuna attività.

Per iniziare a ricompilare un pacchetto Kali, scarica prima il pacchetto sorgente, che è composto da un file *.dsc *(Debian Source Control)* e da file aggiuntivi a cui si fa riferimento in tale file di controllo.

Machine Translated by Google

I pacchetti sorgente sono archiviati su mirror accessibili tramite HTTP. Il modo più efficiente per ottenerli è tramite il comando `apt source source-package-name`, che richiede l'aggiunta della riga `deb-src` al file `/etc/apt/sources.list` e l'aggiornamento dei file di indice con `apt update`.

Inoltre, è possibile utilizzare dget (dal pacchetto *devscripts )* per scaricare direttamente un file .dsc insieme ai file correlati. Per i pacchetti specifici di Kali i cui sorgenti sono ospitati in un repository Git su gitlab.com/kalilinux/packages9 È possibile recuperare i sorgenti con il comando git clone https://gitlab.com/kalilinux/packages/source-package.git.

Dopo aver scaricato i sorgenti, installa i pacchetti elencati nelle dipendenze di compilazione del pacchetto sorgente con il comando `sudo apt build-dep ./`. Questo comando deve essere eseguito dalla directory dei sorgenti del pacchetto.

L'aggiornamento di un pacchetto sorgente consiste in una combinazione di alcune delle seguenti fasi:

- Il primo passo richiesto è modificare il numero di versione per distinguere il tuo pacchetto dall'originale con dch --local version-identifier, oppure modificare altri dettagli del pacchetto con dch.
- Applicare una patch con patch -p1 <patch-file o modificare la serie di patch di quilt . • Modificare le opzioni di compilazione, che di solito si trovano nel file debian/rules del pacchetto o in altri file nella directory debian/ .

Dopo aver modificato un pacchetto sorgente, è possibile compilare il pacchetto binario con il comando `dpkg-buildpackage -us -uc -b` dalla directory sorgente, che genererà un pacchetto binario non firmato. Il pacchetto può quindi essere installato con il comando `dpkg -i package-name_version_arch.deb`.

### 9.5.2. Riepilogo Suggerimenti per la ricompilazione del kernel Linux

In qualità di utente esperto, potresti voler ricompilare il kernel di Kali. Potresti voler alleggerire il kernel standard di Kali, che è carico di molte funzionalità e driver, aggiungere driver o funzionalità non standard oppure applicare patch al kernel. Attenzione però: un kernel configurato in modo errato può destabilizzare il sistema e devi essere pronto ad accettare che Kali non può garantire aggiornamenti di sicurezza per il tuo kernel personalizzato.

Per la maggior parte delle modifiche al kernel, sarà necessario installare alcuni pacchetti con apt install build-essential libncurses5-dev fakeroot.

Il comando apt-cache search ^linux-source dovrebbe elencare l'ultima versione del kernel pacchettizzata da Kali, e apt install linux-source-version-number installa un archivio compresso del codice sorgente del kernel in /usr/src.

I file sorgente devono essere estratti con tar -xaf in una directory diversa da /usr/src (ad esempio ~/kernel).

Quando arriverà il momento di configurare il kernel, tenete a mente questi punti:

[9] https://gitlab.com/kalilinux/packages

Machine Translated by Google

- A meno che tu non sia un utente esperto, dovresti prima popolare un file di configurazione del kernel. Il metodo preferito consiste nel prendere in prestito la configurazione standard di Kali copiando il file /boot/ config-version-string in ~/kernel/linux-source-version-number/.config. In alternativa, è possibile utilizzare il comando make architecture_defconfig per ottenere una configurazione adeguata all'architettura specificata.

- Lo strumento di configurazione del kernel basato su testo `make menuconfig` legge il file .config e presenta tutti gli elementi di configurazione in un ampio menu navigabile. Selezionando un elemento, vengono visualizzati la documentazione, i valori possibili e la possibilità di inserire un nuovo valore.

Eseguito dalla directory dei sorgenti del kernel, il comando `make clean` rimuoverà i file precedentemente compilati, mentre `make deb-pkg` genererà fino a cinque pacchetti Debian. Il file .deb *denominato `linux-image-version`* contiene l'immagine del kernel e i moduli associati.

Per utilizzare effettivamente il kernel compilato, installa i pacchetti necessari con `dpkg -i file.deb`. Il pacchetto "linux-image" è obbligatorio; devi installare il pacchetto "linux-headers" solo se hai dei moduli del kernel esterni da compilare, come nel caso di pacchetti "*-dkms" installati (verifica con `dpkg -l ”*-dkms” | grep ^ii`). Gli altri pacchetti in genere non sono necessari (a meno che tu non sappia perché ti servono!).

### 9.5.3. Riepilogo Suggerimenti per la creazione di immagini ISO live personalizzate di Kali

Le immagini ISO ufficiali di Kali sono create con live-build10, Si tratta di un insieme di script che consente l'automazione e la personalizzazione complete di tutti gli aspetti della creazione di immagini ISO.

Il tuo sistema Kali deve essere completamente aggiornato prima di utilizzare la build live.

La configurazione live-build di Kali può essere recuperata dai repository Git di Kali con due comandi: `apt install`, `curl git live-build` seguito da `git clone https://gitlab.com/kalilinux/build-scripts/live-build- config.git`.

Per generare un'immagine ISO live di Kali aggiornata ma non modificata, è sufficiente eseguire ./build.sh --verbose. La compilazione richiederà molto tempo per essere completata, poiché scaricherà tutti i pacchetti da includere. Al termine, troverai la nuova immagine ISO nella directory images . Se aggiungi --variant variant alla riga di comando, verrà creata la variante specificata dell'immagine ISO di Kali. Le varie varianti sono definite dalle rispettive directory di configurazione kali-config/variant-*. L'immagine principale è Xfce
variante.

Esistono diversi modi per personalizzare la tua ISO modificando la directory di configurazione di live-build:

- È possibile aggiungere (o rimuovere) pacchetti da un'immagine ISO attiva modificando il file package-lists/*. elenco dei file chroot.

- È possibile includere pacchetti personalizzati nell'immagine live posizionando i file .deb in una directory chroot packages . La loro installazione può essere preconfigurata con i file preseed/*.cfg .

10https://live-team.pages.debian.net/live-manual/html/live-manual/index.en.html

Machine Translated by Google

- Puoi aggiungere file al filesystem live inserendoli nella posizione prevista sotto include la directory di configurazione chroot.
- È possibile eseguire script durante il processo di configurazione chroot del sistema live installandoli come file hooks/live/*.chroot . È anche possibile eseguire script all'avvio dell'immagine live generata: è necessario fare in modo che vengano installati in /usr/lib/live/config/XXXX-name, ad esempio utilizzando la directory di configurazione includes.chroot .
- Il Manuale dei sistemi live di Debian11 è un ottimo riferimento per la configurazione di build live e test.

Configurare la persistenza crittografata e non crittografata su una chiavetta USB: creare un'installazione standard di Kali Live su USB è piuttosto semplice. Sebbene il processo possa sembrare sintatticamente complesso, è relativamente facile aggiungere la persistenza crittografata e non crittografata alla propria installazione portatile per estenderne significativamente le funzionalità.

Nel prossimo capitolo (capitolo 10, "Kali Linux in azienda" [pagina 258]), analizzeremo come Kali si adatta al contesto aziendale. Tratteremo la gestione della configurazione e mostreremo come estendere e personalizzare Kali Linux in modo semplice da implementare, sia che si disponga di un paio di macchine, sia di diverse migliaia.

11https://live-team.pages.debian.net/live-manual/html/live-manual/index.en.html

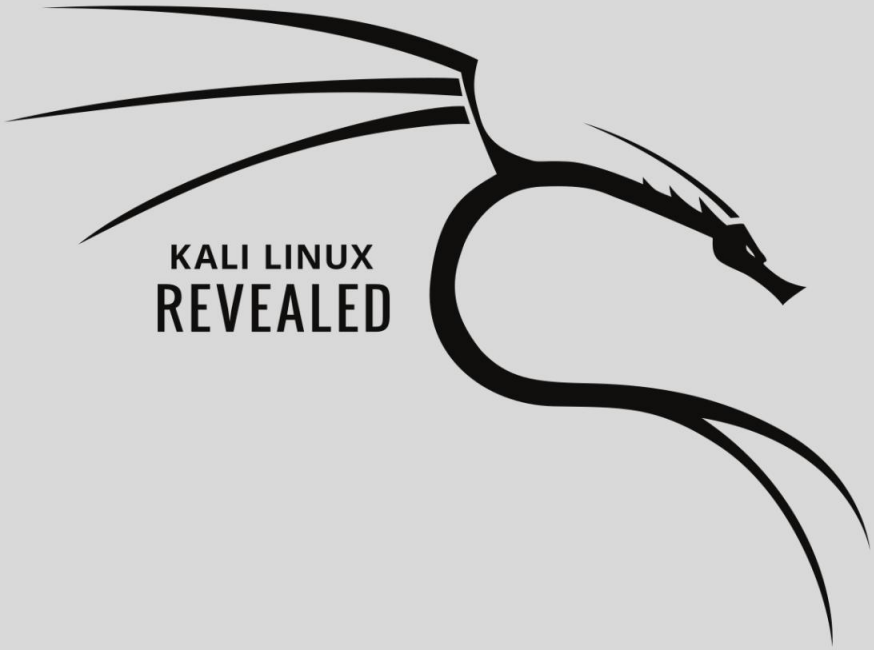
Machine Translated by Google



Machine Translated by Google

**Parole chiave**

**Installazione PXE**
**Gestione della configurazione Salina**
**Pacchetti Forking Kali**
**Pacchetti di configurazione**
**Pacchetto repository**



Machine Translated by Google

Capitolo

# Kali Linux nel **10** Imprese

Contenuto

Installazione di Kali Linux tramite rete (avvio PXE) 258
Sfruttare la gestione della configurazione 261
Estensione e personalizzazione di Kali Linux 268
Sommario 279

Machine Translated by Google

Finora abbiamo visto che Kali è una derivata di Debian estremamente potente e sicura, che offre funzionalità di sicurezza e crittografia di livello industriale, gestione avanzata dei pacchetti, compatibilità multipiattaforma e (ciò per cui è più conosciuta) un arsenale di strumenti di prim'ordine per i professionisti della sicurezza. Ciò che potrebbe non essere immediatamente evidente è come Kali si adatti a implementazioni di medie o grandi dimensioni, fino al livello aziendale. In questo capitolo, mostreremo come Kali possa scalare efficacemente oltre il desktop, fornendo una gestione centralizzata e un controllo di livello enterprise su più installazioni di Kali Linux. In breve, dopo aver letto questo capitolo sarete in grado di implementare rapidamente sistemi Kali altamente sicuri, preconfigurati per le vostre esigenze specifiche, e di mantenerli sincronizzati grazie all'installazione (semi-automatica) degli aggiornamenti dei pacchetti da parte di Kali.

Questo livello di scalabilità richiede diversi passaggi, tra cui l'avvio di una rete PXE, l'utilizzo di uno strumento avanzato di gestione della configurazione (SaltStack), la possibilità di creare fork e personalizzare i pacchetti e la distribuzione di un repository di pacchetti. Tratteremo ogni passaggio in dettaglio, mostrandovi come semplificare le operazioni più complesse e come implementare, gestire e mantenere numerose installazioni personalizzate di Kali Linux con relativa facilità. Come se non bastasse, vi forniremo anche una schiera di collaboratori per aiutarvi a gestire il vostro impero.

## 10.1. Installazione di Kali Linux tramite rete (avvio PXE)

Come abbiamo visto nei capitoli precedenti, la procedura di installazione base di Kali Linux è semplice una volta che si ha familiarità con il sistema. Tuttavia, se è necessario installare Kali su più macchine, la configurazione standard può risultare piuttosto complessa. Fortunatamente, è possibile avviare la procedura di installazione di Kali avviando un computer tramite la rete. Questo permette di installare Kali in modo rapido e semplice su più macchine contemporaneamente.

Innanzitutto, è necessario avviare la macchina di destinazione dalla rete. Questa operazione è facilitata dal Pre-boot eXecution Environment (PXE), un'interfaccia client/server progettata per avviare qualsiasi macchina connessa alla rete, anche se non dispone di un sistema operativo installato. La configurazione dell'avvio di rete PXE richiede la configurazione di almeno un server TFTP (Trivial File Transfer Protocol) e un server DHCP/BOOTP. Sarà inoltre necessario un server web se si desidera ospitare un file di preconfigurazione *debconf* che verrà utilizzato automaticamente durante il processo di installazione.

Fortunatamente, *dnsmasq* gestisce sia DHCP che TFTP, quindi puoi affidarti a un unico servizio per configurare tutto ciò di cui hai bisogno. Inoltre, il server web Apache è installato (ma non abilitato) di default sui sistemi Kali.

| | |
|---|---|
| **Servizi DHCP e TFTP separati** | Per configurazioni più complesse, le funzionalità di dnsmasq potrebbero risultare troppo limitate, oppure potresti voler abilitare l'avvio PXE sulla tua rete principale che già esegue un servizio DHCP. In entrambi i casi, sarà quindi necessario configurare servizi DHCP e TFTP separati.<br><br>Il manuale di installazione di Debian descrive la configurazione di isc-dhcp-server e tftpd-hpa per l'avvio PXE.<br><br>ÿ https://www.debian.org/releases/stable/amd64/ch04s05 |

Machine Translated by Google

Per configurare *dnsmasq,* è necessario innanzitutto configurarlo tramite il file /etc/dnsmasq.conf. Una configurazione di base consiste in poche righe chiave:

```
# Interfaccia di rete da gestire interface=eth0 #
Opzioni DHCP #
Intervallo IP da allocare
dhcp-
range=192.168.101.100,192.168.101.200,12h # Gateway da annunciare ai
client dhcp-option=option:router,192.168.101.1 #
Server DNS da annunciare ai client

dhcp-option=option:dns-server,8.8.8.8,8.8.4.4 # File di avvio da annunciare
ai client
dhcp-boot=pxelinux.0 # Opzioni
TFTP enable-tftp #
Directory che
ospita i file da servire tftp-root=/tftpboot/
```

Una volta configurato il file /etc/dnsmasq.conf , sarà necessario posizionare i file di avvio dell'installazione nella directory /tftpboot/ . Kali Linux fornisce un archivio di file dedicato a questo scopo, che può essere estratto direttamente in /tftpboot/. È sufficiente selezionare la versione a 32 bit (i386) o a 64 bit (amd64) e il metodo di installazione standard o grafico (gtk) per la propria macchina di destinazione e scegliere l'archivio appropriato:

ÿ http://http.kali.org/dists/kali-rolling/main/installer-amd64/current/images/ netboot/gtk/netboot.tar.gz

ÿ http://http.kali.org/dists/kali-rolling/main/installer-amd64/current/images/ netboot/netboot.tar.gz

ÿ http://http.kali.org/dists/kali-rolling/main/installer-i386/current/images/ netboot/gtk/netboot.tar.gz

ÿ http://http.kali.org/dists/kali-rolling/main/installer-i386/current/images/ netboot/netboot.tar.gz

Una volta selezionato l'archivio, crea la directory /tftpboot/, scarica l'archivio ed estrailo al suo interno:

```
# mkdir /tftpboot # cd /
tftpboot # wget http://
http.kali.org/dists/kali-rolling/main/installer-amd64/current/images/
        ÿ netboot/netboot.tar.gz # tar xf
netboot.tar.gz # ls -l totale 25896
drwxrwxr-x
3 root root
                                        4096 6 maggio 04:43 debian-installer
```

Machine Translated by Google

```
lrwxrwxrwx 1 radice radice 47 6 maggio 04:43 ldlinux.c32 -> debian-installer/amd64/boot
    ÿ -screens/ldlinux.c32
-rw-r--r-- 1 root root 26507247 6 maggio 04:43 netboot.tar.gz
lrwxrwxrwx 1 root root 33 6 maggio 04:43 pxelinux.0 -> debian-installer/amd64/
    ÿ pxelinux.0
lrwxrwxrwx 1 radice radice 35 maggio 6 04:43 pxelinux.cfg -> debian-installer/amd64/
    ÿ pxelinux.cfg
-rw-rw-r-- 1 radice radice 71 Maggio 6 04:43 version.info
```

I file decompressi includono il bootloader *pxelinux ,* che utilizza gli stessi file di configurazione di *syslinux* e *isolinux.* Per questo motivo, è possibile modificare i file di avvio in debian-installer/amd64/boot-screens/ come faresti quando generi immagini ISO live personalizzate di Kali Linux.

Ad esempio, supponendo che tu abbia scelto il programma di installazione testuale, puoi aggiungere parametri di avvio per preimpostare i valori di lingua, paese, mappatura della tastiera, nome host e nome di dominio. Puoi anche puntare il programma di installazione a un URL preseed esterno e configurare il timeout in modo che l'avvio avvenga automaticamente se non viene premuto alcun tasto entro 5 secondi. Per fare ciò, dovresti prima modificare il file debian-installer/amd64/txt.cfg :

```
installazione dell'etichetta
        Etichetta del menu ^Installa
        kernel debian-installer/amd64/linux
        append vga=788 initrd=debian-installer/amd64/initrd.gz --- quiet language=en
            ÿ country=US keymap=us hostname=kali domain= url=http://192.168.101.1/
            ÿ preseed.cfg
```

Successivamente, dovresti modificare il file debian-installer/amd64/syslinux.cfg per regolare il timeout:

```
# Versione di configurazione DI 2.0
# Cerca il percorso per le librerie di supporto c32 (libcom32, libutil ecc.)
percorso debian-installer/amd64/boot-screens/
includi debian-installer/amd64/boot-screens/menu.cfg
default debian-installer/amd64/boot-screens/vesamenu.c32
prompt 0
timeout 50
```

Grazie alla possibilità di avviare qualsiasi macchina dalla rete tramite PXE, è possibile sfruttare tutte le funzionalità descritte nella sezione 4.3, "Installazioni automatiche" [pagina 95], che consentono di eseguire l'avvio completo, il pre-avvio e l'installazione automatica su più computer senza supporti di avvio fisici. Inoltre, non dimenticate la flessibilità del parametro di avvio pre- seed/url=http://server/preseed.cfg (né l'utilizzo dell'alias URL ), che consente di impostare un file di pre-avvio basato sulla rete.

Machine Translated by Google

## 10.2. Sfruttare la gestione della configurazione

Grazie alla possibilità di installare Kali su più computer in modo molto rapido, avrai bisogno di aiuto per gestire queste macchine dopo l'installazione. Puoi utilizzare strumenti di gestione della configurazione per amministrare le macchine o configurare i computer sostitutivi secondo le tue esigenze.

Kali Linux include molti strumenti di gestione della configurazione molto diffusi *(Ansible, Chef, Puppet, SaltStack,* ecc.), ma in questa sezione tratteremo solo *SaltStack.*

ÿ https://www.saltstack.com/

### 10.2.1. Configurazione di SaltStack

SaltStack è un servizio centralizzato di gestione della configurazione: un *Salt Master* gestisce molti *Salt Minion.* È necessario installare il pacchetto *salt-master* su un server raggiungibile da tutti gli host che si desidera gestire e *salt-minion* sugli host che si desidera gestire. A ciascun minion deve essere indicato dove trovare il proprio master. È sufficiente modificare il file /etc/salt/minion e impostare la chiave master con il nome DNS (o l'indirizzo IP) del Salt Master. Si noti che Salt utilizza il formato YAML per i suoi file di configurazione.

```
minion# vim /etc/salt/minion minion# grep
^master /etc/salt/minion master: 192.168.122.105
```

Ogni minion ha un identificatore univoco memorizzato in /etc/salt/minion_id, che per impostazione predefinita corrisponde al suo nome host. Questo identificatore del minion verrà utilizzato nelle regole di configurazione e, pertanto, è importante impostarlo correttamente prima che il minion apra la connessione al master:

```
minion# echo kali-scratch >/etc/salt/minion_id minion#
systemctl enable salt-minion minion#
systemctl start salt-minion
```

Quando il servizio *salt-minion* è in esecuzione, tenterà di connettersi al Salt master per scambiare alcune chiavi crittografiche. Lato master, è necessario accettare la chiave utilizzata dal minion per identificarsi, in modo da consentire la connessione. Le connessioni successive saranno automatiche.

```
master# systemctl enable salt-master master#
systemctl start salt-master master# salt-
key --list all
Tasti accettati:
Tasti rifiutati:
Tasti non accettati:
kali-scratch
Chiavi rifiutate:
master# salt-key --accept kali-scratch
Saranno accettate le seguenti chiavi:
```

Machine Translated by Google

```
Tasti non accettati: kali-
scratch Procedere?
[n/Y] y Tasto per il minion
kali-scratch accettato.
```

## 10.2.2. Esecuzione di comandi sui Minion

Non appena i minion si connettono, è possibile eseguire comandi su di essi dal master:

```
master# salt '*' test.ping kali-scratch: True
kali-master: True
```

Questo comando richiede a tutti i minion (l' asterisco (*) è un carattere jolly che si rivolge a tutti i minion) di eseguire la funzione ping dal modulo di esecuzione dei test . Questa funzione restituisce un valore True in caso di successo ed è un modo semplice per verificare che la connessione tra il master e i vari minion funzioni correttamente.

È anche possibile indirizzare un minion specifico fornendo il suo identificatore nel primo parametro, oppure eventualmente un sottoinsieme di minion utilizzando un carattere jolly meno generico (come '*-scratch' o 'kali-*'). Ecco un esempio di come eseguire un comando shell arbitrario sul minion kali-scratch: master# **salt kali-scratch cmd.shell 'uptime; uname -a'** kali-scratch:

```
05:25:48 up 44 min, 2 utenti, carico medio: 0.00, 0.01, 0.05 Linux kali-scratch 4.5.0-kali1-amd64 #1
SMP Debian 4.5.3-2kali1 (2020-05-09) x86_64
ÿ GNU/Linux
```

**Riferimento ai moduli Salt** Sono disponibili numerosi moduli di esecuzione per svariati casi d'uso. Non li tratteremo tutti in questa sede, ma l'elenco completo è disponibile all'indirizzo https://docs.saltproject.io/en/latest/ref/modules/all/index.html . È inoltre possibile ottenere una descrizione di tutti i moduli di esecuzione e delle relative funzioni disponibili su un determinato minion tramite il comando `salt minion sys.doc` . L'esecuzione di questo comando restituisce un elenco molto lungo di funzioni, ma è possibile filtrarlo passando come parametro il nome di una funzione o di un modulo preceduto dal suo modulo padre:

```
master# salt kali-scratch sys.doc disk.usage disk.usage:

    Restituisci le informazioni sull'utilizzo per i volumi montati su questo ÿ minion
```

Uno dei moduli più utili è pkg, che è un'astrazione del gestore di pacchetti che si basa sul gestore di pacchetti appropriato per il sistema (apt-get per Debian e i suoi derivati come Kali).

Machine Translated by Google

Il comando pkg.refresh_db aggiorna l'elenco dei pacchetti (ovvero, esegue apt-get update), mentre pkg.upgrade installa tutti gli aggiornamenti disponibili (esegue apt-get upgrade o apt-get dist-upgrade, a seconda delle opzioni ricevute). Il comando pkg.list_upgrades elenca le operazioni di aggiornamento in sospeso (che verrebbero eseguite dal comando pkg.upgrade dist_upgrade=True ).

Il modulo di servizio è un'astrazione del gestore dei servizi (systemd nel caso di Kali), che consente di eseguire tutte le normali operazioni di systemctl : service.enable, service.disable, service.start, service.stop, service.restart e service.reload:

```
master# salt '*' service.enable ssh kali-scratch: True
kali-master: True



master# salt '*' service.start ssh
kali-master:
    VERO
kali-scratch:
    VERO
master# salt '*' pkg.refresh_db kali-scratch:

    ----------
kali-master:
    ----------
master# salt '*' pkg.upgrade dist_upgrade=True kali-scratch:

    ----------
    modifiche:
        ----------
        file base:
            ----------
            nuovo:
                1:2020.2.1
            vecchio:
                1:2020.2.0
[...]
        zaproxy:
            ----------
            nuovo:
                2.5.0-0kali1
            vecchio:
                2.4.3-0kali3
    commento:
    risultato:
        VERO
```

Machine Translated by Google

Come esempio più concreto, potresti facilmente configurare una scansione *Nmap* distribuita con *dnmap.* Dopo aver installato il pacchetto su tutti i minion, avvia il server in un primo terminale:

```
server# salt '*' pkg.install dnmap [...] server# vim

dnmap.txt server# dnmap_server
-f dnmap.txt
```

Ipotizzando che l'indirizzo IP del server sia 1.2.3.4, è possibile quindi indicare a tutti i minion di avviare un processo client che si connetta al server:

```
server# salt '*' cmd.run_bg template=jinja 'dnmap_client -s 1.2.3.4 -a {{ grains.id }}' kali-scratch:

    ----------
    pid:
        17137
[...]
```

Si noti che l'esempio utilizza cmd.run_bg per eseguire il comando dnmap_client in background.
Non aspettare che termini, poiché si tratta di un processo di lunga durata. Sfortunatamente, non si interrompe correttamente quando si interrompe il server, quindi potrebbe essere necessario ripulirlo manualmente.

```
server# salt '*' cmd.shell 'pkill -f dnmap_client'
```

### 10.2.3. Stati del sale e altre caratteristiche

Sebbene l'esecuzione remota sia un elemento fondamentale, rappresenta solo una minima parte delle potenzialità di SaltStack.

Quando si configura una nuova macchina, spesso si eseguono numerosi comandi e test per determinare i dettagli del sistema prima dell'installazione. Queste operazioni possono essere formalizzate in modelli di configurazione riutilizzabili chiamati *file di stato.* Le operazioni descritte nei file di stato possono quindi essere eseguite con un singolo comando salt state.apply .

Per risparmiare tempo, puoi fare affidamento su numerosi file di stato preconfigurati creati dalla community e distribuiti in "Salt formulas":

ÿ https://docs.saltproject.io/en/latest/topics/development/conventions/formule.html

Esistono molte altre caratteristiche che possono essere combinate:

- Esecuzione programmata delle azioni
- Definire le azioni in risposta agli eventi attivati dai minion • Raccogliere dati dai minion

Machine Translated by Google

• Orchestrazione di una sequenza di operazioni su più minion • Applicazione di stati tramite SSH senza installare il servizio salt-minion • Provisioning di sistemi su infrastrutture cloud e loro gestione

• E altro ancora

SaltStack è un sistema piuttosto vasto e non possiamo certo trattarne tutte le funzionalità in questa sede. Esistono infatti libri interamente dedicati a SaltStack e la documentazione online è altrettanto esaustiva. Consultatela se desiderate approfondire le sue caratteristiche:

ÿ https://docs.saltproject.io/en/latest/

Se gestisci un numero significativo di macchine, ti consigliamo vivamente di approfondire la conoscenza di SaltStack, in quanto ti permetterà di risparmiare molto tempo nella distribuzione di nuove macchine e di mantenere una configurazione coerente in tutta la rete.

Per darvi un'idea di come funziona la gestione dei file di stato, vedremo un semplice esempio: come abilitare il repository APT e installare un pacchetto creato nelle sezioni 10.3.3, "Creazione di un repository di pacchetti per APT" [pagina 275] e 10.3.2, "Creazione di pacchetti di configurazione" [pagina 269]. Dovrete inoltre registrare una chiave SSH nell'account root per poter accedere da remoto in caso di problemi.

Per impostazione predefinita, i file di stato vengono memorizzati in /srv/salt sul master; si tratta di file strutturati in YAML con estensione .sls . Proprio come per l'esecuzione dei comandi, l'applicazione di uno stato si basa su diversi moduli di stato:

ÿ https://docs.saltproject.io/en/latest/topics/tutorials/starting_states.html

ÿ https://docs.saltproject.io/en/latest/ref/states/all/

Il tuo file /srv/salt/offsec.sls richiamerà tre di questi moduli:

```
offsec_repository:
    pkgrepo.managed: - name:
        deb http://pkgrepo.offsec.com offsec-internal main - file: /etc/apt/sources.list.d/offsec.list - key_url:
        salt://offsec-apt-key.asc - require_in: - pkg: offsec-defaults




offsec-defaults: pkg.installed



ssh_key_for_root:
    ssh_auth.present: - utente:
        root
        - nome: ssh-rsa AAAAB3NzaC1yc2...89C4N rhertzog@kali
```

Lo stato offsec_repository si basa sul modulo di stato pkgrepo . L'esempio utilizza la funzione gestita in quel modulo di stato per registrare un repository di pacchetti. Con l' attributo key_url ,

Machine Translated by Google

comunica a Salt che la chiave GPG (in formato ASCII) necessaria per verificare la firma del repository può essere recuperata da /srv/salt/offsec-apt-key.asc sul master di Salt. L' attributo require_in garantisce che questo stato venga elaborato prima di offsec-defaults, poiché quest'ultimo necessita che il repository sia configurato correttamente per poter installare il pacchetto.

Lo stato offsec-defaults installa il pacchetto omonimo. Ciò dimostra che il nome della chiave è spesso un valore importante per gli stati, sebbene possa sempre essere sovrascritto con un nome come attributo (come fatto per lo stato precedente). Per casi semplici come questo, ciò è sia leggibile che
conciso.

L'ultimo stato (ssh_key_for_root) aggiunge la chiave SSH specificata nell'attributo name al file /root/.ssh/authorized_keys (l'utente di destinazione è impostato nell'attributo user ). Si noti che qui abbiamo abbreviato la chiave per una migliore leggibilità, ma è necessario inserire la chiave completa nell'attributo name.

Questo file di stato può quindi essere applicato a un determinato minion:

```
server# salt kali-scratch state.apply offsec kali-scratch:

----------

          ID: offsec_repository Funzione:
    pkgrepo.managed Nome: deb http://
          pkgrepo.offsec.com offsec-internal main Risultato: True


      Commento: Repository di pacchetti configurato 'deb http://pkgrepo.offsec.com offsec-internal'
          ÿ main'
      Avviato: 06:00:15.767794
    Durata: 4707,35 ms Modifiche:

                    ----------

                    repository:
                        deb http://pkgrepo.offsec.com offsec-internal main
----------
          ID: offsec-defaults
    Funzione: pacchetto installato
        Risultato: Vero
      Commento: I seguenti pacchetti sono stati installati/aggiornati: offsec-defaults Avviato: 06:00:21.325184

    Durata: 19246,041 ms
      Modifiche:
                    ----------
                    offsec-defaults:
                        ----------
                        nuovo:
                            1.0
                        vecchio:
----------
          ID: ssh_key_for_root Funzione:
    ssh_auth.present
```

Machine Translated by Google

```
            Nome: ssh-rsa AAAAB3NzaC1yc2...89C4N rhertzog@kali
          Risultato: Vero
        Commento: La chiave host autorizzata AAAAB3NzaC1yc2...89C4N per l'utente root è stata aggiunta. Avviato: 06:00:40.582539

      Durata: 62,103 ms
        Modifiche:
                    ----------
                    AAAAB3NzaC1yc2...89C4N: Nuovo


Riepilogo per kali-scratch
------------
Riuscito: 3 (modificato=3)
Fallito: 0
------------
Numero totale di stati                3
eseguiti: Tempo totale di esecuzione: 24,015 s
```

Può anche essere associato in modo permanente al minion registrandolo nel file /srv/salt/top.sls , che viene utilizzato dal comando state.highstate per applicare tutti gli stati rilevanti in un'unica passata:

```
server# cat /srv/salt/top.sls base: kali-scratch:
- offsec
    server# salt kali-
      scratch
state.highstate kali-scratch:

----------
                ID: offsec_repository Funzione:
      pkgrepo.managed Nome: deb http://
            pkgrepo.offsec.com offsec-internal main
          Risultato: Vero
        Commento: Il repository del pacchetto 'deb http://pkgrepo.offsec.com offsec-internal main' è già presente
            ÿ configurato Avviato:
        06:06:20.650053
      Durata: 62,805 ms
        Modifiche:
----------
                ID: offsec-defaults
      Funzione: pkg.installed Risultato:
          True Commento: Il
        pacchetto offsec-defaults è già installato Avviato: 06:06:21.436193

      Durata: 385,092 ms Modifiche:

----------
                ID: ssh_key_for_root
```

Machine Translated by Google

```
        Funzione: ssh_auth.present
              Nome: ssh-rsa AAAAB3NzaC1yc2...89C4N rhertzog@kali
         Risultato: Vero
          Commento: La chiave host autorizzata AAAAB3NzaC1yc2...89C4N è già presente per
                    ÿ utente root
            Inizio: 06:06:21.821811
          Durata: 1,936 ms
           Modifiche:

Riepilogo per kali-scratch
------------
Riusciti: 3
Fallito:            0
------------
Numero totale di stati                  3
eseguiti: Tempo totale di esecuzione: 449,833 ms
```

## 10.3. Estensione e personalizzazione di Kali Linux

A volte è necessario modificare Kali Linux per adattarlo alle proprie esigenze locali. Il modo migliore per farlo è mantenere un proprio repository di pacchetti che ospiti le versioni modificate dei pacchetti Kali che è stato necessario clonare, nonché pacchetti supplementari che forniscano configurazioni personalizzate e software aggiuntivo (non fornito da Kali Linux).

### 10.3.1. Creazione di fork dei pacchetti Kali

Per ulteriori spiegazioni su questo argomento, si prega di fare riferimento alla sezione 9.1, "Modifica dei pacchetti Kali" [pagina 228].

È possibile effettuare un fork di qualsiasi pacchetto se si ha una buona ragione, ma bisogna essere consapevoli che questa operazione ha un costo, poiché è necessario aggiornarla ogni volta che Kali pubblica un aggiornamento. Ecco alcuni motivi per cui si potrebbe voler effettuare un fork di un pacchetto:

- Per aggiungere una patch per correggere un bug o aggiungere una nuova funzionalità. Tuttavia, nella maggior parte dei casi, è consigliabile inviare la patch agli sviluppatori originali in modo che il bug venga corretto o la funzionalità aggiunta direttamente alla fonte.
- Per compilarlo con opzioni diverse (supponendo che ci siano buone ragioni per cui Kali non l'abbia compilato con quelle opzioni; altrimenti potrebbe essere meglio discuterne con gli sviluppatori di Kali[1]) per verificare se è possibile abilitare le opzioni desiderate).

Al contrario, ecco alcuni motivi sbagliati per effettuare un fork di un pacchetto, insieme a suggerimenti su come risolvere il problema:

[1] https://bugs.kali.org/

Machine Translated by Google

- Per modificare un file di configurazione. Hai a disposizione diverse opzioni migliori, come utilizzare la gestione della configurazione per installare automaticamente un file di configurazione modificato oppure installare un pacchetto di configurazione che inserirà un file in una directory di configurazione (se disponibile) o che sovrascriverà il file di configurazione originale.
- Per aggiornare a una versione upstream più recente. Anche in questo caso, è preferibile collaborare con gli sviluppatori per aggiornare il pacchetto direttamente in Debian o Kali. Con il modello di rilascio continuo (rolling release), gli aggiornamenti raggiungono gli utenti finali piuttosto rapidamente.

Tra tutti i pacchetti disponibili, ce ne sono alcuni che costituiscono i componenti fondamentali di Kali Linux e che potrebbero essere interessanti da duplicare in determinate situazioni:

- *kali-meta:* questo pacchetto sorgente compila tutti i meta-pacchetti kali-linux-* e kali-tools-* e in particolare *kali-linux-default,* che definisce quali pacchetti vengono installati nell'immagine ISO predefinita di Kali Linux.

- *desktop-base:* questo pacchetto sorgente contiene vari file di vario tipo utilizzati di default nelle installazioni desktop. Valuta la possibilità di creare un fork di questo pacchetto se desideri visualizzare il marchio della tua organizzazione nello sfondo predefinito o cambiare il tema del desktop. • *kali-menu:* questo pacchetto definisce la struttura

del menu di Kali e fornisce i file .desktop per tutte le applicazioni che devono essere elencate nel menu di Kali.

### 10.3.2. Creazione di pacchetti di configurazione

Ora che abbiamo accennato all'avvio PXE e discusso la gestione della configurazione con Salt-Stack, nonché il fork dei pacchetti, è il momento di riassumere questi processi in un esempio pratico ed estendere lo scenario creando un pacchetto di configurazione personalizzato per distribuire una configurazione personalizzata a più macchine in modo semiautomatico.

In questo esempio, creerai un pacchetto personalizzato che configura e utilizza il tuo repository di pacchetti e la tua chiave di firma GnuPG, distribuisce una configurazione SaltStack, applica uno sfondo personalizzato e fornisce impostazioni desktop predefinite in modo unificato a tutte le tue installazioni di Kali.

Questo potrebbe sembrare un compito scoraggiante (soprattutto se dai un'occhiata alla Guida per i nuovi manutentori di Debian2) ) ma fortunatamente per noi, un pacchetto di configurazione è principalmente un archivio di file sofisticato e trasformarlo in un pacchetto è piuttosto semplice.

| | |
|---|---|
| **Esaminando un campione Pacchetto** | Se vuoi esaminare un pacchetto reale che sia essenzialmente un pacchetto di configurazione, considera il pacchetto kali-defaults . Non è semplice come l'esempio in questa sezione, ma possiede tutte le caratteristiche rilevanti e utilizza persino alcune tecniche avanzate (come dpkg-divert) per sostituire i file già forniti da altri pacchetti. |

Il pacchetto *offsec-defaults* conterrà alcuni file:

[2] https://www.debian.org/doc/manuals/maint-guide/

Machine Translated by Google

- /etc/apt/sources.list.d/offsec.list: una voce sources.list per APT, che abilita repository interno di pacchetti dell'azienda
- /etc/apt/trusted.gpg.d/offsec.gpg: la chiave GnuPG utilizzata per firmare il repository interno dei pacchetti dell'azienda
- /etc/salt/minion.d/offsec.conf: un file di configurazione di SaltStack per indicare dove trovare il maestro del sale
- /usr/share/images/offsec/background.png: una bella immagine di sfondo con il logo di Offen-sive Security
- /usr/share/glib-2.0/schemas/90_offsec-defaults.gschema.override: un file che fornisce impostazioni predefinite alternative per l'ambiente desktop GNOME

Innanzitutto, crea una directory offsec-defaults-1.0 e inserisci tutti i file in quella directory. Quindi esegui dh_make --native (dal pacchetto *dh-make )* per aggiungere le istruzioni di packaging Debian, che essere memorizzato in una sottocartella debian :

```
$ mkdir offsec-defaults-1.0; cd offsec-defaults-1.0
$ dh_make --native
Tipo di pacchetto: (singolo, indipendente, libreria, python)
 [s/i/l/p]? i
Nome del pacchetto          :buxy'
di licenza                  : gpl3
dell'indirizzo e-mail       : offsec-defaults
Nome del manutentore        : Raphaël Hertzog
Versione                    : 1.0
Tipo di confezione          : indipendente
Data                        : Gio 16 giugno 2020 18:04:21 +0200
I dettagli sono corretti? [S/n/q] s
Attualmente non è presente un Makefile di livello superiore. Ciò potrebbe richiedere ulteriori modifiche.
Fatto. Ora modificate i file nella sottocartella debian/.
```

Innanzitutto, ti viene richiesto di selezionare un tipo di pacchetto. Nell'esempio, abbiamo selezionato *indep,* che indica che questo pacchetto sorgente genererà un singolo pacchetto binario che può essere condiviso tra tutte le architetture (Architettura: tutte). *single* agisce come controparte e produce un singolo pacchetto binario che dipende dall'architettura di destinazione (Architettura: qualsiasi). In questo caso, *indep* è più rilevante, poiché il pacchetto contiene solo file di testo e nessun programma binario, in modo che possa essere utilizzato in modo simile sui computer di tutte le architetture. Il tipo *di libreria* è utile per le librerie condivise, poiché devono seguire regole di packaging rigorose. Allo stesso modo, *Python* dovrebbe essere limitato ai moduli Python.

**Nome del manutentore e Indirizzo e-mail**

La maggior parte dei programmi coinvolti nella manutenzione dei pacchetti cercherà il tuo nome e Indirizzo email nelle variabili d'ambiente DEBFULLNAME e DEBEMAIL o EMAIL .

Definirli una volta per tutte evita di riscriverli più volte. Se il tuo solito La shell è Bash, è sufficiente aggiungere le seguenti due righe al file ~/.bashrc. file. Ad esempio:

Machine Translated by Google

```
export EMAIL=”buxy@kali.org” export
DEBFULLNAME=”Raphael Hertzog”
```

Il comando dh_make ha creato una sottocartella debian contenente molti file. Alcuni sono necessari, in particolare rules, control, changelog e copyright. I file con estensione .ex sono file di esempio che possono essere utilizzati modificandoli e rimuovendo l'estensione. Quando non sono necessari, si consiglia di eliminarli. Il file compat deve essere conservato, poiché è necessario per il corretto funzionamento della suite di programmi *debhelper* (tutti con prefisso dh_ ) utilizzata nelle varie fasi del processo di compilazione del pacchetto.

Il file di copyright deve contenere informazioni sugli autori dei documenti inclusi nel pacchetto e la relativa licenza. Se la licenza predefinita selezionata da dh_make non è di vostro gradimento, è necessario modificare questo file. Ecco la versione modificata del file di copyright:

```
Formato: https://www.debian.org/doc/packaging-manuals/copyright-format/1.0/ Nome upstream: offsec-
defaults

File: *
Copyright: 2020 Offensive Security Licenza: GPL-3.0+


Licenza: GPL-3.0+
 Questo programma è un software libero: è possibile ridistribuirlo e/o modificarlo secondo i termini
 della GNU General Public License, pubblicata dalla Free Software Foundation, nella versione 3
 della Licenza o (a propria discrezione) in qualsiasi versione successiva.

 .
 Questo pacchetto viene distribuito nella speranza che sia utile, ma SENZA ALCUNA GARANZIA; senza nemmeno la
 garanzia implicita di COMMERCIABILITÀ o IDONEITÀ PER UNO SCOPO PARTICOLARE. Vedi il

 Per maggiori dettagli, consultare la Licenza Pubblica Generale GNU.
 .
 Dovresti aver ricevuto una copia della Licenza Pubblica Generale GNU insieme a questo
 programma. In caso contrario, consulta <https://www.gnu.org/licenses/>.
 .
 Sui sistemi Debian, il testo completo della GNU General Public License versione
 3 si trova in "/usr/share/common-licenses/GPL-3".
```

Il file di registro delle modifiche predefinito è generalmente appropriato; sostituire la dicitura "Versione iniziale" con una spiegazione più dettagliata dovrebbe essere sufficiente:

```
offsec-defaults (1.0) instabile; urgenza=media

  * Aggiungi il file di configurazione del minion di Salt.
  * Aggiungi la voce sources.list di un APT e la chiave GPG attendibile di un APT.
```

Machine Translated by Google

```
  * Sovrascrivi lo schema gsettings che definisce l'immagine di sfondo.

 -- Raphaël Hertzog <buxy@kali.org> Gio, 16 giugno 2020 18:04:21 +0200
```

Nell'esempio, apporteremo delle modifiche al file di controllo . Modificheremo il campo Sezione in *"varie"* e rimuoveremo i campi Homepage, Vcs-Git e Vcs-Browser . Infine, compileremo il campo Descrizione :

```
Fonte: offsec-defaults
Sezione: varie
Priorità: opzionale
Manutentore: Raphaël Hertzog <buxy@kali.org>
Dipendenze di compilazione: debhelper (>= 9)
Standard - Versione: 3.9.8

Pacchetto: offsec-defaults
Architettura: tutta
Dipende: ${misc:Depends}
Descrizione: Impostazioni predefinite per Offensive Security. Questo
 pacchetto contiene diversi file per configurare i computer di proprietà di Offensive
 Security.
 .
 In particolare, modifica:
   - Configurazione di APT -
   Configurazione di salt-minion -
   Impostazioni desktop predefinite
```

Il file delle regole di solito contiene un insieme di regole utilizzate per configurare, compilare e installare il software in una sottocartella dedicata (il cui nome corrisponde al pacchetto binario generato). Il contenuto di questa sottocartella viene quindi archiviato all'interno del pacchetto Debian come se fosse la directory principale del filesystem. In questo caso, i file verranno installati nella sottocartella debian/offsec-defaults/ . Ad esempio, per ottenere un pacchetto che installa /etc/apt/sources.list.d/offsec.list, installare il file in debian/offsec-defaults/etc/apt/sources.list.d/offsec.list. Il file delle regole viene utilizzato come Makefile, con alcuni target standard (tra cui clean e binary, utilizzati rispettivamente per pulire la directory sorgente e generare il pacchetto binario).

**Cos'è un file Makefile ?** Potresti aver notato il messaggio relativo al Makefile mancante alla fine dell'output di dh_make e il riferimento alla sua somiglianza con il file delle regole . Un Makefile è un file di script utilizzato dal programma make ; descrive le regole per la compilazione di un insieme di file a partire da un insieme di dipendenze. Ad esempio, un programma può essere compilato a partire da un insieme di file sorgente. Il file Makefile descrive queste regole nel seguente formato:

```
destinazione: fonte1 fonte2 ...
        comando1
        comando2
```

Machine Translated by Google

```
                                                    file                    file
```

Sebbene questo file sia il cuore del processo, contiene solo il minimo indispensabile per eseguire una serie standard di comandi forniti dallo strumento debhelper . Questo è il caso dei file generati da dh_make. Per installare la maggior parte dei file, consigliamo di configurare il comportamento del comando dh_install creando il seguente file debian/offsec-defaults.install :

```
apt/offsec.list etc/apt/sources.list.d/ apt/offsec.gpg etc/apt/
trusted.gpg.d/ salt/offsec.conf etc/salt/minion.d/ images/
background.png usr/share/images/offsec/
```

Potresti anche usare questo metodo per installare il file di override di gsettings, ma debhelper fornisce uno strumento dedicato per questo (dh_installgsettings) , quindi puoi fare affidamento su quello. Per prima cosa, inserisci le tue impostazioni in debian/offsec-defaults.gsettings-override:

```
[org.gnome.desktop.background] picture-
options='zoom' picture-uri='file:///
usr/share/images/offsec/background.png'
```

Successivamente, sovrascrivi la chiamata dh_installgsettings in debian/rules per aumentare la priorità al livello previsto per una sovrascrittura a livello di organizzazione (che è 90 secondo la pagina del manuale):

```
#!/usr/bin/make -f

%:
        dh $@

override_dh_installgsettings:
        dh_installgsettings --priority=90
```

A questo punto, il pacchetto sorgente è pronto. Non resta che generare il pacchetto binario con lo stesso metodo utilizzato in precedenza per la ricompilazione dei pacchetti: eseguire il comando dpkg-buildpackage -us -uc dalla directory offsec-defaults-1.0 :

```
$ dpkg-buildpackage -us -uc dpkg-
buildpackage: info: pacchetto sorgente offsec-defaults dpkg-buildpackage: info:
versione sorgente 1.0 dpkg-buildpackage: info: distribuzione
sorgente instabile dpkg-buildpackage: info: sorgente modificata da Raphaël
Hertzog <buxy@kali.org> dpkg-buildpackage: info: architettura host amd64
```

Machine Translated by Google

```
  dpkg-source --before-build offsec-defaults-1.0 fakeroot debian/rules
  clean
dh clean
       dh_testdir
       dh_auto_clean
       dh_clean
  dpkg-source -b offsec-defaults-1.0 dpkg-source:
info: utilizzo del formato sorgente '3.0 (nativo)' dpkg-source: info: compilazione
di offsec-defaults in offsec-defaults_1.0.tar.xz dpkg-source: info: compilazione di offsec-defaults in offsec-
defaults_1.0.dsc
  build debian/rules
costruzione dh
       dh_testdir
       dh_update_autotools_config
       dh_auto_configure
       dh_auto_build
       dh_auto_test
  fakeroot binario debian/rules
dh binario
       dh_testroot
       dh_prep
       dh_auto_install
       dh_install
       dh_installdocs
       dh_installchangelogs debian/
       rules override_dh_installgsettings
make[1]: Ingresso nella directory '/home/kali/offsec-defaults-1.0' dh_installgsettings --
priority=90 make[1]: Uscita dalla directory '/home/
kali/offsec-defaults-1.0'
       dh_perl
       dh_link
       dh_strip_nondeterminism
       dh_compress
       dh_fixperms
       dh_installdeb
       dh_gencontrol
       dh_md5sums
       dh_builddeb
dpkg-deb: creazione del pacchetto 'offsec-defaults' in '../offsec-defaults_1.0_all.deb'. dpkg-genchanges >../offsec-
  defaults_1.0_amd64.changes dpkg-genchanges: info: inclusione del codice
sorgente completo nel caricamento
  dpkg-source --after-build offsec-defaults-1.0
dpkg-buildpackage: info: caricamento completo; pacchetto nativo Debian (il codice sorgente completo è incluso)
```

Machine Translated by Google

### 10.3.3. Creazione di un repository di pacchetti per APT

Ora che hai un pacchetto personalizzato, puoi distribuirlo tramite un repository di pacchetti APT.
Utilizza Reprepro per creare il repository desiderato e per popolarlo. Questo strumento è piuttosto potente e la sua pagina di manuale merita sicuramente di essere letta.

Un repository di pacchetti è in genere ospitato su un server. Per separarlo correttamente dagli altri servizi in esecuzione sul server, è consigliabile creare un utente dedicato a questo servizio. Nell'account utente dedicato, sarà possibile ospitare i file del repository e anche la chiave GnuPG che verrà utilizzata per firmare il repository dei pacchetti:

```
# apt install reprepro gnupg [...] # adduser
 --
system --group pkgrepo Aggiunta dell'utente di sistema
'pkgrepo' (UID 136) ...
Aggiunta del nuovo gruppo 'pkgrepo' (GID 142) ...
Aggiunta del nuovo utente 'pkgrepo' (UID 136) con gruppo 'pkgrepo' ...
Creazione della directory home '/home/pkgrepo' ... # chown pkgrepo
$(tty) # su - -s /bin/bash pkgrepo
pkgrepo@kali:~$ gpg --gen-key gpg
(GnuPG) 2.1.11; Copyright (C) 2020 Free
Software Foundation, Inc.
Questo è un software libero: siete liberi di modificarlo e ridistribuirlo.
NON VIENE FORNITA ALCUNA GARANZIA, nei limiti consentiti dalla legge.

gpg: directory '/home/pkgrepo/.gnupg' creata gpg: nuovo file di
configurazione '/home/pkgrepo/.gnupg/dirmngr.conf' creato gpg: nuovo file di configurazione '/home/pkgrepo/.gnupg/
gpg.conf' creato gpg: keybox '/home/pkgrepo/.gnupg/pubring.kbx' creato Nota: utilizzare "gpg --full-gen-key"
per una finestra di dialogo completa per la generazione della chiave.



GnuPG necessita di creare un ID utente per identificare la tua chiave.

Nome reale: Chiave di firma del repository di sicurezza offensiva Indirizzo e-mail:
repoadmin@offsec.com Hai selezionato questo ID
utente:
        "Chiave di firma del repository di sicurezza Offensive <repoadmin@offsec.com>"

Cambiare (N)ame, (E)mail o (O)kay/(Q)ui? o Dobbiamo generare molti
byte casuali. È una buona idea eseguire qualche altra azione (digitare sulla tastiera, muovere il mouse, utilizzare i dischi)
durante la generazione dei numeri primi; questo dà al generatore di numeri casuali una migliore possibilità di ottenere
sufficiente entropia. [...] gpg: /home/pkgrepo/.gnupg/trustdb.gpg: trustdb creato gpg: chiave B4EF2D0D
contrassegnata come definitivamente attendibile gpg: directory '/home/

pkgrepo/.gnupg/openpgp-revocs.d' creata
```

Machine Translated by Google

```
gpg: certificato di revoca memorizzato come '/home/pkgrepo/.gnupg/openpgp-revocs.d/
      ÿ F8FE22F74F1B714E38DA6181B27F74F7B4EF2D0D.rev'
Chiave pubblica e chiave segreta create e firmate.

gpg: controllo del trustdb gpg:
marginali necessari: 3 completi necessari: 1 modello di fiducia: PGP gpg: profondità: 0 validi: 1
firmati: 0 fiducia: 0-, 0q, 0n, 0m, 0f, 1u pub rsa2048/B4EF2D0D 2020-06-17 [S]

          Impronta digitale della chiave = F8FE 22F7 4F1B 714E 38DA 6181 B27F 74F7 B4EF 2D0D
uid                    [definitivo] Chiave di firma del repository di sicurezza offensiva <repoadmin@offsec.com>
sub rsa2048/38035F38 2020-06-17 []
```

Tieni presente che quando ti viene richiesta una passphrase, dovresti inserire un valore vuoto (e confermare di non voler proteggere la tua chiave privata) poiché devi essere in grado di firmare il repository in modo non interattivo. Tieni presente inoltre che gpg richiede l'accesso in scrittura al terminale per poter richiedere in modo sicuro una passphrase: ecco perché hai modificato la proprietà del terminale virtuale (che appartiene a root poiché ti sei connesso inizialmente con quell'utente) prima di avviare una shell come pkgrepo.

Ora puoi iniziare a configurare il repository. È necessaria una directory dedicata per reprepro e al suo interno devi creare un file conf/distributions che documenti quali distribuzioni sono disponibili nel repository del pacchetto:

```
pkgrepo@kali:~$ mkdir -p reprepro/conf pkgrepo@kali:~$
cd reprepro pkgrepo@kali:~/reprepro$
cat >conf/distributions <<END
Nome in codice: offsec-internal
AncheAccettaPer: instabile
Origine: Offensive Security
Descrizione: Pacchetti interni di Offsec
Architetture: sorgente amd64 i386
Componenti: principali
SignWith: F8FE22F74F1B714E38DA6181B27F74F7B4EF2D0D
FINE
```

I campi obbligatori sono Codename, che specifica il nome della distribuzione, Architectures, che indica quali architetture saranno disponibili nella distribuzione (e accettate in input), e Components, che indica i vari componenti disponibili nella distribuzione (i componenti sono una sorta di sottosezione della distribuzione, che può essere abilitata separatamente nel file sources.list di APT). I campi Origin e Description sono puramente informativi e vengono copiati così come sono nel file Release . Il campo SignWith richiede a reprepro di firmare il repository con la chiave GnuPG il cui identificatore è elencato (inserire qui l'impronta digitale completa per assicurarsi di utilizzare la chiave corretta e non un'altra che entri in conflitto con l'identificatore breve). Il campo AlsoAcceptForsetting non è obbligatorio, ma consente di elaborare i file .changes il cui campo Distribution ha un valore elencato qui (senza questo, accetterebbe solo il nome in codice della distribuzione in quel campo).

Con questa configurazione di base, puoi lasciare che reprepro generi un repository vuoto:

Machine Translated by Google

```
pkgrepo@kali:~/reprepro$ reprepro export Esportazione
degli indici... pkgrepo@kali:~/
reprepro$ find .
.
./db ./
db/version ./db/
references.db ./db/
contents.cache.db ./db/
checksums.db ./db/
packages.db ./db/
release.caches.db ./conf ./conf/

distributions ./dists ./dists/
offsec-
internal ./dists/offsec-internal/
Release.gpg ./dists/offsec-internal/Release ./dists/
offsec-internal/main ./dists/offsec-internal/
main/source ./dists/offsec-internal/main/
source/Release ./dists/offsec-internal/main/source/
Sources.gz ./dists/offsec-internal/main/binary-amd64 ./dists/
offsec-internal/main/binary-amd64/Packages ./dists/offsec-internal/
main/binary-amd64/Release ./dists/offsec-internal/main/
binary-amd64/Packages.gz ./dists/offsec-internal/main/binary-i386 ./dists/
offsec-internal/main/binary-i386/Packages ./dists/offsec-internal/main/
binary-i386/Release ./dists/offsec-internal/main/binary-i386/Packages.gz ./dists/
offsec-internal/InRelease
```

Come potete vedere, reprepro ha creato le meta-informazioni del repository in una sottocartella chiamata dists . Ha inoltre inizializzato un database interno in una sottocartella chiamata db .

È giunto il momento di aggiungere il tuo primo pacchetto. Per prima cosa, copia i file generati dalla compilazione del pacchetto offsec-defaults (offsec-defaults_1.0.dsc, offsec-defaults_1.0.tar.xz, offsec-defaults_1.0_all.deb e offsec-defaults_1.0_amd64.changes) nella directory /tmp del server che ospita il repository del pacchetto e chiedi a reprepro di includere il pacchetto:

```
pkgrepo@kali:~/reprepro$ reprepro include offsec-internal /tmp/offsec-defaults_1.0 ÿ _amd64.changes Esportazione
        degli indici...
pkgrepo@kali:~/reprepro$
find pool pool pool/main pool/main/o
```

Machine Translated by Google

```
pool/main/o/offsec-defaults pool/
main/o/offsec-defaults/offsec-defaults_1.0.dsc pool/main/o/offsec-
defaults/offsec-defaults_1.0.tar.xz pool/main/o/offsec-defaults/offsec-
defaults_1.0_all.deb
```

Come puoi vedere, ha aggiunto i file al proprio pool di pacchetti in una sottocartella del pool .

Le directory `dists` e `pool` sono le due directory che devi rendere (pubblicamente) disponibili tramite HTTP per completare la configurazione del tuo repository APT. Contengono tutti i file che APT dovrà scaricare.

Supponendo che tu voglia ospitarlo su un host virtuale chiamato pkgrepo.offsec.com, potresti creare il seguente file di configurazione Apache, salvarlo in /etc/apache2/sites-available/pkgrepo.offsec.com.conf e abilitarlo con a2ensite pkgrepo.offsec.com):

```
<VirtualHost *:80> ServerName
        pkgrepo.offsec.com ServerAdmin
        repoadmin@offsec.com

        ErrorLog /var/log/apache2/pkgrepo.offsec.com-error.log CustomLog /var/log/
        apache2/pkgrepo.offsec.com-access.log "%h %l %u %t \"%r\" %>s %O"

        DocumentRoot /home/pkgrepo/reprepro

        <Directory "/home/pkgrepo/reprepro">
                Opzioni Indici FollowSymLinks MultiViews
                Richiedi tutti i dati concessi
                Consenti la sovrascrittura di tutto
        </Directory>
</VirtualHost>
```

E la corrispondente voce sources.list da aggiungere sui computer che necessitano di pacchetti da questo repository sarebbe la seguente:

```
deb http://pkgrepo.offsec.com offsec-internal main

# Abilita la riga successiva se desideri accedere anche ai pacchetti sorgente #
deb-src http://pkgrepo.offsec.com offsec-internal main
```

Il tuo pacchetto è ora pubblicato e dovrebbe essere disponibile per gli host in rete.

Sebbene la configurazione sia stata piuttosto lunga, la parte più impegnativa è ora completata. È possibile avviare le macchine in rete tramite PXE, installare una versione personalizzata di Kali Linux senza interazione grazie a un preset distribuito in rete, configurare SaltStack per gestire le configurazioni (e controllare i minion!), creare pacchetti personalizzati derivati e distribuirli tramite il proprio repository di pacchetti. Ciò garantisce una gestione centralizzata e un controllo a livello aziendale su più installazioni di Kali Linux. In breve, è ora possibile implementare rapidamente sistemi Kali altamente sicuri, preconfigurati per le proprie esigenze specifiche, e mantenerli sincronizzati grazie all'installazione (semi-automatica) di tutti gli aggiornamenti dei pacchetti da parte di Kali.

Machine Translated by Google

## 10.4. Riepilogo

Kali Linux è scalabile e si adatta non solo al desktop, ma anche a implementazioni di medie e grandi dimensioni e persino al livello aziendale. In questo capitolo, abbiamo illustrato come centralizzare la gestione di più installazioni di Kali con SaltStack, consentendo di implementare rapidamente sistemi Kali altamente sicuri e preconfigurati per le proprie esigenze specifiche. Abbiamo anche mostrato come mantenerli sincronizzati grazie all'installazione (semi-automatica) degli aggiornamenti dei pacchetti da parte di Kali.

Abbiamo parlato del fork dei pacchetti, che consente di creare pacchetti sorgente distribuibili personalizzati.

In sintesi, riepiloghiamo i passaggi principali necessari per configurare Salt master e minion, che consentono il controllo e la configurazione remota degli host remoti.

Suggerimenti riassuntivi:

- Avviare la macchina dalla rete tramite PXE, con almeno un server di file TFTP, un server DHCP/BOOTP (e un server web per la preconfigurazione di debconf). *dnsmasq* gestisce sia DHCP che TFTP, e il server web *apache2* è preinstallato (ma disabilitato) su Kali.
- Il manuale di installazione di Debian copre la configurazione di *isc-dhcp-server* e *tftpd-hpa* per l'avvio PXE-ing:

  ÿ https://www.debian.org/releases/stable/amd64/ch04s05
- *dnsmasq* viene configurato tramite il file /etc/dnsmasq.conf. Una configurazione di base consiste in poche righe chiave:

```
# Interfaccia di rete da gestire
interfaccia=eth0
# Opzioni DHCP #
Intervallo IP da allocare dhcp-
range=192.168.101.100,192.168.101.200,12h # Gateway da annunciare ai
client dhcp-option=option:router,192.168.101.1 #
Server DNS da annunciare ai client dhcp-option=option:dns-
server,8.8.8.8,8.8.4.4 # File di avvio da annunciare ai client
dhcp-boot=pxelinux.0 # Opzioni TFTP enable-tftp # Directory che ospita i
file da servire tftp-root=/tftpboot/
```

- Estrai i file di avvio dell'installazione a 32 bit (i386), 64 bit (amd64), standard o grafica (gtk) dall'archivio di Kali nella directory /tftpboot/. Gli archivi si trovano qui:

  ÿ http://http.kali.org/dists/kali-rolling/main/installer-amd64/current/ images/netboot/gtk/netboot.tar.gz

Machine Translated by Google

ÿ http://http.kali.org/dists/kali-rolling/main/installer-amd64/current/ images/netboot/netboot.tar.gz

ÿ http://http.kali.org/dists/kali-rolling/main/installer-i386/current/ images/netboot/gtk/netboot.tar.gz

ÿ http://http.kali.org/dists/kali-rolling/main/installer-i386/current/ images/netboot/netboot.tar.gz

```
# mkdir /tftpboot #
cd /tftpboot #
wget http://http.kali.org/dists/kali-rolling/main/installer-amd64/current/ ÿ images/netboot/
    netboot.tar.gz # tar xf netboot.tar.gz
```

- Facoltativamente, è possibile modificare il file txt.cfg per preimpostare parametri o timeout personalizzati. Vedere la sezione 4.3, "Installazioni automatiche" [pagina 95]. Successivamente, è possibile utilizzare strumenti di gestione della configurazione per gestire le macchine o configurare computer remoti in qualsiasi stato desiderato.
- SaltStack è un servizio centralizzato di gestione della configurazione: un Salt master gestisce molti Salt minion. Installa il pacchetto *salt-master* su un server raggiungibile e *salt-minion* sugli host gestiti.

- Modifica il file di configurazione in formato YAML /etc/salt/minion e imposta la chiave master sul DNS nome (o indirizzo IP) del master Salt.
- Imposta l'identificativo univoco del minion in /etc/salt/minion_id:

```
minion# echo kali-scratch >/etc/salt/minion_id minion#
systemctl enable salt-minion minion#
systemctl start salt-minion
```

- Seguirà lo scambio di chiavi. Sul master, accettare la chiave di identificazione del minion. Successivamente Le connessioni saranno automatiche:

```
master# systemctl enable salt-master master#
systemctl start salt-master master# salt-key
--list all
Tasti accettati:
Tasti rifiutati:
Tasti non accettati:
kali-scratch
Chiavi rifiutate:
master# salt-key --accept kali-scratch
Saranno accettate le seguenti chiavi:
Tasti non accettati:
kali-scratch
Procedere? [n/Y] y
Chiave per minion kali-scratch accettata.
```

Machine Translated by Google

- Una volta che i minion sono connessi, è possibile eseguire comandi su di essi dal master. Esempi:

```
master# salt '*' test.ping kali-scratch:

VERO
kali-master:
VERO
master# salt kali-scratch cmd.shell 'uptime; uname -a' master# salt kali-scratch
sys.doc' master# salt '*' service.enable ssh

[...]
master# salt '*' service.start ssh
[...]
master# salt '*' pkg.refresh_db [...] master# salt
'*'
pkg.upgrade dist_upgrade=True server# salt '*' cmd.shell 'pkill -f
dnmap_client'
```

- L'elenco completo dei moduli di esecuzione è disponibile all'indirizzo https://docs.saltproject.io/en/latest/ref/modules/all/index.html.
- Utilizza i file di stato di Salt (modelli di configurazione riutilizzabili) per pianificare azioni, raccogliere dati, organizzare sequenze di operazioni su più minion, eseguire il provisioning di sistemi cloud e metterli sotto gestione, e molto altro. Risparmia tempo con le formule Salt predefinite:

  ÿ https://docs.saltproject.io/en/latest/topics/development/conventions/ formulas.html

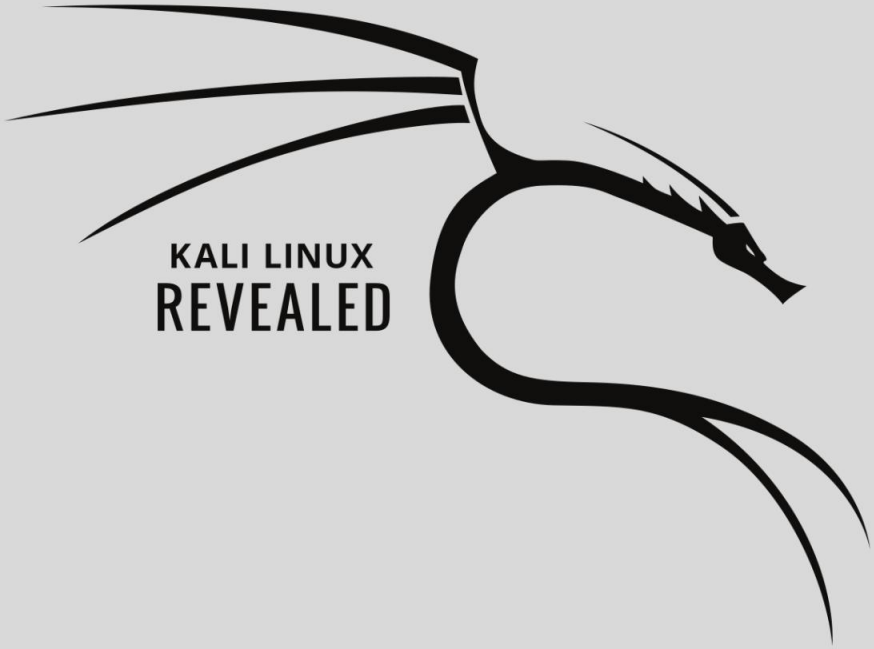
- Quando arriva il momento di creare una copia (fork) di un pacchetto, prima di tutto valuta se si tratta di un'operazione che devi effettivamente affrontare. Ci sono vantaggi e svantaggi significativi. Esaminali attentamente. I pacchetti *kali-meta, desktop-base* e *kali-menu* sono scelte interessanti e plausibili. Il processo di creazione di una copia (fork) di un pacchetto può essere scoraggiante ed è difficile da riassumere.

Ora che abbiamo trattato tutti gli aspetti fondamentali relativi all'installazione, alla configurazione, alla personalizzazione e alla distribuzione di Kali Linux, concentriamoci sul ruolo di Kali Linux nel campo della sicurezza informatica.

Machine Translated by Google

**Parole chiave**

**Tipologie di valutazione**
**Vulnerabilità valutazione**
**Test di penetrazione della conformità**
**Test di penetrazione tradizionale**
**Applicazione valutazione**
**Tipi di attacchi**
**Negazione del servizio**
**Corruzione della memoria**
**Vulnerabilità web**
**Attacchi alle password**
**attacchi lato client**



Machine Translated by Google

Capitolo

# 11

# Introduzione a Sicurezza Valutazioni

Contenuto

Kali Linux in una valutazione 285
Tipologie di valutazione 287
Formalizzazione della valutazione 297
Tipi di attacchi 298
Sommario 301

Machine Translated by Google

Finora abbiamo trattato molte funzionalità specifiche di Kali Linux, quindi dovreste avere una solida comprensione di ciò che rende Kali speciale e di come portare a termine una serie di attività complesse.

Prima di iniziare a utilizzare Kali, tuttavia, è necessario comprendere alcuni concetti relativi alle valutazioni di sicurezza. In questo capitolo, introdurremo questi concetti per fornirvi le basi e vi aiuteremo a trovare riferimenti utili qualora doveste utilizzare Kali per eseguire una valutazione di sicurezza.

Innanzitutto, vale la pena dedicare un po' di tempo ad approfondire cosa significhi esattamente "sicurezza" quando si parla di sistemi informativi. Quando si cerca di proteggere un sistema informativo, ci si concentra su tre attributi principali del sistema:

- *Riservatezza:* possono gli attori che non dovrebbero avere accesso al sistema o alle informazioni accedervi?
- *Integrità:* i dati o il sistema possono essere modificati in modo non previsto?
- *Disponibilità:* i dati o il sistema sono accessibili quando e come previsto?

Insieme, questi concetti costituiscono la triade CIA (Riservatezza, Integrità, Disponibilità) e, in larga misura, rappresentano gli elementi principali su cui concentrarsi per proteggere un sistema durante le fasi standard di implementazione, manutenzione o valutazione.

È importante notare che, in alcuni casi, un aspetto della triade CIA potrebbe essere molto più importante di altri. Ad esempio, se si possiede un diario personale contenente i propri pensieri più segreti, la riservatezza del diario potrebbe essere molto più importante dell'integrità o della disponibilità. In altre parole, potrebbe non essere così importante che qualcuno possa scrivere sul diario (anziché leggerlo) o che il diario sia sempre accessibile. D'altro canto, se si sta proteggendo un sistema che tiene traccia delle prescrizioni mediche, l'integrità dei dati sarà fondamentale. Sebbene sia importante impedire ad altri di leggere quali farmaci vengono assunti da una persona e sia importante poter accedere a tale elenco, se qualcuno fosse in grado di modificarne il contenuto (alterandone l'integrità), ciò potrebbe avere conseguenze potenzialmente letali.

Quando si mette in sicurezza un sistema e viene scoperto un problema, è necessario considerare a quale di questi tre concetti, o a quale combinazione di essi, appartiene il problema. Questo aiuta a comprendere il problema in modo più completo e consente di classificarlo e di rispondere di conseguenza. È possibile identificare vulnerabilità che interessano uno o più elementi della triade CIA. Prendiamo come esempio un'applicazione web con una vulnerabilità di SQL injection:

- *Riservatezza:* una vulnerabilità di SQL injection che consente a un utente malintenzionato di estrarre l'intero contenuto dell'applicazione web, ottenendo così pieno accesso per leggere tutti i dati, ma senza la possibilità di modificarli o disabilitare l'accesso al database.
- *Integrità:* una vulnerabilità di SQL injection che consente a un utente malintenzionato di modificare le informazioni esistenti nel database. L'attaccante non può leggere i dati né impedire ad altri di accedere al database.

Machine Translated by Google

- *Disponibilità:* una vulnerabilità di SQL injection che avvia una query di lunga durata, consumando una grande quantità di risorse sul server. Questa query, se eseguita più volte, porta a una situazione di negazione del servizio (DoS). L'attaccante non ha la possibilità di accedere o modificare i dati, ma può impedire agli utenti legittimi di accedere all'applicazione web.
- *Multipla:* una vulnerabilità di SQL injection consente l'accesso completo alla shell interattiva del sistema operativo host che esegue l'applicazione web. Con questo accesso, l'attaccante può violare la riservatezza del sistema accedendo ai dati a proprio piacimento, compromettere l'integrità del sistema modificando i dati e, se lo desidera, distruggere l'applicazione web, compromettendo così la disponibilità del sistema.

I concetti alla base della triade CIA non sono eccessivamente complicati e, in realtà, si tratta di elementi con cui lavorate intuitivamente, anche se non ve ne rendete conto. Tuttavia, è importante interagire consapevolmente con questo concetto, poiché può aiutarvi a capire dove concentrare i vostri sforzi. Questa base concettuale vi aiuterà a identificare i componenti critici dei vostri sistemi e a quantificare l'impegno e le risorse da investire nella risoluzione dei problemi individuati.

Un altro concetto che tratteremo in dettaglio è *il rischio,* e come esso sia composto da *minacce* e *vulnerabilità.* Questi concetti non sono eccessivamente complessi, ma è facile fraintenderli. Li analizzeremo in dettaglio più avanti, ma a grandi linee, è utile pensare al *rischio* come a ciò che si cerca di impedire che accada, *alla minaccia* come a chi potrebbe farlo e alla *vulnerabilità* come a ciò che permette a chi lo fa di farlo. È possibile implementare dei controlli per affrontare la minaccia o la vulnerabilità, con l'obiettivo di mitigare il rischio.

Ad esempio, visitando alcune parti del mondo, si può correre un *rischio* considerevole di contrarre la malaria. Questo perché la *presenza* di zanzare è molto elevata in alcune zone e quasi certamente non si è immuni alla malaria. Fortunatamente, è possibile controllare la *vulnerabilità* con farmaci e tentare di limitare la *minaccia* utilizzando repellenti per insetti e zanzariere. Adottando misure di controllo che affrontino sia la *minaccia* che la *vulnerabilità,* si può contribuire a ridurre il *rischio* .

## 11.1. Kali Linux in una valutazione

Quando ci si prepara a utilizzare Kali Linux sul campo, è fondamentale assicurarsi di avere un'installazione pulita e funzionante. Un errore comune commesso da molti professionisti della sicurezza alle prime armi è quello di utilizzare la stessa installazione per più valutazioni. Questo rappresenta un problema per due motivi principali:

- Nel corso di una valutazione, spesso dovrai installare, modificare o comunque cambiare manualmente il tuo sistema. Queste modifiche una tantum possono consentirti di essere operativo rapidamente o risolvere un problema specifico, ma sono difficili da tenere traccia, rendono il sistema più difficile da manutenere e complicano le configurazioni future.
- Ogni valutazione della sicurezza è unica. Lasciare note, codice e altre modifiche può generare confusione o, peggio, causare la contaminazione incrociata dei dati del cliente.

Machine Translated by Google

Ecco perché è altamente consigliabile partire da un'installazione pulita di Kali e perché avere una versione preconfigurata di Kali Linux, pronta per un'installazione automatizzata rapida, si rivela vantaggioso. Assicuratevi di consultare nuovamente la sezione 9.3, "Creazione di immagini ISO live personalizzate di Kali" [pagina 241] e la sezione 4.3, "Installazioni automatiche" [pagina 95] per sapere come procedere, poiché più automatizzate oggi, meno tempo sprecherete domani.

Ognuno ha esigenze diverse per quanto riguarda la configurazione di Kali Linux sul campo, ma ci sono alcune raccomandazioni universali che è consigliabile seguire.
Innanzitutto, valuta la possibilità di utilizzare un'installazione crittografata, come descritto nella sezione 4.2.2, "Installazione su un file system completamente crittografato" [pagina 88]. Questo proteggerà i tuoi dati sul computer, il che può essere fondamentale in caso di furto del portatile.

Per una maggiore sicurezza durante i viaggi, si consiglia di eliminare definitivamente la chiave di decrittazione (vedere "Aggiunta di una password di eliminazione per una maggiore sicurezza" [pagina 250]) dopo averne inviato una copia (crittografata) a un collega in ufficio. In questo modo, i dati saranno al sicuro fino al rientro in ufficio, dove sarà possibile ripristinare il laptop con la chiave di decrittazione.

Un altro aspetto da verificare attentamente è l'elenco dei pacchetti installati. Considera quali strumenti potrebbero servirti per il lavoro che intendi svolgere. Ad esempio, se stai per iniziare una valutazione della sicurezza wireless, potresti valutare l'installazione del metapackage *kali-tools-wireless* , che contiene tutti gli strumenti di valutazione wireless disponibili in Kali Linux; se invece devi valutare un'applicazione web, puoi installare tutti gli strumenti di test per applicazioni web disponibili con il metapackage *kali-tools-web* . È consigliabile presumere che non avrai facile accesso a Internet durante una valutazione della sicurezza, quindi assicurati di prepararti il più possibile in anticipo.

Per lo stesso motivo, è consigliabile rivedere le impostazioni di rete (vedere la sezione 5.1, "Configurazione della rete" [pagina 108] e la sezione 7.3, "Protezione dei servizi di rete" [pagina 159]). Verificate le impostazioni DHCP e controllate i servizi in ascolto sul vostro indirizzo IP assegnato.
Queste impostazioni potrebbero avere un impatto cruciale sul tuo successo. Non puoi valutare ciò che non vedi e un numero eccessivo di servizi di ascolto potrebbe segnalare il tuo sistema e causarne l'arresto prima ancora di iniziare.

Se il tuo ruolo prevede l'indagine sulle intrusioni di rete, prestare molta attenzione alle impostazioni di rete è ancora più importante ed è necessario evitare di modificare i sistemi interessati. Una versione personalizzata di Kali con il metapackage *kali-tools-forensics* avviato in modalità forense non monterà automaticamente i dischi né utilizzerà una partizione di swap. In questo modo, puoi contribuire a mantenere l'integrità del sistema in analisi, sfruttando al contempo i numerosi strumenti forensi disponibili in Kali Linux.

È fondamentale preparare adeguatamente l'installazione di Kali Linux. Scoprirai che un ambiente Kali pulito, efficiente ed efficace renderà tutto ciò che segue molto più agevole.

Machine Translated by Google

## 11.2. Tipologie di valutazione

Ora che ti sei assicurato che il tuo ambiente Kali sia pronto, il passo successivo è definire esattamente che tipo di valutazione stai conducendo. Al livello più generale, possiamo descrivere quattro tipi di valutazioni: una *valutazione delle vulnerabilità,* un *test di conformità,* un *penetration test tradizionale* e una *valutazione dell'applicazione.* Un'attività può includere vari elementi di ciascun tipo di valutazione, ma vale la pena descriverli in dettaglio e spiegarne la rilevanza per la tua build di Kali Linux e
ambiente.

Prima di esaminare le diverse tipologie di valutazioni, è importante innanzitutto sottolineare la differenza tra vulnerabilità e sfruttamento di una falla.

Una *vulnerabilità* è definita come un difetto che, se sfruttato, compromette la riservatezza, l'integrità o la disponibilità di un sistema informativo. Esistono molti tipi diversi di vulnerabilità, tra cui:

- Inclusione di file: vulnerabilità di inclusione di file1 Le funzionalità presenti nelle applicazioni web consentono di *includere* il contenuto di un file locale o remoto nell'esecuzione di un programma. Ad esempio, un'applicazione web potrebbe avere una funzione "Messaggio del giorno" che legge il contenuto di un file e lo include nella pagina web per visualizzarlo all'utente. Se questo tipo di funzionalità viene programmata in modo errato, può consentire a un utente malintenzionato di modificare la propria richiesta web per forzare il sito a includere il contenuto di un file a sua scelta.
- Iniezione SQL: un'iniezione SQL2 Un attacco di questo tipo consiste nell'aggirare le routine di convalida dell'input del programma, consentendo a un utente malintenzionato di fornire comandi SQL da eseguire al programma bersaglio. Questa è una forma di esecuzione di comandi che può portare a potenziali rischi per la sicurezza. problemi.
- Overflow del buffer: un overflow del buffer3 è una vulnerabilità che aggira le routine di convalida dell'input per scrivere dati nella memoria adiacente di un buffer. In alcuni casi, tale posizione di memoria adiacente può essere critica per il funzionamento del programma bersaglio e il controllo dell'esecuzione del codice può essere ottenuto attraverso un'attenta manipolazione dei dati di memoria sovrascritti. • Condizioni di gara:

una condizione di gara4 Si tratta di una vulnerabilità che sfrutta le dipendenze temporali in un programma. In alcuni casi, il flusso di lavoro di un programma dipende dal verificarsi di una specifica sequenza di eventi. Se è possibile alterare questa sequenza di eventi, ciò può portare a una vulnerabilità.

Un *exploit,* d'altra parte, è un software che, quando utilizzato, sfrutta una specifica vulnerabilità, sebbene non tutte le vulnerabilità siano sfruttabili. Poiché un exploit deve modificare un processo in esecuzione, costringendolo a compiere un'azione non intenzionale, la creazione di exploit può essere complessa. Inoltre, esistono numerose tecnologie anti-exploit nelle moderne piattaforme informatiche che sono state

[1] https://en.wikipedia.org/wiki/File_inclusion_vulnerability
[2] https://en.wikipedia.org/wiki/SQL_injection
[3] https://en.wikipedia.org/wiki/Buffer_overflow
[4] https://en.wikipedia.org/wiki/Race_condition

Machine Translated by Google

progettato per rendere più difficile lo sfruttamento delle vulnerabilità, come la prevenzione dell'esecuzione dei dati5 (DEP) e randomizzazione del layout dello spazio degli indirizzi6 (ASLR). Tuttavia, il fatto che non esista un exploit pubblicamente noto per una specifica vulnerabilità non significa che non ne esista uno (o che non possa essere creato). Ad esempio, molte organizzazioni vendono exploit commerciali che non vengono mai resi pubblici, quindi tutte le vulnerabilità devono essere considerate potenzialmente sfruttabili.

### 11.2.1. Valutazione della vulnerabilità

Una *vulnerabilità* è considerata una debolezza che potrebbe essere sfruttata in qualche modo per compromettere la riservatezza, l'integrità o la disponibilità di un sistema informativo. In una valutazione delle vulnerabilità, l'obiettivo è creare un semplice inventario delle vulnerabilità individuate all'interno dell'ambiente *target.* Il concetto di ambiente target è estremamente importante. È fondamentale rimanere entro i limiti della rete target del cliente e degli obiettivi richiesti. Uscire dall'ambito della valutazione può causare un'interruzione del servizio, una violazione della fiducia con il cliente o azioni legali contro di voi e il vostro datore di lavoro.

Grazie alla sua relativa semplicità, un test di vulnerabilità viene spesso completato regolarmente in ambienti più maturi come parte della dimostrazione della dovuta diligenza. Nella maggior parte dei casi, uno strumento automatizzato, come quelli nell'analisi delle vulnerabilità7 e applicazioni Web8 Le categorie del sito degli strumenti Kali e del menu delle applicazioni desktop Kali vengono utilizzate per individuare i sistemi attivi in un ambiente di destinazione, identificare i servizi in ascolto ed enumerarli per raccogliere quante più informazioni possibili, come il software del server, la versione, la piattaforma e così via.

Queste informazioni vengono quindi controllate per individuare firme note di potenziali problemi o vulnerabilità. Queste firme sono costituite da combinazioni di punti dati che hanno lo scopo di rappresentare problemi noti. Vengono utilizzati più punti dati, perché maggiore è il numero di punti dati utilizzati, più accurata sarà l'identificazione. Esiste un numero molto elevato di potenziali punti dati, tra cui, a titolo esemplificativo ma non esaustivo:

- Versione del sistema operativo: non è raro che un software sia vulnerabile su una versione del sistema operativo ma non su un'altra. Per questo motivo, lo scanner tenterà di determinare, nel modo più accurato possibile, quale versione del sistema operativo ospita l'applicazione target.

- Livello di patch: Spesso, le patch per un sistema operativo vengono rilasciate senza incrementare le informazioni sulla versione, ma modificando comunque il modo in cui una vulnerabilità reagisce, o addirittura eliminandola completamente.

- Architettura del processore: sono disponibili numerose applicazioni software per diverse architetture di processore, come Intel x86, Intel x64, diverse versioni di ARM, UltraSPARC e così via.

[5] https://en.wikipedia.org/wiki/Executable_space_protection#Windows
[6] https://en.wikipedia.org/wiki/Address_space_layout_randomization
[7] https://tools.kali.org/category/vulnerability-analysis
[8] https://tools.kali.org/category/web-applications

Machine Translated by Google

In alcuni casi, una vulnerabilità esiste solo su una specifica architettura, quindi conoscere questa informazione può essere fondamentale per una firma accurata.

- Versione del software: la versione del software preso di mira è uno degli elementi fondamentali da acquisire per identificare una vulnerabilità.

Questi e molti altri punti dati verranno utilizzati per creare una firma nell'ambito di una scansione delle vulnerabilità. Come prevedibile, maggiore è il numero di punti dati corrispondenti, più accurata sarà la firma. Quando si lavora con le corrispondenze delle firme, si possono ottenere diversi risultati possibili:

- Vero Positivo: la firma corrisponde e rileva una vulnerabilità reale. Questi risultati sono quelli su cui è necessario intervenire e che dovranno essere corretti, poiché si tratta di elementi che individui malintenzionati potrebbero sfruttare per danneggiare la vostra organizzazione (o quella del vostro cliente).
- Falso positivo: la firma corrisponde; tuttavia, il problema rilevato non è una vera vulnerabilità. In una valutazione, questi vengono spesso considerati rumore e possono essere piuttosto frustranti. Non bisogna mai scartare un vero positivo considerandolo un falso positivo senza una convalida più approfondita. •

Vero negativo: la firma non corrisponde e non c'è vulnerabilità. Questo è lo scenario ideale, che verifica l'assenza di vulnerabilità su un target.

- Falso negativo: la firma non corrisponde, ma esiste una vulnerabilità. Per quanto un falso positivo sia grave, un falso negativo è molto peggio. In questo caso, esiste un problema, ma lo scanner non lo ha rilevato, quindi non si ha alcuna indicazione della sua esistenza.

Come potete immaginare, l'accuratezza delle firme è estremamente importante per ottenere risultati precisi. Maggiore è la quantità di dati forniti, maggiore è la probabilità di ottenere risultati accurati da una scansione automatizzata basata sulla firma, ed è per questo che le scansioni autenticate sono spesso così diffuse.

Con una scansione autenticata, il software di scansione utilizza le credenziali fornite per autenticarsi al sistema di destinazione. Ciò offre un livello di visibilità più approfondito rispetto a quanto sarebbe altrimenti possibile. Ad esempio, con una scansione normale si potrebbero rilevare solo informazioni sul sistema derivanti dai servizi di ascolto e dalle funzionalità che questi offrono. A volte si tratta di una quantità considerevole di informazioni, ma non è paragonabile al livello e alla profondità dei dati che si otterrebbero autenticandosi al sistema e analizzando in modo completo tutto il software installato, le patch applicate, i processi in esecuzione e così via. Questa ampiezza di dati è utile per rilevare vulnerabilità che altrimenti potrebbero non essere scoperte.

Una valutazione delle vulnerabilità ben condotta offre un'istantanea dei potenziali problemi all'interno di un'organizzazione e fornisce metriche per misurare i cambiamenti nel tempo. Si tratta di una valutazione relativamente semplice, ma ciononostante, molte organizzazioni eseguono regolarmente scansioni automatiche delle vulnerabilità al di fuori dell'orario di lavoro per evitare potenziali problemi durante il giorno, quando la disponibilità dei servizi e la larghezza di banda sono più critiche.

Come accennato in precedenza, una scansione delle vulnerabilità dovrà controllare molti punti dati diversi per ottenere un risultato accurato. Tutti questi controlli diversi possono creare carico sul sistema di destinazione e consumare larghezza di banda. Sfortunatamente, è difficile sapere esattamente quante risorse verranno consumate sul target poiché dipende dal numero di servizi aperti e dai tipi di

Machine Translated by Google

controlli che sarebbero associati a tali servizi. Questo è il costo dell'esecuzione di una scansione; occuperà risorse di sistema. Avere un'idea generale delle risorse che verranno consumate e del carico massimo che il sistema di destinazione può sopportare è importante quando si utilizzano questi strumenti.

**Thread di scansione** La maggior parte degli scanner di vulnerabilità include un'opzione per impostare il numero di thread per scansione, ovvero il numero di controlli simultanei che vengono eseguiti contemporaneamente. L'aumento di questo numero avrà un impatto diretto sul carico della piattaforma di valutazione, nonché sulle reti e sui target con cui si interagisce. È importante tenerlo presente quando si utilizzano questi scanner. È allettante aumentare i thread per completare le scansioni più velocemente, ma bisogna ricordare il notevole aumento di carico associato a tale operazione.

Al termine di una scansione delle vulnerabilità, i problemi rilevati vengono in genere collegati a identificatori standard del settore come il numero CVE9 , EDB-ID10, e avvisi dei fornitori. Queste informazioni, insieme al punteggio CVSS delle vulnerabilità11, viene utilizzato per determinare un punteggio di rischio. Insieme ai falsi negativi (e ai falsi positivi), questi punteggi di rischio arbitrari sono problemi comuni che devono essere presi in considerazione quando si analizzano i risultati della scansione.

Poiché gli strumenti automatizzati utilizzano un database di firme per rilevare le vulnerabilità, qualsiasi minima deviazione da una firma nota può alterare il risultato e, di conseguenza, la validità della vulnerabilità rilevata. Un falso positivo segnala erroneamente una vulnerabilità inesistente, mentre un falso negativo non rileva alcuna vulnerabilità e non la segnala. Per questo motivo, si dice spesso che la qualità di uno scanner dipende dalla qualità del suo database di firme. Per tale ragione, molti fornitori offrono diversi set di firme: uno gratuito per gli utenti domestici e un altro più completo, ma piuttosto costoso, generalmente venduto alle aziende.

Un altro problema che si riscontra spesso con le scansioni di vulnerabilità riguarda la validità delle valutazioni di rischio suggerite. Queste valutazioni sono definite in modo generico, considerando diversi fattori come il livello di privilegio, il tipo di software e l'autenticazione pre o post-esecuzione. A seconda del contesto, queste valutazioni potrebbero non essere applicabili, pertanto non dovrebbero essere accettate ciecamente.
Solo chi ha una profonda conoscenza dei sistemi e delle vulnerabilità può validare correttamente le valutazioni del rischio.

Sebbene non esista un accordo universalmente definito sulle valutazioni del rischio, la pubblicazione speciale NIST 800-3012 Si raccomanda di utilizzare questo standard come base di riferimento per la valutazione dei punteggi di rischio e della loro accuratezza nel proprio ambiente. Lo standard NIST SP 800-30 definisce il rischio reale di una vulnerabilità scoperta come *una combinazione della probabilità di accadimento e del potenziale impatto.*

[9] https://cve.mitre.org/ 10https://www.exploit-db.com/ 11https://www.first.org/cvss/ 12https://csrc.nist.gov/publications/sp#800-30

Machine Translated by Google

### Probabilità di accadimento

Secondo il National Institute of Standards and Technology (NIST), la probabilità di accadimento si basa sulla probabilità che una particolare minaccia sia in grado di sfruttare una specifica vulnerabilità, con possibili valutazioni di Bassa, Media o Alta.

- Elevato: il potenziale avversario è altamente qualificato e motivato e le misure messe in atto per proteggersi dalla vulnerabilità sono insufficienti.
- Medio: il potenziale avversario è motivato e abile, ma le misure adottate per proteggersi dalla vulnerabilità potrebbero ostacolarne il successo.
- Basso: il potenziale avversario è inesperto o demotivato e sono in atto misure di protezione contro la vulnerabilità che risultano parzialmente o completamente efficaci.

### impatto

Il livello di impatto viene determinato valutando l'entità del danno che potrebbe verificarsi se la vulnerabilità in questione venisse sfruttata o altrimenti utilizzata a proprio vantaggio.

- Alto: sfruttare la vulnerabilità potrebbe comportare perdite finanziarie molto significative, gravi danni alla missione o alla reputazione dell'organizzazione, o persino lesioni gravi, inclusa la perdita di vite umane.
- Medio: sfruttare la vulnerabilità potrebbe comportare perdite finanziarie, danni alla missione o alla reputazione dell'organizzazione, o lesioni personali. • Basso:

sfruttare la vulnerabilità potrebbe comportare un certo grado di perdita finanziaria o un impatto sulla missione e sulla reputazione dell'organizzazione.

### Rischio complessivo

Una volta determinata la probabilità di accadimento e l'impatto, è possibile stabilire il livello di rischio complessivo, definito in funzione dei due valori ottenuti. Il rischio complessivo può essere classificato come Basso, Medio o Alto, fornendo indicazioni a coloro che sono responsabili della sicurezza e della manutenzione dei sistemi in questione.

- Elevato: è fortemente necessario implementare misure aggiuntive per proteggersi dalla vulnerabilità. In alcuni casi, il sistema potrebbe continuare a funzionare, ma è necessario elaborare e attuare un piano il prima possibile.
- Medio: È necessario implementare misure aggiuntive per proteggersi dalla vulnerabilità. Un piano per l'attuazione delle misure richieste deve essere predisposto tempestivamente.

Machine Translated by Google

- Basso: Il proprietario del sistema deciderà se implementare misure aggiuntive per proteggersi dalla vulnerabilità oppure se accettare il rischio e lasciare il sistema invariato.

## In sintesi

Considerando i numerosi fattori che contribuiscono al rischio reale di una vulnerabilità scoperta, le valutazioni di rischio predefinite fornite dagli strumenti dovrebbero essere utilizzate solo come punto di partenza per determinare il rischio effettivo per l'intera organizzazione.

I report di valutazione delle vulnerabilità, redatti in modo competente e analizzati da un professionista, possono fornire una base iniziale per altre valutazioni, come i penetration test di conformità. Pertanto, è importante comprendere come ottenere i migliori risultati possibili da questa valutazione iniziale.

Kali rappresenta un'ottima piattaforma per condurre una valutazione delle vulnerabilità e non richiede alcuna configurazione particolare. Nel menu Applicazioni di Kali, troverai numerosi strumenti per le valutazioni delle vulnerabilità nelle categorie Raccolta di informazioni, Analisi delle vulnerabilità e Analisi delle applicazioni web . Diversi siti, tra cui il già citato Elenco degli strumenti di Kali Linux13 , La documentazione ufficiale di Kali Linux14 sito e il Metasploit Unleashed15 gratuito Il corso fornisce risorse eccellenti per l'utilizzo di Kali Linux durante una valutazione delle vulnerabilità.

### 11.2.2. Test di penetrazione di conformità

Il tipo successivo di valutazione, in ordine di complessità, è il penetration test basato sulla conformità. Si tratta dei penetration test più comuni, in quanto si basano su requisiti imposti da enti governativi e di settore, a loro volta definiti da un quadro di conformità a cui l'intera organizzazione è soggetta.

Sebbene esistano molti framework di conformità specifici per settore, il più comune è probabilmente il Payment Card Industry Data Security Standard16. (PCI DSS), un framework dettato dalle società di carte di pagamento al quale i rivenditori che elaborano pagamenti basati su carte devono conformarsi. Tuttavia, esistono numerosi altri standard come le guide di implementazione tecnica di sicurezza della Defense Information Systems Agency17 (DISA STIG), Programma federale di gestione dei rischi e delle autorizzazioni18 (FedRAMP), Federal Information Security Management Act19 (FISMA) e altri. In alcuni casi, un cliente aziendale può richiedere una valutazione o chiedere di vedere i risultati della valutazione più recente per vari motivi. Che siano ad hoc o obbligatorie, queste tipologie di valutazioni sono collettivamente

13https://tools.kali.org/tools-listing 14https://www.kali.org/docs/ 15https://www.offensive-security.com/metasploit-unleashed/ 16https://www.pcisecuritystandards.org/documents/Penetration_Testing_Guidance_March_2015.pdf 17https://public.cyber.mil/stigs/ 18https://www.fedramp.gov/about-us/about/ 19https://csrc.nist.gov/projects/risk-management

Machine Translated by Google

chiamati test di penetrazione basati sulla conformità, o semplicemente "valutazioni di conformità" o "verifiche di conformità".

Un test di conformità spesso inizia con una valutazione della vulnerabilità. Nel caso dell'audit di conformità PCI20 , una valutazione della vulnerabilità, se eseguita correttamente, può soddisfare diversi dei requisiti di base, tra cui: “2. Non utilizzare le impostazioni predefinite fornite dal fornitore per le password di sistema e altri parametri di sicurezza” (ad esempio, con strumenti della categoria di menu Attacchi alle password ), “11. Testare regolarmente i sistemi e i processi di sicurezza” (con strumenti della categoria Valutazione del database ) e altri. Alcuni requisiti, come “9. Limitare l’accesso fisico ai dati dei titolari di carte” e “12. Mantenere una politica che affronti la sicurezza delle informazioni per tutto il personale” non sembrano prestarsi alla tradizionale valutazione della vulnerabilità basata su strumenti e richiedono ulteriore creatività e test.

Nonostante l'utilizzo di Kali Linux per alcuni aspetti di un test di conformità possa non sembrare immediato, in realtà Kali si adatta perfettamente a questo contesto, non solo per l'ampia gamma di strumenti di sicurezza disponibili, ma anche per l'ambiente open-source Debian su cui è basato, che consente l'installazione di una vasta gamma di software. Una semplice ricerca nel gestore di pacchetti con parole chiave selezionate in base al framework di conformità utilizzato produrrà quasi certamente numerosi risultati. Molte organizzazioni, infatti, utilizzano Kali Linux come piattaforma standard per questo tipo di valutazioni.

### 11.2.3. Test di penetrazione tradizionale

Definire un penetration test tradizionale è diventato un concetto complesso, con diverse definizioni a seconda del settore di riferimento. Questa confusione è in parte dovuta al fatto che il termine "penetration test" viene ormai comunemente utilizzato per indicare il penetration test di conformità (o persino una valutazione delle vulnerabilità), in cui, per sua natura, l'analisi non è troppo approfondita, poiché ciò andrebbe oltre i requisiti minimi.

Ai fini di questa sezione, tralasceremo tale dibattito e utilizzeremo questa categoria per includere le valutazioni che vanno oltre i requisiti minimi; valutazioni progettate per migliorare effettivamente la sicurezza complessiva dell'organizzazione.

A differenza delle tipologie di valutazione discusse in precedenza, i penetration test spesso non iniziano con una definizione dell'ambito, ma piuttosto con un obiettivo come "simulare cosa accadrebbe se un utente interno venisse compromesso" o "identificare cosa accadrebbe se l'organizzazione subisse un attacco mirato da parte di una parte malintenzionata esterna". Una differenza fondamentale di questo tipo di valutazioni è che non si limitano a trovare e convalidare le vulnerabilità, ma sfruttano i problemi identificati per scoprire lo scenario peggiore. Invece di affidarsi esclusivamente a pesanti strumenti di scansione delle vulnerabilità, è necessario convalidare i risultati attraverso l'uso di exploit o test per eliminare i falsi positivi e fare del proprio meglio per rilevare vulnerabilità nascoste o falsi negativi. Questo spesso implica lo sfruttamento di

20https://www.pcisecuritystandards.org/documents/PCIDSS_QRGv3_2.pdf

Machine Translated by Google

vulnerabilità scoperte inizialmente, esplorando il livello di accesso fornito dall'exploit e utilizzando questo maggiore accesso come leva per ulteriori attacchi contro il bersaglio.

Ciò richiede un'analisi critica dell'ambiente target, unitamente a ricerche manuali, creatività e pensiero laterale, per scoprire altre potenziali vulnerabilità e, in definitiva, utilizzare strumenti e test diversi da quelli individuati dai più sofisticati scanner di vulnerabilità. Una volta completata questa fase, è spesso necessario ripetere l'intero processo più volte per ottenere un risultato completo ed efficace.

Anche con questo approccio, spesso si scopre che molte valutazioni sono composte da diverse fasi. Kali semplifica la ricerca dei programmi per ciascuna fase tramite il menu Kali:

- Raccolta di informazioni: In questa fase, ci si concentra sull'apprendimento di quante più informazioni possibili sull'ambiente di destinazione. In genere, questa attività non è invasiva e apparirà simile alla normale attività dell'utente. Queste azioni costituiranno la base per il resto della valutazione e pertanto devono essere il più complete possibile. La categoria Raccolta di informazioni di Kali offre decine di strumenti per scoprire quante più informazioni possibili sull'ambiente in fase di valutazione.

- Individuazione delle vulnerabilità: questa fase viene spesso definita "raccolta attiva di informazioni" e non prevede un attacco diretto, bensì l'adozione di comportamenti utente non standard nel tentativo di identificare potenziali vulnerabilità nell'ambiente target. È in questa fase che si svolge più spesso la scansione delle vulnerabilità precedentemente descritta. I programmi elencati nelle categorie Analisi delle vulnerabilità, Analisi delle applicazioni web, Valutazione dei database e Reverse Engineering saranno utili in questa fase. •

Sfruttamento: una volta individuate le potenziali vulnerabilità, in questa fase si tenta di sfruttarle per ottenere un punto d'appoggio nel sistema target. Gli strumenti utili in questa fase si trovano nelle categorie Analisi delle applicazioni web, Valutazione dei database, Attacchi alle password e Strumenti di sfruttamento .

- Passaggio di livello ed esfiltrazione: una volta stabilito il punto d'appoggio iniziale, è necessario completare ulteriori passaggi. Questi spesso consistono nell'aumentare i privilegi fino a un livello adeguato per raggiungere gli obiettivi prefissati come attaccante, nel passare ad altri sistemi che potrebbero non essere stati accessibili in precedenza e nell'esfiltrare informazioni sensibili dai sistemi target. Consultare le categorie Attacchi alle password, Strumenti di sfruttamento, Sniffing e spoofing e Post-sfruttamento per assistenza in questa fase.
- Reportistica: Una volta completata la parte attiva della valutazione, è necessario documentare e redigere un report sulle attività svolte. Questa fase spesso non è tecnicamente complessa come le precedenti, tuttavia è fondamentale per garantire che il cliente tragga il massimo beneficio dal lavoro svolto. La categoria Strumenti di reporting contiene una serie di strumenti che si sono dimostrati utili nella fase di reporting.

Nella maggior parte dei casi, queste valutazioni saranno molto uniche nella loro progettazione poiché ogni organizzazione opererà con minacce e risorse diverse da proteggere. Kali Linux costituisce una base molto versatile per

Machine Translated by Google

questo tipo di valutazioni ed è qui che puoi davvero sfruttare le numerose funzionalità di personalizzazione di Kali Linux. Molte organizzazioni che conducono questo tipo di valutazioni manterranno versioni altamente personalizzate di Kali Linux per uso interno per accelerare l'implementazione dei sistemi prima
una nuova valutazione.

Le personalizzazioni che le organizzazioni apportano alle proprie installazioni di Kali Linux spesso includono:

- Preinstallazione di pacchetti commerciali con informazioni di licenza. Ad esempio, potresti avere un pacchetto come uno scanner di vulnerabilità commerciale che desideri utilizzare. Per evitare di dover installare questo pacchetto a ogni build, puoi farlo una sola volta e renderlo disponibile in ogni distribuzione di Kali.

- Reti private virtuali (VPN) preconfigurate con connessione inversa. Queste sono molto utili nei dispositivi da lasciare sul posto che consentono di condurre valutazioni "interne remote". Nella maggior parte dei casi, questi sistemi si connetteranno a un sistema controllato dal valutatore, creando un tunnel che il valutatore può utilizzare per accedere ai sistemi interni. L' immagine ISO di Kali Linux di Doom21 è un esempio preciso di questo tipo di personalizzazione.

- Software e strumenti sviluppati internamente e preinstallati. Molte organizzazioni dispongono di set di strumenti proprietari, quindi configurarli una sola volta in un'installazione personalizzata di Kali consente di risparmiare tempo.
- Configurazioni del sistema operativo preconfigurate come mappature host, sfondo del desktop, impostazioni proxy, ecc. Molti utenti di Kali hanno impostazioni specifiche22 A loro piace che le cose siano modificate con cura. Se si prevede di effettuare regolarmente un nuovo deployment di Kali, è molto utile tenere traccia di queste modifiche.

### 11.2.4. Valutazione della candidatura

Mentre la maggior parte delle valutazioni ha un ambito ampio, la valutazione applicativa è una specializzazione focalizzata su una singola applicazione. Questo tipo di valutazioni sta diventando sempre più comune a causa della complessità delle applicazioni critiche utilizzate dalle organizzazioni, molte delle quali sono sviluppate internamente. Una valutazione applicativa viene solitamente aggiunta a una valutazione più ampia, a seconda delle necessità.
Le candidature che possono essere valutate in questo modo includono, a titolo esemplificativo ma non esaustivo:

- Applicazioni web: Essendo la superficie di attacco più comune rivolta verso l'esterno, le applicazioni web rappresentano ottimi bersagli semplicemente perché sono accessibili. Spesso, le valutazioni standard individuano problemi di base nelle applicazioni web, tuttavia un'analisi più mirata è spesso utile per identificare i problemi relativi al flusso di lavoro dell'applicazione. Il meta-pacchetto *kali-tools-web* contiene diversi strumenti utili per queste valutazioni.

- Applicazioni desktop compilate: il software per server non è l'unico obiettivo; anche le applicazioni desktop costituiscono un'ottima superficie di attacco. Negli anni passati, molte applicazioni desktop, come i lettori PDF o i programmi video basati sul web, sono state oggetto di numerosi attacchi, il che le ha costrette a evolversi.

21https://www.offensive-security.com/kali-linux/kali-rolling-iso-of-doom/ 22https://www.offensive-security.com/kali-linux/kali-linux-recipes/

Machine Translated by Google

Tuttavia, esiste ancora un gran numero di applicazioni desktop che, se analizzate correttamente, presentano numerose vulnerabilità.

- Applicazioni mobili: Con la crescente popolarità dei dispositivi mobili, le applicazioni mobili diventeranno sempre più una superficie di attacco standard in molte valutazioni. Si tratta di un obiettivo in rapida evoluzione e le metodologie in questo ambito sono in continua maturazione, il che porta a nuovi sviluppi praticamente ogni settimana. Gli strumenti relativi all'analisi delle applicazioni mobili sono disponibili nella categoria "Reverse Engineering " del menu.

Le valutazioni delle applicazioni possono essere condotte in diversi modi. Ad esempio, è possibile eseguire uno strumento automatizzato specifico per l'applicazione nel tentativo di identificare potenziali problemi. Questi strumenti utilizzeranno una logica specifica per l'applicazione nel tentativo di identificare problemi sconosciuti, anziché basarsi semplicemente su un insieme di firme note. Questi strumenti devono avere una comprensione integrata del comportamento dell'applicazione. Un esempio comune potrebbe essere uno scanner di vulnerabilità per applicazioni web come Burp Suite23, mirato a un'applicazione che dapprima identifica vari campi di input e poi invia comuni attacchi di SQL injection a questi campi, monitorando al contempo la risposta dell'applicazione per rilevare eventuali segnali di un attacco riuscito.

In uno scenario più complesso, la valutazione di un'applicazione può essere condotta in modo interattivo, sia in modalità *black box* che *white box .*

- Valutazione a scatola nera: lo strumento (o valutatore) interagisce con l'applicazione senza conoscenze o permessi speciali, al di là di quelli di un utente standard. Ad esempio, nel caso di un'applicazione web, il valutatore potrebbe avere accesso solo alle funzioni e alle caratteristiche disponibili per un utente non autenticato. Gli account utente utilizzati sarebbero account che un utente generico può creare autonomamente. Ciò impedirebbe all'attaccante di esaminare funzionalità accessibili solo agli utenti che necessitano della creazione di un account da parte di un amministratore.

- Valutazione White Box: Lo strumento (o il valutatore) avrà spesso pieno accesso al codice sorgente, accesso amministrativo alla piattaforma su cui è in esecuzione l'applicazione e così via. Ciò garantisce che venga effettuata una revisione completa e approfondita di tutte le funzionalità dell'applicazione, indipendentemente da dove risiedano tali funzionalità all'interno dell'applicazione. Il compromesso è che la valutazione non simula in alcun modo un'attività dannosa reale.

Ovviamente esistono diverse sfumature intermedie. In genere, il fattore determinante è l'obiettivo della valutazione. Se l'obiettivo è identificare cosa accadrebbe nel caso in cui l'applicazione subisse un attacco esterno mirato, una valutazione black box sarebbe probabilmente la soluzione migliore. Se invece l'obiettivo è identificare ed eliminare il maggior numero possibile di vulnerabilità di sicurezza in un periodo di tempo relativamente breve, un approccio white box potrebbe essere più efficiente.

In altri casi, si può adottare un approccio ibrido in cui il valutatore non ha pieno accesso al codice sorgente dell'applicazione sulla piattaforma che la esegue, ma gli account utente vengono forniti da un amministratore per consentire l'accesso al maggior numero possibile di funzionalità dell'applicazione.

23https://portswigger.net/burp

Machine Translated by Google

Kali è una piattaforma ideale per tutti i tipi di valutazioni di applicazioni. Con un'installazione predefinita, è disponibile una gamma di scanner specifici per le applicazioni. Per valutazioni più avanzate, esistono diversi strumenti, editor di codice sorgente e ambienti di scripting. Puoi trovare l' applicazione Web24 e Ingegneria inversa25 sezioni degli strumenti Kali26 sito web utile.

## 11.3. Formalizzazione della valutazione

Con l'ambiente Kali pronto e il tipo di valutazione definito, sei quasi pronto per iniziare a lavorare. L'ultimo passo consiste nel formalizzare il lavoro da svolgere. Questo è di fondamentale importanza, poiché definisce le aspettative relative al lavoro e ti autorizza a svolgere un'attività che altrimenti potrebbe essere illegale. Tratteremo questo argomento a grandi linee, ma si tratta di un passaggio molto complesso e importante, quindi è consigliabile consultare l'ufficio legale della tua organizzazione per ricevere assistenza.

Nell'ambito del processo di formalizzazione, sarà necessario definire le regole di ingaggio per il lavoro.
Ciò comprende elementi quali:

- Con quali sistemi è consentito interagire? È importante assicurarsi di non interferire accidentalmente con elementi critici per le operazioni aziendali. • In quale momento della giornata e

  in quale finestra temporale è consentito effettuare la valutazione? Alcune organizzazioni preferiscono limitare gli orari in cui è possibile svolgere il lavoro di valutazione.
- Quando si scopre una potenziale vulnerabilità, è consentito sfruttarla? In caso contrario, qual è la procedura di approvazione? Alcune organizzazioni adottano un approccio molto rigoroso a ogni tentativo di sfruttamento, mentre altre preferiscono un approccio più realistico. È opportuno definire chiaramente queste aspettative prima di iniziare il lavoro.
- Se viene scoperto un problema significativo, come dovrebbe essere gestito? A volte le organizzazioni desiderano essere informate immediatamente, altrimenti in genere viene affrontato alla fine della valutazione. nal.
- In caso di emergenza, chi bisogna contattare? È sempre importante sapere chi contattare quando si verifica un problema di qualsiasi tipo.
- Chi verrà a conoscenza dell'attività? Come verrà comunicata? In alcuni casi, le organizzazioni desiderano testare le proprie prestazioni di risposta e rilevamento degli incidenti nell'ambito della valutazione. È sempre una buona idea saperlo in anticipo, in modo da poter decidere se adottare un approccio discreto alla valutazione.
- Quali sono le aspettative al termine della valutazione? Come verranno comunicati i risultati?
  È fondamentale che tutte le parti coinvolte sappiano cosa si aspettano al termine della valutazione. Definire i risultati attesi è il modo migliore per garantire la soddisfazione di tutti al termine del lavoro.

24https://tools.kali.org/category/web-applications 25https://
tools.kali.org/category/reverse-engineering 26https://
tools.kali.org/

Machine Translated by Google

Sebbene non esaustivo, questo elenco fornisce un'idea dei dettagli che dovrebbero essere presi in considerazione. Tuttavia, è importante ricordare che nulla può sostituire una buona rappresentanza legale. Una volta definiti questi elementi, è necessario ottenere l'autorizzazione appropriata per eseguire la valutazione, poiché gran parte dell'attività che si svolgerà nel corso di una valutazione potrebbe non essere legale senza la dovuta autorizzazione da parte di chi ha il potere di rilasciarla.

Detto questo, prima di iniziare il lavoro c'è ancora un ultimo passaggio da compiere: la validazione. Non fidatevi mai dell'ambito di intervento che vi viene fornito, verificatelo sempre. Utilizzate diverse fonti di informazione per confermare che i sistemi inclusi nell'ambito di intervento siano effettivamente di proprietà del cliente e che siano gestiti dal cliente stesso. Con la diffusione dei servizi cloud, un'organizzazione potrebbe dimenticare di non essere effettivamente proprietaria dei sistemi che le forniscono il servizio. Potreste scoprire di dover ottenere un'autorizzazione speciale da un fornitore di servizi cloud prima di iniziare il lavoro. Inoltre, verificate sempre i blocchi di indirizzi IP. Non date per scontato che un'organizzazione presuma di possedere interi blocchi IP, anche se li considera obiettivi validi. Ad esempio, abbiamo visto casi di organizzazioni che richiedevano una valutazione di un intero intervallo di indirizzi di rete di classe C quando, in realtà, possedevano solo un sottoinsieme di tali indirizzi. Attaccando l'intero spazio di indirizzi di classe C, avremmo finito per attaccare i vicini di rete dell'organizzazione. La sottocategoria Analisi OSINT del menu Raccolta informazioni contiene una serie di strumenti che possono aiutarti in questa convalida
processo.

## 11.4. Tipi di attacchi

Una volta avviato il lavoro, quali sono alcuni dei tipi specifici di attacchi che condurrete? Ogni tipo di vulnerabilità27 Ogni vulnerabilità presenta tecniche di sfruttamento specifiche. Questa sezione tratterà le diverse classi di vulnerabilità con cui avrete a che fare più frequentemente.

Indipendentemente dalla categoria di vulnerabilità che stai esaminando, Kali rende facile trovare questi strumenti ed exploit. Il menu di Kali sulla tua interfaccia utente grafica è suddiviso in categorie per aiutarti a trovare più facilmente lo strumento giusto. Inoltre, il sito web Kali Tools28 Contiene un elenco completo dei vari strumenti disponibili in Kali, organizzati per categoria e taggati per una facile consultazione. Ogni voce include informazioni dettagliate sullo strumento e un esempio di utilizzo.

### 11.4.1. Negazione del servizio

Gli attacchi Denial of Service sfruttano una vulnerabilità per causare un'interruzione del servizio, spesso mandando in crash il processo vulnerabile. La categoria Stress Testing del menu di Kali Linux contiene diversi strumenti per questo scopo.

Quando molte persone sentono il termine "attacco denial of service", pensano immediatamente agli attacchi di consumo di risorse che vengono inviati da più fonti contemporaneamente contro un singolo obiettivo.

27https://www.cvedetails.com/vulnerabilities-by-types.php 28https://
tools.kali.org/tools-listing

Machine Translated by Google

sarebbe un attacco di negazione del servizio *distribuito* , o DDoS. Questo tipo di attacchi raramente fa parte di un valutazione professionale della sicurezza.

Invece, un singolo attacco di negazione del servizio è il più delle volte il risultato di un tentativo improprio di sfruttare una vulnerabilità. Se un autore di exploit rilascia una versione parzialmente funzionante o una prova di concetto (PoC) codice e viene utilizzato nel campo, questo potrebbe creare una condizione di negazione del servizio. Anche un exploit correttamente codificato potrebbe funzionare solo in circostanze molto specifiche ma causare una negazione del servizio in caso di circostanze minori. Potrebbe sembrare che la soluzione sia utilizzare solo codice di exploit sicuro e testato, o per scriverne uno proprio. Anche con questa soluzione non ci sono garanzie e questo limita fortemente il valutatore, causando vincoli indebiti, che si traducono in una valutazione inferiore. Invece, la chiave è compromesso. Evita il codice PoC e gli exploit non testati sul campo e assicurati sempre che un avvocato abbia hai coperto altri imprevisti.

In genere, gli attacchi denial of service non vengono lanciati intenzionalmente. La maggior parte delle vulnerabilità automatizzate gli strumenti dichiareranno le vulnerabilità di negazione del servizio come a rischio inferiore a causa del fatto che, sebbene tu possa rimuovere un servizio dal funzionamento, quel servizio non può essere sfruttato per l'esecuzione di codice. Tuttavia, È importante ricordare che non tutti gli exploit vengono rilasciati pubblicamente e una vulnerabilità di negazione del servizio può mascherare una minaccia più profonda e grave. Un exploit di esecuzione di codice per una nota negazione del servizio Il servizio potrebbe esistere ma non essere pubblico. Il punto è prestare attenzione alle vulnerabilità di negazione del servizio. e incoraggiate i vostri clienti ad applicare le patch indipendentemente dal loro livello di minaccia (spesso basso).

### 11.4.2. Corruzione della memoria

Un danneggiamento della memoria si verifica quando una posizione all'interno dello spazio di memoria di un processo viene modificata accidentalmente a causa di errori di programmazione. I bug di danneggiamento della memoria di solito portano a un comportamento imprevedibile del programma, tuttavia in molti casi, questi bug consentono la manipolazione della memoria del processo in modo tale che il flusso di esecuzione del programma possa essere controllato, consentendo all'attaccante di definire attività.

Questi attacchi vengono generalmente definiti buffer overflow, sebbene questo termine sia una semplificazione eccessiva. Le tipologie più comuni di corruzione della memoria sono molto diverse tra loro e richiedono tattiche e tecniche specifiche per essere sfruttate con successo.

- Overflow del buffer dello stack: quando un programma scrive più dati in un buffer sullo stack di quanti ce ne siano c'è spazio disponibile per esso, la memoria adiacente può essere danneggiata, causando spesso il programma incidente.
- Corruzione dell'heap: la memoria heap viene allocata in fase di esecuzione e di solito contiene dati provenienti da programma in esecuzione. Le corruzioni dell'heap si verificano manipolando i dati per sovrascriverli tramite la lista concatenata di puntatori alla memoria heap.
- Overflow di interi: questi overflow si verificano quando un'applicazione tenta di creare un valore numerico che non può essere contenuto all'interno dello spazio di archiviazione assegnato.
- Stringa di formato: Quando un programma accetta input dall'utente e lo formatta senza controllarlo, le posizioni di memoria possono essere rivelate o sovrascritte, a seconda dei token di formato utilizzati.

Machine Translated by Google

### 11.4.3. Vulnerabilità Web

Poiché i siti web moderni non sono più pagine statiche, ma generate dinamicamente per l'utente, un sito web medio risulta piuttosto complesso. Le vulnerabilità web sfruttano questa complessità per attaccare la logica di generazione delle pagine lato server o la presentazione del sito al visitatore.

Questo tipo di attacchi sono estremamente comuni, poiché molte organizzazioni hanno raggiunto il punto in cui hanno pochissimi servizi rivolti all'esterno. Due dei tipi di attacco alle applicazioni web più diffusi29 sono SQL injection e cross-site scripting (XSS).

- Iniezione SQL: questi attacchi sfruttano applicazioni programmate in modo errato che non sanificano correttamente l'input dell'utente, consentendo l'estrazione di informazioni dal database o persino il completo controllo del server.
- Cross-site scripting: come per l'SQL injection, gli attacchi XSS derivano da una sanificazione impropria dell'input dell'utente, consentendo agli aggressori di manipolare l'utente o il sito per eseguire codice nel contesto della propria sessione del browser.

Le applicazioni web complesse, ricche di funzionalità e articolate sono molto comuni e rappresentano una superficie di attacco ideale per i malintenzionati. Troverete un'ampia gamma di strumenti utili nella categoria di menu Analisi delle applicazioni web e nel metapackage *kali-tools-web* .

### 11.4.4. Attacchi alle password

Gli attacchi alle password sono attacchi al sistema di autenticazione di un servizio. Questi attacchi vengono spesso suddivisi in attacchi online e attacchi offline, come spiegato nella sezione " Attacchi alle password ". In un attacco online, si tenta di utilizzare più password contemporaneamente contro un sistema in esecuzione. In un attacco offline, invece, si ottengono i valori crittografati o sottoposti a hashing delle password e l'attaccante tenta di ricavarne i valori in chiaro.
La protezione contro questo tipo di attacco risiede nel fatto che il processo è computazionalmente oneroso, limitando il numero di tentativi al secondo che è possibile effettuare. Tuttavia, esistono delle soluzioni alternative, come l'utilizzo di unità di elaborazione grafica (GPU) per accelerare il numero di tentativi. Il metapackage *kali-tools-gpu* contiene diversi strumenti che sfruttano questa potenza.

Nella maggior parte dei casi, gli attacchi alle password prendono di mira le password predefinite fornite dai fornitori. Poiché si tratta di valori ben noti, gli aggressori cercano questi account predefiniti, sperando di avere fortuna. Altri attacchi comuni includono gli attacchi a dizionario personalizzati, in cui viene creato un elenco di parole adattato all'ambiente di destinazione e quindi viene condotto un attacco online alle password contro account comuni, predefiniti o noti, tentando ogni parola in sequenza.

29https://owasp.org/www-project-top-ten/

Machine Translated by Google

In una valutazione, è fondamentale comprendere le potenziali conseguenze di questo tipo di attacco. Innanzitutto, spesso generano un elevato rumore di fondo a causa dei ripetuti tentativi di autenticazione. In secondo luogo, questi attacchi possono spesso portare al blocco dell'account dopo un numero eccessivo di tentativi non validi effettuati contro un singolo account. Infine, l'esecuzione di questi attacchi è spesso piuttosto lenta, il che rende difficile l'utilizzo di un elenco completo di parole chiave.

### 11.4.5. Attacchi lato client

La maggior parte degli attacchi viene condotta contro i server, ma poiché i servizi sono diventati più difficili da attaccare, sono stati scelti obiettivi più facili. Gli attacchi lato client ne sono una conseguenza, in cui un aggressore prende di mira le varie applicazioni installate sulla workstation di un dipendente all'interno di un'organizzazione bersaglio. La categoria di menu Strumenti di ingegneria sociale contiene diverse applicazioni eccellenti che possono aiutare a condurre questo tipo di attacchi.

Questo tipo di attacco veniva comunemente sfruttato da Flash, Acrobat Reader e Java nei primi anni 2000. Attualmente, il metodo più diffuso è quello delle applicazioni HTML (HTA). Nei casi sopra descritti, gli aggressori cercano di indurre la vittima a visitare una pagina web dannosa. Queste pagine contengono codice specifico in grado di sfruttare vulnerabilità nelle applicazioni lato client o di ingannare l'utente, consentendogli così di eseguire codice dannoso sul sistema della vittima.

Gli attacchi lato client sono incredibilmente difficili da prevenire e richiedono un'attenta formazione degli utenti, aggiornamenti costanti delle applicazioni e controlli di rete per mitigare efficacemente il rischio.

## 11.5. Riepilogo

In questo capitolo, abbiamo esaminato brevemente il ruolo di Kali nel campo della sicurezza informatica. Abbiamo discusso dell'importanza di un'installazione pulita e funzionante e dell'utilizzo della crittografia prima di iniziare a lavorare sul campo, al fine di proteggere le informazioni dei clienti, e dell'importanza di una rappresentanza legale per tutelare gli interessi vostri e dei vostri clienti.

I componenti della triade CIA (riservatezza, integrità, disponibilità) sono gli elementi principali su cui concentrarsi per proteggere un sistema durante le fasi standard di implementazione, manutenzione o valutazione. Questa base concettuale vi aiuterà a identificare i componenti critici dei vostri sistemi e a quantificare l'impegno e le risorse da investire per risolvere i problemi individuati.

Abbiamo discusso di diverse tipologie di vulnerabilità, tra cui l'inclusione di file, l'iniezione SQL, gli overflow del buffer e le condizioni di gara.

L'accuratezza delle firme è fondamentale per ottenere risultati utili nella valutazione delle vulnerabilità. Maggiore è la quantità di dati forniti, maggiori sono le probabilità di ottenere risultati accurati da una scansione automatizzata basata sulle firme, ed è per questo che le scansioni autenticate sono spesso così diffuse.

Machine Translated by Google

Poiché gli strumenti automatizzati utilizzano un database di firme per rilevare le vulnerabilità, qualsiasi minima deviazione da una firma nota può alterare il risultato e, di conseguenza, la validità della vulnerabilità rilevata.

Abbiamo inoltre discusso i quattro tipi di valutazione: la *valutazione della vulnerabilità, il test di conformità, il penetration test tradizionale* e la *valutazione dell'applicazione.* Sebbene ogni tipo di valutazione si avvalga di un set di strumenti di base, molti strumenti e tecniche si sovrappongono.

La valutazione delle vulnerabilità è relativamente semplice rispetto ad altri tipi di valutazione e spesso consiste in un inventario automatizzato dei problemi rilevati all'interno di un ambiente target. In questa sezione, abbiamo discusso del fatto che una vulnerabilità è un difetto che, se sfruttato, compromette la riservatezza, l'integrità o la disponibilità di un sistema informativo. Poiché si basa sulle firme, questo tipo di valutazione si affida a firme accurate e può presentare falsi positivi e negativi. Gli strumenti principali per questo tipo di valutazione si trovano nelle categorie di menu "Analisi delle vulnerabilità" e "Strumenti di sfruttamento " di Kali Linux.

I test di conformità si basano su requisiti imposti da enti governativi e di settore (come PCI DSS, DISA STIG e FISMA), che a loro volta si fondano su un framework di conformità. Questo test inizia solitamente con una valutazione delle vulnerabilità.

Un penetration test tradizionale è una valutazione approfondita della sicurezza, progettata per migliorare il livello di sicurezza complessivo di un'organizzazione sulla base di specifiche minacce reali. Questo tipo di test prevede diverse fasi (rispecchiate dalla struttura dei menu di Kali Linux) e culmina nello sfruttamento delle vulnerabilità e nel passaggio di accesso ad altre macchine e reti all'interno dell'area target.

Le valutazioni delle applicazioni (generalmente di tipo white-box o black-box) si concentrano su una singola applicazione e utilizzano strumenti specializzati, come quelli presenti nelle categorie di menu Analisi delle applicazioni web, Valutazione dei database, Reverse engineering e Strumenti di sfruttamento .

Sono stati discussi diversi tipi di attacchi, tra cui: il Denial of Service (DoS), che interrompe il funzionamento di un'applicazione rendendola inaccessibile; la corruzione della memoria, che porta alla manipolazione della memoria di processo, consentendo spesso a un aggressore l'esecuzione di codice dannoso; gli attacchi web, che prendono di mira i servizi web utilizzando tecniche come l'iniezione SQL e gli attacchi XSS; e gli attacchi alle password, che spesso sfruttano gli elenchi di password per attaccare le credenziali di accesso ai servizi.

Machine Translated by Google

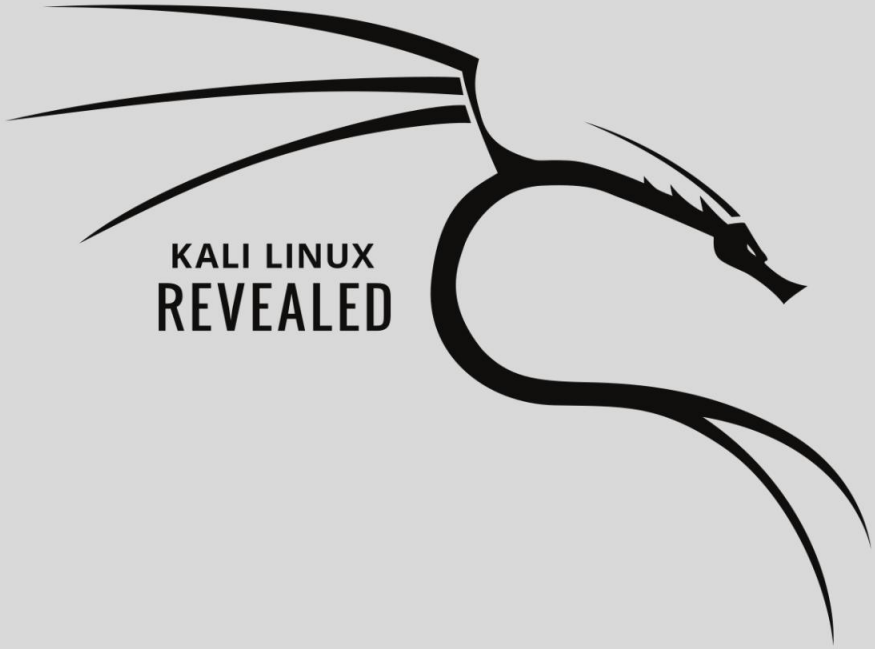


Machine Translated by Google

**Parole chiave**

**Cambiamenti costanti**
**Certificazioni**

**Corsi di formazione**



Machine Translated by Google

Capitolo

# Conclusione: Il **12**

## La strada da percorrere

Contenuto

Tenersi al passo con i cambiamenti 306 Mettere in mostra le proprie nuove conoscenze 306 Andando oltre 307

Machine Translated by Google

Congratulazioni! Speriamo che ora tu abbia maggiore familiarità con il tuo sistema Kali Linux e che non abbia timore di utilizzarlo per qualsiasi esperimento ti venga in mente. Hai scoperto le sue funzionalità più interessanti, ma conosci anche i suoi limiti e i vari modi per aggirarli.

Se non hai ancora messo in pratica tutte le funzionalità, tieni questo libro a portata di mano come riferimento e rinfrescati la memoria quando stai per provare una nuova funzionalità. Ricorda che non c'è niente di meglio della pratica (e della perseveranza) per sviluppare nuove competenze. Prova con più impegno! come afferma Offensive Security.

## 12.1. Tenersi al passo con i cambiamenti

Con una distribuzione in continua evoluzione come *il kali-rolling,* alcune parti del libro diventeranno necessariamente obsolete. Faremo del nostro meglio per mantenerlo aggiornato (almeno per la versione online2 ) ma per la maggior parte abbiamo cercato di fornire spiegazioni generiche che dovrebbero essere utili per molto tempo a venire.

Detto questo, dovresti essere pronto ad accogliere i cambiamenti e a trovare soluzioni a qualsiasi problema che possa presentarsi. Con una migliore comprensione di Kali Linux e del suo rapporto con Debian, potrai fare affidamento sia sulla comunità Debian che su quella Kali e sulle loro numerose risorse (segnalatori di bug, forum, mailing list, ecc.) quando ti troverai in difficoltà.

Non abbiate paura di segnalare i bug (vedi sezione 6.3, "Come inviare una buona segnalazione di bug" [pagina 134])! Se siete come me, nel tempo necessario per completare i passaggi per inviare una buona segnalazione di bug (e ci vuole un po' di tempo), avrete risolto il problema o almeno trovato una valida soluzione alternativa. E segnalando il bug, aiuterete anche altri utenti che sono stati colpiti dal problema.

## 12.2. Mettere in mostra le nuove conoscenze acquisite

Sei orgoglioso delle tue nuove competenze su Kali Linux? Vuoi assicurarti di ricordare gli aspetti davvero importanti? Se hai risposto sì a una di queste domande, allora dovresti valutare la possibilità di candidarti al programma di certificazione Kali Linux Certified Professional.

Si tratta di una certificazione completa che ti garantirà la capacità di installare e utilizzare Kali Linux in numerosi scenari di utilizzo realistici. È un ottimo elemento da aggiungere al tuo curriculum e dimostra anche che sei pronto a fare un ulteriore passo avanti.

[1] https://www.offensive-security.com/offsec/say-try-harder/
[2] https://kali.training/

Machine Translated by Google

## 12.3. Andare oltre

Questo libro ti ha insegnato molte cose che ogni utente di Kali Linux dovrebbe sapere, ma abbiamo dovuto fare delle scelte difficili per mantenerlo breve, e ci sono molti argomenti che non sono stati trattati.

### 12.3.1. Verso l'amministrazione del sistema

Se desideri saperne di più sull'amministrazione di sistema, ti consigliamo vivamente di consultare il Manuale dell'amministratore di Debian:

ÿ https://debian-handbook.info/get/

Troverete numerosi capitoli supplementari che trattano i servizi Unix più comuni, che abbiamo completamente tralasciato in questo libro. Anche per i capitoli riutilizzati nel libro su Kali, troverete molti suggerimenti aggiuntivi, in particolare sul sistema di gestione dei pacchetti (che viene anche trattato in modo più approfondito al suo livello più elementare).

Il libro su Debian presenta ovviamente in modo più approfondito la comunità Debian e il modo in cui è organizzata. Sebbene questa conoscenza non sia fondamentale, è davvero utile quando si deve interagire con i collaboratori di Debian, ad esempio tramite segnalazioni di bug.

### 12.3.2. Verso il penetration testing

Probabilmente avrete già notato che questo libro non vi ha insegnato il penetration testing. Tuttavia, le nozioni apprese sono comunque importanti. Ora siete pronti a sfruttare appieno la potenza di Kali Linux, il miglior framework per il penetration testing. Inoltre, possedete le competenze Linux di base necessarie per partecipare ai corsi di formazione di Offensive Security.

Se ritieni di non essere ancora pronto per un corso a pagamento, puoi iniziare seguendo Metasploit Unleashed[3] Formazione online gratuita. Metasploit è uno strumento di penetration testing molto popolare e devi conoscerlo se vuoi davvero imparare questa tecnica.

Il passo logico successivo sarebbe quindi quello di seguire il Penetration Testing con Kali Linux[4] Corso online che apre la strada alla famosa certificazione "Offensive Security Certified Professional".
Questo corso online può essere seguito al proprio ritmo, ma la certificazione consiste in un difficile test pratico di penetrazione di 24 ore, che si svolge in una rete VPN isolata.

Sei pronto ad accettare la sfida?

[3] https://www.offensive-security.com/metasploit-unleashed/
[4] https://www.offensive-security.com/courses-and-certifications/

Machine Translated by Google

# Indice


_

.config, 239 .d,

200 .htaccess,

120 /dev,

48 /etc/apt/apt.conf.d/, 200 /etc/apt/

preferences, 202 /etc/apt/sources.list,

178 /etc/apt/trusted.gpg.d/, 208 /

etc/group, 112 /etc/gshadow, 112 /etc/

network/interfaces,

109 /etc/passwd, 112 /etc/

salt/minion, 261 /etc/shadow, 112 /etc/

ssh/sshd_config, 115 /

proc, 48 /sys, 48 /var/lib/dpkg/,

217 /var/www/html/, 118

CPU a 32 bit, 16 CPU a 64 bit, 16

UN

a2dismod, 118

a2enmod, 118

a2ensite, 119

ACCETTA,

account 161

- creazione, 112
- disabilitazione,
- 113 modifica, 113

attività, monitoraggio, 168

aggiungi un utente a un gruppo, 112

aggiungigruppo, 113

aggiungiutente, 112

Strumento di gestione pacchetti

avanzato, 177 aide (pacchetto Debian), 170

AllowOverride, direttiva Apache, 119, 120 vulnerabilità di

analisi, 6

- applicazione web, 6
- ansible, 261

Apache, 118

- direttive, 119

Direttive Apache, 121

valutazioni delle applicazioni, 295

raccolta di

- applicazioni, 10
- menu, 6

applicazione di una patch,

233 a proposito, 128

APT, 177

- configurazione, 200
- visualizzazione intestazione,
- 191 configurazione iniziale, 84
- interfacce, 196
- ricerca pacchetti, 191
- pinning, 202
- preferenze, 202 apt,

181 apt

build-dep, 231 apt dist-

upgrade, 185 apt full-upgrade,

185 apt install, 183 apt

purge, 186

Machine Translated by Google

apt remove, 186
apt search, 191
apt show, 191
apt source, 229
apt update, 181
apt upgrade, 184
apt-cache, 191
apt-cache dumpavail, 192 apt-
cache pkgnames, 192 apt-
cache policy, 192 apt-
cache search, 191 apt-
cache show, 191 apt-
cdrom, 178 apt-
get, 181 apt-
get dist-upgrade, 185 apt-get
install, 183 apt-get
purge, 187 apt-get
remove, 186 apt-get
update, 181 apt-get
upgrade, 184 apt-key,
208 apt-mark
auto, 205 apt-mark
manual, 205 apt-xapian-
index, 192 apt.conf.d/, 200
aptitude, 181
aptitude dist- , 196
upgrade, 185 aptitude full-
upgrade, 185 aptitude install,
183 aptitude markauto,
205 aptitude purge, 187
aptitude remove, 186
aptitude safe-upgrade,
184 aptitude search, 191 aptitude
show, 191 aptitude
unmarkauto, 205
aptitude update, 181 aptitude
why, 205 architecture

supporto multi-arco, 206
Installazioni ARM, 98

valutazione
applicazione, 295
scatola nera, 296
formalizzazione, 297
vulnerabilità, 288
scatola bianca,
296
attacchi lato client,
301 database,
6 negazione del servizio,
298 corruzione della memoria,
299 password,, 300
7 tipi di, 298
web, 300
wireless, 7
audit, sicurezza, 5
autenticazione
pacchetto autenticazione, 208
AuthName, direttiva Apache, 120
AuthType, direttiva Apache, 120
AuthUserFile, direttiva Apache, 120
installazione automatica, 95
pacchetti installati automaticamente, 205
effetto valanga, 169 axi-
cache, 192

**B**

processo di background, 57
BackTrack, XXI , 2
bash curly brackets, 168 bash
trick, 168 bg, 57

BIOS, 24
file di dispositivo a blocchi,
49 preimpostazioni di
avvio, 96 schermata
di avvio, 67 chiave USB
avviabile, 19 bootloader, 85
BOOTP, 258
Interruzioni, campo intestazione,
214 dipendenza interrotta, 195
Bruce Schneier, 156

Machine Translated by Google

attacchi di forza bruta, 300
buffer
overflow, 299
buffer di ricezione, 162
segnalazione di
bug, 134 bugs.kali.org,
138 dipendenze di compilazione, installazione,
231 opzioni di
compilazione, 234 Build-
Depends,
231 creazione di un'immagine ISO
live personalizzata, 241 un pacchetto, 236

**C**

cache, proxy, 84 cat,
56 cd,
52
cdimage.kali.org, 14, 181 cdrom
preseed, 96
certificazione, 306
change, 113
chain, 160
file di registro delle
modifiche, 271
changelog.Debian.gz, 130 file
di dispositivo a caratteri,
49 checksecurity ,
171
checksum,
220 chef,
261 chfn,
113
chgrp, 58 chmod,
58 scelta del paese,
68 della
lingua, 67
chown , 58
chroot, 245 chsh, 113 attacchi
lato client, 301 cluster, cluster PostgreSQL,
116, 117 riga di
comando, 51
community, 132 confronto di versioni, 190
compilazione di
un kernel, 237 test
di penetrazione di conformità, 292
componente (di un repository), 179 file di
configurazione,
220 file di

riservatezza, 88 configurazione,
script debconf,
220 configurazione creazione di pacchetti di

configurazione, 269 file, 220
configurazione iniziale
di APT, 84 gestione, 261 rete
DHCP, 71
statico, 71
del kernel, 239
configurazione del programma, 114
conflitti, 214
Conflitti, campo di intestazione,
214 contrib, sezione, 179
controllo, 211
file di controllo, 272
somma di controllo,
169 control.tar.gz, 217
copia, immagine ISO, 19
copyright, 131 file
di copyright, 271
selezione del paese, 68
cp, 53
createdb, 116
createuser, 116
creazione
di un database PostgreSQL, 116 di un
utente PostgreSQL, 116 di
gruppi, 113 di
account utente, 112
credenziali, default, 159 cross-
site scripting (XSS), 300 cryptsetup,
248 nuke password,
250

Machine Translated by Google

parentesi graffe, 168
personalizzazione dell'immagine ISO live, 241

Valutazione del database **D ,** 6
server di database, 115
dch, 232
dd, 22
debconf, 220
debconf-get, 101
debconf-get-selections, 98 debconf-
set, 101 DEBEMAIL,
270 DEBFULLNAME,
270 Relazione di Debian
con Kali
Linux, 4 Manuale dell'amministratore di
Debian, 307 Linee guida del software libero di Debian,
5 Debian GNU/Linux, 2 Politica di Debian, 5
debian-archive-keyring, 208
debian-kernel-
handbook, 238 debian/changelog, 232,
271 debian/control, 272 debian/copyright,
271 debian/patches, 230 debian/
rules, 234, 273 debuild,
237 password predefinite, 159
default.target, 122
eliminazione di un gruppo,
113 delgroup,
113 negazione del servizio,
298 dipendenza, 212
Dipende, campo di intestazione,
212 ambiente
desktop, 3 scelta durante la
creazione di ISO live,
242 desktop-base, 269 rilevamento
delle modifiche sul filesystem,
169 file di dispositivo, 49 df, 60 dh-make, 270
dh_install, 273
DHCP, 258
attacchi a dizionario, 300
direttive, Apache, 119, 121
DirectoryIndex, direttiva Apache, 120 disabilita
un account, 113
preimpostazione disco, 96
Dischi (programma), 21
diskutil, 23
distribuzione, Linux, 2 dm-
crypt, 89 dmesg,
60
DNAT, 161
dnsmasq, 258
documentazione, 128, 130
download
Immagine ISO,
14 le sorgenti, 229
dpkg, 176
database, 217
dpkg --verify, 169
operazione interna, 219 dpkg-
buildpackage, 236 dpkg-deb,
236 dpkg-source
--commit, 233 unità, unità USB, 19

DROP, 161
dropdb, 116
dropuser, 116
dual boot, 87

**E**

eco, 54
editor, 56
partizione crittografata, 88
persistenza crittografata, 248 reverse
engineering, 7
social
engineering, 7
Migliora il campo di intestazione,
ambiente 214
variabile d'ambiente, 54

Machine Translated by Google

ExecCGI, direttiva Apache, 120 moduli di
esecuzione, salt, 262 esecuzione,
destra, 57 sperimentale,
203
Spiegazione, 204
strumenti di sfruttamento, 7

**F**

fail2ban, 158
funzionalità, 8
fg, 57
file
    riservatezza, 88 file di
    configurazione, 220 file system,
49 gerarchia del
file system,
    54 regola di filtro,
160, 163 trova, 56 impronta
digitale,
169 firewall, 159
FollowSymLinks,
direttiva Apache, 120 forensica, 7 modalità, 8
formalizzazione
    della
valutazione, 297 formatta disco, 49 forum, 132
forums.kali.org, 132
FORWARD,
160 gratuito, 60 Freenode,
133 fwbuilder, 166

**G**

ottieni i sorgenti, 229
getent, 112 git
clone, 230
Problemi su GitHub, 148
GNOME, 3
gnome-disk-utility, 21 gnome-
system-monitor, 168
GNU
    Informazioni,
130 gpasswd,
113 Chiave
GPG, 17 graphical.target,
122 grep,
56
    gruppo aggiungi un
        utente, 112
        modifica, 113
        creazione, 113
        eliminazione, 113
        di volumi, 89
proprietario, 57
groupmod,
113 GRUB, 85 gui-
apt-key, 210 partizionamento guidato, 76

**H**

rilevamento hardware, 61
corruzione heap, 299
cronologia di Kali Linux, 2
HOME, 55
directory home, 55 host,
host virtuale, 118 htpasswd,
121 proxy HTTP,
84 server HTTP, 118
http.kali.org, 180
HTTPS, 118 Hyper-V,
24

**I**

ICMP, 162
id, 60, 113
ifupdown, 109
impersonificazione, 7
Include, direttiva Apache, 120
incompatibilità, 214
Indici, direttiva Apache, 120 info, 130
raccolta
informazioni, 6 initrd preseed, 96

Machine Translated by Google

INPUT, 160
installazione, 66
automatico, 95
delle dipendenze di compilazione, 231 su dispositivi ARM, 98 installazione del pacchetto, , 183 182 risoluzione dei problemi, 99 non presidiato, 95 precaricamento del programma di installazione, 96 overflow degli interi, 299
Protocollo dei messaggi di controllo Internet, 162 ip6tables, , 163 159 iptables, 159, 163
Canale IRC, 133
isc-dhcp-server, 258

Autenticazione dell'immagine
ISO, 17
avvio, 24
copia, 19 build personalizzata, 241
download, 14 mirror, 14 varianti, 16

Rivista **J ,** 60
journalctl, 60

**K**

Kali Linux
comunità, 132
documentazione, 131
download, 14
funzionalità, 8 per iniziare, 14
cronologia, 2 metapackage, 243
politiche, 10
relazione con Debian, 4
repository, 179 kali-archive-keyring, 208 kali-defaults, 269
kali-dev, 4 , 180
kali-linux-* metapacchetti, 243 kali-menu, 269 kali-meta, 269 kali-rolling, 4 kali.org/, 179
docs/, 131 KDE, 3
kernel, 48
compilazione, 237
configurazione, 239
registri, 60 sorgenti, 238
chiave
Chiavi di autenticazione di APT, 209
Chiavetta USB, layout tastiera 19 , 69
uccisioni, 57 conquistatori, 130
KVM, 24

**L**

selezione della lingua, 67
layout, tastiera, 69
meno, 56 libapache-mod-php, 118
Linux, 48
distribuzione, 2
kernel, 2 , 9
sorgenti del kernel, 238 immagine ISO
live, 14 build personalizzata, 241 live-boot, 245 live-build, 241
aggiunta di file, 245
preinstallazione debconf, 244
hook, 245 pacchetti da installare, 243 bootloader loader, 85
LOG, 161
logcheck, 167
logging, 167

Machine Translated by Google

Logical Volume Manager, 89
login, accesso remoto, 115
log
aptitude, 199
dpkg, 194
journal, 60
kernel, 60
monitoring, 167
ls, 52
lsdev , 61
lshw, 61
lspci, 61
lspcmcia, 61
lsusb, 61
LUKS, 89
LVM, 89

Macchina **M ,** macchina virtuale, 24
principale, sezione, 179
crea pacchetto deb, 241
Makefile, 272
man, 128
gestione della
configurazione, 261 dei servizi, 121
pagine del
manuale, 128
pacchetti installati manualmente, 205

maschera dei diritti maschera, 59
MASQUERADE, 161
master boot record, 87
master, salt master, 261
MD5, 169
md5sums, 220
corruzione della memoria,
299 menu, menu delle applicazioni di Kali
Linux, 6 metapackage,
213, 215 kali-linux-
*, 243 metapackages, 85
Metasploit Unleashed, 307
minion, salt minion, 261

specchi, 14, 180
mkdir, 53
mkfs, 49
modifica di un pacchetto, 228
modifica, destra, 57
monitoraggio, 167
attività, 168
file, 170
file di log, 167
altro, 56
mount, 49
punto di mount,
82 Multi-Arch,
206 multi-user.target,
122 MultiViews, direttiva Apache, 120
mv, 53

**N**

netfilter, 159
configurazione di rete, 71, 108 con
ifupdown, 109 con
NetworkManager, 108 con systemd-
network, 110 installazione di rete,
258 preseed di rete, 97 servizi di
rete, 10 protezione, 159
NetworkManager, 108
newgrp, 58, 113
NEWS.Debian.gz, 130 non-
free, sezione, 179
password nuke, 250

**O**

rappresentazione ottale dei diritti, 59
Offensive Security, 2
openssh-server, 115
Opzioni, direttiva Apache, 119
OUTPUT, 160
overflow, buffer, 299
overlay filesystem, 246
proprietario

Machine Translated by Google

gruppo, 57
utente, 57

**P**

controllo
di autenticità del pacchetto, 208 pacchetto binario, 176 build, 236 configurazione, 269 conflitto, 214 ispezione del contenuto, 189 pacchetto Debian, 176 dipendenza, 212 elenco file, 187 elenco intestazioni, 190 incompatibilità, , 183 214 info, 190 installazione, 182 apportare, 211 modifiche, 232 meta-informazioni, 210 modifica, 228 priorità, , 186 202 eliminazione, 187 rimozione, 183 sostituzione, , 191 216 repository, 275 sigillo, 208 ricerca, 188 firma, 208 sorgente di, 178 pacchetto sorgente, 176 stato, 188 decompressione, 182
confronto versione, 190 pacchetto virtuale, 215
tracker pacchetti, 5
Packages.xz, 178 opzioni di compilazione del pacchetto, 234 pacchetti di configurazione, 269 nuova versione upstream, 285 pacchetto
filtro, 159
IP, 159
PAE (estensione indirizzo fisico), 36
partizionato, 247
partizione
crittografata, 88
partizione di
swap, 82 partizionamento, 75 partizionamento guidato, 75
partizionamento
manuale, 79
passwd, 113 password, 113 attacchi, 300 password predefinite, 159 policy, 158 attacchi alle password, 7 patch, 233
applicazione patch, 233 PATH, 53 PCI, 292 conformità
test di penetrazione, 292 tradizionale, 293
test di penetrazione, 5 corso di test di penetrazione, 307
permessi, 57 persistenza, 246 crittografato, 248 archivi multipli, 249 pg_createcluster, 117 pg_ctlcluster, 117 pg_dropcluster, 117
pg_hba.conf, 116
pg_lsclusters, 117
pg_renamecluster, 117
pg_upgradecluster, 117 Chiave PGP, 17 PHP, 118 PID, identificator

Machine Translated by Google

pinfo, 130
ping, 162
pinning, APT pinning, 202 point,
mount point, 82 post
exploitation, 7
PostgreSQL, 115
postinst, 217
postrm, 217
POSTROUTING, 160
predipendenza, 213
Pre-dipende, campo intestazione, 213
preferenze, 202
preinst, 217
prerm, 217
PREROUTING, 160 file
preseed, 97 preseed
debian-installer, 96 priorità priorità
pacchetto,
202 configurazione
programma,
114
Fornisce, campo di intestazione,
215 proxy,
84 cache proxy, 84
ps, 57
puppet, 261
eliminazione di un pacchetto,
187 eliminazione di un
pacchetto, 187 pwd, 52
Avvio PXE, 258

**Q**

QCOW, 30
QEMU, 24

**R**

leggi, giusto, 57
README.Debian, 130
buffer di ricezione, 162
Raccomanda, campo di intestazione, 214
REINDIRIZZAMENTO,
161 reindirizzamento, 56
reinstallazione, 194
RIFIUTA, 161
Release.gpg, 208
accesso remoto, 115
rimozione di un pacchetto, 183
rimozione di un pacchetto, 186
sostituzione, 216
Sostituisce, campo intestazione,
216 segnala un bug,
134 reportbug, 143
strumenti di
segnalazione, 7 repository di
pacchetti, 275
reprepro, 275 Richiedi, direttiva Apache,
121 requisiti, requisiti minimi di installazione, 66 modalità di
ripristino del
programma di installazione, 87
ridimensiona una partizione,
80 recupera le sorgenti, 229
reverse engineering, 7 diritti,
57 maschera,
59
rappresentazione ottale , 59
modello di rischio,
156 valutazioni del
rischio, 290
rkhunter,
171 rm, 53
rmdir, 53 Rolling, Kali Rolling,
3 password di root, 159
RTFM, 128
file delle regole, 273

**S** moduli di esecuzione salt, 262
formule salt, 264 moduli
di stato salt, 265 stati salt, 264
chiave salt, 261
stack salt, 261
samhain, 170
thread di
scansione, 290

Machine Translated by Google

Schneier, Bruce, 156
ricerca di pacchi, 191
sezione
    contrib, 179
    main, 179
    non-free, 179
avvio sicuro, 24
ssh sicuro, 159
messa in
    sicurezza, 156
    un laptop, 158
    un server, 158 servizi di
rete, 159
    valutazioni di
    sicurezza,
    284 audit, 5
policy, 156 file di servizio, file di servizio
systemd, 122 gestione dei
servizi, 121 directory
setgid, 58 setgid,
right, 58 setuid, right, 58
Configurazione,
24 sg, 113
SHA1, 169
SHA256SUMS, 17
shell, 52
restringi una partizione,
80 segnale,
57 firma
    del pacchetto firma, 208
SNAT, 161
sniffing, 7
strumenti di ingegneria sociale, 7
fonte
    di pacchetti, 178
    del kernel Linux, 238
    pacchetto, 176
    recupero, 229
compilazione del
    pacchetto
    sorgente, 236 apportare modifiche, 232
sources.list, 178
Sources.xz, 178
spoofing, 7
SQL injection, 300
SSH, 115
servizio ssh, 159
SSL, 118
moduli di stato, salt, 265
sticky bit, 58
sudo, 109
Suggests, campo di intestazione,
214 swap,
82 partizione di swap,
82 SymLinksIfOwnerMatch, direttiva Apache, 120
synaptic, 196, 199
amministrazione di sistema, 307
sistema, file system, 49
systemctl, 121
systemd, 121
systemd-network, 110
systemd-resolved, 111

**T**

target, target systemd, 122
TFTP, 258
tftpd-hpa, 258
modello di minaccia, 156
TLS, 118
top, 168
tracker
    pacchetto tracker, 5
test di penetrazione tradizionali, 293
training, 306
tripwire, 170
installazioni di risoluzione dei problemi,
99 trust, web of trust, 18
chiave attendibile, 209

**U**

UEFI, 24
ULOG, 161
umask, 59

Machine Translated by Google

uname, 60
installazione automatica, 95
montaggio union, 246
unità, unità systemd, 121
decompressione
del pacchetto binario, 182
problemi
di gestione dell'aggiornamento dopo un aggiornamento, 193 aggiornamento del
sistema, 184 versione upstream, creazione di un nuovo pacchetto, 235
Chiavetta USB, 19
utente
proprietario, 57 creazione utente, 72 spazio utente, 48

**V**

variabile, ambiente, 54 varianti di
immagine ISO live, 242
VDI,
versione 30 , confronto, 190 vigr, 112 vipw, 112 host
virtuale, 118 macchina
virtuale, 24 memoria
virtuale, 82 pacchetto
virtuale, 215
VirtualBox, 24
VMware, 24
volumi
gruppo, 89
volume logico, 89
volume fisico, 89 analisi di
vulnerabilità, 6
valutazioni, 288 lato client, 301
negazione del
servizio, 298 corruzione
della memoria, 299 password, 300 scansioni, 290
tipi di, 298
web, 300

**W**

WantedBy, direttiva systemd, 122
Desideri, direttiva systemd, 122
restrizione dell'accesso web, 121
analisi dell'applicazione web, 6
attacchi web, 300
autenticazione web, 120 rete di
fiducia, 18 server
web, 118
Win32 Disk Imager, 19
attacchi wireless, 7
scrittura, destra, 57

**X**

XDG, 55
Xen, 24
Xfce, 3

**Y**

Yelp, 130

Machine Translated by Google